

	DIN EN ISO/IEC 15408-1	
ICS 35.030	Entwurf	Einsprüche bis 2024-01-24 Vorgesehen als Ersatz für DIN EN ISO/IEC 15408-1:2020-12
Informationssicherheit, Cybersicherheit und Schutz der Privatsphäre – Evaluationskriterien für IT-Sicherheit – Teil 1: Einführung und allgemeines Modell (ISO/IEC 15408-1:2022); Deutsche und Englische Fassung prEN ISO/IEC 15408-1:2023 Information security, cybersecurity and privacy protection – Evaluation criteria for IT security – Part 1: Introduction and general model (ISO/IEC 15408-1:2022); German and English version prEN ISO/IEC 15408-1:2023 Sécurité de l’information, cybersécurité et protection de la vie privée – Critères d’évaluation pour la sécurité des technologies de l’information – Partie 1: Introduction et modèle général (ISO/IEC 15408-1:2022); Version allemande et anglaise prEN ISO/IEC 15408-1:2023 Anwendungswarnvermerk Dieser Entwurf mit Erscheinungsdatum 2023-11-24 wird der Öffentlichkeit zur Prüfung und Stellungnahme vorgelegt. Weil das beabsichtigte Dokument von der vorliegenden Fassung abweichen kann, ist die Anwendung dieses Entwurfs besonders zu vereinbaren. Stellungnahmen werden erbeten — vorzugsweise online im Norm-Entwurfs-Portal von DIN unter www.din.de/go/entwuerfe bzw. für Norm-Entwürfe der DKE auch im Norm-Entwurfs-Portal der DKE unter www.entwuerfe.normenbibliothek.de, sofern dort wiedergegeben; — oder als Datei per E-Mail an nia@din.de möglichst in Form einer Tabelle. Die Vorlage dieser Tabelle kann im Internet unter www.din.de/go/stellungnahmen-norm-entwuerfe oder für Stellungnahmen zu Norm-Entwürfen der DKE unter www.dke.de/stellungnahme abgerufen werden; — oder in Papierform an den DIN-Normenausschuss Informationstechnik und Anwendungen (NIA), 10772 Berlin oder Am DIN-Platz, Burggrafenstr. 6, 10787 Berlin. Es wird gebeten, mit den Kommentaren zu diesem Entwurf jegliche relevanten Patentrechte, die bekannt sind, mitzuteilen und unterstützende Dokumentationen zur Verfügung zu stellen. Gesamtumfang 324 Seiten DIN-Normenausschuss Informationstechnik und Anwendungen (NIA)		

Nationales Vorwort

Der Text von ISO/IEC 15408-1:2022 wurde vom Technischen Komitee ISO/IEC JTC 1 „Information technology“ der Internationalen Organisation für Normung (ISO) erarbeitet und als prEN ISO/IEC 15408-1:2023 durch das Technische Komitee CEN/CLC/JTC 13 „Cybersicherheit und Datenschutz“ übernommen, dessen Sekretariat von DIN (Deutschland) gehalten wird.

Das zuständige nationale Normungsgremium ist der Gemeinschaftsarbeitsausschuss NA 043-04-13 GA „DIN/DKE Gemeinschaftsgremium Cybersecurity“ im DIN-Normenausschuss Informationstechnik und Anwendungen (NIA).

Um Zweifelsfälle in der Übersetzung auszuschließen, ist die englische Originalfassung beigelegt. Die Nutzungsbedingungen für den deutschen Text des Norm-Entwurfes gelten gleichermaßen auch für den englischen Text.

Für die in diesem Dokument zitierten Dokumente wird im Folgenden auf die entsprechenden deutschen Dokumente hingewiesen:

ISO/IEC 18045	siehe	DIN EN ISO/IEC 18045
ISO/IEC 19790	siehe	DIN EN ISO/IEC 19790
ISO/IEC 19896-1	siehe	DIN EN ISO/IEC 19896-1
ISO/IEC 19896-3	siehe	DIN EN ISO/IEC 19896-3
ISO/IEC 27001	siehe	DIN EN ISO/IEC 27001
ISO/IEC 27002	siehe	DIN EN ISO/IEC 27002

Aktuelle Informationen zu diesem Dokument können über die Internetseiten von DIN (www.din.de) durch eine Suche nach der Dokumentennummer aufgerufen werden.

Änderungen

Gegenüber DIN EN ISO/IEC 15408-1:2020-12 wurden folgende Änderungen vorgenommen:

- a) Dokument umstrukturiert;
- b) technische Änderungen eingeführt;
- c) Terminologie überprüft und aktualisiert;
- d) genaue Konformitätstyp eingeführt;
- e) Schutzprofile (PPs) mit geringer Sicherheit entfernt und PPs mit direkter Begründung eingeführt;
- f) PP-Module und PP-Konfigurationen für modulare Evaluierungen eingeführt;
- g) Mehrfachsicherungsbewertung eingeführt.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01

Nationaler Anhang NA (informativ)

Literaturhinweise

DIN EN ISO/IEC 18045, *Informationstechnik — Sicherheitstechniken — Methodik für die Bewertung der IT-Sicherheit*

DIN EN ISO/IEC 19790, *Informationstechnik — Sicherheitstechniken — Sicherheitsanforderungen für kryptografische Module*

DIN EN ISO/IEC 19896-1, *IT-Sicherheitstechniken — Kompetenzanforderungen an Tester und Evaluatoren von Informationssicherheit — Teil 1: Einführung, Konzepte und allgemeine Anforderungen*

DIN EN ISO/IEC 19896-3, *IT-Sicherheitstechniken — Kompetenzanforderungen an Tester und Evaluatoren von Informationssicherheit — Teil 3: Anforderungen an die Kenntnisse, Fähigkeiten und Effektivität von Evaluatoren nach ISO/IEC 15408*

DIN EN ISO/IEC 27001, *Informationssicherheit, Cybersicherheit und Datenschutz — Informationssicherheitsmanagementsysteme — Anforderungen*

DIN EN ISO/IEC 27002, *Informationssicherheit, Cybersicherheit und Schutz der Privatsphäre — Informationssicherheitsmaßnahmen*

– ***Entwurf*** –

E DIN EN ISO/IEC 15408-1:2024-01

– Leerseite –

- Entwurf -

Juli 2023

prEN ISO/IEC 15408-1

Informationssicherheit, Cybersicherheit und Schutz der Privatsphäre – Evaluationskriterien für IT-Sicherheit – Teil 1: Einführung und allgemeines Modell (ISO/IEC 15408-1:2022)

Information security, cybersecurity and privacy protection – Evaluation criteria for IT security – Part 1: Introduction and general model (ISO/IEC 15408-1:2022)

Sécurité de l'information, cybersécurité et protection de la vie privée – Critères d'évaluation pour la sécurité des technologies de l'information – Partie 1: Introduction et modèle général (ISO/IEC 15408-1:2022)

Inhalt

	Seite
Europäisches Vorwort	7
Vorwort	8
Einleitung	11
1 Anwendungsbereich	13
2 Normative Verweisungen	13
3 Begriffe	13
4 Symbole und Abkürzungen	26
5 Übersicht	28
5.1 Allgemein	28
5.2 Beschreibung der Normenreihe ISO/IEC 15408	28
5.2.1 Allgemein	28
5.2.2 Zielgruppe	29
5.3 Evaluierungsgegenstand (TOE)	33
5.3.1 Allgemein	33
5.3.2 TOE-Grenzen	33
5.3.3 Unterschiedliche Darstellungen des TOEs	34
5.3.4 Unterschiedliche Konfigurationen des TOEs	34
5.3.5 Betriebsumgebung des TOE	35
5.4 Darstellung des Inhalts dieses Dokuments	35
6 Allgemeines Modell	35
6.1 Hintergrund	35
6.2 Vermögenswerte und Sicherheitsmaßnahmen	36
6.3 Kernkonstrukte des Paradigmas der Normenreihe ISO/IEC 15408	38
6.3.1 Allgemein	38
6.3.2 Konformitätstypen	39
6.3.3 Weitergabe von Sicherheitsanforderungen	39
6.3.4 Erfüllung der Bedürfnisse der Verbraucher (Risikoeigentümer)	42
7 Festlegung von Sicherheitsanforderungen	44
7.1 Sicherheitsproblemdefinition (SPD)	44
7.1.1 Allgemein	44
7.1.2 Bedrohungen	44
7.1.3 Organisatorische Sicherheitsrichtlinien (OSP)	45
7.1.4 Annahmen	45
7.2 Sicherheitszielsetzungen	46
7.2.1 Allgemein	46
7.2.2 Sicherheitszielsetzungen für den TOE	47
7.2.3 Sicherheitszielsetzungen für die Betriebsumgebung	47
7.2.4 Beziehung zwischen Sicherheitszielsetzungen und der SPD	47
7.2.5 Rückverfolgung zwischen Sicherheitszielsetzungen und der SPD	48
7.2.6 Bereitstellen einer Begründung für die Rückverfolgung	48
7.2.7 Zum Entgegenwirken von Bedrohungen	49
7.2.8 Sicherheitszielsetzungen: Schlussfolgerung	49
7.3 Sicherheitsanforderungen	50
7.3.1 Allgemein	50
7.3.2 Sicherheitsfunktionsanforderungen (SFR)	50
7.3.3 Vertrauenswürdigkeitsanforderungen (SARs)	52
7.3.4 Sicherheitsanforderungen: Schlussfolgerung	53
8 Sicherheitskomponenten	55
8.1 Hierarchische Struktur der Sicherheitskomponenten	55
8.1.1 Allgemein	55
8.1.2 Klasse	55

8.1.3	Familie	55
8.1.4	Komponente	55
8.1.5	Element	55
8.2	Operationen	56
8.2.1	Allgemein	56
8.2.2	Iteration	56
8.2.3	Zuweisung	57
8.2.4	Auswahl	58
8.2.5	Präzisierung	59
8.3	Abhängigkeiten zwischen Komponenten	61
8.4	Erweiterte Komponenten	61
8.4.1	Allgemein	61
8.4.2	Definieren erweiterter Komponenten	62
9	Pakete	63
9.1	Allgemein	63
9.2	Pakettypen	63
9.2.1	Allgemein	63
9.2.2	Vertrauenswürdigenpakete	64
9.2.3	Funktionspakete	64
9.3	Paketabhängigkeiten	65
9.4	Evaluierungsmethode(n) und -aufgaben	65
10	Schutzprofile (PP)	65
10.1	Allgemein	65
10.2	PP-Einleitung	65
10.3	Konformitätsansprüche und Konformitätserklärungen	66
10.4	Vertrauenswürdigenanforderungen (SARs)	69
10.5	Zusätzliche gemeinsame Anforderungen an die strikte und nachweisliche Konformität	69
10.5.1	Konformitätsansprüche und Konformitätserklärungen	69
10.5.2	Sicherheitsproblemdefinition (SPD)	69
10.5.3	Sicherheitszielsetzungen	69
10.6	Zusätzliche Anforderungen speziell für die strikte Konformität	70
10.6.1	Anforderungen an die Sicherheitsproblemdefinition (SPD)	70
10.6.2	Anforderungen an die Sicherheitszielsetzungen	70
10.6.3	Anforderungen an die Sicherheitsanforderungen	70
10.7	Zusätzliche Anforderungen speziell für die nachweisliche Konformität	71
10.8	Zusätzliche Anforderungen speziell für die genaue Konformität	71
10.8.1	Allgemein	71
10.8.2	Konformitätsansprüche und -erklärungen	71
10.9	Unter Verwendung von PP	72
10.10	Konformitätserklärungen und -ansprüche im Falle mehrerer PP	72
10.10.1	Allgemein	72
10.10.2	Wenn strikte oder nachweisliche Konformität festgelegt ist	72
10.10.3	Wenn genaue Konformität festgelegt ist	72
11	Modularer Aufbau der Anforderungen	73
11.1	Allgemein	73
11.2	PP-Module	73
11.2.1	Allgemein	73
11.2.2	PP-Modulbasis	73
11.2.3	Anforderungen an PP-Module	73
11.3	PP-Konfigurationen	77
11.3.1	Allgemein	77
11.3.2	Anforderungen an PP-Konfigurationen	78
11.3.3	Verwendung von PP-Konfigurationen	84
12	Sicherheitsvorgaben (ST)	87
12.1	Allgemein	87
12.2	Konformitätsansprüche und -erklärungen	88
12.3	Vertrauenswürdigenanforderungen	90

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

12.4	Zusätzliche Anforderungen im Fall der genauen Konformität	91
12.4.1	Zusätzliche Anforderungen für den Konformitätsanspruch	91
12.4.2	Zusätzliche Anforderungen für die SPD	91
12.4.3	Zusätzliche Anforderungen an die Sicherheitszielsetzungen	91
12.4.4	Zusätzliche Anforderungen an die Sicherheitsanforderungen	92
12.5	Zusätzliche Anforderungen im Fall der Mehrfach-Vertrauenswürdigkeit	92
13	Evaluiierung und Evaluierungsergebnisse	94
13.1	Allgemein	94
13.2	Evaluiierungskontext	96
13.3	Evaluiierung der PP und PP-Konfigurationen	97
13.4	Evaluiierung von ST	98
13.5	Evaluiierung von TOE	98
13.6	Evaluiierungsmethoden und Evaluierungsaufgaben	98
13.7	Evaluiierungsergebnisse	99
13.7.1	Ergebnisse einer PP-Evaluiierung	99
13.7.2	Ergebnisse der Evaluiierung einer PP-Konfiguration	99
13.7.3	Ergebnisse einer ST-/TOE-Evaluiierung	99
13.8	Evaluiierung mit Mehrfach-Vertrauenswürdigkeit	100
14	Zusammensetzung der Vertrauenswürdigkeit	101
14.1	Allgemein	101
14.2	Zusammensetzungsmodelle	102
14.2.1	Mehrschichtiges Zusammensetzungsmodell	102
14.2.2	Netzwerk- oder bi-direktionales Zusammensetzungsmodell	103
14.2.3	Eingebettetes Zusammensetzungsmodell	103
14.3	Evaluiierungstechniken für die Vertrauenswürdigkeit von Zusammensetzungsmodellen	104
14.3.1	Allgemein	104
14.3.2	ACO-Klasse für zusammengesetzte TOE	104
14.3.3	Verbundevaluation für Verbundprodukte	105
14.4	Anforderungen an Evaluiierungen, die Zusammensetzungstechniken verwenden	117
14.4.1	Wiederverwendung von Evaluiierungsergebnissen	117
14.4.2	Aspekte der zusammengesetzten Evaluiierung	118
14.5	Evaluiierung mittels Zusammensetzung und Mehrfach-Vertrauenswürdigkeit	119
Anhang A (normativ)	Spezifikation von Paketen	121
A.1	Ziel und Aufbau dieses Anhangs	121
A.2	Paketfamilien	121
A.2.1	Allgemein	121
A.2.2	Name der Paketfamilie	121
A.2.3	Überblick über die Paketfamilie	121
A.2.4	Zielsetzungen der Paketfamilie	121
A.2.5	Pakete	121
A.3	Pakete	121
A.3.1	Verpflichtender Inhalt eines Pakets	121
A.3.2	Optionaler Inhalt eines Pakets	123
Anhang B (normativ)	Spezifikation von Schutzprofilen (PP)	125
B.1	Ziel und Aufbau dieses Anhangs	125
B.2	Spezifikation eines PP	125
B.2.1	Wie ein PP verwendet werden sollte	125
B.2.2	Wie ein PP nicht verwendet werden sollte	126
B.3	Verpflichtender Inhalt eines PPs	126
B.3.1	Allgemein	126
B.3.2	PP-Einleitung (APE_INT)	128
B.3.3	Konformitätsansprüche und Konformitätserklärung (APE_CCL)	130
B.3.4	Sicherheitsproblemdefinition (SPD) (APE_SPD)	131
B.3.5	Sicherheitszielsetzungen (APE_OBJ)	131
B.3.6	Erweiterte Komponentendefinition (APE_ECD)	131
B.3.7	Sicherheitsanforderungen (APE_REQ)	131
B.4	Verweisen auf andere Normen in einem PP	132

B.5	Die PP mit direkter Begründung	133
B.5.1	Allgemein	133
B.5.2	Konformitätsansprüche (APE_CCL) für die PP mit direkter Begründung	134
B.5.3	Sicherheitszielsetzungen (APE_OBJ) für PP mit direkter Begründung	134
B.6	Optionalen Inhalt eines PP	135
Anhang C	(normativ) Spezifikation von PP-Modulen und PP-Konfigurationen	136
C.1	Ziel und Aufbau dieses Anhangs	136
C.2	Spezifikation von PP-Modulen	136
C.2.1	Unter Verwendung eines PP-Moduls	136
C.2.2	Verpflichtender Inhalt eines PP-Moduls	136
C.2.3	PP-Module mit direkter Begründung	143
C.2.4	Leitlinien für die Einbeziehung von SPD-Elementen aus einer PP-Modulbasis	143
C.2.5	Optionalen Inhalt eines PP-Moduls	144
C.3	Spezifikation von PP-Konfigurationen	144
C.3.1	Allgemein	144
C.3.2	PP-Konfigurationsverweisung	146
C.3.3	Komponentenerklärung	146
C.3.4	TOE-Überblick	146
C.3.5	Konsistenzbegründung	146
C.3.6	Konformitätsanspruch und Konformitätserklärung	146
C.3.7	SAR-Aussage	149
Anhang D	(normativ) Spezifikation von Sicherheitsvorgaben (ST) und ST mit direkter Begründung	150
D.1	Ziel und Aufbau dieses Anhangs	150
D.2	Verwendung einer ST	150
D.2.1	Wie eine ST verwendet werden sollte	150
D.2.2	Wie eine ST nicht verwendet werden sollte	151
D.2.3	Fragen, die mit einer ST beantwortet werden können	151
D.3	Verpflichtender Inhalt einer ST	152
D.3.1	Allgemein	152
D.3.2	ST-Einleitung (ASE_INT)	154
D.3.3	Konformitätsansprüche (ASE_CCL)	157
D.3.4	Sicherheitsproblemdefinition (SPD) (ASE_SPD)	157
D.3.5	Sicherheitszielsetzungen (ASE_OBJ)	157
D.3.6	Erweiterte Komponentendefinition (ASE_ECD)	157
D.3.7	Sicherheitsanforderungen (ASE_REQ)	157
D.3.8	Zusammenfassende Spezifikation des TOEs (ASE_TSS)	159
D.4	ST mit direkter Begründung	159
D.4.1	Allgemein	159
D.4.2	Konformitätsansprüche (ASE_CCL) für ST mit direkter Begründung	161
D.4.3	Sicherheitsproblemdefinition (SPD) (ASE_SPD) für ST mit direkter Begründung	161
D.4.4	Sicherheitsanforderungen (ASE_REQ) für ST mit direkter Begründung	161
D.5	Verweisen auf andere Normen in einer ST	161
Anhang E	(normativ) Konformität des/der PP/PP-Konfiguration	162
E.1	Allgemein	162
E.2	Nachweisliche Konformität	163
E.3	Strikte Konformität	163
E.4	Genaue Konformität	163
E.4.1	Allgemein	163
E.4.2	FAQ/Cheatsheet zu genauer Konformität	166
Literaturhinweise		168

Bilder

Bild 1 — Sicherheitskonzepte und Beziehungen	37
--	----

- Entwurf -

**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Bild 2 — Evaluierungskonzepte und Beziehungen	38
Bild 3 — Rückverfolgungen zwischen Sicherheitszielsetzungen und der SPD	48
Bild 4 — Beziehungen zwischen SPD, Sicherheitszielsetzungen und Sicherheitsanforderungen	54
Bild 5 — Beispiel einer PP-Konfiguration	84
Bild 6 — Verwendung von PP-Konfigurationen mit Einfach- und Mehrfach-Vertrauenswürdigkeit	85
Bild 7 — Zusammensetzung von PP-Komponenten	86
Bild 8 — Vertrauenswürdigkeitsklassen, die zur Evaluierung der PP, PP-Konfigurationen und ST verwendet werden	87
Bild 9 — Beispiel einer ST mit Mehrfach-Vertrauenswürdigkeit	94
Bild 10 — Ablauf der Evaluierung	95
Bild 11 — Mehrschichtiges Zusammensetzungsmodell	102
Bild 12 — Netzwerk- oder bi-direktionales Zusammensetzungsmodell	103
Bild 13 — Eingebettetes Zusammensetzungsmodell	104
Bild 14 — Unter Verwendung der ACO-Klasse evaluierter zusammengesetzter TOE	105
Bild 15 — Verbundevaluation	107
Bild A.1 — Aufbau einer Paketfamilie mit Vertrauenswürdigkeits- oder Funktionspaketen	122
Bild B.1 — Inhalt eines Schutzprofils	127
Bild B.2 — Inhalt eines PP mit direkter Begründung	134
Bild C.1 — Inhalt eines PP-Moduls	137
Bild C.2 — Übernommene Konformitätsansprüche und -erklärungen für den Fall der genauen Konformität	140
Bild C.3 — Inhalte eines PP-Moduls mit direkter Begründung	143
Bild C.4 — Inhalt einer PP-Konfiguration	145
Bild C.5 — PP-Konfiguration und genaue Konformität	148
Bild D.1 — Inhalt einer ST	153
Bild D.2 — Inhalt einer ST mit direkter Begründung	160
Bild E.1 — Genaue Konformität einer ST mit mehreren PP	164
Bild E.2 — Genaue Konformität mit einer PP-Konfiguration mit mehreren PP und PP-Modulen	166

Tabellen

Tabelle 1 — Roadmap für die „Evaluierungskriterien für IT-Sicherheit“	31
Tabelle 2 — Informationen, die dem Entwickler der abhängigen Komponente zur Verfügung zu stellen sind	109
Tabelle 3 — Informationen, die dem Evaluator für Verbundprodukte und der Evaluierungsinstanz für Verbundprodukte zur Verfügung zu stellen sind	110
Tabelle E.1 — Zusammenfassung der genauen Konformität	166

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

Europäisches Vorwort

Der Text von ISO/IEC 15408-1:2022 wurde vom Technischen Komitee ISO/IEC JTC 1 „Information technology“ der Internationalen Organisation für Normung (ISO) erarbeitet und vom Technischen Komitee CEN/CLC/JTC 13 „Cybersicherheit und Datenschutz“ als prEN ISO/IEC 15408-1:2023 übernommen, dessen Sekretariat von DIN gehalten wird.

Dieses Dokument ist derzeit zur CEN-Umfrage vorgelegt.

Dieses Dokument wird EN ISO/IEC 15408-1:2020 ersetzen.

Rückmeldungen oder Fragen zu diesem Dokument sollten an das jeweilige nationale Normungsinstitut des Anwenders gerichtet werden. Eine vollständige Liste dieser Institute ist auf den Internetseiten von CEN abrufbar.

Anerkennungsnotiz

Der Text von ISO/IEC 15408-1:2022 wurde von CEN als prEN ISO/IEC 15408-1:2023 ohne irgendeine Abänderung genehmigt.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****Vorwort**

ISO (die Internationale Organisation für Normung) und IEC (die Internationale Elektrotechnische Kommission) bilden das auf die weltweite Normung spezialisierte System. Nationale Normungsorganisationen, die Mitglieder von ISO oder IEC sind, beteiligen sich an der Entwicklung von Internationalen Normen in Technischen Komitees, die von der jeweiligen Organisation eingerichtet wurden, um spezifische Gebiete technischer Aktivitäten zu behandeln. Auf Gebieten von beiderseitigem Interesse arbeiten die Technischen Komitees von ISO und IEC zusammen. Weitere internationale staatliche und nichtstaatliche Organisationen, die in engem Kontakt mit ISO und IEC stehen, nehmen ebenfalls an der Arbeit teil.

Die Verfahren, die bei der Entwicklung dieses Dokuments angewendet wurden und die für die weitere Pflege vorgesehen sind, werden in den ISO/IEC-Directives, Teil 1 beschrieben. Im Besonderen sollten die für die verschiedenen ISO-Dokumentenarten notwendigen Annahmekriterien beachtet werden. Dieses Dokument wurde in Übereinstimmung mit den Gestaltungsregeln der ISO/IEC-Directives, Teil 2 erarbeitet (siehe www.iso.org/directives oder www.iec.ch/members_experts/refdocs).

Es wird auf die Möglichkeit hingewiesen, dass einige Elemente dieses Dokuments Patentrechte berühren können. ISO und IEC sind nicht dafür verantwortlich, einige oder alle diesbezüglichen Patentrechte zu identifizieren. Details zu allen während der Entwicklung des Dokuments identifizierten Patentrechten finden sich in der Einleitung und/oder in der ISO-Liste der erhaltenen Patenterklärungen (siehe www.iso.org/patents) oder in der IEC-Liste der erhaltenen Patenterklärungen (siehe <http://patents.iec.ch>).

Jeder in diesem Dokument verwendete Handelsname dient nur zur Unterrichtung der Anwender und bedeutet keine Anerkennung.

Für eine Erläuterung des freiwilligen Charakters von Normen, der Bedeutung ISO-spezifischer Begriffe und Ausdrücke in Bezug auf Konformitätsbewertungen sowie Informationen darüber, wie ISO die Grundsätze der Welthandelsorganisation (WTO, en: World Trade Organization) hinsichtlich technischer Handelshemmnisse (TBT, en: Technical Barriers to Trade) berücksichtigt, siehe www.iso.org/iso/foreword.html. In der IEC, siehe www.iec.ch/understanding-standards.

Dieses Dokument wurde vom gemeinsamen Technischen Komitee ISO/IEC JTC 1, *Information technology*, Unterkomitee SC 27, *Information security, cybersecurity and privacy protection* erarbeitet.

Diese vierte Ausgabe ersetzt die dritte Ausgabe (ISO/IEC 15408-1:2009), die technisch überarbeitet wurde.

Die wesentlichen Änderungen sind folgende:

- das Dokument wurde neu strukturiert;
- technische Änderungen wurden eingeführt:
 - die Terminologie wurde überprüft und aktualisiert;
 - der genaue Konformitätstyp wurde eingeführt;
 - die Schutzprofile (PP) mit niedriger Vertrauenswürdigkeit wurden entfernt und die PP mit direkter Begründung eingeführt;
 - PP-Module und PP-Konfigurationen für modulare Evaluierungen wurden eingeführt;
 - eine Evaluierung mit Mehrfach-Vertrauenswürdigkeit wurde eingeführt.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

Eine Auflistung aller Teile der Normenreihe ISO/IEC15408 ist auf der ISO- und auf der IEC-Internetseite abrufbar.

Rückmeldungen oder Fragen zu diesem Dokument sollten an das jeweilige nationale Normungsinstitut des Anwenders gerichtet werden. Eine vollständige Auflistung dieser Institute ist unter www.iso.org/members.html und www.iec.ch/national-committees zu finden.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

Rechtliche Hinweise

Die unten aufgeführten Regierungsorganisationen haben zu der Entwicklung dieser Version der „Common Criteria for Information Technology Security Evaluations“ beigetragen. Als gemeinsame Urheberrechtsinhaber an den Common Criteria for Information Technology Security Evaluations (kurz CC) erteilen sie hiermit der ISO/IEC die nicht-exklusive Lizenz zur Verwendung der CC für die weitere Entwicklung/Pflege der Normenreihe ISO/IEC 15408. Diese Regierungsorganisationen behalten sich allerdings das Recht zur Nutzung, Vervielfältigung, zum Vertrieb sowie zur Übersetzung und Änderung der CC nach Belieben vor.

Australien	Australian Signals Directorate
Kanada	Communications Security Establishment
Frankreich	Agence Nationale de la Sécurité des Systèmes d’Information
Deutschland	Bundesamt für Sicherheit in der Informationstechnik
Japan	Information-technology Promotion Agency
Niederlande	Netherlands National Communications Security Agency
Neuseeland	Government Communications Security Bureau
Republik Korea	National Security Research Institute
Spanien	Ministerio de Asuntos Económicos y Transformación Digital
Schweden	FMV, Swedish Defence Materiel Administration
Vereinigtes Königreich	National Cyber Security Centre
USA	National Security Agency

Einleitung

Die Normenreihe ISO/IEC 15408 ermöglicht die Vergleichbarkeit der Ergebnisse unabhängiger Sicherheitsevaluierungen durch eine einheitliche Reihe von Anforderungen an die Sicherheitsfunktionalität von IT-Produkten und an Maßnahmen zur Zusicherung der Vertrauenswürdigkeit, die auf diese IT-Produkte während einer Sicherheitsevaluierung angewendet werden. Diese IT-Produkte können in Hardware, Firmware oder Software implementiert werden.

Durch den Evaluierungsprozess wird ein Vertrauensniveau hergestellt, dass die Sicherheitsfunktionalität dieser IT-Produkte und die auf diese IT-Produkte angewendeten Maßnahmen zur Zusicherung der Vertrauenswürdigkeit diese Anforderungen erfüllen. Die Evaluierungsergebnisse können die Verbraucher bei der Bestimmung unterstützen, ob diese IT-Produkte ihre Sicherheitsbedürfnisse erfüllen.

Die Normenreihe ISO/IEC 15408 ist hilfreich als Leitfaden für Entwicklung, Evaluierung und/oder Beschaffung von IT-Produkten mit Sicherheitsfunktionalität.

Die Normenreihe ISO/IEC 15408 ist absichtlich flexibel gestaltet, um einen großen Bereich an Evaluierungsansätzen für einen großen Bereich an Sicherheitseigenschaften einer Vielzahl von IT-Produkten abzudecken. Anwender dieser Norm werden daher darauf hingewiesen, sorgfältig vorzugehen, damit diese Flexibilität nicht zweckentfremdet wird. Wird die Normenreihe ISO/IEC 15408 beispielsweise in Verbindung mit ungeeigneten Evaluierungsmethoden/-aufgaben, irrelevanten Sicherheitseigenschaften oder unangemessenen IT-Produkten verwendet, kann dies zu bedeutungslosen Evaluierungsergebnissen führen.

Somit hat die Evaluierung eines IT-Produkts nur eine Bedeutung im Zusammenhang mit den beurteilten Sicherheitseigenschaften und den angewendeten Evaluierungsmethoden. Evaluierungsstellen wird empfohlen, Produkte, Eigenschaften und Methoden zur Bestimmung, ob eine Evaluierung bedeutungsvolle Ergebnisse liefert, sorgfältig zu prüfen. Zusätzlich wird Käufern evaluierter Produkte empfohlen, sorgfältig zu prüfen, ob das evaluierte Produkt in diesem Zusammenhang und für die bestimmte Situation und ihre Bedürfnisse nützlich und anwendbar ist.

Die Normenreihe ISO/IEC 15408 behandelt den Schutz von Vermögenswerten vor unautorisierter Offenlegung, Änderung oder Nutzungsausfall. Die Schutzkategorien für diese drei Ausfalltypen der Sicherheit werden allgemein Vertraulichkeit, Integrität und Verfügbarkeit genannt. Die Normenreihe ISO/IEC 15408 kann auch anwendbar sein auf Bereiche der IT-Sicherheit, die über diese drei Kategorien hinausgehen. Die Normenreihe ISO/IEC 15408 ist anwendbar auf von Menschen ausgelöste Risiken (böswillig oder anders geartet) und auf nicht von Menschen ausgelöste Risiken. Die Normenreihe ISO/IEC 15408 darf auch auf andere Bereiche der IT angewendet werden, aber die Norm erhebt für jene anderen Bereiche keinen Anspruch auf Anwendbarkeit.

Bestimmte Themen liegen außerhalb des Anwendungsbereichs der Normenreihe ISO/IEC 15408, weil sie besondere Techniken umfassen oder nur am Rande Teil der IT-Sicherheit sind. Einige dieser Themen sind unten aufgeführt:

- a) die Normenreihe ISO/IEC 15408 umfasst keine Sicherheitsevaluierungskriterien zu administrativen Sicherheitsmaßnahmen, die sich nicht direkt auf die IT-Sicherheitsfunktionalität beziehen. Allerdings ist es eine anerkannte Tatsache, dass eine beträchtliche Erhöhung der Sicherheit oftmals durch administrative Maßnahmen im organisatorischen, personellen, physischen oder verfahrenstechnischem Bereich erreicht werden kann oder dadurch unterstützt wird;
- b) die Normenreihe ISO/IEC 15408 behandelt nicht die Evaluierungsmethodologie, mit der die Kriterien angewendet werden sollten;

ANMERKUNG 1 Die grundlegende Methodologie ist in ISO/IEC 18045 definiert. ISO/IEC 15408-4 kann zur weiteren Ableitung von Evaluierungsaufgaben und -methoden aus ISO/IEC 18045 verwendet werden.

- c) die Normenreihe ISO/IEC 15408 behandelt nicht das administrative und rechtliche Rahmenwerk, mit dem die Kriterien von Evaluierungsinstanzen angewendet werden dürfen. Es wird jedoch erwartet, dass die

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01**
prEN ISO/IEC 15408-1:2023 (D)

Normenreihe ISO/IEC 15408 für Evaluierungszwecke im Zusammenhang mit einem solchen Rahmenwerk verwendet werden soll;

- d) die Verfahren zur Verwendung von Evaluierungsergebnissen in Akkreditierungen liegen außerhalb des Anwendungsbereichs der Normenreihe ISO/IEC 15408. Akkreditierung ist der administrative Prozess, bei dem die Berechtigung für den Betrieb eines IT-Produkts (oder einer Sammlung dergleichen) in seiner vollständigen Betriebsumgebung gewährt wird, einschließlich aller seiner Nicht-IT-Teile. Die Ergebnisse des Evaluierungsprozesses fließen in den Akkreditierungsprozess ein. Da allerdings andere Techniken für die Bewertung von Eigenschaften ohne Bezug zur IT und deren Beziehung zu Teilen der IT-Sicherheit besser geeignet sind, müssen Akkreditierer gesonderte Bestimmungen für diese Aspekte treffen;
- e) die Kriterien für die Bewertung der charakteristischen Qualitäten von kryptographischen Algorithmen werden nicht in der Normenreihe ISO/IEC 15408 behandelt. Wenn eine unabhängige Bewertung der mathematischen Eigenschaften der Kryptographie erforderlich ist, so muss der in der Normenreihe ISO/IEC 15408 angewendete Evaluierungsplan solch eine Bewertung vorsehen.

ANMERKUNG 2 Im vorliegenden Dokument werden einige Begriffe fett und kursiv gedruckt, um sie vom übrigen Text abzuheben. Die Beziehung zwischen den Komponenten einer Familie wird als Konvention über eine Fettmarkierung hervorgehoben. Diese Markierungskonvention erfordert die Verwendung von Fettdruck für alle neuen Anforderungen. Für hierarchische Komponenten werden Anforderungen fett hervorgehoben, wenn sie über die Anforderungen der vorherigen Komponente hinaus erweitert oder geändert werden. Zusätzlich werden alle neuen oder erweiterten zulässigen über die vorherige Komponente hinausgehenden Operationen auch fett hervorgehoben.

Die Verwendung von Kursivschrift weist auf einen Text hin, der eine genaue Bedeutung hat. Für die Vertrauenswürdigkeitsanforderungen gilt die Konvention für spezielle Verben, die sich auf die Evaluierung beziehen.

1 Anwendungsbereich

Dieses Dokument legt die allgemeinen Konzepte und Prinzipien der IT-Sicherheitsbewertung fest und bestimmt das allgemeine Bewertungsmodell, das in verschiedenen Teilen der Norm verwendet wird, und das in seiner Gesamtheit als Grundlage für die Bewertung der Sicherheitseigenschaften von IT-Produkten vorgesehen ist.

Dieses Dokument bietet einen Überblick über alle Teile der Normenreihe ISO/IEC 15408. Es beschreibt die verschiedenen Teile der Normenreihe ISO/IEC 15408, definiert die Begriffe und Abkürzungen zur Verwendung in allen Teilen der Norm, legt das Kernkonzept des Bewertungsgegenstands (TOE; en: target of evaluation) fest, beschreibt den Bewertungszusammenhang und die Zielgruppe, an die sich die Bewertungskriterien richten. Zu den für die Bewertung von IT-Produkten erforderlichen, grundlegenden Sicherheitskonzepten wird eine Einführung gegeben.

Dieses Dokument führt in folgende Sachverhalte ein:

- die grundlegenden Konzepte von Schutzprofilen (PP), PP-Modulen, PP-Konfigurationen, Paketen, Sicherheitsvorgaben (ST) und Konformitätstypen;
- eine Beschreibung der Organisation von Sicherheitskomponenten im gesamten Modell;
- die verschiedenen Operationen, mit denen die Funktionskomponenten und Vertrauenswürdigkeitskomponenten in ISO/IEC 15408-2 und ISO/IEC 15408-3 für die Verwendung der zulässigen Operationen angepasst werden dürfen;
- allgemeine Informationen über die in ISO/IEC 18045 beschriebenen Bewertungsmethoden;
- Leitlinien für die Anwendung der ISO/IEC 15408-4 zur Entwicklung von Bewertungsmethoden (EM) und Bewertungsaufgaben (EA), die aus ISO/IEC 18045 abgeleitet werden;
- allgemeine Informationen über die vordefinierten Vertrauenswürdigkeitsstufen (EAL-Stufen), die in ISO/IEC 15408-5 definiert sind;
- Informationen über den Anwendungsbereich der Bewertungspläne.

2 Normative Verweisungen

Die folgenden Dokumente werden im Text in solcher Weise in Bezug genommen, dass einige Teile davon oder ihr gesamter Inhalt Anforderungen des vorliegenden Dokuments darstellen. Bei datierten Verweisungen gilt nur die in Bezug genommene Ausgabe. Bei undatierten Verweisungen gilt die letzte Ausgabe des in Bezug genommenen Dokuments (einschließlich aller Änderungen).

ISO/IEC 15408-2:2022, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 2: Security functional components*

ISO/IEC 15408-3:2022, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 3: Security assurance components*

ISO/IEC 18045, *IT security techniques — Methodology for IT security evaluation*

ISO/IEC IEEE 24765, *Systems and software engineering — Vocabulary*

3 Begriffe

Für die Anwendung dieses Dokuments gelten die Begriffe nach ISO/IEC 15408-2, ISO/IEC 15408-3, ISO/IEC 18045 und ISO/IEC IEEE 24765.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

ISO und IEC stellen terminologische Datenbanken für die Verwendung in der Normung unter den folgenden Adressen bereit:

- ISO Online Browsing Platform: verfügbar unter <https://www.iso.org/obp>
- IEC Electropedia: verfügbar unter <https://www.electropedia.org/>

3.1**Aktion**

dokumentierte Aufgabe des *Evaluators* (3.45) oder *Entwicklers* (3.33)

Anmerkung 1 zum Begriff: Evaluatorenaktionen und Entwickleraktionen werden durch ISO/IEC 15408-3 gefordert.

3.2**Administrator**

Entität (3.36), die bezüglich aller durch die *TOE-Sicherheitsfunktionalität (TSF)* (3.92) implementierten Richtlinien einen Vertrauensgrad besitzt

Anmerkung 1 zum Begriff: Nicht alle *Schutzprofile (PP)* (3.68) oder Sicherheitsvorgaben (ST) nehmen für Administratoren den gleichen Vertrauensgrad an. Üblicherweise wird angenommen, dass Administratoren jederzeit die in der ST des *Evaluierungsgegenstands (TOE)* (3.90) definierten Richtlinien einhalten. Manche dieser Richtlinien können mit der Funktionalität des TOEs in Zusammenhang stehen, während andere mit der *Betriebsumgebung* (3.63) zusammenhängen.

3.3**nachteilige Aktion**

Aktion (3.1), die von einem *Bedrohungsagenten* (3.91) gegen ein *Schutzobjekt* (3.4) durchgeführt wird

3.4**Vermögenswert**

Entität (3.36), von der anzunehmen ist, dass sie für den Eigentümer des *Evaluierungsgegenstands (TOE)* (3.90) einen Wert darstellt

3.5**Zuweisung**

Spezifikation eines bezeichneten Parameters in einer Funktions- oder Vertrauenswürdigkeitskomponente

3.6**Vertrauenswürdigkeit**

Vertrauensgrundlage, dass ein *Evaluierungsgegenstand (TOE)* (3.90) die *Sicherheitsfunktionsanforderungen (SFR)* (3.78) einhält

3.7**Vertrauenswürdigkeitspaket**

benannter Satz von *Vertrauenswürdigkeitsanforderungen* (3.76)

BEISPIEL „EAL 3“.

3.8**Angriffspotential**

Maß für den Aufwand, der erforderlich ist, um eine Anfälligkeit in einem *Evaluierungsgegenstand (TOE)* (3.90) auszunutzen

Anmerkung 1 zum Begriff: Der Aufwand wird als Funktion der Eigenschaften des Angreifers (z. B. Fachwissen, Ressourcen und Motivation) und der Eigenschaften der Anfälligkeit selbst (z. B. Zugriffsgelegenheit, Zeit bis zur Aufdeckung) ausgedrückt.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****3.9****Angriffsfläche**

Menge logischer oder physischer Schnittstellen zu einer Zielvorgabe, bestehend aus Punkten, über die versucht wird, auf die Zielvorgabe und ihre Funktionen zuzugreifen.

BEISPIEL 1 Das Gehäuse eines Zahlungsterminals ist ein Teil der physischen Angriffsfläche für dieses Gerät.

BEISPIEL 2 Die Kommunikationsprotokolle, die für die Verbindung mit einem Netzwerkgerät zur Verfügung stehen, sind Teil der logischen Angriffsfläche für dieses Netzwerkgerät.

3.10**Erweiterung**

Hinzufügen von einer oder mehreren Anforderungen zu einem Paket

Anmerkung 1 zum Begriff: Im Falle eines *Funktionspakets* (3.51) wird eine solche Erweiterung nur im Zusammenhang mit einem Paket betrachtet und nicht im Zusammenhang mit anderen Paketen oder *Schutzprofilen (PP)* (3.68) bzw. *Sicherheitsvorgaben (ST)* (3.82).

Anmerkung 2 zum Begriff: Im Falle eines *Vertrauenswürdigkeitspakets* (3.7) bezieht sich die Ergänzung auf eine oder mehrere *Vertrauenswürdigkeitsanforderungen (SAR)* (3.76).

3.11**autorisierter Benutzer**

Entität (3.36), die in Übereinstimmung mit den *Sicherheitsfunktionsanforderungen (SFR)* (3.78) eine Operation am *Evaluierungsgegenstand (TOE)* (3.90) durchführen darf

3.12**Basiskomponente**

unabhängige Entität (3.36) in einem Mehrkomponentenprodukt, die einer oder mehreren *abhängigen Komponente(n)* (3.31) Dienste und Ressourcen zur Verfügung stellt

Anmerkung 1 zum Begriff: Dies gilt insbesondere für „zusammengesetzte TOE“ (3.21) und „Verbundprodukte/Verbund-TOE“ (3.25).

3.13**Basisschutzprofil****Basis-PP**

Schutzprofil (3.68), das in einem PP-Modul (3.71) als Teil der *PP-Modulbasis* (3.72) dieses PP-Moduls festgelegt ist und als Grundlage für die Erstellung einer *PP-Konfiguration* (3.69) dient

3.14**Basis-PP-Modul**

PP-Modul (3.71), das in einem anderen PP-Modul als Teil der *PP-Modulbasis* (3.72) dieses PP-Moduls festgelegt ist und als Grundlage für die Erstellung einer *PP-Konfiguration* (3.69) dient

Anmerkung 1 zum Begriff: Die Spezifikation eines Basis-PP-Moduls in einem PP-Modul schließt implizit die PP-Modulbasis des Basis-PP-Moduls ein.

3.15**Basisevaluierungsgegenstand****Basis-TOE**

Basiskomponente (3.12), die selbst Gegenstand einer Evaluierung ist

Anmerkung 1 zum Begriff: Dies gilt insbesondere für „zusammengesetzte TOE“ (3.21) und „Verbundprodukte/Verbund-TOE“ (3.25).

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****3.16****Klasse**

<Taxonomie> Reihe von Familien mit einem gemeinsamen Fokus

Anmerkung 1 zum Begriff: Die Klasse wird weiter definiert in ISO/IEC 15408-2, die die Sicherheitsfunktionsklassen definiert, und ISO/IEC 15408-3, die die Vertrauenswürdigkeitsklassen definiert.

3.17**Komponente**

<Taxonomie> kleinster selektierbarer Elementesatz, auf dem Anforderungen basieren können

3.18**Komponente**

<Zusammensetzung> *Entität* (3.36), die Ressourcen und Dienstleistungen in einem Produkt bereitstellt

3.19**Komponenten-Evaluierungsgegenstand****Komponenten-TOE**

(bewerteter) *Evaluierungsgegenstand (TOE)* (3.90), der Bestandteil eines anderen *zusammengesetzten TOEs* (3.21) ist

3.20**zusammengesetztes Vertrauenswürdigkeitspaket**

CAP, en: composed assurance package

Vertrauenswürdigkeitspaket (3.7), bestehend aus Komponenten, die vorwiegend aus der *ACO-Klasse* (3.16) stammen und einen Punkt auf der vordefinierten Skala für zusammengesetzte Vertrauenswürdigkeit darstellen

3.21**zusammengesetzter Evaluierungsgegenstand****zusammengesetzter TOE**

Evaluierungsgegenstand (TOE) (3.90), der ausschließlich aus zwei oder mehreren getrennt identifizierten Komponenten besteht, zwischen deren *TOE-Sicherheitsfunktionalitäten (TSF)* (3.92) eine Sicherheitsbeziehung besteht

Anmerkung 1 zum Begriff: Jede der separat identifizierten Komponenten ist selbst ein TOE.

3.22**zusammengesetzte Evaluierung**

Evaluierung eines *zusammengesetzten TOE* (3.21) unter Verwendung der spezifischen, für zusammengesetzte TOE anwendbaren Evaluierungstechnik

Anmerkung 1 zum Begriff: Diese Evaluierungstechnik bezieht sich auf die *ACO-Vertrauenswürdigkeitsklasse* (3.16), die in ISO/IEC 15408-3 definiert ist.

3.23**Verbundevaluation**

Evaluierung eines *Verbund-TOE/-Produkts* (3.25) unter Verwendung der spezifischen Technik zur Verbundevaluation

Anmerkung 1 zum Begriff: Diese Evaluierungstechnik bezieht sich auf die COMP-bezogenen Vertrauenswürdigkeitsfamilien, die in ISO/IEC 15408-3 für die *ADV-, ALC-, ASE-, ATE- und AVA-Klassen* (3.16) festgelegt sind.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****3.24****Verbundprodukt**

Produkt, das aus zwei oder mehr Komponenten besteht, die in zwei Schichten gegliedert werden können: eine Schicht mit einer bereits evaluierten *Basiskomponente (Basis-TOE)* (3.15) und eine Schicht mit einer *abhängigen Komponente* (3.31)

3.25**Verbundevaluierungsgegenstand****Verbund-TOE**

Teil eines *Verbundprodukts* (3.24), das den *Basis-TOE* (3.15) und die *abhängige Komponente* (3.31) enthält

Anmerkung 1 zum Begriff: Eine abhängige Komponente in einem Verbund-TOE kann aus einer oder mehreren abhängigen Komponenten bestehen. Zur Vereinfachung werden sie als „eine abhängige Komponente“ betrachtet.

Anmerkung 2 zum Begriff: Ein Verbund-TOE kann Teile enthalten, die von der *Basiskomponente* (3.12) bzw. dem *Basis-TOE* unabhängig sind. Zur Vereinfachung werden solche Teile als zur abhängigen Komponente gehörig betrachtet.

Anmerkung 3 zum Begriff: Die *Verbundevaluation* (3.23) kann in einem inkrementellen Ansatz so oft wie nötig auf ein mehrkomponentiges/mehrschichtiges Produkt angewendet werden.

3.26**Konfigurationsmanagement**

CM, en: configuration management

Fachgebiet, in dem technische und administrative Anleitung und Überwachung eingesetzt werden, um die funktionellen und physikalischen Merkmale eines Konfigurationselements zu identifizieren und zu dokumentieren, Änderungen dieser Merkmale zu kontrollieren, die Umsetzung von Änderungen sowie den Implementierungsstatus aufzuzeichnen und zu berichten und die Compliance der festgelegten Anforderungen zu überprüfen

[QUELLE: ISO/IEC IEEE 24765:2017, 3.779 1]

3.27**Konfigurationsmanagementsystem**

Satz von Verfahren und Werkzeugen (einschließlich deren Dokumentation), der von einem *Entwickler* (3.33) zur Entwicklung und Wartung der Konfigurationen der Produkte während ihrer Lebenszyklen verwendet wird

Anmerkung 1 zum Begriff: Konfigurationsmanagementsysteme können über unterschiedliche Stringenz- und Funktionsgrade verfügen. Auf den höheren Stufen können Konfigurationsmanagementsysteme automatisiert sein und über Mechanismen für die Mängelbehebung, Änderungskontrolle und sonstige Nachverfolgungsmechanismen verfügen.

3.28**abwehren**, Verb

auf eine bestimmte Bedrohung reagieren, so dass die Bedrohung ausgemerzt oder abgemildert wird

3.29**nachweisliche Konformität**

DC, en: demonstrable conformance

Beziehung zwischen einem *Schutzprofil (PP)* (3.68)/einer *Sicherheitsvorgabe (ST)* (3.82) (PP/ST) und einem PP oder zwischen einer ST und einer *PP-Konfiguration* (3.69), wobei das/die PP/ST eine gleichwertige oder restriktivere Lösung bietet, die das generische Sicherheitsproblem im PP/in der PP-Konfiguration löst

3.30**Abhängigkeit**

Beziehung zwischen Komponenten, so dass ein *Schutzprofil (PP)* (3.68), eine *Sicherheitsvorgabe (ST)* (3.82), ein *Funktionspaket* (3.51) oder *Vertrauenswürdigkeitspaket* (3.7), das eine Komponente enthält, auch alle anderen Komponenten umfasst, die als abhängig ausgewiesen sind, oder eine Begründung enthält, warum sie es nicht sind

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****3.31****abhängige Komponente**

abhängige Entität (3.36) in einem Mehrkomponentenprodukt, die von der Bereitstellung von Dienstleistungen und Ressourcen durch eine oder mehrere *Basiskomponenten* (3.12) abhängt

Anmerkung 1 zum Begriff: Dies gilt insbesondere für „zusammengesetzte TOE“ (3.21) und „Verbundprodukte/Verbund-TOE“ (3.25).

3.32**abhängiger Evaluierungsgegenstand****abhängiger TOE**

abhängige Komponente (3.31), die selbst Gegenstand einer Evaluierung ist

Anmerkung 1 zum Begriff: Dies gilt nur für „zusammengesetzte TOE“ (3.21) und nicht für „Verbundprodukte/Verbund-TOE“ (3.25).

3.33**Entwickler**

Organisation, die für die Entwicklung des *Evaluierungsgegenstandes* (TOE) (3.90) verantwortlich ist

3.34**direkte Begründung**

Art des *Schutzprofils* (3.68), des *PP-Moduls* (3.71) oder der *Sicherheitsvorgabe* (3.82), in denen die Elemente der *Sicherheitsproblemdefinition* (SPD) (3.80) direkt auf die *Sicherheitsfunktionsanforderungen* (SFR) (3.78) und möglicherweise auf die *Sicherheitszielsetzungen* (3.79) für die *Betriebsumgebung* (3.63) abgebildet werden

Anmerkung 1 zum Begriff: Die direkte Begründung enthält keine Sicherheitszielsetzungen für den *Evaluierungsgegenstand* (TOE) (3.90).

3.35**Element**

<Taxonomie> in sich geschlossene Beschreibung eines Sicherheitsbedarfs, der einer *Vertrauenswürdigkeitsanforderung* (SAR) (3.76) oder einer *Sicherheitsfunktionsanforderung* (SFR) (3.78) zugeordnet ist

3.36**Entität**

identifizierbarer Gegenstand, der durch einen Satz oder eine Sammlung von Eigenschaften beschrieben wird

Anmerkung 1 zum Begriff: Zu den Entitäten gehören Subjekte, Benutzer (einschließlich externer IT-Produkte), Objekte, Informationen, Sitzungen und/oder Ressourcen.

3.37**Evaluierung**

Bewertung einer *PP-Konfiguration* (3.69), eines *Schutzprofils* (PP) (3.68), einer *Sicherheitsvorgabe* (ST) (3.82) oder eines *Evaluierungsgegenstandes* (TOE) (3.90) anhand definierter Kriterien

3.38**Evaluierungsaufgabe****EA**

von einer oder mehreren Workunits abgeleitete Aufgabe

Anmerkung 1 zum Begriff: Die Workunits werden in ISO/IEC 18045 definiert.

Anmerkung 2 zum Begriff: Ableitungsmechanismen sind in ISO/IEC 15408-4 definiert.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****3.39****Vertrauenswürdigkeitsstufe****EAL-Stufe****EAL**, en: evaluation assurance levelwohlgeformtes Paket aus *Vertrauenswürdigkeitsanforderungen* (3.76), das einen Punkt auf der vordefinierten Vertrauenswürdigkeitsskala darstellt

Anmerkung 1 zum Begriff: EAL werden in ISO/IEC 15408-5 definiert.

3.40**Evaluierungsinstanz**Stelle, die ein *Evaluierungsprogramm* (3.42) betreibt

Anmerkung 1 zum Begriff: Durch die Anwendung des Evaluierungsprogramms legt die Evaluierungsinstanz die Normen fest und überwacht die Qualität der Evaluierungen, die von Stellen innerhalb einer bestimmten Gemeinschaft durchgeführt werden.

3.41**Evaluierungsmethode****EM**Menge mit einer oder mehreren *Evaluierungsaufgaben* (3.38) zur Anwendung in einem bestimmten Kontext**3.42****Evaluierungsprogramm**

Regeln, Verfahren und Management zur Durchführung von Evaluierungen der IT-Produktsicherheit

Anmerkung 1 zum Begriff: Ein Evaluierungsprogramm implementiert alle Teile der Normenreihe ISO/IEC 15408.

3.43**technischer Evaluierungsbericht****ETR**, en: evaluation technical reportDokumentation der *Gesamtentscheidung* (3.66) und ihrer Begründung, die vom *Evaluator* (3.45) erstellt und einer *Evaluierungsinstanz* (3.40) vorgelegt wird**3.44****technischer Evaluierungsbericht für Verbundevaluation****ETR für eine Verbundevaluation****ETR_COMP**Dokumentation, die im Rahmen des Ansatzes der *Verbundevaluation* (3.23) verwendet und vom *Evaluator* (3.45) der *Basiskomponente* (3.12) aus dem vollständigen *technischen Evaluierungsbericht (ETR)* (3.43) für die evaluierte Basiskomponente abgeleitet werden soll

Anmerkung 1 zum Begriff: Der ETR für die Verbundevaluation gehört zu der Basiskomponente und ihrer Evaluierung und wird für die Evaluierung eines Verbundprodukts mit einer solchen Basiskomponente verwendet, wenn der Ansatz der Verbundevaluation verwendet wird.

Anmerkung 2 zum Begriff: Der ETR für die Verbundevaluation in Bezug auf eine Basiskomponente ist so angelegt, dass er ausreichende Informationen für eine Verbundevaluation eines Verbundprodukts liefert, das eine solche bereits evaluierte Basiskomponente integriert. Er ermöglicht es dem *Evaluator* (3.45) des Verbundprodukts und der jeweiligen *Evaluierungsinstanz* (3.40) für das Verbundprodukt, die Angriffspfade und die Prüfungen, die für die Basiskomponente in Betracht gezogen und durchgeführt wurden, sowie die Wirksamkeit der von der Basiskomponente implementierten Gegenmaßnahmen zu verstehen.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****3.45****Evaluator**

Person, die mit der Durchführung von Evaluierungen nach einer bestimmten Evaluierungsnorm und der zugehörigen Evaluierungsmethodologie beauftragt ist

Anmerkung 1 zum Begriff: Ein Beispiel für Evaluierungsnormen ist die Normenreihe ISO/IEC 15408 mit der zugehörigen Evaluierungsmethodologie, die in ISO/IEC 18045 beschrieben ist.

[QUELLE: ISO/IEC 19896-1:2018, 3.5]

3.46**genaue Konformität**

EC, en: exact conformance

hierarchische Beziehung zwischen einem *Schutzprofil (PP)* (3.68) oder einer *PP-Konfiguration* (3.69) und einer *Sicherheitsvorgabe (ST)* (3.82), wobei alle Anforderungen in der ST nur aus dem PP/der PP-Konfiguration abgeleitet sind

Anmerkung 1 zum Begriff: Eine ST darf eine genaue Konformität mit einem oder mehreren PP beanspruchen, aber nur mit einer PP-Konfiguration.

3.47**ausnutzbare Anfälligkeit**

Schwachstelle im *Evaluierungsgegenstand (TOE)* (3.90), die für Verletzungen von *Sicherheitsfunktionsanforderungen (SFR)* (3.78) in der *Betriebsumgebung* (3.63) des TOEs genutzt werden kann

3.48**erweiterte Sicherheitsanforderung**

Sicherheitsanforderung, die nach den Regeln in diesem Dokument entwickelt wurde, aber in keinem Teil der Normenreihe ISO/IEC 15408 aufgeführt ist

Anmerkung 1 zum Begriff: Eine erweiterte Sicherheitsanforderung behält die in ISO/IEC 15408-2 beschriebene Form und Syntax bei.

Anmerkung 2 zum Begriff: Erweiterte Sicherheitsanforderungen können von den Autoren von *Sicherheitsvorgaben (ST)* (3.82) oder *Schutzprofilen (PP)* (3.68) bzw. *PP-Modulen* (3.71) definiert werden.

3.49**externe Entität****Benutzer**

menschliches technisches System oder eine seiner Komponenten, die mit dem *Evaluierungsgegenstand (TOE)* (3.90) von außerhalb der TOE-Grenze mit dem TOE interagiert

3.50**Familie**

<Taxonomie> Satz von Komponenten, der eine ähnliche Zielsetzung hat, sich aber in Schwerpunkt oder Stringenz unterscheidet

3.51**Funktionspaket**

benannter Satz von *Sicherheitsfunktionsanforderungen* (3.78), der von einer *Sicherheitsproblemdefinition (SPD)* (3.80) und von aus dieser SPD abgeleiteten *Sicherheitszielsetzungen* (3.79) begleitet sein kann

3.52**gesamtes Vertrauenswürdigkeitspaket**

Vertrauenswürdigkeitspaket (3.7), das für den gesamten *Evaluierungsgegenstand (TOE)* (3.90) bei einer *Evaluierung mit Mehrfach-Vertrauenswürdigkeit* (3.60) gilt

Anmerkung 1 zum Begriff: Das gesamte Vertrauenswürdigkeitspaket kann erweiterte Vertrauenswürdigkeitskomponenten enthalten.

3.53**Leitliniendokumentation**

Dokumentation, die die Auslieferung, die Bereitstellung, den Betrieb, das Management und/oder die Verwendung des *Evaluierungsgegenstands (TOE)* (3.90) beschreibt

3.54**Implementierungsrepräsentation**

am wenigsten abstrakte Darstellung der *TOE-Sicherheitsfunktionalität (TSF)* (3.92), genauer die Darstellung, die ohne weitere *Designverfeinerung* (3.73) zur Erstellung der TSF selbst verwendet wird

Anmerkung 1 zum Begriff: Beispiele für Teile von Implementierungsrepräsentationen sind Quellcode, der anschließend kompiliert wird, oder Hardware-Zeichnungen, die zum Aufbau der eigentlichen Hardware verwendet werden.

3.55**in sich widerspruchsfrei, Adj.**

es bestehen keine offensichtlichen Widersprüche zwischen irgendwelchen Aspekten einer *Entität* (3.36)

Anmerkung 1 zum Begriff: In Bezug auf Dokumentation bedeutet dies, dass keine Aussagen in der Dokumentation enthalten sein können, die als widersprüchlich zueinander interpretiert werden können.

3.56**Interpretation**

Klärung oder Erweiterung einer Norm oder einer Anforderung an ein Evaluierungsprogramm

3.57**Iteration**

Verwendung der gleichen Komponente, um zwei oder mehr unterschiedliche Anforderungen auszudrücken

3.58**Schichtung**

Entwurfstechnik, bei der getrennte Komponentengruppen hierarchisch so organisiert sind, dass sie getrennte Zuständigkeiten besitzen, wobei eine Komponentengruppe die Dienste der in der Hierarchie darunterliegenden Komponentengruppen nutzt und die eigenen Dienste den darüberliegenden Komponentengruppen zur Verfügung stellt

3.59**Modul**

architektonische Einheit, die auf einer für die Implementierung der Einheit geeigneten Ebene festgelegt ist

Anmerkung 1 zum Begriff: Die Eigenschaften im Zusammenhang mit der Aufteilung eines *Evaluierungsgegenstands (TOE)* (3.90) in Module sind in ISO/IEC 15408-3 in den Familien ADV_TDS und ADV_INT beschrieben.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****3.60****Evaluierung mit Mehrfach-Vertrauenswürdigkeit**

Evaluierung eines *Evaluierungsgegenstandes (TOE)* (3.90) unter Verwendung einer *PP-Konfiguration* (3.68), wobei jede PP-Konfigurationskomponente mit einem eigenen Satz von Vertrauenswürdigkeitsanforderungen verbunden ist

Anmerkung 1 zum Begriff: Mindestens eine der PP-Konfigurationskomponenten enthält einen abweichenden Satz von Vertrauenswürdigkeitsanforderungen als die anderen.

3.61**Objekt**

Entität (3.36) im *Evaluierungsgegenstand (TOE)* (3.90), die Informationen enthält oder empfängt und an der Subjekte Operationen durchführen

3.62**Operation**

<an einem Objekt> spezifische *Aktion* (3.1), die durch ein Subjekt an einem Objekt durchgeführt wird

3.63**Betriebsumgebung**

Umgebung, in der der *Evaluierungsgegenstand (TOE)* (3.90) betrieben wird, bestehend aus allem, was sich außerhalb der TOE-Grenze befindet

3.64**optionale Sicherheitsfunktionsanforderung****optionale SFR**

Sicherheitsfunktionsanforderung (SFR) (3.78) in einem *Schutzprofil (PP)* (3.68), *Funktionspaket* (3.51) oder *PP-Modul* (3.71), die zu einem bestimmten Aspekt der Beschreibung von Sicherheitsproblemen des PP beiträgt, deren Aufnahme in die Liste der SFR eines konformen PP oder der *Sicherheitsvorgaben (ST)* (3.82) jedoch nicht zwingend ist

Anmerkung 1 zum Begriff: Eine optionale SFR kann auf eine oder mehrere Bedrohungen der entsprechenden Elemente der *Sicherheitsproblemdefinition (SPD)* (3.80) und/oder organisatorische Sicherheitsrichtlinien (OSP) eingehen, die im Hauptteil des PP, des Funktionspakets oder des PP-Moduls angegeben sind, oder auf zugehörige SPD-Elemente/Zielsetzungen verweisen, die selbst optional sind (da sie nur durch die optionale SFR angesprochen werden).

3.65**organisatorische Sicherheitsrichtlinie**

OSP, en: organisational security policy

Satz von Sicherheitsregeln, -verfahren oder -leitlinien für eine Organisation

Anmerkung 1 zum Begriff: Eine Richtlinie kann sich auf eine spezifische *Betriebsumgebung* (3.63) beziehen.

3.66**Gesamtentscheidung**

Urteil, das ein *Evaluator* (3.45) hinsichtlich des Ergebnisses einer Evaluierung fällt

Anmerkung 1 zum Begriff: Das Urteil kann als „akzeptiert“ oder „abgelehnt“ ausgedrückt werden.

3.67**mögliche Anfälligkeit**

vermutete, aber nicht bestätigte Schwachstelle

Anmerkung 1 zum Begriff: Der Verdacht ergibt sich aufgrund eines angenommenen Angriffspaths zur Verletzung der *Sicherheitsfunktionsanforderungen (SFR)* (3.78).

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****3.68****Schutzprofil****PP**, en: protection profileimplementierungsunabhängige Beschreibung der Sicherheitsanforderungen für einen Typ eines *Evaluierungsgegenstandes (TOE)* (3.90)**3.69****Schutzprofilkonfiguration****PP-Konfiguration**implementierungsunabhängige Beschreibung der Sicherheitsbedürfnisse für einen Typ eines *Evaluierungsgegenstandes (TOE)* (3.90), der mindestens ein *Schutzprofil (PP)* (3.68) und eine zusätzliche nicht leere Menge der PP und *PP-Module* (3.71) (mit den zugehörigen PP-Modulbasen) enthält**3.70****Konfigurationskomponente des Schutzprofils****PP-Konfigurationskomponente***Schutzprofil (PP)* (3.68) oder *PP-Modul* (3.71), die in einer *PP-Konfiguration* (3.69) enthalten sind**3.71****Schutzprofilmodul****PP-Modul**implementierungsunabhängige Beschreibung der Sicherheitsbedürfnisse für einen Typ eines *Evaluierungsgegenstandes (TOE)* (3.90) ergänzend zu einem oder mehreren *Basisschutzprofilen* (3.68) und möglicherweise einigen Basis-PP-Modulen (3.14)**3.72****Modulbasis für das Schutzprofil****PP-Modulbasis**Satz entweder aus *PP-Modulen* (3.71) oder *Schutzprofilen (PP)* (3.68) oder aus beiden, festgelegt durch ein PP-Modul als Grundlage für die Erstellung einer *PP-Konfiguration* (3.69)

Anmerkung 1 zum Begriff: Der Begriff der PP-Modulbasis ist insofern iterativ, als die Basis eines PP-Moduls ein anderes PP-Modul mit einer eigenen Basis enthalten kann, wobei diese Basis ein PP-Modul enthält. Diese „Kette“ endet jedoch mit einem PP-Modul, das nur auf einem oder mehreren PP basiert.

3.73**Präzisierung**

Hinzufügen von Details zu einer Sicherheitskomponente

3.74**Restanfälligkeit**Schwachstelle, die nicht in der *Betriebsumgebung* (3.63) des *Evaluierungsgegenstands (TOE)* (3.90) ausgenutzt werden kann, die aber für Verletzungen der *Sicherheitsfunktionsanforderungen (SFR)* (3.78) durch einen Angreifer genutzt werden kann, der ein höheres *Angriffspotential* (3.8) hat, als es für die Betriebsumgebung des TOEs angenommen wird**3.75****Rolle**vordefinierter Regelsatz, der die zulässigen Interaktionen zwischen einem Benutzer und dem *Evaluierungsgegenstand (TOE)* (3.90) festlegt**3.76****Vertrauenswürdigkeitsanforderung****SAR**, en: security assurance requirementSicherheitsanforderung, die sich auf die Bedingungen und Prozesse für die Entwicklung und Lieferung des *Evaluationsgegenstands (TOE)* (3.90) und die von *Evaluatoren* (3.45) geforderten *Aktionen* (3.1) in Bezug auf die aus diesen Bedingungen und Prozessen resultierenden Nachweise bezieht

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****3.77****Sicherheitsattribut**

Eigenschaft von Subjekten, Benutzern, Objekten, Informationen, Sitzungen und/oder Ressourcen, die verwendet wird, um die *Sicherheitsfunktionsanforderungen (SFR)* (3.78) zu definieren, und deren Werte zur Durchsetzung der SFRs verwendet werden

Anmerkung 1 zum Begriff: Benutzer können externe IT-Produkte einschließen.

3.78**Sicherheitsfunktionsanforderung**

SFR, en: security functional requirement

Sicherheitsanforderung, die zur Erfüllung der *Sicherheitsproblemdefinition (SPD)* (3.80) des *Evaluierungsgegenstands (TOE)* (3.90) beiträgt, wie in einer spezifischen *Sicherheitsvorgabe (ST)* (3.82) oder in einem *Schutzprofil (PP)* (3.68) definiert

Anmerkung 1 zum Begriff: Eine Sicherheitsfunktionsanforderung kann direkt behandelt werden, wie im Modell der *direkten Begründung* (3.34), oder indirekt durch die *Sicherheitszielsetzungen* (3.79) für den TOE, wie im allgemeinen Modell.

3.79**Sicherheitszielsetzung**

Absichtserklärung, identifizierte Bedrohungen *abzuwehren* (3.28) und/oder identifizierte organisatorische Sicherheitsrichtlinien und/oder -annahmen zu erfüllen

3.80**Sicherheitsproblem****Sicherheitsproblemdefinition****SPD**

Aussage, die formal die Natur und den Geltungsbereich der Sicherheit definiert, welche den *Evaluierungsgegenstand (TOE)* (3.90) adressieren soll

Anmerkung 1 zum Begriff: Diese Aussage besteht aus einer Kombination von: Bedrohungen, die durch den TOE und seine *Betriebsumgebung* (3.63) abgewehrt werden sollen, den organisatorischen Sicherheitsrichtlinien (OSP), die durch den TOE und seine Betriebsumgebung durchgesetzt, und den Annahmen, die für die Betriebsumgebung des TOE eingehalten werden.

Anmerkung 2 zum Begriff: SPD-Elemente umfassen Bedrohungen, OSP und Annahmen.

3.81**Sicherheitsanforderung**

Anforderung, die Teil einer Sicherheitsspezifikation des *Evaluierungsgegenstands (TOE)* (3.90) ist, wie in einer spezifischen *Sicherheitsvorgabe (ST)* (3.82) oder in einem *Schutzprofil (PP)* (3.68) definiert

Anmerkung 1 zum Begriff: Die Anforderungen werden in einer Sprache, d. h. in Form und Syntax, angegeben, die in der Normenreihe ISO/IEC 15408 festgelegt ist.

3.82**Sicherheitsvorgabe**

ST, en: Security Target

implementierungsabhängige Beschreibung der Sicherheitsanforderungen für einen *Evaluierungsgegenstand (TOE)* (3.90) auf der Grundlage einer *Sicherheitsproblemdefinition* (3.80)

3.83**Auswahl**

Spezifikation eines oder mehrerer Element(e) aus einer Liste innerhalb einer Komponente

3.84**auswahlbasierte Sicherheitsfunktionsanforderung****auswahlbasierte SFR**

Sicherheitsfunktionsanforderung (SFR) (3.78) in einem *Schutzprofil (PP)* (3.78), *PP-Modul* (3.71) oder *Funktionspaket* (3.51), die zu einem bestimmten Aspekt der *Sicherheitsproblemdefinition* (3.80) des PP, PP-Moduls oder Funktionspakets beiträgt, das in ein(e) konforme(s) PP oder ST aufgenommen werden soll, wenn eine im PP/PP-Modul/Funktionspaket identifizierte Auswahlmöglichkeit anzeigt, dass sie eine zugehörige auswahlbasierte SFR hat

3.85**Evaluierung mit Einfach-Vertrauenswürdigkeit**

Evaluierung eines *Evaluierungsgegenstandes (TOE)* (3.90) unter Verwendung eines Satzes von Vertrauenswürdigkeitsanforderungen

3.86**strikte Konformität**

SC, en: strict conformance

hierarchische Beziehung zwischen einem *Schutzprofil (PP)* (3.68) und einem PP/einer *Sicherheitsvorgabe (ST)* (3.82), wobei alle Anforderungen im PP auch im PP/in der ST vorhanden sind

Anmerkung 1 zum Begriff: Diese Beziehung kann umschrieben werden als: „Die ST enthält alle Aussagen, die im PP vorhanden sind, kann aber weitere enthalten“. Es wird erwartet, dass strikte Konformität für stringente Anforderungen eingesetzt wird, die in konsistenter Weise erfüllt werden müssen.

3.87**Teil-TOE-Sicherheitsfunktionalität****Teil-TSF**

kombinierte Funktionalität der gesamten Hardware, Software und Firmware eines *Evaluierungsgegenstandes (TOE)* (3.90), auf die sich die korrekte Durchsetzung der in einer *PP-Konfigurationskomponente* (3.69) definierten Sicherheitsfunktionsanforderungen (SFR) stützt

Anmerkung 1 zum Begriff: Dieser Satz von SFR wird durch Abhängigkeiten, Zielsetzungen und Elemente der *Sicherheitsproblemdefinition (SPD)* (3.80) in der PP-Konfigurationskomponente geschlossen.

Anmerkung 2 zum Begriff: Der Begriff der Teil-TSF wird im Zusammenhang mit der Spezifikation und Evaluierung von PP-Konfigurationen und konformen Sicherheitsvorgaben (ST) verwendet. Sie kann im Ansatz mit Einfach-Vertrauenswürdigkeit verwendet werden, muss aber im Ansatz mit Mehrfach-Vertrauenswürdigkeit verwendet werden: Teil-TSF müssen in einer PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit und in konformen ST mit Mehrfach-Vertrauenswürdigkeit definiert werden.

Anmerkung 3 zum Begriff: Jede Teil-TSF ist mit einem eigenen Satz von Vertrauenswürdigkeitsanforderungen (SAR) in einer PP-Konfiguration/ST mit Mehrfach-Vertrauenswürdigkeit verbunden. Im weiteren Verlauf des Dokuments kann ein Satz von SAR ein *Vertrauenswürdigkeitspaket* (3.7) darstellen.

Anmerkung 4 zum Begriff: Eine Teil-TSF hat die Merkmale einer TSF.

3.88**Subjekt**

Entität (3.36) im *Evaluierungsgegenstand (TOE)* (3.90), die Operationen an Objekten durchführt

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****3.89****Anpassung**

Hinzufügung einer oder mehrerer funktionaler Anforderungen zu einem *Funktionspaket* (3.51) und/oder Hinzufügung einer oder mehrerer Auswahlen zu einer *Sicherheitsfunktionsanforderung (SFR)* (3.78) in einem Funktionspaket

Anmerkung 1 zum Begriff: Eine solche Anpassung wird nur im Zusammenhang mit einem Paket betrachtet und nicht im Zusammenhang mit anderen Paketen oder *Schutzprofilen (PP)* (3.68) bzw. PP-Modulen.

Anmerkung 2 zum Begriff: Die Auswahlen in der SFR können durch die zusätzlichen Auswahlen ersetzt werden.

Anmerkung 3 zum Begriff: Auswahlen können nur für Pakete hinzugefügt werden, die von den PP oder PP-Modulen beansprucht werden. Die ST können keine an das Paket angepasste Konformität mit dem Paketnamen beanspruchen.

3.90**Evaluierungsgegenstand**

TOE, en: target of evaluation

Satz aus Software, Firmware und/oder Hardware, möglicherweise mit beigefügten Leitlinien, der Gegenstand einer Evaluierung ist

3.91**Bedrohungsagent**

Entität (3.36), die das Potential hat, nachteilige *Aktionen* (3.3) auf *Vermögenswerte* (3.4) auszuüben, die durch den *Evaluierungsgegenstand (TOE)* (3.90) geschützt sind

3.92**TOE-Sicherheitsfunktionalität**

TSF, en: TOE security functionality

kombinierte Funktionalität der gesamten Hardware, Software und Firmware eines *Evaluierungsgegenstands (TOE)* (3.90), auf die sich die korrekte Durchsetzung der *Sicherheitsfunktionsanforderungen (SFR)* (3.78) stützt

3.93**TOE-Typ**

Satz von Merkmalen, die einer Gruppe von *Evaluierungsgegenständen (TOE)* (3.90) gemeinsam sind

Anmerkung 1 zum Begriff: Der TOE-Typ kann in einem *Schutzprofil (PP)* (3.68) expliziter definiert werden.

3.94**Übersetzung**

Prozess der Beschreibung von Sicherheitsanforderungen in einer standardisierten Sprache

Anmerkung 1 zum Begriff: Die Verwendung des Begriffs „Übersetzung“ ist in diesem Zusammenhang nicht wörtlich zu nehmen; es wird nicht impliziert, dass jede in standardisierter Sprache ausgedrückte *Sicherheitsfunktionsanforderung (SFR)* (3.78) wieder in die *Sicherheitszielsetzungen* (3.79) zurückübersetzt werden kann.

3.95**Anfälligkeit**

Schwachstelle im *Evaluierungsgegenstand (TOE)* (3.90), die für Verletzungen von *Sicherheitsfunktionsanforderungen (SFR)* (3.78) in manchen Umgebungen ausgenutzt werden kann

4 Symbole und Abkürzungen

AP Vertrauenswürdigkeitspaket (en: Assurance Package)

API Anwendungsprogrammierschnittstelle (en: Application Programming Interface)

CAP zusammengesetztes Vertrauenswürdigkeitspaket (en: Composed Assurance Package)

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

CD	Compact Disc
CM,	Konfigurationsmanagement (en: Configuration Management)
COMP	Vertrauenswürdigkeitspaket für Verbundprodukte (en: Composed Product Assurance Package)
DAC	benutzerbestimmbare Zugangssteuerung (en: Discretionary Access Control)
DC	nachweisliche Konformität (en: Demonstrable Conformance)
DPA	differentielle Stromverbrauchsanalyse (en: Differential Power Analysis)
DRBG	deterministischer Zufallsbitgenerator (en: Deterministic Random Bit Generator)
EA	Evaluiierungsaufgabe
EAL	Vertrauenswürdigkeitsstufe (en: Evaluation Assurance Level)
EC	genaue Konformität (en: exact conformance)
EM	Evaluiierungsmethode
EMS	elektromagnetisches Spektrum
ETR	technischer Evaluiierungsbericht (en: Evaluation Technical Report)
GAP	gesamtes Vertrauenswürdigkeitspaket (en: Global Assurance Package)
GB	Gigabyte
GHz	Gigahertz
GUI	grafische Benutzungsschnittstelle (en: Graphical User Interface)
HSM	Hardware-Sicherheitsmodul
HTTPS	Hypertext-Übertragungsprotokoll sicher (en: Hypertext Transfer Protocol Secure)
IC	integrierte Schaltung (en: Integrated Circuit)
IOCTL	Eingabe-Ausgabe-Steuerung (en: Input Output Control)
IP	Internet-Protokoll
IPsec	IP-Sicherheit (Protokoll) (en: IP security)
IT	Informationstechnologie
LDAP	vereinfachtes Verzeichniszugriffsprotokoll (en: Lightweight Directory Access Protocol)
MAC	systembestimmte Zugangssteuerung (en: Mandatory Access Control)
MB	Megabyte
MBps	Megabytes je Sekunde
OR	Beobachtungsbericht (en: Observation Report)
OS	Betriebssystem (en: Operating System)
OSP	organisatorische Sicherheitsrichtlinie (en: Organisational Security Policy)
OTP	einmalig programmierbar (en: One-Time Programmable)
PC	Personal Computer
PCI	Peripheral Component Interconnect
PKI	Public-Key-Infrastruktur (en: Public Key Infrastructure)
PP	Schutzprofil (en: Protection Profile)
PPA	Vertrauenswürdigkeitspaket für das Schutzprofil (en: Protection Profile Assurance package)
RAM	Direktzugriffsspeicher (en: Random Access Memory)
RBG	Zufallsbitgenerator (en: Random Bit Generator)
RNG	Zufallszahlengenerator (en: Random Number Generator)
RPC	Remote Procedure Call
SAR	Vertrauenswürdigkeitsanforderung (en: Security Assurance Requirement)
SC	strikte Konformität (en: Strict Conformance)

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

SFP	Sicherheitsfunktionsrichtlinien (en: Security Function Policies)
SFR	Sicherheitsfunktionsanforderung (en: Security Functional Requirement)
SPA	einfache Stromverbrauchsanalyse (en: Simple Power Analysis)
SPD	Sicherheitsproblemdefinition (en: Security Problem Definition)
SSH	Secure Shell
ST	Sicherheitsvorgabe (en: Security Target)
STA	Vertrauenswürdigkeitspaket für die Sicherheitsvorgabe (En: Security Target Assurance package)
TCP	Transmission Control Protocol
TLS	Transportschichtssicherheit (en: Transport Layer Security)
TOE	Evaluierungsgegenstand (en: target of evaluation)
TSF	TOE-Sicherheitsfunktionalität (en: TOE Security Functionality)
TSFI	TSF-Schnittstelle (en: TSF Interface)
USB	universeller serieller Bus
VPN	Virtual Private Network

5 Übersicht**5.1 Allgemein**

In diesem Abschnitt werden die wesentlichen Konzepte der Normenreihe ISO/IEC 15408 eingeführt. Beschrieben werden das Konzept des Evaluierungsgegenstands (TOE), die Zielgruppe der Normenreihe ISO/IEC 15408 und die Art der Präsentation des Inhalts in der Normenreihe ISO/IEC 15408.

5.2 Beschreibung der Normenreihe ISO/IEC 15408**5.2.1 Allgemein**

Wie unten aufgezeigt, wird die Normenreihe ISO/IEC 15408 als eine Reihe eigenständiger aber zusammenhängender Teile dargestellt:

- a) **ISO/IEC 15408-1, Einleitung und allgemeines Modell** ist die Einleitung zur Normenreihe ISO/IEC 15408. Dieser Teil definiert die allgemeinen Konzepte und Grundlagen der IT-Sicherheitsevaluierung und zeigt ein allgemeines Evaluierungsmodell;
- b) **ISO/IEC 15408-2, Sicherheitsfunktionskomponenten** legt einen Satz an Funktionskomponenten als Standardvorlagen fest, die als Grundlage für Sicherheitsfunktionsanforderungen (SFR) an TOEs dienen. ISO/IEC 15408-2 katalogisiert den Satz an Sicherheitsfunktionskomponenten und organisiert ihn in Familien und Klassen;
- c) **ISO/IEC 15408-3, Vertrauenswürdigkeitskomponenten** legt einen Satz an Vertrauenswürdigkeitskomponenten als Standardvorlagen fest, die als Grundlage für Vertrauenswürdigkeitsanforderungen an TOEs dienen. ISO/IEC 15408-3 katalogisiert den Satz an Vertrauenswürdigkeitskomponenten und organisiert ihn in Familien und Klassen. ISO/IEC 15408-3 legt auch Evaluierungskriterien für die PP, ST und TOE fest;
- d) **ISO/IEC 15408-4, „Rahmen für die Festlegung von Bewertungsmethoden und -tätigkeiten“** bietet einen normgerechten Rahmen für die Spezifikation von Evaluierungsmethoden und -aufgaben, die in den PP, ST und allen sie unterstützenden Dokumenten enthalten sein können, um von Evaluatoren zur Unterstützung von Evaluierungen unter Verwendung des in den anderen Teilen der Normenreihe ISO/IEC 15408 beschriebenen Modells verwendet zu werden. ISO/IEC 18045 ist grundlegend für ISO/IEC 15408-4;

- e) **ISO/IEC 15408-5, „Vordefinierte Pakete von Sicherheitsanforderungen“** stellt Vertrauenswürdigkeitspakete und SFR zur Verfügung, die als zweckmäßig zur Unterstützung der gemeinsamen Nutzung durch die interessierten Parteien identifiziert worden sind. Beispiele für bereitgestellte Pakete umfassen die Vertrauenswürdigkeitsstufen (EAL-Stufen) und die zusammengesetzten Vertrauenswürdigkeitspakete (CAP).

Bei der Anwendung der Normenreihe ISO/IEC 15408 muss eine Begründung vorgelegt werden, wenn die empfohlene Option nicht gewählt wird.

Zur Unterstützung der Normenreihe ISO/IEC 15408 wurden noch weitere Dokumente veröffentlicht. In den Literaturhinweisen sind Dokumente zur Unterstützung aufgeführt.

ANMERKUNG ISO/IEC 18045 umfasst die grundlegende Methodologie für IT-Sicherheitsbewertungen, die in Übereinstimmung mit der Normenreihe ISO/IEC 15408 durchgeführt wird.

5.2.2 Zielgruppe

5.2.2.1 Allgemein

Fünf Hauptgruppen haben ein allgemeines Interesse an der Evaluierung der Sicherheitseigenschaften der TOE: Verbraucher (Risikoeigentümer), Entwickler, technische Arbeitsgruppen, Evaluatoren und andere. Die in der Normenreihe ISO/IEC 15408 enthaltenen Informationen wurden so strukturiert, dass sie die Bedürfnisse all dieser Gruppen abdecken, die als Hauptbenutzer der Normenreihe ISO/IEC 15408 angesehen werden. In 5.2.2.2 bis 5.2.2.6 wird erklärt, wie die Gruppen von den Kriterien profitieren können.

5.2.2.2 Verbraucher (Risikoeigentümer)

Die Normenreihe ISO/IEC 15408 wurde geschrieben, um sicherzustellen, dass die Evaluierung die Bedürfnisse der Risikoeigentümer erfüllt, da dies grundlegender Zweck und Grund für den Evaluierungsprozess ist.

Risikoeigentümer können die Ergebnisse der Evaluierung als Hilfe bei der Entscheidung verwenden, ob ein TOE ihre Sicherheitsbedürfnisse erfüllt. Diese Sicherheitsbedürfnisse sind üblicherweise das Ergebnis einer Risikoanalyse und auch der Ausrichtung einer Richtlinie. Risikoeigentümer können die Evaluierungsergebnisse auch verwenden, um verschiedene TOEs zu vergleichen.

Die Normenreihe ISO/IEC 15408 übergibt Risikoeigentümern, insbesondere jenen in Verbrauchergruppen und Interessengemeinschaften, eine implementationsunabhängige Struktur, das sogenannte PP, in dem ihre Sicherheitsanforderungen eindeutig formuliert werden können.

5.2.2.3 Entwickler

Die Normenreihe ISO/IEC 15408 ist für die Unterstützung von IT-Produktentwicklern ausgelegt und bereitet sie auf die Evaluierung der TOEs vor und hilft beim Identifizieren der von den TOEs zu erfüllenden Sicherheitsanforderungen. Diese Anforderungen sind in einem implementationsabhängigen Konstrukt, der Sicherheitsvorgabe (ST; en: security target) enthalten. Diese ST kann einem oder mehreren PPs entsprechen, um aufzuzeigen, dass der TOE die Sicherheitsanforderungen von Verbrauchern erfüllt, die in jenen PPs dargelegt sind.

Die Normenreihe ISO/IEC 15408 kann anschließend zur Bestimmung der Verantwortlichkeiten und Aktionen verwendet werden, um bei der Erbringung der erforderlichen Nachweise zur Evaluierung des TOEs gegen diese Anforderung zu unterstützen. Die Norm definiert außerdem den Inhalt und die Präsentation dieser Nachweise.

5.2.2.4 Technische Arbeitsgruppen

Die Normenreihe ISO/IEC 15408 soll technische Arbeitsgruppen bei der Vorbereitung und Entwicklung der PP, PP-Module, PP-Konfigurationen, Pakete und unterstützenden Dokumente oder Leitlinien unterstützen. Technische Arbeitsgruppen können sich aus interessierten Parteien wie Verbrauchern (Risikoeigentümern), Entwicklern, Evaluatoren und Wissenschaftlern zusammensetzen.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01 prEN ISO/IEC 15408-1:2023 (D)

5.2.2.5 Evaluatoren

Die Normenreihe ISO/IEC 15408 enthält Kriterien, die von Evaluatoren bei ihrer Beurteilung zur Konformität von TOEs, ST, PP und PP-Konfigurationen mit ihren Sicherheitsanforderungen zu verwenden sind. Die Normenreihe ISO/IEC 15408 beschreibt die allgemeine Reihe von Aktionen, die von Evaluatoren auszuführen sind.

ANMERKUNG Die Normenreihe ISO/IEC 15408 spezifiziert keine Verfahren zur Ausführung dieser Aktionen. Weitere Informationen zu diesen Verfahren können Abschnitt 13 entnommen werden.

5.2.2.6 Weitere

Die Normenreihe ISO/IEC 15408 ist zwar für die Spezifizierung und Evaluierung von IT-Sicherheitseigenschaften von TOEs ausgelegt, kann aber auch als Verweismaterial für alle interessierten oder verantwortlichen Parteien in der IT-Sicherheit nützlich sein. Einige der zusätzlichen Interessengruppen, die von den in der Normenreihe ISO/IEC 15408 enthaltenen Informationen profitieren können, sind:

- a) Systemverwalter und Systemsicherheitsbeauftragte, die für die Bestimmung und Einhaltung organisatorischer IT-Sicherheitsrichtlinien und Sicherheitsanforderungen verantwortlich sind;
- b) Auditoren, sowohl interne als auch externe, die für die Bewertung der Angemessenheit der Sicherheit einer IT-Lösung (die ein TOE sein oder enthalten kann) verantwortlich sind;
- c) Sicherheitsarchitekten und Sicherheitsdesigner, die für die Spezifizierung der Sicherheitseigenschaften eines IT-Produkts verantwortlich sind;
- d) Akkreditierer, die für das Akzeptieren einer IT-Lösung zur Verwendung in einer bestimmten Umgebung verantwortlich sind;
- e) Sponsoren der Evaluierung, die für die Anforderung und Unterstützung einer Evaluierung verantwortlich sind;
- f) Evaluierungsinstanzen, die für das Management und die Aufsicht eines IT-Sicherheitsevaluierungsprogramms verantwortlich sind;
- g) Akademiker, die Forschung zum Thema IT-Sicherheit betreiben.

Tabelle 1 zeigt, wie die einzelnen Teile der Normenreihe ISO/IEC 15408 für jede der Zielgruppen von Interesse sein können.

- Entwurf -

Tabelle 1 — Roadmap für die „Evaluierungskriterien für IT-Sicherheit“

Teile der ISO/IEC 15408	Verbraucher (Risikoeigentümer)	Entwickler	Technische Arbeitsgruppen	Evaluatoren	Weitere
Teil 1	Sollte für Hintergrundinformationen, Verweisungszwecke und als Leitfaden für die Struktur der PP, PP-Module, PP-Konfigurationen, ST und Zusammensetzung verwendet werden. Muss für die Entwicklung von Sicherheitsspezifikationen und Sicherheitsproblemdefinitionen (SPD) für TOE verwendet werden.	Sollte für Hintergrundinformationen, Verweisungszwecke und als Leitfaden für die Struktur der PP, PP-Module, PP-Konfigurationen, ST und Zusammensetzung verwendet werden. Muss für die Entwicklung von Sicherheitsspezifikationen für TOEs verwendet werden.	Sollte für Hintergrundinformationen, Verweisungszwecke und als Leitfaden für die Struktur der PP, PP-Module, PP-Konfigurationen, ST und Zusammensetzung verwendet werden. Muss für die Entwicklung von Sicherheitsspezifikationen für Pakete, PP, PP-Module und PP-Konfigurationen verwendet werden.	Sollte für Hintergrundinformationen, Verweisungszwecke und als Leitfaden für die Struktur der PP, PP-Module, PP-Konfigurationen, ST und Zusammensetzung verwendet werden. Muss bei der Evaluierung der PP, PP-Konfigurationen und ST verwendet werden.	Darf für Hintergrundinformationen, Verweisungszwecke und als Leitfaden für die Struktur der PP, PP-Module, PP-Konfigurationen, ST und Zusammensetzung verwendet werden.
Teil 2	Muss als Leitfaden und zur Verweisung bei der Festlegung von Aussagen zu Sicherheitsfunktionskomponenten für deren Risikoumgebung verwendet werden.	Muss zur Verweisung bei der Interpretation von Aussagen zu Sicherheitsfunktionskomponenten in Paketen, PP und PP-Modulen verwendet werden. Muss bei der Ausarbeitung der ST verwendet werden. Darf bei der Formulierung von Sicherheitsfunktionen für IT-Produkte verwendet werden.	Muss zur Verweisung bei der Festlegung von Aussagen zu Sicherheitsfunktionskomponenten in Paketen, PP und PP-Modulen verwendet werden.	Muss zur Verweisung bei der Evaluierung von Sicherheitsfunktionskomponenten in Paketen, PP und PP-Modulen oder Sicherheitsfunktionsanforderungen (SFR) in den ST verwendet werden.	Darf zur Verweisung bei der Überprüfung der in den Paketen, PP und PP-Modulen angegebenen Sicherheitsfunktionskomponenten oder der Sicherheitsfunktionsanforderungen (SFR) in den ST verwendet werden.
Teil 3	Muss als Leitlinien und zur Verweisung bei der Bestimmung der für ihre Risikoumgebung erforderlichen Sicherheitsmaßnahmen verwendet werden.	Muss zur Verweisung bei der Interpretation von Aussagen zu Vertrauenswürdigkeitskomponenten in Paketen, PP, PP-Modulen und PP-Konfigurationen verwendet werden. Muss bei der Ausarbeitung der ST verwendet werden. Darf bei der Formulierung oder Verbesserung der Entwicklungsprozesse verwendet werden.	Muss zur Verweisung bei der Festlegung von Aussagen zu Vertrauenswürdigkeitskomponenten in Paketen, PP, PP-Modulen und PP-Konfigurationen verwendet werden.	Muss zur Verweisung bei der Evaluierung von Sicherheitsfunktionskomponenten in Paketen, PP, PP-Modulen und PP-Konfigurationen oder Vertrauenswürdigkeitsanforderungen in den ST verwendet werden.	Darf zur Verweisung bei der Überprüfung der in den Paketen, PP, PP-Modulen und PP-Konfigurationen angegebenen Sicherheitsfunktionskomponenten oder der Vertrauenswürdigkeitsanforderungen in den ST verwendet werden.

- Entwurf -
Tabelle 1 (fortgesetzt)

Teile der ISO/IEC 15408	Verbraucher (Risikoeigentümer)	Entwickler	Technische Arbeitsgruppen	Evaluatoren	Weitere
Teil 4	Sollte zur Verweisung und Hintergrundinformation für die Struktur der Evaluierungsmethode(n) und/oder -aufgaben verwendet werden.	Sollte zu Referenzzwecken und als Leitlinien für die Struktur der Evaluierungsmethode(n) und/oder -aufgaben verwendet werden.	Sollte zu Referenzzwecken und als Leitlinien für die Struktur der Evaluierungsmethoden und -aufgaben verwendet werden.	Sollte zu Referenzzwecken und als Leitlinien für die Struktur der Evaluierungsmethoden und -aufgaben verwendet werden. Sollte bei der Formulierung spezifischer Evaluierungsmethoden und -aufgaben verwendet werden.	Darf zu Referenzzwecken und als Leitlinien für die Struktur der Evaluierungsmethoden und -aufgaben verwendet werden.
Teil 5	Sollte zur Verweisung bei der Bestimmung des Inhalts von beanspruchten vordefinierten Paketen von Sicherheitsanforderungen verwendet werden.	Muss bei der Entwicklung der ST verwendet werden, die Konformität mit vordefinierten Paketen von Sicherheitsanforderungen beanspruchen. Muss zur Verweisung bei der Vorbereitung eines TOE für die Evaluierung konform mit vordefinierten Paketen von Sicherheitsanforderungen verwendet werden.	Muss bei der Entwicklung der PP, PP-Module und PP-Konfigurationen verwendet werden, die Konformität mit vordefinierten Paketen von Sicherheitsanforderungen beanspruchen.	Muss zur Verweisung bei der Evaluierung der PP, PP-Module und PP-Konfigurationen oder ST verwendet werden, die Konformität mit vordefinierten Paketen von Sicherheitsanforderungen beanspruchen.	Darf zur Verweisung bei der Bestimmung des Inhalts von beanspruchten vordefinierten Paketen von Sicherheitsanforderungen verwendet werden.

5.3 Evaluierungsgegenstand (TOE)

5.3.1 Allgemein

Die Normenreihe ISO/IEC 15408 ist flexibel bei der Frage, was evaluiert wird und daher nicht an die Grenzen von IT-Produkten gebunden wie sie im Allgemeinen aufgefasst werden. Daher benutzt die Normenreihe ISO/IEC 15408 im Zusammenhang mit der Evaluierung den Begriff „Evaluierungsgegenstand“ (TOE; en: Target of Evaluation).

Der TOE mag in vielen Fällen ein vollständiges IT-Produkt sein, braucht es aber nicht. Der TOE kann ein IT-Produkt sein, Teil eines IT-Produkts, ein Satz von IT-Produkten, eine spezifische Technologie, die vielleicht nie zu einem Produkt wird, oder eine Kombination dieser Komponenten.

Im Sinne der Normenreihe ISO/IEC 15408 ist die genaue Beziehung zwischen dem TOE und jeglichem IT-Produkt nur für einen Aspekt wichtig: Die Evaluierung eines TOEs, das nur einen Teil des IT-Produkts umfasst, sollte nicht fälschlich für die Evaluierung des gesamten IT-Produkts gehalten werden.

BEISPIEL Beispiele für TOE sind Geräte, die sich durch wenige Schnittstellen, eine geringe Angriffsfläche und eine bekannte Lieferkette auszeichnen:

- ein Netzwerkgerät;
- eine Softwareanwendung;
- ein Betriebssystem;
- ein Virtualisierungssystem;
- eine integrierte Schaltung;
- der kryptographische Co-Prozessor einer integrierten Schaltung;
- eine Anwendung für ein Mobilgerät;
- eine Datenbankanwendung ohne Remote-Client-Software, die bei Datenbankanwendungen üblich ist.

Die TOE können auch komplexer sein, gekennzeichnet durch eine große Schnittstelle/große Schnittstellen und/oder eine große Anzahl an Komponenten, mehrere Herstellungs-/Integrationsphasen, vor Ort aufrüstbare Produkte wie z. B.:

- ein lokales Netz (LAN) mit allen Terminals, Servern, Netzwerkeinrichtungen und Software;
- ein Mobilgerät;
- Gateways und Hubs;
- eine Softwareanwendung in Verbindung mit einem Betriebssystem;
- ein Multifunktionsgerät wie z. B. einen Multifunktionsdrucker;
- ein Hardware-Sicherheitsmodul (HSM).

5.3.2 TOE-Grenzen

Das Konzept einer TOE-Grenze ist für die Spezifikation der ST von grundlegender Bedeutung.

Ein TOE kann ein komplettes IT-Produkt (oder Produkte) sein, ein Teil eines IT-Produkts oder aus verschiedenen Komponenten bestehen. Die ST muss den physischen und logischen Anwendungsbereich des TOE bei der Auslieferung an den Kunden klar umreißen.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Alle Teile eines IT-Produkts, die nicht innerhalb der TOE-Grenze liegen, befinden sich außerhalb des Anwendungsbereichs der Evaluierung und werden als *Nicht-TOE-Teile des IT-Produkts* bezeichnet.

5.3.3 Unterschiedliche Darstellungen des TOEs

In der Normenreihe ISO/IEC 15408 kann ein TOE im Zusammenhang mit den Vertrauenswürdigkeitskriterien in mehreren Darstellungen auftreten:

ANMERKUNG Zu diesen Vertrauenswürdigkeitskriterien gehören das Prüfen (ATE) und die Anfälligkeitsanalyse (AVA), für die Proben des TOE erforderlich sind, einige Designkriterien (ADV_IMP), für die eine Implementierungsrepräsentation, z. B. der Quellcode, erforderlich ist, und der Lebenszyklus (ALC), für den die Konfigurationsliste des TOE erforderlich ist.

BEISPIEL TOE-Darstellungen für einen Software-TOE:

- eine Liste von Dateien in einem Konfigurationsmanagementsystem;
- eine einzige Master-Kopie, die soeben kompiliert wurde;
- der Quellcode für eine bestimmte Version einer Open-Source-Distribution;
- eine Schachtel mit einem physischen Medium und einem Handbuch, bereit zur Lieferung an den Kunden;
- eine Binärdatei, die zum sicheren Download bereitsteht;
- eine installierte und betriebsbereite Version.

TOE-Darstellungen für einen Hardware-TOE:

- Layout von integrierten Schaltungen;
- Speicherzuordnungen;
- Wafer;
- Module.

Alle Aufzählungspunkte werden als TOE betrachtet und überall, wo der Begriff „TOE“ in der Normenreihe ISO/IEC 15408 verwendet wird, bestimmt der Kontext die beschriebene Darstellung.

5.3.4 Unterschiedliche Konfigurationen des TOEs

Im Allgemeinen können IT-Produkte auf unterschiedliche Weise mit verschiedenen aktivierten oder deaktivierten Optionen konfiguriert werden. Bei einer Evaluierung, die in Übereinstimmung mit der Normenreihe ISO/IEC 15408 durchgeführt wird, wird festgestellt, ob ein TOE bestimmte Anforderungen erfüllt. Es ist oft der Fall, dass der Leitlinienteil des TOE die möglichen Konfigurationen des TOE einschränkt, d. h. die Leitlinien für den TOE können sich von den allgemeinen Leitlinien des IT-Produkts unterscheiden.

BEISPIEL Ein Betriebssystem ist ein IT-Produkt: Das Produkt kann auf verschiedene Arten konfiguriert werden, einschließlich z. B. der Arten der Benutzer, der Anzahl der Benutzer, der Arten der erlaubten/unerlaubten externen Verbindungen, der aktivierten/deaktivierten Optionen.

Wenn ein IT-Produkt einen TOE enthält oder ein TOE ist, muss die Konfiguration des Produkts im Allgemeinen sehr viel strenger kontrolliert werden, da einige Konfigurationsoptionen dazu führen können, dass ein TOE die Anforderungen nicht erfüllt.

Aus diesem Grund wäre ein Unterschied zu erwarten zwischen der Leitliniendokumentation für das allgemeine IT-Produkt, die viele Konfigurationen zulässt, und der Leitliniendokumentation für den TOE, die möglicher-

weise nur eine oder nur eine Reihe von Konfigurationen zulässt, die sich in sicherheitsrelevanter Hinsicht nicht unterscheiden.

Wenn die Leitliniendokumentation für den TOE mehr als eine Konfiguration erlaubt, werden diese Konfigurationen insgesamt „der TOE“ genannt, und jede Konfiguration muss die an den TOE gestellten Anforderungen erfüllen.

5.3.5 Betriebsumgebung des TOE

Alles, was außerhalb der TOE-Grenze liegt, gehört zur Betriebsumgebung des TOE. Wenn der TOE-Teil eines IT-Produkts ist, kann das IT-Produkt Teile haben, die nicht zum TOE gehören. Solche Nicht-TOE-Teile sind ebenfalls Teil der Betriebsumgebung des TOE.

Die ST muss Annahmen beschreiben und Sicherheitszielsetzungen für die Betriebsumgebung definieren, die zusammen mit der vom TOE selbst bereitgestellten Sicherheitsfunktionalität notwendig sind, um die Bedrohungen abzuschwächen und die organisatorischen Sicherheitsrichtlinien (OSP) durchzusetzen.

Die Sicherheitszielsetzungen für die Betriebsumgebung dürfen die TOE-Sicherheitsfunktionalität unterstützen.

Die ST muss klare Anforderungen an die TOE-Umgebung formulieren, um dem Benutzer ausreichende Informationen für die ordnungsgemäße Nutzung des evaluierten TOE zur Verfügung zu stellen.

BEISPIEL Beispiele für eine Sicherheitszielsetzung für die Betriebsumgebung, die die kryptographischen Dienste des TOE unterstützt, die unter Verwendung der FCS-Komponenten von ISO/IEC 15408-2 festgelegt wurden, sind sichere Schlüsselgenerierungs- und Injektionsvoraussetzungen und -prozesse.

5.4 Darstellung des Inhalts dieses Dokuments

Das allgemeine Modell wird in Abschnitt 6 vorgestellt, in dem die Konzepte im Zusammenhang mit der Evaluierung der Sicherheitsfunktionalität von IT-Produkten, der Definition des Sicherheitsproblems und der Spezifikation von Sicherheitsanforderungen zur Lösung des Sicherheitsproblems erläutert werden. Es werden Konzepte für die Spezifikation von Sicherheitsanforderungen, Paketen, PP, PP-Modulen und PP-Konfigurationen vorgestellt, die sich auf die Bedürfnisse von Risikoeigentümern mit ähnlichen Sicherheitsproblemen beziehen.

Die in ISO/IEC 15408-2 und ISO/IEC 15408-3 vorgesehenen Mittel zur Spezifizierung von Sicherheitsanforderungen und zur Vervollständigung von Sicherheitskomponenten werden in Abschnitt 7 und Abschnitt 8 erläutert.

Die Anforderungen und Empfehlungen für die Kernkonstrukte der Pakete, PP, PP-Module, PP-Konfigurationen und ST sind in Abschnitt 9, Abschnitt 10, Abschnitt 11 und 11.3.3 erläutert.

Die Anforderungen und Empfehlungen für die Evaluierung und die Evaluierungsergebnisse für die TOE, ST, PP und PP-Konfigurationen sind in Abschnitt 13 zu finden.

Schließlich findet sich das Thema der Zusammensetzung der Vertrauenswürdigkeit in Abschnitt 14.

6 Allgemeines Modell

6.1 Hintergrund

Dieser Abschnitt zeigt die durchgängig in der Normenreihe ISO/IEC 15408 verwendeten allgemeinen Konzepte, einschließlich des Kontextes, in dem die Konzepte zu verwenden sind, und des Ansatzes zur Anwendung der Konzepte. ISO/IEC 15408-2, ISO/IEC 15408-3, ISO/IEC 15408-4 und ISO/IEC 15408-5 erweitern die Verwendung dieser Konzepte und gehen davon aus, dass der hier beschriebene Ansatz verwendet wird. Des Weiteren ist ISO/IEC 18045 anwendbar für Anwender der Normenreihe ISO/IEC 15408, die Evaluierungstätigkeiten planen.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01 prEN ISO/IEC 15408-1:2023 (D)

Die Normenreihe ISO/IEC 15408 behandelt Sicherheit über eine Reihe von Sicherheitskonzepten und Terminologie. Ein Verständnis dieser Konzepte und der Terminologie ist eine Voraussetzung für die effektive Verwendung der Normenreihe ISO/IEC 15408. Die Konzepte selbst sind allerdings nicht dazu ausgelegt, die Klassen der IT-Sicherheitsprobleme einzuschränken, für die die Normenreihe ISO/IEC 15408 anwendbar ist. Abschnitt 6 setzt voraus, dass der Leser über Wissen im Bereich der IT-Sicherheit verfügt, und er soll nicht als Anleitung in diesem Bereich dienen.

6.2 Vermögenswerte und Sicherheitsmaßnahmen

Bei der Sicherheit geht es um den Schutz von Vermögenswerten innerhalb der Betriebsumgebung.

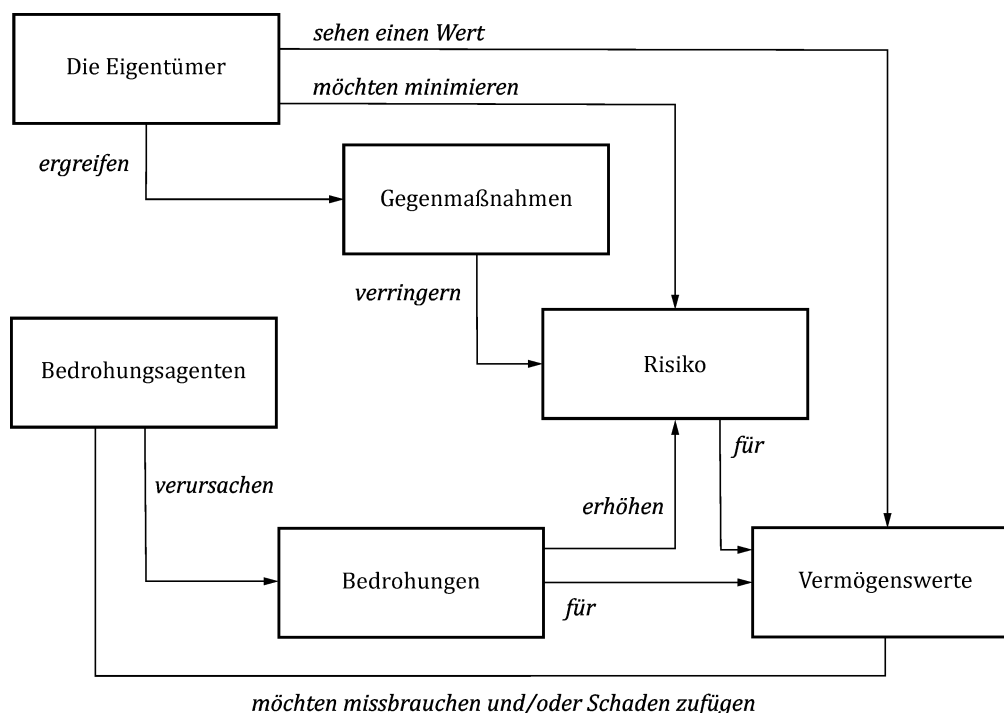
BEISPIEL 1 Ein Beispiel für einen Vermögenswert sind Inhalte von Dateien oder eines Servers.

Beispiele für Betriebsumgebungen im Zusammenhang mit einem solchen Vermögenswert sind:

- ein Rechenzentrum, in dem der Server installiert ist;
- ein mit dem Internet verbundenes Rechnernetzwerk, das den Server mit der Welt verbindet;
- ein LAN, das den Server mit anderen Servern und/oder Arbeitsstationen verbindet;
- die alltägliche Umgebung eines Benutzers, der Informationen vom Server oder eine bestimmte Datei verwendet;
- eine allgemeine Büroumgebung, die Kommunikationsmöglichkeiten mit dem Server und/oder einer bestimmten Datei bietet.

Viele Vermögenswerte liegen in der Form von Informationen vor, die von IT-Produkten gespeichert, verarbeitet und übertragen werden, welche die von den Informationseigentümern festgelegten Anforderungen erfüllen müssen. Informationseigentümer können verlangen, dass Verfügbarkeit, Verbreitung und Veränderung solcher Informationen streng geregelt sind und dass Vermögenswerte durch in der Betriebsumgebung implementierten Sicherheitsmaßnahmen vor Bedrohungen geschützt werden. Bild 1 zeigt diese übergeordneten Konzepte und Beziehungen.

ANMERKUNG ISO/IEC 27001 bietet die Anforderungen für die Einrichtung, Umsetzung, Aufrechterhaltung und fortlaufende Verbesserung eines Informationssicherheitsmanagementsystems einschließlich der Spezifikation der Maßnahmen.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****Bild 1 — Sicherheitskonzepte und Beziehungen**

Die Absicherung von Vermögenswerten liegt in der Verantwortung der Eigentümer, die Wert in diesen Vermögenswerten sehen. Tatsächliche und angenommene Bedrohungsagenten können auch Wert in den Vermögenswerten sehen und versuchen, diese Vermögenswerte in einem dem Eigentümer entgegengesetztem Interesse zu missbrauchen.

BEISPIEL 2 Beispiele für Bedrohungsagenten umfassen Hacker, böswillige Benutzer, nicht-böswillige Benutzer (die manchmal Fehler machen), Computerprozesse und Unfälle.

Die Eigentümer der Vermögenswerte können diese Bedrohungen als potentielle Quelle für eine Schädigung der Vermögenswerte wahrnehmen, was zu einer Minderung ihres Werts führt. Sicherheitsspezifische Schädigung umfasst häufig, aber ist nicht beschränkt auf den Verlust der Vertraulichkeit des Vermögenswerts, den Verlust der Integrität des Vermögenswerts und den Verlust der Verfügbarkeit des Vermögenswerts.

Diese Bedrohungen verursachen daher Risiken für die Vermögenswerte, basierend auf der Wahrscheinlichkeit der Umsetzung der Bedrohung und des Einflusses auf die Vermögenswerte, wenn die Bedrohung umgesetzt wird. Anschließend werden Maßnahmen ergriffen, um die Risiken auf die Vermögenswerte zu reduzieren. Diese Maßnahmen können aus IT-bezogenen Maßnahmen (z. B. Firewalls und Chipkarten) und Nicht-IT-Maßnahmen (z. B. Wachleute und Verfahren) bestehen. Siehe auch ISO/IEC 27001 und ISO/IEC 27002 für eine allgemeinere Erörterung zu Sicherheitsmaßnahmen und deren Implementierung und Verwaltung.

Eigentümer von Vermögenswerten können verantwortlich (oder haftbar) sein für diese Vermögenswerte und sollten daher in der Lage sein, die Entscheidung zum Akzeptieren der Risiken zu verteidigen, wenn die Vermögenswerte den Bedrohungen ausgesetzt werden.

Bei der Verteidigung dieser Entscheidung gibt es zwei wichtige Elemente, die das demonstrieren:

- die Maßnahmen sind angemessen: wenn die angewandten Maßnahmen das tun, was sie versprechen, sind die Bedrohungen für die Vermögenswerte abgewehrt;
- die Maßnahmen sind korrekt: wenn die angewandten Maßnahmen das tun, was sie versprechen.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Vielen Eigentümern von Vermögenswerten mangelt es an Wissen, Expertise oder den erforderlichen Ressourcen, um die Angemessenheit und die Korrektheit der Sicherheitsmaßnahmen zu beurteilen, und die Eigentümer möchten sich nicht immer allein auf die Aussagen der Entwickler der Sicherheitsmaßnahmen verlassen. Diese Verbraucher können sich daher dazu entschließen, ihre Zuversicht in Angemessenheit und Korrektheit einiger oder aller derer Sicherheitsmaßnahmen zu erhöhen, indem sie eine Evaluierung dieser Sicherheitsmaßnahmen beauftragen.

Bild 2 beschreibt die in diesem Abschnitt erörterten Evaluierungskonzepte und Beziehungen.

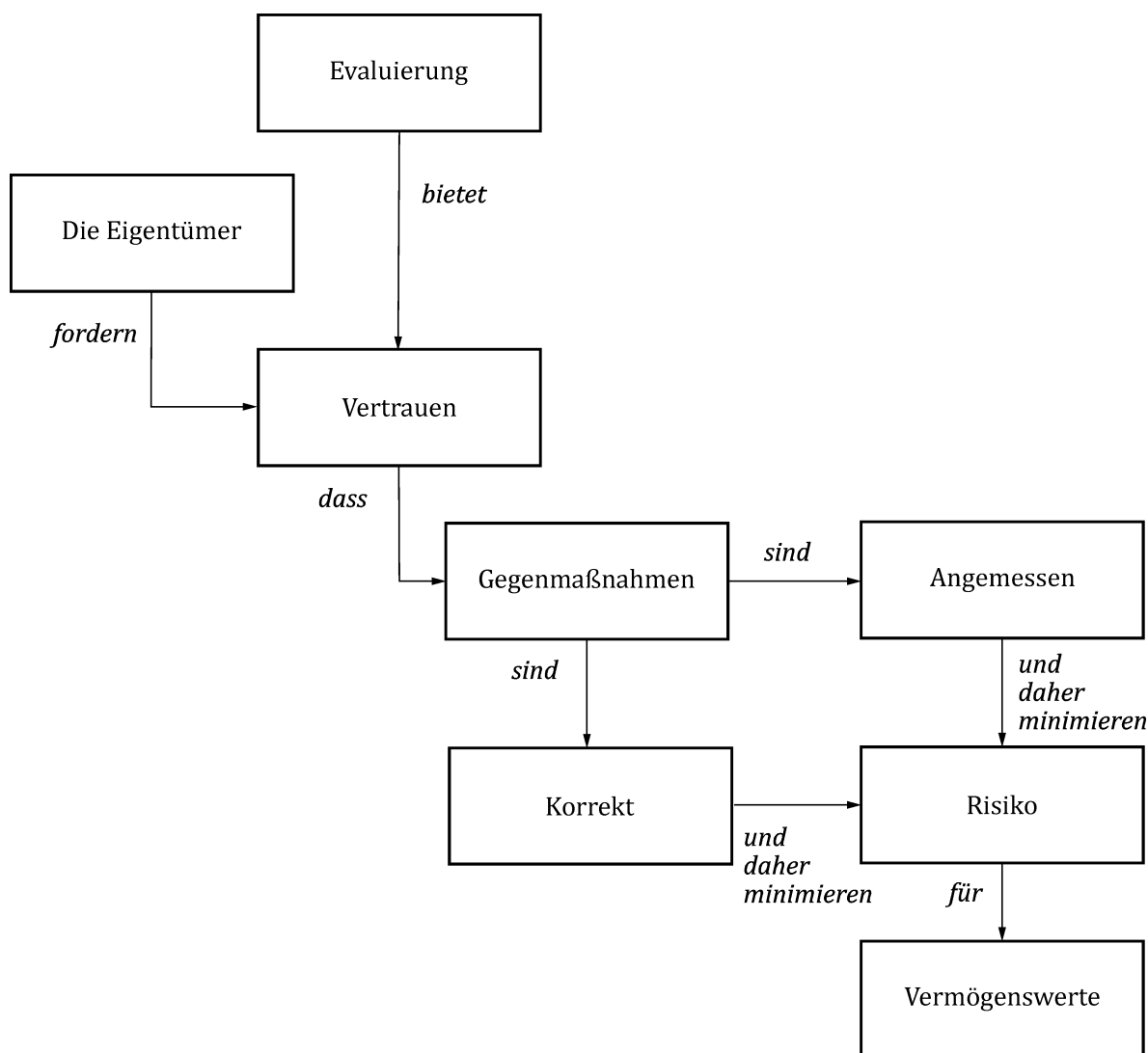


Bild 2 — Evaluierungskonzepte und Beziehungen

Die Angemessenheit der Sicherheitsmaßnahmen wird bei einer Evaluierung über ein Konstrukt namens Sicherheitsvorgabe (ST) analysiert.

6.3 Kernkonstrukte des Paradigmas der Normenreihe ISO/IEC 15408

6.3.1 Allgemein

Die Normenreihe ISO/IEC 15408 legt ein flexibles Rahmenwerk für die Evaluierung von IT-Produkten fest.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Um Verbrauchergruppen und technischen Gemeinschaften die Möglichkeit zu geben, ihre Sicherheitsbedürfnisse auszudrücken, und um das Verfassen geeigneter Dokumente zu erleichtern, die diese Bedürfnisse zum Ausdruck bringen, sind im Paradigma fünf Konstrukte vorgesehen: Paket, PP, PP-Modul, PP-Konfiguration und ST.

Da eine Evaluierung unterschiedliche Vertrauenswürdigkeitsanforderungen der Verbraucher (Risikoeigentümer) erfüllen muss, stellt die Normenreihe ISO/IEC 15408 verschiedene Werkzeuge zur Verfügung, darunter wohlgeformte Vertrauenswürdigkeitskomponenten (ISO/IEC 15408-3) sowie einen Mechanismus zur Definition erweiterter Vertrauenswürdigkeitskomponenten (ISO/IEC 15408-1).

Benutzer der Normenreihe ISO/IEC 15408 können auch aus vordefinierten Paketen wählen, einschließlich der Pakete für die EAL (basierend auf ISO/IEC 15408-5), oder aus einem Rahmen für die Definition von Evaluierungsmethoden und -aufgaben (ISO/IEC 15408-4) und der zugehörigen Evaluierungsmethodologie (basierend auf ISO/IEC 18045).

6.3.2 Konformitätstypen

Drei verschiedene Typen der Konformität mit PP und PP-Konfigurationen wurden definiert, um den Bedürfnissen der Verbraucher (Risikoeigentümer) gerecht zu werden. Es handelt sich um genaue, strikte und nachweisliche Konformität. Sie werden ausführlich in Anhang E beschrieben.

Die PP, PP-Module und PP-Konfigurationen müssen einen Konformitätstyp festlegen.

Die ST beanspruchen Konformität mit den PP und PP-Konfigurationen nach deren Konformitätstypen. Die PP können auch Konformität mit anderen PP nach ihrem Konformitätstyp beanspruchen.

Konformitätstypen, Konformitätsansprüche und Beziehungen zwischen Konformitätstypen der PP, PP-Module und PP-Konfigurationen werden in Anhang E beschrieben und müssen in Verbindung mit den Abschnitten des vorliegenden Dokuments verwendet werden.

6.3.3 Weitergabe von Sicherheitsanforderungen**6.3.3.1 Pakete**

Pakete beschreiben eine Reihe zusammenhängender Sicherheitsanforderungen, die häufig gemeinsam verwendet werden. Pakete sind oft so gestaltet, dass sie wiederverwendet werden können, was eine gewisse Vergleichbarkeit zwischen den PP, PP-Modulen und ST, die sie verwenden, ermöglicht.

Sicherheitsfunktionspakete können zur Festlegung von Sicherheitsprotokollen oder anderen Sicherheitsfunktionskonzepten verwendet werden.

Vertrauenswürdigkeitspakete können verwendet werden, um die Bedingungen und Prozesse wie Spezifikation, Design, Entwicklung, Prüfung und Auslieferung festzulegen, auf deren Grundlage der TOE entwickelt und konfiguriert wird.

Kernanforderungen für Pakete können Abschnitt 9 entnommen werden. Anhang A enthält zusätzliche Informationen und Anforderungen an Pakete, die in Verbindung mit den Abschnitten dieses Dokuments verwendet werden müssen.

ISO/IEC 15408-3 enthält Evaluationskriterien und spezifische Anforderungen für zu evaluierende ST, PP und PP-Module, die Pakete verwenden können, und ISO/IEC 15408-5 enthält einige vordefinierte Vertrauenswürdigkeitspakete, die von Autoren für PP, PP-Module, PP-Konfigurationen und ST verwendet werden können.

6.3.3.2 Schutzprofile (PP)

Die PP beschreiben einen TOE-Typ und die Vertrauenswürdigkeitsanforderungen (SAR) und die Sicherheitsfunktionsanforderungen (SFR), die für diesen Typ von TOE vorgesehen sind.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Die auf anderen PP beruhenden PP können zur weiteren Präzisierung eines TOE-Typs verwendet werden.

Die PP können entweder einen Standard- oder einen direkten Begründungsansatz verfolgen.

Kernanforderungen an ein PP können Abschnitt 10 entnommen werden und weitere Informationen finden sich in Anhang B, der in Verbindung mit den Abschnitten dieses Dokuments verwendet werden muss.

ISO/IEC 15408-3 enthält Evaluierungskriterien für die PP.

6.3.3.3 PP-Module und PP-Konfigurationen

PP-Konfigurationen bauen auf den Konzepten der PP und PP-Module auf.

Ein PP-Modul kann verwendet werden, um den generischen TOE-Typ eines Basis-PP zu präzisieren oder um Sicherheitsanforderungen für bestimmte Technologien hinzuzufügen, die optional mit dem in den Basis-PP definierten TOE-Typ verbunden sein können. PP-Module können auch auf anderen PP-Modulen beruhen. Darüber hinaus bestehen PP-Konfigurationen aus einem TOE-Typ und einem Satz von Anforderungen, die in mehreren PP und möglicherweise PP-Modulen festgelegt sind (dies sind die Komponenten der PP-Konfiguration).

Dieses Konzept wird in Abschnitt 11 und Anhang C ausführlicher beschrieben.

BEISPIEL Ein PP-Modul beschreibt die SFR für die Bluetooth-Technologie. Ein weiteres PP-Modul beschreibt die SFR für Wireless-LAN-Clients. Unter Verwendung einer PP-Konfiguration können die SFR für jede dieser Technologien mit einem PP kombiniert werden, das einen TOE-Typ beschreibt, z. B. ein PP für ein Betriebssystem oder ein PP für ein Mobilgerät. In diesem Zusammenhang wird das PP, das den TOE-Typ beschreibt, als Basis-PP bezeichnet. Eine PP-Konfiguration beschreibt, welche PP und PP-Module kombiniert werden, um eine Spezifikation zu erstellen, die alle in den entsprechenden PP und PP-Modulen genannten Anforderungen enthält.

In diesem Beispiel wäre es möglich, sechs PP-Konfigurationen festzulegen:

- a) Betriebssystem mit Bluetooth;
- b) Betriebssystem in Verbindung mit einem Wireless Client;
- c) Betriebssystem mit Bluetooth und Wireless Client;
- d) Mobilgerät mit Bluetooth;
- e) Mobilgerät mit einem Wireless Client;
- f) Mobilgerät mit Bluetooth und Wireless Client.

6.3.3.4 Sicherheitsvorgaben (ST)**6.3.3.4.1 Allgemein**

Der Abschnitt stellt eine vereinfachte Sicht des ST-Konstrukts dar. Eine ausführlichere und vollständige Beschreibung des ST-Konzepts und der inhaltlichen Anforderungen kann 11.3.3 und Anhang D entnommen werden, die in Verbindung mit den Abschnitten dieses Dokuments verwendet werden müssen.

ISO/IEC 15408-3 enthält Evaluationskriterien und spezifische Anforderungen für zu evaluierende ST.

6.3.3.4.2 Zweck einer ST

Die ST ist ein Schlüsseldokument, das mit der Festlegung der Sicherheitsproblemdefinition (SPD) für den TOE beginnt. Dazu gehört die Festlegung der zu schützenden Vermögenswerte und deren Bedrohungen. Die ST berücksichtigt dann alle relevanten Annahmen und beschreibt die Sicherheitsmaßnahmen, die eingerichtet

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

werden müssen, um nachzuweisen, dass diese Bedrohungen abgewehrt werden. Wenn die Sicherheitsmaßnahmen das tun, was sie versprechen, sind die Bedrohungen abgewehrt.

Zu den beiden Gruppen von Sicherheitsmaßnahmen gehören:

- a) die Sicherheitszielsetzungen für den TOE: diese beschreiben die Sicherheitsmaßnahme(n), für die in der Evaluierung Korrektheit bestimmt wird;
- b) die Sicherheitszielsetzungen für die Betriebsumgebung: diese beschreiben die Sicherheitsmaßnahmen, für die in der Evaluierung Korrektheit nicht bestimmt wird.

Die Gründe für diese Einteilung sind wie folgt.

- Die Normenreihe ISO/IEC 15408 eignet sich für die Bewertung der Korrektheit von IT-Entwicklungs- und Produktionsumgebungen sowie des Produktlebenszyklusmanagements. Die von der Betriebsumgebung geforderten Sicherheitsmaßnahmen sind nicht Gegenstand der Evaluierung nach der Normenreihe ISO/IEC 15408.
- Die Bewertung der Korrektheit von Sicherheitsmaßnahmen kostet Zeit und Geld und die Bewertung aller Sicherheitsmaßnahmen ist daher vermutlich unzumutbar.
- Die Korrektheit einiger Sicherheitsmaßnahmen kann auch bereits in einer anderen Evaluierung bewertet worden sein. Daher ist es nicht wirtschaftlich, diese Korrektheit erneut zu bewerten.

In der ST werden die Sicherheitszielsetzungen für den TOE durch die Festlegung der SFR weiter ausgeführt. Diese SFRs müssen in einer standardisierten Sprache formuliert sein (beschrieben in ISO/IEC 15408-2), um Genauigkeit sicherzustellen und Vergleichbarkeit herzustellen.

Zusammengefasst zeigen die ST Folgendes:

- die SFRs erfüllen die Sicherheitszielsetzungen für den TOE;
- die Sicherheitszielsetzungen für den TOE und die Sicherheitszielsetzungen für die Betriebsumgebung behandeln die SPD und wehren insbesondere die Bedrohungen ab;
- und deshalb behandeln die SFRs und die Sicherheitszielsetzungen für die Betriebsumgebung die SPD und wehren insbesondere die Bedrohungen ab.

Daraus folgt, dass ein korrekter TOE, d. h. ein TOE, der die SFRs in Verbindung mit einer korrekten Betriebsumgebung erfüllt, die wiederum die Sicherheitszielsetzungen für diese Betriebsumgebung erfüllt, die Bedrohungen abwehren wird. Die Korrektheit des TOEs und die Korrektheit der Betriebsumgebung werden in 6.3.3.4.3 und 6.3.3.4.4 separat erörtert.

In einigen Fällen ist es angemessen, eine ST zu definieren, die die Sicherheitszielsetzungen für den TOE weglässt und die SFR direkt dem SPD zuordnet. Dies ist eine ST „mit direkter Begründung“ und wird in 11.3.3 und Anhang D ausführlich erläutert.

Eine ST kann als eigenständiges Dokument für einen bestimmten TOE definiert werden oder sie kann mit einer bereits vorhandenen PP-Konfiguration bzw. einem oder mehreren bereits vorhandenen PP konform sein. Diese Dokumente ermöglichen es, generische Definitionen eines TOE-Typs vorzunehmen, die eine Vergleichbarkeit der Evaluierungsergebnisse zwischen den TOE sowie die Erzielung von Effizienzgewinnen ermöglichen.

Pakete, PP, PP-Module und PP-Konfigurationen, die zur Spezifikation einer ST beitragen können, werden in 6.3.3.1, 6.3.3.2 und 6.3.3.3 vorgestellt.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****6.3.3.4.3 Korrektheit des TOEs**

Ein TOE kann inkorrekt gestaltet oder implementiert sein und daher Fehler enthalten, die zu Schwachstellen führen. Durch das Ausnutzen dieser Schwachstellen können Angreifer in der Lage sein, die Vermögenswerte zu beschädigen und/oder zu missbrauchen.

Diese Schwachstellen können z. B. durch schlechtes Design, versehentliche Fehler während der Entwicklung, absichtliches Hinzufügen von Schadcode oder schlechtes Konfigurationsmanagement entstehen.

Um die Korrektheit des TOEs zu bestimmen, dürfen unterschiedliche Tätigkeiten ausgeführt werden, beispielsweise:

- Prüfen des TOEs;
- Untersuchen unterschiedlicher Design-Darstellungen des TOEs;
- Untersuchen der physischen Sicherheit der Entwicklungsumgebung des TOEs.

Die ST bietet eine strukturierte Beschreibung dieser Tätigkeiten zur Bestimmung der Korrektheit in Form von SAR. Diese SAR müssen in einer standardisierten Sprache formuliert sein (beschrieben in ISO/IEC 15408-3), um Genauigkeit sicherzustellen und Vergleichbarkeit herzustellen.

Wenn die SARs erfüllt werden, besteht die Zusicherung der Korrektheit des TOEs und es ist daher unwahrscheinlicher, dass der TOE Schwachstellen enthält, die von Angreifern ausgenutzt werden können. Der Grad an Vertrauenswürdigkeit in die Korrektheit des TOEs wird durch die SARs selbst bestimmt.

6.3.3.4.4 Korrektheit der Betriebsumgebung

Auch eine Betriebsumgebung kann inkorrekt festgelegt oder implementiert sein und daher Fehler enthalten, die zu Schwachstellen führen. Durch das Ausnutzen dieser Schwachstellen können Angreifer die Vermögenswerte beschädigen und/oder missbrauchen.

Über die Normenreihe ISO/IEC 15408 ist allerdings keine Zusicherung zur Korrektheit der Betriebsumgebung möglich, d. h. die Betriebsumgebung wird nicht evaluiert.

In Bezug auf die Evaluierung wird davon ausgegangen, dass die Betriebsumgebung eine korrekte Instanziierung der Sicherheitszielsetzungen für die Betriebsumgebung ist.

Das hindert jedoch den Verbraucher des TOEs nicht daran, andere Methoden zur Bestimmung der Korrektheit seiner Betriebsumgebung anzuwenden.

BEISPIEL 1 Wenn für ein Betriebssystem-TOE die Sicherheitszielsetzungen für die Betriebsumgebung besagen „Die Betriebsumgebung stellt sicher, dass Entitäten aus einem nicht vertrauenswürdigen Netzwerk nur per FTP- auf den TOE zugreifen können“, so kann der Verbraucher eine evaluierte Firewall auswählen und so konfigurieren, dass nur FTP-Zugriff auf den TOE zu erlaubt ist.

BEISPIEL 2 Wenn die Sicherheitszielsetzungen für die Betriebsumgebung besagen: „Die Betriebsumgebung muss sicherstellen, dass alle Administratoren sich nicht böswillig verhalten“, so kann der Verbraucher seine Verträge mit den Administratoren um entsprechende Strafsanktionen erweitern, aber diese Bestimmung ist nicht Teil einer Evaluierung, die sich auf die Normenreihe ISO/IEC 15408 stützt.

ANMERKUNG Das Internet ist ein Beispiel für ein nicht vertrauenswürdiges Netzwerk.

6.3.4 Erfüllung der Bedürfnisse der Verbraucher (Risikoeigentümer)**6.3.4.1 Allgemein**

Die Verbraucher (Risikoeigentümer) können unterschiedliche Ansätze verfolgen, um sich zu vergewissern, dass die von ihnen verwendeten Produkte die SPD abdecken. 6.3.4.2 und 6.3.4.3 stellen diese Ansätze vor.

Darüber hinaus bietet ISO/IEC 15408-4 Verfahren zur Definition spezifischer Evaluierungsaufgaben für die Vertrauenswürdigkeitsanforderungen.

6.3.4.2 Evaluierung mit Einfach-Vertrauenswürdigkeit

Die Evaluierung mit Einfach-Vertrauenswürdigkeit ist die Art von Evaluierung, die in früheren Revisionen der Normenreihe ISO/IEC 15408 festgelegt wurde. Bei einer Evaluierung mit Einfach-Vertrauenswürdigkeit wird eine einzige Menge an SAR auf den gesamten TOE angewandt.

Das Paradigma der Evaluierung mit Einfach-Vertrauenswürdigkeit:

- setzt voraus, dass der gesamte TOE denselben SAR unterliegt;
- wird verwendet, wenn ein einziger Satz an SAR den Sicherheitsanforderungen für den TOE angemessen ist.

Eine Evaluierung mit Einfach-Vertrauenswürdigkeit basiert auf einer ST, die Konformität mit den PP oder einer PP-Konfiguration beanspruchen kann, aber darauf angewiesen ist, dass alle beanspruchten PP oder PP-Konfigurationskomponenten identische Sätze oder übergeordnete Sätze von Vertrauenswürdigkeitskomponenten spezifizieren. Eine Evaluierung auf der Grundlage einer ST, die keinen Anspruch auf Konformität mit PP oder einer PP-Konfiguration erhebt, ist demnach eine Evaluierung mit Einfach-Vertrauenswürdigkeit.

6.3.4.3 Evaluierung mit Mehrfach-Vertrauenswürdigkeit

Das Paradigma der Evaluierung mit Mehrfach-Vertrauenswürdigkeit besteht in der Anwendung verschiedener Vertrauenswürdigkeitsanforderungen auf verschiedene Teile der TSF (Teil-TSF), während eine Gesamtmenge an SAR für den gesamten TOE durchgesetzt wird.

Das Paradigma der Evaluierung mit Mehrfach-Vertrauenswürdigkeit:

- richtet sich an heterogene IT-Produkte, bei denen unterschiedliche Sicherheitsbedürfnisse im Rahmen einer Evaluierung mit Einfach-Vertrauenswürdigkeit eine unterschiedliche Vertrauenswürdigkeit erfordern;
- stellt sicher, dass die Anforderungen mit Mehrfach-Vertrauenswürdigkeit den Sicherheitsbedürfnissen für das IT-Produkt gerecht werden.

Technisch gesehen wird eine Evaluierung mit Mehrfach-Vertrauenswürdigkeit durch eine ST gesteuert, die mit einer (und nur einer) PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit übereinstimmt. Die PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit stellt sicher, dass die Anwendung unterschiedlicher Vertrauenswürdigkeitsanforderungen auf verschiedene Teile der TSF mit deren Sicherheitsbedürfnissen widerspruchsfrei ist. Bei diesem Evaluierungsansatz erzwingt jede Teil-TSF eine bestimmte Sicherheitsfunktionalität, z. B. ein Authentifizierungsprotokoll, eine Firewall-Richtlinie, den Boot-Prozess oder Verschlüsselungs-/Entschlüsselungsoperationen; in einigen Fällen kann die Teil-TSF mit einer Teilmenge von TOE-Komponenten verbunden sein, z. B. einem TPM, einer kryptographischen Bibliothek oder einem Kartenleser.

Das Paradigma mit Mehrfach-Vertrauenswürdigkeit ist vor allem in den folgenden Situationen von Bedeutung:

- ein Produkt, bei dem einige Sicherheitsfunktionen eine höhere Vertrauenswürdigkeit erfordern als die übrigen, z. B. eine Schlüsselspeicher- und -verarbeitungseinheit, ein sicheres Systemstartmodul;
- ein Produkt, bei dem einige Teile der Sicherheitsfunktionalität nicht die gleiche hohe Vertrauenswürdigkeit bei der Evaluierung erfordern wie andere, stärker exponierte Teile, z. B. ein Internet-Gateway mit Unterstützung für Personal-Area-Network-Protokolle;
- eine Produktfamilie, bei der einige Sicherheitsfunktionen von allen Produkten mit der gleichen Vertrauenswürdigkeit gemeinsam benutzt und einige Sicherheitsfunktionen für verschiedene Anwendungsfälle auf

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

unterschiedliche Weise implementiert werden, z. B. in einem manipulationssicheren Modul oder in einem Softwaremodul oder durch COTS, was eine andere Vertrauenswürdigkeit erfordert;

Ein Beispiel dafür ist eine Familie von biometrischen Authentifizierungsgeräten, die entweder eine Übereinstimmung auf dem Gerät oder auf dem Server oder beides aufweisen. Dies kann zu einem PP für das Authentifizierungsgerät ohne die Abgleichsfunktion und zu zwei PP-Modulen für die verschiedenen Arten von Abgleichsfunktionen führen, die jeweils einen eigenen Satz von Vertrauenswürdigkeitsanforderungen haben. Für das Gerät können drei PP-Konfigurationen festgelegt werden: PP mit jedem der PP-Module, PP mit beiden PP-Modulen. Eine ähnliche Situation ergibt sich beispielsweise für eine Familie mobiler Anwendungen, die entweder eine durch White-Box-Techniken gesicherte Software-Kryptobibliothek oder eine hardwarebasierte Kryptobibliothek verwenden, oder für eine Familie von Zahlungsterminals mit IC- und/oder Magnetkartenlesern.

Mehrfach-Vertrauenswürdigkeit ist auch für Produkte relevant, die Konformität mit verschiedenen PP mit unterschiedlichen Vertrauenswürdigkeitspaketen beanspruchen: Durch die Definition und Evaluierung einer PP-Konfiguration ermöglicht das Paradigma mit Mehrfach-Vertrauenswürdigkeit bessere Kontrolle über mögliche Inkonsistenzen zwischen diesen PP. Die Evaluierung von elektronischen Reisepässen, bei denen sowohl eine einfache als auch eine erweiterte Zugangssteuerung implementiert ist, stellt ein typisches Beispiel dar, da diese Zugangskontrollmechanismen unterschiedlichen Sicherheitsproblemen und Vertrauenswürdigkeitsanforderungen unterliegen.

7 Festlegung von Sicherheitsanforderungen

7.1 Sicherheitsproblemdefinition (SPD)

7.1.1 Allgemein

Die SPD definiert das zu behandelnde Sicherheitsproblem und kann in den PP, PP-Modulen und den ST erscheinen. Die SPD ist, was die Normenreihe ISO/IEC 15408 betrifft, axiomatisch, d. h. der Prozess der Ableitung der SPD fällt nicht in den Anwendungsbereich der Normenreihe ISO/IEC 15408.

SPD-Elemente können Konfigurationen oder Anforderungen zugeordnet werden, die für den gegebenen TOE-Typ optional sind, z. B. in einem Fall, in dem der TOE verteilt ist oder in dem optionale funktionale Anforderungen (wie in 7.3.2.6 beschrieben) festgelegt sind. Dies ist zulässig, solange der fakultative Charakter der SPD-Elemente (und alle damit verbundenen Zielsetzungen und funktionalen Anforderungen) wie in diesem Dokument beschrieben angegeben wird.

ANMERKUNG 1 Der Nutzen der Ergebnisse einer Evaluierung hängt stark von der Qualität der SPD ab. Daher ist es häufig den Aufwand wert, die entsprechenden Ressourcen aufzuwenden und klar definierte Prozesse und Analysen zu verwenden, um eine gute SPD herzuleiten. ISO/IEC 15446 enthält Leitlinien für die Ableitung einer SPD.

ANMERKUNG 2 Nach ISO/IEC 15408-3 ist es nicht verpflichtend, in allen Abschnitten Aussagen zu treffen. Ein PP mit Bedrohungen erfordert keine OSP und umgekehrt. Ein PP kann außerdem Annahmen weglassen.

ANMERKUNG 3 Bei einem physisch verteilten TOE ist es vorzuziehen, die relevanten Bedrohungen, OSPs und Annahmen separat für die einzelnen Domänen der TOE-Betriebsumgebung zu behandeln.

7.1.2 Bedrohungen

Die SPD beschreibt die vom TOE, seiner Betriebsumgebung oder einer Kombination dieser beiden zu begegnenden Bedrohungen.

Eine Bedrohung besteht aus einer unerwünschten Aktion, die von einem Bedrohungsagenten gegen einen Vermögenswert durchgeführt wird.

Nachteilige Aktionen beeinflussen eine oder mehrere Eigenschaften eines Vermögenswerts, aus dem dieser Vermögenswert seinen Wert ableitet.

Bedrohungsagenten können als individuelle Entitäten beschrieben werden, aber in einigen Fällen ist es vorzuziehen, sie z. B. als Typen von Entitäten, Gruppen von Entitäten zu beschreiben.

BEISPIEL 1 Beispiele für Bedrohungsagenten sind:

- Hacker;
- Benutzer;
- Computerprozesse;
- Unfälle.

Bedrohungsagenten können noch weiter über Attribute wie Fachkenntnis, Ressourcen, Möglichkeiten und Motivation beschrieben werden.

BEISPIEL 2 Beispiele für Bedrohungen sind:

- ein Hacker (mit beträchtlicher Fachkenntnis, Standardausrüstung und Bezahlung für seine Tätigkeit), der aus der Ferne vertrauliche Dateien aus einem Unternehmensnetzwerk kopiert;
- ein Wurm, der die Leistung eines WANs erheblich verringert;
- ein Systemadministrator, der die Privatsphäre eines Benutzers verletzt;
- jemand, der im Internet vertrauliche elektronische Kommunikation abhört.

7.1.3 Organisatorische Sicherheitsrichtlinien (OSP)

Die SPD beschreibt die OSPs, die vom TOE, seiner Betriebsumgebung oder einer Kombination aus beidem durchgesetzt werden sollen.

OSP sind in der Betriebsumgebung auferlegte Sicherheitsregeln, Verfahren oder Leitlinien. OSPs können von einer Organisation zum Steuern der Betriebsumgebung eines TOEs oder von Gesetzgebungsorganen oder Aufsichtsbehörden erstellt werden. OSPs können für den TOE und/oder die Betriebsumgebung des TOEs gelten.

BEISPIEL Beispiele für OSPs sind:

- „Alle von der Regierung verwendeten Produkte müssen mit der nationalen Norm für Passwörterzeugung und Passwortverschlüsselung konform sein“;
- „Nur Benutzer mit Systemadministratorrechten und Freigabe durch die Sicherheitsabteilung dürfen den Dateiserver der Abteilung verwalten“.

7.1.4 Annahmen

Die SPD beschreibt die für die Betriebsumgebung gemachten Annahmen, um die Sicherheitsfunktionalität bereitzustellen. Wenn der TOE in einer Betriebsumgebung eingesetzt wird, die diese Annahmen nicht erfüllt, besteht die Möglichkeit, dass der TOE nicht mehr seine vollständige Sicherheitsfunktionalität bereitstellen kann. Annahmen können sich auf physische Eigenschaften, Personal und Konnektivität der Betriebsumgebung beziehen.

BEISPIEL Beispiele für Annahmen sind:

- Annahmen über den Nicht-TOE-Teil des Produkts;
- es wird angenommen, dass der TOE in ein Gerät integriert wird, das eine hardwarebasierte Vertrauensbasis bietet.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

- Annahmen zu physischen Aspekten der Betriebsumgebung;
 - es wird angenommen, dass der TOE in einem Raum eingesetzt wird, der zur Minimierung von elektromagnetischen Emanationen ausgelegt ist;
 - es wird angenommen, dass die Administratorkonsolen des TOEs in einem Bereich mit Zugangsbeschränkung eingesetzt werden.
- Annahmen zu Personalaspekten der Betriebsumgebung;
 - es wird angenommen, dass Benutzer des TOEs ausreichend in der Bedienung des TOEs geschult werden;
 - es wird angenommen, dass Benutzer des TOEs eine Freigabe für als nationales Geheimnis eingestufte Informationen haben;
 - es wird angenommen, dass Benutzer des TOEs ihre Passwörter nicht aufschreiben.
- Annahmen zu Aspekten der Konnektivität der Betriebsumgebung;
 - es wird angenommen, dass eine Arbeitsstation mit mindestens 10 GB freiem Speicherplatz für den Betrieb des TOEs verfügbar ist;
 - es wird angenommen, dass der TOE die einzige Anwendung auf der Arbeitsstation ist, die kein Betriebssystem ist;
 - es wird angenommen, dass der TOE nicht mit einem nicht vertrauenswürdigen Netzwerk verbunden wird.

ANMERKUNG Diese Annahmen werden zum Zeitpunkt der Evaluierung als wahr betrachtet, sie werden in keiner Weise überprüft. Daher können Annahmen nur in Bezug zur Betriebsumgebung getroffen werden. Annahmen können niemals in Bezug auf das Verhalten des TOEs gemacht werden, weil eine Evaluierung aus der Bewertung der gemachten Aussagen über den TOE besteht und nicht aus der Annahme, dass diese Aussagen über den TOE wahr sind. Dennoch helfen die ST-, PP- und PP-Konfigurationsevaluierungen dabei, unrealistische Annahmen für den TOE-Typ und die Betriebsumgebung aufzudecken, die unannehmbar werden können.

7.2 Sicherheitszielsetzungen

7.2.1 Allgemein

Sicherheitszielsetzungen sind eine präzise Aussage zur angestrebten Lösung des Sicherheitsproblems. Die Rolle der Sicherheitszielsetzungen umfasst drei Aspekte:

- a) Bereitstellung einer allgemeinen Lösung des Problems in natürlicher Sprache. Die Sicherheitszielsetzungen bestehen aus einem Satz an Aussagen ohne übermäßig viele Einzelheiten und bilden gemeinsam die allgemeine Lösung für das Sicherheitsproblem. Die Abstraktionsebene der Sicherheitszielsetzungen zielt auf Klarheit und Verständlichkeit für sachkundige potentielle Verbraucher des TOEs. Die Sicherheitszielsetzungen sind in natürlicher Sprache formuliert;
- b) Einteilung dieser Lösung in zwei Teillösungen, die die Rollen des TOE und seiner Betriebsumgebung widerspiegeln, um jeweils einen Teil des Problems anzusprechen. Eine wie in einer Sicherheitszielsetzung beschriebene allgemeine Sicherheitslösung in einer ST ist in zwei Teillösungen unterteilt. Diese Teillösungen werden Sicherheitszielsetzungen für den TOE und Sicherheitszielsetzung für die Betriebsumgebung genannt;
- c) Darstellung dieser Teillösungen als Gesamtlösung des Problems.

7.2.2 Sicherheitszielsetzungen für den TOE

Der TOE bietet Sicherheitsfunktionalität zur Lösung eines bestimmten Teils des in der SPD definierten Problems. Diese Teillösung wird Sicherheitszielsetzung für den TOE genannt und besteht aus einem Satz an Zielsetzungen, die der TOE erfüllen muss, um seinen Teil des Problems zu lösen.

BEISPIEL Beispiele für Sicherheitszielsetzungen für den TOE sind:

- „Der TOE muss den Inhalt aller zwischen ihm und dem Server übertragenen Dateien vertraulich halten“;
- „Der TOE muss alle Benutzer vor der Zugriffserlaubnis auf den vom TOE bereitgestellten Übertragungsdienst identifizieren und authentifizieren“;
- „Der TOE muss den Benutzerzugriff auf Daten entsprechend der in Anhang 3 der PP beschriebenen Datenzugriffsrichtlinie einschränken“.

Wenn der TOE physisch verteilt wird, ist es vorzuziehen, den Abschnitt zu den Sicherheitszielsetzungen für den TOE in mehrere Unterabschnitte einzuteilen, um dies entsprechend abzubilden.

ANMERKUNG In der ST mit direkter Begründung sind Sicherheitszielsetzungen für den TOE nicht enthalten: Siehe D.4.

7.2.3 Sicherheitszielsetzungen für die Betriebsumgebung

Die Betriebsumgebung des TOEs implementiert technische und verfahrenstechnische Maßnahmen zur Unterstützung des TOEs bei der korrekten Bereitstellung seiner Sicherheitsfunktionalität (die von den Sicherheitszielsetzungen für den TOE definiert wird). Diese paarweise Lösung wird Sicherheitszielsetzung für die Betriebsumgebung genannt und besteht aus einem Satz an Aussagen mit Zielen, die von der Betriebsumgebung erreicht werden müssen.

BEISPIEL Beispiele für Sicherheitszielsetzungen für die Betriebsumgebung sind:

- „Die Betriebsumgebung muss eine Arbeitsstation mit dem Betriebssystem Linux Version 3.01b zur Ausführung des TOEs bereitstellen“;
- „Die Betriebsumgebung muss sicherstellen, dass alle menschlichen TOE-Benutzer vor der Erlaubnis zur Arbeit mit dem TOE eine entsprechende Schulung erhalten“;
- „Die Betriebsumgebung des TOEs muss den physischen Zugriff zum TOE auf administratives Personal und Wartungspersonal in Begleitung von administrativem Personal einschränken“;
- „Die Betriebsumgebung muss die Vertraulichkeit der vom TOE auf dem Audit-Server empfangenen Audit-Logdateien sicherstellen“.

Wenn die Betriebsumgebung des TOEs aus mehreren physischen Standorten mit unterschiedlichen Eigenschaften besteht, ist es vorzuziehen, den Abschnitt zu den Sicherheitszielsetzungen für die Betriebsumgebung in mehrere Unterabschnitte einzuteilen, um dies entsprechend abzubilden.

Komponenten von Drittanbietern, die nicht evaluiert werden dürfen, weil kein Evaluationsnachweis verfügbar ist, werden in die Betriebsumgebung einbezogen; in den Sicherheitszielsetzungen für die Betriebsumgebung muss die Anforderung enthalten sein, dass die Komponente des Drittanbieters wie vorgesehen funktioniert.

7.2.4 Beziehung zwischen Sicherheitszielsetzungen und der SPD

ST, PP, PP-Module und Pakete enthalten auch eine Begründung zu den Sicherheitszielsetzungen mit zwei Abschnitten:

- a) eine Rückverfolgung, die zeigt, welche Sicherheitszielsetzungen welche SPD-Elemente ansprechen;

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

- b) einen Satz an Begründungen, der aufzeigt, dass alle SPD-Elemente von den Sicherheitszielsetzungen effektiv angesprochen werden.

ANMERKUNG In den PP mit direkter Begründung ist keine Begründung für Sicherheitszielsetzungen im TOE enthalten. Siehe D.4.

BEISPIEL Eine Bedrohung „T17: Bedrohungsagent X liest die vertrauliche Information auf dem Weg zwischen A und B“; eine Sicherheitszielsetzung für den TOE: „OT12: Der TOE muss sicherstellen, dass alle zwischen A und B übertragenen Informationen vertraulich bleiben“, und ein Nachweis „OT12 wirkt direkt T17 entgegen“.

7.2.5 Rückverfolgung zwischen Sicherheitszielsetzungen und der SPD

Die Rückverfolgung zeigt auf, wie sich die Sicherheitszielsetzungen zu den SPD-Elementen verfolgen lassen und dass:

- a) *es keine falschen Zielsetzungen gibt;*

Jede Sicherheitszielsetzung lässt sich auf mindestens ein SPD-Element rückverfolgen.

- b) *die Sicherheitsproblemdefinition vollständig abgedeckt ist;*

Jedes SPD-Element hat mindestens eine Sicherheitszielsetzung, die sich auf sie rückverfolgen lässt;

- c) *die Rückverfolgung korrekt ist.*

Da Annahmen stets vom TOE für die Betriebsumgebung gemacht werden, lassen sich Sicherheitszielsetzungen für einen TOE nicht zu Annahmen rückverfolgen. Die von ISO/IEC 15408-3 erlaubten Rückverfolgungen sind in Bild 3 dargestellt.

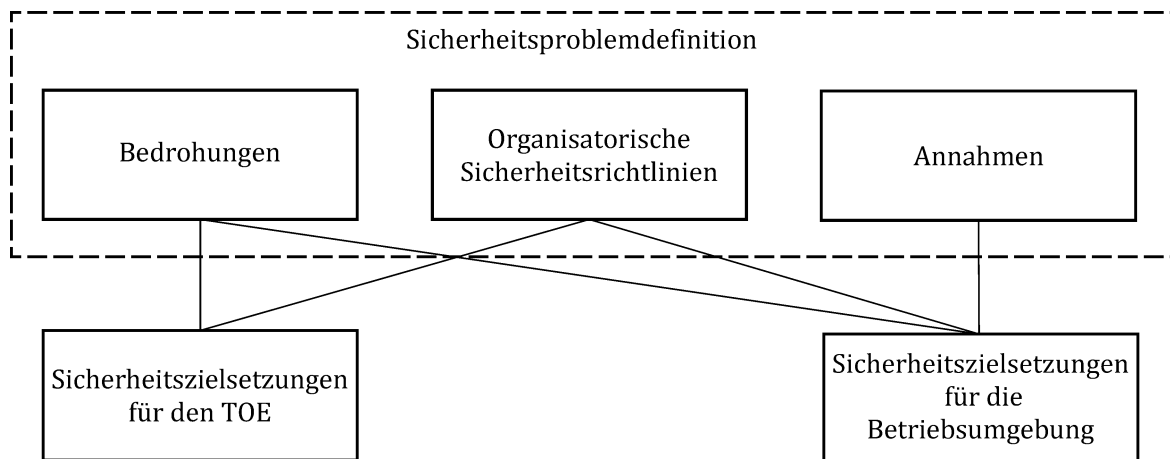


Bild 3 — Rückverfolgungen zwischen Sicherheitszielsetzungen und der SPD

Es kann sein, dass sich mehrere Sicherheitszielsetzungen auf dieselbe Bedrohung rückverfolgen lassen; dies zeigt an, dass eine Kombination dieser Sicherheitszielsetzungen dieser Bedrohung entgegenwirkt. Ähnliches gilt für OSPs und Annahmen.

7.2.6 Bereitstellen einer Begründung für die Rückverfolgung

Die Begründung für die Sicherheitszielsetzungen zeigt außerdem die Effektivität der Rückverfolgung auf: Alle angegebenen Bedrohungen, OSPs und Annahmen sind angesprochen (d. h. entgegengewirkt, durchgesetzt und eingehalten), wenn alle Sicherheitszielsetzungen, die sich zu einer bestimmten Bedrohung, OSP oder Annahme rückverfolgen lassen, erreicht werden.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Dieser Nachweis analysiert den Effekt des Erreichens der relevanten Sicherheitszielsetzungen zum Entgegenwirken der Bedrohungen, Durchsetzen der OSPs und Einhalten der Annahmen und führt zu der Schlussfolgerung, dass dies auch wirklich zutrifft.

In einigen Fällen, in denen Teile der SPD sehr stark den Sicherheitszielsetzungen ähneln, kann dieser Nachweis einfach sein.

7.2.7 Zum Entgegenwirken von Bedrohungen

Das Entgegenwirken einer Bedrohung bedeutet nicht notwendigerweise das Entfernen dieser Bedrohung; es kann auch bedeuten, dass das damit verbundene Risiko ausreichend verringert oder abgeschwächt wird.

BEISPIEL Beispiele für das Entfernen von Bedrohungen sind:

- Verhindern der Möglichkeit des Bedrohungsagenten, die unerwünschte Aktion auszuführen;
- Umzug, Veränderung oder Schutz des Vermögenswerts in einer Art und Weise, dass die unerwünschte Aktion nicht mehr auf ihn anwendbar ist;
- Entfernen des Bedrohungsagenten, z. B. Entfernen von Maschinen aus einem Netzwerk, die häufig für den Absturz des Netzwerks verantwortlich sind.

Beispiele für das Verringern von Bedrohungen sind:

- Einschränken der Möglichkeit des Bedrohungsagenten, unerwünschte Aktionen auszuführen;
- Einschränken der Gelegenheiten für den Bedrohungsagenten, eine unerwünschte Aktion auszuführen;
- Verringern der Wahrscheinlichkeit des Erfolgs einer unerwünschten Aktion;
- Verringern der Motivation durch Abschreckung des Bedrohungsagenten, eine unerwünschte Aktion auszuführen;
- Notwendigkeit größerer Fachkenntnis oder von mehr Ressourcen des Bedrohungsagenten.

Beispiele für das Abschwächen von Effekten einer Bedrohung sind:

- Erstellen häufiger Datensicherungen des Vermögenswerts;
- Anschaffen von Ersatzexemplaren eines Vermögenswerts;
- Versichern eines Vermögenswerts;
- Sicherstellen, dass erfolgreiche unerwünschte Aktionen stets zeitnah bemerkt werden, damit entsprechende Aktionen eingeleitet werden können.

7.2.8 Sicherheitszielsetzungen: Schlussfolgerung

Ausgehend von den Sicherheitszielsetzungen und der Begründung der Sicherheitszielsetzungen wird die folgende Schlussfolgerung gezogen: Wenn alle Sicherheitszielsetzungen erreicht sind, ist das Sicherheitsproblem, wie es in der SPD definiert ist, gelöst. Alle Bedrohungen werden abgewehrt, alle OSP werden durchgesetzt und alle Annahmen werden eingehalten.

ANMERKUNG Die ASE_SPD-Familie in ISO/IEC 15408-3 unterstützt diese Bestimmung.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01 prEN ISO/IEC 15408-1:2023 (D)

7.3 Sicherheitsanforderungen

7.3.1 Allgemein

Wie in 6.3.3.4 und 6.3.3 erwähnt, spezifizieren Pakete, PP, PP-Module, PP-Konfigurationen und ST die detaillierten Sicherheitsanforderungen, die für einen TOE gelten und aus der angegebenen SPD abgeleitet worden sind. SFR und SAR müssen aus den in ISO/IEC 15408-2 bzw. ISO/IEC 15408-3 definierten Sicherheitskomponenten abgeleitet werden, die eine Vorlage für in einer standardisierten Sprache geschriebene Sicherheitsanforderungen darstellen. Der Prozess der Ableitung einer Sicherheitsanforderung aus einer Sicherheitskomponente beinhaltet die Zerlegung der Komponenten und wird als „Vervollständigung“ bezeichnet.

ANMERKUNG 1 In Abschnitt 7 umfasst der Begriff „Autor“ die Autoren von ST, PP, PP-Modulen, PP-Konfigurationen und Paketen.

Sicherheitsanforderungen werden als Ergebnis der Beschreibung der in einer ST und möglicherweise einem PP, PP-Modul oder Paketen enthaltenen Komponenten festgelegt. Die Sicherheitsanforderungen werden durch die Auswahl der Komponenten festgelegt, die in ISO/IEC 15408-2, ISO/IEC 15408-3 angegeben sind oder die als erweiterte Komponenten in Übereinstimmung mit 8.4 definiert wurden. Der Anpassungsprozess verwendet die in 8.2 beschriebenen Operationen.

ANMERKUNG 2 Da eine ST die Sicherheitsanforderungen für einen bestimmten TOE festlegt, enthält sie nur vollständig fertiggestellte Komponenten. PP, PP-Module und Pakete enthalten oft unvollständige Sicherheitskomponenten, die den Autoren der darauf basierenden Dokumente eine angemessene Flexibilität bieten.

Die Sicherheitsanforderungen bestehen aus zwei Gruppen von Anforderungen:

- a) **Sicherheitsfunktionsanforderungen** (SFRs): eine Beschreibung, wie der TOE die SPD in einer standardisierten Sprache behandelt;
- b) **Vertrauenswürdigkeitsanforderungen** (SARs): eine Beschreibung, wie die Zusicherung, dass der TOE die SFRs erfüllt, erreicht wird.

ANMERKUNG 3 Die SAR betreffen die Einhaltung der ST durch den TOE. Die SAR spielen keine Rolle bei der Abdeckung der SPD, die durch Sicherheitszielsetzungen und SFR abgedeckt ist.

Diese zwei Gruppen werden in 7.3.2 und 7.3.3 erörtert.

7.3.2 Sicherheitsfunktionsanforderungen (SFR)

7.3.2.1 Allgemein

Die SFR tragen zur Erfüllung der SPD des TOE bei und berücksichtigen die für den TOE definierten Sicherheitszielsetzungen. Üblicherweise sind sie auf einer ausführlicheren Abstraktionsebene, müssen allerdings eine vollständige Übertragung (die Sicherheitszielsetzungen müssen vollständig angesprochen sein) darstellen. Der Normenreihe ISO/IEC 15408 erfordert aus folgenden Gründen die Übertragung in eine standardisierte Sprache:

- zur präzisen Beschreibung des Evaluierungsgegenstands. Da Sicherheitszielsetzungen für den TOE üblicherweise in natürlicher Sprache formuliert werden, erzwingt die Übertragung in eine standardisierte Sprache eine präzisere Beschreibung der Funktionsvielfalt des TOEs;
- um Vergleiche zwischen zwei STs zu ermöglichen. Die standardisierte Sprache erzwingt die Verwendung einheitlicher Terminologie und Begriffe. Dies ermöglicht den Vergleich der ST, selbst wenn die Autoren bei der Beschreibung ihrer SPD und Sicherheitszielsetzungen eine unterschiedliche Terminologie verwenden (dies ist nicht der Fall, wenn die ST denselben PP oder der gleichen PP-Konfiguration entsprechen).

Im Zusammenhang mit den PP und PP-Modulen müssen die SFR unabhängig von einer bestimmten technischen Lösung (Implementierung) sein.

In diesem Dokument ist für die Sicherheitszielsetzungen der Betriebsumgebung keine Übertragung erforderlich, weil die Betriebsumgebung nicht evaluiert wird und daher eine Beschreibung mit dem Ziel ihrer Evaluierung nicht erforderlich ist.

ANMERKUNG 1 Für relevante Punkte zur Sicherheitsbeurteilung von Systemen im Betrieb siehe Literaturhinweise.

ANMERKUNG 2 Es kann sein, dass Teile der Betriebsumgebung in einer anderen Evaluierung begutachtet werden, aber dies liegt außerhalb des Anwendungsbereichs der Normenreihe ISO/IEC 15408.

BEISPIEL Ein TOE vom Typ Betriebssystem kann das Vorhandensein einer Firewall in seiner Betriebsumgebung erfordern. Eine weitere Evaluierung kann anschließend die Firewall evaluieren, aber diese Evaluierung hat dann nichts zu tun mit der Evaluierung des Betriebssystem-TOEs.

7.3.2.2 Wie diese Übertragung unterstützt wird

Die Normenreihe ISO/IEC 15408 unterstützt diese Übertragung auf drei Weisen:

- a) Durch eine vordefinierte „Sprache“, die für die präzise Beschreibung des Evaluierungsgegenstands ausgelegt ist. Diese Sprache ist in ISO/IEC 15408-2 als ein Satz an Komponenten definiert. Die Verwendung dieser Sprache als eine klar definierte Übertragung der Sicherheitszielsetzungen für den TOE in SFRs ist verpflichtend, wobei es einige Ausnahmen gibt, die in 8.4 aufgeführt sind;
- b) durch Operationen: Mechanismen, die es dem Autor des Pakets, der ST, dem PP oder dem PP-Modul ermöglichen, die SFRs zu vervollständigen und zu modifizieren, um eine genauere Übertragung der Sicherheitszielsetzungen für den TOE oder den TOE-Typ bereitzustellen. Dieses Dokument definiert die vier erlaubten Operationen: Zuweisung, Auswahl, Iteration und Präzisierung. Diese Operationen werden in 8.2 ausführlicher beschrieben;
- c) durch Abhängigkeiten: ein Mechanismus zur Unterstützung einer vollständigeren Übertragung in SFRs. In der Sprache von ISO/IEC 15408-2 darf eine SFR eine Abhängigkeit zu anderen SFRs haben. Das deutet darauf hin, dass eine diese SFR verwendende ST im Allgemeinen auch jene anderen SFRs erfordert. Dies macht es für den ST-Autor wesentlich schwieriger, das Einbinden der erforderlichen SFRs zu übersehen und verbessert somit die Vollständigkeit der ST. Abhängigkeiten werden ausführlicher in 8.3 beschrieben.

7.3.2.3 Beziehung zwischen SFRs und Sicherheitszielsetzungen

Pakete, PP, PP-Module und ST enthalten auch eine Begründung zu den SFR, bestehend aus zwei Abschnitten:

- a) eine Rückverfolgung, die aufzeigt, welche SFRs welche Sicherheitszielsetzungen für den TOE ansprechen;
- b) einen Satz an Begründungen, der aufzeigt, dass alle Sicherheitszielsetzungen für diesen TOE von den SFRs effektiv angesprochen werden.

ANMERKUNG Beim Ansatz der direkten Begründung wird die Rückverfolgung und Begründung zwischen den SFR und der SPD vorgenommen.

7.3.2.4 Rückverfolgung zwischen SFRs und den Sicherheitszielsetzungen für den TOE

Die Rückverfolgung zeigt die Verfolgung der SFR zurück zu den Sicherheitszielsetzungen für den TOE wie folgt:

- a) *keine falschen SFRs*: Jede SFR wird zu mindestens einer Sicherheitszielsetzung rückverfolgt;
- b) *vollständig in Hinblick auf Sicherheitszielsetzungen für den TOE*: Jede Sicherheitszielsetzung für den TOE hat mindestens eine SFR, die zur Sicherheitszielsetzung rückverfolgt werden kann.

Es kann sein, dass sich mehrere SFRs auf dieselbe Sicherheitszielsetzung für den TOE rückverfolgen lassen; dies zeigt an, dass eine Kombination dieser Sicherheitsanforderungen diese Sicherheitszielsetzung für den TOE erfüllt.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****7.3.2.5 Bereitstellen einer Begründung für die Rückverfolgung**

Die Begründung der SFRs zeigt die Effektivität der Rückverfolgung: wenn alle SFRs, die sich auf eine bestimmte Sicherheitszielsetzung für den TOE rückverfolgen lassen, erfüllt sind, dann ist die Sicherheitszielsetzung für den TOE erfüllt.

Dieser Nachweis analysiert die Effekte der Erfüllung der relevanten SFRs zum Erreichen der Sicherheitszielsetzung für den TOE und führt zu der Schlussfolgerung, dass dies auch wirklich zutrifft.

7.3.2.6 Spezielle Typen von SFR

Die SFR können in Paketen, PP und PP-Modulen als optionale Anforderungen oder auswahlbasierte Anforderungen bezeichnet werden.

A. Optionale Anforderungen

Optionale Anforderungen sind „optional“ in dem Sinne, dass sie nicht in einem PP/einer ST enthalten sein brauchen, damit das PP/die ST Anspruch auf Konformität (jeglicher Art) mit einem PP oder einer PP-Konfiguration beanspruchen kann.

Pakete, PP und PP-Module dürfen optionale Anforderungen in einer der zwei Kategorien definieren. Jede Kategorie wird explizit vom Autor festgelegt.

Die erste Kategorie der optionalen Anforderungen ist eine fakultativ zu berücksichtigende Kategorie. Anforderungen in dieser Kategorie müssen nicht in einem PP/einer ST enthalten sein, damit das PP/die ST Konformität (jeglicher Art) mit dem PP oder der PP-Konfiguration beanspruchen kann, wenn die Anforderung definiert ist. In diesem Fall ist es nicht zwingend erforderlich, dass das PP/die ST die Anforderung enthält, selbst wenn der TOE die in der Anforderung beschriebene Funktionalität implementiert.

Die zweite Kategorie der optionalen Anforderungen ist bedingt. Wenn der TOE die beschriebene Funktionalität implementiert, muss die optionale Anforderung in das PP/die ST aufgenommen werden. Wenn der TOE die von der optionalen Anforderung abgedeckte Funktionalität nicht implementiert, dann wird die Anforderung nicht in das PP/die ST aufgenommen.

ANMERKUNG Optionale Anforderungen können als Antwort auf SPD-Elemente geschrieben werden, die im Paket, PP oder PP-Modul vorhanden sind, oder auf SPD-Elemente, die speziell mit der Anforderung verbunden sind. Solche Assoziationen werden im Paket, PP oder PP-Modul identifiziert. Ein Paket, PP, PP-Modul oder ST mit direkter Begründung definiert keine Sicherheitszielsetzungen für optionale Anforderungen, die zugehörige SPD-Elemente haben, während ein reguläres Paket, PP, PP-Modul oder ST Sicherheitszielsetzungen für die zugehörigen SFR und SPD-Elemente enthält.

B. Auswahlbasierte Anforderungen

Pakete, PP und PP-Module können einen Satz auswahlbasierter SFR identifizieren. In diesem Fall stellt der Autor zusätzlich sicher, dass das Paket/PP/PP-Modul die Abhängigkeiten zwischen einer bestimmten Auswahl in einer Sicherheitsfunktionskomponente und/oder SFR, die in dem Paket/PP/PP-Modul enthalten ist, und der/den zugehörigen auswahlbasierten SFR, die enthalten sein muss/müssen, wenn diese Auswahl von einem anderen PP-/ST-Autor gewählt wird, klar angibt. Dies wird in 8.2.4.2 erläutert.

7.3.3 Vertrauenswürdigkeitsanforderungen (SARs)**7.3.3.1 Allgemein**

Die SARs sind eine Beschreibung, wie der TOE zu evaluieren ist, wobei sie in Paketen, PP, PP-Modulen, PP-Konfigurationen und ST definiert werden dürfen. Diese Beschreibung verwendet aus zwei Gründen eine standardisierte Sprache:

- zur genauen Beschreibung, wie der TOE zu evaluieren ist;

- um Vergleiche zwischen zwei STs zu ermöglichen. Die standardisierte Sprache erzwingt die Verwendung einheitlicher Terminologie und Begriffe.

Diese standardisierte Sprache wird durch die in ISO/IEC 15408-3 definierten Komponenten wiedergegeben, und die zulässigen Operationen sind in Abschnitt 8 definiert. Die Verwendung dieser Sprache ist verpflichtend, wobei es einige Ausnahmen gibt. Die Normenreihe ISO/IEC 15408 erweitert diese Sprache auf zwei Weisen:

- a) Durch die Bereitstellung von Operationen: Mechanismen, die dem Autor von Paketen/PP/PP-Modulen/PP-Konfigurationen/ST eine Modifizierung der SARs erlauben. Die Normenreihe ISO/IEC 15408 definiert vier Operationen: Zuweisung, Auswahl, Iteration und Präzisierung. Diese Operationen werden in 8.2 ausführlicher beschrieben;
- b) Durch die Bereitstellung von Abhängigkeiten: ein Mechanismus zur Unterstützung einer konsistenten Auswahl aus anderen SARs, um die abhängige SAR zu vervollständigen. In der Sprache von ISO/IEC 15408-3 kann eine SAR eine Abhängigkeit zu anderen SARs haben. Das deutet darauf hin, dass ein(e) diese SAR verwendende(s) Paket/PP/PP-Modul/PP-Konfiguration/ST im Allgemeinen auch jene anderen SARs erfordert. Dies macht es für den Autor wesentlich schwieriger, das Einbinden der erforderlichen SARs zu übersehen und verbessert somit die Vollständigkeit der Pakete, ST, PP, PP-Module und PP-Konfigurationen. Abhängigkeiten werden ausführlicher in 8.3 beschrieben.

ANMERKUNG Die in ISO/IEC 15408-3 definierten SAR benutzen keine Zuweisungen oder Auswahlen. Es ist jedoch möglich, erweiterte Vertrauenswürdigkeitskomponenten zu definieren, die diese Operationen ermöglichen.

7.3.3.2 SARs und die Begründung der Sicherheitsanforderungen

Vertrauenswürdigkeitspakete, PP, PP-Module, PP-Konfigurationen und ST enthalten auch eine Begründung für die Sicherheitsanforderungen, in der erklärt wird, warum der gewählte Satz von SAR als angemessen erachtet wird.

ANMERKUNG Im Falle der genauen Konformität übernimmt ein PP-Modul die SARs von seiner PP-Modulbasis, so dass keine Begründung für die SARs erforderlich ist.

Die SARs tragen zu dem Vertrauen bei, das ein Risikoeigentümer in eine Evaluierung setzen kann. Viele der in ISO/IEC 15408-3 aufgeführten SARs beziehen sich auf die Design- und Entwicklungsprozesse, die bei der Implementierung eines TOE durch einen Entwickler verwendet werden, sowie auf die Prüfung durch den Entwickler. Einige SARs beziehen sich auf einen betrieblichen TOE, z. B. den sicheren Auslieferungsprozess und die Mängelbeseitigung. Einige SARs beziehen sich speziell auf die Anfälligkeitsanalyse des Evaluators und auf unabhängige Funktions- und Penetrationstests.

BEISPIEL Ein Beispiel für eine Inkonsistenz in der Auswahl der SARs ist die Erwähnung einer SPD mit sehr leistungsfähigen Bedrohungsagenten und einer niedrigen (oder nicht vorhandenen) „Vulnerability analysis“ (AVA_VAN) in den SARs.

7.3.4 Sicherheitsanforderungen: Schlussfolgerung

Im Abschnitt der SPD eines/einer Funktionspakets/PP/PP-Moduls/ST ist das Sicherheitsproblem als eine Zusammensetzung aus den SPD-Elementen definiert: Bedrohungen, OSPs und Annahmen. Im Abschnitt der Sicherheitszielsetzungen eines/einer Funktionspakets/PP/PP-Moduls/ST wird die Lösung in Form von zwei Teillösungen bereitgestellt:

- Sicherheitszielsetzungen für den TOE;
- Sicherheitszielsetzungen für die Betriebsumgebung.

Zusätzlich wird eine Begründung für die Sicherheitszielsetzungen geliefert, um zu rechtfertigen, dass das Sicherheitsproblem gelöst ist, wenn alle Sicherheitszielsetzungen erfüllt sind.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01 prEN ISO/IEC 15408-1:2023 (D)

Im Abschnitt der Sicherheitsanforderungen werden die Sicherheitszielsetzungen für den TOE in SFRs übertragen und es wird eine Begründung der Sicherheitsanforderungen bereitgestellt, die aufzeigt, dass die Sicherheitszielsetzungen für den TOE erreicht sind, wenn alle SFRs erfüllt werden.

Zusätzlich wird ein Satz an SARs bereitgestellt, der aufzeigt, wie der TOE zu evaluieren ist, einschließlich einer Erklärung für die Auswahl dieser SARs. Der Satz an SARs muss mit den aus der SPD abgeleiteten Sicherheitserwartungen übereinstimmen. Die Erklärung für die SAR-Auswahl muss in der SAR-Begründung enthalten sein.

Die Betriebsumgebung selbst fällt nicht in den Anwendungsbereich der Evaluierung; wenn jedoch die Vertrauenswürdigkeitsklasse des AGD in einer ST enthalten ist, müssen die TOE-Leitlinien diese Sicherheitszielsetzungen für die Betriebsumgebung vollständig widerspiegeln und werden als Teil der Evaluierung anhand der AGD-Klasse bewertet.

Der oben aufgeführte Inhalt wird in folgender Aussage zusammengefasst: „Wenn alle SFRs und SARs erfüllt werden und alle Sicherheitszielsetzungen für die Betriebsumgebung erreicht werden, dann liegt die Zusage vor, dass das Sicherheitsproblem entsprechend der Definition in ASE_SPD gelöst wird: allen Bedrohungen wird entgegengewirkt, alle OSPs werden durchgesetzt und alle Annahmen werden eingehalten.“ Dies ist in Bild 4 dargestellt.

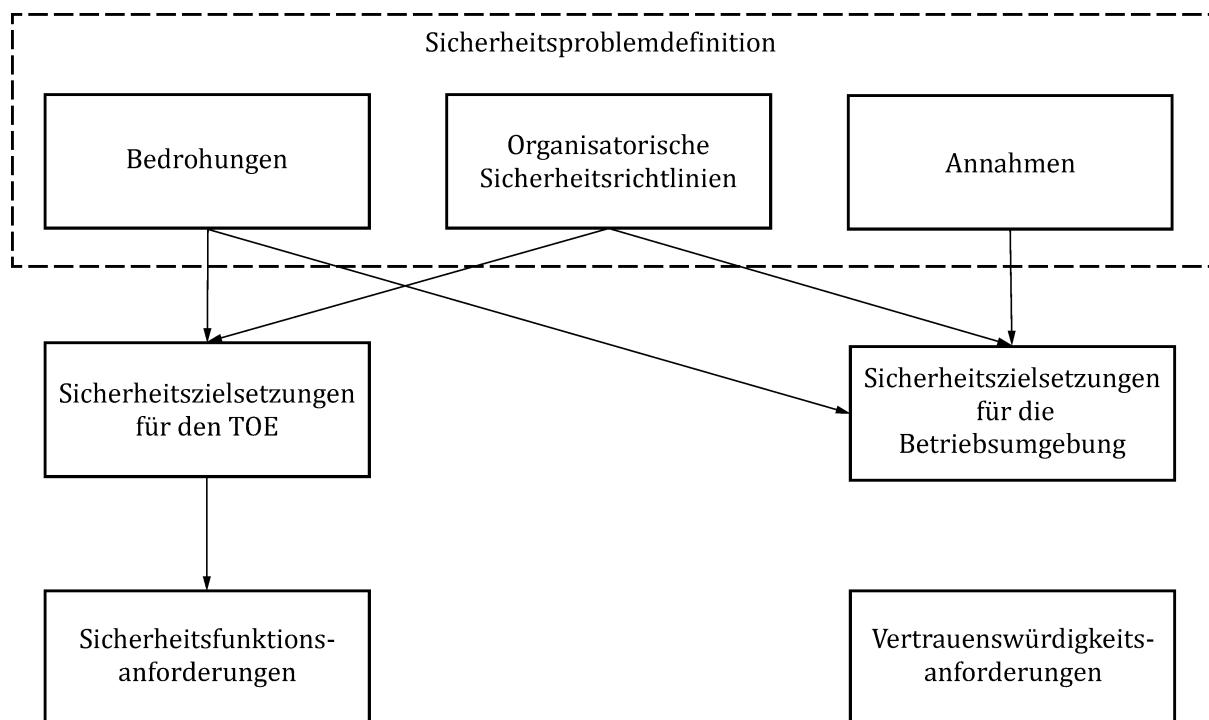


Bild 4 — Beziehungen zwischen SPD, Sicherheitszielsetzungen und Sicherheitsanforderungen

Der Grad der durch eine Evaluierung erreichten Vertrauenswürdigkeit wird über die SARs definiert und die Frage, ob dieser Vertrauenswürdigkeitsgrad für die die ST benutzenden Risikoeigentümer ausreicht, wird über die abgegebenen Erklärungen für die Auswahl dieser SARs beschrieben.

8 Sicherheitskomponenten

8.1 Hierarchische Struktur der Sicherheitskomponenten

8.1.1 Allgemein

ISO/IEC 15408-2 und ISO/IEC 15408-3 enthalten Kataloge von Sicherheitskomponenten, die bei der Festlegung von Sicherheitsanforderungen verwendet werden müssen. In den Katalogen sind die Komponenten in einer hierarchischen Struktur auf vier Ebenen angeordnet:

- Klassen, bestehend aus;
- Familien, bestehend aus;
- Komponenten, bestehend aus;
- Elementen, die nicht unterteilt werden können.

8.1.2 Klasse

Die Anforderungen für Funktionsklassen finden sich in ISO/IEC 15408-2: 2022, 6.1.2. Die Anforderungen für Vertrauenswürdigkeitsklassen finden sich in ISO/IEC 15408-3: 2022, 6.2.

Eine Klasse besteht aus einem Satz Familien.

BEISPIEL Ein Beispiel für eine Klasse ist die Klasse „FIA: Identification and authentication“ mit dem Schwerpunkt auf Identifizierung von Benutzern, Authentifizierung von Benutzern und Bindung von Benutzern und Subjekten.

8.1.3 Familie

Die Anforderungen für Funktionsfamilien finden sich in ISO/IEC 15408-2: 2022, 6.1.3. Die Anforderungen für Vertrauenswürdigkeitsfamilien finden sich in ISO/IEC 15408-3: 2022, 6.3.

Eine Familie besteht aus einem Satz Komponenten.

BEISPIEL Ein Beispiel für eine Familie ist die Familie „User authentication“ (FIA_UAU), die Teil der Klasse „FIA: Identification and authentication“ ist. Diese Familie legt den Schwerpunkt auf die Authentifizierung von Benutzern.

8.1.4 Komponente

Die Anforderungen für Funktionskomponenten finden sich in ISO/IEC 15408-2:2022, 6.1.4. Die Anforderungen für Vertrauenswürdigkeitskomponenten finden sich in ISO/IEC 15408-3:2022, 6.4.

Eine Komponente besteht aus einem Satz Elementen.

BEISPIEL Ein Beispiel für eine Komponente ist die Komponente „FIA_UAU.3 Unforgeable authentication“, die den Schwerpunkt auf fälschungssichere Authentifizierung legt.

8.1.5 Element

Die Anforderungen für Funktionselemente finden sich in ISO/IEC 15408-2:2022, 6.1.4. Die Anforderungen für Vertrauenswürdigkeitselemente finden sich in ISO/IEC 15408-3:2022, 6.5.

BEISPIEL Ein Beispiel für ein Element ist „FIA_UAU.3.2“, das den Schwerpunkt auf die Verhinderung von Nutzen kopierter Authentifizierungsdaten legt.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****8.2 Operationen****8.2.1 Allgemein**

ISO/IEC 15408-2 und ISO/IEC 15408-3 enthalten Kataloge von Sicherheitskomponenten, und dieses Dokument bietet den Autoren die Möglichkeit, die Komponentenkataloge unter bestimmten Umständen zu erweitern. Durch die Anwendung von Operationen auf die Sicherheitskomponenten können diese beim Schreiben von PP, PP-Modulen, Paketen und ST genau auf die Bedürfnisse des Autors zugeschnitten werden.

Sicherheitskomponenten können genauso verwendet werden, wie in ISO/IEC 15408-2 und ISO/IEC 15408-3 definiert, oder sie können für die Verwendung zulässiger Operationen angepasst werden.

Wenn Operationen verwendet werden, sollte der Autor besonders darauf achten, dass die Abhängigkeiten aus anderen Anforderungen, die von dieser Anforderung abhängen, erfüllt sind. Die zulässigen Operationen werden aus folgender Menge ausgewählt:

- a) Iteration: erlaubt die mehrmalige Verwendung einer Komponente mit wechselnden Operationen;
- b) Zuweisung: erlaubt die Spezifizierung von Parametern;
- c) Auswahl: erlaubt die Spezifizierung von einem oder mehreren Elementen aus einer Liste; und
- d) Präzisierung: erlaubt das Hinzufügen von Details.

Die Operationen Zuweisung und Auswahl sind nur zulässig, wenn dies explizit in einer Komponente angezeigt wird. Iteration und Präzisierung sind für alle Sicherheitsanforderungen zulässig. Eine ausführlichere Beschreibung dieser Operationen folgt unten.

Die Anhänge von ISO/IEC 15408-2 bieten Leitlinien für die zulässige Gestaltung von Auswahlen und Zuweisungen. Diese Leitlinien enthalten Anleitungen zum Vervollständigen von Operationen; diese Anleitungen müssen befolgt werden, es sei denn, der Autor rechtfertigt die Abweichung.

- „Keine“ ist nur als Option für die Vervollständigung einer Auswahl verfügbar, wenn dies explizit angeboten wird;

Die angebotenen Listen für die Vervollständigung von Auswahlen müssen „nicht-leer“ sein. Wenn die Option „Keine“ ausgewählt wird, dürfen keine anderen Optionen ausgewählt werden. Wenn „Keine“ nicht als Option in einer Auswahl verfügbar ist, dann ist es zulässig, die Optionen in einer Auswahl mit „unds“ und „oders“ zu kombinieren, es sei denn, die Auswahl gibt explizit „eine auswählen“ vor.

Auswahl-Operationen dürfen mit Iterationen kombiniert werden, falls erforderlich. In solch einem Fall sollte die Anwendbarkeit einer ausgewählten Option für jede Iteration sich nicht mit dem Inhalt einer anderen iterierten Auswahl überschneiden, da jede Auswahl exklusiv sein soll.

- Bei der Fertigstellung von Zuweisungen müssen die Anhänge von ISO/IEC 15408-2 hinzugezogen werden, um zu bestimmen, in welchen Fällen „Keine“ eine gültige Gestaltung ist.

8.2.2 Iteration

Die Operation Iteration darf für jede Komponente ausgeführt werden. Der Autor führt eine Iterationsoperation unter Einbeziehung mehrerer Anforderungen auf Grundlage der gleichen Komponente durch. Jede Iteration einer Komponente muss sich von allen anderen Iterationen dieser Komponente unterscheiden; dies wird über die unterschiedliche Ausgestaltung von Zuweisungen und Auswahlen oder durch die Anwendung von Präzisierungen umgesetzt.

Unterschiedliche Iterationen müssen eindeutig identifiziert werden, um klare Begründungen und Rückverfolgbarkeit von und zu diesen Anforderungen zu erreichen. Zuordnungsmerkmale zur Iteration sollten für die Leser aussagekräftig sein.

BEISPIEL „FCS_COP.1 Cryptographic operation“, die zweimal iteriert wird, um so die Implementation von zwei unterschiedlichen kryptographischen Algorithmen zu erfordern. Ein Beispiel für jede dieser einmalig identifizierten Iterationen ist:

- kryptographische Operation (RSA-Signaturen) (FCS_COP.1(RSA signatures));
- kryptographische Operation (AES-Datenverschlüsselung/-entschlüsselung) (FCS_COP.1(AES data encryption/decryption)).

ANMERKUNG Manchmal kann eine Operation vom Typ Iteration mit Komponenten verwendet werden, bei denen auch eine Operation vom Typ Zuweisung möglich ist; diese Zuweisung könnte dann einen Bereich oder eine Werteliste enthalten, anstatt die Komponente zu iterieren. In solch einem Fall kann der Autor die zweckmäßigste Alternative auswählen; dabei ist zu berücksichtigen, ob eine vollständige Begründung für den gesamten Wertebereich notwendig ist, oder ob es erforderlich ist, eine separate Begründung für jeden einzelnen Wert zu verwenden. Der Autor wägt ab, ob individuelle Rückverfolgbarkeit für diese Werte erforderlich ist.

8.2.3 Zuweisung

Eine Zuweisungsoperation tritt auf, wenn eine Komponente ein Element mit einem Parameter enthält, der von einem Autor gesetzt werden kann. Der Parameter kann eine uneingeschränkte Variable oder eine Regel sein, die die Variable auf einen bestimmten Wertebereich einschränkt.

Wenn ein Element in einem PP, PP-Modul oder Paket innerhalb eines PP/PP-Moduls eine Zuweisung enthält, muss der Autor eine von vier Aufgaben ausführen:

- a) die Zuweisung unvollständig lassen;

BEISPIEL 1 Der Autor kann FIA_AFL.1.2 in das PP, PP-Modul oder Paket aufnehmen.

„Wenn die definierte Anzahl an nicht erfolgreichen Authentifizierungsversuchen erreicht oder überschritten wurde, **muss** die TSF [Zuweisung: Maßnahmenliste].“

In diesem Fall kann der ST-Autor FIA_AFL.1.2 entsprechend ergänzen:

„Wenn die definierte Anzahl an nicht erfolgreichen Authentifizierungsversuchen erreicht oder überschritten wurde, muss die TSF diese externe Entität zukünftig von der Bindung zu jeglichem Subjekt abhalten.“

- b) die Zuweisung vervollständigen;

BEISPIEL 2 Der Autor kann FIA_AFL.1.2 in das PP, PP-Modul oder Paket aufnehmen.

„Wenn die definierte Anzahl an nicht erfolgreichen Authentifizierungsversuchen erreicht oder überschritten wurde, muss die TSF diese externe Entität zukünftig von der Bindung zu jeglichem Subjekt abhalten.“

- c) die Zuweisung einschränken, um den erlaubten Wertebereich weiter zu beschränken;

BEISPIEL 3 Der Autor kann FIA_AFL.1.1 in das PP, PP-Modul oder Paket aufnehmen.

„Die TSF muss erkennen, wenn [Zuweisung: positive ganze Zahl] erfolglose Authentifizierungsversuche auftreten ...“

In diesem Fall kann der ST-Autor FIA_AFL.1.1 entsprechend ergänzen:

„Die TSF muss erkennen, wenn **3** erfolglose Authentifizierungsversuche auftreten ...“

- d) die Zuweisung in eine Auswahl umwandeln und damit die Zuweisung einschränken.

BEISPIEL 4 Der Autor kann FIA_AFL.1.2 in das PP, PP-Modul oder Paket aufnehmen.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

„Wenn die definierte Anzahl an nicht erfolgreichen Authentifizierungsversuchen erreicht oder überschritten wurde, muss die TSF [Auswahl: diesen Benutzer in Zukunft von der Bindung zu jeglichem Subjekt abhalten, den Administrator benachrichtigen].“

In diesem Fall kann der ST-Autor FIA_AFL.1.2 entsprechend ergänzen:

„Wenn die definierte Anzahl an nicht erfolgreichen Authentifizierungsversuchen erreicht oder überschritten wurde, muss die TSF **diesen Benutzer zukünftig von der Bindung zu jeglichem Subjekt abhalten.**“

Ein ST-Autor muss alle Zuweisungen vervollständigen.

Die ausgewählten Werte in den Optionen b) und c) müssen dem angezeigten Typ entsprechen, der für die Zuweisung erforderlich ist.

Wenn eine Zuweisung mit einem Satz zu vervollständigen ist, sollte der Autor eine Beschreibung des Satzes liefern, aus dem die Elemente des Satzes abgeleitet werden können, solange es klar ist, welche Themen gemeint sind.

BEISPIEL 5 Wo der Satz „Subjekte“ ist:

- alle Subjekte;
- alle Subjekte vom Typ X;
- alle Subjekte außer Subjekt a.

8.2.4 Auswahl

8.2.4.1 Allgemein

Eine Auswahloperation tritt auf, wenn eine Komponente ein Element enthält, für das der Autor aus mehreren Punkten wählen muss.

Wenn ein Element in einem PP, PP-Modul oder Paket eine Auswahl enthält, darf der Autor eine von drei Aufgaben ausführen:

- a) die Auswahl unvollständig lassen;
- b) die Auswahl mit einem oder mehreren Punkten vervollständigen;
- c) die Auswahl durch Entfernen von Optionen einschränken, dabei aber zwei oder mehr aktiv lassen.

Wenn ein Element in einem PP, PP-Modul oder Paket eine Auswahl enthält, muss ein ST-Autor die Auswahl wie oben in b) vervollständigen. Optionen a) und c) sind für STs nicht erlaubt.

Der/die in b) und c) gewählte(n) Punkt(e) müssen Punkte aus der vorgegebenen Auswahl sein.

BEISPIEL 1 Ein Beispiel für ein Element mit einer Auswahl ist:

FPT_TST.1.1 „Die TSF muss eine Folge an Selbsttests ausführen [Auswahl: beim ersten Hochfahren, regelmäßig im Normalbetrieb, auf Anforderung des autorisierten Benutzers, bei den Bedingungen [Auswahl: Bedingungen, bei denen der Selbsttest ausgeführt werden sollte]], um den ordnungsgemäßen Betrieb von ...“

8.2.4.2 Auswahlbasierte Sicherheitsfunktionskomponenten und SFR

Ein PP, PP-Modul oder Paket kann einen Satz von Sicherheitsfunktionskomponenten und/oder SFR definieren, die als auswahlbasierte SFR bezeichnet werden. Dieser Satz von Komponenten und/oder SFR ist mit einer Auswahl verbunden, die in einer anderen Komponente und/oder SFR im PP, PP-Modul oder Paket getroffen

wurde. Die zugehörigen auswahlbasierten Komponenten und/oder SFR müssen in einem PP, PP-Modul, Paket oder ST enthalten sein, wenn:

- eine im PP, PP-Modul oder Paket identifizierte Auswahlmöglichkeit anzeigt, dass sie eine zugehörige auswahlbasierte SFR hat;
- diese Auswahl vom Autor getroffen wird.

Das PP, PP-Modul oder Paket kann so angeordnet werden, dass auswahlbasierte Komponenten und/oder SFR zusammengefasst werden.

Für den Fall, dass ein Autor eine Auswahloperation unvollendet lassen muss, muss er die auf der Auswahl basierenden Komponenten und/oder SFR, die mit der unvollendeten Auswahloperation verbunden sind, unverändert lassen.

Für den Fall, dass der Autor die Auswahl vervollständigen muss, sollten die Autoren die entsprechenden auswahlbasierten Komponenten und/oder SFR in die Liste der SFR für das PP, PP-Modul, Paket oder ST aufnehmen.

Für den Fall, dass die Auswahloperation eingeschränkt werden soll, d. h. einige, aber nicht alle Auswahlen entfernt werden, muss der Autor alle auf der Auswahl basierenden Komponenten und/oder SFR aus der Liste entfernen, die den aus der Auswahl entfernten Auswahlen entsprechen.

Nachstehend ein weiteres Beispiel für eine solche SFR:

BEISPIEL 1 Ein Beispiel für eine auswahlbasierte SFR, bei der FTP_ITC.1.1 die SFR mit der Auswahl und FCS_IPSEC.1 die auswahlbasierte SFR ist:

FTP_ITC.1.1 Die TSF muss in der Lage sein, die [Auswahl: IPsec, SSH, TLS, HTTPS] zur Bereitstellung eines vertrauenswürdigen Kommunikationskanals zu nutzen zwischen...

Anwendungshinweis:

Bei der Auswahl für FTP_ITC.1.1 wählt der ST-Autor den Mechanismus oder die Mechanismen aus, die vom TOE unterstützt werden, und stellt dann sicher, dass die auf der Auswahl basierenden Anforderungen in Anhang B dieses PP, die dem ausgewählten Mechanismus oder den ausgewählten Mechanismen entsprechen, in der ST enthalten sind.

Und in Anhang B des Beispiels PP:

Die folgenden SFR sind in der ST enthalten, wenn der ST-Autor „IPsec“ in FTP_ITC.1.1 auswählt:

FCS_IPSEC.1 [...]

8.2.5 Präzisierung

Die Operation Präzisierung darf für jede Komponente ausgeführt werden. Der Autor führt eine Präzisierung über eine Änderung der Anforderung durch.

ANMERKUNG 1 Eine Reihe von präzisierten Iterationsoperationen kann verwendet werden, um alle Subjekte, Objekte, Operationen, Sicherheitsattribute und/oder externen Entitäten abzudecken, wobei jedoch nicht jede einzelne Präzisierung ausreicht.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01**
prEN ISO/IEC 15408-1:2023 (D)

Die erste Regel für eine Präzisierung ist, dass ein TOE, der die präzisierte Anforderung erfüllt, auch die unpräzisierte Anforderung im Kontext des PPs, PP-Moduls, Pakets oder STs erfüllt, d. h. eine präzisierte Anforderung muss „strenger“ sein, als die ursprüngliche Anforderung. Wenn die Präzisierung diese Regel nicht erfüllt, wird die daraus entstehende Anforderung als eine erweiterte Anforderung betrachtet und muss auch als solche in Übereinstimmung mit 7.3 behandelt werden.

BEISPIEL 2 Ein Beispiel für eine gültige Präzisierung umfasst:

FIA_UAU.2.1 „Die TSF muss von jedem Benutzer die erfolgreiche Authentifizierung erfordern, bevor irgendwelche weiteren TSF-vermittelten Tätigkeiten im Namen dieses Benutzers erlaubt werden.“ wird präzisiert zu „Die TSF muss von jedem Benutzer die erfolgreiche Authentifizierung über Benutzername/Passwort erfordern, bevor irgendwelche weiteren TSF-vermittelten Tätigkeiten im Namen dieses Benutzers erlaubt werden.“

Die einzige Ausnahme zu dieser Regel ist, dass ein Autor eine SFR präzisieren kann, um sie auf einige, aber nicht alle Subjekte, Objekte, Operationen, Sicherheitsattribute und/oder externe Entitäten anzuwenden. Für zu präzisierende SFRs, die aus den PP, PP-Modulen oder Paketen stammen, für die Konformität beansprucht wird, gilt diese Ausnahme allerdings nicht; diese SFRs dürfen nicht präzisiert werden, um weniger Subjekte, Objekte, Operationen, Sicherheitsattribute und/oder externe Entitäten als die SFR im ursprünglichen PP, PP-Modul oder Paket anzuwenden.

BEISPIEL 3 Ein Beispiel für eine solche Ausnahme ist:

FIA_UAU.2.1 „Die TSF muss von jedem Benutzer die erfolgreiche Authentifizierung erfordern, bevor irgendwelche weiteren TSF-vermittelten Tätigkeiten im Namen dieses Benutzers erlaubt werden.“ wird präzisiert zu „Die TSF muss von jedem Benutzer, der aus dem Internet zugreifen möchte, die erfolgreiche Authentifizierung erfordern, bevor irgendwelche weiteren TSF-vermittelten Tätigkeiten im Namen dieses Benutzers erlaubt werden.“

Die zweite Regel für eine Präzisierung ist, dass die Präzisierung einen Bezug zur ursprünglichen Komponente haben muss.

BEISPIEL 4 Die Präzisierung einer Audit-Komponente mit einem zusätzlichen Element zur Verhinderung von elektromagnetischer Strahlung ist nicht erlaubt.

Ein Sonderfall der Präzisierung ist eine redaktionelle Präzisierung, bei der eine kleine Änderung in der Anforderung durchgeführt werden darf, d. h. Umformulieren eines Satzes, um der deutschen Grammatik zu entsprechen oder um den Satz verständlicher für die Leser zu gestalten. Eine Bedeutungsänderung der Anforderung ist durch diese Änderung in keinem Fall erlaubt.

BEISPIEL 5 Ein Beispiel für eine redaktionelle Präzisierung umfasst:

Die SFR FPT_FLS.1, „Die TSF muss in einem sicheren Zustand verbleiben, wenn einer der folgenden Fehlerzustände eintritt: **Ausfall einer CPU**“

die präzisiert werden könnte zu

FPT_FLS.1, „Die TSF muss in einem sicheren Zustand verbleiben, wenn der folgende Fehlerzustand eintritt: **Ausfall einer CPU**“

oder sogar

FPT_FLS.1, „Die TSF muss in einem sicheren Zustand verbleiben, wenn **eine CPU ausfällt**“.

8.3 Abhängigkeiten zwischen Komponenten

Zwischen den Komponenten können Abhängigkeiten bestehen. Wenn eine Komponente für sich genommen nicht angemessen ist und auf das Vorhandensein einer anderen Komponente angewiesen ist, um Sicherheitsfunktionalität oder Vertrauenswürdigkeit herzustellen, entstehen Abhängigkeiten.

Die Funktionskomponenten in ISO/IEC 15408-2 haben üblicherweise Abhängigkeiten zu anderen Funktionskomponenten. Einige der Vertrauenswürdigkeitskomponenten in ISO/IEC 15408-3 haben auch Abhängigkeiten, die wiederum Abhängigkeiten zu anderen Komponenten in ISO/IEC 15408-3 haben.

Es können auch Abhängigkeiten zwischen Komponenten von ISO/IEC 15408-2 zu Komponenten von ISO/IEC 15408-3 definiert sein. Erweiterte Funktions-/Vertrauenswürdigkeitskomponenten können Abhängigkeiten in ähnlicher Weise definieren.

Beschreibungen zu den Abhängigkeiten der Komponenten werden anhand der Komponentendefinitionen in ISO/IEC 15408-2, ISO/IEC 15408-3 oder der erweiterten Komponentendefinition festgelegt. Um die Vollständigkeit der TOE-Sicherheitsanforderungen sicherzustellen, sollten Abhängigkeiten erfüllt sein, wenn Anforderungen, die auf abhängigkeitsbehafteten Komponenten basieren, in PPs, PP-Module, Pakete oder STs aufgenommen werden. Abhängigkeiten sollten auch bei der Erstellung von Paketen berücksichtigt werden, d. h. wenn Komponente A eine Abhängigkeit zu Komponente B hat, folgt daraus, dass immer dann, wenn ein PP, PP-Modul, Paket oder eine ST eine Sicherheitsanforderung enthält, die auf Komponente A basiert, das PP, PP-Modul, Paket oder die ST auch eine der folgenden Anforderungen enthalten muss:

- a) eine Sicherheitsanforderung basierend auf Komponente B; oder
- b) eine Sicherheitsanforderung basierend auf einer Komponente, die in der Hierarchie höher liegt als B; oder
- c) eine Begründung, warum das PP, PP-Modul, Paket oder die ST keine Sicherheitsanforderung basierend auf Komponente B enthält.

Wenn eine Sicherheitsanforderung wegen einer Abhängigkeit aufgenommen wird, wie in den Fällen a) und b), kann es erforderlich sein, Operationen (Zuweisung, Iteration, Präzisierung, Auswahl) für diese Sicherheitsanforderung in einer speziellen Weise zu vervollständigen, um sicherzustellen, dass die Abhängigkeit auch wirklich erfüllt wird.

Für den Fall c) sollte die Begründung, dass die Sicherheitsanforderung nicht aufgenommen wird, einen der folgenden Punkte behandeln:

- warum die Abhängigkeit nicht erforderlich oder sinnvoll ist; oder
- dass die Abhängigkeit über die Betriebsumgebung des TOEs behandelt wurde; in diesem Fall sollte in der Begründung beschrieben sein, wie die Sicherheitszielsetzungen für die Betriebsumgebung diese Abhängigkeit behandeln; oder
- dass die Abhängigkeit in irgendeiner anderen Art über andere SFRs behandelt wurde (z. B. erweiterte SFRs, Kombinationen von SFRs).

8.4 Erweiterte Komponenten

8.4.1 Allgemein

Sicherheitsanforderungen müssen auf Komponenten aus ISO/IEC 15408-2 oder ISO/IEC 15408-3 basieren; dabei gelten zwei Ausnahmen:

- a) es gibt Sicherheitszielsetzungen für den TOE, die nicht mit Hilfe der Komponenten in ISO/IEC 15408-2 in SFR übertragen werden können;

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

- b) eine Sicherheitszielsetzung für den TOE, die nur mit großen Schwierigkeiten und/oder großer Komplexität auf der Grundlage der Komponenten in ISO/IEC 15408-2 in SFR übertragen werden kann; es gibt Anforderungen Dritter, die nicht unter Verwendung der Komponenten in ISO/IEC 15408-3 in SAR übertragen werden können.

BEISPIEL Gesetze und/oder Vorschriften über die Evaluierung der Kryptographie.

In diesen Fällen muss der Autor neue Komponenten, so genannte erweiterte Komponenten, definieren. Eine präzise definierte erweiterte Komponente erfordert Kontext und Aussagekraft in Bezug auf die erweiterten SFRs und SARs, die auf diesen Komponenten basieren.

Nachdem die neuen Komponenten korrekt definiert wurden, kann der Autor anschließend eine oder mehrere SFRs oder SARs auf diesen neu definierten erweiterten Komponenten basieren lassen und sie dann genau wie die anderen SFRs und SARs verwenden. Ab diesem Zeitpunkt gibt es keine weitere Unterscheidung mehr zwischen aus der Normenreihe ISO/IEC 15408 abgeleiteten SFRs und SARs und auf erweiterten Komponenten basierenden SFRs und SARs.

Siehe ISO/IEC 15408-3 „Extended components definition“ (APE_ECD) und „Extended components definition“ (ASE_ECD) für weitere Anforderungen zu erweiterten Komponenten. Weitere Informationen zu erweiterten Komponenten sind auch unter D.3.6 zu finden.

8.4.2 Definieren erweiterter Komponenten

Die Definition einer erweiterten Komponente durch einen Autor eines Pakets, PP, PP-Moduls oder einer ST muss in einer ähnlichen Art erfolgen wie für bestehende Komponenten von der Normenreihe ISO/IEC 15408: deutlich, unmissverständlich und evaluierbar (ein systematischer Nachweis, dass eine auf der Komponente basierende Anforderung für einen TOE gilt, ist möglich). Erweiterte Komponenten müssen in Bezug auf Kennzeichnung, Ausdrucksart und Detailgrad bestehenden Komponenten der Normenreihe ISO/IEC 15408 ähneln.

Der Autor muss außerdem sicherstellen, dass alle geltenden Abhängigkeiten einer erweiterten Komponente in der Definition dieser erweiterten Komponenten enthalten sind.

BEISPIEL Beispiele für mögliche Abhängigkeiten sind:

- a) eine erweiterte Komponente, die auf Auditierung verweist, kann Abhängigkeiten zu Komponenten der Klasse „FAU“: „Security audit class“ aufnehmen;
- b) eine erweiterte Komponente, die auf Daten zugreift oder Daten verändert, kann Abhängigkeiten der Familie „Access control policy“ (FDP_ACC) von Komponenten aufnehmen;
- c) eine erweiterte Komponente, die eine bestimmte Design-Beschreibung verwendet, kann eine Abhängigkeit zur entsprechenden Familie „ADV“: „Development family“ aufnehmen.

Im Falle einer erweiterten Funktionskomponente, muss der Autor außerdem alle geltenden Informationen bezüglich Audit-Operationen und verwandter Operationen in die Komponentendefinition aufnehmen, ähnlich bestehender Komponenten von ISO/IEC 15408-2. Im Falle einer erweiterten Vertrauenswürdigkeitskomponente darf der Autor außerdem eine passende Evaluierungsmethodologie mitliefern, ähnlich der in der in ISO/IEC 18045 bereitgestellten Methode.

Erweiterte Komponenten dürfen in bestehende Familien eingeordnet werden; in solch einem Fall muss der Autor aufzeigen, wie sich diese Familien ändern. Wenn die Komponenten nicht in eine bestehende Familie passen, müssen sie in eine neue Familie eingeordnet werden. Neue Familien müssen in ähnlicher Weise definiert werden wie in ISO/IEC 15408-2 oder ISO/IEC 15408-3.

Neue Familien dürfen in bestehende Klassen eingeordnet werden; in solch einem Fall muss der Autor aufzeigen, wie sich diese Klassen ändern. Wenn die Familien nicht in eine bestehende Klasse passen, müssen sie in eine neue Klasse eingeordnet werden. Neue Klassen müssen ähnlich wie in ISO/IEC 15408-2 oder ISO/IEC 15408-3 definiert werden.

9 Pakete

9.1 Allgemein

Ein Paket ist ein benannter Satz an Sicherheitskomponenten oder Sicherheitsanforderungen.

Jede Partei kann ein Paket definieren und das Paket ist auf Wiederverwendbarkeit ausgelegt. Für dieses Ziel enthält das Paket nur Anforderungen, die sowohl sinnvoll als auch effektiv sind.

Wenn zwei oder mehr Pakete miteinander verbunden sind, können sie als Teil einer Paketfamilie dargestellt werden, siehe A.2.

Pakete können von PP, PP-Modulen, PP-Konfigurationen und ST beansprucht und zur Bildung größerer Pakete verwendet werden. Die Autoren dürfen die beanspruchten oder verwendeten Pakete nicht umbenennen.

ANMERKUNG 1 Obwohl in der Normenreihe ISO/IEC 15408 keine separaten Kriterien für die Evaluierung von Paketen angegeben sind, werden solche Pakete, sobald sie in einem PP, PP-Modul oder ST enthalten sind, anhand der Kriterien APE, ACE oder ASE evaluiert.

ANMERKUNG 2 ISO/IEC 15408-5 bietet häufig verwendete Pakete, wie z. B. EAL, die vordefiniert wurden und von PP, PP-Modulen, PP-Konfigurationen oder ST-Autoren verwendet werden können.

Funktionspakete können nicht direkt von einer PP-Konfiguration beansprucht werden; sie müssen Teil einer PP-Konfigurationskomponente sein.

Weitere Angaben zu den Paketen sind Anhang A zu entnehmen.

9.2 Pakettypen

9.2.1 Allgemein

Ein Paket muss entweder:

- ein Funktionspaket sein, das Funktionskomponenten oder -anforderungen, aber keine Sicherheitskomponenten oder -anforderungen enthält; oder
- ein Vertrauenswürdigkeitspaket sein, das Vertrauenswürdigkeitskomponenten oder -anforderungen, aber keine Funktionskomponenten oder -anforderungen enthält.

Gemischte Pakete, die sowohl Funktions- als auch Vertrauenswürdigkeitskomponenten oder -anforderungen enthalten, dürfen nicht festgelegt werden.

Alle Pakete müssen Folgendes umfassen:

- a) die Paketidentifizierung mit eindeutigem Namen, Kurznamen, Version, Datum, Antragsteller und den relevanten Teilen der Normenreihe ISO/IEC 15408;
- b) die Art des Pakets, entweder ein Vertrauenswürdigkeitspaket oder ein Funktionspaket;
- c) einen Paketüberblick mit ausformulierter Beschreibung zum Zweck des Pakets;
- d) Anwendungshinweise, die zusätzliche Informationen über das Paket enthalten;
- e) Identifizierung der Evaluierungsmethode(n) und/oder -aufgaben, wenn solche von ISO/IEC 18045 abgeleiteten Evaluierungsmethoden/-aufgaben festgelegt worden sind;
- f) eine oder mehrere Sicherheitskomponenten oder -anforderungen;

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

- g) wenn erweiterte Komponenten festgelegt wurden, enthält das Paket eine erweiterte Komponentendefinition;
- h) eine Komponentenbegründung für die Auswahl der Funktions- oder Vertrauenswürdigkeitskomponenten/-anforderungen, die im Paket enthalten sind.

9.2.2 Vertrauenswürdigkeitspakete

Ein Vertrauenswürdigkeitspaket enthält einen Satz von Vertrauenswürdigkeitskomponenten oder -anforderungen, die aus ISO/IEC 15408-3 stammen können, erweiterte Vertrauenswürdigkeitskomponenten sein oder eine Kombination aus beidem sein können.

Ein Vertrauenswürdigkeitspaket darf weder eine SPD oder Sicherheitszielsetzungen noch irgendwelche Sicherheitsfunktionskomponenten oder -anforderungen enthalten.

Vertrauenswürdigkeitspakete können in PP, PP-Modulen, PP-Konfigurationen und ST verwendet werden. Ein Satz vordefinierter hierarchischer Vertrauenswürdigkeitspakete wird in ISO/IEC 15408-5 angegeben.

BEISPIEL Die in ISO/IEC 15408-5 definierten EAL bestehen aus SAR, die aus ISO/IEC 15408-3 abgeleitet sind. Die EAL sind vordefinierte Vertrauenswürdigkeitspakete.

9.2.3 Funktionspakete

Ein Funktionspaket enthält einen Satz funktionaler Komponenten oder Anforderungen, die aus ISO/IEC 15408-2 stammen können, oder die erweiterte Funktionskomponenten oder -anforderungen oder eine Kombination aus beidem sein können.

Ein Funktionspaket darf eine SPD und aus dieser SPD abgeleitete Sicherheitszielsetzungen enthalten. Wenn das Paket eine SPD festlegt, dann müssen die Sicherheitszielsetzungen des Funktionspakets angegeben werden. Zu den Zielsetzungen gehören die Sicherheitszielsetzungen für den TOE (diese werden weggelassen, wenn der Ansatz der direkten Begründung verwendet wird), die Sicherheitszielsetzungen für die Betriebsumgebung und die Begründung der Sicherheitszielsetzungen.

Funktionspakete können innerhalb von PP, PP-Modulen und ST als Mittel zur Strukturierung der Sicherheitsfunktionalität in Bausteine verwendet werden.

Funktionspakete dürfen Abhängigkeiten zu anderen Funktionspaketen haben. Solche Abhängigkeiten müssen im Funktionspaket dokumentiert werden und können auch in einem PP, PP-Modul oder einer ST dokumentiert werden.

BEISPIEL Ein PP definiert und enthält Funktionspaket A; Paket A hat keine Abhängigkeiten. Die Funktionspakete B, C und D werden an anderer Stelle definiert. Paket D hat keine Abhängigkeiten, aber Paket C hängt von Paket B ab. Eine ST kann dann Konformität mit den folgenden Kombinationen aus PP und Paketen beanspruchen:

- die ST beansprucht Konformität mit dem PP (das das Funktionspaket A enthält);
- die ST beansprucht Konformität mit dem PP und dem Funktionspaket B;
- die ST beansprucht Konformität mit dem PP sowie den Funktionspaketen B und C;
- die ST beansprucht Konformität mit dem PP und dem Funktionspaket D;
- die ST beansprucht Konformität mit dem PP und den Funktionspaketen B, C und D.

Folgendes wäre nicht zulässig:

- Die ST beansprucht Konformität mit dem PP und dem Funktionspaket C (dies ist nicht zulässig, da das Paket C von Paket B abhängt und daher nicht unabhängig beansprucht werden kann).

9.3 Paketabhängigkeiten

Ein Paket erfüllt möglicherweise nicht alle Abhängigkeiten der in ihm enthaltenen Komponenten. Die Abhängigkeiten müssen jedoch von einem PP, PP-Modul, einer PP-Konfiguration oder ST erfüllt werden, die das Paket enthalten. Das bedeutet, dass es in der Verantwortung des Autors liegt, entweder sicherzustellen, dass alle Abhängigkeiten erfüllt sind, oder eine Begründung beizufügen, die erklärt, warum die Abhängigkeiten nicht erfüllt sind. Dies wird in 8.3 erklärt.

9.4 Evaluierungsmethode(n) und -aufgaben

Die Pakete können Evaluierungsmethoden/-aufgaben enthalten, die von ISO/IEC 18045 abgeleitet wurden. Wenn Evaluierungsmethoden/-aufgaben, die von ISO/IEC 18045 abgeleitet wurden, zur Evaluierung des Pakets verwendet werden sollen, dann müssen diese in dem entsprechenden Abschnitt der Sicherheitsanforderung durch eine Erklärung in der folgenden Form angegeben werden:

„Dieses Paket erfordert die Verwendung der in <Verweisung(en)> festgelegten Evaluierungsmethoden/Evaluierungsaufgaben.“

In dieser Erklärung wird <Verweisung> durch die Angabe des Orts der betreffenden Evaluierungsmethoden und Evaluierungsaufgaben ersetzt. Diese Verweisung darf sich auf das Dokument beziehen, das das Paket enthält, oder auf ein oder mehrere separate Dokumente.

ANMERKUNG ISO/IEC 15408-4 enthält ein Rahmenwerk für die Durchführung solcher Ableitungen.

10 Schutzprofile (PP)

10.1 Allgemein

Ein PP dient zur Beschreibung eines allgemeinen TOE-Typs. Deshalb kann ein PP verwendet werden:

- als ST-Vorlage für alle TOE, die dem TOE-Typ des PP entsprechen;
- als Vorlage für andere PP, um den TOE-Typ weiter zu präzisieren;
- als Basis für ein PP-Modul; in diesem Zusammenhang spricht man von einem Basis-PP.

Eine ausführliche Beschreibung der PPs ist in Anhang B enthalten.

ANMERKUNG Eine ST beschreibt die Anforderungen an einen bestimmten TOE und wird in der Regel vom Entwickler dieses TOE in Auftrag gegeben.

10.2 PP-Einleitung

Die Einleitung zum PP muss einen Referenzidentifikator für das PP enthalten.

Die Einleitung zum PP muss eine Übersicht über das PP enthalten, einschließlich einer Beschreibung des TOE-Typs.

Der Referenzidentifikator für ein PP muss innerhalb eines Katalogs eindeutig sein.

BEISPIEL Ein TOE-Typ kann „Firewall“ lauten;

Ein präzisierter TOE-Typ kann „Firewalls mit zustandsabhängiger Inspektion“ lauten;

Ein spezifischer TOE, der sich auf diesen TOE-Typ bezieht, kann die „MinuteGap Firewall v18.5“ sein.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Ein PP beschreibt die allgemeinen Anforderungen an einen TOE-Typ und wird daher in der Regel in Auftrag gegeben von

- einer technischen Benutzergruppe, die einen Konsens für die Anforderungen an einen bestimmten TOE-Typ erreichen möchte;
- einem Entwickler eines TOEs, oder einer Gruppe von Entwicklern ähnlicher TOEs, die Mindestanforderungen für diesen TOE-Typ festlegen möchte;
- einer Organisation wie z. B. einer Regierung oder einem großen Unternehmen bei der Festlegung ihrer/seiner Sicherheitsanforderungen als Teil ihres/seines Beschaffungsprozesses.

10.3 Konformitätsansprüche und Konformitätserklärungen

In diesem Unterabschnitt kennzeichnet die Verwendung von kursivem Text den wörtlichen Text, der im Text des PP erscheinen muss.

Die Konformitätsansprüche von PP:

- a) müssen die Ausgabe der relevanten Teile der Normenreihe ISO/IEC 15408 angeben, mit denen das PP Konformität beansprucht;
- b) müssen die Konformität mit ISO/IEC 15408-2 beschreiben, entweder als

— „*ISO/IEC 15408-2-konform*“;

Ein PP ist ISO/IEC 15408-2-konform, wenn alle SFR in diesem PP nicht auf Funktionskomponenten von ISO/IEC 15408-2 basieren, oder

— „*ISO/IEC 15408-2-erweitert*“

Ein PP ist ISO/IEC 15408-2-erweitert, wenn mindestens eine SFR in diesem PP nicht auf Funktionskomponenten von ISO/IEC 15408-2 basiert;

- c) müssen die Konformität mit ISO/IEC 15408-3 beschreiben, entweder als

— „*ISO/IEC 15408-3-konform*“;

Ein PP ist ISO/IEC 15408-3-konform, wenn alle SAR in diesem PP nicht auf Vertrauenswürdigkeitskomponenten von ISO/IEC 15408-3 basieren; oder

— „*ISO/IEC 15408-3-erweitert*“

Ein PP ist ISO/IEC 15408-3-erweitert, wenn mindestens eine SAR in diesem PP nicht auf Vertrauenswürdigkeitskomponenten von ISO/IEC 15408-3 basiert;

- d) dürfen auch einen Konformitätsanspruch in Bezug auf andere PP enthalten:

— „*PP-konform*“;

Ein PP ist „PP-konform“, wenn es einem oder mehreren anderen spezifischen PP entspricht.

- e) kann einen Anspruch auf Paketkonformität enthalten;

In einem PP kann mehr als ein Paket beansprucht werden.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Sofern ein Anspruch auf das Paket erhoben wird, muss er aus einer der folgenden Erklärungen für jeden Anspruch auf das Paket bestehen:

— „*Paket-konform*“;

Ein PP ist mit einem Paket konform, wenn

- bei Funktionspaketen alle Bestandteile (SPD, Sicherheitszielsetzungen und SFR) des Funktionspakets ohne Änderung in den entsprechenden Teilen des PP enthalten sind;
- bei Vertrauenswürdigkeitspaketen die SAR dieser PP mit den SAR des Vertrauenswürdigkeitspakets identisch sind;
- ein PP, das die Auswahl einiger SFR in einem Paket einschränkt, trotzdem beanspruchen kann, dass es Paket-konform ist.

— „*Paket-ergänzt*“;

Ein PP beansprucht eine Ergänzung eines Pakets, wenn

- bei Funktionspaketen alle Bestandteile (SPD, Sicherheitszielsetzungen und SFR) dieses PP alle Bestandteile enthalten, die im Funktionspaket angegeben sind, müssen aber mindestens eine zusätzliche SFR oder eine hierarchisch höhere SFR enthalten als eine SFR im Funktionspaket;
- bei Vertrauenswürdigkeitspaketen die SARs dieses PP alle SARs in diesem Vertrauenswürdigkeitspaket enthalten, aber mindestens eine zusätzliche SAR oder eine hierarchisch höhere SAR enthält als eine SAR im Vertrauenswürdigkeitspaket.

— „*Paket-angepasst*“

Ein PP beansprucht eine Anpassung eines Pakets, wenn

- bei Funktionspaketen alle Bestandteile (SPD, Sicherheitszielsetzungen und SFR) dieses PP alle Bestandteile enthalten, die im Funktionspaket angegeben sind, müssen aber zusätzliche Auswahlmöglichkeiten für einen SFR mit bestehenden Auswahlmöglichkeiten im Paket haben, und optional mindestens eine zusätzliche SFR oder eine hierarchisch höhere SFR enthalten als eine SFR im Funktionspaket,
- Vertrauenswürdigkeitspakete und ST dürfen keine Anpassung beanspruchen (oder durchführen).

In einem PP darf mehr als ein Paket beansprucht werden.

Wenn die PP eine strikte oder nachweisliche Konformität mit einer oder mehreren PP beanspruchen, dürfen sie nicht auch die Konformität mit den Paketen beanspruchen, die in den PP, deren Konformität sie beanspruchen, angegeben sind, es sei denn, das PP ergänzt das Paket. Das PP beansprucht <Paket>-ergänzt nur dann, wenn das PP die Pakete über das hinaus ergänzt, was das PP beansprucht, für das es Konformität beansprucht.

ANMERKUNG 1 Die PP können keine genaue Konformität mit einem oder mehreren PP beanspruchen.

- f) Die PP müssen eine Begründung für den Konformitätsanspruch enthalten;

In der Begründung des Konformitätsanspruchs werden die Gründe und die logische Basis für die Auswahl der Konformitätsansprüche und -aussagen durch den Autor beschrieben.

- g) Die PP müssen eine Konformitätserklärung bereitstellen.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Die Konformitätserklärung muss die Art und Weise beschreiben, in der andere PP oder ST mit diesem PP konform sein müssen: Die Konformitätserklärung muss von einem der folgenden Typen sein:

— „Genaue Konformität“;

Wenn das PP eine genaue Konformität vorschreibt, muss eine ST genau mit dem PP konform sein, d. h. eine konforme ST muss SPD und Zielsetzungen enthalten, die mit denen des PP identisch sind, sowie denselben Satz an SFR des PP mit allen aufgelösten Zuweisungen und Auswahlen;

— „Strikte Konformität“;

Wenn das PP eine strikte Konformität vorschreibt, muss ein(e) PP/ST strikt mit dem PP konform sein, d. h. ein(e) konforme(s) PP/ST muss eine Obermenge aus SPD des PP, Zielsetzungen und SFR enthalten, wobei die neuen Annahmen (falls vorhanden) die SPD des PP nicht abschwächen und die Zuweisungen und Auswahlen aller SFR des PP unverändert oder gegebenenfalls aufgelöst sind;

Strikte Konformität erlaubt es dem/der konformen PP/ST, der SPD, dem Satz von Zielsetzungen und den SFR des PP kein Element hinzuzufügen, d. h. die in dem/der PP/ST definierte Obermenge kann mit der des PP identisch sein, wobei alle SFR aufgelöst werden;

— „Nachweisliche Konformität“

Wenn das PP vorschreibt, dass eine nachweisliche Konformität erforderlich ist, müssen das/die PP/ST mit dem PP in strikter oder nachweislicher Weise konform sein, d. h. ein(e) konforme(s) PP/ST muss eine SPD, einen Satz von Zielsetzungen und einen Satz von SFR enthalten, die äquivalent zu einer Obermenge der SPD, der Zielsetzungen und der SFR des PP sind, wobei die neuen Annahmen (falls vorhanden) die SPD des PP nicht abschwächen und der Satz des/der konformen PP/ST der SFR die SFR des PP impliziert.

Die nachweisliche Konformität erlaubt es dem/der konformen PP/ST, unterschiedliche, aber äquivalente Aussagen zu verwenden, und sie erlaubt es auch, einfach eine Obermenge zu definieren, wie im Fall der strikten Konformität, ohne die im PP angegebenen Anweisungen zu ändern.

ANMERKUNG 2 Anders ausgedrückt ist ein(e) PP/ST nur für die nachweisliche Konformität mit einem PP erlaubt, wenn das PP dies explizit erlaubt.

ANMERKUNG 3 Die PP-Module und PP-Konfigurationen können keine Konformität mit einem PP beanspruchen. Für weitere Informationen siehe 11.2 und 11.3.

Die Konformitätserklärung darf auch eine Verweisung auf Evaluierungsmethoden/-aufgaben enthalten, die von ISO/IEC 18045 abgeleitet wurden. Wenn Evaluierungsmethoden/-aufgaben, die von ISO/IEC 18045 abgeleitet wurden, zur Evaluierung des PP verwendet werden sollen, dann müssen diese mit dem entsprechenden Abschnitt der Sicherheitsanforderung durch eine Erklärung in der folgenden Form gekennzeichnet werden:

„Dieses PP erfordert die Verwendung der in <Verweisung(en)> festgelegten Evaluierungsmethoden/Evaluierungsaufgaben.“

In dieser Erklärung wird <Verweisung> durch die Angabe des Orts der betreffenden Evaluierungsmethoden und Evaluierungsaufgaben ersetzt. Diese Verweisung darf sich auf das Dokument beziehen, das das PP enthält, oder auf ein oder mehrere separate Dokumente.

ANMERKUNG 4 Entweder ist ein(e) PP/ST mit einem PP konform oder nicht. Die Normenreihe ISO/IEC 15408 kennt keine „teilweise“ Konformität. Es liegt daher in der Verantwortung des PP-Autors, dass die PP nicht zu übermäßig beschwerlich ist und somit PP-/ST-Autoren die Möglichkeit verwehrt, Konformität mit dem PP zu beanspruchen. Für weitere Informationen zur Konformitätserklärung für die PP siehe Anhang B.

10.4 Vertrauenswürdigkeitsanforderungen (SARs)

Ein PP, das in Übereinstimmung mit ISO/IEC 15408-3 (möglicherweise erweitert) ist, muss den Satz an SAR festlegen, der für den gesamten TOE gilt.

Ein PP darf einen eindeutigen Namen für den Satz an SAR festlegen, die anwendbar sind. Handelt es sich bei dem Satz von SAR jedoch um eine (ergänzte) vordefinierte EAL (EAL1 bis EAL7) oder um ein (ergänzt) Vertrauenswürdigkeitspaket, das in einer anwendbaren externen Verweisung definiert ist, so ist derselbe Name zu verwenden.

ANMERKUNG Vordefinierte EAL werden in ISO/IEC 15408-5 angegeben.

10.5 Zusätzliche gemeinsame Anforderungen an die strikte und nachweisliche Konformität

10.5.1 Konformitätsansprüche und Konformitätserklärungen

Beansprucht ein(e) PP/ST entweder strikte oder nachweisliche Konformität mit mehreren PP, so muss es/sie mit jedem PP in der Art und Weise konform sein, wie es das jeweilige PP vorgibt, d. h. entweder strikt oder nachweislich, d. h. das/die PP/ST kann mit einigen PP strikt und mit anderen PP nachweislich konform sein.

Ein(e) PP/ST ist konform mit einem PP, wenn das/die PP/ST gleichwertig oder restriktiver als ein PP ist, d. h. wenn

- alle das/die PP/ST erfüllenden TOE auch das PP erfüllen,
- alle das PP erfüllenden Betriebsumgebungen auch das/die PP/ST erfüllen.

Anders ausgedrückt muss das/die PP/ST die gleichen oder mehr Anforderungen zu diesem TOE aufweisen und die gleichen oder weniger Bedingungen zur Betriebsumgebung des TOEs.

Diese allgemeine Erklärung gilt für die verschiedenen Konstrukte des/der PP/ST, d. h. für die SPD, die Sicherheitszielsetzungen für den TOE, die Sicherheitszielsetzungen für die Umgebung sowie die SFR und SAR.

10.5.2 Sicherheitsproblemdefinition (SPD)

Die Konformitätsbegründung in dem/der PP/ST muss demonstrieren, dass die SPD in dem/der PP/ST gleichwertig oder restriktiver als die SPD im PP sind, d. h.:

- alle die SPD in dem/der PP/ST erfüllenden TOEs erfüllen auch die SPD im PP;
- alle Betriebsumgebungen, die die SPD im PP erfüllen, erfüllen auch das/die PP/ST.

10.5.3 Sicherheitszielsetzungen

Die Konformitätsbegründung in dem/der PP/ST muss demonstrieren, dass die Sicherheitszielsetzungen in dem/der PP/ST gleichwertig (oder restriktiver) als die Sicherheitszielsetzungen im PP sind, d. h.:

- TOEs, die die Sicherheitszielsetzungen für den TOE in dem/der PP/ST erfüllen, erfüllen auch die Sicherheitszielsetzungen für diesen TOE im PP;
- Betriebsumgebungen, die die Sicherheitszielsetzungen für die Betriebsumgebung im PP erfüllen, erfüllen auch die Sicherheitszielsetzungen für die Betriebsumgebung in dem/der PP/ST.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****10.6 Zusätzliche Anforderungen speziell für die strikte Konformität****10.6.1 Anforderungen an die Sicherheitsproblemdefinition (SPD)**

Das PP/Die ST muss die SPD des PP/der ST enthalten und darf zusätzliche Bedrohungen und OSPen spezifizieren; sie muss alle im PP definierten Annahmen enthalten, wobei es zwei mögliche Ausnahmen gibt, die in den folgenden beiden Aufzählungspunkten erklärt werden:

- eine im PP spezifizierte Annahme (oder ein Teil einer Annahme) darf von dem PP/der ST weggelassen werden, wenn alle Sicherheitszielsetzungen für die in der PP definierte Betriebsumgebung, die diese Annahme (oder diesen Teil der Annahme) betreffen, durch Sicherheitszielsetzungen für diesen TOE in dem PP/der ST ersetzt werden;
- eine neue Annahme darf in dem PP/der ST zum im PP definierten Satz an Annahmen hinzugefügt werden, wenn diese neue Annahme eine Bedrohung (oder einen Teil einer Bedrohung), die von Sicherheitszielsetzungen für diesen TOE im PP angesprochen werden soll, nicht abschwächt, und wenn diese Annahme keine OSP (oder Teile einer OSP) erfüllt, die von Sicherheitszielsetzungen für diesen TOE im PP angesprochen werden soll.

10.6.2 Anforderungen an die Sicherheitszielsetzungen

Das PP/Die ST

- muss alle Sicherheitszielsetzungen für den TOE im PP enthalten, darf aber zusätzliche Sicherheitszielsetzungen für den TOE spezifizieren,
- muss alle im PP definierten Sicherheitszielsetzungen für die Betriebsumgebung enthalten, wobei es zwei mögliche Ausnahmen gibt, die in den folgenden beiden Aufzählungspunkten erklärt werden,
- darf spezifizieren, dass gewisse Sicherheitszielsetzungen für die Betriebsumgebung im PP Sicherheitszielsetzungen für den TOE in dem PP/der ST sind. Dies wird als Wiederzuweisung einer Sicherheitszielsetzung bezeichnet. Wenn eine Sicherheitszielsetzung wieder zu den Sicherheitszielsetzungen für den TOE zugewiesen wird, muss die Begründung für die Sicherheitszielsetzung deutlich machen, welche Annahme/OSP oder welche Teile der Annahme/OSP nicht mehr erforderlich sind,
- darf für die Betriebsumgebung zusätzliche Sicherheitszielsetzungen spezifizieren, wenn diese neuen Zielsetzungen eine Bedrohung (oder einen Teil einer Bedrohung), die von Sicherheitszielsetzungen für diesen TOE im PP angesprochen werden soll, nicht abschwächen, und wenn diese neuen Zielsetzungen keine OSP (oder Teile einer OSP) erfüllen, die von Sicherheitszielsetzungen für diesen TOE im PP angesprochen werden soll.

10.6.3 Anforderungen an die Sicherheitsanforderungen

Das PP/Die ST

- müssen alle SFR und SAR im PP enthalten,
- dürfen zusätzliche oder hierarchisch stärkere SFR und SAR beanspruchen. Die Vervollständigung der Operationen in der ST muss in sich konsistent mit den Operationen im PP sein; es wird entweder die gleiche Vervollständigung in dem/der PP/ST wie im PP verwendet oder eine Vervollständigung, die für eine restriktivere Anforderung sorgt.

ANMERKUNG Es gelten die Regeln zur Präzisierung.

10.7 Zusätzliche Anforderungen speziell für die nachweisliche Konformität

Nachweisliche Konformität erlaubt dem PP-Autor die Beschreibung eines zu lösenden gemeinsamen Sicherheitsproblems und bietet einen generischen Leitfaden für die zur Auflösung erforderlichen Anforderungen, wissend, dass es vermutlich mehr als eine Möglichkeit zur Spezifizierung einer Auflösung gibt.

Das/Die PP/ST müssen eine Begründung darüber enthalten, warum das/die PP/ST als „gleichwertig oder restriktiver“ als das PP angesehen wird.

10.8 Zusätzliche Anforderungen speziell für die genaue Konformität

10.8.1 Allgemein

Genaue Konformität wird verwendet, wenn ein PP-Autor kontrollieren muss, was eine ST in Bezug auf das von ihm geschriebene PP als konform beanspruchen kann. Sie wird in Fällen verwendet, in denen der PP-Autor verlangt, dass die ST, die Konformität mit dem PP beanspruchen, keine zusätzlichen SPD, Sicherheitszielsetzungen oder Anforderungen enthalten, die vom PP-Autor nicht berücksichtigt wurden.

Ein PP, das in seiner Konformitätserklärung genaue Konformität verlangt, darf optionale SFR und beliebige SPD-Elemente definieren, die zur Unterstützung dieser SFR erforderlich sind. Eine ST (oder ein PP-Modul) darf dann diese optionalen SFR (und alle erforderlichen SPD-Elemente) in seinen Anforderungssatz aufnehmen und behält dabei seinen genauen Konformitätsanspruch aufrecht.

Ein PP mit genauem Konformitätstyp darf keine Konformität zu anderen PP eines beliebigen Konformitätstyps beanspruchen. Ein PP mit genauem Konformitätstyp darf nicht in eine PP-Konfiguration aufgenommen werden, die auch PP oder PP-Module mit striktem oder nachweislichem Konformitätstyp enthält.

ANMERKUNG Es ist nicht möglich, sowohl die Konformität mit einem strikten/nachweislichen Konformitäts-PP als auch mit einem genauen Konformitäts-PP zu beanspruchen, da dies bedeuten würde, dass dem genauen Konformitäts-PP Anforderungen oder SPD-Elemente hinzugefügt werden müssten, was diese Operation ausdrücklich untersagt.

Im „einfachen“ Fall, in dem eine ST eine genaue Konformität mit einem PP beansprucht, besteht keine Unklarheit darüber, ob die ST genau konform ist oder nicht, da die Übereinstimmung zwischen der SPD, den Sicherheitszielsetzungen, den SFR und den SAR während der Evaluierung nachgewiesen wird, ohne dass ein Beitrag des PP-Autors erforderlich ist.

Es sind jedoch auch andere Fälle zulässig, in denen mehrere Sätze von SPD-Elementen, Sicherheitszielsetzungen und SFR kombiniert werden dürfen; in diesen Fällen sind Mechanismen erforderlich, die die Fähigkeit der Autoren von PP mit genauer Konformität bewahren, einen Konformitätsanspruch gegen ihre PP zu kontrollieren. Diese Mechanismen werden in den folgenden Unterabschnitten beschrieben.

BEISPIEL Ein komplexer Fall kann vorliegen, wenn ein PP-Modul darauf abzielt, ein PP als Basis-PP zu verwenden, oder wenn eine ST Konformität mit zwei PP beansprucht.

Wenn ein PP genaue Konformität verlangt, dann sind nur die von diesem PP festgelegten SFR und SAR in der konformen ST zulässig. Diese Sicherheitsanforderungen beziehen sich auf die SPD und die in den PP festgelegten Sicherheitszielsetzungen, die auch in der konformen ST enthalten sind. Die SFR in einer genauen Konformitäts-PP können iteriert und präzisiert werden (wie in ISO/IEC 18045 für ASE_CCL.1-12 angegeben).

10.8.2 Konformitätsansprüche und -erklärungen

Wenn ein PP in seiner Konformitätserklärung genaue Konformität verlangt, dann

- a) muss das PP eine Zulässigkeitserklärung enthalten, die angibt, welche anderen PP und PP-Module zusammen mit dem PP in einem Konformitätsanspruch enthalten sein dürfen,
- b) müssen alle zusätzlichen PP, zu denen eine ST genaue Konformität beanspruchen darf, ebenfalls eine genaue Konformitätsanforderung haben,

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

- c) müssen alle zusätzlichen PP, für die eine ST Konformität beansprucht, das PP in ihren jeweiligen Zulässigkeitserklärungen identifizieren,
- d) müssen alle zusätzlichen PP-Module, die durch eine PP-Konfiguration beansprucht werden, das PP in ihren jeweiligen Zulässigkeitserklärungen identifizieren.

Ein PP-Modul muss seine eigenen Basis-PP/PP-Module in seiner Konformitätserklärung nicht angeben, jedoch muss die PP-Modulbasis in seiner Einleitung für PP-Module angegeben werden.

10.9 Unter Verwendung von PP

Wenn ein(e) PP/ST beansprucht, mit einem oder mehreren PP und möglicherweise mit einem oder mehreren Paketen konform zu sein, wird die Evaluierung dieses/dieser PP/ST den Nachweis beinhalten, dass das/die PP/ST tatsächlich mit den beanspruchten PP und/oder Paketen konform ist. Einzelheiten zur Bestimmung der Konformität können Anhang A und Anhang B entnommen werden.

Dies erlaubt folgenden Prozess:

- a) eine Organisation möchte einen bestimmten Typ von IT-Sicherheitsprodukt beschaffen und entwickelt ihre Sicherheitsbedürfnisse in einem PP, lässt dieses PP anschließend evaluieren und veröffentlicht es;
- b) ein Entwickler nimmt dieses PP, schreibt eine ST, die Konformität mit diesem PP beansprucht und lässt diese ST evaluieren;
- c) der Entwickler erstellt anschließend einen TOE (oder verwendet einen bestehenden) und lässt diesen gegen die ST evaluieren.

Das Ergebnis ist, dass der evaluierte TOE die Anforderungen der Organisation, wie sie im PP festgelegt sind, erfüllt und dass die Organisation daher darauf vertrauen kann, dass der TOE ihre Sicherheitsanforderungen erfüllt. Bei Paketen gilt ein vergleichbarer Argumentationsstrang.

10.10 Konformitätserklärungen und -ansprüche im Falle mehrerer PP**10.10.1 Allgemein**

Die Normenreihe ISO/IEC 15408 erlaubt es sowohl den ST als auch den PP, Konformität mit mehreren PP zu beanspruchen. Der Fall, dass eine ST Konformität mit mehreren PP beansprucht, wird in 11.3.3 behandelt. 10.10 behandelt den Fall, dass ein PP Konformität mit mehreren PP beansprucht.

10.10.2 Wenn strikte oder nachweisliche Konformität festgelegt ist

Wenn ein PP Konformität mit mehreren PP beanspruchen darf, können Ketten von PP gebildet werden, wobei jedes PP in der Kette auf dem/den vorherigen PP aufbaut.

BEISPIEL Die PP für eine integrierte Schaltung und für ein Betriebssystem einer Chipkarte können verwendet werden und daraus ein PP für eine Chipkarte konstruiert werden (IC und OS), das dann Konformität mit beiden beansprucht. Dieses PP für Chipkarten kann wiederum zur Entwicklung spezifischer PP für verschiedene Anwendungsfälle verwendet werden, z. B. für Fahrtenschreiberkarten, Zahlungskarten, elektronische Reisepässe usw. Ein Entwickler kann dann eine ST konstruieren, die mit jedem dieser PP konform ist.

10.10.3 Wenn genaue Konformität festgelegt ist

Ein PP darf keine genaue Konformität mit einem anderen PP oder einer Kombination von PP beanspruchen.

ANMERKUNG In Fällen, in denen eine solche Kombination von Funktionen erforderlich ist, kann dies durch die Erstellung einer PP-Konfiguration erreicht werden, die aus den PP besteht, deren Konformität beansprucht werden soll.

11 Modularer Aufbau der Anforderungen

11.1 Allgemein

Um eine modulare Beschreibung der Sicherheitsmerkmale des TOE zu ermöglichen, können ST Konformität mit einer PP-Konfiguration statt mit PP beanspruchen. Solche PP-Konfigurationen bestehen aus einem Satz von PP und PP-Modulen, der die PP-Modulbasis bzw. -basen enthält.

PP-Konfigurationen können so konstruiert werden, dass sie sowohl für Evaluierungen mit Einfach-Vertrauenswürdigkeit als auch mit Mehrfach-Vertrauenswürdigkeit geeignet sind. Bei einer Evaluierung mit Einfach-Vertrauenswürdigkeit gilt ein einziger Satz von Vertrauenswürdigkeitsanforderungen für alle Komponenten der PP-Konfiguration. Bei einer Evaluierung mit Mehrfach-Vertrauenswürdigkeit gibt es einen einzigen Gesamtsatz von Vertrauenswürdigkeitsanforderungen, der für alle Komponenten der PP-Konfiguration gilt, aber zusätzlich hat jede Komponente (PP oder PP-Modul) ihren eigenen Satz von Vertrauenswürdigkeitsanforderungen, denen sie unterliegt. In den folgenden Unterabschnitten werden die inhaltlichen Details für diese beiden Evaluierungsansätze vorgestellt; die eigentlichen Evaluierungsdetails unter Verwendung dieser Ansätze werden in Abschnitt 13 behandelt.

11.2 PP-Module

11.2.1 Allgemein

Ein PP-Modul ist eine in sich konsistente Menge von SPD-Elementen, Sicherheitszielsetzungen für den TOE und die Betriebsumgebung sowie die SFR, die im Kontext eines oder mehrerer PP und möglicherweise anderer PP-Module definiert sind.

Anders als die PP behandeln die PP-Module diejenigen Sicherheitsmerkmale eines bestimmten TOE-Typs, die nicht einheitlich für alle Produkte dieses TOE-Typs gefordert werden können.

Im Gegensatz zu den PP dürfen die PP-Module nur in PP-Konfigurationen verwendet werden. Ein(e) PP/ST kann nicht direkt Konformität mit einem PP-Modul beanspruchen.

BEISPIEL Beispiele für Merkmale, die nicht einheitlich für alle Produkte innerhalb eines TOE-Typs gefordert werden können, sind die Authentifizierung mittels biometrischer Daten, Bluetooth-Sicherheitsfunktionen und drahtlose LAN-Clients.

11.2.2 PP-Modulbasis

Ein bestimmtes PP-Modul legt eine PP-Modulbasis oder mehrere Modulbasen fest, die aus einer Menge von PP und möglicherweise anderen PP-Modulen besteht bzw. bestehen. Jedes Mal, wenn das angegebene PP-Modul in einer PP-Konfiguration verwendet wird, ist eine seiner PP-Modulbasen bzw. sind mehrere seiner Modulbasen erforderlich. Siehe Abschnitt 10 und Anhang B.

11.2.3 Anforderungen an PP-Module

11.2.3.1 Allgemein

Ein PP-Modul muss mit einem Referenzidentifikator identifiziert werden.

Der Referenzidentifikator für ein PP-Modul muss innerhalb eines Katalogs eindeutig sein.

Ein PP-Modul muss eine PP-Modulbasis oder mehrere Modulbasen definieren, die mit dem PP-Modul in einer PP-Konfiguration verwendet werden kann bzw. können.

Ein PP-Modul muss die TOE-Typen relativ zu jeder seiner PP-Modulbasen angeben.

Ein PP-Modul darf neue SPD-Elemente und Zielsetzungen einführen und auch einige der SPD-Elemente oder Zielsetzungen seiner PP-Modulbasen präzisieren.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Ein PP-Modul muss eine nicht leere Menge an SFR definieren, die eine Präzisierung der SFR der PP-Modulbasen oder neu sind.

Eine ST, die Konformität mit einer PP-Konfiguration beansprucht, die ein bestimmtes PP-Modul enthält, muss dann die SPD-Elemente, Sicherheitszielsetzungen und SFR des PP-Moduls zusammen mit denjenigen der PP-Modulbasis enthalten, die zur PP-Konfiguration gehören.

ANMERKUNG 1 Der im PP-Modul definierte TOE-Typ kann den in jeder seiner PP-Modulbasen definierten TOE-Typ ergänzen.

Ein PP-Modul muss eine Begründung für die Konsistenz liefern, die sicherstellt, dass die Vereinigung der im PP-Modul und in jeder seiner PP-Modulbasen definierten Elemente nicht zu Widersprüchen führt.

ANMERKUNG 2 In einem PP-Modul mit direkter Begründung sind Sicherheitszielsetzungen für den TOE nicht enthalten.

Die Evaluierung eines PP-Moduls allein ist bedeutungslos. Ein PP-Modul muss als Teil einer PP-Konfiguration evaluiert werden, mindestens jedoch mit einer PP-Modulbasis

Weitere Angaben zu den PP-Modulen sind C.1 zu entnehmen.

11.2.3.2 Direkte Begründung

Ein PP-Modul darf den Ansatz der direkten Begründung verwenden, wenn seine PP-Modulbasis/-basen ebenfalls den Ansatz der direkten Begründung verwenden.

11.2.3.3 Konformitätsansprüche und Konformitätserklärungen

In diesem Unterabschnitt kennzeichnet die Verwendung von kursivem Text den wörtlichen Text, der im Text des PP-Moduls erscheinen muss.

Die Konformitätsansprüche eines PP-Moduls:

- a) müssen die Ausgabe der relevanten Teile der Normenreihe ISO/IEC 15408 angeben, mit denen das PP-Modul Konformität beansprucht;
- b) müssen die Konformität mit ISO/IEC 15408-2 beschreiben, entweder als
 - „ISO/IEC 15408-2-konform“;

ANMERKUNG 1 Ein PP-Modul ist ISO/IEC 15408-2-konform, wenn alle SFR in diesem PP-Modul nicht auf Funktionskomponenten von ISO/IEC 15408-2 basieren.

oder

— „ISO/IEC 15408-2-erweitert“

ANMERKUNG 2 Ein PP-Modul ist ISO/IEC 15408-2-erweitert, wenn mindestens eine SFR in diesem PP-Modul nicht auf Funktionskomponenten von ISO/IEC 15408-2 basiert.

- c) kann einen Konformitätsanspruch in Bezug auf Funktionspakete enthalten. In einem PP-Modul darf mehr als ein Funktionspaket beansprucht werden.

ANMERKUNG 3 Ein PP-Modul erhebt keinen Anspruch auf Konformität mit einem Funktionspaket, das bereits von einem der PP oder PP-Module in den PP-Modulbasen beansprucht wird. Eine Ausnahme von dieser Regel besteht, wenn das PP-Modul das Funktionspaket, wie es in seiner PP-Modulbasis instanziiert ist, ergänzt oder anpasst; in diesem Fall würde das PP-Modul das Funktionspaket in seiner Erklärung zum Paket-Konformitätsanspruch als „Paket-ergänzt“ oder „Paket-angepasst“ (je nach Fall) beanspruchen.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Sofern ein Anspruch auf das Funktionspaket erhoben wird, muss dieser einen der folgenden Ansprüche für jedes Paket umfassen:

— „*Paket-konform*“;

Ein PP-Modul ist konform mit einem Paket, wenn alle Bestandteile des Funktionspakets, einschließlich der SPD, Sicherheitszielsetzungen und SFR dieses Funktionspakets ohne Änderung in den entsprechenden Teilen des PP-Moduls enthalten sind;

— „*Paket-ergänzt*“;

Ein PP-Modul beansprucht eine Ergänzung eines Pakets, wenn alle Bestandteile des Funktionspakets, einschließlich der SPD, der Sicherheitszielsetzungen und der SFR, die im PP-Modul enthalten sind, mit denen des Funktionspakets identisch sind, muss aber auch mindestens eine SFR enthalten, die entweder zusätzlich oder hierarchisch höher als eine SFR im Funktionspaket ist;

— „*Paket-angepasst*“;

Ein PP-Modul beansprucht die Anpassung eines Pakets, wenn alle Bestandteile des Funktionspakets, einschließlich der SPD, der Sicherheitszielsetzungen und der SFR, die in dem PP-Modul enthalten sind, mit denen des Funktionspakets identisch sind, muss aber zusätzliche Auswahlmöglichkeiten für eine SFR mit bestehenden Auswahlmöglichkeiten im Paket haben, und optional mindestens eine zusätzliche SFR oder eine hierarchisch höhere SFR enthalten als eine SFR im Funktionspaket;

- d) muss einen Konformitätsanspruch unter Bezugnahme auf ISO/IEC 15408-3 enthalten. Der Anspruch auf Konformität mit ISO/IEC 15408-3 muss entweder sein:

— „*ISO/IEC 15408-3-konform*“;

Ein PP-Modul ist ISO/IEC 15408-3-konform, wenn alle SAR in diesem PP-Modul ausschließlich auf Vertrauenswürdigkeitskomponenten von ISO/IEC 15408-3 basieren;

oder

— „*ISO/IEC 15408-3-erweitert*“;

Ein PP-Modul ist ISO/IEC 15408-3-erweitert, wenn mindestens eine SAR in diesem PP-Modul nicht auf Vertrauenswürdigkeitskomponenten von ISO/IEC 15408-3 basiert;

- darf einen Konformitätsanspruch in Bezug auf Vertrauenswürdigkeitspakete enthalten. In einem PP-Modul darf mehr als ein Vertrauenswürdigkeitspaket beansprucht werden. Überschneidungen zwischen den beanspruchten Vertrauenswürdigkeitspaketen sind zulässig; konstruktionsbedingt hat die hierarchisch höhere SAR Vorrang vor der anderen und wird in der PP-Konfiguration angewendet.

In den strikten und nachweislichen Fällen darf ein PP-Modul die Konformität mit mehr als einem Vertrauenswürdigkeitspaket beanspruchen, z. B. einem ALC-basierten Paket und einem ADV-basierten Paket.

Sofern ein Paketanspruch erhoben wird, muss dieser aus einem der folgenden Ansprüche für jedes Paket bestehen:

— „*Paket-konform*“;

Ein PP-Modul ist konform mit einem Vertrauenswürdigkeitspaket, wenn alle Bestandteile des Vertrauenswürdigkeitspakets im PP-Modul enthalten sind;

— „*Paket-ergänzt*“;

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Ein PP-Modul beansprucht eine Ergänzung eines Vertrauenswürdigkeitspakets, wenn alle im PP-Modul enthaltenen Bestandteile des Vertrauenswürdigkeitspakets mit denen des Vertrauenswürdigkeitspakets identisch sind, aber zusätzlich mindestens eine SAR enthalten, die entweder zusätzlich oder hierarchisch höher als die im Paket enthaltenen SAR ist;

Die Konformitätserklärung eines PP-Moduls:

- e) muss eine Konformitätserklärung bereitstellen, die die Art und Weise beschreibt, in der die ST mit diesem PP-Modul als Teil einer PP-Konfiguration konform sein müssen. Die Konformitätserklärung muss von einem der folgenden Typen sein:

— „*Genaue Konformität*“;

Das PP-Modul muss dann und nur dann genaue Konformität erfordern, wenn alle seine PP-Modulbasen genau konform sind. Eine ST muss dem PP-Modul als Teil einer PP-Konfiguration genau entsprechen. Zusätzlich:

- Die Zulässigkeitserklärung muss angeben, welche anderen PP und PP-Module (die nicht in der Menge der PP-Modulbasen enthalten sind) in einer PP-Konfiguration mit diesem PP-Modul verwendet werden dürfen;
- jedes PP und PP-Modul in der PP-Modulbasis für das zu definierende PP-Modul und alle zusätzlichen PP und PP-Module (die nicht in der PP-Modulbasis enthalten sind), die mit dem PP-Modul in einer PP-Konfiguration angegeben werden dürfen, müssen das zu definierende PP-Modul in ihren jeweiligen Zulässigkeitserklärungen identifizieren.
- alle referenzierten PP-Modulbasen müssen ebenfalls eine genaue Konformität aufweisen.

— „*Strikte Konformität*“;

Wenn das PP-Modul aussagt, dass strikte Konformität erforderlich ist, muss die ST strikt mit dem PP-Modul als Teil einer PP-Konfiguration übereinstimmen;

— „*Nachweisliche Konformität*“;

Wenn das PP-Modul aussagt, dass nachweisliche Konformität erforderlich ist, muss die ST strikt oder demonstrierbar mit dem PP-Modul als Teil einer PP-Konfiguration übereinstimmen. Eine ST darf als Teil einer PP-Konfiguration nur dann nachweislich mit einem PP-Modul konform sein, wenn das PP-Modul dies ausdrücklich zulässt;

ANMERKUNG 1 Ein PP-Modul kann strikte oder nachweisliche Konformität erfordern, obwohl seine PP-Modulbasis/-basen nicht alle strikte oder nachweisliche Konformität erfordern. Die Kombination aus nachweislicher und strikter Konformität wird in der Evaluierung der PP-Konfiguration validiert.

ANMERKUNG 2 Die explizite Erklärung der strikten oder nachweislichen Konformität ermöglicht es Antragstellern, die am besten geeignete Erklärung in jedem PP-Modul abzugeben, und zwar unabhängig von dessen PP-Modulbasis/-basen.

ANMERKUNG 3 (Eine) PP-Modulbasis/-basen muss/müssen nicht in der Konformitätserklärung der PP-Module festgelegt werden.

- f) dürfen auch eine Verweisung auf Evaluierungsmethoden/-aufgaben enthalten, die von ISO/IEC 18045 abgeleitet wurden.

Wenn Evaluierungsmethoden/-aufgaben, die von ISO/IEC 18045 abgeleitet wurden, zur Evaluierung des PP-Moduls verwendet werden sollen, dann müssen diese mit dem entsprechenden Abschnitt der Sicherheitsanforderung durch eine Erklärung in der folgenden Form gekennzeichnet werden:

„Dieses PP-Modul erfordert die Verwendung der in <Verweisung(en)> festgelegten Evaluierungsmethoden/Evaluierungsaufgaben.“

In dieser Erklärung wird <Verweisung> durch die Angabe des Orts der betreffenden Evaluierungsmethoden und Evaluierungsaufgaben ersetzt. Diese Verweisung darf sich auf das Dokument beziehen, das das PP-Modul enthält, oder auf ein oder mehrere separate Dokumente.

Für weitere Informationen und Anforderungen an die Konformitätstypen, -ansprüche und -erklärungen für PP-Module muss Anhang C in Verbindung mit den Abschnitten des vorliegenden Dokuments verwendet werden.

11.2.3.4 Vertrauenswürdigkeitsanforderungen

Ein PP-Modul muss den Satz an SAR definieren, der für die im PP-Modul definierte TSF gilt und der entweder von der PP-Modulbasis bzw. den PP-Modulbasen übernommen oder vom Autor des PP-Moduls explizit deklariert werden kann.

Ein PP-Modul darf einen eindeutigen Namen für seinen Satz an SAR festlegen. Wenn das PP-Modul jedoch eine (ergänzte) vordefinierte EAL (EAL1 bis EAL7) oder ein (ergänztes) Vertrauenswürdigkeitspaket deklariert, das in einer anwendbaren externen Verweisung definiert ist oder den Satz an SAR von seiner PP-Modulbasis bzw. seinen PP-Modulbasen übernimmt, so muss derselbe Name verwendet werden.

Ein PP-Modul muss eine Begründung für die interne Konsistenz seiner Sätze an SAR bereitstellen, d. h.:

- die Konsistenz des Satzes an SAR in Bezug auf das Bedrohungsmodell, wie es in der SPD des PP-Moduls definiert ist;
- wenn das PP-Modul seine Menge an SAR nicht von seiner PP-Modulbasis bzw. seinen PP-Modulbasen übernimmt, die Konsistenz des Satzes an SAR mit allen in der PP-Modulbasis bzw. den PP-Modulbasen des PP-Moduls definierten Mengen an SAR.

ANMERKUNG 1 Konsistenz bedeutet die Abwesenheit von Widersprüchen. Ein Beispiel für eine Inkonsistenz zwischen den SAR und der SPD wäre die Berücksichtigung hochqualifizierter Bedrohungsagenten zusammen mit einem niedrigen AVA_VAN-Niveau, das diese Bedrohungsagenten laut Definition nicht berücksichtigen kann.

ANMERKUNG 2 Die Begründung für die Vertrauenswürdigkeit des PP-Moduls stellt sicher, dass der im PP-Modul definierte Satz an SAR die Sicherheit, die für die vom PP-Modul und seiner PP-Modulbasis bzw. seinen PP-Modulbasen gemeinsam genutzten Vermögenswerte erwartet wird, nicht untergräbt (falls gemeinsame Vermögenswerte vorhanden sind).

ANMERKUNG 3 Die Begründung für die Vertrauenswürdigkeit auf PP-Modulebene trägt dazu bei, ist aber nicht ausreichend, die Konsistenz der Vertrauenswürdigkeitsanforderungen auf PP-Konfigurationsebene sicherzustellen. Siehe 11.3.2.4.

ANMERKUNG 4 Die Begründung für die Vertrauenswürdigkeit kann sich auf die Beziehung zwischen dem Satz an SAR im PP-Modul und den vordefinierten EAL stützen, um die interne Konsistenz nachzuweisen.

11.3 PP-Konfigurationen

11.3.1 Allgemein

Eine PP-Konfiguration ist eine Spezifikation für den Aufbau eines Satzes von Anforderungen, für die Konformität beansprucht werden kann.

Eine PP-Konfiguration dient zur Beschreibung eines allgemeinen TOE-Typs. Eine PP-Konfiguration:

- darf als ST-Vorlage für alle TOE verwendet werden, die dem TOE-Typ der PP-Konfiguration entsprechen;

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

- kann nicht als Vorlage für andere PP-Konfigurationen, PP oder PP-Module verwendet werden.

Eine PP-Konfiguration enthält eine Menge von PP und PP-Modulen (die PP-Konfigurationskomponenten) und kann keine Konformität mit Funktionspaketen beanspruchen, außer indirekt über ihre PP/PP-Module. PP-Konfigurationen dürfen SAR enthalten und Konformität mit Vertrauenswürdigkeitspaketen beanspruchen.

Es werden zwei Arten von PP-Konfigurationen unterschieden, die jeweils unterschiedliche Anforderungen an ihre Konstruktion stellen und je nach den Bedürfnissen des Verbrauchers (Risikoeigentümers) anwendbar sind. Diese sind:

- PP-Konfiguration mit Einfach-Vertrauenswürdigkeit: Dies beschreibt einen Konfigurationstyp, bei dem die Menge an SAR, die für die Komponenten der PP-Konfiguration gelten, identisch ist.
- PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit: Dies beschreibt einen Konfigurationstyp, bei dem die SAR in den Komponenten der PP-Konfiguration nicht identisch sind.

11.3.2 Anforderungen an PP-Konfigurationen**11.3.2.1 Allgemein**

Eine PP-Konfiguration muss mit einer Verweisung gekennzeichnet werden.

Der Referenzidentifikator für eine PP-Konfiguration muss innerhalb eines Katalogs eindeutig sein.

Eine PP-Konfiguration muss die Aussage zu den Komponenten der PP-Konfiguration definieren, eine Liste, die alle PP und PP-Module, aus denen die PP-Konfiguration besteht, durch Verweisung eindeutig identifiziert. Eine PP-Konfiguration muss ein PP und mindestens eine weitere PP-Konfigurationskomponente enthalten. Sie darf ein PP-Modul enthalten, sofern eine der PP-Modulbasen ebenfalls in der PP-Konfiguration enthalten ist. Sie darf PP enthalten, die keine zugehörigen PP-Module haben.

Eine PP-Konfiguration muss den TOE-Typ definieren, für den sie gilt

Eine PP-Konfiguration enthält durch Verweisung genau die SPD, Sicherheitszielsetzungen, SFR und Funktionspakete, die in ihren Komponenten definiert sind; die Spezifikation jedes zusätzlichen Elements muss in einer ihrer Komponenten vorgenommen werden.

Eine PP-Konfiguration muss eine Begründung für die Konsistenz enthalten, die sicherstellt, dass die Vereinigung der in ihren Komponenten definierten Elemente nicht zu Widersprüchen führt.

Eine PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit muss die Organisation der TSF anhand der in ihren Komponenten definierten Teil-TSF beschreiben und für jede Teil-TSF einen Satz an SAR festlegen, der mit der entsprechenden Komponente konsistent ist.

ANMERKUNG Im Falle einer PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit, die ein PP und ein PP-Modul mit unterschiedlichen Sätzen an SAR enthält, sieht die TSF-Organisation wie folgt aus: Die TSF ist die Vereinigung der im PP und im PP-Modul definierten SFR, und es gibt zwei Teil-TSF, die aus der TSF des PP und der TSF des PP-Moduls bestehen. Die gleiche Organisation gilt für eine PP-Konfiguration, die aus zwei PP besteht, die die beiden Teil-TSF definieren.

Die in einer PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit enthaltenen Teil-TSF dürfen sich teilweise überschneiden. Dies hat keine Auswirkungen auf die geltenden Vertrauenswürdigkeitsanforderungen: Jede Teil-TSF muss anhand ihres eigenen Satzes an SAR evaluiert werden. Dies bedeutet, dass die sich überschneidenden Teile anhand mehrerer Sätze von Vertrauenswürdigkeitsanforderungen evaluiert werden dürfen.

Eine PP-Konfiguration:

- darf im Zusammenhang mit dem in B.5 und C.2.3 beschriebenen Ansatz der direkten Begründung verwendet werden. In diesem Fall müssen alle Komponenten der PP-Konfiguration ebenfalls den Ansatz der direkten Begründung verwenden;

- darf keine zusätzlichen Inhalte umfassen, die über die in diesem Dokument beschriebenen hinausgehen.

11.3.2.2 Komponentenerklärung

Eine PP-Konfiguration:

- muss alle Komponenten der PP-Konfiguration in einer Komponentenerklärung identifizieren. Die Komponentenerklärung muss ein PP und mindestens eine weitere Komponente enthalten;

ANMERKUNG 1 Die Komponentenerklärung wird in C.3.3 näher beschrieben.

- darf keinen Anspruch auf Konformität mit einer anderen PP-Konfiguration erheben;

ANMERKUNG 2 Wenn dies gewünscht ist, kann die Wirkung dadurch erzielt werden, dass alle Komponenten aus beiden PP-Konfigurationen direkt in eine neu definierte PP-Konfiguration aufgenommen werden, in der die genaue Konformität geprüft und eingehalten werden kann.

- muss die PP-Modulbasen aller in der PP-Konfiguration enthaltenen PP-Module enthalten. Wenn ein PP-Modul alternative Mengen von PP-Modulbasen festlegt, dann darf nur eine dieser Mengen in einer PP-Konfiguration verwendet werden;
- darf mehr PP auswählen als die PP-Modulbasis der PP-Module;
- darf bei PP-Konfigurationen mit Einfach-Vertrauenswürdigkeit die Teil-TSF identifizieren, die jeder durch die PP-Konfiguration definierten Komponente entspricht;
- muss bei PP-Konfigurationen mit Mehrfach-Vertrauenswürdigkeit die Teil-TSF identifizieren, die jeder durch die PP-Konfiguration definierten Komponente entspricht.

Bei einer PP-Konfiguration, die genaue Konformität erfordert, müssen sich alle PP-Konfigurationskomponenten in ihren jeweiligen Zulässigkeitserklärungen gegenseitig festlegen.

Eine Ausnahme von der Auflistung in der Zulässigkeitserklärung besteht darin, dass ein PP-Modul in seiner Zulässigkeitserklärung keine PP oder PP-Module auflisten darf, die in seiner PP-Modulbasis enthalten sind (da sie aufgrund der Tatsache, dass sie eine Basis für das PP-Modul sind, ausdrücklich zugelassen sind).

11.3.2.3 Konformitätsansprüche und Konformitätserklärung

In diesem Unterabschnitt kennzeichnet die Verwendung von kursivem Text den wörtlichen Text, der im Text der PP-Konfiguration erscheinen muss.

Die Konformitätsansprüche einer PP-Konfiguration:

- müssen die Ausgabe der relevanten Teile der Normenreihe ISO/IEC 15408 angeben, mit denen die PP-Konfigurationskomponenten Konformität beanspruchen.
- müssen die Konformität mit ISO/IEC 15408-2 (SFR) beschreiben, entweder als

- „ISO/IEC 15408-2-konform“;

Eine PP-Konfiguration ist ISO/IEC 15408-2-konform, wenn alle PP und PP-Module in der PP-Konfiguration ISO/IEC 15408-2-konform sind.

oder

- „ISO/IEC 15408-2-erweitert“.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Eine PP-Konfiguration ist ISO/IEC 15408-2-erweitert, wenn mindestens ein PP oder PP-Modul nicht auf Funktionskomponenten von ISO/IEC 15408-2 basiert.

- c) müssen die Konformität mit ISO/IEC 15408-3 (Vertrauenswürdigkeitsanforderungen) beschreiben, entweder als

— „ISO/IEC 15408-3-konform“;

Eine PP-Konfiguration ist ISO/IEC 15408-3-konform, wenn alle SAR in dieser PP-Konfiguration, die einfach von ihren Komponenten übernommen werden dürfen, ausschließlich auf Vertrauenswürdigkeitskomponenten von ISO/IEC 15408-3 basieren; oder

— „ISO/IEC 15408-3-erweitert“

Eine PP-Konfiguration ist ISO/IEC 15408-3-erweitert, wenn mindestens eine SAR in dieser PP-Konfiguration, die einfach von ihren Komponenten übernommen werden darf, nicht auf Vertrauenswürdigkeitskomponenten von ISO/IEC 15408-3 basiert;

- d) dürfen einen Anspruch auf Konformität mit dem Vertrauenswürdigkeitspaket enthalten;

In einer PP-Konfiguration kann mehr als ein Paket beansprucht werden. Sofern ein Anspruch auf ein Vertrauenswürdigkeitspaket erhoben wird, muss er eine der folgenden Erklärungen für jeden Anspruch auf das Paket umfassen:

— „Paket-konform“;

Eine PP-Konfiguration ist konform mit einem Vertrauenswürdigkeitspaket, wenn die SAR dieser PP-Konfiguration, die von ihren Komponenten übernommen werden dürfen, mit den SAR des Vertrauenswürdigkeitspakets identisch sind.

— „Paket-ergänzt“

Eine PP-Konfiguration beansprucht eine Ergänzung eines Vertrauenswürdigkeitspakets, wenn: die SAR dieser PP-Konfiguration, die von ihren Komponenten übernommen werden dürfen, alle SAR des Vertrauenswürdigkeitspakets enthalten, aber mindestens eine zusätzliche SAR oder eine SAR haben, die hierarchisch höher ist als eine SAR des Vertrauenswürdigkeitspakets.

- e) dürfen keinen Anspruch auf funktionale Paketkonformität enthalten. Funktionspakete dürfen durch die Komponenten der PP-Konfiguration beansprucht werden;
- f) dürfen keinen Konformitätsanspruch in Bezug auf andere PP-Konfigurationen, PP oder PP-Module enthalten;

Die PP-Konfiguration muss eine Konformitätserklärung bereitstellen, die die Art und Weise beschreibt, in der die ST mit dieser PP-Konfiguration konform sein müssen:

- g) für eine PP-Konfiguration, bei der alle PP und PP-Module vom gleichen Konformitätstyp sind, muss die Konformitätserklärung einen einzigen Konformitätstyp angeben, der einer der folgenden ist:

— „Genaue Konformität“;

Wenn die PP-Konfiguration aussagt, dass genaue Konformität erforderlich ist, muss eine ST genau mit der PP-Konfiguration übereinstimmen.

— „Strikte Konformität“;

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Wenn die PP-Konfiguration aussagt, dass strikte Konformität erforderlich ist, muss eine ST strikt mit der PP-Konfiguration übereinstimmen.

— „Nachweisliche Konformität“.

Wenn die PP-Konfiguration aussagt, dass nachweisliche Konformität erforderlich ist, muss eine ST strikt oder demonstrierbar mit der PP-Konfiguration übereinstimmen.

- h) für eine PP-Konfiguration, bei der die PP und PP-Module nicht alle denselben Konformitätstyp erfordern, muss die Konformitätserklärung eine Liste der Konformitätstypen enthalten, die von jedem der PP und PP-Module, aus denen die PP-Konfiguration besteht, gefordert werden. Eine ST muss mit der PP-Konfiguration konform sein, indem sie mit jedem der PP und PP-Module in der von ihnen geforderten Weise konform ist.

ANMERKUNG Dies gilt nur für strikte und nachweisliche Konformität, da die Kombination von genauer Konformität mit anderen Typen von Konformität in einer PP-Konfiguration nicht zulässig ist.

Die Kompatibilität der Mehrfachkonformität muss bei der ST-Evaluierung in der gleichen Weise validiert werden, als ob eine ST Konformität mit mehreren PP beansprucht, die unterschiedliche Konformität erfordern.

- i) dürfen auch eine Verweisung auf Evaluierungsmethoden/-aufgaben enthalten, die von ISO/IEC 18045 abgeleitet wurden. Wenn der PP-Konfiguration Evaluierungsmethoden/-aufgaben zugeordnet sind, die aus der ISO/IEC 18045 abgeleitet wurden, dann muss die Konformitätserklärung auch eine Aussage in der folgenden Form enthalten:

„Diese PP-Konfiguration erfordert die Verwendung der in <Verweisung> festgelegten Evaluierungsmethoden/Evaluierungsaufgaben.“

In dieser Erklärung wird <Verweisung> durch die Angabe des Orts der betreffenden Evaluierungsmethoden und Evaluierungsaufgaben ersetzt. Diese Verweisung darf sich auf die PP-Konfiguration selbst beziehen oder auf ein oder mehrere separate Dokumente.

ANMERKUNG 1 Die Spezifikation zusätzlicher EM/EA, die für eine oder mehrere PP-Konfigurationskomponenten gelten, ist nur für PP-Konfigurationen vom Typ strikte oder nachweisliche Konformität zulässig.

ANMERKUNG 2 Es gibt Auswirkungen für Konformitätserklärungen in PP-Modulen im Fall genauer Konformität, die in C.2.2.5 behandelt werden

11.3.2.4 Vertrauenswürdigkeitsanforderungen

Eine PP-Konfiguration muss eine SAR-Aussage enthalten, in der die anwendbaren Vertrauenswürdigkeitsanforderungen und die zugehörigen Begründung definiert sind.

Eine PP-Konfiguration mit Einfach-Vertrauenswürdigkeit muss einen einzigen Satz an SAR für alle Komponenten der PP-Konfiguration definieren. Im Fall der genauen Konformität muss dieser Satz an SAR identisch mit denen sein, die in den einzelnen PP-Konfigurationskomponenten angegeben sind. Im Fall der strikten und nachweislichen Konformität muss dieser Satz an SAR identisch mit den Komponenten sein, die in den einzelnen PP-Konfigurationskomponenten angegeben sind, oder diese ergänzen.

Eine PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit muss Folgendes definieren:

- Den Gesamtsatz an SAR, der für den gesamten TOE gilt. Im Fall der genauen Konformität muss dieser Satz an SAR identisch mit der gemeinsamen Teilmenge an SAR in den einzelnen PP-Konfigurationskomponenten sein. Im Fall der strikten und nachweislichen Konformität muss dieser Satz an SAR mit der gemeinsamen Teilmenge an SAR in den einzelnen PP-Konfigurationskomponenten identisch sein oder diese ergänzen;

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

- Für jede Teil-TSF die Menge der geltenden SAR. Im Fall der genauen Konformität muss dieser Satz an SAR identisch mit dem in der PP-Konfigurationskomponente für die Teil-TSF deklarierten Satz an SAR sein. Im Fall der strikten und nachweislichen Konformität muss dies identisch mit der Menge an SAR sein oder diese ergänzen, die in der PP-Konfigurationskomponente für die Teil-TSF angegeben ist.

Eine PP-Konfiguration darf die in ISO/IEC 15408-5 vordefinierten EAL (EAL1 bis EAL7), in externen Verweisungen definierte Vertrauenswürdigkeitspakete und/oder in der PP-Konfiguration selbst definierte SAR verwenden, um ihre SAR-Aussage zu definieren.

ANMERKUNG 1 Die Evaluierung mit Mehrfach-Vertrauenswürdigkeit ermöglicht die Anwendung mehrerer vordefinierter EAL. Aus denselben Gründen wie für die PP im allgemeinen Modell können PP-Konfigurationen jedoch Sätze an SAR beanspruchen, die von den vordefinierten EAL abweichen und/oder erweiterte SAR enthalten.

Eine PP-Konfiguration kann eindeutige Namen für die Sätze an SAR definieren, die für den gesamten TOE und für jede Teil-TSF gelten. Die Verwendung einer (ergänzten) vordefinierten EAL oder eines (ergänzten) Vertrauenswürdigkeitspakets, die bzw. das in einer der Komponenten der PP-Konfiguration oder in einer anderen externen Verweisung definiert ist, erfordert jedoch die Verwendung desselben Namens.

Eine PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit muss eine Begründung für die Vertrauenswürdigkeit enthalten für

- die Konsistenz des Gesamtsatzes an SAR in Bezug auf die Bedrohungsmodelle, wie es in den SPD der PP und der PP-Module in der PP-Konfiguration definiert ist,
- die Konsistenz des Gesamtsatzes an SAR und alle Mengen an SAR für die Teil-TSF miteinander.

Bei der Erstellung der Gesamtmenge der SAR für den Fall der genauen Konformität wählt der Autor der PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit die hierarchisch niedrigste SAR, wenn die Teil-TSF hierarchisch unterschiedliche SAR festlegen. Wenn es beispielsweise drei Teil-TSFs mit ADV_FSP.1, ADV_FSP.2 bzw. ADV_FSP.3 gibt, dann würde die Gesamtmenge der SAR ADV_FSP.1 enthalten. Wenn jedoch einer der Teil-TSF keine ADV_FSP-Komponente enthielte, dann wäre ADV_FSP nicht in der Gesamtmenge der SAR enthalten. In einem strikten/nachweislichen Fall kann der Autor einer PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit ADV_FSP.1 oder eine höhere Komponente wählen und damit die Vertrauenswürdigkeitsanforderungen für einige seiner Teil-TSF erhöhen (selbst wenn eine Teil-TSF keine ADV_FSP-Komponente definiert), vorausgesetzt, die Begründung für die Vertrauenswürdigkeit ist konsistent.

ANMERKUNG 2 In den meisten Fällen (und immer im Fall der genauen Konformität) kann der Gesamtsatz an SAR als gemeinsamer Satz von SAR gebildet werden, der für alle Teil-TSF gilt. Wie bei den ST im allgemeinen Modell kann die PP-Konfiguration (vom Typ strikte oder nachweisliche Konformität) jedoch zusätzliche oder höhere SAR erfordern. Die Evaluierung der PP-Konfiguration stellt die Konsistenz des Anspruchs sicher, ähnlich dem allgemeinen Modell für die Konformität mit zwei oder mehr PP, die unterschiedliche Mengen an SAR definieren, und ähnlich dem Ansatz für eine ST mit Mehrfach-Vertrauenswürdigkeit, die die Mengen an SAR erweitern kann, die in der PP-Konfiguration, mit der die ST Konformität beansprucht, definiert sind.

ANMERKUNG 3 Eine PP-Konfiguration kann nicht weniger Vertrauenswürdigkeitsanforderungen als den Gesamtsatz von SAR/Vertrauenswürdigkeitspaket beanspruchen, als in dem gemeinsamen Satz von SAR enthalten sind, der für alle Teil-TSF gilt.

ANMERKUNG 4 Die Begründung für die Vertrauenswürdigkeit der PP-Konfiguration trägt dazu bei, dass mehrere Sätze von SAR die erwartete Sicherheit der Vermögenswerte, die von den PP und PP-Modulen in der PP-Konfiguration gemeinsam genutzt werden, nicht untergraben. Die Begründung für die Vertrauenswürdigkeit der PP-Konfiguration stützt sich auf die in den PP und PP-Modulen angegebenen Gründe für die Vertrauenswürdigkeit und/oder verwendet diese wieder.

Für PP-Konfigurationen des genauen Konformitätstyps ist eine Ergänzung der SAR für jede Teil-TSF (durch die PP-Konfiguration) nicht zulässig.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Wenn zusätzliche SAR festgelegt oder SAR durch hierarchisch höhere SAR ersetzt werden, müssen alle abgeleiteten Evaluierungsmethoden/Evaluierungsaufgaben, die für die Komponenten der PP-Konfiguration erforderlich sind, in der Begründung für die Vertrauenswürdigkeit behandelt werden, um nachzuweisen, dass die von der PP-Konfiguration geforderten Evaluierungsmethoden/Evaluierungsaufgaben:

- immer noch angemessen sind, d. h. die neue SAR hat keine Auswirkungen auf die EM/EA in den Komponenten und die Vertrauenswürdigkeit, die sie bieten; oder
- durch definierte Präzisierungen der ursprünglichen EM/EA in den Komponenten behandelt wurden, so dass die resultierenden EM/EA, die für die PP-Konfiguration erforderlich sind, eine Vertrauenswürdigkeit erzeugen, genauso hoch wie oder höher ist als die ursprünglichen EM/EA, die auf die Komponenten angewendet wurden; oder
- durch zusätzliche EM/EA ergänzt wurden, so dass die daraus resultierenden EM/EA die gleiche oder eine höhere Vertrauenswürdigkeit erzeugen als die ursprünglich auf die Komponenten angewandten EM/EA.

BEISPIEL 1 Eine Aufgabe, die aus einer Prüfung der Dokumentation für eine niedrigere SAR bestand, bei der aber zusätzliche Prüfungen für eine hierarchisch höhere SAR erforderlich sein könnten, kann die ursprünglichen Aufgaben zur Evaluierung der Dokumentation durch zusätzliche Evaluierungsaufgaben ergänzen, die Prüfungen erfordern.

BEISPIEL 2 Bild 5 zeigt ein Beispiel für eine PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit mit einem PP, A, und zwei PP-Modulen, X und Y. Es veranschaulicht die Standardkonstruktion des Gesamtsatzes an SAR für den gesamten TOE, der aus C besteht, d. h. dem gemeinsamen Satz an SAR für jede der PP-Konfigurationskomponenten A, X und Y. In dem Beispiel sind die Sätze an SAR, die für die in A, X und Y definierten Teil-TSF gelten, ebenfalls unverändert.

ANMERKUNG 5 Die Regeln erlauben die Ergänzung der Sätze an SAR.

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

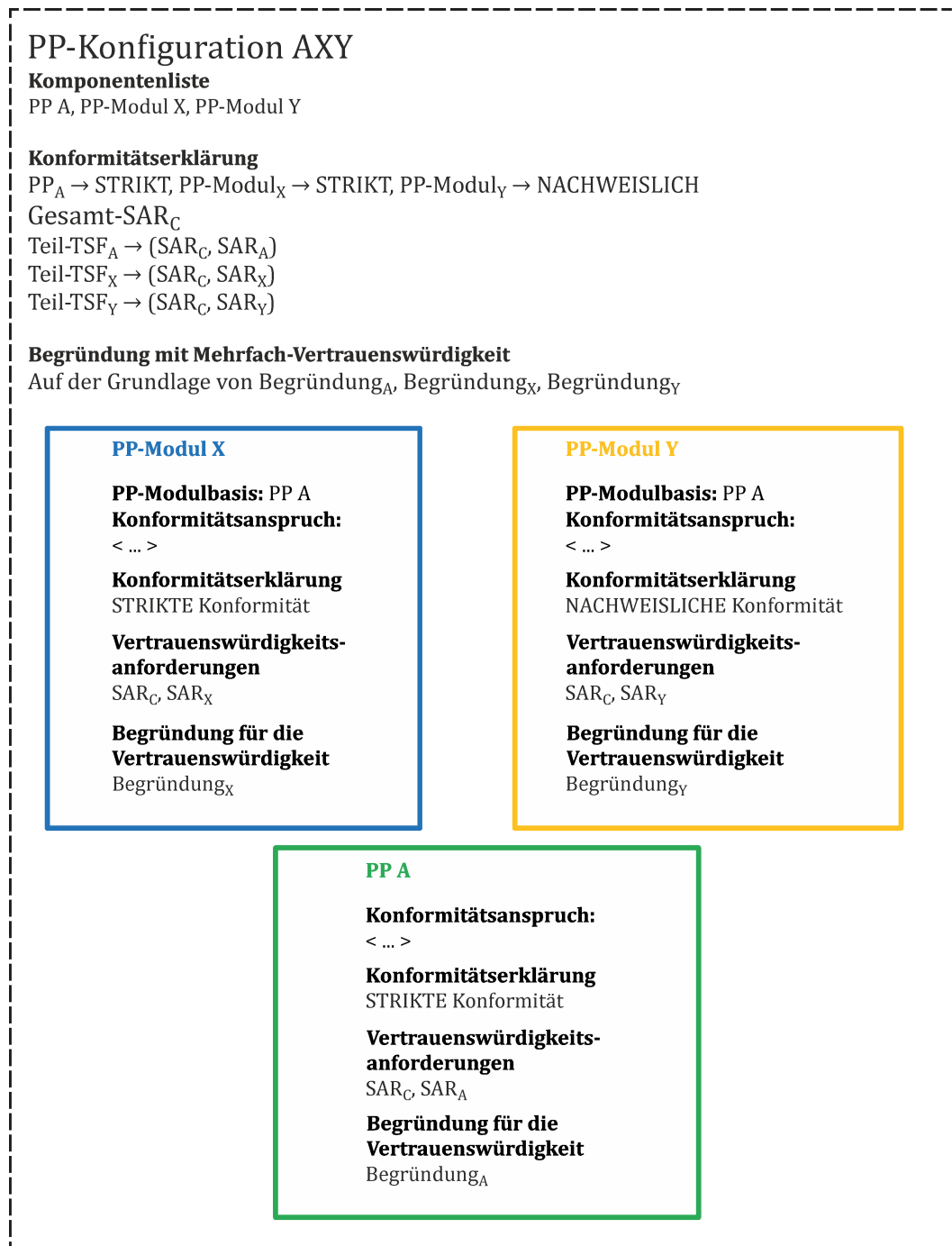


Bild 5 — Beispiel einer PP-Konfiguration

11.3.3 Verwendung von PP-Konfigurationen

Bild 6 zeigt die Verwendung von PP-Konfigurationen mit Einfach- und Mehrfach-Vertrauenswürdigkeit. Bild 7 enthält Angaben zu den Komponenten der PP-Konfiguration. Bild 8 zeigt die Vertrauenswürdigkeitsklassen, die zur Evaluierung der PP, PP-Konfigurationen und ST verwendet werden

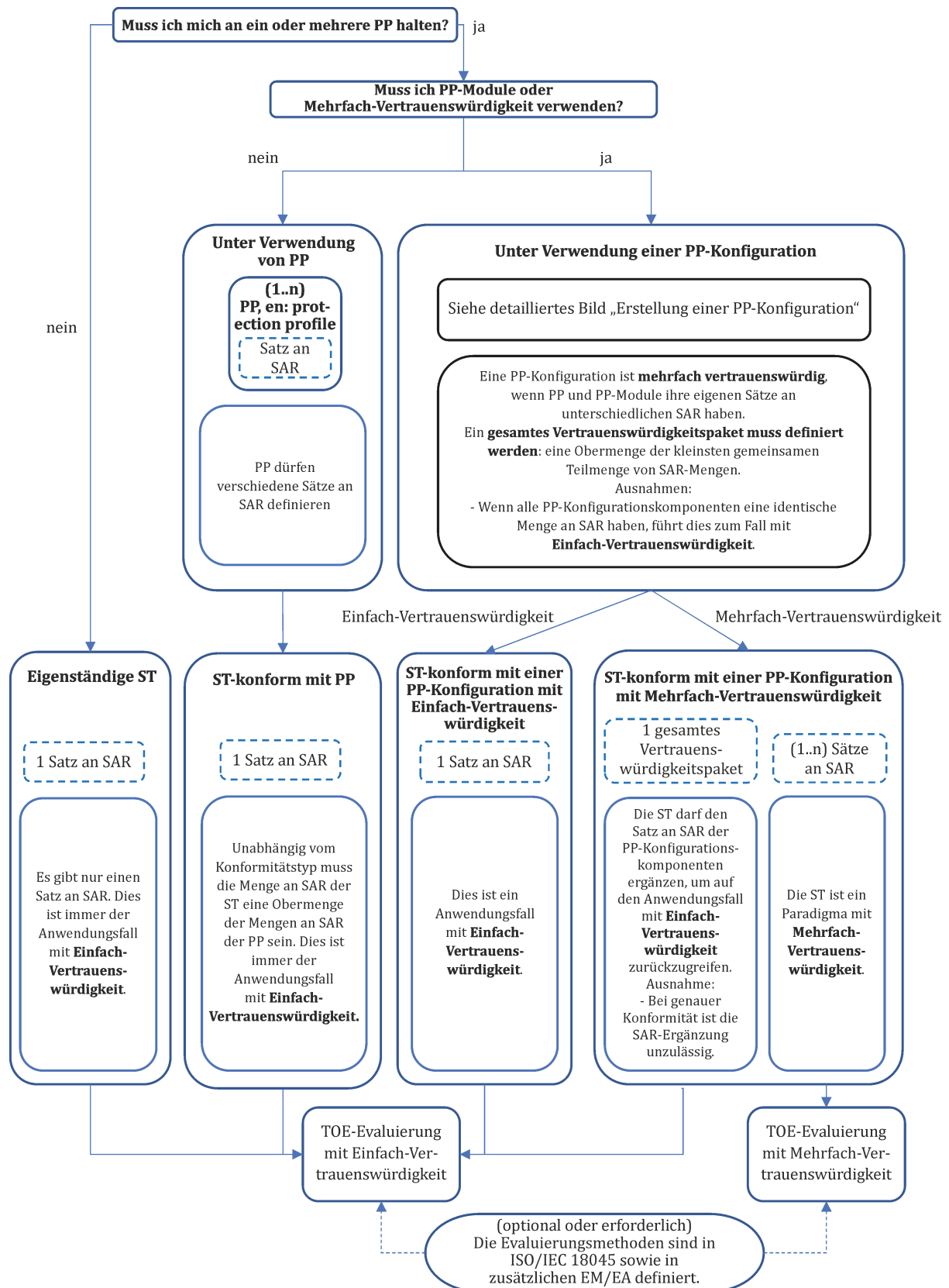


Bild 6 — Verwendung von PP-Konfigurationen mit Einfach- und Mehrfach-Vertrauenswürdigkeit

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

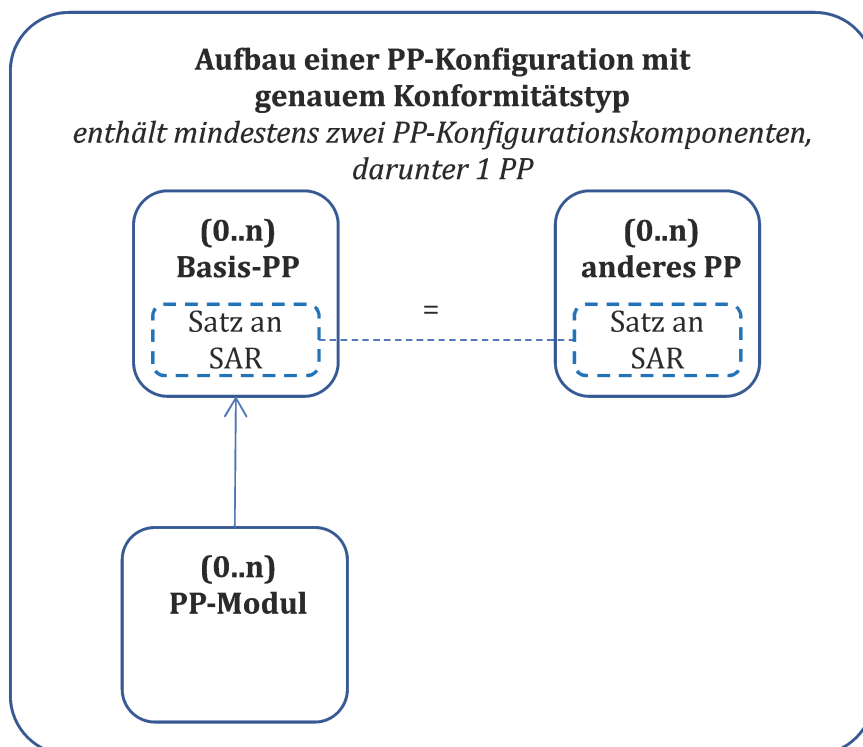
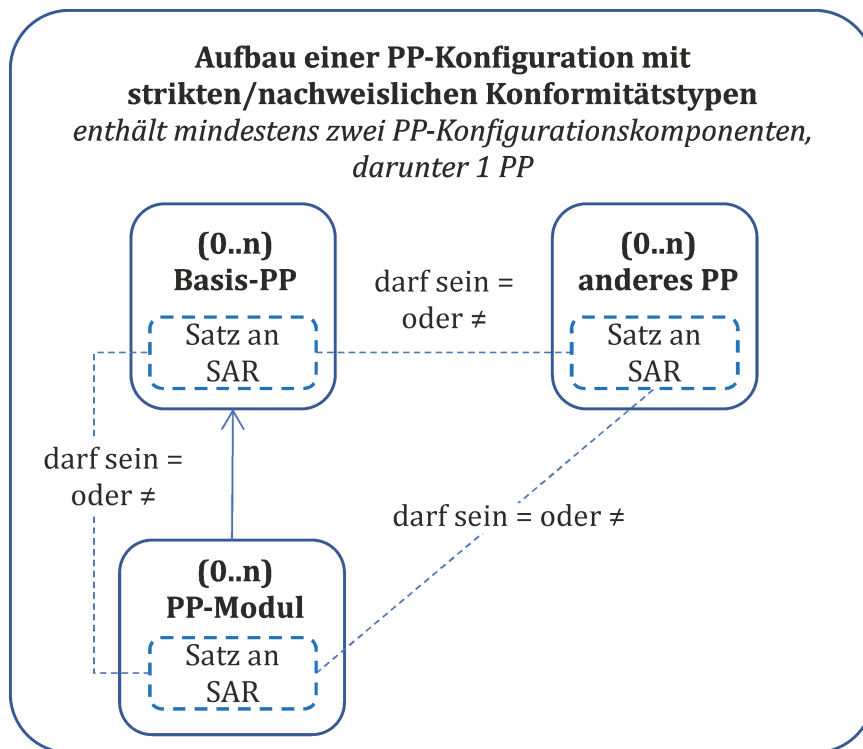


Bild 7 — Zusammensetzung von PP-Komponenten

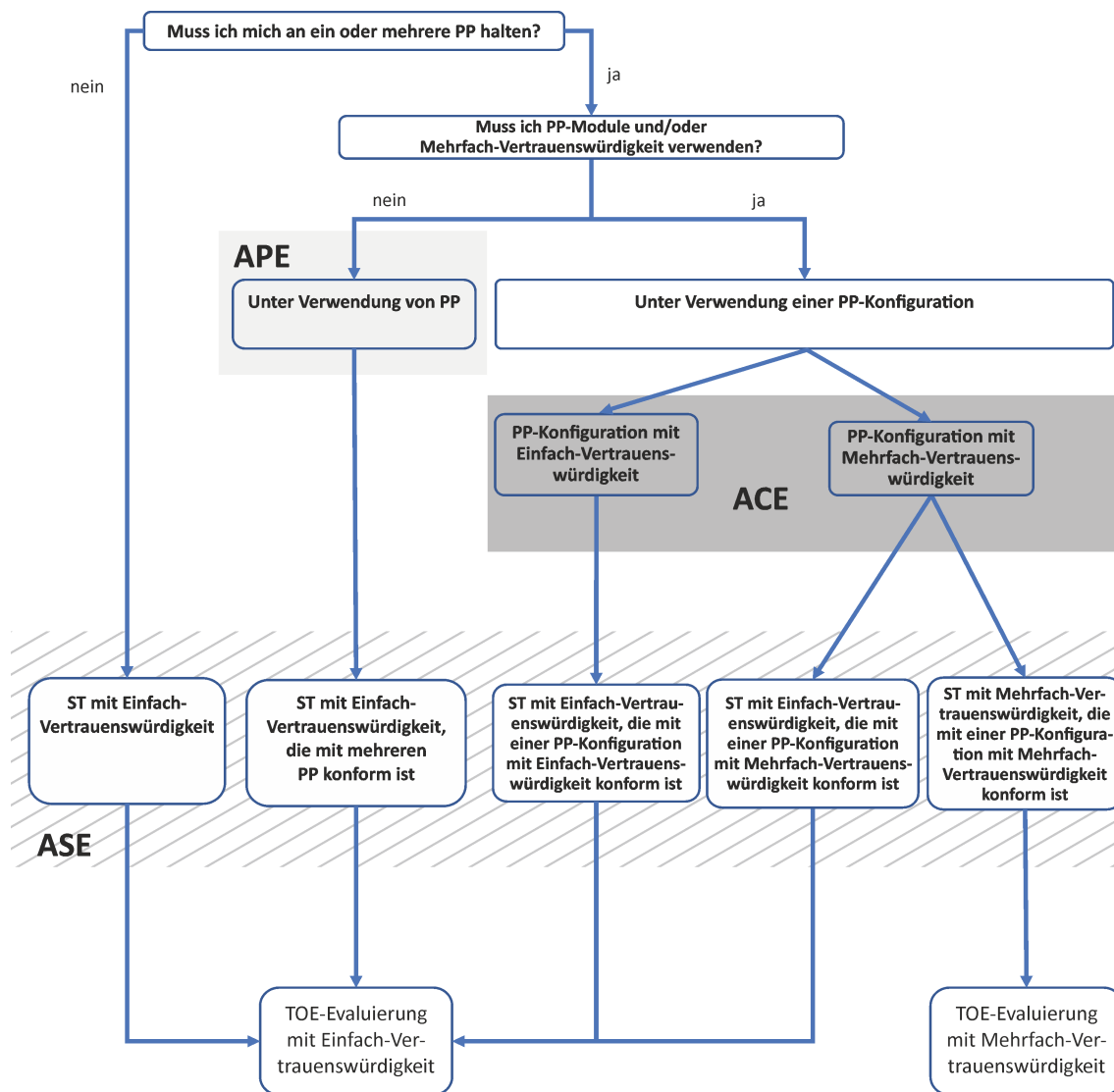


Bild 8 — Vertrauenswürdigkeitsklassen, die zur Evaluierung der PP, PP-Konfigurationen und ST verwendet werden

12 Sicherheitsvorgaben (ST)

12.1 Allgemein

Eine ST ist ein Dokument, das einen bestimmten TOE, die Konformitätsansprüche, die für die Evaluierung des TOE gelten, das zu behandelnde Sicherheitsproblem, die Sicherheitszielsetzungen für den TOE und seine Betriebsumgebung, die Sicherheitsanforderungen, die für die Lösung des angegebenen Sicherheitsproblems gelten, und zusätzliches Material, das zur ausreichenden Beschreibung des TOE für die Evaluierung notwendig ist, beschreibt. Die ST beruhen im allgemeinen auf den PP oder PP-Konfigurationen, die ein Sicherheitsproblem und Sicherheitsanforderungen für einen TOE-Typ beschreiben, der für den spezifischen TOE relevant ist.

Eine ST wird in der Regel von einem Entwickler erstellt, und zur Zielgruppe der ST gehören Evaluatoren, Zertifizierungsstellen und Endbenutzer des evaluierten TOE.

Weitere Informationen über die ST, Anhang D, müssen in Verbindung mit den Abschnitten des vorliegenden Dokuments verwendet werden.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****12.2 Konformitätsansprüche und -erklärungen**

In diesem Unterabschnitt kennzeichnet die Verwendung von kursivem Text den wörtlichen Text, der im Text der ST erscheinen muss.

Die Konformitätsansprüche einer ST:

- a) müssen die Ausgabe der relevanten Teile der Normenreihe ISO/IEC 15408 angeben, mit denen die ST Konformität beansprucht;
- b) müssen die Konformität mit ISO/IEC 15408-2 (SFR) beschreiben, entweder als

— „ISO/IEC 15408-2-konform“

Eine ST ist ISO/IEC 15408-2-konform, wenn alle SFR in dieser ST ausschließlich auf Funktionskomponenten von ISO/IEC 15408-2 basieren, oder

— „ISO/IEC 15408-2-erweitert“

Eine ST ist ISO/IEC 15408-2-erweitert, wenn mindestens eine SFR in dieser ST nicht auf Funktionskomponenten von ISO/IEC 15408-2 basiert.

ANMERKUNG 1 Bei der erfolgreichen Evaluierung eines TOEs nach einer ST gelten jegliche Konformitätsansprüche der ST auch für den TOE. Daher kann ein TOE auch beanspruchen, ISO/IEC 15408-2-konform sein.

- c) müssen die Konformität mit ISO/IEC 15408-3 (Vertrauenswürdigkeitsanforderungen) beschreiben, entweder als

— „ISO/IEC 15408-3-konform“;

Eine ST ist ISO/IEC 15408-3-konform, wenn alle SAR in dieser ST ausschließlich auf Vertrauenswürdigkeitskomponenten von ISO/IEC 15408-3 basieren, oder

— „ISO/IEC 15408-3-erweitert“

Eine ST ist ISO/IEC 15408-3-erweitert, wenn mindestens eine SAR in dieser ST nicht auf Vertrauenswürdigkeitskomponenten von ISO/IEC 15408-3 basiert.

- d) dürfen einen Konformitätsanspruch in Bezug auf Pakete enthalten.

Sofern ein Anspruch auf Paketkonformität erhoben wird, muss dieser einen der folgenden Ansprüche für jedes Paket umfassen:

— „Paket-konform“;

Eine ST ist konform mit einem Paket, wenn:

- bei Funktionspaketen alle Bestandteile (SPD, Sicherheitszielsetzungen und SFR) des Funktionspakets ohne Änderung in den entsprechenden Teilen der ST enthalten sind;
- bei Vertrauenswürdigkeitspaketen die SAR dieser ST mit den SAR des Vertrauenswürdigkeitspakets identisch sind.

— „Paket-ergänzt“

Eine ST beansprucht eine Ergänzung eines Pakets, wenn:

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

- bei Funktionspaketen alle Bestandteile (SPD, Sicherheitszielsetzungen und SFR) des Funktionspakets in den entsprechenden Teilen der ST vorhanden sind, die ST aber mindestens eine zusätzliche SFR oder eine SFR enthält, die hierarchisch höher als eine SFR im Paket ist;
- bei Vertrauenswürdigkeitspaketen die ST alle SARs in diesem Vertrauenswürdigkeitspaket enthält, aber mindestens eine zusätzliche SAR oder eine hierarchisch höhere SAR enthält als eine SAR im Vertrauenswürdigkeitspaket.
- „*Paket-angepasst*“

Die ST dürfen keine Anpassung beanspruchen oder durchführen.

In einer ST darf mehr als ein Paket beansprucht werden.

Wenn die ST eine genaue Konformität mit dem/den PP beanspruchen, dürfen sie keine Konformität mit irgendwelchen Paketen beanspruchen, auch nicht mit den von den PP beanspruchten Paketen.

Wenn die ST eine strikte oder nachweisliche Konformität mit den PP beanspruchen, dürfen sie nicht auch Konformität mit den in den PP beanspruchten Paketen beanspruchen, es sei denn, die ST ergänzt das in den PP beanspruchte Paket, d. h. die PP dürfen ein Paket als <Paket>-konform, <Paket>-ergänzt oder <Paket>-angepasst beanspruchen; wenn jedoch die ST nicht selbst die konforme/ergänzte/angepasste Version des Pakets in den PP ergänzt, dann beansprucht sie keine Konformität mit dem Paket. Die ST beansprucht <Paket>-ergänzt nur dann, wenn die ST die Pakete über das hinaus ergänzt, was das PP beansprucht.

Wenn die ST Konformität mit einer PP-Konfiguration beanspruchen, dürfen sie nicht auch Konformität mit anderen Funktionspaketen beanspruchen, einschließlich der Funktionspakete, die von den Komponenten der PP-Konfiguration beansprucht werden.

Wenn die ST eine strikte oder nachweisliche Konformität mit einer PP-Konfiguration beanspruchen, dürfen sie nicht auch Konformität mit den in der PP-Konfiguration beanspruchten Vertrauenswürdigkeitspaketen beanspruchen, es sei denn, die ST ergänzt das in der PP-Konfiguration beanspruchte Vertrauenswürdigkeitspaket, d. h. die PP-Konfiguration kann ein Vertrauenswürdigkeitspaket als <Paket>-konform oder <Paket>-ergänzt beanspruchen; wenn jedoch wenn die ST nicht selbst die konforme/ergänzte Version des Pakets in der PP-Konfiguration ergänzt, dann beansprucht sie keine Konformität mit dem Vertrauenswürdigkeitspaket. Die ST beansprucht <Paket>-ergänzt nur dann, wenn die ST das Vertrauenswürdigkeitspaket über das hinaus ergänzt, was die PP-Konfiguration beansprucht.

ANMERKUNG 2 Für eine genaue Konformität ist es zulässig, die Konformität mit einem PP zu beanspruchen, das die Konformität mit einem Paket beansprucht, oder mit einer PP-Konfiguration, die Komponenten hat, die Konformität mit einem Paket beanspruchen, die sich aber nicht im Konformitätsanspruch des ST widerspiegeln.

- e) dürfen auch einen Konformitätsanspruch in Bezug auf die PP enthalten:

- „*PP-konform*“;

Ein PP oder TOE erfüllt einen oder mehrere bestimmte PP.

Eine ST mit direkter Begründung darf nur Konformität mit einem oder mehreren anderen PP mit direkter Begründung beanspruchen. (Siehe Anhang B)

- f) dürfen auch einen Konformitätsanspruch in Bezug auf PP-Konfigurationen enthalten:

- eine ST darf Konformität mit genau einer PP-Konfiguration beanspruchen;
- eine ST mit direkter Begründung darf nur dann Konformität mit einer PP-Konfiguration beanspruchen, wenn diese PP-Konfiguration den Ansatz der direkten Begründung verwendet.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

ANMERKUNG 3 Die Evaluierung einer PP-Konfiguration kann im Vorfeld, unabhängig von einer Produktevaluierung, durchgeführt werden. Alternativ kann die Evaluierung einer PP-Konfiguration während der Evaluierung einer konformen ST durchgeführt werden, bevor der Konformitätsanspruch der ST evaluiert wird. Siehe 13.3 für eine Diskussion über die Evaluierung von PP-Konfigurationen.

PP-Module werden verwendet, um spezifische PP-Konfigurationen auf einer oder mehreren PP-Modulbasen aufzubauen. Daher dürfen PP-Module von den ST nur durch beanspruchte PP-Konfigurationen verwendet werden.

- g) Wenn Evaluierungsmethoden/Evaluierungsaufgaben, die von ISO/IEC 18045 abgeleitet wurden, in der Konformitätserklärung eines Pakets, eines PP, eines PP-Moduls oder einer PP-Konfiguration, zu dem/der die ST Konformität beansprucht, identifiziert werden, dann muss der Konformitätsanspruch auch einen Anspruch in der folgenden Form enthalten:

„Der TOE wird unter Verwendung der in <Verweisung> festgelegten Evaluierungsmethoden/Evaluierungsaufgaben evaluiert.“

In dieser Erklärung wird <Verweisung> durch die Angabe des Orts der betreffenden Evaluierungsmethoden und Evaluierungsaufgaben ersetzt.

Die ST, die auf Evaluierungsmethoden/-aufgaben verweisen, müssen den Text der Evaluierungsmethoden/-aufgaben in der ST nicht wiedergeben.

Eine ST darf nur für Evaluierungsmethoden/Evaluierungsaufgaben einen Konformitätsanspruch erheben, die in einem Paket, PP, PP-Modul oder einer PP-Konfiguration enthalten sind, auf die die ST Anspruch erhebt.

ANMERKUNG 4 Der Leser wird darauf hingewiesen, dass es vorkommen kann, dass eine ST kein PP bzw. keine PP-Konfiguration beansprucht, aber dennoch direkt ein Paket festlegen kann.

- Eine ST kann Konformität mit mehreren PP beanspruchen. Wenn ein solches PP einen genauen Konformitätstyp hat, dann müssen alle PP dem genauen Konformitätstyp entsprechen. Andernfalls können die PP eine Mischung aus strikten und nachweislichen Typen haben, und die Konsistenz der Kombination aus nachweislicher und strikter Konformität muss als Teil der ST-Evaluierung validiert werden.

Für weitere Informationen und Anforderungen zu Konformitätsansprüchen für die ST siehe Anhang D.

Für weitere Informationen und Anforderungen zu Konformitätstypen siehe Anhang E.

12.3 Vertrauenswürdigkeitsanforderungen

Eine ST, die Konformität mit ISO/IEC 15408-3 (möglicherweise erweitert) beansprucht, muss den gesamten Satz an SAR definieren, der für den TOE gilt.

Eine ST kann einen eindeutigen Namen für den Satz an SAR festlegen, die anwendbar sind. Die Verwendung einer (ergänzten) vordefinierten EAL oder eines (ergänzten) Vertrauenswürdigkeitspakets, das in einer anwendbaren externen Verweisung definiert ist, muss jedoch die Verwendung desselben Namens erfordern.

Wenn zusätzliche SAR festgelegt oder SAR durch hierarchisch höhere SAR in einer ST ersetzt werden, müssen alle abgeleiteten Evaluierungsmethoden/Evaluierungsaufgaben in der Begründung der Vertrauenswürdigkeit behandelt werden, um zu zeigen, dass die von der ST verwendeten Evaluierungsmethoden/Evaluierungsaufgaben:

- immer noch angemessen, d. h. die neue SAR hat keine Auswirkungen auf die EM/EA, die für die Verwendung in der ST festgelegt sind, und die Vertrauenswürdigkeit, die sie bieten; oder

- durch definierte Präzisierungen der ursprünglichen durch die ST festgelegten EM/EA behandelt wurden, so dass die resultierenden EM/EA, die für die ST erforderlich sind, eine Vertrauenswürdigkeit erzeugen, die gleich hoch oder höher ist als die ursprünglichen EM/EA, die auf die ST angewendet wurden; oder
- durch zusätzliche EM/EA ergänzt wurden, so dass die daraus resultierenden EM/EA die gleiche oder eine höhere Vertrauenswürdigkeit erzeugen als die ursprünglich auf die ST angewandten EM/EA.

BEISPIEL Eine Aufgabe, die aus einer Prüfung der Dokumentation für eine niedrigere SAR bestand, bei der aber zusätzliche Prüfungen für eine hierarchisch höhere SAR erforderlich sein könnten, kann die ursprünglichen Aufgaben zur Evaluierung der Dokumentation durch zusätzliche Evaluierungsaufgaben ergänzen, die Prüfungen erfordern.

12.4 Zusätzliche Anforderungen im Fall der genauen Konformität

12.4.1 Zusätzliche Anforderungen für den Konformitätsanspruch

Eine ST darf nicht die Konformität mit einem/einer genau konformen PP/PP-Konfiguration und gleichzeitig mit anderen PP beanspruchen, die nicht vom Typ der genauen Konformität sind, d. h. ein(e) PP/PP-Konfiguration mit genauer Konformität darf nicht mit strikter oder nachweislicher Konformität kombiniert werden.

12.4.2 Zusätzliche Anforderungen für die SPD

Eine ST, die genaue Konformität beansprucht:

- muss die SPD aller Pakete und der PP oder PP-Konfiguration enthalten, zu denen sie genaue Konformität beansprucht, einschließlich aller SPD-Elemente;
- darf keine SPD-Elemente enthalten, die nicht in den Paketen oder PP/PP-Konfigurationen enthalten sind, zu denen sie genaue Konformität beansprucht.

ANMERKUNG Die SPD, die in der ST aus einer PP-Konfiguration instanziiert wird, enthält genau die SPD-Elemente, die in den Komponenten der PP-Konfiguration (PP und PP-Module) vorhanden sind. Es ist zu beachten, dass PP-Konfigurationskomponenten kombiniert werden können, um SPD-Elemente zu verändern oder zu eliminieren (z. B. kann eine Annahme in einem Basis-PP zu einer Bedrohung werden, die durch ein PP-Modul über diesem Basis-PP abgewehrt wird), so dass das Ergebnis, das in der ST erscheint, diese Art von Änderungen berücksichtigt. Siehe 11.3.

12.4.3 Zusätzliche Anforderungen an die Sicherheitszielsetzungen

Eine ST, die genaue Konformität beansprucht:

- muss alle Sicherheitszielsetzungen für den TOE enthalten, die in allen PP festgelegt sind, für die er Konformität beansprucht;
- darf keine zusätzlichen Sicherheitszielsetzungen für den TOE festlegen, die nicht in der Kombination der PP festgelegt sind, für die sie Konformität beansprucht;
- muss alle Sicherheitszielsetzungen für die Betriebsumgebung enthalten, die in der Kombination der PP, für die sie Konformität beansprucht, festgelegt sind; und
- darf keine zusätzlichen Sicherheitszielsetzungen für die Betriebsumgebung festlegen, die nicht in der Kombination der PP enthalten sind, für die sie Konformität beansprucht.

Dasselbe gilt für PP-Konfigurationen. Die Sicherheitszielsetzungen, die in der ST aus einer PP-Konfiguration instanziiert werden, enthalten genau die Sicherheitszielsetzungen, die in den Komponenten der PP-Konfiguration vorhanden sind. Es sollte beachtet werden, dass PP-Konfigurationskomponenten kombiniert werden können, um Sicherheitszielsetzungen zu ändern oder zu beseitigen (z. B. kann eine Sicherheitszielsetzung für die Umgebung in einem Basis-PP zu einer TOE-Sicherheitszielsetzung in einem PP-Modul werden, das dieses Basis-PP verwendet), so dass die resultierende ST diese Art von Änderungen widerspiegelt.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****12.4.4 Zusätzliche Anforderungen an die Sicherheitsanforderungen**

Eine ST muss alle in den PP vorhandenen SAR und alle in den PP-Konfigurationskomponenten vorhandenen SFR enthalten; dabei gelten die folgenden Ausnahmen:

- ST-Autoren dürfen keine zusätzlichen oder hierarchisch höheren Sicherheitsanforderungen stellen;
- die in den PP oder PP-Modulen als auswahlbasierte SFR bezeichneten SFR müssen ausgeschlossen werden, wenn die Auswahl, die ihre Einbeziehung erfordert, nicht vom ST-Autor getroffen wird;
- die in den PP oder PP-Modulen als optionale SFR bezeichneten SFR dürfen unter Beibehaltung ihres genauen Konformitätsanspruchs einbezogen oder ausgeschlossen werden.

ANMERKUNG 1 Die SFR in einer genauen Konformitäts-PP können iteriert und präzisiert werden (wie in ISO/IEC 18045 für ASE_CCL.1-12 angegeben).

ANMERKUNG 2 Siehe 7.3.2.6 für weitere Informationen zu optionalen und auswahlbasierten SFR.

ANMERKUNG 3 Weitere Informationen zur PP-Konformität sind in Anhang E enthalten.

12.5 Zusätzliche Anforderungen im Fall der Mehrfach-Vertrauenswürdigkeit

Eine ST mit Mehrfach-Vertrauenswürdigkeit muss die Konformität mit genau einer PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit beanspruchen und darf kein anderes PP und keine andere PP-Konfiguration beanspruchen.

Eine ST mit Mehrfach-Vertrauenswürdigkeit muss die TSF in Teil-TSF organisieren und einen spezifischen Satz an SAR für jede der Teil-TSF und einen Gesamtsatz an SAR für den gesamten TOE beanspruchen: Dies kann ausschließlich durch die Konformität mit einer PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit erreicht werden. Die in der ST definierte TSF-Struktur wird von der PP-Konfiguration übernommen, und die Sätze an SAR, die für sie in der ST gelten, sind entweder identisch mit denen, die in der PP-Konfiguration definiert sind, oder sie werden ergänzt.

Eine ST mit Mehrfach-Vertrauenswürdigkeit kann die PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit (vom Typ strikte oder nachweisliche Konformität) um zusätzliche SFR (und ggf. zugehörige SPD und Sicherheitszielsetzungen) erweitern, so dass jedes neue Element mindestens ein PP oder PP-Modul der PP-Konfiguration vervollständigt, sofern die erforderlichen Konformitätsregeln erfüllt sind, d. h. die neuen SFR zielen darauf ab, die durch die Komponenten der PP-Konfiguration definierten Teil-TSF zu erweitern. Infolgedessen unterliegen die erweiterten Teil-TSF dem Satz an SAR, die in den ursprünglichen PP/PP-Modulen definiert sind.

Eine ST mit Mehrfach-Vertrauenswürdigkeit darf die in der PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit definierten Sätze von SAR beanspruchen oder, im Falle eines strikten oder nachweislichen Konformitätstyps, eine Begründung für die Beanspruchung „ergänzter“ Sätze von SAR liefern, ähnlich wie bei den ST im allgemeinen Modell.

Um mit zwei oder mehr PP nach ihren jeweiligen Sätzen von SAR konform zu sein, muss eine aus den PP zusammengesetzte PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit von der ST definiert und beansprucht werden.

Eine ST, die Konformität mit einer PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit beansprucht und alle anwendbaren Sätze von SAR ergänzt, um denselben Satz von SAR für den gesamten TOE und alle Teil-TSF zu erreichen, wird zu einer ST mit Einfach-Vertrauenswürdigkeit. In diesem Fall muss die Evaluierung des TOE nach dem Ansatz der Evaluierung mit Einfach-Vertrauenswürdigkeit erfolgen. Dies ist nur für PP-Konfigurationen vom Typ strikte oder nachweisliche Konformität zulässig.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Eine ST, die Konformität mit mehreren PP beansprucht, kann nur einen Gesamtsatz an SAR definieren, der für den gesamten TOE gilt, so dass eine ST mit Einfach-Vertrauenswürdigkeit entsteht. Es gelten die ASE-Regeln zur Sicherstellung der Konsistenz der Vertrauenswürdigkeitsanforderungen der ST mit Einfach-Vertrauenswürdigkeit in Bezug auf die PP.

Eine ST, die Konformität mit einer PP-Konfiguration mit Einfach- Vertrauenswürdigkeit beansprucht, d. h. die nur einen Satz an SAR für den gesamten TOE und seine Teile definiert, kann nicht zu einer ST mit Mehrfach-Vertrauenswürdigkeit werden. Der Grund dafür ist, dass die Konsistenzregeln für die Mehrfach-Vertrauenswürdigkeit auf der Ebene der PP-Konfiguration definiert sind. Um dies zu erreichen, muss eine von der PP-Konfiguration abgeleitete PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit definiert und evaluiert werden.

Für weitere Informationen zu PP-Konfigurationen mit Mehrfach-Vertrauenswürdigkeit und den ST siehe 12.4.2. Eine ST, die Konformität mit einer PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit beansprucht, kann zu einer ST mit Mehrfach-Vertrauenswürdigkeit werden, indem sie für jede Teil-TSF den entsprechenden Satz an SAR definiert. Dabei handelt es sich entweder um denselben Satz an SAR, der von der PP-Konfiguration übernommen wurde, oder um einen größeren Satz (Ergänzung, gültig nur in den Fällen einer strikten oder nachweislichen Konformität), der die Aktualisierung der in der PP-Konfiguration enthaltenen Begründung für die Vertrauenswürdigkeit erfordert.

Eine ST mit Mehrfach-Vertrauenswürdigkeit darf eindeutige Namen für die Sätze an SAR definieren, die für den gesamten TOE und für jede Teil-TSF gelten. Die Namen müssen mit den in der PP-Konfiguration angegebenen Namen konsistent sein. Die Verwendung einer (ergänzten) vordefinierten EAL oder eines (ergänzten) Vertrauenswürdigkeitspakets, das in einer anwendbaren externen Verweisung definiert ist, erfordert die Verwendung desselben Namens.

Eine ST mit Mehrfach-Vertrauenswürdigkeit, die strikte oder nachweisliche Konformität mit einer PP-Konfiguration beansprucht und die Sätze an SAR der PP-Konfiguration, mit der sie Konformität beansprucht, erweitert, muss eine Begründung für die Vertrauenswürdigkeit liefern, die die Konsistenz der Erweiterung rechtfertigt.

Eine ST mit Mehrfach-Vertrauenswürdigkeit muss mit allen Konformitätstypen übereinstimmen, die in der Konformitätserklärung der PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit gekennzeichnet sind.

ANMERKUNG Eine ST, die Konformität mit mehr als einem PP beansprucht, kann nur einen Gesamtsatz an SAR definieren, der für den gesamten TOE gilt. In diesem Fall gelten die ASE-Regeln zur Sicherstellung der Konsistenz der Vertrauenswürdigkeitsanforderungen der ST in Bezug auf die PP.

Bild 9 zeigt ein Beispiel für eine ST mit Mehrfach-Vertrauenswürdigkeit, die Konformität mit der PP-Konfiguration „AXY“ beansprucht, die aus dem PP A und zwei PP-Modulen X und Y besteht. Die TSF-Struktur besteht aus der in A, X und Y definierten Teil-TSF. Der Gesamtsatz an SAR (SAR_C) und die mehrfachen Sätze an SAR, die auf die Teil-TSF anwendbar sind, stammen aus der PP-Konfiguration ohne jegliche Ergänzung.

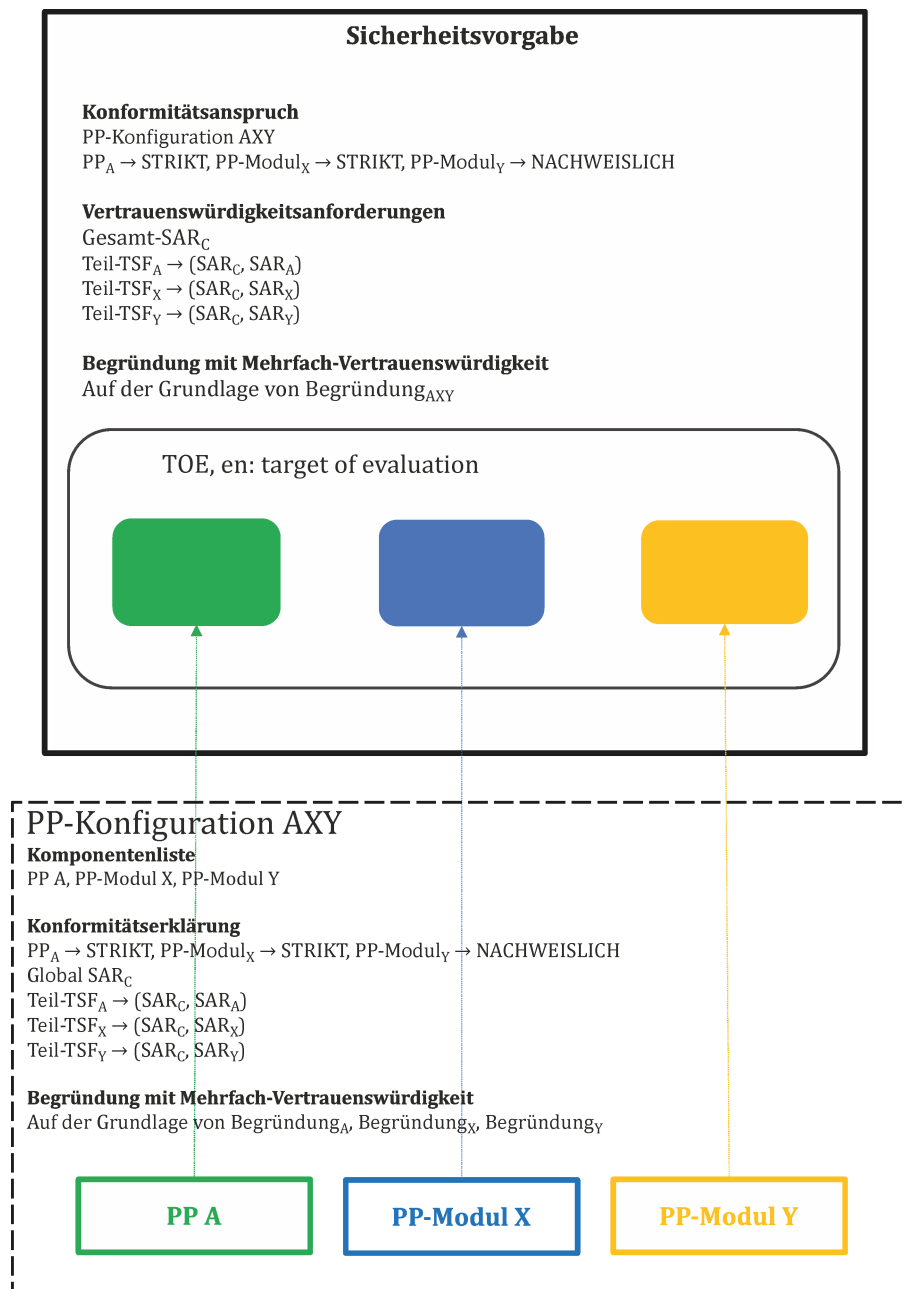


Bild 9 — Beispiel einer ST mit Mehrfach-Vertrauenswürdigkeit

13 Evaluierung und Evaluierungsergebnisse

13.1 Allgemein

Dieser Abschnitt zeigt die erwarteten Ergebnisse aus dem PP, der PP-Konfiguration und den Evaluierungen zu PPs und STs/TOEs, die entweder nach ISO/IEC 18045 und/oder unter Berücksichtigung zusätzlicher Evaluierungsmethoden und -aufgaben durchgeführt wurden.

Das Ziel der Evaluierung besteht darin, objektive und wiederholbare Ergebnissen bereitzustellen, die anschließend als Nachweis zitiert werden können, auch wenn es keine vollkommen objektive Skala für die Darstellung von Ergebnissen einer Sicherheitsevaluierung gibt.

ANMERKUNG 1 Oft ist ein Kompromiss zwischen dem Stand der Technik und einem ausreichenden Maß an Wiederholpräzision erforderlich. Daher werden Eigenschaften wie Objektivität und Wiederholpräzision von der Norm nicht als absolut angesehen, sondern eher als Ziele, die auf unterschiedliche Weise angegangen werden können. ISO/IEC 15408-4 bietet zum Beispiel einen solchen Rahmen für die Wahrung der Objektivität und Wiederholpräzision bei der Ableitung von Evaluierungsaufgaben aus ISO/IEC 18045.

Ein Evaluierungsergebnis steht für die Feststellungen eines spezifischen Typs einer Untersuchung der Sicherheitseigenschaften eines TOEs. Ein solches Ergebnis garantiert nicht automatisch die Eignung zur Verwendung in irgendeiner bestimmten Anwendungsumgebung. Die Entscheidung, einen TOE zur Verwendung in einer spezifischen Anwendungsumgebung zu akzeptieren, basiert auf der Betrachtung verschiedener Sicherheitsaspekte, einschließlich der Feststellungen aus der Evaluierung.

Bild 10 beschreibt die verschiedenen Evaluierungen, die erforderlich sind, um Vertrauen in die Evaluierungsergebnisse für einen TOE zu schaffen.

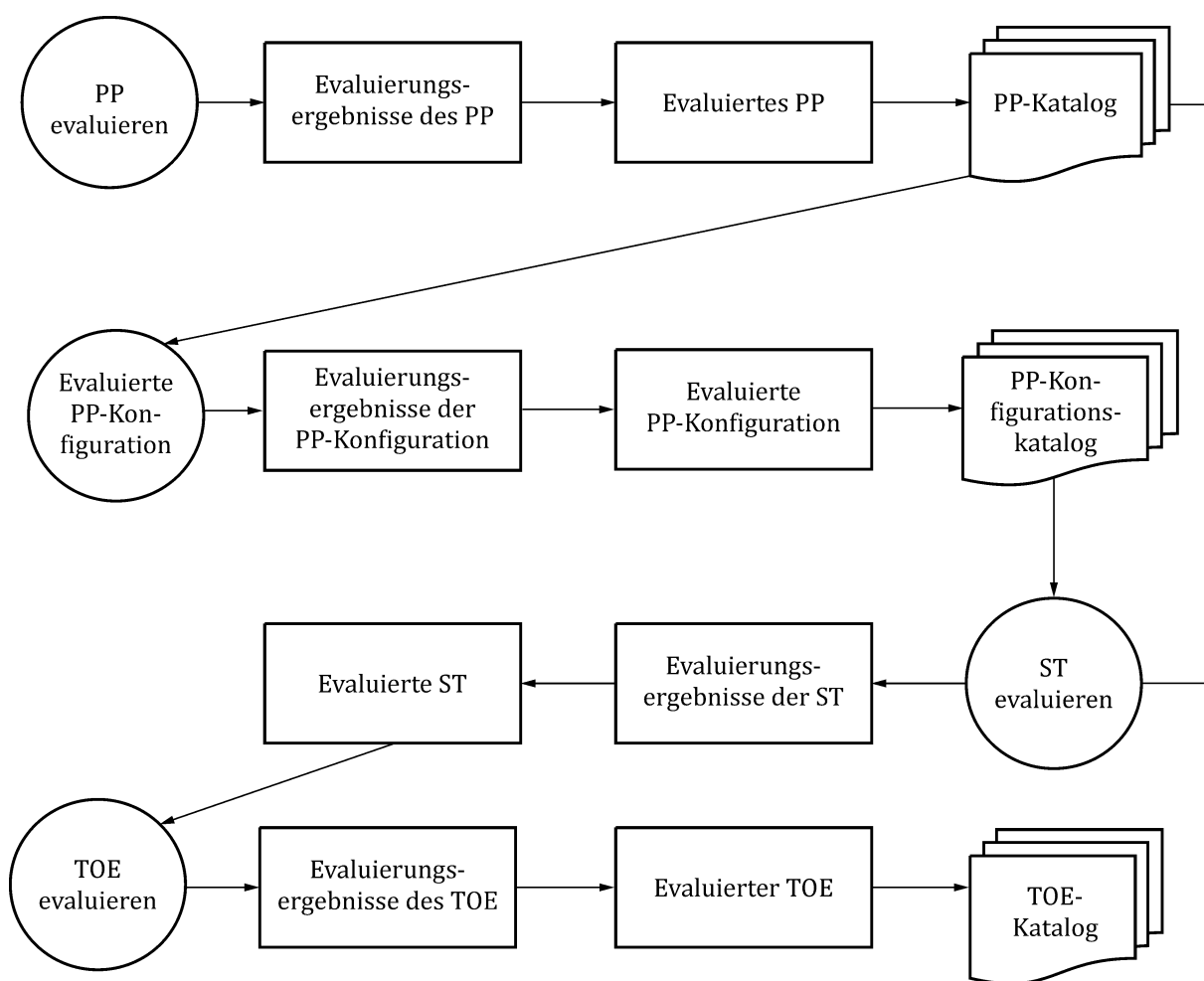


Bild 10 — Ablauf der Evaluierung

Die Normenreihe ISO/IEC 15408 enthält Kriterien für vier Typen der Evaluierung:

- eine PP-Evaluierung, die auf der in ISO/IEC 15408-3 angegebenen APE-Klasse basiert, wie in 13.3 beschrieben;
- eine Evaluierung der PP-Konfiguration, die auf der in ISO/IEC 15408-3 angegebenen ACE-Klasse basiert, wie in 13.3 beschrieben;

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

- c) eine ST-Evaluierung, die auf der in ISO/IEC 15408-3 angegebenen ASE-Klasse basiert, wie in 13.4 beschrieben;
- d) eine TOE-Evaluierung, die auf einer evaluierten ST und den in 13.5 beschriebenen Kriterien für die Evaluierung der von der ST beanspruchten Sicherheitsanforderungen basiert.

Evaluierungen von PP und PP-Konfigurationen schaffen Vertrauen, dass das PP und/oder die PP-Konfiguration die Anforderungen der Normenreihe ISO/IEC 15408 erfüllt. Kataloge der PP und PP-Konfigurationen können von Behörden oder anderen Stellen geführt werden, die die Kriterien für die Aufnahme in den Katalog festlegen.

ANMERKUNG 2 Die Kriterien für die Aufnahme in einen Katalog liegen außerhalb des Anwendungsbereichs der Normenreihe ISO/IEC 15408.

PP-Module werden nur im Rahmen einer Evaluierung auf Basis einer PP-Konfiguration evaluiert.

Pakete werden nur im Rahmen der Evaluierung einer PP-Konfiguration, eines PP oder einer ST evaluiert.

ANMERKUNG 3 In der Praxis kann eine ST, die Konformität mit einigen nicht evaluierten PP-Konfigurationen beansprucht, trotzdem evaluiert werden, indem zuerst die Evaluierung der PP-Konfiguration durchgeführt wird.

Eine ST-Evaluierung führt zu einem Zwischenergebnis, das im Rahmen von TOE-Evaluierungen verwendet werden kann. Optional dürfen die ST mit Ansprüchen auf Konformität mit Paketen, PP und PP-Konfigurationen entwickelt werden.

Evaluierungen zu STs/TOEs können zu Katalogen von evaluierten TOEs führen. In vielen Fällen beziehen diese Kataloge sich auf die IT-Produkte, aus denen die TOEs abgeleitet werden und nicht auf einen spezifischen TOE. Daher kann das Vorhandensein eines IT-Produkts in einem Katalog nicht so interpretiert werden, als ob dieses IT-Produkt in seiner Gesamtheit evaluiert wurde; die eigentliche ST definiert stattdessen den eigentlichen Umfang der TOE-Evaluierung.

Die Literaturhinweise enthalten Beispiele für solche Kataloge.

13.2 Evaluierungskontext

Um eine bessere Vergleichbarkeit der Evaluierungsergebnisse zu erreichen, sollten die Evaluierungen im Rahmen eines Evaluierungsprogramms durchgeführt werden.

ANMERKUNG 1 Die Normenreihe ISO/IEC 15408 enthält keine Aussagen zu solchen Evaluierungsprogrammen.

Eine bessere Vergleichbarkeit der Evaluierungsergebnisse wird auch durch die Verwendung gemeinsamer Evaluierungsmethoden erreicht, die zu diesen Evaluierungsergebnissen führen. Die Verwendung einer einheitlichen Evaluierungsmethodologie trägt zur Wiederholbarkeit und Objektivität der Ergebnisse bei, ist aber für sich genommen nicht ausreichend. Eine Vielzahl der Evaluierungskriterien erfordert die Beurteilung durch Experten und Hintergrundwissen; hierfür ist Konsistenz schwieriger zu erreichen. Um die Konsistenz von Evaluierungsfeststellungen zu verbessern, können die finalen Evaluierungsergebnisse an einen Zertifizierungsprozess übergeben werden.

ANMERKUNG 2 Die Normenreihe ISO/IEC 15408 enthält keine Anforderungen zur Bewertung der Kompetenzen von Entwicklern oder Evaluatoren. ISO/IEC 19896-3 enthält Kompetenzanforderungen für die Evaluatoren der Normenreihe ISO/IEC 15408, die als Unterstützung im Evaluierungsprozess verwendet werden können. Sie befasst sich jedoch nur mit grundlegenden Methodologiekompetenzen und geht nicht auf die Art und Weise der Bewertung der folgenden Kompetenzen ein:

- technologiebezogenes Wissen und Fähigkeiten, wie sie für die Durchführung von ADV-, ATE- oder AVA_VAN-Evaluierungen für einen bestimmten Produkttyp erforderlich sind;
- branchenspezifisches Wissen, das üblicherweise für die Durchführung einer ASE-, APE- oder ACE-Evaluierung erforderlich ist.

Darüber hinaus können spezifische Fertigkeiten, die für Evaluierungen in Übereinstimmung mit ISO/IEC 15408 erforderlich sind, zusätzliche Kompetenzbewertungsmethoden erfordern. Zum Beispiel, um die Fertigkeiten in Bezug auf formale Methoden zu bewerten.

Für die Normenreihe ISO/IEC 15408 ist die generische Methodologie für IT-Sicherheitsbewertungen in ISO/IEC 18045 enthalten. Spezifischere Evaluierungsmethoden und -aufgaben können aus ISO/IEC 18045 abgeleitet werden, indem das in ISO/IEC 15408-4 beschriebene Rahmenwerk verwendet wird, indem Standard-Vertrauenswürdigkeitskomponenten präzisiert oder indem erweiterte Vertrauenswürdigkeitskomponenten definiert werden.

Es kann für PP-Autoren notwendig sein, die in ISO/IEC 18045 angegebene generische Methodologie für IT-Sicherheitsbewertungen durch eine Methode zu ergänzen, die technologiespezifische Evaluierungsaufgaben beinhaltet.

Ein Zertifizierungsprozess, der außerhalb des Anwendungsbereichs der Normenreihe ISO/IEC 15408 liegt, kann eine unabhängige Prüfung der Evaluierungsergebnisse enthalten und führt zur Erstellung eines finalen Zertifikats oder einer finalen Genehmigung, die öffentlich zugänglich gemacht werden kann. Der Zertifizierungsprozess ist ein Mittel zum Erreichen von besserer Vergleichbarkeit in der Anwendung der IT-Sicherheitskriterien.

13.3 Evaluierung der PP und PP-Konfigurationen

Der Aufbau eines PP oder einer ST aus einem/einer evaluiertem PP/PP-Konfiguration hat zwei Vorteile:

- Das Risiko von Fehlern, Mehrdeutigkeiten oder Lücken im/in der PP/PP-Konfiguration ist viel geringer. Wenn irgendwelche Probleme damit während der Evaluierung dieses/dieser PP/PP-Konfigurationen gefunden wurden oder während des Verfassens oder der Evaluierung der neuen ST gefunden werden, kann viel Zeit bis zur Korrektur des/der PP/PP-Konfiguration vergehen;
- die Evaluierung des/der neuen PP/PP-Konfiguration kann die bisherigen Evaluierungsergebnisse wieder verwenden, was zu einem geringeren Aufwand bei der Evaluierung des/der neuen PP/PP-Konfiguration führt.

Ist die Evaluierung eines PP erforderlich, so müssen die in ISO/IEC 15408-3 aufgeführten APE-Kriterien verwendet werden.

Wenn die Evaluierung einer PP-Konfiguration erforderlich ist, müssen die in ISO/IEC 15408-3 angegebenen ACE-Kriterien verwendet werden.

Ziel solcher Evaluierungen ist der Nachweis, dass das PP bzw. die PP-Konfiguration vollständig, in sich widerspruchsfrei und technisch solide und angemessen für die Verwendung als Vorlage zum Aufbau einer ST oder eines weiteren PP ist.

Die Methode zur Angabe der Evaluierungsergebnisse für die PP und PP-Konfigurationen ist in 13.7 beschrieben.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01 prEN ISO/IEC 15408-1:2023 (D)

ANMERKUNG PP-Module werden nicht separat evaluiert, sondern im Zuge der Evaluierung der PP-Konfiguration, die sie verwendet.

13.4 Evaluierung von ST

Bei einer ST-Evaluierung wird die Hinlänglichkeit des TOE, der Betriebsumgebung und der internen Konsistenz der in der ST enthaltenen Beschreibungen und Anforderungen bestimmt.

Die ST-Evaluierung muss unter Anwendung der in ISO/IEC 15408-3 definierten ASE-Evaluierungskriterien durchgeführt werden. Die Methoden und Aufgaben, die zur Anwendung der ASE-Kriterien verwendet werden, werden durch die Evaluierungsmethodologie bestimmt, die mit der ST verbunden ist und in ISO/IEC 18045 festgelegt ist, oder durch Evaluierungsmethoden/-aufgaben, die von ISO/IEC 18045 abgeleitet sind. Abgeleitete Evaluierungsmethoden/Evaluierungsaufgaben werden außerhalb der Normenreihe ISO/IEC 15408 und ISO/IEC 18045 validiert.

Die Benutzer dieses Dokuments/dieser Normenreihe sollten sich darüber im Klaren sein, dass Evaluierungsprogramme nicht immer die Verwendung bestimmter Evaluierungsmethoden/Evaluierungsaufgaben zulassen. Eine ST kann Evaluierungsmethoden/Evaluierungsaufgaben vorschreiben, und ein Evaluierungsprogramm kann beschließen, keine Evaluierungen nach dieser ST durchzuführen.

Die Methode zur Angabe der ST-Evaluierungsergebnisse ist in 13.7 beschrieben. Diese Ergebnisse bestimmen auch alle PP und Pakete, für die die ST Konformität beansprucht.

13.5 Evaluierung von TOE

Bei einer TOE-Evaluierung wird die Korrektheit des TOE anhand der in der ST definierten Kriterien bestimmt. Wie bereits erwähnt, wird die Korrektheit der Betriebsumgebung bei der TOE-Evaluierung nicht bewertet.

Die TOE-Evaluierung ist komplexer. Die wesentlichen Inputs einer TOE-Evaluierung sind: der Evaluationsnachweis, der den TOE und die ST enthält, aber üblicherweise auch Input aus der Entwicklungsumgebung wie Design-Dokumente oder Testergebnisse von Entwicklern.

Die TOE-Evaluierung umfasst die Anwendung der SARs (aus der ST) auf den Evaluationsnachweis. Die Methode zur Anwendung einer bestimmten SAR auf einen TOE wird durch ISO/IEC 18045 und durch Evaluierungsmethoden/-aufgaben, die von ISO/IEC 18045 abgeleitet sind, bestimmt. Abgeleitete Evaluierungsmethoden/Evaluierungsaufgaben werden außerhalb der Normenreihe ISO/IEC 15408 und ISO/IEC 18045 validiert. Die Benutzer dieses Dokuments/dieser Normenreihe sollten sich darüber im Klaren sein, dass Evaluierungsprogramme nicht immer die Verwendung bestimmter Evaluierungsmethoden/Evaluierungsaufgaben zulassen. Eine ST darf Evaluierungsmethoden/Evaluierungsaufgaben vorschreiben, und ein Evaluierungsprogramm kann beschließen, keine Evaluierungen nach dieser ST durchzuführen.

Die Dokumentation der Ergebnisse aus der Anwendung der SARs, und welche Berichte in welchem Umfang erzeugt werden müssen, wird sowohl durch die verwendete Evaluierungsmethodologie als auch das eingesetzte Evaluierungsprogramm vorgegeben.

Die TOE-Evaluierung kann nach Abschluss der TOE-Entwicklung oder zeitgleich zur TOE-Entwicklung ausgeführt werden, vorausgesetzt, dass für diese Evaluierung die geeigneten Vertrauenswürdigkeitskomponenten ausgewählt werden.

Die Methode zur Angabe der ST-/TOE-Evaluierungsergebnisse ist in 13.7 beschrieben.

13.6 Evaluierungsmethoden und Evaluierungsaufgaben

Generische IT Evaluierungsmethoden und -aufgaben für jede der in ISO/IEC 15408-3 genannten Vertrauenswürdigkeitsklassen sind in ISO/IEC 18045 enthalten. Die in ISO/IEC 18045 angegebenen Evaluierungsmethoden und -aufgaben sind sehr allgemein gehalten. Je nach Art der Technologie, der Vertrauenswürdigkeits-

stufe oder des beschriebenen Sicherheitsproblems können spezifischere Evaluierungsmethoden und -aufgaben erforderlich sein.

Solche von ISO/IEC 18045 abgeleiteten Evaluierungsmethoden/Evaluierungsaufgaben dürfen entweder als Bestandteil in den PP, PP-Modulen und Paketen oder als separate Dokumente veröffentlicht werden.

13.7 Evaluierungsergebnisse

13.7.1 Ergebnisse einer PP-Evaluierung

Die Ergebnisse der PP-Evaluierung müssen einen „Konformitätsanspruch“ in Übereinstimmung mit 10.3 enthalten.

ANMERKUNG ISO/IEC 15408-3 enthält Evaluierungskriterien für die PP in der APE-Klasse.

13.7.2 Ergebnisse der Evaluierung einer PP-Konfiguration

Die Ergebnisse der Evaluierung einer PP-Konfiguration müssen einen „Konformitätsanspruch“ in Übereinstimmung mit 11.3 enthalten.

Sobald eine PP-Konfiguration evaluiert wurde, darf eine ST-Evaluierung auf den Ergebnissen der Evaluierung der PP-Konfiguration aufbauen.

ANMERKUNG 1 ISO/IEC 15408-3 enthält Evaluierungskriterien für die PP-Konfigurationen in der ACE-Klasse.

ANMERKUNG 2 Die Evaluierung einer PP-Konfiguration kann in zwei Situationen erfolgen, die keinen Einfluss auf die Evaluierungsmethodologie haben:

- unabhängig von einer Produktevaluierung, oder
- in einem ersten Schritt der Evaluierung einer ST, die Konformität mit der PP-Konfiguration beansprucht. Andernfalls ist der Konformitätsanspruch bedeutungslos, und die ST-Evaluierung würde in diesem Punkt versagen.

13.7.3 Ergebnisse einer ST-/TOE-Evaluierung

13.7.3.1 Allgemein

Die Ergebnisse einer ST-Evaluierung müssen, wie in 12.2 definiert, einen „Konformitätsanspruch“ enthalten.

Eine erfolgreiche TOE-Evaluierung erfordert eine erfolgreiche ST-Evaluierung. Das Ergebnis des TOE-Evaluierungsprozesses ist entweder

- eine Aussage, dass alle SARs erfüllt wurden und daher die angegebene Stufe an Vertrauenswürdigkeit, dass der TOE die in der ST angegebenen SFRs erfüllt, erreicht wird;
- eine Aussage, dass nicht alle SARs erfüllt wurden und daher die angegebene Stufe an Vertrauenswürdigkeit, dass der TOE die in der ST angegebenen SFRs erfüllt, nicht erreicht wird.

ANMERKUNG In manchen Fällen werden die Evaluierungsergebnisse in einem anschließenden Zertifizierungsprozess verwendet, aber dieser Zertifizierungsprozess liegt außerhalb des Anwendungsbereichs der Normenreihe ISO/IEC 15408.

Wenn die TOE-Evaluierung zu einer Aussage Bestanden geführt hat, kann das zugrundeliegende Produkt für die Aufnahme in einen Katalog erfolgreich evaluierter Produkte ausgewählt werden.

13.7.3.2 Verwendung der ST-/TOE-Evaluierungsergebnisse

Sobald eine ST und ein TOE evaluiert wurden, haben Eigentümer von Vermögenswerten die Zusicherung (wie in der ST definiert), dass der TOE im Verbund mit der Betriebsumgebung die angegebenen Bedro-

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01 prEN ISO/IEC 15408-1:2023 (D)

hungen abwehrt. Die Evaluierungsergebnisse können vom Eigentümer der Vermögenswerte als Teil einer Risikoakzeptanzentscheidung in Bezug auf die Aussetzung der Vermögenswerte gegenüber den Bedrohungen verwendet werden.

Die Eigentümer der Vermögenswerte sollten allerdings sorgfältig prüfen, ob

- a) die SPD in der ST mit ihrem eigenen Sicherheitsproblem übereinstimmt;
- b) deren Betriebsumgebungen mit den Sicherheitszielsetzungen für die in der ST beschriebene Betriebsumgebung konform ist (oder konform gestaltet werden kann);
- c) alle vom Entwickler im Rahmen der TOE-Evaluierung zur Verfügung gestellten Leitliniendokumente während der Installation, der Konfiguration und des Betriebs des TOE berücksichtigt werden.

Wenn eine dieser Bedingungen nicht zutrifft, kann man sich nicht auf die damit verbundene Vertrauenswürdigkeit verlassen, und die Evaluierungsergebnisse sollten bei einer Risikoakzeptanzentscheidung entsprechend behandelt werden.

Sobald ein evaluierter TOE in Betrieb ist, ist es außerdem wahrscheinlich, dass vorher unbekannte Fehler oder Schwachstellen in diesem TOE entdeckt werden. Dann kann der Entwickler den TOE korrigieren (um die Schwachstellen zu beseitigen) oder die ST so anpassen, dass die neu festgestellten Schwachstellen vom Anwendungsbereich der Evaluierung ausgeschlossen werden. In jedem Fall können die alten Evaluierungsergebnisse nicht länger gültig sein.

ANMERKUNG Falls die Vertrauenswürdigkeit aufrechterhalten werden soll, ist eine erneute Evaluierung notwendig. Die Normenreihe ISO/IEC 15408 kann für diese erneute Evaluierung verwendet werden, aber ausführliche Verfahren für erneute Evaluierungen liegen außerhalb des Anwendungsbereichs dieses Dokuments.

13.8 Evaluierung mit Mehrfach-Vertrauenswürdigkeit

Für eine PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit stellen die ACE-Anforderungen in ISO/IEC 15408-3 sicher, dass die Kombination verschiedener Sätze von SAR die erwartete Sicherheit der zugrundeliegenden Vermögenswerte, wie sie in den SPD der PP und PP-Module, aus denen die PP-Konfiguration besteht, definiert sind, nicht untergräbt.

Für eine ST mit Mehrfach-Vertrauenswürdigkeit stellen die in ISO/IEC 15408-3 aufgeführten ASE-Anforderungen sicher, dass die ST mit einer PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit, die die ACE-Vertrauenswürdigkeitsanforderungen erfüllt, konform ist. Dies bedeutet, dass die Organisation der TSF in Teil-TSF und die für sie geltenden SAR mit der PP-Konfiguration konsistent sind. Für jede Teil-TSF bedeutet dies, dass die ST mit Mehrfach-Vertrauenswürdigkeit einen Satz an SAR beansprucht, der mit dem in der PP-Konfiguration für die entsprechende Komponente (PP oder PP-Modul) festgelegten Satz an SAR identisch ist oder diesen ergänzt.

Das allgemeine Modell der Norm, das bei einer Evaluierung mit Mehrfach-Vertrauenswürdigkeit gilt, sieht vor, dass der Evaluator die TSF evaluiert, um die Sicherheit des TOE sicherzustellen. Im Zusammenhang mit der Mehrfach-Vertrauenswürdigkeit berücksichtigt der Evaluator bei der Evaluierung der einzelnen Teil-TSF weiterhin die Auswirkungen auf den gesamten TOE.

In der Praxis kann eine Evaluierung mit Mehrfach-Vertrauenswürdigkeit als mehrere Evaluierungen desselben TOE nach verschiedenen PP angesehen werden. Die Evaluierung mit Mehrfach-Vertrauenswürdigkeit fügt die Konsistenzprüfungen hinzu, die erforderlich sind, um sicherzustellen, dass diese Evaluierungen gemeinsam durchgeführt werden können. Dies bedeutet insbesondere, dass der Satz an SAR, der zu einer Teil-TSF gehört, keine Auswirkungen auf die anderen Teil-TSF hat. Daher können die für die SAR einer Teil-TSF geforderten Nachweise nicht durch die für die anderen Teil-TSF gewählten SAR beeinträchtigt werden.

BEISPIEL Angenommen, eine PP-Konfiguration wählt AVA_VAN.3 für eine Teil-TSF. ADV_TDS.3 wird dann aufgrund von Abhängigkeiten erforderlich sein. Bei der Evaluierung von ADV_TDS.3 für diese Teil-TSF werden definitionsgemäß alle Teilsysteme des TOE berücksichtigt, und zwar unabhängig von den ADV_TDS-Stufen der anderen im TOE definierten Teil-TSF.

Die Evaluierung mit Mehrfach-Vertrauenswürdigkeit eines TOE, der mit einer ST mit Mehrfach-Vertrauenswürdigkeit konform ist, besteht in der Evaluierung des gesamten TOE anhand des Gesamtsatzes an SAR und der Evaluierung jeder der Teil-TSF im Abgleich mit den entsprechenden Sätzen an SAR, wie sie in der ST definiert sind. Die Reihenfolge der Evaluierungsaufgaben ist dem Evaluator überlassen. Die geeignetste Reihenfolge hängt von Faktoren wie der tatsächlichen Struktur der TSF in Bezug auf die Teil-TSF und dem Unterschied zwischen dem Gesamtsatz von SAR und den Sätzen von SAR, die für die Teil-TSF gelten, ab.

Die Beschränkung der Evaluierung mit Mehrfach-Vertrauenswürdigkeit auf die TOE (und ST), die mit einer PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit konform sind, und die Definition der Konsistenzregeln für Mehrfach-Vertrauenswürdigkeit in ACE ermöglichen es, die Auswirkungen auf die anderen Vertrauenswürdigkeitsklassen zu begrenzen. Die Durchführung einer Evaluierung mit Mehrfach-Vertrauenswürdigkeit besteht in der Anwendung einer einheitlichen Interpretation aller Vertrauenswürdigkeitsklassen, wie sie in ISO/IEC 18405 definiert sind: Im Zusammenhang mit einer Evaluierung mit Mehrfach-Vertrauenswürdigkeit bezieht sich eine SAR, in der der TOE erwähnt wird, auf den gesamten TOE. Wenn in einer SAR von „TSF“ die Rede ist, bezieht sich dies auf die Teil-TSF, für die die SAR gilt.

Eine ST mit Mehrfach-Vertrauenswürdigkeit spiegelt die TSF-Organisation in den Teil-TSF wider, die in der PP-Konfiguration definiert sind, für die die ST Konformität beansprucht. Diese TSF-Organisation beschreibt nicht die Organisation der TOE-Implementierung in Teilsystemen und Modulen, sondern verbindet einen bestimmten Satz von Sicherheitsfunktionalitäten (Teil-TSF) mit bestimmten Vertrauenswürdigkeitsanforderungen. Es kann vorkommen, dass Teil-TSF von verschiedenen Mengen von Teilsystemen/Modulen implementiert werden, aber es kann auch ein gewisses Maß an Überschneidungen geben: ein Teilsystem oder Modul kann Funktionalitäten implementieren, die zu zwei verschiedenen Teil-TSF gehören. Dies bedeutet, dass die beiden Sätze an SAR für das gemeinsame Teilsystem oder Modul gelten (d.h. die Vereinigung der Sätze an SAR gilt). In beiden Fällen gehören für jede Teil-TSF alle anderen Teil-TSF zum TOE, und die entsprechenden Teilsysteme/Module müssen durch das Prisma der Anforderungen der Teil-TSF evaluiert werden.

14 Zusammensetzung der Vertrauenswürdigkeit

14.1 Allgemein

IT-Produkte setzen sich fast immer aus mehreren Komponenten zusammen, wobei einige von ihnen evaluiert werden und andere nicht. Unabhängige Produktkomponenten werden oft getrennt evaluiert, und es stellt sich die Frage, wie die Vertrauenswürdigkeiten der einzelnen Komponenten zusammengesetzt werden, um die Vertrauenswürdigkeit des gesamten Produkts zu bestimmen.

BEISPIEL Software wird mit evaluierter Hardware zu einem IT-Produkt zusammengestellt.

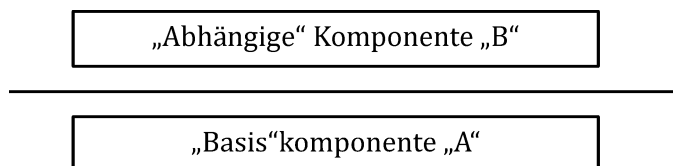
Die Zusammensetzung der Vertrauenswürdigkeit ist abhängig:

- von der Art der Zusammensetzung,
- von den Sicherheitsfunktionsrichtlinien und den OSP, auf denen die Evaluierung der Komponente beruhte;
- die beanspruchte Vertrauenswürdigkeit, z. B. die Vertrauenswürdigkeitsstufe;
- die allgemeinen Sicherheitsrichtlinien für das gesamte Produkt.

Die Konzepte der Zusammensetzungsmodelle werden in 14.2 beschrieben. Evaluierungsmethoden, mit denen die Vertrauenswürdigkeiten in solchen Zusammensetzungsmodellen berücksichtigt werden können, werden in 14.3 beschrieben. Überlegungen zur Wiederverwendung von Evaluierungsergebnissen, die sich auf einzelne Produktkomponenten im Zusammensetzungsansatz beziehen, werden in 14.4 behandelt. 14.5 befasst sich mit der Beziehung zwischen zusammengesetzten Evaluierungsansätzen und Ansätzen zur Evaluierung mit Mehrfach-Vertrauenswürdigkeit.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****14.2 Zusammensetzungsmodelle****14.2.1 Mehrschichtiges Zusammensetzungsmodell**

Bei dieser Art der Zusammensetzung wird eine Komponente auf eine andere Komponente aufgebaut, wie in Bild 11 zu sehen ist.

**Bild 11 — Mehrschichtiges Zusammensetzungsmodell**

Für das mehrschichtige Zusammensetzungsmodell werden die folgenden Annahmen getroffen:

- die Basiskomponente ist unabhängig von der abhängigen Komponente;
- die Basiskomponente wird durch die abhängige Komponente nicht verändert;
- die abhängige Komponente nutzt die Funktionalität der Basiskomponente und nicht umgekehrt.

Wer eine solche Zusammensetzung vornimmt, sollte berücksichtigen, dass:

- die abhängige Komponente von anderen Funktionen als den Sicherheitsfunktionen im Rahmen der Evaluierung der Basiskomponente abhängen kann;

Zur Verdeutlichung des in Bild 11 beschriebenen Modells der mehrschichtigen Zusammensetzung werden zwei Beispiele angeführt.

BEISPIEL 1 Das erste und wichtigste Beispiel stammt aus dem Bereich der Chipkarten, wo ein Evaluierungsverfahren für das mehrschichtige Zusammensetzungsmodell definiert wurde. In diesem Zusammenhang wird eine Chipkarte aus einer Kombination von zwei Teilen aufgebaut:

- einem Teil, der aus Hardware in Form einer integrierten Hardware-Schaltung (IC) (als Basiskomponente) besteht;
- einem darauf aufbauenden Softwareteil (als abhängiger Komponente).

Der Softwareteil kann von Funktionen abhängen, die nicht zu den evaluierten Sicherheitsfunktionen der zugrunde liegenden Hardware gehören. Im Allgemeinen sind jedoch fast alle Anweisungen der Hardware Teil der Sicherheitsfunktionalität der Hardware und werden zur Implementierung der Sicherheitsfunktionalität des Softwareteils verwendet.

Der Softwareteil der Chipkarte ist potentiell selbst mehrschichtig und besteht aus einer

- „Betriebssystem“-Schicht mit möglicherweise integrierter Anwendungsfunktionalität (als Basiskomponente),
- „Anwendungs“-Schicht, die verschiedene Anwendungen enthält (als abhängige Komponente).

Alle diese Teile können von verschiedenen Akteuren mit bestimmten Zielsetzungen entwickelt werden.

BEISPIEL 2 Anwendungen, die auf einem Personal Computer laufen, folgen demselben Grundsatz, wobei ein Betriebssystem (OS) als Basiskomponente und die Anwendungsschicht als abhängige Komponente fungieren: Die Anwendung verwendet die vom OS bereitgestellte Identifizierung und Authentifizierung, baut ihre eigenen Objekte auf dem OS-Dateisystem auf, baut ihre eigene Anwendungsstruktur auf der OS-Adressraumverwaltung und -trennung auf und muss bestimmte Eigenschaften (z. B. Fehlertoleranz, Informationsflusskontrolle) durchsetzen. Wurde das Betriebssystem bereits evaluiert, so kann die Sicherheitsfunktionalität der Anwendungsschicht auf die evaluierte Sicherheitsfunktionalität der Basiskomponente heruntergebrochen werden. Wenn dies nicht möglich ist, implementiert die abhängige Komponente die Sicher-

heitsfunktionalität selbst. Darüber hinaus kann die abhängige Komponente von Funktionen abhängen, die nicht zu den evaluierten Sicherheitsfunktionen der zugrunde liegenden Basiskomponente gehören.

14.2.2 Netzwerk- oder bi-direktionales Zusammensetzungsmodell

Bei dieser Art der Zusammensetzung nutzt eine Komponente die spezifische Funktionalität einer anderen Komponente, die über einen Kommunikationskanal kommuniziert, wie in Bild 12 dargestellt.

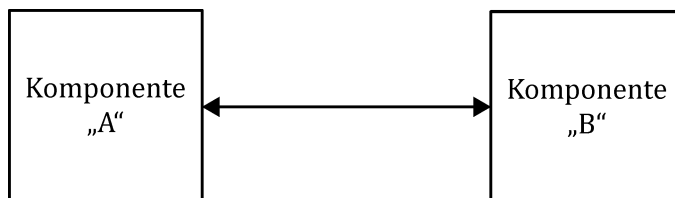


Bild 12 — Netzwerk- oder bi-direktionales Zusammensetzungsmodell

Für das Netzwerk- oder bi-direktionale Zusammensetzungsmodell werden die folgenden Annahmen getroffen:

- die Sicherheitsinterdependenzen sind klar beschrieben;
- beide Produkte sind so getrennt, dass es keinen anderen Kanal oder Einfluss als den festgelegten gibt;
- beide Produkte verfügen über die erforderliche Funktionalität zum Schutz des Kommunikationskanals.

BEISPIEL 1 Eine Anwendung (Komponente „A“), die die Funktionalität eines externen LDAP-Servers (Komponente „B“) nutzt.

Wer eine solche Zusammensetzung vornimmt, berücksichtigt, dass:

- die Sicherheitsfunktionen möglicherweise nicht zusammenpassen.

BEISPIEL 2 Die Zugangssteuerung kann sich auf verschiedene Objekte beziehen:

- Annahmen, die für ein Bauteil getroffen wurden, sind möglicherweise nicht gültig.

BEISPIEL 3 Annahme über den Schutz kritischer Daten, die an eine andere Komponente übertragen werden:

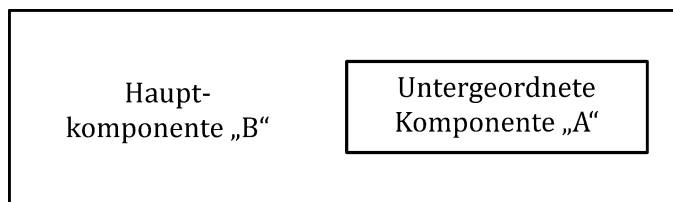
- Sicherheitsfunktionen können unerwünschte Nebeneffekte haben.

BEISPIEL 4 Ein verdeckter Kanal, durch den kryptographische Schlüssel entweichen.

Wenn derartige Probleme festgestellt werden, sollten sie zusammen mit der Festlegung geeigneter Abhilfemaßnahmen klar dokumentiert werden.

14.2.3 Eingebettetes Zusammensetzungsmodell

Bei dieser Art der Zusammensetzung wird eine Komponente als Teil einer größeren Komponente oder eines Produkts verwendet, wie in Bild 13 zu sehen ist.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01**
prEN ISO/IEC 15408-1:2023 (D)**Bild 13 — Eingebettetes Zusammensetzungsmodell**

Für das eingebettete Zusammensetzungsmodell werden die folgenden Annahmen getroffen:

- in der Regel gibt es keine Trennung zwischen den Komponenten;
- jeder Teil kann den anderen über andere als die vorgesehenen Kanäle und Schnittstellen beeinflussen.

BEISPIEL Eine Bibliothek oder ein Teilsystem, die/das bestimmte Sicherheitsfunktionen als Teil eines größeren Produkts bereitstellt.

Wer eine solche Zusammensetzung vornimmt, sollte berücksichtigen, dass aufgrund der fehlenden Trennung die Komponenten potentiell:

- die Sicherheitsfunktionalität der anderen Komponenten umgehen;
- die Sicherheitsfunktionalität und die Sicherheitsrichtlinie anderer Komponenten und des gesamten Produkts ändern;
- eine Reihe kritischer Nebeneffekte mit sich bringen.

ANMERKUNG Wenn eine Trennung angegeben ist, beschreibt ADV_ARC in ISO/IEC 15408-3 die Kriterien für die Evaluierung.

14.3 Evaluierungstechniken für die Vertrauenswürdigkeit von Zusammensetzungsmodellen

14.3.1 Allgemein

Um zuverlässige und wiederholbare Evaluierungsergebnisse für die Evaluierung von IT-Produkten (TOE) zu erhalten, die die in 14.2 beschriebenen Zusammensetzungsmodelle verwenden, ist eine entsprechende, angemessen definierte Evaluierungsmethode erforderlich.

14.3.2 und 14.3.3 befassen sich mit Evaluierungstechniken für das Modell der mehrschichtigen Zusammensetzung. 14.3.2 beschreibt, wie die in ISO/IEC 15408-3 definierte ACO-Klasse für zusammengesetzte TOE verwendet werden kann, und in 14.3.3 wird ein Evaluierungsverfahren für Verbundprodukte vorgestellt, das in der Industrie bereits weitgehend angewandt wird und zahlreiche Vorteile aufweist (siehe 14.3.3.1).

Die beiden anderen Zusammensetzungsmodelle (d.h. bi-direktional und eingebettet) werden nicht explizit durch Konstrukte behandelt, die in der Normenreihe ISO/IEC 15408 definiert sind.

14.3.2 ACO-Klasse für zusammengesetzte TOE

Die in ISO/IEC 15408-3 festgelegte ACO-Klasse befasst sich mit einem TOE, der aus zwei TOE besteht, die ein mehrschichtiges Zusammensetzungsmodell, wie in 14.2 beschrieben, verwenden, wobei beide getrennt evaluiert wurden. Diese Komponenten-TOE können als Basis-TOE und als abhängiger TOE beschrieben werden, wie in Bild 14 dargestellt. In einem solchen Fall wird die ACO-Klasse für die Evaluierung des zusammengesetzten TOE verwendet.

Eine Evaluierung eines solchen zusammengesetzten TOE besteht in der Evaluierung der Interaktion zwischen den beiden TOE, wobei eine Wiederverwendung der Evaluierungsergebnisse sowohl des Basis-TOE als auch des abhängigen TOE stattfindet.

ISO/IEC 15408-5 enthält vordefinierte CAP, die zur Bestimmung der Vertrauenswürdigkeitsstufe des zusammengesetzten TOE verwendet werden können.

Die ACO-Klasse ist bis zur Vertrauenswürdigkeitsstufe „Enhanced-Basic“ anwendbar.

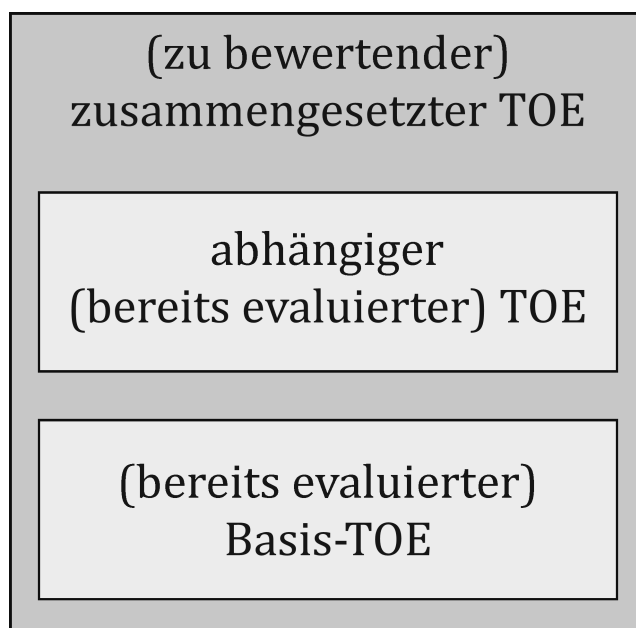


Bild 14 — Unter Verwendung der ACO-Klasse evaluierter zusammengesetzter TOE

14.3.3 Verbundevaluation für Verbundprodukte

14.3.3.1 Allgemein

Das Verfahren der Verbundevaluation orientiert sich an dem in 14.2 beschriebenen Modell der mehrschichtigen Zusammensetzung von Verbundprodukten und wurde entwickelt, um die folgenden Zielsetzungen zu erfüllen:

- unabhängig die Evaluierung einer Basiskomponente durchführen, um mehrere abhängige Komponenten und Kunden zu berücksichtigen;
- eine oder mehrere abhängige Komponente(n) zur Verwendung mit einer evaluierten Basiskomponente erstellen;
- eine abhängige Komponente auf eine evaluierte Basiskomponente installieren, um den Evaluierungsaufwand zu verringern und gleichzeitig ein hohes Maß an Vertrauen zu erhalten.

Die Technik der Verbundevaluation beschreibt einen Weg, den Wissenstransfer und die Wiederverwendung von Nachweisen durchzuführen, um diese Zielsetzungen zu erreichen.

Die in ISO/IEC 15408-3 für die Klassen ADV, ALC, ASE, ATE und AVA festgelegten COMP-Vertrauenswürdigkeitsfamilien bieten Evaluierungskriterien für Verbundprodukte, die dieses Schichtenmodell verwenden.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****14.3.3.2 Zielsetzungen**

Diese Methode für die Zusammensetzung der Vertrauenswürdigkeit gilt für mehrschichtige Produkte, die eine unabhängige evaluierte Basiskomponente und eine abhängige Komponente umfassen.

ANMERKUNG Eine abhängige Komponente kann aus einer oder mehreren abhängigen Teilkomponenten bestehen. Zur Vereinfachung werden sie im Folgenden als „eine abhängige Komponente“ betrachtet.

Das Verbundprodukt besteht aus der Integration der bereits evaluierten Basiskomponente (einschließlich ihres Basis-TOE) und der abhängigen Komponente. Dabei ist der Basis-TOE Teil des Verbund-TOE. Bei dem Ansatz der Verbundevaluation werden die bereits für den Basis-TOE erzielten Evaluierungsergebnisse wiederverwendet, und die Evaluierung der abhängigen Komponente wird im Rahmen der Evaluierung des Verbundprodukts durchgeführt, wobei insbesondere die Evaluierung der Beziehung zwischen dem Basis-TOE und der abhängigen Komponente im Vordergrund steht. Daher wird eine Vertrauenswürdigkeitsstufe für das Verbundprodukt als Ganzes und nicht nur für die abhängige Komponente beansprucht und gilt für diese.

Das Verbundprodukt mit seiner Basiskomponente (einschließlich des Basis-TOE) und seiner abhängigen Komponente soll effizient evaluiert werden. Die spezifische Technik der Verbundevaluation wurde mit dem Ziel entwickelt, die Evaluierung eines solchen Verbundprodukts zu optimieren.

Im Gegensatz zur ACO-basierten Evaluierung ermöglicht dies einen direkten Vergleich mit ähnlichen Produkten, die ohne Verwendung von Zusammensetzungstechniken auf einmal evaluiert werden. Darüber hinaus gibt es keine Begrenzung der Vertrauenswürdigkeitsstufe, d. h. das Verbundprodukt kann jede vordefinierte EAL oder jedes wohldefinierte Vertrauenswürdigkeitspaket beanspruchen, einschließlich der Widerstandsfähigkeit bis zu „High attack potential“, wie in ISO/IEC 15408-3 AVA_VAN.5 definiert, wohingegen ACO durch die CAP-Anforderungen bis zum Angriffspotential „Enhanced-Basic“ begrenzt ist. Ziel ist es nicht, eine zusätzliche Vertrauenswürdigkeitsklasse zu definieren, sondern zusätzliche Vertrauenswürdigkeitsanforderungen für eine Verbundevaluation festzulegen.

BEISPIEL Beispiele für Chipkartengeräte, die ein hohes Maß an Vertrauenswürdigkeit erfordern, sind Anwendungen für Zahlungen und digitale Signaturen.

14.3.3.3 Design eines Verbundprodukts und eines Verbund-TOE

Das Verbundprodukt besteht aus einer Basiskomponente (einschließlich ihres Basis-TOE) und einer abhängigen Komponente, wobei im Hinblick auf Evaluierungsaspekte die folgenden Regeln und Einschränkungen für das Verbundprodukt und seinen Teil des Verbund-TOE gelten:

- die Basiskomponente bildet die zugrunde liegende unabhängige Schicht des Verbundprodukts und enthält den Basis-TOE. Die Basiskomponente mit ihrem Basis-TOE muss bereits evaluiert worden sein;
- die abhängige Komponente bildet eine ergänzende Schicht des Verbundprodukts, die von der Basiskomponente abhängt und die im Rahmen der Verbundevaluation evaluiert werden muss;
- der Verbund-TOE ist Teil des Verbundprodukts und deckt die gesamte abhängige Komponente und den Basis-TOE ab, wobei für die korrekte und sichere Ausführung des Verbundprodukts eine detailliertere Obermenge der Funktionalitäten des Basis-TOE erforderlich ist;

ANMERKUNG 1 Ein Verbund-TOE kann Teile enthalten, die von der Basiskomponente bzw. dem Basis-TOE unabhängig sind. Zur Vereinfachung werden solche Teile als zur abhängigen Komponente gehörig betrachtet.

- die abhängige Komponente kann sich nicht auf Funktionalitäten der Basiskomponente stützen, die in der Basiskomponente enthalten sind, aber außerhalb des Basis-TOE liegen (d. h. Funktionalitäten im Nicht-TOE-Teil der Basiskomponente);
- der Nicht-TOE-Teil des Verbundprodukts kann Funktionalitäten von Basiskomponenten-, insbesondere Basis-TOE-Funktionalitäten, verwenden. Wie üblich muss bei der Verbundevaluation festgestellt werden,

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

dass dieser Nicht-TOE-Teil des Verbundprodukts die abhängige Komponente nicht beeinträchtigt – weder direkt noch durch die Nutzung der Funktionalitäten der Basiskomponente;

- Nicht-TOE-Teile des Verbundprodukts, insbesondere Nicht-TOE-Teile der evaluierten Basiskomponente (d. h. Teile in der Basiskomponente, die außerhalb des Basis-TOE liegen), werden als Teil der Betriebsumgebung des Verbund-TOE betrachtet.

ANMERKUNG 2 Die Verbundevaluation ist unabhängig von der EAL für das angestrebte Verbundprodukt anwendbar. Wenn einige Evaluierungsaufgaben aufgrund der gewählten EAL nicht anwendbar sind, wird auch nicht erwartet, dass sie angewendet werden.

ANMERKUNG 3 Dieses Dokument behandelt nur die Fälle, in denen die Vertrauenswürdigkeitsstufe der Basiskomponente der Vertrauenswürdigkeitsstufe der Verbundevaluation entspricht oder höher als diese ist.

ANMERKUNG 4 Wenn sowohl die Basiskomponente als auch die abhängige Komponente bereits anhand der Normenreihe ISO/IEC 15408 evaluiert wurden, kann die Verbundevaluation auf den Ergebnissen der vorangegangenen Evaluierung der Basiskomponente und der vorangegangenen Evaluierung der abhängigen Komponente beruhen. Dennoch muss die in diesem Dokument definierte Zielsetzung der Verbundevaluation noch erreicht werden.

Bild 15 veranschaulicht das allgemeine Design und die Schichtung eines Verbundprodukts und eines Verbund-TOE im Rahmen des Ansatzes der Verbundevaluation.

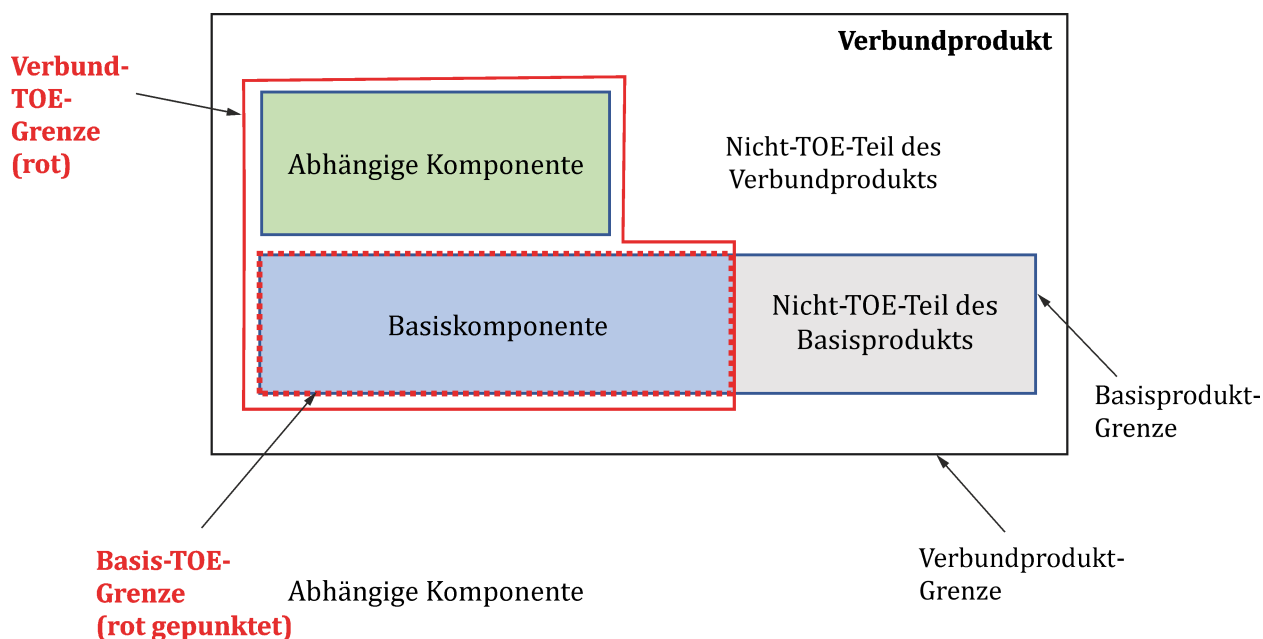


Bild 15 — Verbundevaluation

Es können mehrere Zusammensetzungsschritte aufeinander folgen. Mit anderen Worten: Die Basiskomponente kann selbst ein Verbundprodukt sein, das aus einer eigenen, bereits evaluierten Basiskomponente und einer abhängigen Komponente besteht.

14.3.3.4 Rollen

Die Basiskomponente und das Verbundprodukt, genauer gesagt der Basis-TOE und der Verbund-TOE, werden beide einer Evaluierung unterzogen. Daher haben beide einen Antragsteller, einen Entwickler, einen Evaluator und eine Evaluierungsinstanz.

Für das Modell der Verbundevaluation, das sich mit der Evaluierung des Verbundprodukts befasst, wird eine vorhergehende abgeschlossene Evaluierung der Basiskomponente mit ihrem Basis-TOE erwartet. Die

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Verbundevaluation führt die Evaluierung des Verbundprodukts durch, indem sie die Evaluierungsergebnisse der bereits evaluierten Basiskomponente wiederverwendet. Daher konzentriert sich die Evaluierung des Verbundprodukts auf die Evaluierung der abhängigen Komponente einschließlich ihrer Beziehung zur Basiskomponente und berücksichtigt dabei den Basis-TOE mit seinen zugehörigen Evaluierungsergebnissen.

In der Praxis gibt es keinen Entwickler für Verbundprodukte, da das Verbundprodukt durch die Integration der abhängigen Komponente und der Basiskomponente entsteht. Stattdessen sind die relevanten entwicklungsbezogenen Rollen hier:

- der Entwickler für die abhängige Komponente, der für die Implementierung der abhängigen Komponente (und ggf. weiterer Nicht-TOE-Teile des Verbundprodukts) verantwortlich ist;
- der Entwickler für die Basiskomponente, der für die Implementierung der Basiskomponente verantwortlich ist;
- der Integrator für das Verbundprodukt, der für die Integration der Basiskomponente und der abhängigen Komponente verantwortlich ist.

Um diesem Rollenmodell gerecht zu werden, definieren der Ansatz und die Technik der Verbundevaluation zusätzliche Evaluierungsaufgaben für den oben erwähnten Entwickler der abhängigen Komponente, den Entwickler der Basiskomponente und den Integrator des Verbundprodukts.

ANMERKUNG 1 Wie bereits erwähnt, kann die abhängige Komponente einer separaten Evaluierung unterzogen worden sein, aber der Evaluator und die Evaluierungsinstanz dieser früheren Evaluierung werden hier nicht berücksichtigt. Würden die Basiskomponente und die abhängige Komponente getrennt evaluiert, gäbe es für jede Komponente einen Antragsteller, einen Entwickler, einen Evaluator und eine Evaluierungsinstanz.

ANMERKUNG 2 Wie in den allgemeinen Fällen können einige der beteiligten Akteure dieselben sein. Der Kontext der Verbundevaluation führt auch zu bestimmten Fällen von Akteuren mit mehreren Rollen. Bei jeder Evaluierung werden bestimmte Organisationen oder Personen mit diesen allgemeinen Rollen zugeordnet.

BEISPIEL 1

- Der Entwickler für die Basiskomponente kann auch der Antragsteller für die Basiskomponente sein;
- die Evaluierungsinstanz für die Basiskomponente kann auch die Evaluierungsinstanz für das Verbundprodukt sein.

ANMERKUNG 3 Der Integrator von Verbundprodukten ist eine andere Rolle als der Entwickler. Auch wenn dieser Integrator in einigen Fällen einer der zuvor definierten Entwickler sein kann, ist dies nicht immer der Fall.

Das folgende Beispiel veranschaulicht die Rolle des Integrators von Verbundprodukten:

BEISPIEL 2

- **Native Chipkarten:** Die zugrunde liegende Basiskomponente ist eine integrierte Schaltung und der Entwickler der Basiskomponente ist der Hersteller der integrierten Schaltung (Chip); die abhängige Komponente besteht aus einem Kartenbetriebssystem und dessen Anwendung(en) und der Entwickler der abhängigen Komponente ist der Entwickler des Chipkartenbetriebssystems und der Anwendung(en). In diesem Fall wird die Rolle des Integrators von Verbundprodukten von den folgenden Akteuren übernommen:
 - dem Chip-Hersteller, der den Kern des Betriebssystems in das ROM des Chips einbettet, dann von;
 - dem Kartenhersteller, der in der Regel einige Teile des Betriebssystems und der Anwendungen in die nichtflüchtigen -Speicher (EEPROM und/oder Flash) des Chips lädt.
- **Geräte, die die Java Card-Technologie unterstützen:** Die zugrundeliegende Basiskomponente ist das Java Card System (Java Card Runtime Environment, Virtual Machine und API) auf dem Chip und der Entwickler der Basiskomponente ist der Kartenhersteller/-ausgeber; die abhängige Komponente ist ein Java Card Applet, das von einem Applet-Entwickler

entwickelt werden kann, der die Rolle des Entwicklers der abhängigen Komponente übernimmt. In diesem Fall kann die Rolle des Integrators von Verbundprodukten vom Anbieter von Domänen-/Anwendungsdiensten oder von einem Trustcenter übernommen werden, das das Applet lädt und die Karte häufig elektronisch personalisiert.

14.3.3.5 Aktionselemente und erforderliche Informationen

Um die Evaluierung eines Verbundprodukts zu ermöglichen, identifiziert die Technik der Verbundevaluation zwei Hauptgruppen von Fragen, die zu den folgenden Regeln führen:

- Das Verbundprodukt kann aufgrund von Lücken bei der Definition, der Integration oder der Prüfung der Sicherheitsmechanismen der Basiskomponente und der abhängigen Komponenten unsicher sein. Insbesondere müssen die folgenden Eigenschaften durchgesetzt werden:
 - die zu schützenden Vermögenswerte sind die Vermögenswerte des endgültigen Verbundprodukts, die in einem speziellen Verbundprodukt definiert sind und zwar als ST;
 - die Sicherheitsmechanismen, die zum Schutz dieser Vermögenswerte beitragen, sind diejenigen, die von der Basiskomponente und der abhängigen Komponente bereitgestellt werden;
 - einige der von der Basiskomponente bereitgestellten Sicherheitsmechanismen und Sicherheitsdienste können eine Konfiguration, Programmierung oder Aktivierung durch die abhängige Komponente erfordern, wie sie für den Basis-TOE zulässig ist;
 - die Evaluierung wird am endgültigen Verbundprodukt durchgeführt und validiert.

Zu diesem Zweck definiert die Technik der Verbundevaluation bestimmte Aktionselemente, die von den an der Evaluierung der Basiskomponente sowie an der Entwicklung der abhängigen Komponente und an der Evaluierung des Verbundprodukts beteiligten Akteuren durchzuführen sind.

- Die oben genannten Aktionselemente sind aufgrund des mangelnden Informationsaustauschs zwischen den Akteuren potentiell nicht durchführbar. Um dies zu vermeiden, legt die Technik der Verbundevaluation ausdrücklich fest, welche Informationen für jedes Aktionselement erforderlich sind.

Tabelle 2 und Tabelle 3 legen fest, welche SAR in der Verbundprodukt-ST ausgewählt werden müssen und welche Informationen dem Entwickler der abhängigen Komponente, dem Evaluator des Verbundprodukts und der Evaluierungsinstanz für das Verbundprodukt zur Verfügung stehen müssen, um eine Verbundevaluation zu ermöglichen und zu unterstützen.

Tabelle 2 — Informationen, die dem Entwickler der abhängigen Komponente zur Verfügung zu stellen sind

SAR zur Festlegung der Aktionselemente	Erforderliche Informationen	Urheber der Informationen
„Consistency of composite product Security Target (Konsistenz der Sicherheitsvorgaben des Verbundprodukts) (ASE_COMP)“	ST der Basiskomponente Informationen zur Erstellung des Verbundprodukts ST und zur Sicherstellung der Konsistenz der Sicherheitsdefinition zwischen der Basiskomponente und der abhängigen Komponente. Informationen, die sich auf die Sicherheitsmechanismen und Sicherheitsdienste der Basiskomponente beziehen, die die abhängige Komponente zu verwalten oder zu nutzen hat.	Entwickler der Basiskomponente
„Composite design compliance“ (Compliance des Verbunddesigns) (ADV_COMP)	Informationen (in der Regel in Form von Leitlinien oder Benutzerhandbüchern), die sich auf die Sicherheitsmechanismen und Sicherheitsdienste der Basiskomponente beziehen, die die abhängige Komponente zu verwalten oder zu nutzen hat.	Entwickler der Basiskomponente

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

Möglicherweise benötigt der Evaluator des Verbundprodukts nicht alle detaillierten Ergebnisse der Evaluierung der Basiskomponente, um eine Verbundevaluation eines Verbundprodukts durchzuführen, das eine solche evaluierte Basiskomponente integriert. Für die Wiederverwendung der Evaluierungsergebnisse der Basiskomponente benötigt der Evaluator des Verbundprodukts jedoch ergänzende Informationen über die Vertrauenswürdigkeitsmaßnahmen, wenn sich die Basiskomponente und die abhängige Komponente überschneiden. Insbesondere für die Untersuchung, ob die abhängige Komponente die von der Basiskomponente auferlegten Sicherheitsanforderungen erfüllt, und für die Schwachstellenanalyse des Verbundprodukts nutzt der Evaluator des Verbundprodukts die Benutzerführung der evaluierten Basiskomponente, den zugehörigen Bericht der für die Evaluierung der Basiskomponente zuständigen Instanz (d. h. den Bericht für ein evaluiertes Produkt, der die Akzeptanz der vom Evaluator vorgelegten Evaluierungsergebnisse bestätigt) und den in 14.3.3.6 beschriebenen sogenannten „*ETR for composite evaluation*“ (ETR_COMP).

Alles in allem werden für die Anwendung der Technik der Verbundevaluation zusätzlich zu der Standardmenge an Informationen, die das für die Verbundevaluation gewählte Vertrauenswürdigkeitspaket (z. B. eine EAL) verlangt, die folgenden Angaben wie in Tabelle 3 skizziert benötigt.

Tabelle 3 — Informationen, die dem Evaluator für Verbundprodukte und der Evaluierungsinstanz für Verbundprodukte zur Verfügung zu stellen sind

SAR zur Festlegung der Aktionselemente	Erforderliche Informationen	Urheber der Informationen
Konsistenz des Verbundprodukts „Security Target“ (Sicherheitsvorgabe) (ASE_COMP)	ST der Basiskomponente	Entwickler der Basiskomponente
	Informationen über das Verbundprodukt ST zur Sicherstellung der Konsistenz der Sicherheitsdefinition zwischen der Basiskomponente und der abhängigen Komponente. Informationen, die sich auf die Sicherheitsmechanismen und Sicherheitsdienste der Basiskomponente beziehen, die die abhängige Komponente zu verwalten oder zu nutzen hat.	
	ST des Verbundprodukts (einschließlich Informationen über die Kompatibilität der ST des Verbundprodukts mit der ST der Basiskomponente).	Entwickler der abhängigen Komponente
„Integration of composition parts and consistency check of delivery procedures“ (Integration von Zusammensetzungsteilen und Konsistenzprüfung von Auslieferungsverfahren) (ALC_COMP)	Nachweis für eine Verbundkonfiguration. Organisatorischer Nachweis der Versionsrichtigkeit auf der Grundlage seiner Konfigurationslisten mit eindeutigen Versionsinformationen der evaluierten Basiskomponente und der abhängigen Komponente, die in das Verbund-Endprodukt integriert wurden. Elemente, mit denen nachgewiesen wird, dass die vom Entwickler der Basiskomponente und vom Entwickler der abhängigen Komponente vorgeschriebenen Sicherheitsmaßnahmen vom Integrator des Verbundprodukts tatsächlich angewendet werden.	Integrator des Verbundprodukts
	Nachweis von Liefer- und Abnahmeverfahren. Informationen über die Compliance der Auslieferungsverfahren des Entwicklers der Basiskomponente und des Entwicklers der abhängigen Komponente mit dem Abnahmeverfahren des Integrators des Verbundprodukts. Organisatorischer Nachweis, dass Komponenten (abhängige Komponente und Basiskomponente), die von einem Akteur an einen anderen übermittelt werden, sicher empfangen, abgenommen und parametrisiert werden.	Integrator des Verbundprodukts Entwickler der Basiskomponente Entwickler der abhängigen Komponente

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****Tabelle 3 (fortgesetzt)**

SAR zur Festlegung der Aktionselemente	Erforderliche Informationen	Urheber der Informationen
„Composite design compliance“ (Compliance des Verbunddesigns) (ADV_COMP)	Anforderungen und Empfehlungen zur Integration von Basiskomponenten, in der Regel einschließlich der Benutzerführung.	Entwickler der Basiskomponente
	<i>ETR für eine Verbundevaluation.</i> Anforderungen und Empfehlungen zur Integration von Basiskomponenten.	Evaluator der Basiskomponente
	Nachweis der Compliance mit dem Design. Nachweis darüber, dass das Verbundprodukt die Anforderungen und Empfehlungen zur Integration der Basiskomponenten erfüllt. Sie enthält Nachweise darüber, wie die Anforderungen an das Design der abhängigen Komponente, die in der Benutzerführung der Basiskomponente und im Bericht der für die Evaluierung der Basiskomponente zuständigen Instanz festgelegt sind, im Verbundprodukt erfüllt werden. Wurde eine solche Anforderung nicht erfüllt, so muss hier eine Begründung dafür vorgelegt werden, dass die Implementierung des gewählten Verbundprodukts dennoch sicher ist.	Integrator des Verbundprodukts Entwickler der abhängigen Komponente
	Bericht zur Evaluierung der Basiskomponente, der von der Evaluierungsinstanz für Basiskomponenten erstellt wird. (Zusätzliche) Anforderungen und Empfehlungen zur Integration von Basiskomponenten.	Evaluierungsinstanz für Basiskomponenten
„Composite functional testing“ (Funktionsprüfung von Verbund) (ATE_COMP)	Zum Prüfen geeignete Verbundproduktproben.	Integrator des Verbundprodukts
„Composite vulnerability assessment“ (Bewertung der Anfälligkeit von Verbundprodukten) (AVA_COMP)	<i>ETR für eine Verbundevaluation.</i> Nachweise, die es dem Evaluator des Verbundprodukts und der jeweiligen Evaluierungsinstanz ermöglichen, die Angriffspfade und die Prüfungen, die für die Basiskomponente in Betracht gezogen und durchgeführt wurden, sowie die Wirksamkeit der von der Basiskomponente implementierten Gegenmaßnahmen zu verstehen, sowie Erläuterungen zu den verbleibenden Schwachstellen der Basiskomponente in Verbindung mit den in der Benutzerführung der Basiskomponente enthaltenen Integrationsempfehlungen.	Evaluator der Basiskomponente
	Bericht zur Evaluierung der Basiskomponente, der von der Evaluierungsinstanz für Basiskomponenten erstellt wird. (Zusätzliche) Anforderungen und Empfehlungen, Verpflichtungen, Informationen über Schwachstellen zur Integration von Basiskomponenten.	Evaluierungsinstanz für Basiskomponenten
	Die auf die Basiskomponente bezogene Benutzerführung.	Entwickler der Basiskomponente

ANMERKUNG Der von der für die Evaluierung von Basiskomponenten zuständigen Instanz erstellte Bericht über die Evaluierung von Basiskomponenten kann auch für die SAR ASE_COMP, ALC_COMP und ATE_COMP relevant sein, selbst wenn er in Tabelle 3 nicht direkt angesprochen wird.

Im Falle der Zusammensetzung muss der Begriff „Entwickler“ weiter geklärt werden, um die Akteure zu unterscheiden. Dabei kann es sich beim Entwickler der Basiskomponente, dem Entwickler der abhängigen Komponente und dem Integrator des Verbundprodukts um unterschiedliche Entitäten handeln. Auch bei den Begriffen „Evaluator“ und „Evaluierungsinstanz (Evaluierungsprogramm)“ ist eine weitere Unterscheidung zwischen den verschiedenen beteiligten Entitäten vorzunehmen.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Wenn sowohl die Basiskomponente als auch die abhängige Komponente bereits evaluiert wurden, reicht es unter Umständen aus, eine geringere Anzahl von Evaluierungsaufgaben durchzuführen, wenn man die bereits aus der vorangegangenen Evaluierung der abhängigen Komponente gewonnenen Ergebnisse berücksichtigt. Dennoch müssen die in diesem Dokument definierten Aufgaben einer Verbundevaluation noch erreicht werden.

BEISPIEL Chipkarte.

Die Chipkartenarchitektur besteht aus einer Hardwareplattform und einer darauf aufbauenden Softwareanwendung. In diesem Fall ist die Plattform die Basiskomponente, und die Anwendung ist die abhängige Komponente. Bei einer Verbundevaluation wird die Plattform bereits evaluiert, die Anwendung wird als Teil der Verbundevaluation evaluiert und die Ergebnisse der Plattformevaluierung werden wiederverwendet.

Die Hardwareplattform bietet Funktionen, die den Schutz der Vermögenswerte des Verbundprodukts unterstützen; das Verhalten des Verbundprodukts hängt jedoch von der Softwareanwendung ab, die die Sicherheitsfunktionen nutzen, konfigurieren und aktivieren muss.

Daher bieten die Ergebnisse der Evaluierung der Hardwareplattform in der Regel spezifische Sicherheitsempfehlungen und -bedingungen für die Implementierung der Softwareanwendung. Im Rahmen der Verbundevaluation wird auch untersucht, ob die Kombination der beiden Komponenten zu keiner ausnutzbaren Anfälligkeit führt.

Es werden eine Methode für die Verbundevaluation und zugehörige Evaluierungsaufgaben bereitgestellt, die genaue Workunits mit klaren Aussagen zu den vom Plattformentwickler geforderten Informationen enthalten und einen vereinbarten „Rahmen“ für den Informationstransfer vom Plattformevaluator zum Evaluator des Verbundprodukts bieten.

Die erforderlichen Informationen sind bereits aus den Evaluierungsaufgaben der Plattform bekannt und erfordern keine zusätzliche Arbeit seitens des Plattformentwicklers.

Für die Entwicklungsklasse ADV gibt es keine weiteren Anforderungen.

Die Benutzerführung (AGD) der Plattform wird bereits in einem frühen Stadium der Entwicklung des Verbundprodukts berücksichtigt und bietet alle Schnittstellen, zu denen Informationen benötigt werden.

Die Entwicklung und die Evaluierung des Verbundprodukts hängen von der korrekten Implementierung der evaluierten Schnittstellen der Plattform ab.

Die ordnungsgemäße Nutzung aller relevanten Schnittstellen zwischen der Plattform und der Anwendung ist Gegenstand der Verbundevaluation.

Prüfung (ATE) und Schwachstellenbewertung (AVA) werden für das Verbundprodukt unter Nutzung der verfügbaren Ergebnisse der Plattformevaluierung durchgeführt.

14.3.3.6 ETR für Verbundevaluation (ETR_COMP)

14.3.3.6.1 Zielsetzung des Dokuments

Das Dokument *ETR for composite evaluation* (ETR_COMP) wird aus dem Technischen Evaluierungsbericht (ETR) zu einer Basiskomponente und deren Evaluierung zusammengestellt, um ausreichende Informationen für eine Verbundevaluation mit einer solchen bereits evaluierten Basiskomponente bereitzustellen.

ANMERKUNG 1 Ein Standard-ETR enthält in der Regel geschützte Informationen über die Basiskomponente und ihre Evaluierung, die nicht veröffentlicht werden dürfen. Ein solcher vollständiger ETR ist daher möglicherweise nicht für eine externe Auslieferung geeignet. Die im ETR_COMP-Dokument enthaltenen Informationen stellen eine sinnvolle Teilmenge der Informationen dar, die im vollständigen ETR der Basiskomponente zur Unterstützung einer Verbundevaluation bereitgestellt werden.

Ziel des ETR_COMP-Dokuments ist es, den Evaluator des Verbundprodukts und die Evaluierungsinstanz für das Verbundprodukt in die Lage zu versetzen, die Angriffspfade und die Prüfungen, die für die Basiskomponente in Betracht gezogen und durchgeführt wurden, sowie die Wirksamkeit der von der Basiskomponente implementierten Gegenmaßnahmen zu verstehen.

ANMERKUNG 2 Der Inhalt des ETR_COMP-Dokuments stellt ein ausgewogenes Verhältnis zwischen dem Schutz der geheimen Informationen des Entwicklers der Basiskomponente und/oder des Evaluators der Basiskomponente einerseits sowie der Bereitstellung ausreichender Informationen für den Evaluator des Verbundprodukts und die Evaluierungsinstanz für das Verbundprodukt andererseits dar.

14.3.3.6.2 Verfahren

Der ETR_COMP wird vom Evaluator der Basiskomponente auf der Grundlage der Evaluierungsergebnisse der Basiskomponente erstellt und aus dem vollständigen ETR für die Evaluierung der Basiskomponente abgeleitet.

Der ETR_COMP ist Teil der Evaluierung der Basiskomponente. Der ETR_COMP wird auf Anfrage des Antragstellers für die Evaluierung der Basiskomponente bereitgestellt und validiert. Der Bericht der Evaluierungsinstanz für die Basiskomponente erklärt insbesondere die Akzeptanz des ETR_COMP durch alle an der Evaluierung der Basiskomponente beteiligten Parteien (d. h. den Evaluator der Basiskomponente, die Evaluierungsinstanz für die Basiskomponente, den Entwickler der Basiskomponente und den Antragsteller der Evaluierung der Basiskomponente). Eine solche Validierungserklärung für den ETR_COMP bezieht sich insbesondere auf die Konsistenz des ETR_COMP mit dem ursprünglichen ETR. Der ETR_COMP wird im Bericht der für die Basiskomponente zuständigen Evaluierungsinstanz zur Weiterverwendung referenziert.

Für die Wiederverwendung des ETR_COMP in einer Verbundevaluation ist die vorherige Abnahme des ETR_COMP durch die Evaluierungsinstanz für die Basiskomponente im Rahmen der Evaluierung der Basiskomponente erforderlich. Der ETR_COMP wird dem Evaluator für das Verbundprodukt und der Evaluierungsinstanz für das Verbundprodukt zur Verwendung bei der Verbundevaluation zur Verfügung gestellt.

Für den ETR_COMP als Teil der Evaluierung der Basiskomponente stellen der Evaluator der Basiskomponente und die für die Evaluierung der Basiskomponente zuständige Instanz sicher, dass in dem ETR_COMP ausreichende Informationen zur Verfügung gestellt werden, die den Ansatz für die Verbundevaluation und die beabsichtigte sichere Verwendung der Basiskomponente in Verbundprodukten berücksichtigen.

Falls nach der Abnahme des ETR_COMP Sicherheitsprobleme für die Basiskomponente festgestellt werden, die im ETR_COMP nicht ausreichend behandelt wurden, entscheidet die Evaluierungsinstanz für die Basiskomponente, welche Aktionen zu ergreifen sind. Dies kann eine entsprechende Aktualisierung des ETR_COMP und eine anschließende Validierung dieses aktualisierten ETR_COMP beinhalten.

Darüber hinaus stellt der Evaluator der Basiskomponente im Rahmen der Evaluierung der Basiskomponente sicher, dass die im zugehörigen ETR_COMP enthaltenen Empfehlungen für die Basiskomponente in Bezug auf die in der Benutzerführung der Basiskomponente enthaltenen Anforderungen konsistent und vollständig sind. Werden Inkonsistenzen (einschließlich fehlender Anforderungen) festgestellt, die bis zur Bereitstellung des Berichts der Evaluierungsinstanz für die Basiskomponente nicht behoben sind, kann die Evaluierungsinstanz für die Basiskomponente zusätzliche Informationen für den Entwickler der abhängigen Komponente in den Bericht der Evaluierungsinstanz für die Basiskomponente aufnehmen.

Wenn bei einer Verbundevaluation die aktuelle Basiskomponente selbst auf einer früheren Verbundevaluation beruht und wenn es eine direkte Schnittstelle zwischen der abhängigen Komponente der aktuellen Evaluierung und der früheren Basiskomponente gibt, dann wird der ETR_COMP der früheren Verbundevaluation auch dem aktuellen Evaluator für das Verbundprodukt und der Evaluierungsinstanz für das Verbundprodukt mitgeteilt.

14.3.3.6.3 Austausch des ETR für die Verbundevaluation

Das Dokument ETR_COMP wird vom Evaluator der Basiskomponente erstellt und gepflegt. Bei einer Verbundevaluation ist jedoch der Entwickler der Basiskomponente der Ansprechpartner für den Entwickler der abhängigen Komponente.

Der Entwickler der abhängigen Komponente setzt sich mit dem Entwickler der Basiskomponente in Verbindung, um den ETR_COMP an den zuständigen Ansprechpartner beim Evaluator des Verbundprodukts zu übermitteln. Der Entwickler der Basiskomponente prüft seine Regeln für das Vertraulichkeitsmanagement, um fest-

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

zustellen, ob eine Auslieferung möglich ist. Gegebenenfalls setzt sich der Entwickler der Basiskomponente mit der für die Evaluierung der Basiskomponente zuständigen Instanz in Verbindung, um die Absicht der Auslieferung des ETR_COMP zu erfragen.

Der Entwickler der Basiskomponente setzt sich mit dem Evaluator der Basiskomponente in Verbindung, um die Auslieferung des ETR_COMP an den angegebenen Ansprechpartner des Evaluators des Verbundprodukts anzufordern (unter Verwendung einer sicheren Methode und mit ausschließlicher Verteilung gekennzeichneten Versionen). Wenn die Lieferung bewilligt wird, sendet entweder der Evaluator der Basiskomponente oder der Entwickler der Basiskomponente den ETR_COMP an den Evaluator des Verbundprodukts – je nach den Vereinbarungen zwischen diesen beiden Parteien. Der Auslieferungsprozess des ETR_COMP hängt von der (in der Regel vertraglichen) Vereinbarung zwischen dem Entwickler der Basiskomponente und dem Evaluator der Basiskomponente ab, was zu Abweichungen vom beschriebenen Verfahren führen kann. Das ETR_COMP-Dokument wird auch der Evaluierungsinstanz für Verbundprodukte zugestellt, wobei ein ähnliches Austauschverfahren wie bei der Bereitstellung für den Evaluator des Verbundprodukts angewandt wird.

Falls erforderlich, tauschen der Evaluator der Basiskomponente und der Evaluator des Verbundprodukts zusätzliche oder detailliertere Informationen aus. Dies unterliegt immer der Kontrolle des Entwicklers der Basiskomponente. Im Falle der Klärung sind der Evaluator der Basiskomponente und der Evaluator des Verbundprodukts die Hauptbeteiligten. Wenn eine zusätzliche Vertrauenswürdigkeitserklärung erforderlich ist, wird die für die Evaluierung der Basiskomponente zuständige Instanz ebenfalls in den Austausch einbezogen.

Es ist wichtig, dass beim Informationsaustausch zwischen mehreren Parteien alle ermittelten Maßnahmen für den Informationsaustausch und -schutz berücksichtigt werden.

14.3.3.6.4 Inhalt des ETR für die Verbundevaluation

Das Dokument ETR_COMP muss unter anderem folgende Informationen enthalten:

a) Informationen über die evaluierte Basiskomponente;

Dieser Abschnitt des ETR_COMP muss formale Informationen über die Evaluierung der Basiskomponente enthalten:

- Versionsinformationen des ETR_COMP;
- eindeutige Identifizierung der Basiskomponente;
- Identitäten der Entwickler und Antragsteller von Basiskomponenten;
- Identitäten des Evaluators der Basiskomponente und der Evaluierungsinstanz der Basiskomponente;
- Vertrauenswürdigkeitsstufe der Evaluierung der Basiskomponente;
- formale Evaluierungsergebnisse wie „bestanden/nicht bestanden“;
- Verweisung auf den ETR in Bezug auf die Basiskomponente und ihre Evaluierung.

b) Informationen über das Design der evaluierten Basiskomponente:

Dieser Abschnitt des ETR_COMP muss eine allgemeine Beschreibung der Basiskomponente und ihrer Hauptkomponenten auf der Grundlage der von der Vertrauenswürdigkeitsklasse ADV geforderten Pflichtergebnisse enthalten.

Zweck dieses Abschnitts ist es, den Grad der architektonischen Trennung der Hauptkomponenten der Basiskomponente zu charakterisieren, mögliche technische Abhängigkeiten zwischen der Basiskomponente und einer abhängigen Komponente, die diese Basiskomponente verwendet, aufzuzeigen und

die Sicherheitsmechanismen der Basiskomponente, die von der Evaluierung der Basiskomponente erfasst werden, darzulegen.

c) Informationen über die evaluierte Konfiguration der Basiskomponente:

Dieser Abschnitt des ETR_COMP enthält je nach Bedarf bzw. von Fall zu Fall Informationen über die evaluierte Konfiguration der Basiskomponente, die in der Konfigurationsliste des Entwicklers aufgeführt ist, oder über relevante Teile. Die Basiskomponente muss eindeutig identifizierbar sein, und diese Identifizierung muss mit der evaluierten Konfiguration verknüpft sein, wie im Bericht der für die Basiskomponente zuständigen Evaluierungsinstanz für die Basiskomponente angegeben.

Gegebenenfalls sind für die Basiskomponente sicherheitsrelevante Einstellungen von Generierungs- und Installationsparametern zu erläutern und ihre Auswirkungen auf die Abwehr von Angriffen darzulegen (z. B. Schlüssellänge, Zählergrenzen). Dazu müssen Methoden gehören, mit denen der Entwickler der abhängigen Komponente und der Evaluator der abhängigen Komponente die Werte dieser Einstellungen verifizieren können, um sicherzustellen, dass die erwartete evaluierte Konfiguration verwendet wird.

Dieser Nachweis kann Verfahren zur Installation, Generierung und Inbetriebnahme der Basiskomponente umfassen, wie sie in der entsprechenden Benutzerführung beschrieben sind, um sicherzustellen, dass die Basiskomponente auf sichere Weise konfiguriert ist.

d) Informationen über Auslieferungsverfahren, die beteiligten Entwicklungs- und Produktionsstandorte und den Datenaustausch:

Zur Unterstützung der Verbundevaluation sind sowohl Evaluationsnachweise für die Auslieferungsverfahren der Basiskomponente als auch für die Abnahmeverfahren der abhängigen Komponente sowie entsprechende Daten erforderlich, die während der Entwicklung und Produktion integriert werden müssen.

Der ETR_COMP muss einen Überblick über die an der Entwicklung und Produktion der Basiskomponente beteiligten Standorte einschließlich der Rolle jedes Standorts und des Datums des letzten Audits geben.

e) Informationen über die Penetrationstests der Basiskomponente einschließlich der betrachteten Angriffspfade und der Zusammenfassung der Prüfergebnisse; Informationen über die Penetrationstests der unterstützenden Funktionen der Basiskomponente:

Dieser Abschnitt des ETR_COMP muss Informationen über die vom Evaluator der Basiskomponente für die Basiskomponente durchgeführte unabhängige Schwachstellenanalyse mit den in Betracht gezogenen Angriffsszenarien, die durchgeführten Penetrationstests und die Verweisung auf die entsprechende Bewertung (Angabe) des Angriffspotentials enthalten.

Die Informationen über die Penetrationstests müssen Folgendes enthalten:

- eine Zusammenfassung aller Angriffsverfahren, die bei der Schwachstellenanalyse behandelt wurden;
- die Details, die zum Verständnis der untersuchten Angriffsszenarien/-pfade erforderlich sind;
- die Bewertungen der durchgeführten Penetrationstests und deren Ergebnisse.

Die Beschreibungen der Angriffsszenarien müssen genügend Einzelheiten enthalten, um den Evaluator des Verbundprodukts bei der Reproduktion von Angriffen zu unterstützen, die zusätzliche Gegenmaßnahmen im Verbundprodukt erfordern.

Wenn eine mögliche Anfälligkeit der Basiskomponente durch Einhaltung der Leitlinien für die Basiskomponente behoben werden muss, ist dies in der Zusammenfassung deutlich darzustellen, einschließlich einer Verweisung auf einen bestimmten Abschnitt in den Leitlinien oder, wenn möglich, auf ein Leitlinienelement.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****f) Beobachtungen und Empfehlungen:**

Die evaluierte Benutzerführung für die Basiskomponente muss alle Informationen enthalten, die für die sichere Verwendung der Basiskomponente nach der Definition in der ST der Basiskomponente erforderlich sind, insbesondere auch Informationen darüber, wie Restschwachstellen und unerwartetes Verhalten vermieden werden können. Der Evaluator der Basiskomponente muss sicherstellen, dass der ETR_COMP nur Empfehlungen zur sicheren Verwendung der Basiskomponente enthält, die auch als Anforderungen in der Benutzerführung der Basiskomponente behandelt werden. Der Evaluator der Basiskomponente muss sicherstellen, dass die Benutzerführung der Basiskomponente und die Empfehlungen im ETR_COMP übereinstimmen und dass die Anforderungen an die Benutzerführung hinreichend spezifisch sind, damit der Entwickler der abhängigen Komponente die Analyse der Design-Compliance durchführen kann.

In einigen Fällen können jedoch zusätzliche detaillierte Informationen, die über die Leitlinien für die Basiskomponenten hinausgehen, erforderlich sein, damit der Evaluator des Verbundprodukts die Verbundevaluation durchführen kann, wie z. B.:

- Beobachtungen zu den Ergebnissen der Evaluierung der Basiskomponente (z. B. spezifische Konfiguration der Basiskomponente für die Evaluierung der Basiskomponente);
- Empfehlungen/Vorgaben für den Evaluator des Verbundprodukts: spezifische Informationen über die Verwendung der Evaluierungsergebnisse der Basiskomponente (z. B. über spezifische Prüfungen, die während einer Evaluierung des Verbundprodukts erforderlich sind).

Jede derartige Beobachtung oder Empfehlung/Vorgabe stammt vom Evaluator der Basiskomponente und/oder der Evaluierungsinstanz der Basiskomponente.

Das ETR_COMP-Dokument ist nicht dazu gedacht, Informationen (z. B. Textkopien) aus anderen verfügbaren Dokumenten zu Basiskomponenten wie der ST und den Leitlinien wiederzugeben. Die Verbundevaluation wird jedoch durch Verweisungen auf die entsprechenden Abschnitte solcher Basiskomponentennachweise unterstützt.

14.3.3.7 Berichte und deren Gültigkeit

Die Ergebnisse einer Verbundevaluation werden der Evaluierungsinstanz für Verbundprodukte in Form eines ETR für das Verbundprodukt zur Verfügung gestellt. Dieser Verbundprodukt-ETR muss neben anderen Informationen die endgültige Gesamtentscheidung für die Verbundevaluation auf der Grundlage der Teilurteile für jede in den Anwendungsbereich der aktuellen Verbundevaluation fallende Vertrauenswürdigkeitskomponente enthalten. Die Anwendung des Ansatzes der Verbundevaluation ist im ETR für das Verbundprodukt und gegebenenfalls im Bericht der Evaluierungsinstanz für das Verbundprodukt zu erläutern.

Da das Verbundprodukt und seine Verbundevaluation die Basiskomponente und ihre zugehörige Evaluierung umfassen, ist die Verbundevaluation an die Gültigkeit und Aktualität des Berichts der für die Evaluierung der Basiskomponente zuständigen Instanz für die Basiskomponente gebunden. Der Evaluator des Verbundprodukts und die Evaluierungsinstanz für das Verbundprodukt benötigen einen gültigen und aktuellen Bericht der Evaluierungsinstanz für die Basiskomponente oder zumindest die Bewertung der Evaluierungsinstanz für die Basiskomponente über den Status des fraglichen Berichts der Evaluierungsinstanz.

ANMERKUNG 1 Die für die Evaluierung des Verbundprodukts zuständige Instanz verlangt in der Regel eine Neubewertung der Basiskomponente, wenn der ETR_COMP der Basiskomponente nicht gültig oder nicht auf dem neuesten Stand ist und sich daher nicht für die Wiederverwendung im Rahmen der Verbundevaluation eignet, insbesondere wegen seiner (veralteten oder unzureichenden) Anfälligkeitsanalyse und Penetrationstests. Diese Neubewertung besteht aus einer Reevaluierung der Basiskomponente, die sich auf eine Erneuerung der Anfälligkeitsanalyse und der Penetrationstests (Überwachungsprozess) konzentriert, oder alternativ aus einer Bestätigungserklärung der Evaluierungsinstanz der Basiskomponente.

ANMERKUNG 2 Wenn der ETR_COMP der Basiskomponente vor der Einreichung der zugehörigen Aufgaben für eine Verbundevaluation ausgestellt wurde und in der Zwischenzeit eine wesentliche Änderung bei der Durchführung der nach

dem Stand der Technik relevanten Angriffe auf die Basiskomponente eingetreten ist (z. B. eine wesentliche Änderung der Angriffsverfahren oder der Angriffsbewertungen), dann verlangt die Evaluierungsinstanz für Verbundprodukte möglicherweise eine Neubewertung oder Reevaluierung der Basiskomponente mit besonderem Augenmerk auf die neuen Angriffsaspekte.

ANMERKUNG 3 Regeln, die die Gültigkeit und Aktualität von Berichten (hier insbesondere der Basiskomponentenbericht der Evaluierungsinstanz für Basiskomponenten und der ETR_COMP) bestimmen, werden durch das jeweilige Evaluierungsprogramm definiert und können mit einem spezifisch definierten Gültigkeitszeitraum verknüpft werden.

ANMERKUNG 4 Stellt der Evaluator des Verbundprodukts bei der Prüfung der Basiskomponente Fehler fest (z. B. Anfälligkeiten aufgrund verbesserter Angriffsverfahren oder -techniken), so werden diese Ergebnisse der für die Evaluierung des Verbundprodukts zuständigen Instanz mitgeteilt. Die für die Evaluierung des Verbundprodukts zuständige Instanz ergreift dann gemeinsam mit der für die Evaluierung der Basiskomponente zuständigen Instanz geeignete Schritte, z. B. um eine erneute Bewertung oder Evaluierung der Basiskomponente zu veranlassen.

Falls das gesamte Verbundprodukt als eine Kette von aufeinander aufbauenden Verbundprodukten aufgebaut ist (wenn z. B. die Basiskomponente selbst bereits ein Verbundprodukt ist), ist die Gültigkeit und Aktualität jedes in dieser Kette von Verbundprodukten verwendeten ETR_COMP und Berichts der Evaluierungsinstanz erforderlich. Darüber hinaus werden alle Abhängigkeiten von einem ETR_COMP einer niedrigeren Stufe zu einem ETR_COMP einer höheren Stufe bei der Wiederverwendung der Ergebnisse in der Verbundevaluation des gesamten Verbundprodukts berücksichtigt.

ANMERKUNG 5 Der Bericht der Evaluierungsinstanz für ein Produkt erklärt die Abnahme der Produktevaluierung und ihrer Ergebnisse durch die jeweilige Evaluierungsinstanz (d. h. die Abnahme des zugehörigen ETR durch die Evaluierungsinstanz ist gegeben). In diesem Bericht wird insbesondere erklärt, dass die Evaluierung des Produkts nach ISO/IEC 15408 durchgeführt wurde.

Die Gültigkeit, Aktualität und Relevanz des Berichts zur Basiskomponente der Evaluierungsinstanz für Basiskomponenten und des ETR_COMP für das aktuelle Verbundprodukt und seine Verbundevaluation werden durch den Bericht zum Verbundprodukt der Evaluierungsinstanz für Verbundprodukte anerkannt. Dies schließt die Feststellung und Anerkennung der Gleichwertigkeit von Komponenten mit Einfach-Vertrauenswürdigkeit (und damit von Vertrauenswürdigkeitsstufen) ein, die zu unterschiedlichen Versionen von ISO/IEC 15408 und ISO/IEC 18405 gehören, wenn die Evaluierung der Basiskomponente in Übereinstimmung mit einer anderen Version von ISO/IEC 15408 und ISO/IEC 18045 als der aktuellen Verbundevaluation durchgeführt wurde.

Die Evaluierungsinstanz für Verbundprodukte stellt einen Bericht für das Verbundprodukt aus, wenn:

- die abschließende Gesamtentscheidung für die Verbundevaluation im ETR für das Verbundprodukt lautet „akzeptiert“, und
- die Gültigkeit, Aktualität und Relevanz des Berichts zur Basiskomponente der Evaluierungsinstanz für Basiskomponenten und des ETR_COMP für das vorliegende Verbundprodukt und seine Verbundevaluation durch die Evaluierungsinstanz für Verbundprodukte anerkannt werden.

14.4 Anforderungen an Evaluierungen, die Zusammensetzungstechniken verwenden

14.4.1 Wiederverwendung von Evaluierungsergebnissen

Bei der Zusammensetzung von Komponenten zu einem IT-Produkt ist es möglich, dass einzelne Komponenten des Produkts bereits evaluiert wurden und daher bereits vorhandene Evaluierungsergebnisse für solche Komponenten wiederverwendet werden können. In der Regel sind jedoch zusätzliche Evaluierungsaufgaben erforderlich und werden durchgeführt, um die Vertrauenswürdigkeit des gesamten IT-Produkts zu bestätigen.

Die Wiederverwendung von Evaluierungsergebnissen und Nachweisen, die sich auf solche Komponenten des IT-Produkts (TOE) beziehen, setzt voraus, dass sie für die Evaluierung des gesamten IT-Produkts (TOE) zur Verfügung stehen.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

14.3.2 und 14.3.3 befassen sich mit Evaluierungstechniken für das Modell der mehrschichtigen Zusammensetzung. 14.3.2 beschreibt die Verwendung der in ISO/IEC 15408-3 definierten ACO-Klasse für zusammengesetzte TOE, und in 14.3.3 wird ein Evaluierungsverfahren für Verbundprodukte vorgestellt.

Die Wiederverwendung von Evaluierungsergebnissen und Nachweisen von Komponenten des IT-Produkts (TOE) ist abhängig von:

- dem für das IT-Produkt (TOE) verwendeten Zusammensetzungsmodell;
- der für das gesamte IT-Produkt (TOE) zu beanspruchenden Vertrauenswürdigkeit, insbesondere im Verhältnis zu seinen Komponenten und deren Vertrauenswürdigkeit;
- den Sicherheitseigenschaften, die für das IT-Produkt (TOE) und seine Komponenten beansprucht werden.

BEISPIEL Trennung, Informationsflusskontrolle und Fehlertoleranz sind Beispiele für Sicherheitseigenschaften.

14.4.2 Aspekte der zusammengesetzten Evaluierung**14.4.2.1 Begründung für die Zusammensetzung**

Wenn ein IT-Produkt (TOE) aus Komponenten unter Verwendung eines Zusammensetzungsmodells, wie in 14.2 beschrieben, zusammengesetzt wird und Zusammensetzungsverfahren für seine Evaluierung verwendet werden, muss eine Begründung der Zusammensetzung für die Evaluierung des IT-Produkts bereitgestellt werden (z. B. in der ST des Verbundprodukts bzw. des zusammengesetzten Produkts). Dies umfasst mindestens die Analyse von:

- dem für das IT-Produkt (TOE) verwendeten Zusammensetzungsmodell;
- der für den gesamten TOE zu beanspruchenden Vertrauenswürdigkeit, insbesondere im Verhältnis zu seinen Komponenten und deren Vertrauenswürdigkeit;
- den Schnittstellen und Abhängigkeiten der Komponenten und ihrer Funktionalität;
- der Zusammensetzbarkeit der Sicherheitsfunktionsrichtlinien und der OSP der Komponenten;
- der Erhaltung der Sicherheitseigenschaften der Komponenten;
- den Aspekten der Korrektheit (beim eingebetteten Zusammensetzungsmodell).

14.4.2.2 Anfälligkeitsanalyse

Das IT-Produkt, das aus Komponenten unter Verwendung eines Zusammensetzungsmodells nach 14.2 und unter Verwendung von Zusammensetzungstechniken für seine Evaluierung zusammengesetzt wurde, muss einer Anfälligkeitsanalyse nach der in ISO/IEC 15408-3 angegebenen AVA-Klasse unterzogen werden, wobei die vorgeschlagene EAL für das IT-Produkt zu berücksichtigen ist. Obwohl es möglich ist, die Ergebnisse der Anfälligkeitsanalyse der Komponenten wiederzuverwenden, müssen zusätzliche Anfälligkeitsanalysen für das gesamte IT-Produkt (TOE) erarbeitet und durchgeführt werden.

Die Anfälligkeitsanalyse muss unter Berücksichtigung der Analyse des IT-Produkts mit seinen Komponenten erarbeitet werden.

14.4.2.3 Prüfungen

Das IT-Produkt, das aus Komponenten unter Verwendung eines Zusammensetzungsmodells nach 14.2 und unter Verwendung von Zusammensetzungstechniken für seine Evaluierung besteht, muss zusätzlichen Prüfungen unter Anwendung der in ISO/IEC 15408-3 angegebenen ATE-Klasse unterzogen werden. Obwohl es möglich ist, die Evaluierungsergebnisse der Prüfungen aus den Komponenten wiederzuverwenden, müssen zusätzliche Prüfungen für das gesamte IT-Produkt (TOE) erarbeitet und durchgeführt werden.

Die Prüfungen müssen unter Berücksichtigung der Analyse des IT-Produkts und seiner Komponenten erarbeitet werden.

14.4.2.4 Verwendung der ACO-Klasse für zusammengesetzte TOE

ISO/IEC 15408-3 beschreibt die ACO-Klasse, die Vertrauenswürdigkeitskomponenten zur Unterstützung der Evaluierung zusammengesetzter TOE bereitstellt.

ISO/IEC 15408-5 enthält eine Familie von vordefinierten Vertrauenswürdigkeitspaketen für zusammengesetzte TOE [Composed Assurance Packages (CAP)], die ein Gleichgewicht zwischen der erreichten Vertrauenswürdigkeit und den Kosten und der Durchführbarkeit zum Erwerb einer solchen Vertrauenswürdigkeit für zusammengesetzte TOE herstellen.

Die CAP sollen sicherstellen, dass die Zusammenstellung korrekt, mit einer bestimmten Strenge und unter Berücksichtigung der vorgeschlagenen EAL für das zusammengesetzte IT-Produkt durchgeführt wurde.

14.4.2.5 Verwendung der Technik der Verbundevaluation für Verbundprodukte

ISO/IEC 15408-3 beschreibt die COMP-Familien in verschiedenen Vertrauenswürdigkeitsklassen, die Vertrauenswürdigkeitskomponenten zur Unterstützung der Evaluierung von Verbundprodukten bereitstellen. Diese COMP-Familien werden als Vertrauenswürdigkeitsfamilien zusammengestellt, die andere, bereits bestehende Vertrauenswürdigkeitsfamilien, die in ISO/IEC 15408-3 definiert sind, in geeigneter Weise ergänzen, um die zusammensetzungsspezifischen Evaluierungsaspekte und -fragen zu behandeln.

Die COMP-Familien sollen sicherstellen, dass die Zusammenstellung korrekt, mit einer bestimmten Strenge und unter Berücksichtigung der vorgeschlagenen EAL für das Verbundprodukt durchgeführt wurde.

Die Anwendung der Technik der Verbundevaluation für die Evaluierung eines Verbundprodukts erfordert eine bereits evaluierte Basiskomponente mit einem entsprechenden ETR_COMP und einem gültigen Bericht der für die Evaluierung der Basiskomponente zuständigen Instanz.

14.5 Evaluierung mittels Zusammensetzung und Mehrfach-Vertrauenswürdigkeit

Die Begriffe Zusammensetzung und Mehrfach-Vertrauenswürdigkeit zielen auf die Lösung unterschiedlicher Probleme ab. Zusammenfassend beziehen sich zusammengesetzte Evaluierungen und Verbundevaluationen auf Evaluierungsprozesse, die besonders für die TOE mit mehreren Akteuren geeignet sind und die eine Wiederverwendung früherer Evaluierungsergebnisse ermöglichen, während sich Mehrfach-Vertrauenswürdigkeit auf eine Eigenschaft einiger TOE im Zusammenhang mit einem bestimmten Sicherheitsproblem und einer bestimmten Betriebsumgebung bezieht.

Die Evaluierung mittels Zusammensetzung bezieht sich auf die TOE mit einer Liefer- und/oder Integrationskette, an der möglicherweise mehrere Parteien beteiligt sind, wobei jede Partei die Evaluierung der von ihr entwickelten Sicherheitsfunktionalität übernimmt. Die Normenreihe ISO/IEC 15408 vereinheitlicht zwei Ansätze für die Wiederverwendung von Evaluierungsergebnissen in einem Evaluierungsprozess:

- a) Die zusammengesetzte Evaluierung ermöglicht es, eine zusammengesetzte Vertrauenswürdigkeitsstufe für einen TOE aus den einzelnen Vertrauenswürdigkeitsstufen seiner interagierenden Teil-TOE zu erhalten;
- b) die Verbundevaluation ermöglicht es, eine EAL für einen mehrschichtigen TOE auf inkrementelle Weise zu erhalten, wobei zuerst die Basisschicht evaluiert wird und dann die integrierte abhängige Schicht und die Basisschicht unter Wiederverwendung der Evaluierungsergebnisse der Basisschicht evaluiert werden.

Die Evaluierung mit Mehrfach-Vertrauenswürdigkeit konzentriert sich auf die TOE, bei denen unterschiedliche Vertrauenswürdigkeitsanforderungen für verschiedene Teile der Sicherheitsfunktionalität (die Teil-TSF) gelten, während gleichzeitig eine Gesamtvertrauenswürdigkeitsstufe für den gesamten TOE sichergestellt wird. Vor der Einführung der Mehrfach-Vertrauenswürdigkeit hätten solche Anforderungen einen Antragsteller dazu

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

gezwungen, mehrere Evaluierungen desselben TOE für verschiedene ST durchzuführen. Mit diesem Konzept vereinheitlicht und optimiert die Normenreihe ISO/IEC 15408 diesen Prozess.

Aus der Sicht des/der TOE/TSF gilt die Evaluierung mit Mehrfach-Vertrauenswürdigkeit für jede beliebige Architektur, während die Evaluierung durch Zusammensetzung für bestimmte Architekturen gilt: Die zusammengesetzte Evaluierung gilt für einen TOE, der aus mehreren interagierenden Teil-TOE besteht, während die Verbundevaluation für einen TOE gilt, bei dem eine abhängige Schicht von einer Basisschicht abhängig ist.

In der Praxis können Mehrfach-Vertrauenswürdigkeit und Evaluierung mittels Zusammensetzung gemeinsam in einer Evaluierung verwendet werden.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

Anhang A (normativ)

Spezifikation von Paketen

A.1 Ziel und Aufbau dieses Anhangs

Ziel dieses Anhangs ist es, weitere Informationen über die Spezifikation von Paketen zu geben.

ANMERKUNG ISO/IEC 15408-3 definiert keine Evaluierungskriterien für Pakete, da Pakete nicht separat evaluiert werden. Die Evaluierung von Paketen ist implizit, sobald ein Paket in ein PP, PP-Modul oder eine ST integriert ist.

A.2 Paketfamilien

A.2.1 Allgemein

Bild A.1 zeigt den Aufbau einer Paketfamilie. Jeder Teil wird im Folgenden erläutert.

A.2.2 Name der Paketfamilie

Pakete mit verwandten Zielsetzungen werden als eine Familie von Paketen dargestellt. In diesem Fall ist der Name der Paketfamilie verpflichtend, und der Antragsteller der Paketfamilie bemüht sich, einen eindeutigen Namen zu vergeben.

A.2.3 Überblick über die Paketfamilie

Pakete, die als eine Familie von Paketen dargestellt werden, enthalten einen Abschnitt, der einen Überblick über die Familie gibt und die Familie allgemein beschreibt.

A.2.4 Zielsetzungen der Paketfamilie

Der Abschnitt „Zielsetzungen“ der Paketfamilie beschreibt den Zweck der Familie.

A.2.5 Pakete

Ein oder mehrere Pakete sind, wie nachfolgend beschrieben, in der Paketfamilie enthalten. Pakete von SAR und Pakete von SFR werden nicht in derselben Paketfamilie gemischt.

A.3 Pakete

A.3.1 Verpflichtender Inhalt eines Pakets

A.3.1.1 Paketidentifizierung

Die Paketidentifizierung umfasst:

- den Namen des Pakets. Der Name liefert eine eindeutige Beschreibung des Zwecks des Pakets;
- Informationen zur Paketversion;
- Datum der letzten Aktualisierung;
- Antragsteller;

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

e) Verweisung auf die verwendete Ausgabe der Normenreihe ISO/IEC 15408.

Das Paket kann auch mit einem Kurznamen versehen werden.

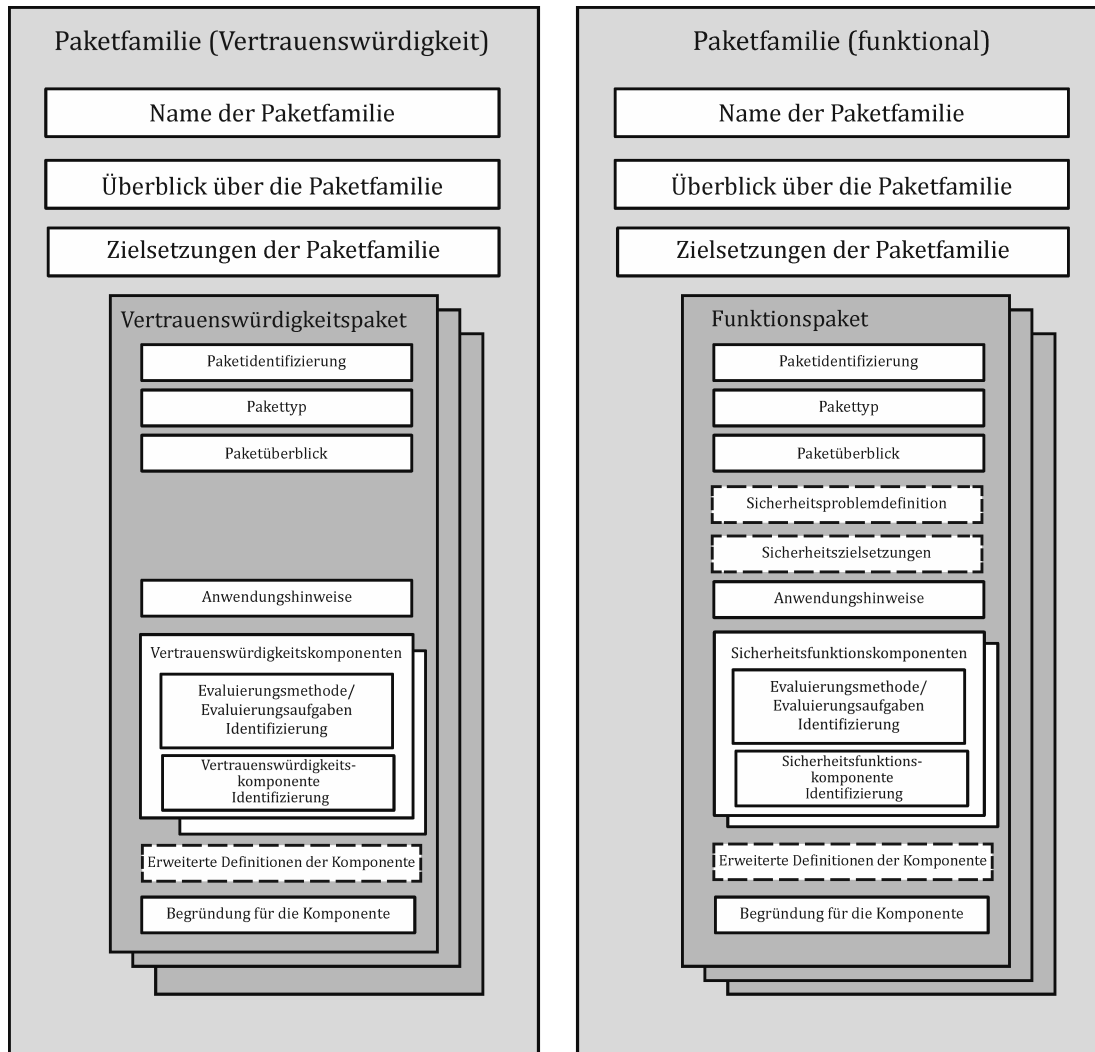


Bild A.1 — Aufbau einer Paketfamilie mit Vertrauenswürdigkeits- oder Funktionspaketen

BEISPIEL Vertrauenswürdigkeitsstufe 1 wird auch als „EAL 1“ bezeichnet.

ANMERKUNG Für die in ISO/IEC 15408-5 definierten Pakete sind die Punkte b) bis e) implizit in den Angaben zur Ausgabe von ISO/IEC 15408-5 enthalten.

A.3.1.2 Pakettyp

Ein Paket wird als einer der nachfolgenden Typen identifiziert:

- a) Funktionspaket; oder
- b) Vertrauenswürdigkeitspaket.

A.3.1.3 Paketüberblick

Die Pakete enthalten einen Abschnitt, der einen allgemeinen Überblick über den Zweck des Pakets gibt.

A.3.1.4 Anwendungshinweise

Anwendungshinweise sind bis auf die folgenden Ausnahmen optional:

- Bei Funktionspaketen müssen alle zusätzlichen Audit- und Managementanforderungen in Bezug auf die im Paket enthaltenen SFR im Abschnitt „Anwendungshinweise“ angegeben werden;
- Funktionspakete dürfen Abhängigkeiten zu anderen Funktionspaketen haben. Solche Abhängigkeiten müssen im Funktionspaket dokumentiert werden und können auch in einem PP, PP-Modul oder einer ST dokumentiert werden.

Funktionspakete dürfen auch Komponenten mit Abhängigkeiten festlegen, die nicht durch das Paket erfüllt werden, sondern von einem anderen Paket, PP, PP-Modul oder einer ST, die das Paket verwendet, erfüllt werden sollen.

BEISPIEL Ein Paket, das die Spezifikation für ein kryptographisches Protokoll (z. B. TLS) enthält, wobei die übergeordneten SFR-Komponenten im Paket festgelegt sind, die kryptographischen Primitive jedoch nicht.

In diesem Fall darf eine fakultative Liste der abhängigen Komponenten in den Anwendungshinweisen des Funktionspakets aufgeführt werden, die weitere Informationen enthält, wie z. B. alle erforderlichen Auswahlen/Zuordnungen für diese SFR.

ANMERKUNG Zu den Benutzern von Paketen gehören Autoren von PP, PP-Modulen, anderen Paketen und ST, Integratoren und Evaluatoren.

A.3.1.5 Komponenten (entweder SFR oder SAR)

Die in dem Paket enthaltenen Sicherheitsanforderungen sind vorgegeben. In diesem Abschnitt wird auch die Begründung für die Auswahl der Anforderungen angegeben.

Die Sicherheitsanforderungen können auswahlbasiert sein. Siehe 8.2.4.2. Optionale SFR (und ggf. unterstützende SPD-Elemente und Zielsetzungen) dürfen auch in Funktionspaketen angegeben werden.

A.3.2 Optionaler Inhalt eines Pakets

A.3.2.1 Sicherheitsproblemdefinition (SPD) (Funktionspakete)

Vertrauenswürdigkeitspakete enthalten diesen Abschnitt nicht.

Funktionspakete dürfen diesen Abschnitt enthalten.

Dieser Abschnitt enthält alle SPD-Elemente, die das Sicherheitsproblem beschreiben, das durch das Funktionspaket behandelt wird. SPD-Elemente, die mit optionalen SFR verbunden sind, dürfen in diesem Abschnitt definiert werden. Anwendungshinweise müssen verwendet werden, um die Sicherheitszielsetzungen (falls zutreffend) und SFR zu identifizieren, denen die optionalen SPD-Elemente zugeordnet sind.

A.3.2.2 Sicherheitszielsetzungen (Funktionspakete)

Vertrauenswürdigkeitspakete dürfen diesen Abschnitt nicht enthalten.

Funktionspakete dürfen diesen Abschnitt enthalten.

Im Falle eines Funktionspakets, das für die PP/PP-Module/ST mit direkter Begründung verwendet wird, dürfen die TOE-Sicherheitszielsetzungen nicht enthalten sein.

Der Abschnitt „Sicherheitszielsetzungen“ eines Funktionspakets enthält alle zusätzlichen Sicherheitszielsetzungen für den TOE oder für die Betriebsumgebung, die aus der SPD abgeleitet werden. Sicherheitszielsetzungen für den mit optionalen SFR verbundenen TOE dürfen gegebenenfalls in diesem Abschnitt

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01 prEN ISO/IEC 15408-1:2023 (D)

definiert werden. Anwendungshinweise müssen verwendet werden, um die SPD-Elemente und die SFR zu identifizieren, denen die optionalen Sicherheitszielsetzungen zugeordnet sind.

A.3.2.3 Anwendungshinweise

Die Aufnahme von Anwendungshinweisen in ein Paket ist optional. Siehe A.3.1.4.

Der Abschnitt „Anwendungshinweise“ kann auch Informationen enthalten, die für die Benutzer des Pakets von besonderem Interesse sind. Die Darstellung ist informell und umfasst z. B. Warnungen über Nutzungseinschränkungen und Bereiche, in denen besondere Aufmerksamkeit erforderlich ist.

A.3.2.4 Erweiterte Komponentendefinition(en)

Ein Paket darf erweiterte Komponenten enthalten. In diesem Fall enthalten die Pakete einen Abschnitt mit den erweiterten Komponentendefinitionen.

A.3.2.5 Evaluierungsmethoden/-aufgaben

Die Pakete dürfen Evaluierungsmethoden/-aufgaben enthalten, die von ISO/IEC 18045 abgeleitet wurden. Wenn Evaluierungsmethoden/-aufgaben enthalten sind, müssen eine oder mehrere Konformitätserklärungen in den Abschnitt „Sicherheitsanforderungen“ des Pakets aufgenommen werden, siehe 9.4. Die Evaluierungsmethoden/-aufgaben können entweder im Pakettdokument enthalten sein oder auf externe Dokumente verweisen.

Anhang B
(normativ)**Spezifikation von Schutzprofilen (PP)****B.1 Ziel und Aufbau dieses Anhangs**

Ziel dieses Anhangs ist die Zusammenfassung des Aufbaus und des erwarteten Inhalts eines PP.

ANMERKUNG 1 Dieser Anhang definiert nicht die Anforderungen an die Evaluierung von PP. Die PP-Evaluierungskriterien sind der APE-Klasse in ISO/IEC 15408-3 entnommen.

ANMERKUNG 2 Dieser Anhang enthält nicht die Anforderungen an die Spezifikation von PP-Konfigurationen und PP-Modulen. Diese sind Anhang C zu entnehmen.

Dieser Anhang besteht aus den folgenden wesentlichen Teilen:

a) *Spezifikation eines PP*

Dies wird in B.2 zusammengefasst und deckt die folgenden Punkte ab:

- *Wie ein PP verwendet werden sollte;*
- *Wie ein PP nicht verwendet werden sollte.*

b) *Verpflichtender Inhalt eines PP*

Dies wird in B.3 zusammengefasst und in B.3.2 bis B.3.7, die die verpflichtenden Inhalte des PP sowie die Wechselbeziehungen zwischen diesen Inhalten beschreiben und Beispiele anführen, näher erläutert.

c) *Beanspruchung von Konformität mit Normen*

B.4 beschreibt, wie ein PP-Autor die Einhaltung einer bestimmten Norm durch einen TOE beanspruchen kann.

d) *Die PP mit direkter Begründung*

Die PP mit direkter Begründung sind solche, bei denen die Bedrohungen und OSP in der SPD direkt auf die SFR und möglicherweise auf Sicherheitszielsetzungen für die Betriebsumgebung abgebildet werden. Sie werden ausführlich in B.5 beschrieben.

B.2 Spezifikation eines PP**B.2.1 Wie ein PP verwendet werden sollte**

Ein PP ist üblicherweise eine Bedarfsaussage, bei der eine Benutzergruppe, ein Regulierungsorgan oder eine Gruppe an Entwicklern einen gemeinsamen Satz an Sicherheitsbedürfnissen definieren. Ein PP gibt Verbrauchern die Möglichkeit, auf diesen Satz zu verweisen und ermöglicht später die Evaluierung gegen diese Bedürfnisse.

Obwohl dies andere Verwendungszwecke nicht ausschließt, wird ein PP in der Regel verwendet als:

- Teil einer Anforderungsspezifikation für einen bestimmten Verbraucher oder eine Gruppe an Verbrauchern, die den Kauf eines bestimmten Typs eines IT-Produkts in Betracht ziehen, wenn er das PP erfüllt;

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

- Teil einer Verordnung eines bestimmten Regulierungsorgans, das nur einen bestimmten Typ eines IT-Produkts erlaubt, wenn er das PP erfüllt;
- um ein gemeinsames Sicherheitsproblem zu lösen, das von einer Vielzahl von Verbrauchern aufgeworfen wird und oft von einer Gruppe definiert wird, der mehrere IT-Produktentwickler angehören, die dann IT-Produkte dieser Art herstellen, um die Bedürfnisse ihres gemeinsamen Marktes zu erfüllen.

B.2.2 Wie ein PP nicht verwendet werden sollte

Zwei Rollen unter vielen, die ein PP nicht erfüllt, sind folgende:

- eine vollständige Spezifikation;

Ein PP ist als Sicherheitsspezifikation und nicht als allgemeine Spezifikation ausgelegt. Eigenschaften wie Interoperabilität, physische Größe und Gewicht, erforderliche Spannung usw. sollten nicht Teil eines PPs sein, sofern sie nicht sicherheitsrelevant sind. Daraus folgt, dass ein PP im Allgemeinen Teil einer vollständigen Spezifikation, aber für sich genommen keine vollständige Spezifikation ist.

- eine Spezifikation eines einzelnen Produkts.

Im Gegensatz zu einer ST ist ein PP auf die Beschreibung eines bestimmten Typs eines IT-Produkts ausgelegt und nicht auf ein einzelnes Produkt. Wenn nur ein einzelnes Produkt beschrieben werden soll, ist eine ST besser geeignet.

B.3 Verpflichtender Inhalt eines PPs**B.3.1 Allgemein**

Es gibt zwei Typen von PP. Erstens das „reguläre“ PP, das den gesamten Inhalt wie in B.3.2 bis B.3.7 beschrieben enthält. Zweitens kann ein PP-Autor in einigen Fällen ein PP mit direkter Begründung schreiben, das einen anderen Inhalt hat als die PP, die Sicherheitszielsetzungen für den TOE enthalten. Die PP mit direkter Begründung sowie die Gründe und Umstände, unter denen sie verwendet werden, werden in B.5 ausführlich beschrieben. Alle anderen Teile dieses Anhangs gehen von einem PP mit vollständigem Inhalt aus.

Bild B.1 zeigt den in ISO/IEC 15408-3 festgelegten Inhalt eines PPs. Bild B.1 kann auch als Grundstruktur für das PP verwendet werden, wobei auch alternative Strukturen erlaubt sind. Wenn beispielsweise die Begründung für die Sicherheitsanforderungen besonders umfangreich ist, kann diese Begründung auch in einen Anhang des PP aufgenommen werden, anstatt in den Abschnitt der Sicherheitsanforderungen. Die einzelnen Abschnitte eines PPs und die Inhalte dieser Abschnitte werden unten kurz zusammengefasst und in B.3.2 bis B.3.7 deutlich ausführlicher erklärt.

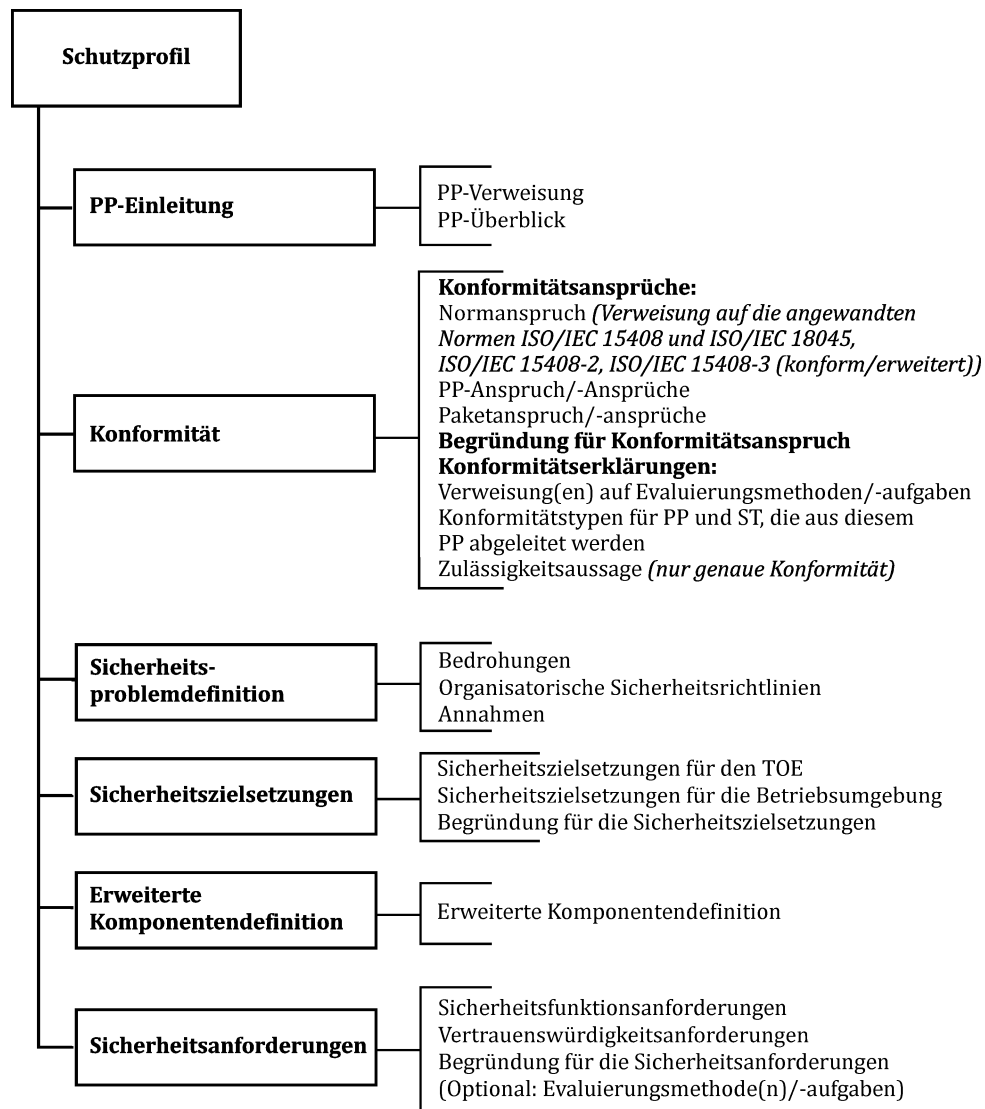


Bild B.1 — Inhalt eines Schutzprofils

Ein PP enthält:

- eine *PP-Einleitung*, mit der PP-Verweisung und einer ausformulierten Beschreibung des TOE-Typs,
- Konformitätsansprüche*, die aufzeigen:
 - welche Ausgabe der relevanten Teile der Normenreihe ISO/IEC 15408 anwendbar ist;
 - Konformität mit ISO/IEC 15408-2 und ISO/IEC 15408-3 (konform oder erweitert);
 - ob das PP Konformität mit anderen PP und/oder Paketen beansprucht, und falls dem so ist, mit welchen und welche Art der Konformität beansprucht wird.
- eine *Konformitätserklärung* mit:
 - Verweisung auf eine oder mehrere Evaluierungsmethoden/-aufgaben, die von ISO/IEC 18045 abgeleitet wurden;

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

ANMERKUNG Einzelheiten zu den Evaluierungsmethoden/-aufgaben können optional in das PP oder in ein zugehöriges Begleitdokument aufgenommen werden.

- bei genauer Konformität erscheint in diesem Abschnitt des PP die Zulässigkeitserklärung, die angibt, welche PP und PP-Module in Verbindung mit dem PP verwendet werden können.
 - dem Typen der Konformität, der von den ST und anderen daraus abgeleiteten PP verlangt wird.
- d) eine *Sicherheitsproblemdefinition*, die Bedrohungen, OSPen und Annahmen aufzeigt;
- e) *Sicherheitszielsetzungen*, die aufzeigen, wie die Lösung des Sicherheitsproblems aufgeteilt ist zwischen Sicherheitszielsetzungen für die Betriebsumgebung und optional Sicherheitszielsetzungen für den TOE;
- f) *erweiterte Komponentendefinition(en)*, in der bzw. denen neue Komponenten (d.h. nicht in ISO/IEC 15408-2 oder ISO/IEC 15408-3 enthaltene Komponenten) definiert werden dürfen. Diese neuen Komponenten sind zur Definition von erweiterten funktionalen Anforderungen und erweiterten Vertrauenswürdigkeitsanforderungen erforderlich;
- g) *Sicherheitsanforderungen*, bei denen eine Übertragung der Sicherheitszielsetzungen für den TOE in eine standardisierte Sprache bereitgestellt wird. Diese standardisierte Sprache wird in SFRs dargestellt. Zusätzlich werden in diesem Abschnitt die SARs definiert.

B.3.2 PP-Einleitung (APE_INT)**B.3.2.1 Allgemein**

Die PP-Einleitung, beschreibt die TOEs ausformuliert auf zwei Abstraktionsebenen:

- a) die PP-Verweisung, die Informationen zur Identifizierung des PP's liefert;
- b) der TOE-Überblick, der den TOE kurz beschreibt.

B.3.2.2 PP-Verweisung

Ein PP enthält eine eindeutige PP-Verweisung, die diese bestimmte PP identifiziert. Eine typische PP-Verweisung umfasst Titel, Version, Autoren und Veröffentlichungsdatum.

ANMERKUNG Hier wird unterschieden zwischen dem Antragsteller eines PP, d.h. der für seine Entwicklung verantwortlichen Entität, und dem Autor eines PP, der für seine Produktion verantwortlich ist.

BEISPIEL Ein Beispiel für eine PP-Verweisung ist „PP zum Atlantean Navy CablePhone Encryptor, Version 2b, Beschaffungsstelle Atlantean Navy, 1. April 2020“.

Die Verweisung sollte eindeutig sein, um unterschiedliche PP's und verschiedene Versionen derselben PP unterscheiden zu können. Die PP-Verweisung erleichtert das Indexieren und Verweisen des PP's und seine Aufnahme in PP-Kataloge.

B.3.2.3 PP-Überblick**B.3.2.3.1 Allgemein**

Der TOE-Überblick richtet sich an potentielle Verbraucher eines TOEs, die Kataloge von PP durchsuchen, mit deren Unterstützung sie ihre Sicherheitsbedürfnisse festlegen können.

Der PP-Überblick richtet sich auch an Entwickler, die das PP in der Ausgestaltung von TOEs oder für das Anpassen bestehender Produkte nutzen können.

Die typische Länge eines PP-Überblicks sind einige Absätze.

Zu diesem Zweck beschreibt der PP-Überblick kurz die Verwendung des TOEs und seine wesentlichen Sicherheitsmerkmale, identifiziert den TOE-Typ und jegliche wesentliche, nicht im TOE enthaltene Hardware/Software/Firmware, die für den TOE verfügbar ist.

B.3.2.3.2 Verwendung und wesentliche Sicherheitsmerkmale eines TOE-Typs

Die Beschreibung der Verwendung und wesentlichen Sicherheitsmerkmale eines TOE-Typs dient dazu, eine allgemeine Vorstellung über die Fähigkeiten des TOEs und seine Anwendung zu geben. Dieser Abschnitt wird für PP-Autoren, TOE-Entwickler oder potentielle Verbraucher des TOEs geschrieben und beschreibt die Verwendung und die wesentlichen Sicherheitsmerkmale des TOE-Typs im Hinblick auf den Geschäftsbetrieb in einer für den Verbraucher des TOEs verständlichen Sprache.

BEISPIEL Ein Beispiel dafür ist „Der Atlantean Navy CablePhone Encryptor ist ein Gerät zur Verschlüsselung, das vertrauliche Kommunikation zwischen den Schiffen über das Kabeltelefonsystem der Atlantischen Marine erlaubt. Zu diesem Zweck erlaubt das Gerät mindestens 1024 unterschiedliche Benutzer und unterstützt mindestens 500 Mb/s als Verschlüsselungsgeschwindigkeit. Es erlaubt sowohl bilaterale Kommunikation zwischen Schiffen als auch Sammelaufwurf über das gesamte Netzwerk.“

B.3.2.3.3 TOE-Typ

Der TOE-Überblick bestimmt den allgemeinen Typ eines vom PP angesprochenen TOEs wie: Firewall, VPN-Firewall, Chipkarte, kryptographisches Modem, Intranet, Webserver, Datenbank, Webserver, Mobilgerät und Datenbank usw. Die Definition des TOE-Typs beinhaltet oft eine Charakterisierung der Software- und Hardware-Grenzen des TOE.

BEISPIEL Dieses Beispiel für die Beschreibung eines TOE-Typs ist dem Sicherheits-IC-Schutzprofil entnommen: „Der Evaluierungsgegenstand (TOE) ist eine integrierte Sicherheitsschaltung (Sicherheits-IC), die aus einer Verarbeitungseinheit, Sicherheitskomponenten, E/A-Anschlüssen (kontaktbehaftet, kontaktlos oder ähnliche Schnittstellen wie USB, MMC) und flüchtigen und nichtflüchtigen Speichern (Hardware) besteht. Der TOE kann auch IC-Entwickler/Hersteller-eigene IC-spezifische Software enthalten, solange sie vom IC-Hersteller geliefert wird. (...) Alle andere Software, die auf der Sicherheits-IC läuft, wird als eingebettete Software der Sicherheits-IC bezeichnet und ist nicht Teil des TOE.“

B.3.2.3.4 Verfügbare nicht im TOE enthaltene Hardware/Software/Firmware

Einige TOEs sind nicht auf andere IT-Komponenten angewiesen, aber viele TOEs, insbesondere Software-TOEs, erfordern zusätzliche Hardware, Software und/oder Firmware, die nicht Teil des TOEs sind. Im letzteren Fall ist der PP-Überblick erforderlich, um die nicht im TOE enthaltene Hardware, Software/Firmware zu identifizieren.

Da ein PP nicht für ein spezifisches Produkt geschrieben wird, kann in vielen Fällen nur eine allgemeine Vorstellung der verfügbaren Hardware/Software/Firmware vermittelt werden. In einigen anderen Fällen können spezifischere Informationen bereitgestellt werden.

BEISPIEL 1 Ein Beispiel, bei dem spezifischere Informationen bereitgestellt werden, wäre eine Anforderungsspezifikation für einen bestimmten Verbraucher, bei dem die Plattform bereits bekannt ist.

BEISPIEL 2 Beispiele für die Identifizierung von Hardware/Software/Firmware:

- keine (für einen TOE, der komplett eigenständig ist);
- ein Standard-PC mit einem Dual-Core-Prozessor mit 2,10 GHz oder schneller und 4 GB RAM oder mehr, auf dem das Yaiza-Betriebssystem für professionelle Anwender, Version 53.0 Update 6b, c oder 7, oder Version 54.0 läuft;
- ein Standard-64-Bit-Server mit einem 2xQuad-Core-Prozessor und 16 GB oder mehr RAM, auf dem das Yaiza-Betriebssystem, Server Edition Version 7.0 Update 6d, und die WonderMagic 12.0-Grafikkarte mit dem 1.01 WM Driver Set laufen;
- eine integrierte Schaltung CleverCard SB17067;
- eine integrierte Schaltung CleverCard SB17067 mit v12.0 des QuickOS Chipkarten-Betriebssystems;

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

— das Yaiza mobile-OS 3.1.6 auf Smartphone- und Tablet-Geräten mit FP9-Prozessor.

B.3.3 Konformitätsansprüche und Konformitätserklärung (APE_CCL)**B.3.3.1 Allgemein**

Der Abschnitt über die Konformitätsansprüche eines PP beschreibt, wie das PP

- die anwendbare Ausgabe der relevanten Teile der Normenreihe ISO/IEC 15408 angibt;
- ISO/IEC 15408-2 und ISO/IEC 15408-3 (d. h. konform oder erweitert) entspricht;
- andere PP (falls vorhanden) beansprucht;
- Pakete beansprucht (falls vorhanden);

Die Beschreibung des PP hinsichtlich seiner Konformität mit der Normenreihe ISO/IEC 15408 besteht aus zwei Punkten: der Ausgabe des relevanten Teils der Normenreihe ISO/IEC 15408 und der Angabe, ob das PP erweiterte Sicherheitsanforderungen enthält oder nicht (siehe 10.3 und D.3.6).

Die Beschreibung der vom PP beanspruchten Konformität mit anderen PP bedeutet, dass das PP alle anderen PP auflistet, mit denen Konformität beansprucht wird. Der Typ der beanspruchten Konformität wird ebenfalls angegeben. Zu einer Erläuterung siehe 10.3.

Die Beschreibung zur Konformität des PP mit Paketen bedeutet, dass das PP die Pakete auflistet, mit denen Konformität beansprucht wird. Zu einer Erläuterung siehe 10.3.

ANMERKUNG 1 Zur Verwendung von Konformitätsansprüchen in PP-Modulen siehe C.2.2.5.

ANMERKUNG 2 Zur Verwendung von Konformitätsansprüchen in PP-Modulen mit direkter Begründung siehe B.5.2.

Der Abschnitt „Konformitätserklärung eines PP“ beschreibt, wie das PP:

- auf eine oder mehrere Evaluierungsmethoden/-aufgaben verweist, die von ISO/IEC 18405 abgeleitet wurden;
- in Verbindung mit anderen PP und PP-Modulen in der PP-Konfiguration verwendet werden darf. Im Falle einer genauen Konformität ist die Konformitätserklärung erforderlich.

In der Konformitätserklärung bedeuten die Verweisungen auf die Evaluierungsmethoden/-aufgaben, dass das PP Verweisungen auf die Evaluierungsmethode(n) und/oder -aufgaben enthält, die während einer Evaluierung auf der Grundlage einer ST, die Konformität mit dem PP beansprucht, zu verwenden sind. Diese Evaluierungsmethoden und -aufgaben dürfen direkt in das PP aufgenommen werden oder einem referenzierten Begleitdokument entnommen werden. Es ist nicht notwendig, den Text dieser Evaluierungsmethoden und -aufgaben im PP wiederzugeben. Siehe 10.3.

Wenn Evaluierungsmethoden/-aufgaben, die von ISO/IEC 18405 abgeleitet wurden, zur Evaluierung des PP verwendet werden sollen, dann müssen diese mit dem entsprechenden Abschnitt der Sicherheitsanforderung durch eine Erklärung in der folgenden Form gekennzeichnet werden:

„Dieses PP erfordert die Verwendung der in <Verweisung(en)> festgelegten Evaluierungsmethoden/Evaluierungsaufgaben.“

In dieser Erklärung wird <Verweisung> durch die Angabe des Orts der betreffenden Evaluierungsmethoden und Evaluierungsaufgaben ersetzt. Diese Verweisung darf sich auf das Dokument beziehen, das das PP enthält, oder auf ein oder mehrere separate Dokumente.

ANMERKUNG 3 Wie in 13.5 dargelegt, wird die Verwendung bestimmter EM/EA in einigen Fällen von den Evaluierungsprogrammen nicht immer genehmigt.

Der Konformitätstyp im PP besagt, wie STs und/oder andere PPs mit diesem PP konform sein müssen. Der PP-Autor wählt aus, ob „genaue“, „strikte“ oder „nachweisliche“ Konformität erforderlich ist.

B.3.3.2 Genaue Konformität

Wenn die genaue Konformität gewählt wird, muss der PP-Autor gegebenenfalls die folgenden Informationen in der Zulässigkeitserklärung im Abschnitt über die Konformitätsansprüche des PP angeben:

- andere PP, die entweder von einer ST, die auf diesem PP basiert, oder in einer PP-Konfiguration mit diesem PP verwendet werden können;
- PP-Module, die dieses PP in der PP-Modulbasis dieses PP-Moduls festlegen können oder die in einer PP-Konfiguration vorhanden sein können, die dieses PP ebenfalls enthält.

ANMERKUNG 1 Wird keine der beiden vorgenannten Möglichkeiten in Anspruch genommen, so kann eine ST nur die genaue Konformität mit dem PP für sich beanspruchen.

ANMERKUNG 2 Ein PP kann keine genaue Konformität mit einem anderen PP beanspruchen.

B.3.4 Sicherheitsproblemdefinition (SPD) (APE_SPD)

Siehe 7.1 für Informationen und Anforderungen an die SPD einschließlich Bedrohungen, Annahmen und organisatorischer Sicherheitsrichtlinien (OSP).

B.3.5 Sicherheitszielsetzungen (APE_OBJ)

Zu den Informationen und Anforderungen für die Sicherheitszielsetzungen, einschließlich der Sicherheitszielsetzungen für den TOE und der Sicherheitszielsetzungen für die Betriebsumgebung, siehe 7.2

ANMERKUNG Im Falle der direkten Begründung sind Sicherheitszielsetzungen für den TOE nicht enthalten.

B.3.6 Erweiterte Komponentendefinition (APE_ECD)

Häufig basieren die Sicherheitsanforderungen in einem PP auf Komponenten, die in ISO/IEC 15408-2 oder ISO/IEC 15408-3 angegeben sind, siehe B.3.7. In einigen Fällen kann es allerdings Anforderungen in einem PP geben, die nicht auf Komponenten in ISO/IEC 15408-2 oder ISO/IEC 15408-3 basieren. In solchen Fällen müssen neue Komponenten, d. h. erweiterte Komponenten, definiert werden und die Definition im Abschnitt „Erweiterte Komponentendefinition“ enthalten sein. Für nähere Angaben siehe 8.4.

ANMERKUNG Dieser Unterabschnitt ist nur für die Aufnahme der erweiterten Komponenten gedacht und nicht für die erweiterten Anforderungen, die auf den erweiterten Komponenten basieren. Die erweiterten Anforderungen sind im Abschnitt „Sicherheitsanforderungen“ enthalten wie in B.3.7 beschrieben und werden für jeden Einsatzzweck identisch mit den Anforderungen behandelt, die auf den in ISO/IEC 15408-2 oder ISO/IEC 15408-3 angegebenen Komponenten beruhen.

B.3.7 Sicherheitsanforderungen (APE_REQ)

B.3.7.1 Allgemein

Die Sicherheitsanforderungen bestehen aus zwei Gruppen von Anforderungen:

- a) *Sicherheitsfunktionsanforderungen* (SFRs): eine Übertragung der Sicherheitszielsetzungen für den TOE in eine standardisierte Sprache;

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01 prEN ISO/IEC 15408-1:2023 (D)

- b) *Vertrauenswürdigkeitsanforderungen* (SARs): eine Beschreibung, wie die Zusicherung, dass der TOE die SFRs erfüllt, erreicht wird.

Diese zwei Gruppen werden in 7.3 erörtert.

B.3.7.2 Aufnahme von Anforderungen in ein PP

Bei einem PP mit strikter Konformität mit einem anderen PP müssen alle Anforderungen in diesem PP enthalten sein, und zusätzliche Anforderungen können in das konforme PP aufgenommen werden.

Bei einem PP mit nachweislicher Konformität mit einem anderen PP müssen alle Anforderungen in diesem PP enthalten sein, oder es muss eine Begründung angeführt werden, wie sie in dem konformen PP anderweitig erfüllt werden.

Die folgenden Arten von Ermessensanforderungen können in den PP in allen (genauen, strikten und nachweislichen) Konformitätstypen enthalten sein:

Enthält ein PP optionale Anforderungen, so kann ein konformes PP diese Anforderungen instanziiieren, wobei darauf zu achten ist, dass alle erforderlichen SPD-Elemente, die mit diesen Anforderungen verbunden sind, enthalten sind. Dies darf unabhängig von der durch das PP geforderten Konformität durchgeführt werden. Das Weglassen optionaler SFR stellt keine „Teilkonformität“ mit einem PP dar und ist daher zulässig.

B.4 Verweisen auf andere Normen in einem PP

In manchen Fällen muss ein PP-Autor auf eine externe Norm wie einen bestimmten kryptographischen Standard oder ein Protokoll verweisen. Die Normenreihe ISO/IEC 15408 erlaubt dies auf zwei Weisen.

- a) als eine OSP (oder ein Teil davon);

BEISPIEL 1 Es gibt eine Regierungsnorm zur Auswahl von Passwörtern; dies kann als OSP in einer PP angegeben werden. Dies kann zu einer Zielsetzung für die Umgebung führen (z. B. wenn Benutzer des TOEs Passwörter entsprechend wählen müssen) oder zu Sicherheitszielsetzungen für den TOE und dann zu entsprechenden SFRs (wahrscheinlich von der Klasse FIA), wenn der TOE Passwörter generiert. In beiden Fällen muss die Begründung des PP-Autors eine plausible Erklärung liefern, dass die Sicherheitszielsetzungen für den TOE und die SFRs die OSP erfüllen. Der Evaluator wird die tatsächliche Plausibilität überprüfen (und kann sich auch zu einer Betrachtung der Norm entschließen) und prüfen, ob die OSP durch die SFRs wie oben erklärt implementiert ist.

- b) als technische Norm, die bei der Präzisierung einer Komponente oder einer Sicherheitsanforderung verwendet wird.

BEISPIEL 2

FCS_CKM.1.1 „Refinement“: „Die [Auswahl: TSF, TOE-Plattform] muss asymmetrische kryptographische Schlüssel in Übereinstimmung mit einem festgelegten Algorithmus zum Generieren kryptographischer Schlüssel erzeugen

[Auswahl:

RSA-Programme, die kryptographische Schlüsselgrößen von 2048 Bit oder mehr verwenden und die folgenden Bedingungen erfüllen: [Auswahl:

FIPS PUB 186-4, „Digital Signature Standard (DSS)“, B.3;

ANSI X9.31-1998, 4.1];

ECC-Programme unter Verwendung der „NIST-Kurven“ P-256, P-384 und [Auswahl: P-521, keine anderen Kurven], die die folgenden Bedingungen erfüllen: FIPS PUB 186-4, „Digital Signature Standard (DSS)“, B.4;

FFC-Programme, die kryptographische Schlüsselgrößen von 2048 Bit oder mehr verwenden und die folgenden Bedingungen erfüllen: FIPS PUB 186-4, „Digital Signature Standard (DSS)“, B.1

]“.

Wenn eine Verweisung nur auf einen bestimmten Teil der Norm vorgesehen ist, muss dieser Teil unmissverständlich in der Präzisierung der SFR angegeben werden.

ANMERKUNG Der PP-Autor wird an dieser Stelle noch einmal daran erinnert, dass die Verweisung auf eine Norm in SFRs eine erhebliche Belastung für den Entwickler eines TOEs bei der Erfüllung des PP sein kann (abhängig von Größe und Komplexität der Norm und der erforderlichen Vertrauenswürdigkeit) und es kann daher sinnvoller sein, die Konformität mit der Norm über eine alternative (nicht CC-bezogene) Weise zu beurteilen.

B.5 Die PP mit direkter Begründung

B.5.1 Allgemein

Bei der Erstellung eines PP werden auch die ST berücksichtigt, die auf der Grundlage des PP geschrieben werden sollen. Wie in D.4 erwähnt, ist es in manchen Fällen erwünscht, ein PP zu schreiben, das die Spezifikation der ST mit direkter Begründung unterstützt.

Die Absicht des PP mit direkter Begründung ist es, den Grad der Indirektion zwischen der SPD, etwaigen Sicherheitszielsetzungen für die Betriebsumgebung und den SFR zu minimieren.

In manchen Situationen ist es angebracht, die Definition der Sicherheitszielsetzungen des TOE wegzulassen. In diesem Fall bilden die mit natürlichsprachlichen Beschreibungen angereicherten SFR und die Zielsetzungen für die Umgebung direkt die SPD ab.

Ein PP mit direkter Begründung besteht aus

- a) einer PP-Einleitung mit einer PP-Verweisung und einem TOE-Überblick,
- b) dem Konformitätsanspruch,
- c) Sicherheitszielsetzungen für die Betriebsumgebung;
- d) den SFRs und die SARs (einschließlich der erweiterten Komponentendefinition) und der Begründung für die Sicherheitsanforderungen (nur, wenn die Abhängigkeiten nicht erfüllt sind).

In Bild B.2 ist der Inhalt eines PP mit direkter Begründung dargestellt.

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

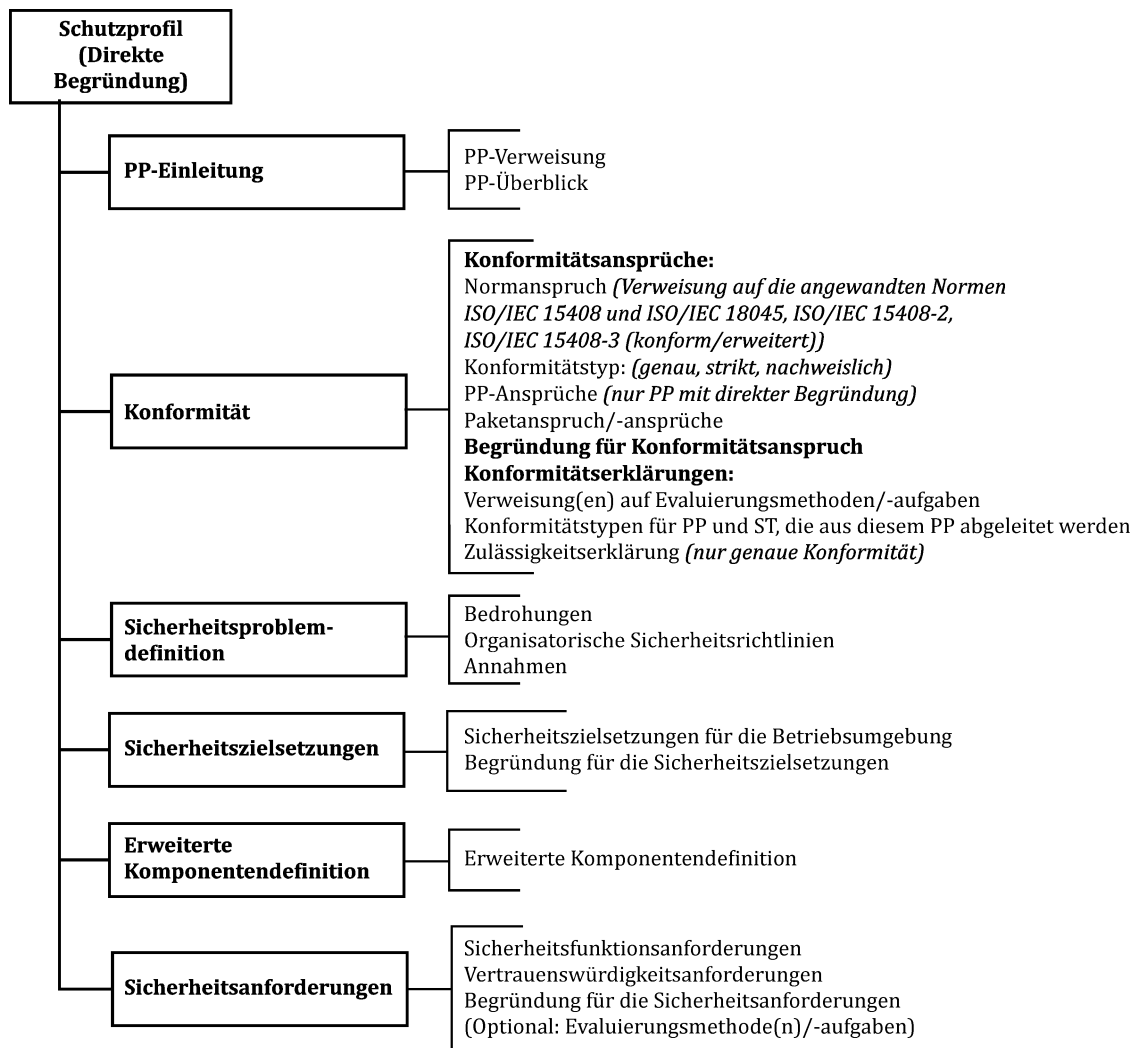


Bild B.2 — Inhalt eines PP mit direkter Begründung

B.5.2 Konformitätsansprüche (APE_CCL) für die PP mit direkter Begründung

Ein PP mit direkter Begründung darf nur Konformität mit einem anderen PP mit direkter Begründung beanspruchen.

Ein reguläres PP darf Konformität mit einem PP mit direkter Begründung beanspruchen.

B.5.3 Sicherheitszielsetzungen (APE_OBJ) für PP mit direkter Begründung

Ein PP mit direkter Begründung unterscheidet sich in Bezug auf die Sicherheitszielsetzungen wie folgt von einem PP, das Sicherheitszielsetzungen für den TOE enthält:

- Sicherheitszielsetzungen für den TOE sind nicht enthalten. Die Sicherheitszielsetzungen für die Betriebsumgebung müssen weiterhin beschrieben werden;
- eine Begründung der Sicherheitszielsetzungen ist nur für die Sicherheitszielsetzungen für die Betriebsumgebung enthalten, da es keine TOE-Sicherheitszielsetzungen im PP gibt;
- Sicherheitszielsetzungen (APE_REQ) für die PP mit direkter Begründung.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

Eine Begründung der Sicherheitsanforderungen, die die SFR und alle Sicherheitszielsetzungen für die Betriebsumgebung direkt den SPD-Elementen zuordnet, ist enthalten. Es wird empfohlen, diesen Teil der Begründung der Sicherheitsanforderungen direkt unter den einzelnen Bedrohungen, OSP und Annahmen im SPD-Abschnitt unterzubringen. Wie in regulären PP müssen auch in der Begründung der Sicherheitsanforderungen alle SFR-Abhängigkeiten, die nicht erfüllt werden, begründet werden; dieser Teil der Begründung befindet sich üblicherweise im Anschluss an die Definition der SFR.

B.6 Optionaler Inhalt eines PP

Die PP dürfen Evaluierungsmethoden/-aufgaben enthalten, die von ISO/IEC 18045 abgeleitet werden. Auf die mit dem PP verbundenen Evaluierungsmethoden/-aufgaben wird im Abschnitt Konformitätserklärung des PP verwiesen. Siehe 10.3.

Wenn der PP-Autor beschließt, eine oder mehrere Evaluierungsmethoden und/oder -aufgaben in das PP aufzunehmen, können diese entweder in einem (separaten) Begleitdokument oder im Abschnitt über die Sicherheitsanforderungen des PP zusammen mit der entsprechenden Sicherheitsanforderung beschrieben werden.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

Anhang C **(normativ)**

Spezifikation von PP-Modulen und PP-Konfigurationen

C.1 Ziel und Aufbau dieses Anhangs

Ziel dieses Anhangs ist die Zusammenfassung des Aufbaus und des erwarteten Inhalts der PP-Module und PP-Konfigurationen.

ANMERKUNG Dieser Anhang definiert nicht die Anforderungen an die Evaluierung von PP-Konfigurationen. Die Evaluierungskriterien für die PP-Konfiguration sind der ACE-Klasse in ISO/IEC 15408-3 entnommen.

C.2 Spezifikation von PP-Modulen

C.2.1 Unter Verwendung eines PP-Moduls

Ein PP-Modul ist eine Sicherheitserklärung einer Gruppe von Benutzern oder Entwicklern, Aufsichtsbehörden, der Verwaltung oder jeder anderen Entität, die spezifische Verbraucherbedürfnisse erfüllt. Ein PP-Modul ergänzt ein oder mehrere PP und gegebenenfalls andere PP-Module, die als „PP-Modulbasis“ dieses PP-Moduls bezeichnet werden, und ermöglicht es den Verbrauchern, sich auf diese Erklärung zu beziehen, erleichtert die Evaluierung anhand dieser Erklärung und den Vergleich von konformen evaluierten TOE. Ein PP-Modul kann nur innerhalb einer PP-Konfiguration verwendet werden, die diese PP-Modulbasis enthält.

ANMERKUNG Ein Basis-PP ist ein PP, das von einem PP-Modul benötigt wird. Ein Basis-PP-Modul ist ein PP-Modul, das zusammen mit seiner PP-Modulbasis von einem anderen PP-Modul benötigt wird.

C.2.2 Verpflichtender Inhalt eines PP-Moduls

C.2.2.1 Allgemein

Bild C.1 zeigt den Inhalt eines PP-Moduls.

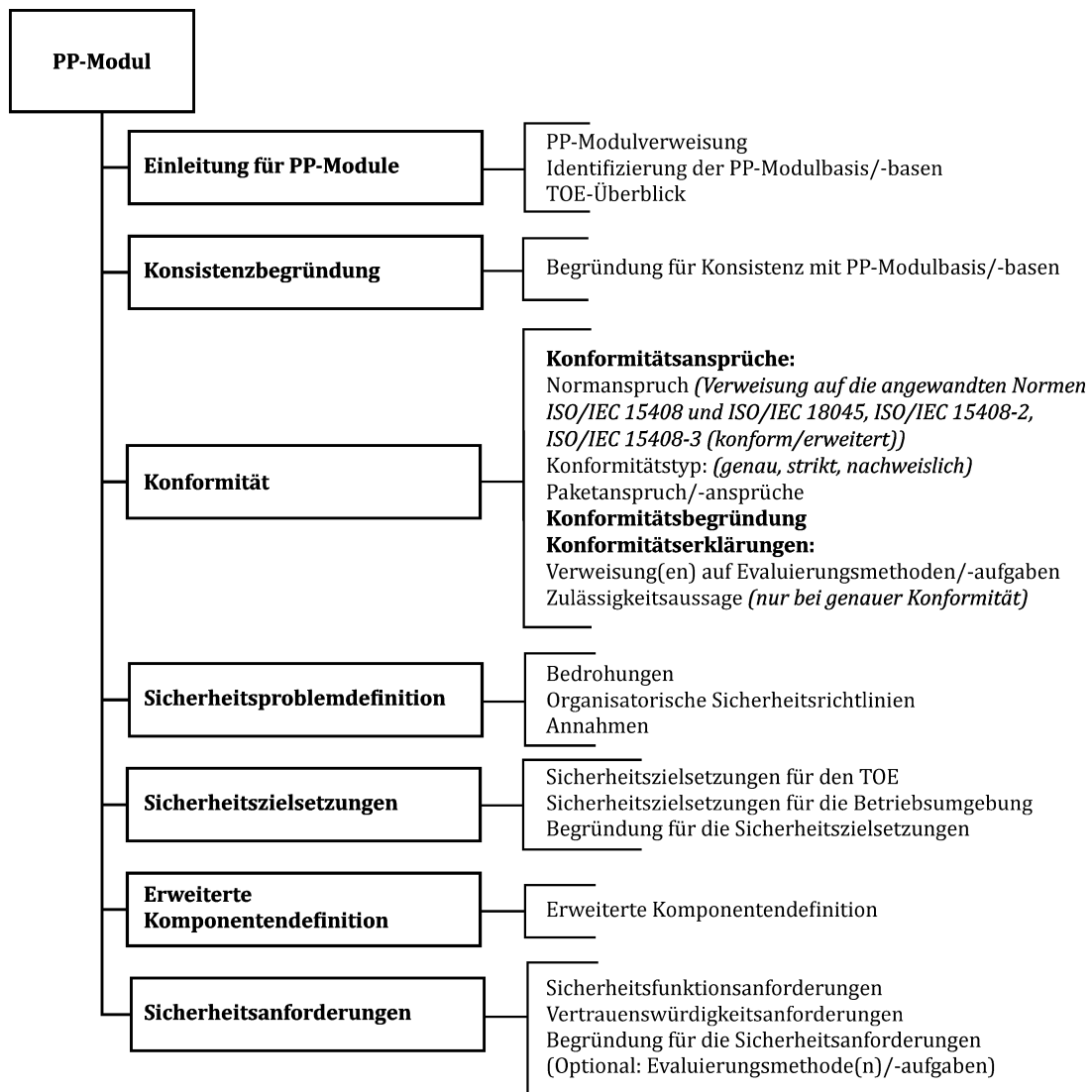


Bild C.1 — Inhalt eines PP-Moduls

Der Inhalt eines PP-Moduls wird im Folgenden zusammengefasst und in C.2.2.2 bis C.2.3 näher erläutert. Ein PP-Modul enthält

- eine *Einleitung*, die das PP-Modul identifiziert, die PP-Modulbasis, auf der es basiert, identifiziert und eine Beschreibung des TOE in seiner Umgebung liefert, die den Beschreibungen entspricht, die der PP-Modulbasis zugrunde liegen,
- eine *Konsistenzbegründung*, die die Übereinstimmung zwischen dem PP-Modul und seiner PP-Modulbasis angibt,
- einen *Konformitätsanspruch* bezüglich der Ausgabe der Normenreihe ISO/IEC 15408, die Konformitätserklärung und für den Fall der genauen Konformität die Zulässigkeitsklärungen,
- eine *Sicherheitsproblemdefinition* mit Bedrohungen, Annahmen und OSP,
- einen Abschnitt „*Sicherheitszielsetzungen*“, in dem die Lösung des Sicherheitsproblems in Form von Zielsetzungen für den TOE und seine Betriebsumgebung dargestellt wird,

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

- eine optionale Definition der *erweiterten Funktionskomponenten*, in die neue, in ISO/IEC 15408-2 nicht enthaltene Funktionskomponenten aufgenommen werden,
- einen Abschnitt *Sicherheitsfunktionsanforderungen* mit einer standardisierten Erklärung der TOE-Sicherheitszielsetzungen,
- einen Abschnitt „*Vertrauenswürdigkeitsanforderung*“, außer bei der genauen Konformität, bei der die SAR von den Basis-PP übernommen werden.

C.2.2.2 Einleitung für PP-Module**C.2.2.2.1 PP-Modulverweisung**

Die Einleitung des PP-Moduls bietet eine klare und eindeutige Verweisung, die die Identifizierung des PP-Moduls ermöglicht. Üblicherweise wird auf die Überschrift des PP-Moduls und die Version des Dokuments, die Antragsteller und das Veröffentlichungsdatum verwiesen.

Die Verweisung auf PP-Module kann zur Indizierung des Dokuments in PP-Katalogen verwendet werden.

C.2.2.2.2 Identifizierung der PP-Modulbasis

Die Einleitung des PP-Moduls identifiziert seine PP-Modulbasis. Die Identifizierung besteht aus einer Liste von Verweisungen.

Ein PP-Modul, das mit einer PP-Modulbasis, beispielsweise $\{B_1 \dots, B_n\}$, verwendet werden soll, liefert eine Identifikationsliste der folgenden Form:

$$B_1 \dots \text{UND} \dots B_n, \text{ wobei } n \geq 1$$

Dieser Satz von PP/PP-Modulen muss geschlossen sein, d. h. für jedes PP-Modul B_i muss seine eigene PP-Modulbasis zum Satz $\{B_1 \dots B_n\}$ gehören.

ANMERKUNG 1 Das bedeutet, dass die Menge $\{B_1 \dots, B_n\}$ entweder kein PP-Modul enthält oder dass sie mindestens ein PP-Modul enthält, das nur Basis-PP benötigt, aber kein anderes Basis-PP-Modul.

Ein PP-Modul darf auch alternative Mengen von PP-Modulbasen zulassen, z. B. $\{S_1 \dots S_k\}$; in diesem Fall lautet die Identifikationsliste:

$$S_1 \dots \text{ODER} \dots S_k, \text{ wobei } k \geq 1$$

Die entfaltete Form der Identifizierung alternativer Sätze von PP-Modulbasen ist dann:

$$(B_1 \dots \text{UND} \dots B_{n1}) \dots \text{ODER} \dots (B_1 \dots \text{UND} \dots B_{nk}), \text{ wobei } k \geq 1 \text{ und } n_i \geq 1$$

ANMERKUNG 2 Ein PP-Modul, das eine ODER-verknüpfte Liste angibt, ist äquivalent zu so vielen PP-Modulen wie Elementen S_i in der Liste, d. h. eine ODER-verknüpfte Liste ist eine Abkürzung, um die Definition und Pflege ähnlicher PP-Module für verschiedene Verwendungen zu vermeiden.

C.2.2.2.3 TOE-Überblick

Der TOE-Überblick eines PP-Moduls darf die TOE-Überblicke der PP-Modulbasis ergänzen, sofern die Konsistenz zwischen dem PP-Modul und seiner PP-Modulbasis sichergestellt ist;

- der TOE-Typ des PP-Moduls kann entweder derselbe sein wie der der PP-Modulbasis oder er kann Besonderheiten enthalten, die zur Erfüllung des Zwecks des PP-Moduls erforderlich sind;
- das PP-Modul darf zusätzlich zu den in der PP-Modulbasis genannten weitere Nutzungs- und wichtige Sicherheitsmerkmale einführen;

- das PP-Modul kann bestimmte Nicht-TOE-Hardware, -Software und/oder -Firmware festlegen, die mit der Aussage in der PP-Modulbasis konform sind.

In einem PP-Modul hat die Möglichkeit, den TOE-Überblick der PP-Modulbasis zu ergänzen, die gleiche Bedeutung wie in einem PP oder einer ST, die den TOE-Überblick eines anderen PP ergänzen, mit dem sie Konformität beanspruchen.

Die Aussage des TOE-Überblicks in einem PP-Modul darf durch Verweisung angegeben werden, wenn sie dieselbe ist wie in seiner PP-Modulbasis, d. h. wenn es keinen Zusatz gibt. Das PP-Modul darf so viele spezifische TOE-Überblicke bereitstellen wie alternative PP-Modulbasen.

C.2.2.3 Konsistenzbegründung

Das PP-Modul muss eine Begründung für die Konsistenz in Bezug auf seine PP-Modulbasis enthalten.

Wenn das PP-Modul alternative PP-Modulbasen angibt, muss die Anzahl der vom PP-Modul angegebenen Konsistenzbegründungen der Anzahl der alternativen PP-Modulbasen entsprechen.

Die Konsistenzanalyse für jede PP-Modulbasis muss für den TOE-Typ, die SPD, die Zielsetzungen und die SFR durchgeführt werden. Am Ende soll der Nachweis erbracht werden, dass ein TOE die Beschreibungen des TOE-Typs in der PP-Modulbasis und im PP-Modul erfüllen kann und alle im PP-Modul und seiner PP-Modulbasis festgelegten SFR erfüllt. Die Konsistenzbegründung muss zeigen, dass die im PP-Modul und in seiner PP-Modulbasis definierten Vereinigungen von SPD, Zielsetzungen und SFR nicht zu Widersprüchen führen.

Für die Begründung der Konsistenz dürfen Tabellen mit Übereinstimmungen zwischen SPD/Zielsetzungen/SFR zusammen mit textlichen Begründungen verwendet werden.

C.2.2.4 Begründung für die Vertrauenswürdigkeit

Die Begründung für die Vertrauenswürdigkeit muss die Konsistenz des anwendbaren Satzes an SAR, die von den Basis-PP übernommen werden dürfen, mit der im PP-Modul definierten SPD nachweisen, d. h. die Vertrauenswürdigkeitsanforderungen und das Bedrohungsmodell sind nicht widersprüchlich.

Wenn das PP-Modul seinen Satz an SAR nicht von seinen Basis-PP übernimmt, dann muss die Begründung für die Vertrauenswürdigkeit zeigen, dass die Vertrauenswürdigkeitsanforderungen im PP-Modul und in seiner PP-Modulbasis in Bezug auf die Vermögenswerte, die dem PP-Modul und seiner PP-Modulbasis gemeinsam sind, nicht widersprüchlich sind.

C.2.2.5 Konformitätsansprüche und Konformitätserklärung

C.2.2.5.1 Allgemein

Dieser Abschnitt eines PP-Moduls muss für alle PP-Module enthalten sein und beschreibt die Konformität des PP-Moduls mit:

- ISO/IEC 15408-2, ISO/IEC 15408-3, deren Ausgaben und jeglicher Verwendung von erweiterten Sicherheitsanforderungen;
- Funktions- und Vertrauenswürdigkeitspaketen.

Ein PP-Modul darf keine Konformität mit irgendeinem PP, einem anderen PP-Modul oder einer PP-Konfiguration beanspruchen.

Die Konformitätserklärung des PP-Moduls identifiziert den erforderlichen Konformitätstyp. Genaue Konformität wird von den Basis-PP übernommen und erfordert, dass alle PP-Modulbasen ebenfalls von genauer Konformität sind. In der Konformitätserklärung des PP-Moduls können auch alle Evaluierungsmethoden/-aufgaben angegeben werden, die im Zusammenhang mit dem Modul verwendet werden müssen.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01 prEN ISO/IEC 15408-1:2023 (D)

Wenn Evaluierungsmethoden/-aufgaben, die von ISO/IEC 18045 abgeleitet wurden, zur Evaluierung des PP-Moduls verwendet werden sollen, dann müssen diese mit dem entsprechenden Abschnitt der Sicherheitsanforderung durch eine Erklärung in der folgenden Form gekennzeichnet werden:

„Dieses PP-Modul erfordert die Verwendung der in <Verweisung> festgelegten Evaluierungsmethoden/Evaluierungsaufgaben.“

Dabei wird <Verweisung> durch die Angabe des Orts der für das PP-Modul geltenden Evaluierungsmethoden und Evaluierungsaufgaben ersetzt. Diese Verweisung darf sich auf das Dokument beziehen, das das Paket enthält, oder auf ein oder mehrere separate Dokumente.

ANMERKUNG Evaluierungsmethoden/Evaluierungsaufgaben können entweder in das PP-Modul selbst aufgenommen werden oder durch Verweisung auf ein oder mehrere separate Dokumente, in denen sie beschrieben werden.

C.2.2.5.2 Genaue Konformität

Im Falle einer genauen Konformität enthält die Zulässigkeitserklärung auch eine Identifizierung der PP und PP-Module, die in PP-Konfigurationen mit diesem PP-Modul verwendet werden dürfen, mit Ausnahme der PP-Modulbasen des PP-Moduls.

Alle Komponenten in einer PP-Konfiguration, die genaue Konformität erfordern, müssen auch in ihren Konformitätserklärungen genaue Konformität erfordern.

ANMERKUNG 1 Damit wird das Konzept der genauen Konformität beibehalten, dass die Autoren des PP-Moduls die Kontrolle darüber haben, welche anderen Anforderungen in Kombination mit den in ihrem PP-Modul festgelegten Anforderungen festgelegt werden können.

Bild C.2 zeigt, wie Konformitätsansprüche und -erklärungen im Fall der genauen Konformität mit Einfach-Vertrauenswürdigkeit übernommen werden.

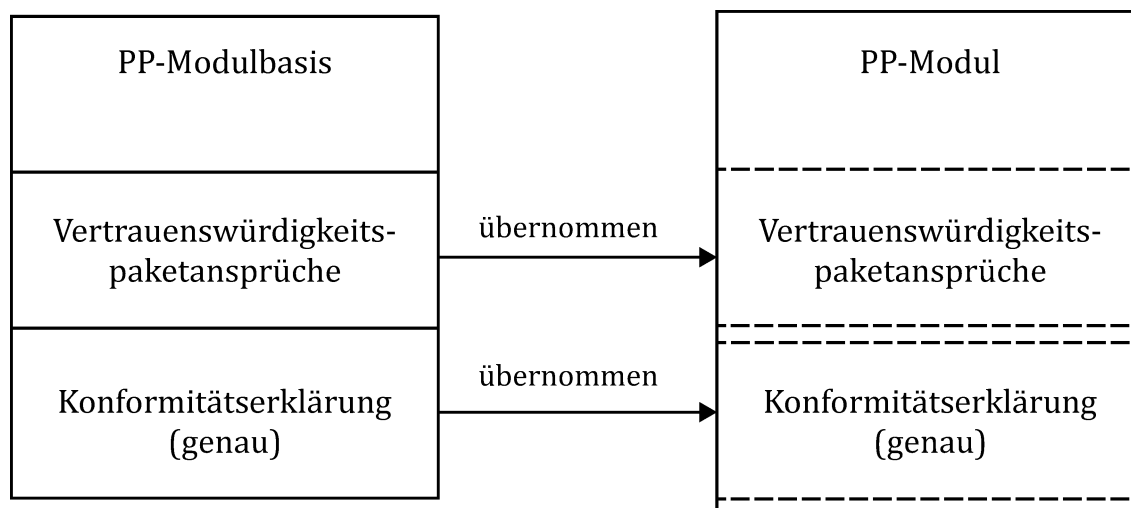


Bild C.2 — Übernommene Konformitätsansprüche und -erklärungen für den Fall der genauen Konformität

ANMERKUNG 2 Bei genauer Konformität ist es nicht zulässig, dass die EM/EA in einer PP-Konfiguration definiert werden (d. h. die zu verwendenden EM/EA werden nur in den in der PP-Konfiguration verwendeten PP und PP-Modulen angegeben).

C.2.2.6 Sicherheitsproblemdefinition (SPD)

In diesem Abschnitt wird das Sicherheitsproblem definiert, mit dem sich das PP-Modul befasst. Es kann alle Arten von SPD-Elementen enthalten, d. h. Annahmen, Bedrohungen und OSP.

Ein PP-Modul definiert das Sicherheitsproblem im Zusammenhang mit dem Sicherheitsproblem der PP-Modulbasis und der Definition des TOE und seiner Umgebung, die in der *Einleitung* des PP-Moduls gegeben wird.

Jedes SPD-Element kann entweder aus einer PP-Modulbasis stammen oder völlig neu sein. Wenn „E“ ein SPD-Element des PP-Moduls ist, gilt einer der folgenden Fälle:

- „E“ gehört zu einer identifizierten PP-Modulbasis; eine Verweisung auf das SPD-Element ist ausreichend;
- „E“ ist eine Präzisierung für ein SPD-Element einer PP-Modulbasis;
- „E“ ist ein neues SPD-Element, das sich auf zusätzliche Merkmale des TOE oder seiner Umgebung bezieht.

ANMERKUNG 1 Die präzisierten SPD-Elemente können als neue SPD-Elemente behandelt werden, ohne dass dies Auswirkungen auf den Sinn der SPD hat.

ANMERKUNG 2 Genauso wie die ST kann ein PP-Modul Annahmen einführen, sofern sie Aspekte abdecken, die nicht in den Anwendungsbereich der PP-Modulbasis fallen.

C.2.2.7 Sicherheitszielsetzungen

In diesem Abschnitt werden die Sicherheitszielsetzungen für den TOE und dessen Betriebsumgebung definiert.

Ein PP-Modul definiert neue Sicherheitszielsetzungen im Zusammenhang mit den Sicherheitszielsetzungen der PP-Modulbasis.

Jede Sicherheitszielsetzung kann entweder aus einer PP-Modulbasis stammen oder völlig neu sein. Wenn „O“ eine Zielsetzung des PP-Moduls ist, gilt einer der folgenden Fälle:

- „O“ gehört zur PP-Modulbasis; eine Verweisung auf die Sicherheitszielsetzung ist ausreichend;
- „O“ ist eine Präzisierung für eine Sicherheitszielsetzung der PP-Modulbasis;
- „O“ ist eine neue Zielsetzung, die durch das PP-Modul eingeführt wird.

ANMERKUNG Die präzisierten Zielsetzungen können als neue Zielsetzungen behandelt werden, ohne dass dies Auswirkungen auf den Sinn des gesamten Satzes von Zielsetzungen hat.

Ein PP-Modul darf nur dann neue Zielsetzungen für die Betriebsumgebung des TOE einführen, wenn sie Aspekte betreffen, die außerhalb des Anwendungsbereichs der PP-Modulbasis liegen.

In dem Fall, dass ein PP-Modul den TOE-Typ präzisiert, können einige Sicherheitszielsetzungen für die Umgebung der PP-Modulbasis zu Sicherheitszielsetzungen für den TOE im PP-Modul werden.

Dieser Abschnitt definiert auch den Zusammenhang zwischen der SPD und den Sicherheitszielsetzungen des PP-Moduls, der aus einer Zuordnung besteht, die die SPD des PP-Moduls auf ihre Sicherheitszielsetzungen zurückführt, sowie aus einer Begründung, die zeigt, dass die Rückführung wirksam ist, wie in 7.2.5 beschrieben. Außerdem muss die Zuordnung nicht nur zeigen, dass alle SPD-Elemente abgedeckt sind, sondern auch, dass es keine nutzlose Sicherheitszielsetzung gibt.

Es kann vorkommen, dass einige Sicherheitszielsetzungen des PP-Moduls auch SPD-Elemente der PP-Modulbasis umfassen, die nicht zur SPD des PP-Moduls selbst gehören. Diese Angaben sind nicht erforderlich, können aber in den Anwendungshinweisen gemacht werden.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****C.2.2.8 Definition der erweiterten Funktionskomponenten**

Dieser Abschnitt ist identisch mit dem Abschnitt über die erweiterten PP- und ST-Komponenten in B.3.6.

C.2.2.9 Sicherheitsanforderungen

Die Sicherheitsanforderungen bestehen aus zwei Gruppen von Anforderungen:

a) Sicherheitsfunktionsanforderungen (SFRs)

eine Übertragung der Sicherheitszielsetzungen für den TOE in eine standardisierte Sprache;

b) Vertrauenswürdigkeitsanforderungen (SARs)

Eine Beschreibung, wie die Zusicherung, dass der TOE die SFRs erfüllt, erreicht wird.

Diese zwei Gruppen werden in 7.3 erörtert.

C.2.2.9.1 Sicherheitsfunktionsanforderungen (SFRs)

In diesem Abschnitt werden die SFR für den TOE im Zusammenhang mit dem Satz an TOE-Sicherheitszielsetzungen im PP-Modul und mit den SFR der PP-Modulbasis definiert.

Jede Sicherheitsfunktionsanforderung kann entweder aus der PP-Modulbasis stammen oder völlig neu sein. Wenn „R“ eine Sicherheitsfunktionsanforderung des PP-Moduls ist, gilt einer der folgenden Fälle:

- „R“ gehört zur PP-Modulbasis; eine Verweisung auf die Anforderung ist ausreichend;
- „R“ ist eine Präzisierung für eine SFR in der PP-Modulbasis;
- „R“ ist eine neue Anforderung, die durch das PP-Modul eingeführt wird.

ANMERKUNG Die präzisierten Anforderungen können als neue Anforderungen behandelt werden, ohne dass dies Auswirkungen auf den Sinn des gesamten Satzes von Anforderungen hat.

Dieser Abschnitt definiert auch den Zusammenhang zwischen den SFR und den TOE-Sicherheitszielsetzungen des PP-Moduls, der aus einer Zuordnung besteht, die die SFR auf die TOE-Zielsetzungen des PP-Moduls zurückführt, sowie aus einer Begründung, die zeigt, dass die Rückführung wirksam ist, wie in 7.2.5 festgelegt. Außerdem muss die Zuordnung nicht nur zeigen, dass alle Zielsetzungen für den TOE abgedeckt sind, sondern auch, dass es keine nutzlose Sicherheitsfunktionsanforderung gibt.

Es kann vorkommen, dass einige SFR des PP-Moduls auch TOE-Sicherheitszielsetzungen der PP-Modulbasis umfassen, die nicht zum PP-Modul selbst gehören. Diese Angaben sind nicht erforderlich, können aber in den Anwendungshinweisen gemacht werden.

PP-Module dürfen optionale SFR (und alle erforderlichen SPD-Elemente) definieren und enthalten, wie zuvor für die PP in B.3.7 angegeben.

C.2.2.9.2 Vertrauenswürdigkeitsanforderungen (SARs)

Ein PP-Modul definiert den Satz an SAR, der in PP-Konfigurationen, die dieses PP-Modul enthalten, zu verwenden sind. Die in C.2.2.4. beschriebene Begründung für die Vertrauenswürdigkeit stellt die Konsistenz dieses Satzes an SAR in Bezug auf die PP-Modulbasis sicher.

Ein PP-Modul, das die Einfach-Vertrauenswürdigkeit verwendet, übernimmt den Satz an SAR, einschließlich aller Vertrauenswürdigkeitspakete wie die vordefinierten EAL, von seiner PP-Modulbasis. Das Problem der UND-verknüpften Elemente der PP-Modulbasis mit unterschiedlichen SAR muss auf dieselbe Weise gelöst und gehandhabt werden, wie ein PP, das mit all diesen PP konform ist, mit diesem Problem umgeht.

C.2.3 PP-Module mit direkter Begründung

PP-Module können mit der Absicht geschrieben werden, dass sie mit Komponenten in ihrer PP-Modulbasis verwendet werden, die ebenfalls den Ansatz der direkten Begründung verwenden. In diesem Fall werden die Sicherheitszielsetzungen für den TOE nicht in das PP-Modul aufgenommen, während die Sicherheitszielsetzungen für die Betriebsumgebung des TOE aufgenommen werden dürfen.

In Bild C.3 sind die Inhalte für ein PP-Modul mit direkter Begründung dargestellt.

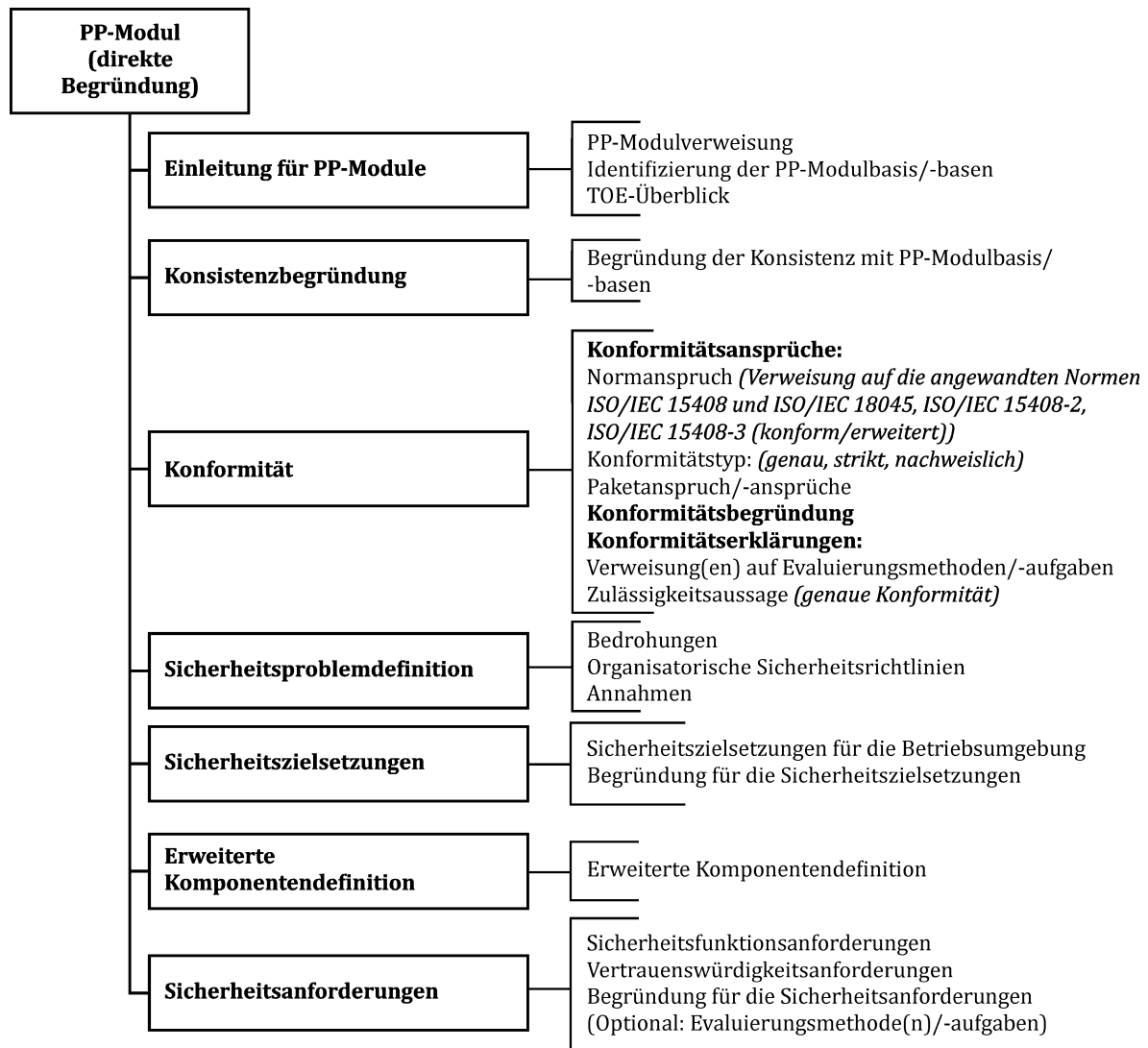


Bild C.3 — Inhalte eines PP-Moduls mit direkter Begründung

C.2.4 Leitlinien für die Einbeziehung von SPD-Elementen aus einer PP-Modulbasis

Um die Menge der in einem PP-Modul enthaltenen Informationen zu begrenzen, wendet der Autor des PP-Moduls die folgenden Regeln an:

E gehört zur SPD, O zu den Sicherheitszielsetzungen und R zu den SFR eines PP/PP-Moduls Q, wobei R auf O und O auf E abgebildet ist.

M sei ein PP-Modul und Q gehöre zur PP-Modulbasis von M.

– Entwurf –

E DIN EN ISO/IEC 15408-1:2024-01 prEN ISO/IEC 15408-1:2023 (D)

M muss die folgende Bedingung erfüllen: E, O, R und die Zuordnungen zwischen ihnen sollten nur dann zu M gehören, wenn mindestens eines dieser Elemente mit einem neuen Element in M verbunden ist, d. h.:

- entweder gibt es ein neues SPD-Element E' in M, so dass O auf E' abgebildet wird, oder
- es gibt eine neue Zielsetzung O' in M, so dass O' auf E' abgebildet wird oder R auf O' abgebildet wird; oder
- es gibt eine neue Anforderung R' in M, so dass R auf O' abgebildet wird.

Ein PP-Modul würde keine Teile der PP-Modulbasis enthalten, es sei denn, sie werden benötigt, um neue Anforderungen zu erfüllen. Hier werden präzisierte Elemente als neu angesehen.

C.2.5 Optionaler Inhalt eines PP-Moduls

PP-Module dürfen optional Evaluierungsmethoden/-aufgaben enthalten, die von ISO/IEC 18045 abgeleitet wurden. Die mit dem PP-Modul verbundenen Evaluierungsmethoden/-aufgaben sind im Abschnitt Konformitätserklärung angegeben. Siehe 11.2.3.3.

Wenn der Autor des PP-Moduls beschließt, Evaluierungsmethoden und/oder -aufgaben in das PP-Modul aufzunehmen, können diese entweder im Abschnitt über die Sicherheitsanforderungen mit der entsprechenden Sicherheitsanforderung oder in einem anderen geeigneten Abschnitt oder externen Dokument bereitgestellt werden. Anwendungshinweise sollten gegebenenfalls mit den spezifischen Anforderungen des PP-Moduls verknüpft werden.

C.3 Spezifikation von PP-Konfigurationen

C.3.1 Allgemein

Der Inhalt einer PP-Konfiguration wird im nachstehenden Bild C.4 zusammengefasst und in C.3.2 bis C.3.7 näher erläutert.

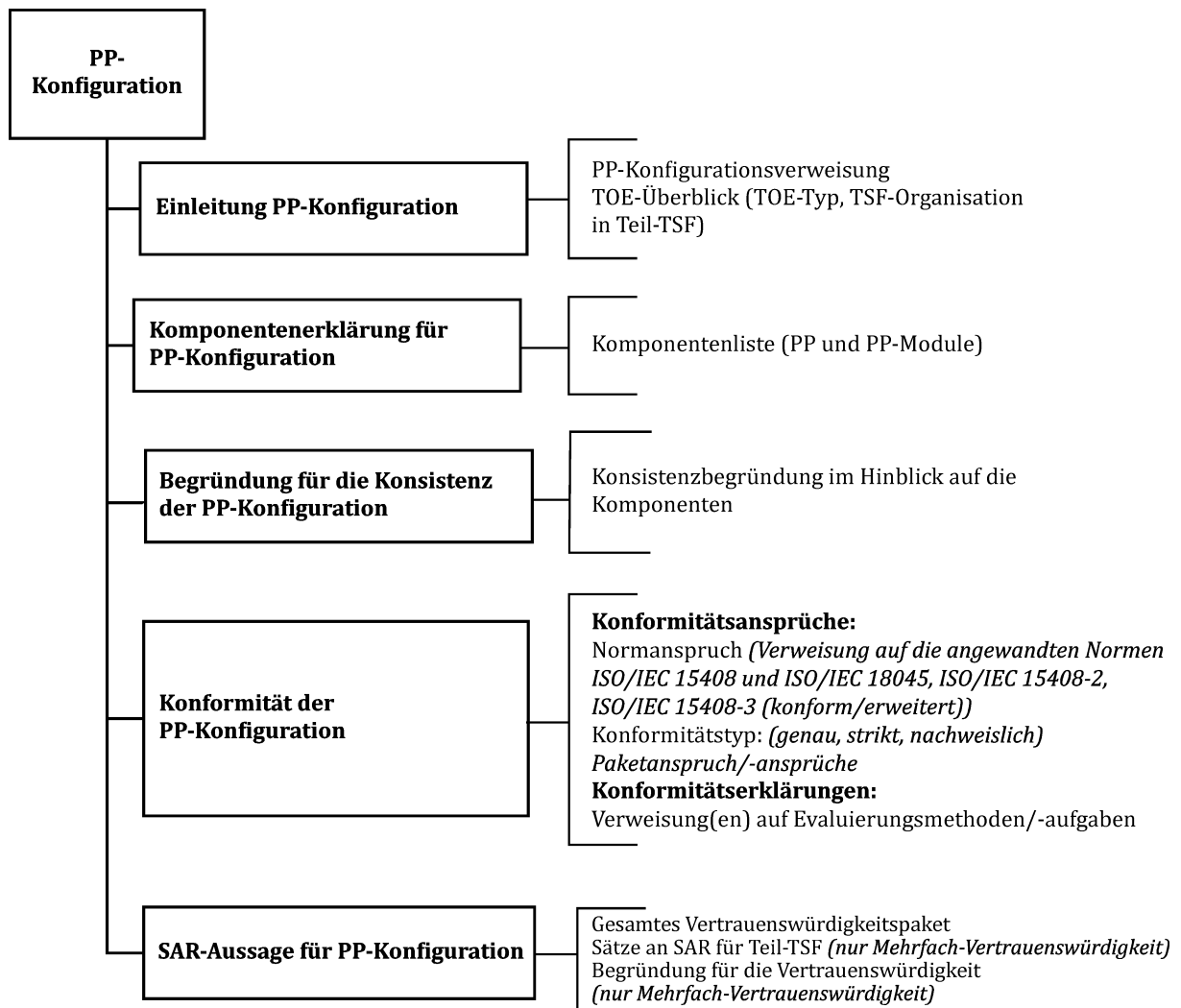


Bild C.4 — Inhalt einer PP-Konfiguration

Eine PP-Konfiguration enthält:

- eine Verweisung, die die PP -Konfiguration eindeutig identifiziert;
- eine Komponentenerklärung, die die PP und die PP-Module identifiziert, aus denen sich die PP-Konfiguration zusammensetzt, einschließlich aller PP-Modulbasen, die zur Definition eines geschlossenen Satzes von Komponenten erforderlich sind;
- einen Konformitätsanspruch, der die Ausgabe der relevanten Teile der Normenreihe ISO/IEC 15408, die Ansprüche an ISO/IEC 15408-2 und ISO/IEC 15408-3, die Ansprüche an die Vertrauenswürdigkeitspakete und die Konformitätserklärung angibt, die definiert, ob die Konformität der ST mit dieser PP-Konfiguration genau, strikt, nachweislich oder eine Kombination aus strikt und nachweislich sein muss, die sich aus dem Satz ihrer Komponenten ergibt, sowie alle anwendbaren Evaluierungsmethoden/-aufgaben;
- eine Beschreibung des TOE-Typs;
- eine Beschreibung der TSF-Organisation in Bezug auf die durch die PP-Konfigurationskomponenten definierten Teil-TSF;
- eine SAR-Aussage, die den Satz an SAR festlegt, der auf den gesamten TOE anwendbar ist. In einem Fall mit Mehrfach-Vertrauenswürdigkeit enthält die SAR-Aussage die Sätze an SAR, die für die in den PP-Konfigu-

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01 prEN ISO/IEC 15408-1:2023 (D)

rationskomponenten definierten Teil-TSF gelten. Die SAR-Aussage enthält auch eine Begründung für die Vertrauenswürdigkeit, um die Konsistenz zwischen der PP-Konfiguration und ihren Komponenten sicherzustellen.

ANMERKUNG Ein Vertrauenswürdigkeitspaket kann eine EAL sein, die aus ISO/IEC 15408-5 stammt.

C.3.2 PP-Konfigurationsverweisung

Die PP-Konfigurationsverweisung bietet eine klare und eindeutige Identifizierung, die in der Regel aus einer Überschrift, Versionsnummer, einem Autor und dem Veröffentlichungsdatum besteht.

Die PP-Konfigurationsverweisung kann zur Indizierung des Dokuments in Katalogen verwendet werden.

C.3.3 Komponentenerklärung

Die Komponentenerklärung der PP-Konfiguration identifiziert die PP und die PP-Module, aus denen die PP-Konfiguration besteht.

Die Komponentenerklärung der PP-Konfiguration muss die PP-Modulbasis enthalten, die von den angegebenen PP-Modulen benötigt wird. Wenn ein PP-Modul alternative Sätze von PP-Modulbasen festlegt, darf in der PP-Konfiguration nur auf einen dieser Sätze verwiesen werden.

ANMERKUNG PP-Konfigurationen erheben keinen direkten Anspruch auf Konformität mit Funktionspaketen, unabhängig davon, ob sie von einer ihrer Komponenten beansprucht werden oder nicht.

Im Fall mit Mehrfach-Vertrauenswürdigkeit muss die Komponentenerklärung der PP-Konfiguration die TSF-Organisation in Form der durch die Komponenten der PP-Konfiguration definierten Teil-TSF angeben.

C.3.4 TOE-Überblick

Der TOE-Überblick über eine PP-Konfiguration muss Folgendes enthalten:

- den TOE-Typ der PP-Konfiguration, der von den ST zu verwenden ist, die Konformität mit der PP-Konfiguration beanspruchen;
- die erwartete Verwendung und wesentlichen Sicherheitsmerkmale des TOEs;
- die verfügbare, nicht im TOE enthaltene Hardware, Software und/oder Firmware (falls zutreffend)

C.3.5 Konsistenzbegründung

Eine PP-Konfiguration muss eine Begründung für die Konsistenz enthalten, um die Kompatibilität der Kombination von Komponenten sicherzustellen.

Die Konsistenzbegründung muss aufzeigen, dass der TOE-Überblick mit dem TOE-Überblick der PP-Konfigurationskomponenten konsistent ist und dass die in diesen Komponenten definierten Vereinigungen von SPD, Zielsetzungen und SFR nicht zu Widersprüchen führen.

Für die Begründung der Konsistenz dürfen Tabellen mit Übereinstimmungen zwischen SPD/Zielsetzungen/SFR zusammen mit textlichen Begründungen verwendet werden.

C.3.6 Konformitätsanspruch und Konformitätserklärung

C.3.6.1 Konformitätsanspruch der Normenreihe ISO/IEC 15408

Die Ausgabe der relevanten Teile der Normenreihe ISO/IEC 15408, die für die PP-Konfiguration gelten.

C.3.6.2 Konformitätstyp

Die Konformität einer ST mit dieser PP-Konfiguration muss genau, strikt oder nachweislich sein; oder eine Kombination aus strikt und nachweislich, wenn die PP-Konfiguration Komponenten beider Konformitätstypen enthält.

Jede ST, die Konformität mit einer PP-Konfiguration beansprucht, muss mit dem in der Konformitätserklärung der PP-Konfiguration geforderten Konformitätstyp konform sein.

C.3.6.3 Konformitätsanspruch des Vertrauenswürdigkeitspakets

Der Konformitätsanspruch kann einen Konformitätsanspruch für ein Vertrauenswürdigkeitspaket enthalten, der die Konformität der PP-Konfiguration mit einem Vertrauenswürdigkeitspaket beschreibt. In einer PP-Konfiguration kann mehr als ein Paket beansprucht werden.

C.3.6.4 Verweisungserklärung(en) zu Evaluierungsmethoden/-aufgaben

In der Konformitätserklärung für die PP-Konfiguration EM/EA dürfen auch alle Evaluierungsmethoden/-aufgaben angegeben werden, die im Zusammenhang mit dem Modul verwendet werden müssen.

Eine PP-Konfiguration, die vom Typ der strikten oder nachweislichen Konformität (aber nicht vom Typ der genauen Konformität) ist, darf Evaluierungsmethoden/-aufgaben zusätzlich zu denen angeben, auf die in den PP-Konfigurationskomponenten verwiesen wird.

C.3.6.5 Zusätzliche Anforderungen für die genaue Konformität

Wenn eine PP-Konfiguration in ihrer Konformitätserklärung genaue Konformität als ihren Konformitätstyp angibt, dann gilt Folgendes:

- Wenn eine Komponente in der PP-Konfiguration genaue Konformität erfordert, dann müssen auch alle anderen Komponenten in der PP-Konfiguration genaue Konformität erfordern, und die Konformitätserklärung der PP-Konfiguration muss genaue Konformität festlegen;
- alle Komponenten in der PP-Konfiguration müssen es allen anderen Komponenten in der PP-Konfiguration erlauben, zusammen in der PP-Konfiguration in ihrer jeweiligen Zulässigkeitserklärung im Abschnitt „Konformitätsansprüche“ verwendet zu werden;

ANMERKUNG Ein PP-Modul braucht seine eigene PP-Modulbasis nicht in seine Zulässigkeitserklärung aufnehmen, da sie implizit erlaubt sind. Ein Beispiel ist in Bild C.5 dargestellt.

- die EM/EA, die auf eine PP-Konfiguration angewendet werden, dürfen nur diejenigen sein, die in den Komponenten der PP-Konfiguration enthalten sind; es sind keine zusätzlichen Evaluierungsmethoden/-aufgaben oder Änderungen an den Evaluierungsmethoden/-aufgaben der Komponenten der PP-Konfiguration erlaubt.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

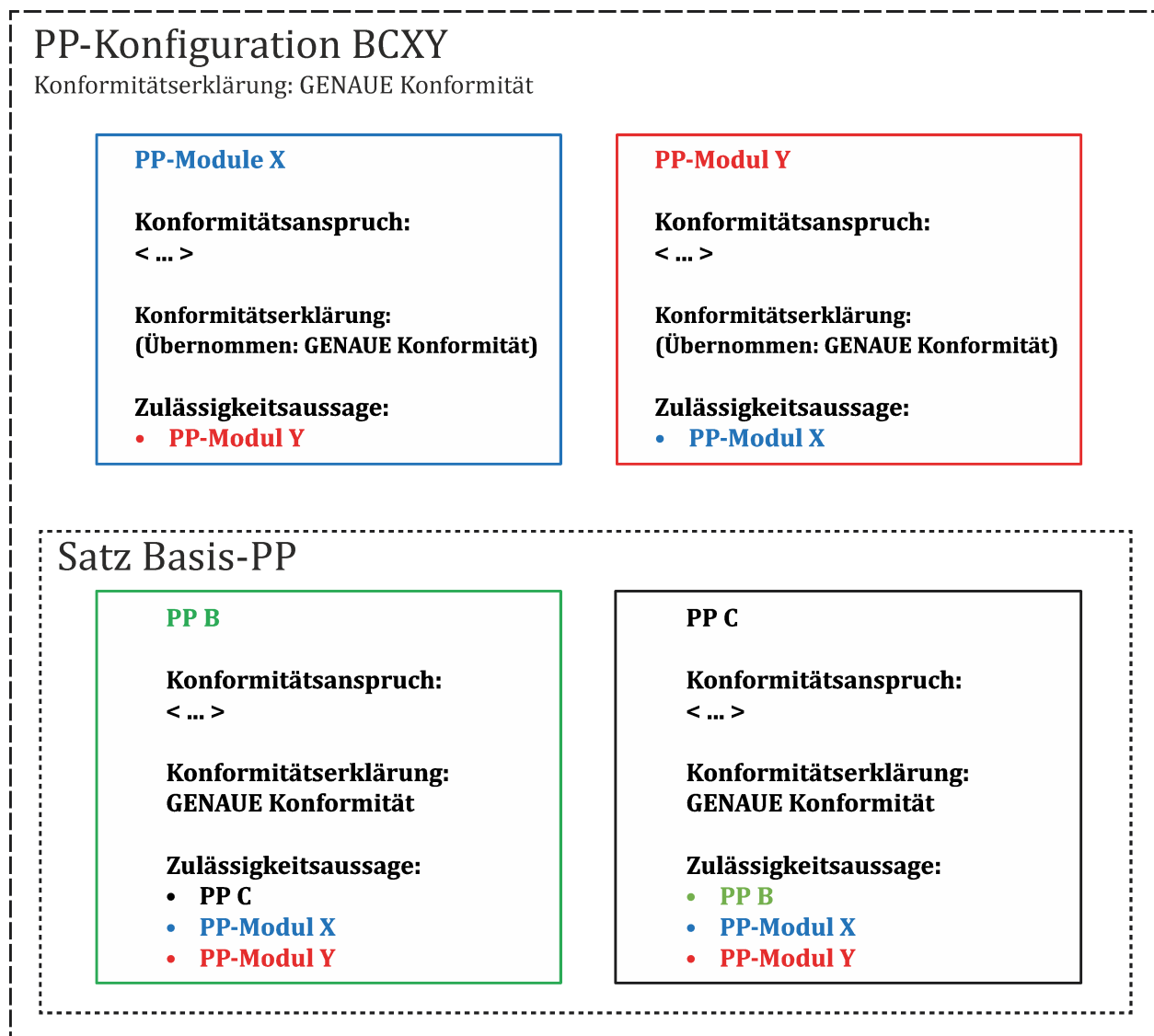


Bild C.5 — PP-Konfiguration und genaue Konformität

BEISPIEL Eine PP-Konfiguration erfordert genaue Konformität in ihrer Konformitätserklärung, da genaue Konformität in beiden Basis-PP erforderlich ist und daher von den PP-Modulen übernommen wird. Die PP-Module X und Y haben beide einen identischen Satz an Basis-PP: PP B und PP C, die beide eine genaue Konformität erfordern. Die folgenden Erklärungen (im Diagramm dargestellt) müssen zutreffen, damit es sich um eine evaluierbare PP-Konfiguration mit einer Konformitätserklärung von „genauer Konformität“ handelt:

- die PP-Module übernehmen die Konformitätserklärung von ihren Basis-PP, so dass ihre Konformitätserklärung genau konform ist;
- die PP-Konfiguration muss genau konform sein, da die PP-Module genau konform sein müssen;
- PP B muss in seiner Konformitätserklärung festlegen, dass es mit PP C, PP-Modul X und PP-Modul Y verwendet werden darf;
- PP C muss in seiner Konformitätserklärung festlegen, dass es mit PP B, PP-Modul X und PP-Modul Y verwendet werden darf;
- PP-Modul X muss in seiner Konformitätserklärung festlegen, dass es mit dem PP-Modul Y verwendet werden darf;

- f) PP-Modul Y muss in seiner Konformitätserklärung festlegen, dass es mit dem PP-Modul X verwendet werden darf.

C.3.7 SAR-Aussage

Die SAR-Aussage zur PP-Konfiguration legt den Satz an SAR fest, der für die Evaluierung eines TOE gilt, der von einer ST festgelegt wurde, die Konformität mit dieser PP-Konfiguration beansprucht. Im Fall einer Mehrfach-Vertrauenswürdigkeit gilt: Wenn die Komponenten der PP-Konfiguration unterschiedliche Sätze von SAR tragen, muss die PP-Konfiguration den Satz von SAR definieren, der für jeden der von diesen Komponenten definierten Teil-TSF gilt.

Der Satz an SAR, der für den gesamten TOE gilt, wird als gesamtes Vertrauenswürdigkeitspaket bezeichnet.

Im Falle des nachweislichen oder strikten Typs ist das gesamte Vertrauenswürdigkeitspaket eine Obermenge der gemeinsamen Untermenge an SAR, die für jede der Komponenten der PP-Konfigurationen gilt.

Im Falle eines genauen Konformitätstyps ist das gesamte Vertrauenswürdigkeitspaket der minimale gemeinsame Satz an SAR für die Komponenten der PP-Konfiguration; eine Ergänzung ist nicht zulässig.

In der PP-Konfiguration ist der Satz an SAR, der für jede der Teil-TSF gilt, entweder identisch mit dem in der entsprechenden PP-Konfigurationskomponente definierten Satz an SAR oder eine Ergänzung dieses Satzes.

BEISPIEL Ein Beispiel für einen Satz an SAR ist ein in ISO/IEC 15408-5 vordefiniertes EAL-Vertrauenswürdigkeitspaket.

Eine PP-Konfiguration muss eine Begründung für die Vertrauenswürdigkeit liefern, um die Konsistenz des anwendbaren Satzes an SAR mit den in ihren Komponenten definierten SAR, insbesondere in Bezug auf die gemeinsamen Vermögenswerte, nachzuweisen. Darüber hinaus wird in der Begründung für die Vertrauenswürdigkeit die Anordnung der EM/EA in den PP-Konfigurationskomponenten für den Fall erörtert, dass die SAR auf der PP-Konfigurationsebene ergänzt wurden oder zusätzliche EM/EA auf der PP-Konfigurationsebene festgelegt wurden.

ANMERKUNG Die Begründung für die Vertrauenswürdigkeit der PP-Konfiguration muss die in den PP-Modulen gegebene Analyse auf alle Komponenten der PP-Konfiguration zusammen erweitern. In der Regel geschieht dies durch die Entfaltung der SPD-Elemente der PP-Konfigurationskomponenten und die Analyse der Sätze an SAR, die für jeden Vermögenswert gelten.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

Anhang D **(normativ)**

Spezifikation von Sicherheitsvorgaben (ST) und ST mit direkter Begründung

D.1 Ziel und Aufbau dieses Anhangs

Ziel dieses Anhangs ist die Zusammenfassung des Aufbaus und des erwarteten Inhalts einer ST.

Da es bei PPs und STs erhebliche Überschneidungen gibt, konzentriert sich dieser Anhang auf die Unterschiede zwischen PPs und STs. Identischer Inhalt von STs und PPs wird in Anhang B beschrieben.

ANMERKUNG Dieser Anhang definiert nicht die Anforderungen an die Evaluierung von ST. Die ST-Evaluationskriterien sind der ASE-Klasse in ISO/IEC 15408-3 entnommen.

Dieser Anhang besteht aus vier wesentlichen Teilen:

a) *Wie eine ST verwendet werden sollte;*

Dies wird in D.2 zusammengefasst. Dieser Teil beschreibt, wie eine ST verwendet werden sollte und einige der Fragen, die über eine ST beantwortet werden können.

b) *Was eine ST enthalten muss;*

Dies wird in D.3 ausführlich beschrieben. Dieser Teil beschreibt die verpflichtenden Inhalte der ST, die Wechselbeziehungen zwischen diesen Inhalten und geben darüber hinaus Beispiele.

c) *Beanspruchung von Konformität mit Normen;*

D.5 beschreibt, wie ein ST-Autor die Einhaltung einer bestimmten Norm durch einen TOE beanspruchen kann.

d) *ST mit direkter Begründung.*

ST mit direkter Begründung sind ST, bei denen die SFR und möglicherweise die Sicherheitszielsetzungen für die Betriebsumgebung direkt auf die SPD-Elemente abgebildet werden. D.4 gilt für ST mit direkter Begründung.

D.2 Verwendung einer ST

D.2.1 Wie eine ST verwendet werden sollte

Eine typische ST erfüllt zwei Rollen.

- Vor und während der Evaluierung spezifiziert die ST, „was evaluiert werden soll“. Die ST dient in dieser Rolle als Grundlage für die Vereinbarung zu den exakten Sicherheitseigenschaften des TOEs und den exakten Sicherheitseigenschaften des Anwendungsbereichs der Evaluierung zwischen Entwickler und Evaluator. Für diese Rolle sind technische Korrektheit und Vollständigkeit die wesentlichen Aspekte. D.3.2 und D.3.5 beschreiben, wie die ST in dieser Rolle verwendet wird;
- Nach der Evaluierung spezifiziert die ST, „was evaluiert wurde“. Die ST dient in dieser Rolle als Grundlage für die Vereinbarung zwischen Entwickler oder Vertreiber des TOEs und dem potentiellen Verbraucher des TOEs. Die ST beschreibt die exakten Sicherheitseigenschaften des TOEs in abstrakter Form und der

potentielle Verbraucher kann dann dieser Beschreibung vertrauen, weil der TOE mit Blick auf die Erfüllung der ST evaluiert wurde. Für diese Rolle sind Benutzerfreundlichkeit und Verständlichkeit die wesentlichen Aspekte. D.2.3 beschreibt, wie eine ST in dieser Rolle verwendet werden sollte.

D.2.2 Wie eine ST nicht verwendet werden sollte

Eine von vielen Rollen, die eine ST nicht erfüllen sollte, ist diese:

— *eine vollständige Spezifikation:*

Eine ST ist als Sicherheitsspezifikation und nicht als vollständige Spezifikation ausgelegt. Eigenschaften wie Interoperabilität, physische Größe und Gewicht, erforderliche Spannung usw. sollten nicht Teil einer ST sein, sofern sie nicht sicherheitsrelevant sind. Daraus folgt, dass eine ST im Allgemeinen Teil einer vollständigen Spezifikation sein kann, aber für sich genommen keine vollständige Spezifikation ist.

D.2.3 Fragen, die mit einer ST beantwortet werden können

Nach der Evaluierung spezifiziert die ST, „was evaluiert wurde“. Die ST dient in dieser Rolle als Grundlage für die Vereinbarung zwischen Entwickler oder Vertreiber des TOEs und dem potentiellen Verbraucher des TOEs. Die ST kann daher folgende Fragen (und mehr) beantworten.

a) *Wie kann ich bei der Vielzahl an STs/TOEs die ST/den TOE finden, die/den ich benötige?*

Diese Frage wird im TOE-Überblick angesprochen. Dieser Überblick gibt eine kurze (einige Absätze lange) Zusammenfassung des TOEs.

b) *Passt dieser TOE in meine bestehende Infrastruktur?*

Diese Frage wird im TOE-Überblick beantwortet. Dort werden die wesentlichen Elemente an Hardware/Software/Firmware für den Betrieb des TOEs bestimmt.

c) *Passt dieser TOE in meine bestehende Betriebsumgebung?*

Diese Frage wird von den Sicherheitszielsetzungen für die Betriebsumgebung angesprochen, die alle durch den TOE an die Betriebsumgebung auferlegten Beschränkungen für eine ordnungsgemäße Funktion bestimmen.

d) *Was macht der TOE (interessierter Leser)?*

Diese Frage wird im TOE-Überblick angesprochen. Dieser Überblick gibt eine kurze (einige Absätze lange) Zusammenfassung des TOEs.

e) *Was macht der TOE (potentieller Verbraucher)?*

Diese Frage wird in der TOE-Beschreibung angesprochen. Diese Beschreibung gibt eine längere (einige Seiten lange) Zusammenfassung des TOEs.

f) *Was macht der TOE (technisch)?*

Diese Frage wird in der zusammenfassenden Spezifikation des TOEs angesprochen. Sie gibt eine allgemeine Beschreibung des vom TOE verwendeten Mechanismus.

g) *Was macht der TOE (Experte)?*

Diese Frage wird in den SFRs angesprochen, die eine abstrakte und sehr technische Beschreibung bieten und von der zusammenfassenden Spezifikation des TOEs, die zusätzliche Einzelheiten liefert.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)****h) *Behandelt der TOE das von meiner Regierung/Organisation definierte Problem?***

Wenn Ihre Regierung/Organisation ein Paket und/oder PPs und/oder PP-Konfigurationen zur Definition dieser Lösung definiert hat, finden Sie die Antwort im Abschnitt Konformitätsanspruch der ST; dort sind alle Pakete, PPs und PP-Konfigurationen aufgelistet, mit denen diese ST konform ist.

i) *Behandelt der TOE mein Sicherheitsproblem (Experte)?*

Welche Bedrohungen werden vom TOE abgewehrt? Welche OSP wird durch ihn durchgesetzt? Welche Annahmen werden von ihm zur Betriebsumgebung getroffen? Diese Fragen werden von der SPD angesprochen.

j) *Wie sehr kann ich dem TOE vertrauen?*

Dies kann im Abschnitt Sicherheitsanforderungen in den SARs gefunden werden. Dieser Abschnitt bestimmt die für die Evaluierung des TOEs verwendeten Vertrauenswürdigkeitsanforderungen und somit das Vertrauen, das die Evaluierung für die Korrektheit des TOEs bietet.

D.3 Verpflichtender Inhalt einer ST**D.3.1 Allgemein**

Es gibt zwei Arten von ST. Erstens die „reguläre“ ST, die den gesamten Inhalt wie in D.3.3 bis D.3.7.2B.3.7.2 beschrieben enthält. Zweitens darf ein ST-Autor in einigen Fällen eine ST mit direkter Begründung verwenden, in der die Sicherheitszielsetzungen für den TOE nicht angegeben sind. ST mit direkter Begründung und die Gründe und Umstände, unter denen sie verwendet werden, werden in D.4 ausführlich beschrieben. Alle anderen Teile dieses Anhangs gehen von einer ST mit vollständigem Inhalt aus.

Bild D.1 zeigt den in ISO/IEC 15408-3 festgelegten Inhalt einer ST.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

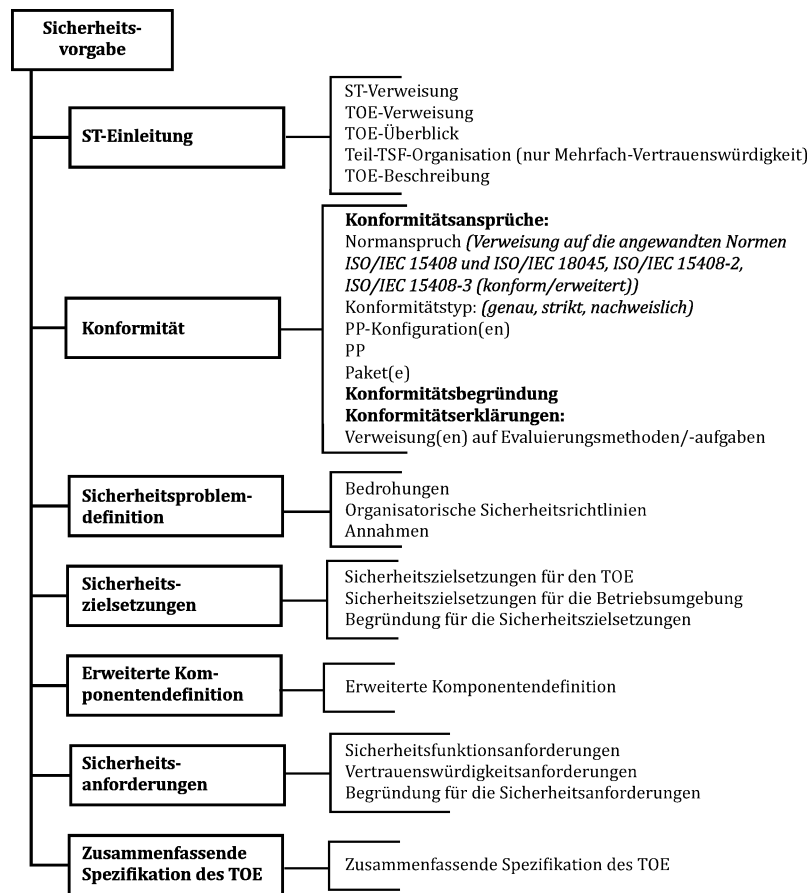


Bild D.1 — Inhalt einer ST

Bild D.1 kann auch als Grundstruktur für die ST verwendet werden, wobei auch alternative Strukturen erlaubt sind. Wenn beispielsweise die Begründung für die Sicherheitsanforderungen besonders umfangreich ist, kann diese Begründung auch in einen Anhang der ST aufgenommen werden, anstatt in den Abschnitt der Sicherheitsanforderungen. Die einzelnen Abschnitte einer ST und deren Inhalte werden unten kurz zusammengefasst und in D.3.3 bis D.3.7.2 deutlich ausführlicher erklärt. Eine ST enthält

- eine ST-Einleitung*, mit drei ausformulierten Beschreibungen des TOEs über unterschiedliche Abstraktionsebenen,
- einen *Konformitätsanspruch*, der die Konformität der ST mit der entsprechenden Ausgabe von ISO/IEC 15408-2 und ISO/IEC 15408-3 angibt; d bei muss der Konformitätsanspruch aufzeigen, ob die ST Konformität mit irgendwelchen PP, PP-Konfigurationen und/oder Paketen beansprucht, und, wenn dies der Fall ist, muss der Konformitätsanspruch die spezifischen PP, PP-Konfigurationen und/oder Pakete, Evaluierungsmethoden/-aufgaben und den Typ der beanspruchten Konformität angeben,
- eine Sicherheitsproblemdefinition*, die Bedrohungen, OSPen und Annahmen aufzeigt,
- Sicherheitszielsetzungen*, die aufzeigen, wie die Lösung des Sicherheitsproblems aufgeteilt ist zwischen Sicherheitszielsetzungen für den TOE und Sicherheitszielsetzungen für die Betriebsumgebung des TOEs,
- erweiterte Komponentendefinition* (optional), in der neue Komponenten (d. h. nicht in ISO/IEC 15408-2 oder ISO/IEC 15408-3 enthaltene Komponenten) definiert werden dürfen. Diese neuen Komponenten sind zur Definition von erweiterten funktionalen Anforderungen und erweiterten Vertrauenswürdigkeitsanforderungen erforderlich,

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

- f) *Sicherheitsanforderungen*, bei denen eine Übertragung der Sicherheitszielsetzungen für den TOE in eine standardisierte Sprache bereitgestellt wird. Diese standardisierte Sprache wird in SFRs dargestellt. Zusätzlich werden in diesem Abschnitt SARs definiert,
- g) *eine zusammenfassende Spezifikation zum TOE*, die aufzeigt, wie die SFRs im TOE implementiert sind.

D.3.2 ST-Einleitung (ASE_INT)**D.3.2.1 Allgemein**

Die ST-Einleitung beschreibt die TOEs in ausformulierter Weise auf drei Abstraktionsebenen:

- a) die ST-Verweisung und die TOE-Verweisung mit Identifizierungsinhalt für die ST und den TOE, auf den sich die ST bezieht;
- b) der TOE-Überblick, der den TOE kurz beschreibt;
- c) die TOE-Beschreibung, die den TOE ausführlicher beschreibt.

D.3.2.2 ST-Verweisung und TOE-Verweisung

Die ST-Verweisung und die TOE-Verweisung erleichtern das Indexieren und Verweisen von STs und TOEs und die Aufnahme in Katalogen.

Eine ST enthält eine eindeutige ST-Verweisung, die diese bestimmte ST identifiziert. Eine typische ST-Verweisung umfasst Titel, Version, Antragsteller und Veröffentlichungsdatum.

BEISPIEL 1 Ein Beispiel einer ST-Verweisung ist „MauveRAM Database ST, Version 1.3, MauveCorp Specification Team, 11 October 2017“.

Eine ST enthält auch eine TOE-Verweisung, die den TOE bezeichnet, der Konformität mit dieser ST beansprucht. Eine typische TOE-Verweisung umfasst Entwicklernamen, TOE-Namen und TOE-Versionsnummer. Ein einzelner TOE darf mehrfach evaluiert werden, beispielsweise von unterschiedlichen Verbrauchern dieses TOEs; daher kann ein TOE mehrere STs einhergehend mit dieser Verweisung haben.

BEISPIEL 2 Ein Beispiel für eine TOE-Verweisung ist „MauveCorp MauveRAM Database v5.12“.

Wenn der TOE aus einem oder mehreren gut bekannten Produkten aufgestellt wird, dann ist es erlaubt, dies in der TOE-Verweisung durch Bezug auf den bzw. die Produktnamen kenntlich zu machen. Diese Möglichkeit sollte allerdings nicht verwendet werden, um Verbraucher zu täuschen: Situationen, in denen wesentliche Teile oder Sicherheitsfunktionen nicht in der Evaluierung betrachtet wurden und die TOE-Verweisung dies nicht kenntlich macht, sind nicht erlaubt.

D.3.2.3 TOE-Überblick**D.3.2.3.1 Allgemein**

Der TOE-Überblick richtet sich an potentielle Verbraucher eines TOEs, die Kataloge evaluierter TOEs/Produkte durchsuchen, um TOEs zu finden, die ihre Sicherheitsbedürfnisse erfüllen und von ihrer Hardware, Software und Firmware unterstützt werden. Die typische Länge eines TOE-Überblicks sind einige Absätze.

Zu diesem Zweck beschreibt der TOE-Überblick kurz die Verwendung des TOEs und seine wesentlichen Sicherheitsmerkmale, identifiziert den TOE-Typ und jegliche wesentliche, nicht im TOE enthaltene Hardware/Software/Firmware, die vom TOE vorausgesetzt wird.

Bei einer ST mit Mehrfach-Vertrauenswürdigkeit enthält der TOE-Überblick auch die TSF-Organisation in Bezug auf die in der PP-Konfiguration definierten Teil-TSF, mit der die ST Konformität beansprucht.

D.3.2.3.2 Verwendung und wesentliche Sicherheitsmerkmale eines TOEs

Die Beschreibung der Verwendung und wesentlichen Sicherheitsmerkmale eines TOEs dient dazu, eine allgemeine Vorstellung über die sicherheitstechnischen Fähigkeiten des TOEs und seine Anwendung im Kontext der Sicherheit geben. Dieser Abschnitt der ST wird für (potentielle) Verbraucher des TOEs geschrieben und beschreibt die Verwendung und die wesentlichen Sicherheitsmerkmale des TOEs in Hinblick auf den Geschäftsbetrieb in einer für den Verbraucher des TOEs verständlichen Sprache.

BEISPIEL „Die MauveCorp MauveRAM Database v5.12 ist eine Mehrbenutzerdatenbank zur Verwendung in einer Netzwerkumgebung. Sie erlaubt 1 024 zeitgleich aktive Benutzer. Sie erlaubt Authentifizierung über Passwort/Token und Biometrie, schützt vor unbeabsichtigter Datenkorruption und kann zehntausend Transaktionen rückgängig machen („Roll-back“). Die Audit-Funktionen sind hochgradig konfigurierbar und erlauben ausführliche Audits für einzelne Benutzer und Transaktionen, bei gleichzeitigem Schutz der Privatsphäre anderer Benutzer und Transaktionen.“

D.3.2.3.3 TOE-Typ

Der TOE-Überblick bestimmt den Typ des TOEs, z. B. Firewall, VPN-Firewall, Chipkarte, kryptographisches Modem, Intranet, Webserver, Datenbank, Webserver und Datenbank, lokales Netz, lokales Netz mit Webserver und Datenbank.

Falls der TOE von einem nicht gängigen Typ ist, kann der TOE-Typ „keiner“ verwendet werden.

Die Bestimmung des TOE darf für Verbraucher nicht irreführend sein.

BEISPIEL Beispiele für irreführende TOE-Typen:

- eine bestimmte Funktion, die aufgrund des TOE-Typs erwartet werden kann, über die der TOE aber nicht verfügt;

Beispiele sind unter anderem:

- ein TOE vom Typ Geldautomatkarte, der keine Funktionen zur Identifizierung/Authentifizierung unterstützt;
- ein TOE vom Typ Firewall, der keine annähernd allseits verwendeten Protokolle unterstützt;
- ein TOE vom Typ PKI, der keine Funktionen zum Sperren von Zertifikaten hat;
- vom TOE kann erwartet werden, dass er aufgrund seines Typs in bestimmten Betriebsumgebungen verwendet werden kann, dem ist jedoch nicht so;
- ein TOE vom Typ PC-Betriebssystem, der nur sicher funktioniert, wenn der PC nicht mit Netzwerk, Diskettenlaufwerk und CD/DVD-Laufwerk verbunden ist;
- eine Firewall, die nur sicher funktioniert, wenn alle sich über diese Firewall verbindenden Benutzer harmlos sind.

D.3.2.3.4 Erforderliche nicht im TOE enthaltene Hardware/Software/Firmware

Einige TOEs sind nicht auf andere IT-Komponenten angewiesen, aber viele TOEs (insbesondere Software-TOEs) erfordern zusätzliche, Hardware, Software und/oder Firmware, die nicht Teil des TOEs sind. Im letzteren Fall ist der TOE-Überblick erforderlich, um solche nicht im TOE enthaltene Hardware, Software und/oder Firmware zu identifizieren. Eine vollständige und ausführliche Identifizierung der zusätzlichen Hardware, Software und/oder Firmware ist nicht erforderlich, aber die Identifizierung muss vollständig und ausführlich genug sein, damit potentielle Verbraucher die wesentliche Hardware, Software und/oder Firmware bestimmen können, die zur Verwendung des TOEs erforderlich ist.

BEISPIEL Beispiele für die Identifizierung von Hardware/Software/Firmware sind:

- ein Standard-PC mit einem Dual-Core-Prozessor mit 2,10 GHz oder schneller und 4 GB RAM oder mehr, auf dem das Yaiza-Betriebssystem für professionelle Anwender, Version 53.0 Update 6b, c oder 7, oder Version 54.0 läuft;

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

- ein Standard-64-Bit-Server mit einem 2xQuad-Core-Prozessor und 16 GB oder mehr RAM, auf dem das Yaiza-Betriebssystem, Server Edition Version 7.0 Update 6d, und die WonderMagic 12.0-Grafikkarte mit dem 1.0 WM Driver Set laufen;
- eine integrierte Schaltung CleverCard SB17067;
- eine integrierte Schaltung CleverCard SB17067 mit v12.0 des QuickOS Chipkarten-Betriebssystems;
- die Installation von Dezember 2020 des lokalen Netzes für das Büro des Generaldirektors des Verkehrsministeriums.

D.3.2.3.5 TSF-Organisation in den Teil-TSF im Fall der Mehrfach-Vertrauenswürdigkeit

Eine ST mit Mehrfach-Vertrauenswürdigkeit, d. h. eine ST, die Konformität mit einer PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit beansprucht und die mehrere Sätze von SAR für die verschiedenen Teil-TSF definiert, muss die Organisation der TSF in den Teil-TSF aus der PP-Konfiguration übernehmen.

Der TOE-Überblick beschreibt diese Organisation, möglicherweise durch Einzelheiten des eigentlichen TOE ergänzt.

D.3.2.4 TOE-Beschreibung

Eine TOE-Beschreibung ist eine ausformulierte Beschreibung des TOEs, die sich üblicherweise über mehrere Seiten erstreckt. Die TOE-Beschreibung vermittelt Evaluatoren und potentiellen Verbrauchern ein allgemeines Verständnis der Sicherheitsfunktionen des TOEs, wobei dies ausführlicher geschehen soll, als im TOE-Überblick. Die TOE-Beschreibung darf auch verwendet werden, um den breiteren Anwendungskontext des TOEs zu beschreiben.

In der TOE-Beschreibung wird der physische Anwendungsbereich des TOEs behandelt: eine Liste der gesamten Hardware, Software, Firmware und Leitlinien, die den TOE bilden. Diese Liste muss so ausführlich beschrieben werden, dass der Leser ein ausreichendes, allgemeines Verständnis dieser Teile vermittelt bekommt.

Die TOE-Beschreibung muss auch den logischen Anwendungsbereich des TOE, einschließlich der Hauptfunktionen des TOE, erörtern und eine kurze Beschreibung der Sicherheitsmerkmale (die TSF) bieten. Die Beschreibung muss so ausführlich sein, dass dem Leser ein ausreichendes, allgemeines Verständnis dieser Merkmale vermittelt wird. Es wird erwartet, dass diese Beschreibung ausführlicher ist, als die Beschreibung der wesentlichen Sicherheitsmerkmale im TOE-Überblick.

Eine wichtige Eigenschaft des physischen und logischen Anwendungsbereichs ist die Beschreibung des TOEs in einer Art und Weise, dass kein Zweifel daran bestehen bleibt, ob ein bestimmtes Teil oder Merkmal zum TOE gehört oder nicht. Das ist besonders wichtig, wenn ein TOE mit einer Nicht-TOE-Komponente verflochten ist und sich nicht leicht von ihr trennen lässt.

BEISPIEL 1 Beispiele für die Verflechtung von TOE und Nicht-TOE-Komponente sind:

- der TOE ist ein kryptographischer Co-Prozessor einer integrierten Schaltung einer Chipkarte und nicht die gesamte integrierte Schaltung;
- der TOE ist eine integrierte Schaltung einer Chipkarte, jedoch ohne den kryptographischen Prozessor;
- der TOE ist der Teil der Netzwerkadressübersetzung der MinuteGap Firewall v28.2.

In einigen Fällen kann die Beschaffung von Nachweisen durch Komponenten Dritter praktische Schwierigkeiten bereiten.

BEISPIEL 2 Ein Beispiel für den Fall, dass keine ausreichenden Nachweise Dritter für die Evaluierung zur Verfügung stehen, ist der Fall, dass der Quellcode, die Design-Dokumentation oder Prüfnachweise dem Entwickler des TOE nicht zur Verfügung gestellt werden können.

D.3.3 Konformitätsansprüche (ASE_CCL)

Der Abschnitt „Konformitätsansprüche“ einer ST beschreibt, wie die ST mit der Normenreihe ISO/IEC 15408, den Paketen, den PP und den PP-Konfigurationen konform ist. Er ähnelt dem in B.3.3 beschriebenen Abschnitt über Konformitätsansprüche für ein PP mit einer Ausnahme: Eine ST hat keine Konformitätserklärung, da die ST keine Konformität mit einer anderen ST beanspruchen darf.

Ein zusätzlicher Unterschied zwischen einer ST, die Konformität mit einem PP beansprucht, und einer ST, die Konformität mit einer PP-Konfiguration beansprucht, besteht darin, dass eine ST zwar Konformität mit mehreren PP beanspruchen und Funktionspakete in den PP ergänzen kann und sogar Konformität sowohl mit einem PP als auch mit einem Funktionspaket beanspruchen kann, eine ST aber nur Konformität mit genau einer PP-Konfiguration beanspruchen kann und nicht mit weiteren PP-Konfigurationen, PP oder Funktionspaketen.

D.3.4 Sicherheitsproblemdefinition (SPD) (ASE_SPD)

Der Abschnitt „SPD“ einer ST beschreibt, wie die ST das anzusprechende Sicherheitsproblem angibt. Er ist identisch mit dem in B.3.4 beschriebenen Abschnitt „SPD“ für ein PP.

Bei einer ST, die mit den PP und/oder der PP-Konfiguration konform ist, umfasst die ST alle SPD-Elemente, die in diesen PP und PP-Konfigurationskomponenten definiert sind. Es kann der Fall eintreten, dass eine Annahme in einer Komponente des PP oder der PP-Konfiguration zu einer Zielsetzung für den TOE in der ST wird.

D.3.5 Sicherheitszielsetzungen (ASE_OBJ)

Dieser Abschnitt entspricht dem Abschnitt „Sicherheitszielsetzungen“ eines PP; für Erläuterungen siehe B.3.5 und B.5.

Bei einer ST, die mit den PP und/oder der PP-Konfiguration konform ist, umfasst die ST alle Zielsetzungen, die in diesen Komponenten der PP und PP-Konfiguration definiert sind. Es kann der Fall sein, dass Zielsetzungen für die Betriebsumgebung des TOE in einer Komponente des PP oder der PP-Konfiguration zu einer Zielsetzung für den TOE in der ST werden können.

D.3.6 Erweiterte Komponentendefinition (ASE_ECD)

Dieser Abschnitt einer ST entspricht dem Abschnitt „Erweiterte Komponenten“ eines PP; für Erläuterungen siehe B.3.6.

D.3.7 Sicherheitsanforderungen (ASE_REQ)

D.3.7.1 Sicherheitsfunktionsanforderungen (SFR)

D.3.7.1.1 Allgemein

Dieser Abschnitt einer ST ist identisch mit dem Abschnitt der Sicherheitsanforderungen einer PP, wie in B.3.7 erläutert, mit der Ausnahme, dass die Spezifikation von auswahlbasierten SFR und optionalen Anforderungen in den ST nicht anwendbar ist, da alle SFR vollständig instanziiert sein müssen.

Bei einer ST, die mit den PP und/oder der PP-Konfiguration konform ist, umfasst die ST alle SFR, die in diesen Komponenten der PP und PP-Konfiguration definiert sind.

D.3.7.1.2 Aufnahme von Anforderungen in eine ST

Bei den ST, die genau mit einem PP konform sind, müssen alle Anforderungen des PP enthalten sein. Anforderungen, die nicht im PP enthalten sind, dürfen nicht in die ST aufgenommen werden.

Bei den ST, die strikt mit einem PP konform sind, müssen alle Anforderungen in einem PP enthalten sein.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01 prEN ISO/IEC 15408-1:2023 (D)

Bei den ST mit nachweislicher Konformität mit einem PP müssen alle Anforderungen in einem PP enthalten sein, oder es muss eine Begründung in der ST dafür enthalten sein, wie sie anderweitig erfüllt werden.

Bei den ST, die eine strikte oder nachweisliche Konformität mit einem PP aufweisen, dürfen zusätzliche Anforderungen, die nicht in dem PP enthalten sind, aufgenommen werden, sofern sie zusätzliche Sicherheitszielsetzungen unterstützen/zusätzliche Bedrohungen abdecken.

Für eine ST, die Konformität mit einer PP-Konfiguration beansprucht, gelten die gleichen Regeln wie für die Konformität mit einem PP. In diesem Fall werden die Anforderungen den Komponenten der PP-Konfiguration entnommen, d. h. ihren PP und PP-Modulen. Enthält die PP-Konfiguration Komponenten, die unterschiedliche Konformitätstypen erfordern (nur strikt und nachweislich, da genaue Konformität nicht mit anderen Typen kombiniert werden kann), so entspricht die ST jeder der Komponenten (PP und PP-Module) auf die von ihnen geforderte Weise, entweder strikt oder nachweislich.

Erhebt die ST Anspruch auf Konformität mit einem PP oder einer PP-Konfiguration und enthalten das PP oder die Komponenten der PP-Konfiguration optionale Anforderungen, so darf die ST diese Anforderungen instanzieren und dabei sicherstellen, dass alle erforderlichen SPD-Elemente im Zusammenhang mit diesen Anforderungen enthalten sind. Dies darf unabhängig von der durch das PP oder die PP-Konfiguration geforderten Konformität durchgeführt werden. Das Weglassen optionaler SFR in einer ST stellt keine „Teilkonformität“ mit einem PP oder einer PP-Konfiguration dar und ist daher zulässig.

BEISPIEL Beispiel für die Spezifikation externer Normen in den SFR und deren Evaluierung:

FCS_CKM.1.1 „Refinement“: „Die TSF¹ muss asymmetrische kryptographische Schlüssel in Übereinstimmung mit einem festgelegten Algorithmus zum Generieren kryptographischer Schlüssel generieren: RSA-Programme, die kryptographische Schlüsselgrößen von 2048 Bit oder mehr verwenden und die folgenden Bedingungen erfüllen: FIPS PUB 186-4, „Digital Signature Standard (DSS)“, B.3².“

Die Konformität mit der Norm als Teil der Erfüllung der SFR durch den TOE wird dann auf eine der folgenden Arten bewertet:

- wenn eine explizite Evaluierungsaufgabe für den SFR definiert wurde, dann werden die Evaluatorenaktionen in dieser Evaluierungsaufgabe ausgeführt;
- wenn keine explizite Evaluierungsaufgabe für die SFR definiert wurde, wird die Konformität anschließend so bestimmt, als ob der vollständige Text der Norm als Teil der SFR enthalten wäre, wobei die für die ST ausgewählten SAR angewendet werden.

D.3.7.2 Vertrauenswürdigkeitsanforderungen (SARs)

Die ST legt den Satz an SAR fest, der für die Evaluierung eines TOE gilt.

Entspricht die ST einem PP oder einer PP-Konfiguration, so muss der Satz an SAR mit dem PP oder der PP-Konfiguration konsistent sein.

Wenn die ST mit einer PP-Konfiguration mit Mehrfach-Vertrauenswürdigkeit konform ist, dann:

1 [Auswahl: **TSF, TOE-Plattform**]

2 [Auswahl: RSA-Programme, die kryptographische Schlüsselgrößen von 2048 Bit oder mehr verwenden und die folgenden Bedingungen erfüllen: [Auswahl: **FIPS PUB 186-4, „Digital Signature Standard (DSS)“, B.3; ANSI X9.31-1998, 4.1**]; ECC-Programme unter Verwendung der „NIST-Kurven“ P-256, P-384 und [Auswahl: P-521, keine anderen Kurven], die die folgenden Bedingungen erfüllen: FIPS PUB 186-4, „Digital Signature Standard (DSS)“, B.4; FFC-Programme, die kryptographische Schlüsselgrößen von 2048 Bit oder mehr verwenden und die folgenden Bedingungen erfüllen: FIPS PUB 186-4, „Digital Signature Standard (DSS)“, B.1]

- wendet entweder die ST einen Satz von SAR für den gesamten TOE und die TSF an (in Übereinstimmung mit dem in der PP-Konfiguration definierten gesamten Vertrauenswürdigkeitspaket). In diesem Fall muss der TOE nach dem Ansatz mit Einfach-Vertrauenswürdigkeit evaluiert werden; oder
- die ST definiert den gesamten Satz von SAR, der für den gesamten TOE gilt, und die Sätze von SAR, die für jede der in der PP-Konfiguration definierten Teil-TSF gelten (in Übereinstimmung mit den in der PP-Konfiguration definierten Sätzen von SAR). In diesem Fall muss der TOE nach dem Ansatz mit Mehrfach-Vertrauenswürdigkeit evaluiert werden.

Eine ST mit Mehrfach-Vertrauenswürdigkeit und ST, die die SAR der PP/PP-Konfigurationen, mit denen sie konform sind, ergänzen, müssen eine Begründung für die Vertrauenswürdigkeit liefern, um die Konsistenz der Sätze von SAR nachzuweisen.

D.3.8 Zusammenfassende Spezifikation des TOEs (ASE_TSS)

Das Ziel der zusammenfassenden Spezifikation des TOEs (TSS) ist die Bereitstellung einer Beschreibung an die potentiellen Verbraucher, wie der TOE alle SFRs erfüllt. Die zusammenfassende Spezifikation des TOEs liefert die allgemeinen technischen Mechanismen, die der TOE für diesen Zweck verwendet. Der Ausführungsgrad dieser Beschreibung muss ausreichen, damit potentielle Verbraucher die allgemeine Form und Implementation des TOEs verstehen.

Die TSS enthält eine Beschreibung der Implementierung der SFR in natürlicher Sprache, die zum Teil beschreibt, wie die SFR miteinander kombiniert werden, um die Sicherheitsfunktionalität in Bezug auf die Architektur, die für Administratoren und andere Benutzer sichtbar (beobachtbar) ist, oder in Bezug auf die internen Merkmale oder Eigenschaften bereitzustellen.

BEISPIEL 1 Im Folgenden sind Beispiele für interne Merkmale aufgeführt:

- Nichtverfügbarkeit von Restdaten bei Neuzuweisung einer Ressource;
- versteckte Fehlerbedingungen bei der Anmeldung/Passwort-Authentifizierung;
- versteckter biometrischer Vergleichswert.

BEISPIEL 2 Wenn der TOE ein Internet-PC ist und die SFR FIA_UAU.1 enthalten, um die Authentifizierung festzulegen, gibt die Zusammenfassende Spezifikation des TOEs, an, wie diese Authentifizierung durchgeführt wird: Passwort, Token, Iris-Scan usw. Weitere Informationen, wie anwendbare Normen, die der TOE zur Erfüllung der SFR verwendet, oder detailliertere Beschreibungen können ebenfalls angegeben werden.

BEISPIEL 3 Die zusammenfassende Spezifikation des TOEs kann z. B. auf technische Normen verweisen: „Der TOE bietet kryptographische Funktionen zur Durchführung einer AES-Verschlüsselung und -Entschlüsselung mit 128-, 192- oder 256-Bit-Schlüsseln für die eingebettete Software. Der AES-Algorithmus entspricht ISO/IEC 18033-3:2010, 5.2“.

ANMERKUNG Die ST ist eine Eingabe für ADV, was bedeutet, dass ADV es erlaubt, dass auf Inkonsistenzen zwischen der TSS und anderen Spezifikationen hingewiesen wird. Es wird jedoch keine gezielte Evaluierungsaufgabe festgelegt, was die Tatsache widerspiegelt, dass die TSS einen Überblick über die Umsetzung der SFR durch den TOE gibt, aber keine Implementierungsspezifikation darstellt.

D.4 ST mit direkter Begründung

D.4.1 Allgemein

In manchen Situationen ist es angebracht, die Definition der Sicherheitszielsetzungen des TOE wegzulassen. In diesem Fall ordnet die Begründung der Sicherheitsanforderungen die SFR und gegebenenfalls die Sicherheitszielsetzungen für die Betriebsumgebung direkt der SPD zu.

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

Die Absicht der ST mit direkter Begründung ist es, den Grad der Indirektion zwischen der SPD, etwaigen Sicherheitszielsetzungen für die Betriebsumgebung und den SFR auf der Grundlage einer erweiterten Beschreibung der SFR zu minimieren.

Die Unterschiede in einer ST mit direkter Begründung liegen in den Konformitätsansprüchen, den Sicherheitszielsetzungen und in den SPD-Abschnitten. Diese werden in D.4.2 und D.4.3 beschrieben.

In Bild D.2 ist der Inhalt für eine ST mit direkter Begründung dargestellt.

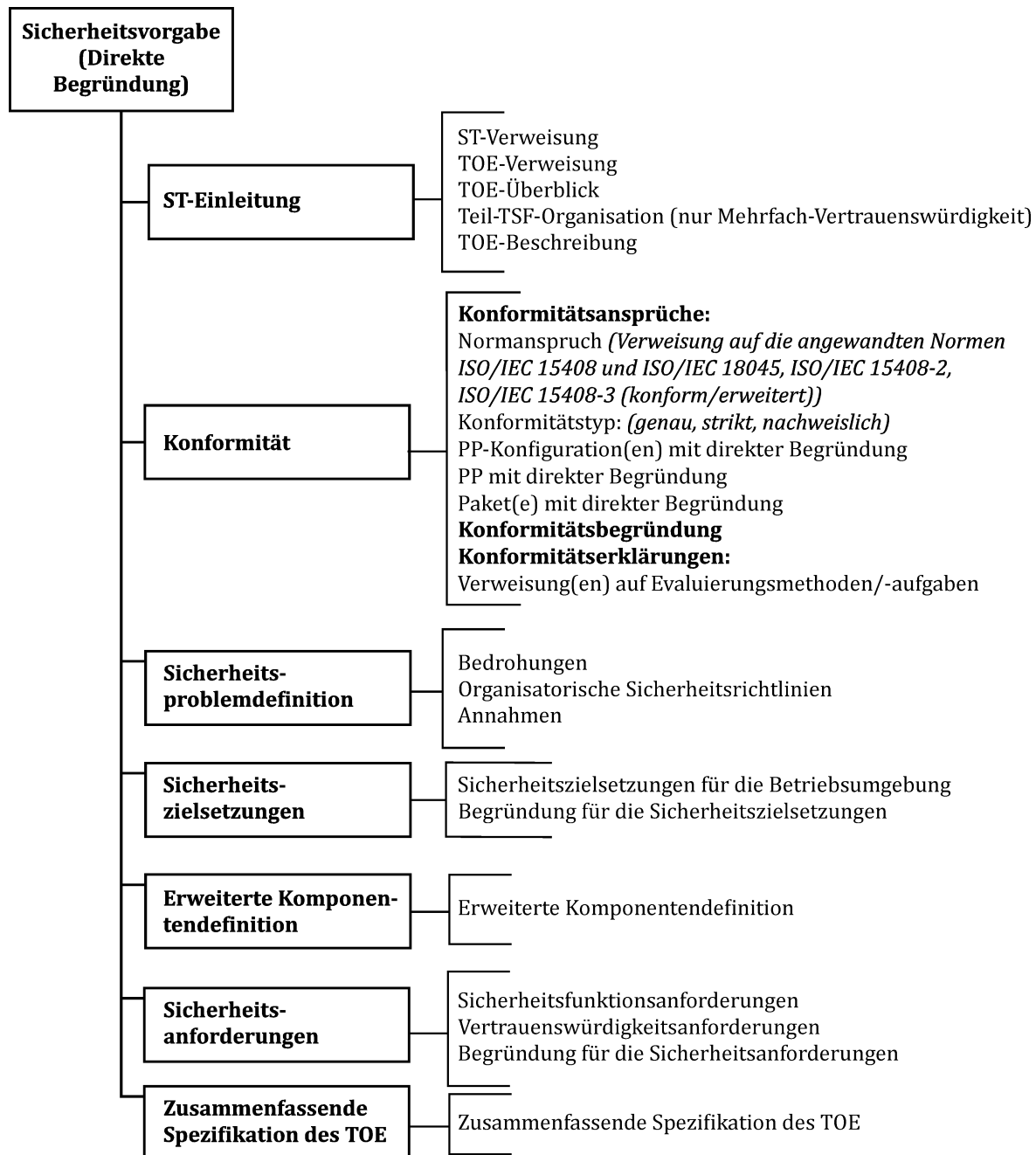


Bild D.2 — Inhalt einer ST mit direkter Begründung

D.4.2 Konformitätsansprüche (ASE_CCL) für ST mit direkter Begründung

Eine ST mit direkter Begründung darf nur Konformität mit anderen PP mit direkter Begründung beanspruchen, siehe 12.2 und Anhang B.

Eine ST mit direkter Begründung darf nur Konformität mit einer PP-Konfiguration beanspruchen, die den Ansatz der direkten Begründung verwendet, siehe 12.2.

D.4.3 Sicherheitsproblemdefinition (SPD) (ASE_SPD) für ST mit direkter Begründung

Eine ST mit direkter Begründung unterscheidet sich in Bezug auf die Sicherheitszielsetzungen wie folgt von einer ST, die Sicherheitszielsetzungen für den TOE enthält:

- Sicherheitszielsetzungen für den TOE sind nicht enthalten. Die Sicherheitszielsetzungen für die Umgebung müssen weiterhin beschrieben werden;
- eine Begründung der Sicherheitszielsetzungen ist nur für die Sicherheitszielsetzungen für die Betriebsumgebung enthalten, da es keine TOE-Sicherheitszielsetzungen in der ST gibt.

D.4.4 Sicherheitsanforderungen (ASE_REQ) für ST mit direkter Begründung.

Eine Begründung der Sicherheitsanforderungen, die die SFR und alle Sicherheitszielsetzungen für die Betriebsumgebung direkt den SPD-Elementen zuordnet, ist enthalten. Es wird empfohlen, diesen Teil der Begründung der Sicherheitsanforderungen direkt unter den einzelnen Bedrohungen, OSP und Annahmen im SPD-Abschnitt unterzubringen. Wie bei den ST, die Sicherheitszielsetzungen für den TOE enthalten, muss auch die Begründung der Sicherheitsanforderungen das Fehlen überflüssiger SFR und aller SFR-Abhängigkeiten, die nicht erfüllt werden, rechtfertigen; dieser Teil der Begründung befindet sich üblicherweise im Anschluss an die Definition der SFR.

D.5 Verweisen auf andere Normen in einer ST

Die Verweisung auf Normen in einer ST ist vergleichbar mit dem Abschnitt über Normen für die PP, wie in B.4 beschrieben. Beispiele sind in D.3.7.1.2 und D.3.7.2 angegeben.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01**
prEN ISO/IEC 15408-1:2023 (D)**Anhang E**
(normativ)**Konformität des/der PP/PP-Konfiguration****E.1 Allgemein**

Ein PP ist als „Vorlage“ für eine ST gedacht, d. h. das PP bzw. die PP-Konfiguration beschreibt eine Reihe von Benutzeranforderungen, während eine ST, die mit diesem/dieser PP/PP-Konfiguration konform ist, einen TOE beschreibt, der diese Anforderungen erfüllt.

Die Normenreihe ISO/IEC 15408 lässt keine Form der Teilkonformität zu. Wird also eine Konformität mit einem PP oder einer PP-Konfiguration beansprucht, muss die ST mit dem/den referenzierten PP oder der referenzierten PP-Konfiguration konform sein.

ANMERKUNG 1 Im Fall von auswahlbasierten oder optionalen SFR wird die Einbeziehung oder der Ausschluss dieser Typen von SFR, wie in 7.3.2.6 beschrieben, nicht als Teilkonformität betrachtet und ist daher zulässig.

Die Normenreihe ISO/IEC 15408 definiert drei Typen von Konformität: „nachweislich“, „strikt“ und „genau“, wobei der Typ der zulässigen Konformität durch das/die PP/PP-Konfiguration (und indirekt durch ihre PP und PP-Module) bestimmt wird, d. h. das/die PP/PP-Konfiguration gibt in seiner/ihrer Konformitätserklärung an, welche Typen der Konformität für die abgeleiteten ST zulässig sind.

Wie in 10.5 angegeben, darf eine ST, wenn ein(e) PP/PP-Konfiguration genaue Konformität festlegt, nur genaue Konformität mit diesem/dieser PP/PP-Konfiguration beanspruchen, und alle anderen PP, mit denen die ST Konformität beansprucht, müssen ebenfalls genaue Konformität erfordern. Wenn das PP in einer PP-Konfiguration enthalten ist (entweder allein oder als Basis-PP für ein PP-Modul in dieser PP-Konfiguration), dann müssen auch die PP-Konfiguration selbst und alle anderen Komponenten der PP-Konfiguration genau konform sein.

Die Unterscheidung zwischen nachweislicher und strikter Konformität, wenn solche Konformitätserklärungen in mehreren PP enthalten sind, mit denen eine ST Konformität beansprucht, gilt für jedes PP, mit dem eine ST Konformität einzeln beanspruchen kann. Das kann bedeuten, dass die ST mit einigen anderen PPs strikte Konformität erreicht und mit anderen nachweisliche Konformität.

Eine ST mit genauem Konformitätstyp darf nur dann Konformität mit einem/einer PP/PP-Konfiguration beanspruchen, wenn das/die PP/PP-Konfiguration vom genauen Konformitätstyp ist und dies ausdrücklich erlaubt.

Eine ST darf nur dann eine nachweisliche Konformität mit einem/einer PP/PP-Konfiguration beanspruchen, wenn das/die PP/PP-Konfiguration dies ausdrücklich erlaubt.

ANMERKUNG 2 Nachweisliche Konformität bedeutet, dass STs, die Konformität mit dem PP oder einer PP-Konfiguration beanspruchen, eine Lösung des im PP bzw. in der PP-Konfiguration beschriebenen, generischen Sicherheitsproblems bieten müssen; diese STs können dies allerdings in irgendeiner Art und Weise tun, die gleichwertig mit der im PP bzw. in der PP-Konfiguration beschriebenen Lösung oder restriktiver als diese Lösung ist. Grundsätzlich bedeutet dies, dass die ST Aussagen enthalten kann, die vom PP bzw. von der PP-Konfiguration abweichen, vorausgesetzt, dass die ST insgesamt die gleichen oder mehr Einschränkungen für den TOE und die gleichen oder weniger Einschränkungen für die Betriebsumgebung des TOE auferlegt.

Es ist auch möglich, das ein PP als Vorlage für ein anderes PP verwendet wird, das entweder eine strikte oder eine nachweisliche Konformität festlegt, d. h. PP, die entweder eine strikte oder eine nachweisliche Konformität festlegen, können Konformität mit anderen PP beanspruchen. Dieser Fall ist einem Fall ST zu PP absolut gleichwertig.

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Wenn die ST mit einer PP-Konfiguration konform ist und diese PP-Konfiguration keine genaue Konformität aufweist, kann von der ST eine strikte und eine nachweisliche Konformität verlangt werden, abhängig von den Konformitätstypen der Komponenten der PP-Konfiguration.

Die Konformität eines PP mit einer PP-Konfiguration ist unabhängig von den Konformitätstypen nicht zulässig.

E.2 Nachweisliche Konformität

Nachweisliche Konformität richtet sich an den Antragsteller des PP bzw. der PP-Konfiguration, der einen Nachweis benötigt, dass die ST eine geeignete Lösung zum im PP bzw. in der PP-Konfiguration beschriebenen, generischen Sicherheitsproblem ist.

Während es bei der strikten Konformität eine klare Beziehung von Obermenge und Untermenge zwischen PP/PP-Konfiguration und ST gibt, ist die Beziehung bei der nachweislichen Konformität weniger deutlich. STs, die Konformität mit dem PP bzw. der PP-Konfiguration beanspruchen, müssen eine geeignete Lösung des im PP bzw. in der PP-Konfiguration beschriebenen, generischen Sicherheitsproblems bieten.

Beanspruchung von Konformität ist allerdings nur erlaubt, wenn die ST die gleichen oder mehr Restriktionen gegenüber diesem TOE aufweist und die gleichen oder weniger Restriktionen gegenüber der Betriebsumgebung des TOEs.

E.3 Strikte Konformität

Strikte Konformität richtet sich an den Antragsteller des PP bzw. der PP-Konfiguration, der einen Nachweis zur Erfüllung der Anforderungen benötigt, dass die ST eine Instanziierung des PPs bzw. der PP-Konfiguration ist; die ST kann dabei allerdings weiter gefasst sein als das PP bzw. die PP-Konfiguration. Die ST spezifiziert im Kern, dass der TOE mindestens dasselbe leistet wie im PP bzw. in der PP-Konfiguration beschrieben, während die Betriebsumgebung höchstens dasselbe leistet wie im PP bzw. in der PP-Konfiguration beschrieben.

BEISPIEL Ein typisches Beispiel für die Anwendung strikter Konformität ist ein auf Auswahl basierter Erwerb eines IT-Produkts, von dem die Übereinstimmung der Sicherheitsanforderungen mit den im PP bzw. in der PP-Konfiguration spezifizierten Anforderungen erwartet wird.

Eine strikte Konformität mit einem PP/einer PP-Konfiguration instanziiierende ST darf weiterhin zusätzliche Restriktionen zu denen im PP bzw. in der PP-Konfiguration einbringen.

E.4 Genaue Konformität**E.4.1 Allgemein**

Die genaue Konformität richtet sich an den Antragsteller des PP/PP-Moduls, der einen Nachweis darüber verlangt, dass die Anforderungen des PP/PP-Moduls erfüllt werden und dass die ST eine Instanziierung genau dieser Sicherheitsanforderungen (SFR) ist, ohne zusätzliche Funktionalität einzubeziehen. Im Wesentlichen legt die ST fest, dass der TOE das tut, was vom PP oder einer PP-Konfiguration, die ein PP-Modul enthält, gefordert wird, ohne zusätzliche Ansprüche zu stellen.

Wenn „genaue“ Konformität gewählt wird, hat der Autor des PP/PP-Moduls auch die Möglichkeit, die folgenden Informationen anzugeben:

- a) andere PP, mit denen ein ST in Kombination mit dem betreffenden PP/PP-Modul Konformität beanspruchen kann und dennoch genaue Konformität beibehält;
- b) PP-Module, die mit dem PP/PP-Modul festgelegt werden dürfen und dennoch genaue Konformität beibehalten.

Die Normenreihe ISO/IEC 15408 erlaubt es den ST, genaue Konformität mit mehreren PP zu beanspruchen, solange alle PP in ihrer Zulässigkeitserklärung genaue Konformität verlangen und den Anspruch mit den ande-

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01 prEN ISO/IEC 15408-1:2023 (D)

ren angegebenen PP zulassen. Die Normenreihe ISO/IEC 15408 erlaubt es den ST, genaue Konformität mit einer PP-Konfiguration zu beanspruchen, solange die PP-Konfiguration genaue Konformität verlangt und die ST keine Konformität mit einem anderen PP oder einer anderen PP-Konfiguration beanspruchen.

Die Normenreihe ISO/IEC 15408 erlaubt es den PP auch, Konformität mit einem oder mehreren PP zu beanspruchen. In dem Fall, in dem das beanspruchte PP eine genaue Konformität erfordert, wird jedoch das Potential deutlich, die Absicht der genauen Konformität zu umgehen. Dies liegt daran, dass Anforderungen hinzugefügt werden können, die die PP-Autoren der genauen Konformität für die Verwendung mit der beanspruchten PP nicht für angemessen halten würden. Wenn also ein PP genaue Konformität verlangt, darf ein anderes PP keine Art von Konformität mit diesem PP beanspruchen. Diese Einschränkung gibt dem PP-Autor der genauen Konformität mehr Kontrolle über die Funktionalität und die Vertrauenswürdigkeit, die für konforme ST bereitgestellt werden, als dies bei strikter oder nachweislicher Konformität der Fall ist.

BEISPIEL 1 Wenn eine ST gleichzeitig Konformität mit PP A (das genaue Konformität verlangt) und mit PP B (das nachweisliche Konformität verlangt) beanspruchen kann, würde dies SFR einbeziehen, die der Autor von PP A nicht ausdrücklich zur Verwendung in Kombination mit der Funktionalität von PP A genehmigt hat, wenn eine ST Konformität mit PP A beansprucht.

Wie bereits erwähnt, ist es zulässig, dass eine ST genaue Konformität mit mehreren PP mit genauer Konformität beansprucht. Außerdem darf eine PP-Konfiguration mehrere Komponenten (PP, Basis-PP, PP-Module und Basis-PP-Module) enthalten, die genaue Konformität verlangen. Damit PP-Autoren die Kontrolle darüber behalten, welche Komponenten der PP-Konfiguration zusammen mit ihrem PP beansprucht werden dürfen, kann die in B.2.3 beschriebene Zulässigkeitserklärung im PP aufgenommen werden, die angibt, für welche PP ein ST-Autor gleichzeitig Konformität mit dem betreffenden PP beanspruchen darf. Alle identifizierten PP müssen in ihrer Zulässigkeitserklärung eine genaue Konformität verlangen und in ihrer Zulässigkeitserklärung auch die betreffenden PP und alle anderen beanspruchten PP auflisten. Dasselbe Konstrukt wird für PP-Module und Basis-PP verwendet, ebenso wie für alle Basis-PP-Module, die angegeben werden können. Beispiel 2 soll das Konzept einer ST verdeutlichen, die Konformität mit mehreren PP beansprucht.

BEISPIEL 2 Angenommen, die Autoren von PP B wollten den ST erlauben, Konformität mit PP „B“ zu beanspruchen und auch Konformitätsansprüche in Kombination mit PP „C“ zuzulassen. Diese Situation ist in Bild E.1 dargestellt.

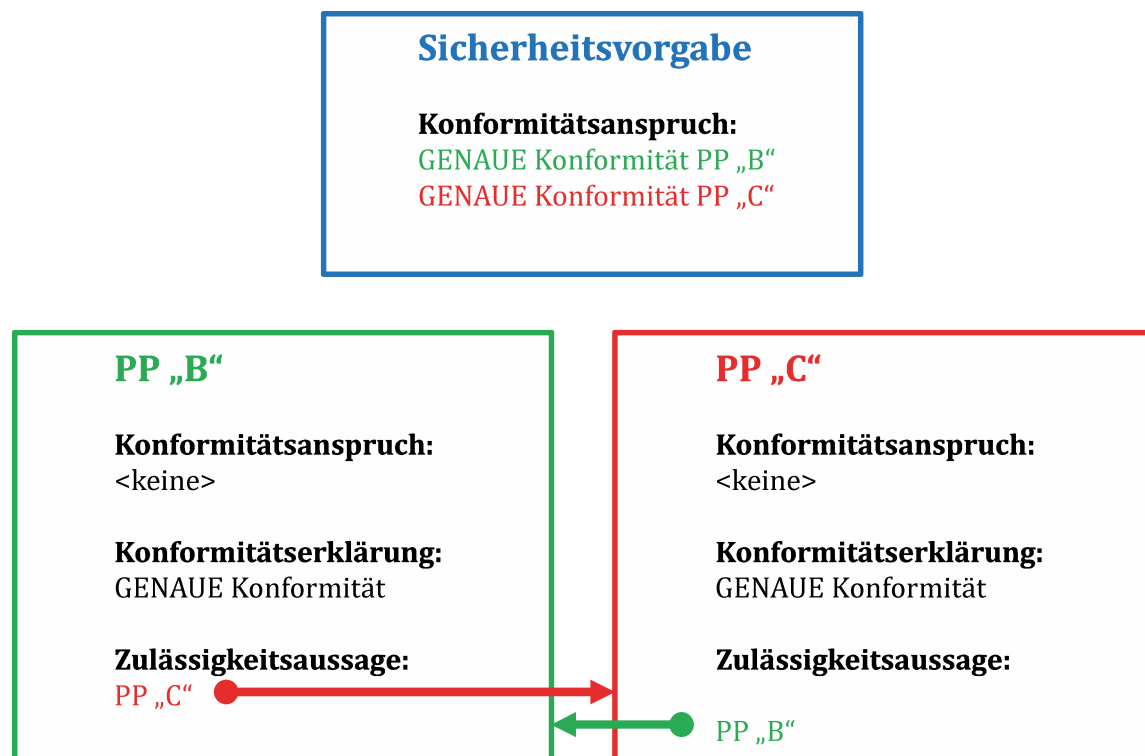


Bild E.1 — Genaue Konformität einer ST mit mehreren PP

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)**

Dann müsste das Folgende zutreffen:

- a) Sowohl PP B als auch PP C müssten die genaue Konformität in ihrer Konformitätserklärung angeben;
- b) PP B würde PP C in seiner Zulässigkeitserklärung als mit PP B zulässig aufführen;
- c) PP C würde PP B in seiner Zulässigkeitserklärung als mit PP C zulässig aufführen.

Wenn eine dieser Aussagen nicht zutrifft, kann die ST keine genaue Konformität mit PP B und PP C beanspruchen.

Dieses Konzept erstreckt sich auch auf PP-Module und PP-Konfigurationen. Ein PP-Modul muss eine Reihe von PP-Modulbasen identifizieren; wenn eine der identifizierten PP-Modulbasen eine Konformitätserklärung der genauen Konformität hat, dann müssen alle von dem PP-Modul festgelegten PP-Modulbasen ebenfalls Konformitätserklärungen haben, die die genaue Konformität angeben. Um sicherzustellen, dass die PP-Module für die Verwendung mit der PP-Modulbasis zugelassen sind, gibt jede PP-Modulbasis in ihrer Zulässigkeitserklärung die PP-Module an, die sie als PP-Modulbasis zur Verwendung in einer PP-Konfiguration angeben dürfen.

ANMERKUNG Umgekehrt braucht ein PP-Modul in der Zulässigkeitserklärung keine Angaben zu seinen PP-Modulbasen machen, da es dies implizit durch die Definition des PP/PP-Moduls als PP-Modulbasis getan hat.

Ein PP-Modul gibt auch an, welche anderen PP-Module oder PP, die nicht bereits in der PP-Modulbasis des PP-Moduls enthalten sind, in Kombination mit ihm in einer PP-Konfiguration verwendet werden können.

BEISPIEL 3 Bild E.2 beschreibt einen Fall von genauer Konformität, der sowohl PP als auch PP-Module umfasst.

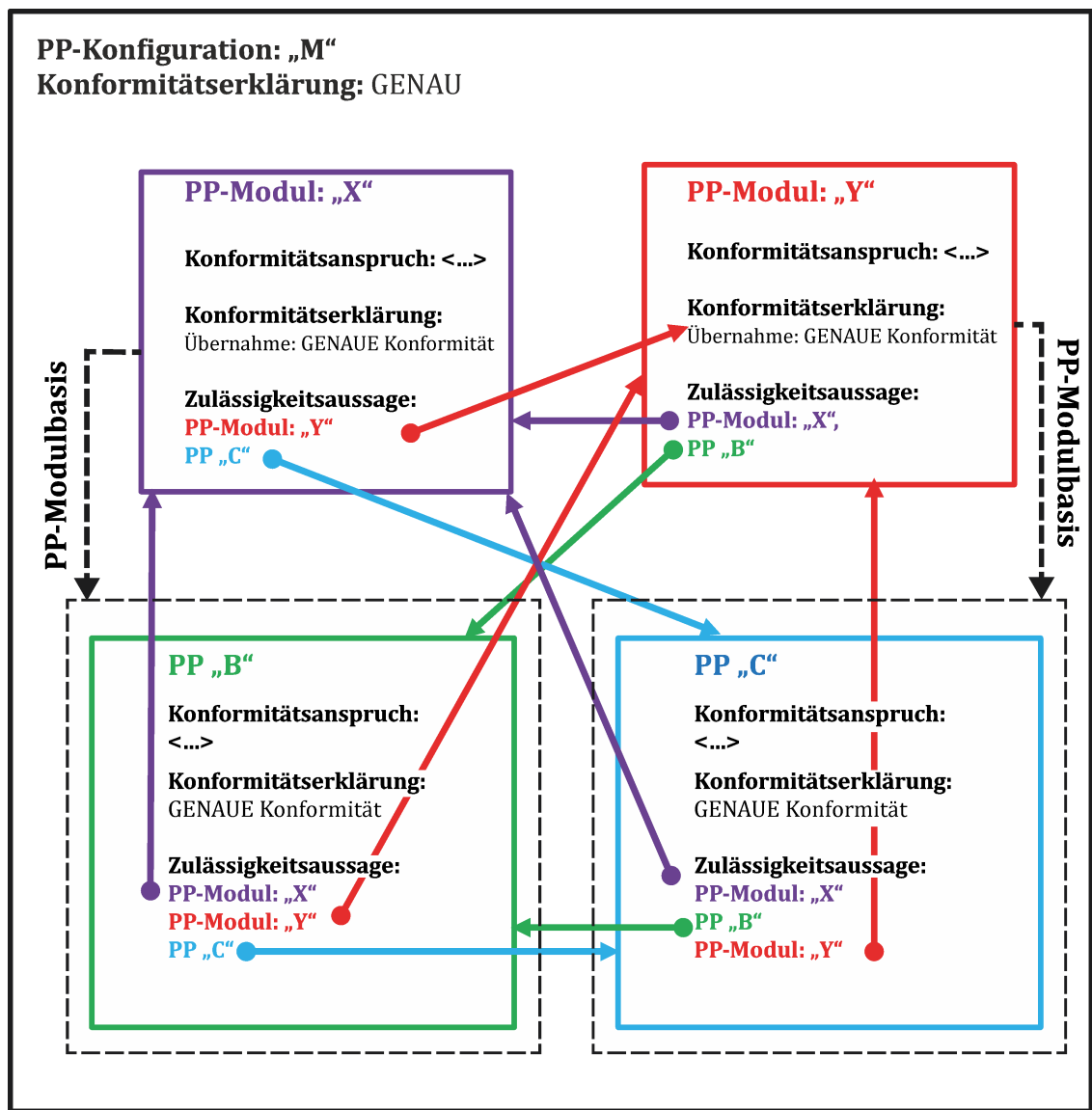


Bild E.2 — Genaue Konformität mit einer PP-Konfiguration mit mehreren PP und PP-Modulen

E.4.2 FAQ/Cheatsheet zu genauer Konformität

Tabelle E.1 gibt einen Überblick über häufig gestellte Fragen zum Fall der genauen Konformität.

Tabelle E.1 — Zusammenfassung der genauen Konformität

PP-Konfigurationen	Verweisung	Zulässig/Erforderlich?
Verwendbar bei Mehrfach-Vertrauenswürdigkeit – modulare PP-Konfiguration?	Bild 5	ja
Verwendbar bei Einfach-Vertrauenswürdigkeit – modulare PP-Konfiguration?	Bild 5	ja
Kann EC mit strikten/nachweislichen Konformitätstypen mischen	10.8.1	nein
Andere EC PP in EC PP-Konfiguration zulässig		ja
EC PP		

- Entwurf -

E DIN EN ISO/IEC 15408-1:2024-01
prEN ISO/IEC 15408-1:2023 (D)

Tabelle E.1 (*fortgesetzt*)

PP-Konfigurationen	Verweisung	Zulässig/Erforderlich?
Optionale/auswahlbasierte SFR in EC PP	12.4.1	ja
Zusätzliche SPD-Elemente, die mit optionalen SFR verbunden sind		ja
EC PP beanspruchen Konformität mit einem anderen EC PP? (verkettet)	10.8.1 10.10.3 B.3.2.2	nein
Andere EC PP in EC PP-Konfiguration zulässig		ja
PP baut auf striktem oder nachweislichem PP auf?		nein
Verwendbar bei strikter oder nachweislicher PP-Konfiguration?		nein
Gibt an, welche anderen EC PP „miteinander zulässig“ sind		ja
Gibt an, welche anderen EC PP-Module „miteinander zulässig“ sind	11.2.3.3 d)	ja
EC PP-Module		
Optionale/auswahlbasierte SFR in EC PP-Modulen	11.2.3.3	ja
EC PP-Modul schließt in seiner Zulässigkeitserklärung keine Komponenten in seiner PP-Modulbasis ein.	11.2.3.3 d)	ja
Gibt an, dass andere EC PP und PP-Module „miteinander zulässig“ sind	11.2.3.3 d)	ja
Alle zulässigen Elemente auch EC	11.2.3.3 d)	ja
EC-Funktionspakete		
Optionale/auswahlbasierte SFR in EC-Funktionspaket zulässig		ja
Funktionspakete können in der ST ergänzt werden		nein
Werden in einem ST-Konformitätsanspruch geltend gemacht	12.2 d)	nein
EC ST		
Enthält die SPD aller EC PP, und/oder Komponenten der PP-Konfiguration	12.4.3	ja
Zusätzliche oder hierarchisch höhere Sicherheitsanforderungen?	12.4.4	nein
Enthält nur die ausgewählten auswahlbasierten Anforderungen	12.4.4	ja
Kann mit dem Ansatz der direkten Begründung verwendet werden		ja

- Entwurf -**E DIN EN ISO/IEC 15408-1:2024-01**
prEN ISO/IEC 15408-1:2023 (D)**Literaturhinweise****ISO/IEC-Normen und Leitlinien**

- [1] ISO/IEC 8367, *Information technology — Security techniques — Cryptographic algorithms and security mechanisms conformance testing*
- [2] ISO/IEC 15408-4:2022, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 4: Framework for the specification of evaluation methods and activities*
- [3] ISO/IEC 15408-5:2022, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 5: Pre-defined packages of security requirements*
- [4] ISO/IEC 15446, *Information technology — Security techniques — Guidance for the production of Protection Profiles and STs*
- [5] ISO/IEC TR 18018:2010, *Information technology — Systems and software engineering — Guide for configuration management tool capabilities*
- [6] ISO/IEC TR 18031:2011, *Information technology — Security techniques — Random bit generation*
- [7] ISO/IEC 18033-3:2010, *Information technology — Security techniques — Encryption algorithms — Part 3: Block ciphers*
- [8] ISO/IEC 19608, *Information technology — Security techniques — Guidance for developing security and privacy functional requirements based on ISO/IEC 15408*
- [9] ISO/IEC 19249, *Information technology — Security techniques — Catalogue of architectural and design principles for secure products, systems, and applications*
- [10] ISO/IEC 19790, *Information technology — Security techniques — Security requirements for cryptographic modules*
- [11] ISO/IEC 19791, *Information technology — Security techniques — Security assessment of operational systems*
- [12] ISO/IEC 19896-1, *IT security techniques — Competence requirements for information security testers and evaluators — Part 1: Introduction, concepts and general requirements*
- [13] ISO/IEC 19896-3, *IT security techniques — Competence requirements for information security testers and evaluators — Part 3: Knowledge, skills and effectiveness requirements for ISO/IEC 15408 evaluators*
- [14] ISO/IEC 20004, *Information technology — Security techniques — Refining software vulnerability analysis under ISO/IEC 15408 and ISO/IEC 18045*
- [15] ISO/IEC TR 22216, *Information security, cybersecurity and privacy protection — New concepts and changes in ISO/IEC 15408:2022 and ISO/IEC 18045:2022*
- [16] ISO/IEC 27001, *Information technology — Security techniques — Information security management systems — Requirements*
- [17] ISO/IEC 27002, *Information security, cybersecurity and privacy protection — Information security controls*
- [18] ISO/IEC 27034 (alle Teile), *Information technology — Application security*

Kataloge von PPs und evaluierter Produkte

- [19] Common Criteria portal: Certified Products, available at <http://www.commoncriteriaportal.org/products/>
- [20] Common Criteria portal: Protection Profiles, available at <http://www.commoncriteriaportal.org/pps/>
- [21] Common Criteria portal: Collaborative Protection Profiles, available at <http://www.commoncriteriaportal.org/pps/?cpp=1>

- Entwurf -

Contents

Page

Foreword	vi
Introduction	viii
1 Scope	1
2 Normative references	1
3 Terms and definitions	2
4 Abbreviated terms	13
5 Overview	15
5.1 General	15
5.2 ISO/IEC 15408 series description	15
5.2.1 General	15
5.2.2 Audience	16
5.3 Target of evaluation (TOE)	19
5.3.1 General	19
5.3.2 TOE boundaries	19
5.3.3 Different representations of the TOE	20
5.3.4 Different configurations of the TOE	20
5.3.5 Operational environment of the TOE	20
5.4 Presentation of material in this document	21
6 General model	21
6.1 Background	21
6.2 Assets and security controls	21
6.3 Core constructs of the paradigm of the ISO/IEC 15408 series	24
6.3.1 General	24
6.3.2 Conformance types	24
6.3.3 Communicating security requirements	24
6.3.4 Meeting the needs of consumers (risk owners)	27
7 Specifying security requirements	29
7.1 Security problem definition (SPD)	29
7.1.1 General	29
7.1.2 Threats	29
7.1.3 Organizational security policies (OSPs)	30
7.1.4 Assumptions	30
7.2 Security objectives	31
7.2.1 General	31
7.2.2 Security objectives for the TOE	31
7.2.3 Security objectives for the operational environment	31
7.2.4 Relation between security objectives and the SPD	32
7.2.5 Tracing between security objectives and the SPD	32
7.2.6 Providing a justification for the tracing	33
7.2.7 On countering threats	33
7.2.8 Security objectives: conclusion	33
7.3 Security requirements	33
7.3.1 General	33
7.3.2 Security Functional Requirements (SFRs)	34
7.3.3 Security assurance requirements (SARs)	36
7.3.4 Security requirements: conclusion	37
8 Security components	38
8.1 Hierarchical structure of security components	38
8.1.1 General	38
8.1.2 Class	38
8.1.3 Family	39

8.1.4	Component.....	39
8.1.5	Element.....	39
8.2	Operations.....	39
8.2.1	General.....	39
8.2.2	Iteration.....	40
8.2.3	Assignment.....	40
8.2.4	Selection.....	41
8.2.5	Refinement.....	43
8.3	Dependencies between components.....	44
8.4	Extended components.....	44
8.4.1	General.....	44
8.4.2	Defining extended components.....	45
9	Packages.....	45
9.1	General.....	45
9.2	Package types.....	46
9.2.1	General.....	46
9.2.2	Assurance packages.....	46
9.2.3	Functional packages.....	47
9.3	Package dependencies.....	47
9.4	Evaluation method(s) and activities.....	47
10	Protection Profiles (PPs).....	48
10.1	General.....	48
10.2	PP introduction.....	48
10.3	Conformance claims and conformance statements.....	48
10.4	Security assurance requirements (SARs).....	51
10.5	Additional requirements common to strict and demonstrable conformance.....	51
10.5.1	Conformance claims and conformance statements.....	51
10.5.2	Security problem definition (SPD).....	51
10.5.3	Security objectives.....	52
10.6	Additional requirements specific to strict conformance.....	52
10.6.1	Requirements for the security problem definition (SPD).....	52
10.6.2	Requirements for the security objectives.....	52
10.6.3	Requirements for the security requirements.....	52
10.7	Additional requirements specific to demonstrable conformance.....	53
10.8	Additional requirements specific to exact conformance.....	53
10.8.1	General.....	53
10.8.2	Conformance claims and statements.....	53
10.9	Using PPs.....	54
10.10	Conformance statements and claims in the case of multiple PPs.....	54
10.10.1	General.....	54
10.10.2	Where strict or demonstrable conformance is specified.....	54
10.10.3	Where exact conformance is specified.....	54
11	Modular requirements construction.....	54
11.1	General.....	54
11.2	PP-Modules.....	55
11.2.1	General.....	55
11.2.2	PP-Module Base.....	55
11.2.3	Requirements for PP-Modules.....	55
11.3	PP-Configurations.....	59
11.3.1	General.....	59
11.3.2	Requirements for PP-Configurations.....	59
11.3.3	Usage of PP-Configurations.....	65
12	Security Targets (STs).....	68
12.1	General.....	68
12.2	Conformance claims and statements.....	68
12.3	Assurance requirements.....	71

12.4	Additional requirements in the exact conformance case.....	71
12.4.1	Additional requirements for the conformance claim	71
12.4.2	Additional requirements for the SPD	71
12.4.3	Additional requirements for the security objectives.....	72
12.4.4	Additional requirements for the security requirements	72
12.5	Additional requirements in the multi-assurance case.....	72
13	Evaluation and evaluation results	74
13.1	General.....	74
13.2	Evaluation context	76
13.3	Evaluation of PPs and PP-Configurations.....	77
13.4	Evaluation of STs.....	77
13.5	Evaluation of TOEs.....	77
13.6	Evaluation methods and evaluation activities.....	78
13.7	Evaluation results.....	78
13.7.1	Results of a PP evaluation.....	78
13.7.2	Results of a PP-Configuration evaluation	78
13.7.3	Results of a ST/TOE evaluation.....	78
13.8	Multi-assurance evaluation.....	79
14	Composition of assurance	80
14.1	General.....	80
14.2	Composition models	81
14.2.1	Layered composition model	81
14.2.2	Network or bi-directional composition model	82
14.2.3	Embedded composition model.....	82
14.3	Evaluation techniques for providing assurance in composition models.....	83
14.3.1	General	83
14.3.2	ACO class for composed TOEs.....	83
14.3.3	Composite evaluation for composite products.....	84
14.4	Requirements for evaluations using composition techniques.....	95
14.4.1	Re-use of evaluation results.....	95
14.4.2	Composition evaluation issues	96
14.5	Evaluation by composition and multi-assurance.....	97
	Annex A (normative) Specification of packages	98
	Annex B (normative) Specification of Protection Profiles (PPs)	102
	Annex C (normative) Specification of PP-Modules and PP-Configurations.....	112
	Annex D (normative) Specification of Security Targets (STs) and Direct Rationale STs.....	125
	Annex E (normative) PP/PP-Configuration conformance.....	136
	Bibliography.....	141

Foreword

ISO (the International Organization for Standardization) and IEC (the International Electrotechnical Commission) form the specialized system for worldwide standardization. National bodies that are members of ISO or IEC participate in the development of International Standards through technical committees established by the respective organization to deal with particular fields of technical activity. ISO and IEC technical committees collaborate in fields of mutual interest. Other international organizations, governmental and non-governmental, in liaison with ISO and IEC, also take part in the work.

The procedures used to develop this document and those intended for its further maintenance are described in the ISO/IEC Directives, Part 1. In particular, the different approval criteria needed for the different types of document should be noted. This document was drafted in accordance with the editorial rules of the ISO/IEC Directives, Part 2 (see www.iso.org/directives or www.iec.ch/members_experts/refdocs).

Attention is drawn to the possibility that some of the elements of this document may be the subject of patent rights. ISO and IEC shall not be held responsible for identifying any or all such patent rights. Details of any patent rights identified during the development of the document will be in the Introduction and/or on the ISO list of patent declarations received (see www.iso.org/patents) or the IEC list of patent declarations received (see <https://patents.iec.ch>).

Any trade name used in this document is information given for the convenience of users and does not constitute an endorsement.

For an explanation of the voluntary nature of standards, the meaning of ISO specific terms and expressions related to conformity assessment, as well as information about ISO's adherence to the World Trade Organization (WTO) principles in the Technical Barriers to Trade (TBT) see www.iso.org/iso/foreword.html. In the IEC, see www.iec.ch/understanding-standards.

This document was prepared by Technical Committee ISO/IEC JTC 1, *Information technology*, Subcommittee SC 27, *Information security, cybersecurity and privacy protection*.

This fourth edition cancels and replaces the third edition (ISO/IEC 15408-1:2009), which has been technically revised.

The main changes are as follows:

- the document has been restructured;
- technical changes have been introduced:
 - the terminology has been reviewed and updated;
 - the exact conformance type has been introduced;
 - low assurance protection profiles (PPs) have been removed and direct rationale PPs have been introduced;
 - PP-Modules and PP-Configurations for modular evaluations have been introduced;
 - multi-assurance evaluation has been introduced.

A list of all parts in the ISO/IEC 15408 series can be found on the ISO and IEC websites.

Any feedback or questions on this document should be directed to the user's national standards body. A complete listing of these bodies can be found at www.iso.org/members.html and www.iec.ch/national-committees.

Legal notice

The governmental organizations listed below contributed to the development of this version of the Common Criteria for Information Technology Security Evaluations. As the joint holders of the copyright in the Common Criteria for Information Technology Security Evaluations (called CC), they hereby grant non-exclusive license to ISO/IEC to use CC in the continued development/maintenance of the ISO/IEC 15408 series of standards. However, these governmental organizations retain the right to use, copy, distribute, translate or modify CC as they see fit.

Australia	The Australian Signals Directorate
Canada	Communications Security Establishment
France	Agence Nationale de la Sécurité des Systèmes d'Information
Germany	Bundesamt für Sicherheit in der Informationstechnik
Japan	Information-technology Promotion Agency
Netherlands	Netherlands National Communications Security Agency
New Zealand	Government Communications Security Bureau
Republic of Korea	National Security Research Institute
Spain	Ministerio de Asuntos Económicos y Transformación Digital
Sweden	FMV, Swedish Defence Materiel Administration
United Kingdom	National Cyber Security Centre
United States	The National Security Agency

Introduction

The ISO/IEC 15408 series permits comparability between the results of independent security evaluations by providing a common set of requirements for the security functionality of IT products and for assurance measures applied to these IT products during a security evaluation. These IT products may be implemented in hardware, firmware, or software.

The evaluation process establishes a level of confidence that the security functionality of these IT products and the assurance measures applied to these IT products meet these requirements. The evaluation results may help consumers to determine whether these IT products fulfil their security needs.

The ISO/IEC 15408 series is useful as a guide for the development, evaluation and/or procurement of IT products with security functionality.

The ISO/IEC 15408 series is intentionally flexible, enabling a range of evaluation approaches to be applied to a range of security properties of a range of IT products. Therefore, users of the standard are cautioned to exercise care that this flexibility is not misused. For example, using the ISO/IEC 15408 series in conjunction with unsuitable evaluation methods/activities, irrelevant security properties, or inappropriate IT products, can result in meaningless evaluation results.

Consequently, the fact that an IT product has been evaluated has meaning only in the context of the security properties that were evaluated and the evaluation methods that were used. Evaluation authorities are advised to carefully check the products, properties, and methods to determine that an evaluation provides meaningful results. Additionally, purchasers of evaluated products are advised to carefully consider this context to determine whether the evaluated product is useful and applicable to their specific situation and needs.

The ISO/IEC 15408 series addresses the protection of assets from unauthorized disclosure, modification, or loss of use. The categories of protection relating to these three types of failure of security are commonly called confidentiality, integrity, and availability, respectively. The ISO/IEC 15408 series may also be applicable to aspects of IT security outside of these three categories. The ISO/IEC 15408 series is applicable to risks arising from human activities (malicious or otherwise) and to risks arising from non-human activities. The ISO/IEC 15408 series may be applied in other areas of IT but makes no claim of applicability in these areas.

Certain topics, because they involve specialized techniques or because they are somewhat peripheral to IT security, are considered to be outside the scope of the ISO/IEC 15408 series. Some of these are identified below:

- a) the ISO/IEC 15408 series does not contain security evaluation criteria pertaining to administrative security measures not related directly to the IT security functionality. However, it is recognized that significant security can often be achieved through or supported by administrative measures such as organizational, personnel, physical, and procedural controls;
- b) the ISO/IEC 15408 series does not address the evaluation methodology under which the criteria should be applied;

NOTE 1 The baseline methodology is defined in ISO/IEC 18045. ISO/IEC 15408-4 can be used to further derive evaluation activities and methods from ISO/IEC 18045.

- c) the ISO/IEC 15408 series does not address the administrative and legal framework under which the criteria may be applied by evaluation authorities. However, it is expected that the ISO/IEC 15408 series is intended to be used for evaluation purposes in the context of such a framework;
- d) the procedures for use of evaluation results in accreditation are outside the scope of the ISO/IEC 15408 series. Accreditation is the administrative process whereby authority is granted for the operation of an IT product (or collection thereof) in its full operational environment including all of its non-IT parts. The results of the evaluation process are an input to the accreditation process. However, as other techniques are more appropriate for the assessments of non-IT related properties

and their relationship to the IT security parts, accreditors must make separate provisions for those aspects;

- e) the subject of criteria for the assessment of the inherent qualities of cryptographic algorithms is not covered in the ISO/IEC 15408 series. In the case that independent assessment of mathematical properties of cryptography is required, the evaluation scheme under which the ISO/IEC 15408 series is applied shall make provision for such assessments.

NOTE 2 This document uses bold and italic type in some cases to distinguish terms from the rest of the text. The relationship between components within a family is highlighted using a bolding convention. This convention calls for the use of bold type for all new requirements. For hierarchical components, requirements are presented in bold type when they are enhanced or modified beyond the requirements of the previous component. In addition, any new or enhanced permitted operations beyond the previous component are also highlighted using bold type.

The use of italics indicates text that has a precise meaning. For security assurance requirements the convention is for special verbs relating to evaluation.

- Entwurf -

Information security, cybersecurity and privacy protection — Evaluation criteria for IT security —

Part 1: Introduction and general model

1 Scope

This document establishes the general concepts and principles of IT security evaluation and specifies the general model of evaluation given by various parts of the standard which in its entirety is meant to be used as the basis for evaluation of security properties of IT products.

This document provides an overview of all parts of the ISO/IEC 15408 series. It describes the various parts of the ISO/IEC 15408 series; defines the terms and abbreviations to be used in all parts of the standard; establishes the core concept of a Target of Evaluation (TOE); describes the evaluation context and describes the audience to which the evaluation criteria is addressed. An introduction to the basic security concepts necessary for evaluation of IT products is given.

This document introduces:

- the key concepts of Protection Profiles (PP), PP-Modules, PP-Configurations, packages, Security Targets (ST), and conformance types;
- a description of the organization of security components throughout the model;
- the various operations by which the functional and assurance components given in ISO/IEC 15408-2 and ISO/IEC 15408-3 can be tailored through the use of permitted operations;
- general information about the evaluation methods given in ISO/IEC 18045;
- guidance for the application of ISO/IEC 15408-4 in order to develop evaluation methods (EM) and evaluation activities (EA) derived from ISO/IEC 18045;
- general information about the pre-defined Evaluation Assurance Levels (EALs) defined in ISO/IEC 15408-5;
- information in regard to the scope of evaluation schemes.

2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

ISO/IEC 15408-2:2022, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 2: Security functional components*

ISO/IEC 15408-3:2022, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 3: Security assurance components*

ISO/IEC 18045, *IT security techniques — Methodology for IT security evaluation*

ISO/IEC IEEE 24765, *Systems and software engineering — Vocabulary*

3 Terms and definitions

For the purposes of this document, the terms and definitions given in ISO/IEC 15408-2, ISO/IEC 15408-3, ISO/IEC 18045 and ISO/IEC IEEE 24765 apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <https://www.iso.org/obp>
- IEC Electropedia: available at <https://www.electropedia.org/>

3.1 action

documented activity of the *evaluator* (3.45) or *developer* (3.33)

Note 1 to entry: Evaluator actions and developer actions are required by ISO/IEC 15408-3.

3.2 administrator

entity (3.36) that has a level of trust with respect to all policies implemented by the *TOE security functionality (TSF)* (3.92)

Note 1 to entry: Not all *protection profiles (PPs)* (3.68) or security targets (STs) assume the same level of trust for administrators. Typically, administrators are assumed to adhere at all times to the policies in the ST of the *target of evaluation (TOE)* (3.90). Some of these policies can be related to the functionality of the TOE, while others can be related to the *operational environment* (3.63).

3.3 adverse action

action (3.1) performed by a *threat agent* (3.91) on an *asset* (3.4)

3.4 asset

entity (3.36) that the owner of the *target of evaluation (TOE)* (3.90) presumably places value on

3.5 assignment

specification of an identified parameter in a functional or assurance component

3.6 assurance

grounds for confidence that a *target of evaluation (TOE)* (3.90) meets the *security functional requirements (SFRs)* (3.78)

3.7 assurance package

named set of *security assurance requirements* (3.76)

EXAMPLE “EAL 3”.

3.8 attack potential

measure of the effort needed to exploit a vulnerability in a *target of evaluation (TOE)* (3.90)

Note 1 to entry: The effort is expressed as a function of properties related to the attacker (e.g. expertise, resources, and motivation) and properties related to the vulnerability itself (e.g. window of opportunity, time to exposure).

3.9**attack surface**

set of logical or physical interfaces to a target, consisting of points through which access to the target and its functions may be attempted

EXAMPLE 1 The casing of a payment terminal is a part of physical attack surface for that device.

EXAMPLE 2 The communications protocols available for connection to a network device are part of the logical attack surface for that network device.

3.10**augmentation**

addition of one or more requirements to a package

Note 1 to entry: In case of a *functional package* (3.51), such an augmentation is considered only in the context of one package and is not considered in the context with other packages or *protection profiles (PPs)* (3.68) or *security targets (STs)* (3.82).

Note 2 to entry: In case of an *assurance package* (3.7), augmentation refers to one or more *security assurance requirements (SARs)* (3.76).

3.11**authorized user**

entity (3.36) who may, in accordance with the *security functional requirements (SFRs)* (3.78), perform an operation on the *target of evaluation (TOE)* (3.90)

3.12**base component**

independent entity (3.36) in a multi-component product that provides services and resources to one or more *dependent component(s)* (3.31)

Note 1 to entry: This applies in particular to 'composed TOEs' (3.21) and 'composite products / composite TOEs' (3.25).

3.13**base Protection Profile****base PP**

Protection Profile (3.68) specified in a *PP-Module* (3.71), as part of that PP-Module's *PP-Module Base* (3.72), used as a basis to build a *PP-Configuration* (3.69)

3.14**base PP-Module**

PP-Module (3.71) specified in a different PP-Module, as part of that PP-Module's *PP-Module Base* (3.72), used as a basis to build a *PP-Configuration* (3.69)

Note 1 to entry: Specifying a base PP-Module in a PP-Module implicitly includes the base PP-Module's PP-Module Base.

3.15**base target of evaluation****base TOE**

base component (3.12) which is itself the subject of an evaluation

Note 1 to entry: This applies in particular to 'composed TOEs' (3.21) and 'composite products/composite TOEs' (3.25).

3.16**class**

{taxonomy} set of families that share a common focus

Note 1 to entry: Class is further defined in ISO/IEC 15408-2, which defines security functional classes and ISO/IEC 15408-3, which defines security assurance classes.

**3.17
component**

{taxonomy} smallest selectable set of elements on which requirements may be based

**3.18
component**

<composition> *entity* (3.36) which provides resources and services in a product

**3.19
component target of evaluation
component TOE**

(evaluated) *target of evaluation (TOE)* (3.90) that is a component of another *composed TOE* (3.21)

**3.20
composed assurance package
CAP**

assurance package (3.7) consisting of components drawn predominately from the *ACO class* (3.16), representing a point on the pre-defined scale for composition assurance

**3.21
composed target of evaluation
composed TOE**

target of evaluation (TOE) (3.90) comprising solely two or more separately identified components with a security relationship between their *TOE security functionality (TSFs)* (3.92)

Note 1 to entry: Each of the separately identified components is itself a TOE.

**3.22
composed evaluation**

evaluation of a *composed TOE* (3.21) using the specific evaluation technique applicable to composed TOEs

Note 1 to entry: This evaluation technique refers to the *ACO assurance class* (3.16) that is defined in ISO/IEC 15408-3.

**3.23
composite evaluation**

evaluation of a *composite TOE/product* (3.25) using the specific composite evaluation technique

Note 1 to entry: This evaluation technique refers to the COMP related assurance families that are specified in ISO/IEC 15408-3 for the ADV, ALC, ASE, ATE and AVA *classes* (3.16).

**3.24
composite product**

product comprised of two or more components which can be organized in two layers: a layer of one already evaluated base *component (base TOE)* (3.15) and a layer of one *dependent component* (3.31)

**3.25
composite target of evaluation
composite TOE**

part of a *composite product* (3.24) including the *base TOE* (3.15) and the *dependent component* (3.31)

Note 1 to entry: A dependent component in a composite TOE can consist of one or more dependent components. For simplification, they are considered as 'one dependent component'.

Note 2 to entry: A composite TOE can contain parts that are independent from the *base component* (3.12) or base TOE respectively. For simplification, such parts are considered as belonging to the dependent component.

Note 3 to entry: The *composite evaluation* (3.23) can be applied as many times as necessary to a multi-component/multi-layered product, in an incremental approach.

3.26**configuration management
CM**

discipline applying technical and administrative direction and surveillance to: identify and document the functional and physical characteristics of a configuration item, control changes to those characteristics, record and report change processing and implementation status, and verify compliance with specified requirements

[SOURCE: ISO/IEC IEEE 24765:2017, 3.779 1]

3.27**configuration management system**

set of procedures and tools (including their documentation) used by a *developer* (3.33) to develop and maintain configurations of their products during their life-cycles

Note 1 to entry: Configuration management systems can have varying degrees of rigour and function. At higher levels, configuration management systems can be automated, with flaw remediation, change controls, and other tracking mechanisms.

3.28**counter, verb**

act on or respond to a particular threat so that the threat is eradicated or mitigated

3.29**demonstrable conformance****DC**

relation between a *protection profile (PP)* (3.68)/*security target (ST)* (3.82) (PP/ST) and a PP, or an ST and a *PP-Configuration* (3.69), where the PP/ST provides an equivalent or more restrictive solution that solves the generic security problem in the PP/PP-Configuration

3.30**dependency**

relationship between components such that a *protection profile (PP)* (3.68), *security target (ST)* (3.82), *functional package* (3.51) or *assurance package* (3.7) including a component also includes any other components that are identified as being depended upon or include a rationale as to why they are not

3.31**dependent component**

dependent entity (3.36) in a multi-component product that relies on the provision of services and resources by one or more *base components* (3.12)

Note 1 to entry: This applies in particular to '*composed TOEs*' (3.21) and '*composite products / composite TOE*' (3.25).

3.32**dependent target of evaluation****dependent TOE**

dependent component (3.31) which is itself the subject of an evaluation

Note 1 to entry: This applies only to '*composed TOEs*' (3.21) and not to '*composite products / composite TOEs*' (3.25).

3.33**developer**

organization responsible for the development of the *target of evaluation (TOE)* (3.90)

3.34**direct rationale**

type of *Protection Profile* (3.68), *PP-Module* (3.71) or *Security Target* (3.82) in which the *security problem definition (SPD)* (3.80) elements are mapped directly to the *security functional requirements (SFRs)* (3.78) and possibly to the *security objectives* (3.79) for the *operational environment* (3.63)

Note 1 to entry: Direct rationale does not include security objectives for the *target of evaluation (TOE)* (3.90).

3.35**element**

⟨taxonomy⟩ self-contained description of a security need assigned to *security assurance requirement (SAR)* (3.76) or *security functional requirement (SFR)* (3.78)

3.36**entity**

identifiable item that is described by a set or collection of properties

Note 1 to entry: Entities include subjects, users (including external IT products), objects, information, sessions and/or resources.

3.37**evaluation**

assessment of a *PP-Configuration* (3.69), *protection profile (PP)* (3.68), a *security target (ST)* (3.82), or a *target of evaluation (TOE)* (3.90), against defined criteria

3.38**evaluation activity****EA**

activity derived from one or more work units

Note 1 to entry: Work units are defined in ISO/IEC 18045.

Note 2 to entry: Derivation mechanisms are defined in ISO/IEC 15408-4.

3.39**evaluation assurance level****EAL**

well-formed package of *security assurance requirements* (3.76) representing a point on the pre-defined assurance scale

Note 1 to entry: EALs are defined in ISO/IEC 15408-5.

3.40**evaluation authority**

body operating an *evaluation scheme* (3.42)

Note 1 to entry: By applying the evaluation scheme, the evaluation authority sets the standards and monitors the quality of evaluations conducted by bodies within a specific community.

3.41**evaluation method****EM**

set of one or more *evaluation activities* (3.38) for application in a specific context

3.42**evaluation scheme**

rules, procedures and management to carrying evaluations of IT product security

Note 1 to entry: An evaluation scheme implements all parts of the ISO/IEC 15408 series.

3.43**evaluation technical report****ETR**

documentation of the *overall verdict* (3.66) and its justification, produced by the *evaluator* (3.45), and submitted to an *evaluation authority* (3.40)

3.44**evaluation technical report for composite evaluation****ETR for composite evaluation****ETR_COMP**

documentation intended to be used within the *composite evaluation* (3.23) approach and derived by the *base component* (3.12) *evaluator* (3.45) from the full *evaluation technical report (ETR)* (3.43) for the evaluated base component

Note 1 to entry: The ETR for composite evaluation belongs to the base component and its evaluation and is used for the evaluation of a composite product with such base component when using the composite evaluation approach.

Note 2 to entry: The ETR for composite evaluation related to a base component is set up to provide sufficient information for a composite evaluation of a composite product that integrates such already evaluated base component. It enables the composite product *evaluator* (3.45) and the respective composite product *evaluation authority* (3.40) to understand the attack paths and the tests that have been considered and performed for the base component and the effectiveness of the countermeasures implemented by the base component.

3.45**evaluator**

individual assigned to perform evaluations in accordance with a given evaluation standard and associated evaluation methodology

Note 1 to entry: An example of evaluation standards is the ISO/IEC 15408 series with the associated evaluation methodology given in ISO/IEC 18045.

[SOURCE: ISO/IEC 19896-1:2018, 3.5]

3.46**exact conformance****EC**

hierarchical relationship between a *protection profile (PP)* (3.68) or *PP Configuration* (3.69) and a *security target (ST)* (3.82) where all the requirements in the ST are drawn only from the PP/PP-Configuration

Note 1 to entry: An ST is allowed to claim exact conformance to one or more PPs but only to one PP-Configuration.

3.47**exploitable vulnerability**

weakness in the *target of evaluation (TOE)* (3.90) that can be used to violate the *security functional requirements (SFRs)* (3.78) in the *operational environment* (3.63) for the TOE

3.48**extended security requirement**

security requirement developed according to the rules in this document, but which are not listed in any part of the ISO/IEC 15408 series

Note 1 to entry: An extended security requirement preserves the form and syntax described in ISO/IEC 15408-2.

Note 2 to entry: Extended security requirements can be defined by authors of *security target (ST)* (3.82) or *protection profile (PP)* (3.68) or *PP-Module* (3.71).

3.49**external entity****user**

human technical system or one of its components interacting with the *target of evaluation (TOE)* (3.90) from outside of the TOE boundary

**3.50
family**

{taxonomy} set of components that shares a similar goal but differs in emphasis or rigour

**3.51
functional package**

named set of *security functional requirements* (3.78) that may be accompanied by a *security problem definition (SPD)* (3.80) and *security objectives* (3.79) derived from that SPD

**3.52
global assurance package**

assurance package (3.7) that applies to the entire *target of evaluation (TOE)* (3.90) in a *multi-assurance evaluation* (3.60)

Note 1 to entry: Global assurance package can contain extended assurance components.

**3.53
guidance documentation**

documentation that describes the delivery, preparation, operation, management and/or use of the *target of evaluation (TOE)* (3.90)

**3.54
implementation representation**

least abstract representation of the *TOE security functionality (TSF)* (3.92), specifically the one that is used to create the TSF itself without further design *refinement* (3.73)

Note 1 to entry: Source code that is then compiled or a hardware drawing that is used to build the actual hardware are examples of parts of an implementation representation.

**3.55
internally consistent, adj.**

no apparent contradictions exist between any aspects of an *entity* (3.36)

Note 1 to entry: In terms of documentation, this means that there can be no statements within the documentation that can be taken to contradict each other.

**3.56
interpretation**

clarification or amplification of a standard or an evaluation scheme requirement

**3.57
iteration**

use of the same component to express two or more distinct requirements

**3.58
layering**

design technique where separate groups of components are hierarchically organized to have separate responsibilities such that a group of components depends on groups of components below it in the hierarchy for services, and provides its services to the groups of components above it

**3.59
module**

architectural unit specified at a level suitable for implementation of the unit

Note 1 to entry: Properties related to division of a *target of evaluation (TOE)* (3.90) into modules are described in ISO/IEC 15408-3, in the ADV_TDS and ADV_INT families.

3.60**multi-assurance evaluation**

evaluation of a *target of evaluation (TOE)* (3.90) using a *PP-Configuration* (3.68) where each PP-Configuration component is associated with its own set of assurance requirements

Note 1 to entry: At least one of the PP-Configuration components contains a different set of assurance requirements to the others.

3.61**object**

entity (3.36) in the *target of evaluation (TOE)* (3.90) that contains or receives information, and upon which subjects perform operations

3.62**operation**

(on an object) specific type of *action* (3.1) performed by a subject on an object

3.63**operational environment**

environment in which the *target of evaluation (TOE)* (3.90) is operated, consisting of everything that is outside the TOE boundary

3.64**optional Security Functional Requirement****optional SFR**

security functional requirement (SFR) (3.78) in a *Protection Profile (PP)* (3.68), *functional package* (3.51), or *PP-Module* (3.71) that contributes to a stated aspect of the PP's security problem description but whose inclusion in a conformant PP's or *security target (ST's)* (3.82) list of SFRs is not mandatory

Note 1 to entry: An optional SFR can address appropriate *security problem definition (SPD)* (3.80) elements threat(s) and/or organizational security policies (OSPs) stated in the main body of the PP, functional package, or PP-Module, or reference associated SPD elements/objectives that themselves are optional (in that they are addressed solely by the optional SFR).

3.65**organizational security policy****OSP**

set of security rules, procedures, or guidelines for an organization

Note 1 to entry: A policy can pertain to a specific *operational environment* (3.63).

3.66**overall verdict**

statement issued by an *evaluator* (3.45) with respect to the result of an evaluation

Note 1 to entry: The statement can be expressed as "pass" or "fail".

3.67**potential vulnerability**

suspected, but not confirmed, weakness

Note 1 to entry: Suspicion is by virtue of a postulated attack path to violate the *security functional requirements (SFRs)* (3.78).

3.68**Protection Profile****PP**

implementation-independent statement of security needs for a *target of evaluation (TOE)* (3.90) type

3.69**Protection Profile Configuration****PP-Configuration**

implementation-independent statement of security needs for a *target of evaluation (TOE)* (3.90) type containing at least one *protection profile (PP)* (3.68) and an additional non-empty set of PPs and *PP-Modules* (3.71) (with the associated PP-Modules Bases)

3.70**Protection Profile Configuration component****PP-Configuration component**

Protection Profile (PP) (3.68) or *PP-Module* (3.71) included in a *PP-Configuration* (3.69)

3.71**Protection Profile module****PP-Module**

implementation-independent statement of security needs for a *target of evaluation (TOE)* (3.90) type complementary to one or more base *Protection Profiles* (3.68) and possibly some *base PP-Modules* (3.14)

3.72**Protection Profile Module Base****PP-Module Base**

set of either *PP-Modules* (3.71) or *Protection Profiles (PPs)* (3.68) or both, specified by a PP-Module as a basis for building a *PP-Configuration* (3.69)

Note 1 to entry: The notion of a PP-Module Base is iterative in that the base of a PP-Module can contain another PP-Module with its own base, with that base containing a PP-Module. However, this “chain” terminates with a PP-Module that has only PP(s) as its base.

3.73**refinement**

addition of details to a security component

3.74**residual vulnerability**

weakness that cannot be exploited in the *operational environment* (3.63) for the *target of evaluation (TOE)* (3.90), but that can be used to violate the *security functional requirements (SFRs)* (3.78) by an attacker with greater *attack potential* (3.8) than is anticipated in the operational environment for the TOE

3.75**role**

pre-defined set of rules establishing the allowed interactions between a user and the *target of evaluation (TOE)* (3.90)

3.76**security assurance requirement****SAR**

security requirement that refers to the conditions and processes for the development and delivery of the *target of evaluation (TOE)* (3.90), and the *actions* (3.1) required of *evaluators* (3.45) with respect to evidence produced from these conditions and processes

3.77**security attribute**

property of subjects, users, objects, information, sessions and/or resources that is used in defining the *security functional requirements (SFRs)* (3.78) and whose values are used in enforcing the SFRs

Note 1 to entry: Users can include external IT products.

3.78**security functional requirement****SFR**

security requirement, which contributes to fulfil the *target of evaluation (TOE)* (3.90) *security problem definition (SPD)* (3.80) as defined in a specific *security target (ST)* (3.82) or in a *protection profile (PP)* (3.68)

Note 1 to entry: A security functional requirement can be addressed directly as in the *direct rationale* (3.34) model, or indirectly, through the *security objectives* (3.79) for the TOE, as in the general model.

3.79**security objective**

statement of an intent to *counter* (3.28) identified threats and/or satisfy identified organization security policies and/or assumptions

3.80**security problem****security problem definition****SPD**

statement, which in a formal manner defines the nature and scope of the security that the *target of evaluation (TOE)* (3.90) is intended to address

Note 1 to entry: This statement consists of a combination of: threats to be countered by the TOE and its *operational environment* (3.63), the organizational security policies (OSPs) enforced by the TOE and its operational environment, and the assumptions that are upheld for the operational environment of the TOE.

Note 2 to entry: SPD-elements include threats, OSPs, and assumptions.

3.81**security requirement**

requirement, which is part of a *target of evaluation (TOE)* (3.90) security specification as defined in a specific *security target (ST)* (3.82) or in a *protection profile (PP)* (3.68) Note 1 to entry:

Requirements are stated in a language, i.e. form and syntax, specified in the ISO/IEC 15408 series.

3.82**Security Target****ST**

implementation-dependent statement of security requirements for a *target of evaluation (TOE)* (3.90) based on a *security problem definition* (3.80)

3.83**selection**

specification of one or more items from a list in a component

3.84**selection-based security functional requirement****selection-based SFR**

security functional requirement (SFR) (3.78) in a *Protection Profile (PP)* (3.78), *PP-Module* (3.71), or *functional package* (3.51) that contributes to a stated aspect of the PP's, PP-Module's or functional package's *security problem definition* (3.80) that is to be included in a conformant PP or ST if a selection choice identified in the PP/PP-Module/functional package indicates that it has an associated selection-based SFR

3.85**single-assurance evaluation**

evaluation of a *target of evaluation (TOE)* (3.90) using one set of assurance requirements

3.86**strict conformance****SC**

hierarchical relationship between a *protection profile (PP)* (3.68) and a *PP/security target (ST)* (3.82) where all the requirements in the PP also exist in the PP/ST

Note 1 to entry: This relation can be paraphrased as “the ST contains all statements that are in the PP but can contain more”. Strict conformance is expected to be used for stringent requirements that are to be adhered to in a single manner.

3.87**sub-TOE security functionality****sub-TSF**

combined functionality of all hardware, software, and firmware of a *target of evaluation (TOE)* (3.90) that is relied upon for the correct enforcement of the security functional requirements (SFRs) defined in one *PP-Configuration* (3.69) component

Note 1 to entry: This set of SFRs is closed by dependencies, objectives, and *security problem definition (SPD)* (3.80) elements in the PP-Configuration component.

Note 2 to entry: The notion of sub-TSF is applied in relationship with the specification and evaluation of PP-Configurations and conformant security targets (STs). It can be used in the single-assurance approach, but it has to be used in the multi-assurance approach: sub-TSFs have to be defined in a multi-assurance PP-Configuration and in conformant multi-assurance STs.

Note 3 to entry: Each sub-TSF is associated with its own set of security assurance requirements (SARs) in a multi-assurance PP-Configuration/ST. In the rest of the document, a set of SARs can be an *assurance package* (3.7).

Note 4 to entry: A sub-TSF has the characteristics of a TSF.

3.88**subject**

entity (3.36) in the *target of evaluation (TOE)* (3.90) that performs operations on objects

3.89**tailoring**

addition of one or more functional requirements to a *functional package* (3.51), and/or the addition of one or more selections to a *security functional requirement (SFR)* (3.78) in a functional package

Note 1 to entry: Such tailoring is considered only in the context of one package and is not considered in the context with other packages, *protection profiles (PPs)* (3.68), or PP-Modules.

Note 2 to entry: The selections in the SFR can be replaced by the additional selections.

Note 3 to entry: Selections can only be added for packages claimed by PPs or PP-Modules. STs cannot claim package-name tailored conformance to the package.

3.90**target of evaluation****TOE**

set of software, firmware and/or hardware possibly accompanied by guidance, which is the subject of an evaluation

3.91**threat agent**

entity (3.36) that has potential to exercise adverse *actions* (3.3) on *assets* (3.4) protected by the *target of evaluation (TOE)* (3.90)

3.92**TOE security functionality****TSF**

combined functionality of all hardware, software, and firmware of a *target of evaluation (TOE)* (3.90) that is relied upon for the correct enforcement of the *security functional requirements (SFRs)* (3.78)

3.93**TOE type**

set of characteristics common to a group of *target of evaluations (TOEs)* (3.90)

Note 1 to entry: The TOE type can be more explicitly defined in a *protection profile (PP)* (3.68).

3.94**translation**

process of describing security requirements in a standardized language

Note 1 to entry: Use of the term translation in this context is not literal and does not imply that every *security functional requirement (SFR)* (3.78) expressed in standardized language can also be translated back to the *security objectives* (3.79).

3.95**vulnerability**

weakness in the *target of evaluation (TOE)* (3.90) that can be used to violate the *security functional requirements (SFRs)* (3.78) in some environment

4 Abbreviated terms

AP	assurance package
API	application programming interface
CAP	composition assurance package
CD	compact disk
CM	configuration management
COMP	composite product assurance package
DAC	discretionary access control
DC	demonstrable conformance
DPA	differential power analysis
DRBG	deterministic random bit generator
EA	evaluation activity
EAL	evaluation assurance level
EC	exact conformance
EM	evaluation method
EMS	electromagnetic spectrum
ETR	evaluation technical report
GAP	global assurance package

E DIN EN ISO/IEC 15408-1:2024-01
ISO/IEC 15408-1:2022(E)

- Entwurf -

GB	gigabyte
GHz	gigahertz
GUI	graphical user interface
HSM	hardware security module
HTTPS	hypertext transfer protocol secure
IC	integrated circuit
IOCTL	input output control
IP	internet protocol
IPsec	IP security (protocol)
IT	information technology
LDAP	lightweight directory access protocol
MAC	mandatory access control
MB	megabyte
MBps	megabytes per second
OR	observation report
OS	operating system
OSP	organizational security policy
OTP	one-time programmable
PC	personal computer
PCI	peripheral component interconnect
PKI	public key infrastructure
PP	protection profile
PPA	protection profile assurance package
RAM	random access memory
RBG	random bit generator
RNG	random number generator
RPC	remote procedure call
SAR	security assurance requirement
SC	strict conformance
SFP	security function policies
SFR	security functional requirement

SPA	simple power analysis
SPD	security problem definition
SSH	secure shell
ST	security target
STA	security target assurance package
TCP	transmission control protocol
TLS	transport layer security
TOE	target of evaluation
TSF	TOE security functionality
TSFI	TSF interface
USB	universal serial bus
VPN	virtual private network

5 Overview

5.1 General

This clause introduces the main concepts of the ISO/IEC 15408 series. It identifies the concept of the Target of Evaluation (TOE), the target audience of the ISO/IEC 15408 series, and the approach taken to present the material in the ISO/IEC 15408 series.

5.2 ISO/IEC 15408 series description

5.2.1 General

The ISO/IEC 15408 series is presented as a set of distinct but related parts as identified below:

- a) **ISO/IEC 15408-1, Introduction, and general model** is the introduction to the ISO/IEC 15408 series. It defines the general concepts and principles of IT security evaluation and presents a general model of evaluation;
- b) **ISO/IEC 15408-2, Security functional components** establishes a set of functional components that serve as standard templates upon which security functional requirements (SFRs) for TOEs are based. ISO/IEC 15408-2 catalogues the set of security functional components and organizes them in families and classes;
- c) **ISO/IEC 15408-3, Security assurance components** establishes a set of assurance components that serve as standard templates upon which security assurance requirements for TOEs are based. ISO/IEC 15408-3 catalogues the set of security assurance components and organizes them into families and classes. ISO/IEC 15408-3 also defines evaluation criteria for PPs, STs and TOEs;
- d) **ISO/IEC 15408-4, Framework for the specification of evaluation methods and activities** provides a standardized framework for the specification of evaluation methods and activities that may be included in PPs, STs and any documents supporting them, to be used by evaluators in support of evaluations using the model described in the other parts of the ISO/IEC 15408 series. ISO/IEC 18045 is fundamental to ISO/IEC 15408-4;

- e) **ISO/IEC 15408-5, Pre-defined packages of security requirements** provides packages of security assurance and SFRs that have been identified as useful in support of common usage by stakeholders. Examples of provided packages include the evaluation assurance levels (EAL) and the composed assurance packages (CAPs).

In the application of the ISO/IEC 15408 series, a justification shall be provided whenever the recommended option is not chosen.

In support of the ISO/IEC 15408 series, other documents have been published. The Bibliography provides a list of supportive documents.

NOTE ISO/IEC 18045 provides the baseline methodology for IT security evaluations performed in accordance with the ISO/IEC 15408 series.

5.2.2 Audience

5.2.2.1 General

There are five main groups with a general interest in evaluation of the security properties of TOEs: consumers (risk owners), developers, technical working groups, evaluators and others. The information presented in the ISO/IEC 15408 series has been structured to support the needs of all of these groups which are considered to be the principal users of the ISO/IEC 15408 series. The groups can benefit from the criteria as explained in 5.2.2.2 through 5.2.2.6.

5.2.2.2 Consumers (Risk owners)

The ISO/IEC 15408 series is written to ensure that evaluation fulfils the needs of risk owners as this is the fundamental purpose and justification for the evaluation process.

Risk owners can use the results of evaluations to help decide whether a TOE fulfils their security needs. These security needs are typically identified as a result of both risk analysis and policy direction. Risk owners can also use the evaluation results to compare different TOEs.

The ISO/IEC 15408 series gives risk owners, especially those in consumer groups and communities of interest, an implementation-independent structure, termed the PP, in which to express their security requirements in an unambiguous manner.

5.2.2.3 Developers

The ISO/IEC 15408 series is intended to support IT product developers in preparing for and assisting in the evaluation of their TOEs and in identifying security requirements to be satisfied by those TOEs. These requirements are contained in an implementation-dependent construct termed the Security Target (ST). This ST may conform to one or more PPs to show that the TOE meets the security requirements from consumers as laid down in those PPs.

The ISO/IEC 15408 series can then be used to determine the responsibilities and actions to provide evidence that is necessary to support the evaluation of the TOE against these requirements. It also defines the content and presentation of that evidence.

5.2.2.4 Technical working groups

The ISO/IEC 15408 series is intended to support technical working groups in preparing and developing PPs, PP-Modules, PP-Configurations, packages and supporting documents or guidance. Technical working groups can be composed of stakeholders including consumers (risk owners), developers, evaluators, and academics.

5.2.2.5 Evaluators

The ISO/IEC 15408 series contains criteria to be used by evaluators when forming judgements about the conformance of TOEs, STs, PPs and PP-Configurations to their security requirements. The ISO/IEC 15408 series describes the general set of actions the evaluator is to carry out.

NOTE The ISO/IEC 15408 series does not specify procedures to be followed in carrying out those actions. More information on these procedures can be found in Clause 13.

5.2.2.6 Others

While the ISO/IEC 15408 series is oriented towards specification and evaluation of the IT security properties of TOEs, it can also be useful as reference material to all parties with an interest in or responsibility for IT security. Some of the additional interest groups that can benefit from information contained in the ISO/IEC 15408 series are:

- system custodians and system security officers responsible for determining and meeting organizational IT security policies and requirements;
- auditors, both internal and external, responsible for assessing the adequacy of the security of an IT solution (which can consist of or contain a TOE);
- security architects and designers responsible for the specification of security properties of IT products;
- accreditors responsible for accepting an IT solution for use within a particular environment;
- sponsors of evaluation responsible for requesting and supporting an evaluation;
- evaluation authorities responsible for the management and oversight of IT security evaluation programs;
- academia who perform research on the topic of IT security.

Table 1 presents the interest of each part of ISO/IEC 15408 series to each of the audience groupings.

Table 1 — Road map to the “Evaluation criteria for IT security”

ISO/IEC 15408 parts	Consumers (Risk owners)	Developers	Technical working groups	Evaluators	Others
Part 1	Should use for background information, reference purposes, and for guidance on the structure of PPs, PP-Modules, PP-Configurations, STs and composition. Shall use for the development of security specifications and security problem definitions (SPDs) for TOEs.	Should use for background information, reference purposes, and for guidance on the structure of PPs, PP-Modules, PP-Configurations, STs and composition. Shall use for the development of security specifications for TOEs.	Should use for background information, reference purposes, and for guidance on the structure of PPs, PP-Modules, PP-Configurations, STs and composition. Shall use for the development of security specifications for packages, PPs, PP-Modules and PP-Configurations.	Should use for background information, reference purposes, and for guidance on the structure of PPs, PP-Modules, PP-Configurations, STs and composition. Shall use when evaluating PPs, PP-Configurations and STs.	May use for background information, reference purposes, and for guidance on the structure of PPs, PP-Modules, PP-Configurations, STs and composition.

Table 1 (continued)

ISO/IEC 15408 parts	Consumers (Risk owners)	Developers	Technical working groups	Evaluators	Others
Part 2	Shall use for guidance and reference when formulating statements of security functional components for their risk-environment.	Shall use for reference when interpreting statements of security functional components in packages, PPs and PP-Modules. Shall use when developing STs. May use when formulating security functionality for IT products.	Shall use for reference when formulating statements of security functional components in packages, PPs and PP-Modules.	Shall use for reference when evaluating security functional components given in packages, PPs and PP-Modules or security functional requirements (SFRs) in STs.	May use for reference when reviewing security functional components given in packages, PPs and PP-Modules or security functional requirements (SFRs) in STs.
Part 3	Shall use for guidance and reference when determining the security assurance required for their risk-environment.	Shall use for reference when interpreting statements of security assurance components in packages, PPs, PP-Modules and PP-Configurations. Shall use when developing STs May use when formulating or improving development processes.	Shall use for reference when formulating statements of security assurance components in packages, PPs, PP-Modules and PP-Configurations.	Shall use for reference when evaluating security functional components given in packages, PPs, PP-Modules and PP-Configurations or security assurance requirements in STs.	May use for reference when reviewing security functional components given in packages, PPs, PP-Modules and PP-Configurations or security assurance requirements in STs.
Part 4	Should use for reference and background information in the structure of evaluation method(s) and/or activities.	Should use for reference purposes and for guidance in the structure of evaluation method(s) and/or activities.	Should use for reference purposes and for guidance in the structure of evaluation methods and activities.	Should use for reference purposes and for guidance in the structure of evaluation methods and activities. Should use when formulating specific evaluation methods and activities.	May use for reference purposes and for guidance in the structure of evaluation methods and activities.
Part 5	Should use for reference in determining the contents of any claimed pre-defined packages of security requirements.	Shall use when developing STs claiming conformance to pre-defined packages of security requirements. Shall use for reference when preparing a TOE for evaluation conformant to pre-defined packages of security requirements.	Shall use when developing PPs, PP-Modules and PP-Configurations claiming conformance to pre-defined packages of security requirements.	Shall use for reference when evaluating PPs, PP-Modules and PP-Configurations or STs claiming conformance to pre-defined packages of security requirements.	May use for reference in determining the contents of any claimed pre-defined packages of security requirements.

5.3 Target of evaluation (TOE)

5.3.1 General

The ISO/IEC 15408 series is flexible in what is evaluated and is therefore not tied to the boundaries of IT products as commonly understood. Therefore, in the context of evaluation the ISO/IEC 15408 series uses the term “TOE” (Target of Evaluation).

While there are cases where a TOE consists of a complete IT product, this need not be the case. The TOE may be an IT product, a part of an IT product, a set of IT products, a unique technology that can never be made into a product, or a combination of these.

As far as the ISO/IEC 15408 series is concerned, the precise relation between the TOE and any IT products is only important in one aspect: the evaluation of a TOE containing only part of an IT product should not be misrepresented as the evaluation of the entire IT product.

EXAMPLE Examples of TOEs include devices characterized by few interfaces, reduced attack surface, and a well-known supply chain:

- a network device;
- a software application;
- an operating system;
- a virtualization system;
- an integrated circuit;
- the cryptographic co-processor of an integrated circuit;
- an application for a mobile device;
- a database application excluding the remote client software normally associated with that database application.

TOEs can also be more complex, characterized by a large interface/large interfaces and/or number of components, multiple manufacturing/integration phases, field upgradeable products such as:

- a Local Area Network (LAN) including all terminals, servers, network equipment and software;
- a mobile device;
- gateways and hubs;
- a software application in combination with an operating system;
- a multi-function device, such as a multi-function printer;
- a Hardware Security Module (HSM).

5.3.2 TOE boundaries

The concept of a TOE boundary is fundamental to the specification of the ST.

A TOE may be a complete IT product (or products), a part of an IT product, or made up of various components. The ST shall clearly outline the physical and logical scope of the TOE as it is delivered to the customer.

Any parts of an IT product that are not within the TOE boundary are outside the scope of the evaluation and are called *non-TOE parts of the IT product*.

5.3.3 Different representations of the TOE

In the ISO/IEC 15408 series, a TOE can occur in several representations in relationship with the assurance criteria:

NOTE These assurance criteria include testing (ATE) and vulnerability analysis (AVA), which require TOE samples, some design (ADV_IMP), which require an implementation representation, e.g. source code, and lifecycle (ALC), which requires the TOE's configuration list.

EXAMPLE TOE representations for a software TOE:

- a list of files in a configuration management system;
- a single master copy that has just been compiled;
- the source code for a specific version of an open-source distribution;
- a box containing physical media and a manual, ready to be shipped to a customer;
- a binary file available for secure download;
- an installed and operational version.

TOE representations for a hardware TOE:

- integrated circuit layout;
- memory mappings;
- wafers;
- modules.

All of these are considered to be a TOE and wherever the term “TOE” is used in the ISO/IEC 15408 series, the context determines the representation that is described.

5.3.4 Different configurations of the TOE

In general, IT products can be configured in many ways with different options enabled or disabled. During an evaluation performed in accordance with the ISO/IEC 15408 series, it will be determined whether a TOE meets certain requirements. It is often the case that the guidance part of the TOE constrains the possible configurations of the TOE, i.e. the guidance for the TOE can be different from the general guidance of the IT product.

EXAMPLE An operating system IT product: This product can be configured in many ways including, e.g. the types of users, number of users, types of external connections allowed/disallowed, options enabled/disabled.

In general, if an IT product contains or is a TOE then the configuration of the product will need to be much more tightly controlled, since some configuration options can lead to a TOE not meeting the requirements.

For this reason, there would be an expected difference between the guidance documentation for the general IT product, that can allow many configurations; and the guidance documentation for the TOE, that may allow only one or only a set of configurations that do not differ in security-relevant ways.

If the guidance documentation for the TOE allows more than one configuration, these configurations are collectively called “the TOE” and each configuration shall meet the requirements levied on the TOE.

5.3.5 Operational environment of the TOE

Everything outside the TOE boundary belongs to the TOE operational environment. In the case where the TOE is part of an IT product the IT product can have non-TOE parts. Such non-TOE parts are also part of the operational environment of the TOE.

The ST shall describe assumptions and define security objectives for the operational environment which together with the security functionality provided by the TOE itself are necessary to mitigate the threats, and to enforce organizational security policies (OSPs).

The security objectives for the operational environment may support the TOE security functionality.

The ST shall formulate clear requirements for the TOE environment in order to provide the user with sufficient information to use the evaluated TOE properly.

EXAMPLE Secure key generation and injection premises and processes is an example of a security objective for the operational environment which supports the TOE cryptographic services specified using FCS components from ISO/IEC 15408-2.

5.4 Presentation of material in this document

The general model is presented in Clause 6, which explains the concepts relating to the evaluation of the security functionality of IT products, the definition of the security problem and the specification of security requirements addressing the security problem. Concepts relating to the specification of security requirements, packages, PPs, PP-Modules and PP-Configurations, that relate to the needs of risk-owners with similar security problems are introduced.

The means of specifying security requirements and the completion of security components provided in ISO/IEC 15408-2 and ISO/IEC 15408-3 are explained in Clauses 7 and 8.

The requirements and recommendations for the core constructs of packages, PPs, PP-Modules, PP-Configurations and ST s, are explained in Clauses 9, 10, 11 and 11.3.3.

The requirements and recommendations for evaluation and evaluation results for TOEs, STs, PPs and PP-Configurations are found in Clause 13.

Finally, the topic of composing assurance is found in Clause 14.

6 General model

6.1 Background

This clause presents the general concepts used throughout the ISO/IEC 15408 series, including the context in which the concepts are to be used and the approach for applying the concepts. ISO/IEC 15408-2, ISO/IEC 15408-3, ISO/IEC 15408-4, and ISO/IEC 15408-5 expand on the use of these concepts and assume that the approach described here is used. Further, for users of the ISO/IEC 15408 series who intend to perform evaluation activities, ISO/IEC 18045 is applicable.

The ISO/IEC 15408 series discusses security using a set of security concepts and terminology. An understanding of these concepts and the terminology is a prerequisite to the effective use of the ISO/IEC 15408 series. However, the concepts themselves are not intended to restrict the class of IT security problems to which the ISO/IEC 15408 series is applicable. Clause 6 assumes that the reader has knowledge of IT security and it is not intended to act as a tutorial in this area.

6.2 Assets and security controls

Security is concerned with the protection of assets within the operational environment.

EXAMPLE 1 An example of an asset is the contents of a file or a server.

Examples of operational environments in the context of such an asset are:

- a data centre where the server is installed;
- a computer network connected to the Internet which connects the server to the world;
- a LAN which connects the server to other servers and/or workstations;

- the every-day environment of a user who uses information from the server or a particular file;
- a general office environment which provides communication facilities to the server and/or a particular file.

Many assets are in the form of information that is stored, processed, and transmitted by IT products to meet requirements laid down by owners of the information. Information owners can require that availability, dissemination, and modification of any such information are strictly controlled and that the assets are protected from threats by security controls implemented in the operational environment. Figure 1 illustrates these high-level concepts and relationships.

NOTE ISO/IEC 27001 provides requirements for establishing, implementing, maintaining and continually improving an information security management system including the specification of controls.

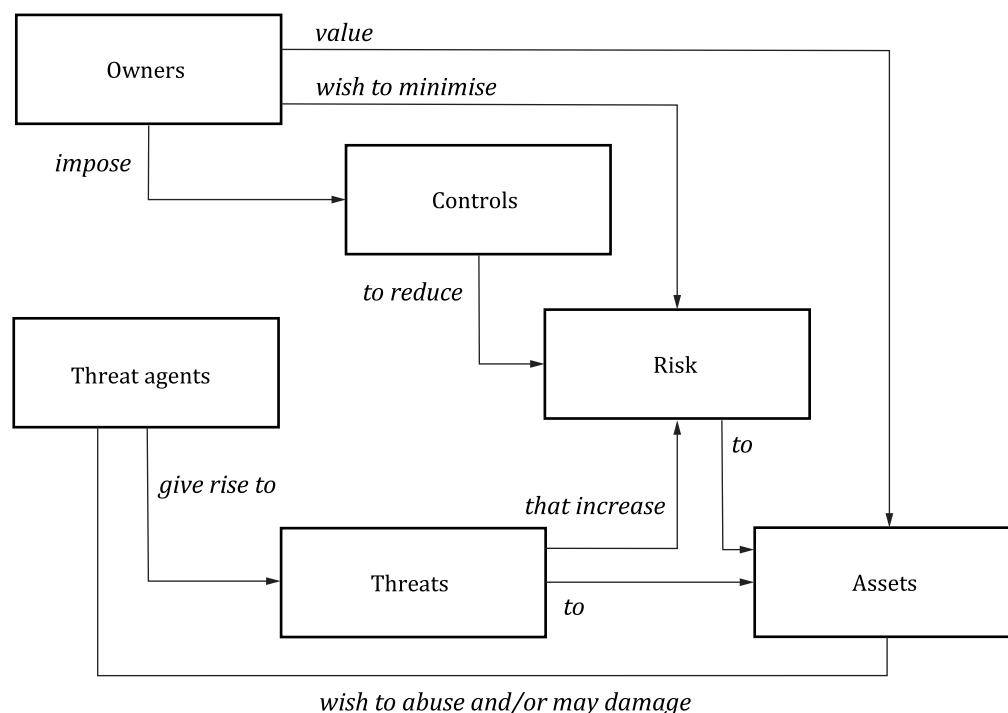


Figure 1 — Security concepts and relationships

Safeguarding assets of interest is the responsibility of owners who place value on those assets. Actual or presumed threat agents can also place value on the assets and seek to abuse assets in a manner contrary to the interests of the owner.

EXAMPLE 2 Examples of threat agents include hackers, malicious users, non-malicious users, who sometimes make errors, computer processes and accidents.

The owners of the assets can perceive such threats as a potential source of impairment of the assets, leading to a decrease of their value. Security-specific impairment commonly includes, but is not limited to, loss of asset confidentiality, loss of asset integrity and loss of asset availability.

These threats therefore give rise to risks to the assets, based on the likelihood of a threat being realized and the impact on the assets when that threat is realized. Subsequently controls are imposed to reduce the risks to assets. These controls can consist of IT-related controls (e.g. firewalls and smart cards) and non-IT controls (e.g. guards and procedures). See also ISO/IEC 27001 and ISO/IEC 27002 for a more general discussion on security controls and how to implement and manage them.

Owners of assets can be held responsible for those assets and therefore should be able to defend the decision to accept the risks of exposing the assets to the threats.

Two important elements in defending this decision are being able to demonstrate that:

- the controls are sufficient: if the applied controls do what they claim to do, the threats to the assets are countered;
- the controls are correct: if the applied controls do what they claim to do.

Many owners of assets lack the knowledge, expertise, or resources necessary to judge sufficiency and correctness of the security controls, and they do not always wish to rely solely on the assertions of the developers of the security controls. These consumers can therefore choose to increase their confidence in the sufficiency and correctness of some or all of their security controls by ordering an evaluation of these security controls.

Figure 2 describes the evaluation concepts and relationships discussed in this clause.

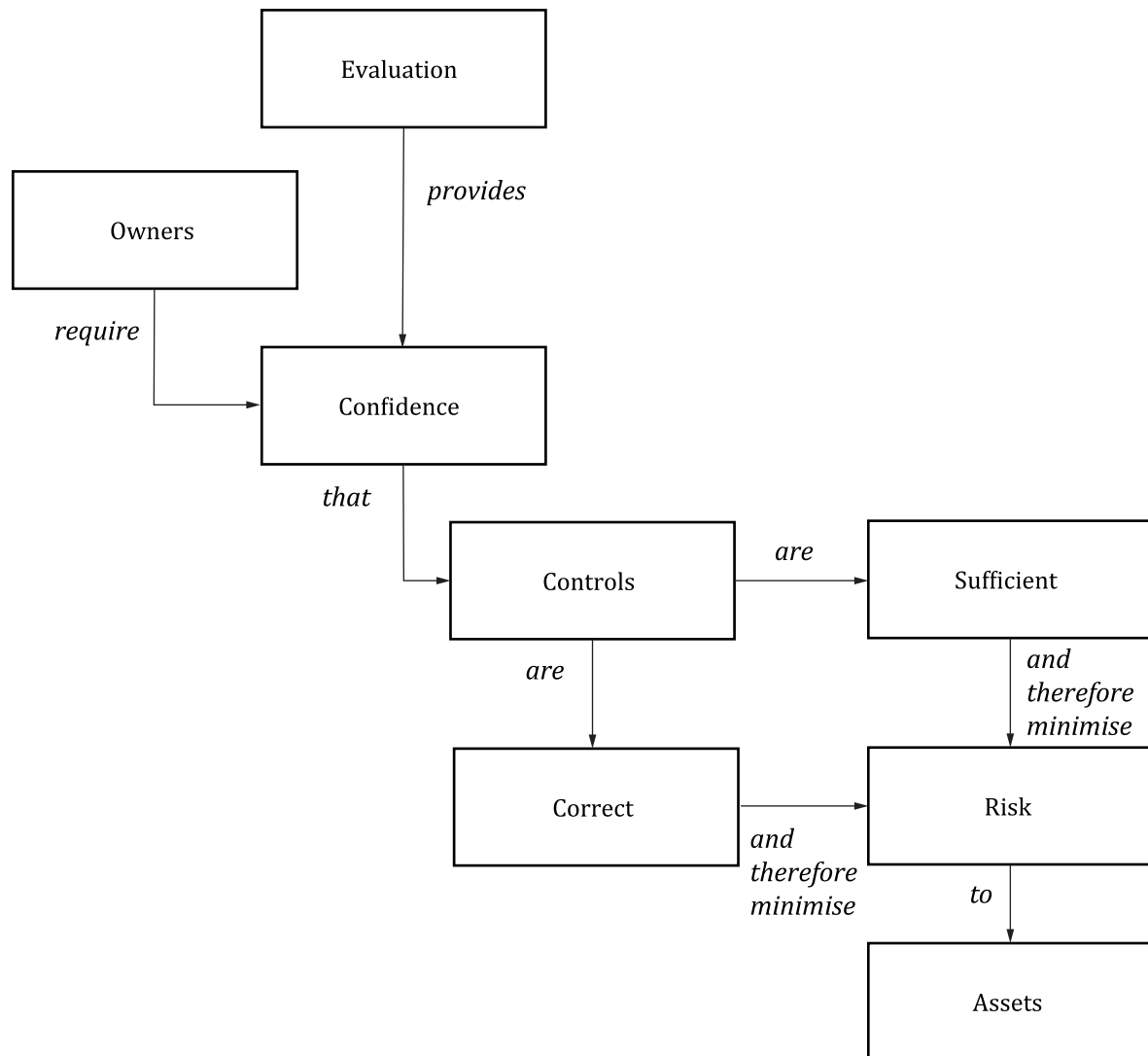


Figure 2 — Evaluation concepts and relationships

In an evaluation, the sufficiency of the security controls is analysed through a construct called the security target (ST).

6.3 Core constructs of the paradigm of the ISO/IEC 15408 series

6.3.1 General

The ISO/IEC 15408 series defines a flexible framework for the evaluation of IT products.

To allow consumer groups and technical communities to express their security needs, and to facilitate authoring appropriate documents that express these needs, five constructs are provided in the paradigm: package, PP, PP-Module, PP-Configuration and ST.

As an evaluation can need to meet varying assurance needs of consumers (risk owners), the ISO/IEC 15408 series provides different tools including well-formed security assurance components (ISO/IEC 15408-3) as well as a mechanism to define extended assurance components (ISO/IEC 15408-1).

Users of ISO/IEC 15408 series may also choose from pre-defined packages including those for EALs (based on ISO/IEC 15408-5), or from a framework for defining evaluation methods and activities (ISO/IEC 15408-4), and the associated evaluation methodology (based on ISO/IEC 18045).

6.3.2 Conformance types

Three different types of conformance to PPs and PP-Configurations have been defined to meet the needs of consumers (risk owners). These are exact, strict and demonstrable conformance. They are described in detail in Annex E.

PPs, PP-Modules and PP-Configurations shall specify a conformance type.

STs claim conformance to PPs and PP-Configurations according to their conformance types. PPs can also claim conformance to other PPs according to their conformance type.

Conformance types, conformance claims, and relationships of conformance types of PPs, PP-Modules and PP-Configurations are described in Annex E and shall be used in conjunction with the clauses of this document.

6.3.3 Communicating security requirements

6.3.3.1 Packages

Packages describe a set of related security requirements that are frequently used together. Packages are often designed to be re-used bringing some comparability between those PPs, PP-Modules and STs that use them.

Security functional packages may be used to define security protocols, or other security functional concepts.

Security assurance packages may be used to define the conditions and processes such as specification, design, development, testing and delivery under which the TOE is developed and configured.

Core requirements for packages can be found in Clause 9. Annex A provides additional information and requirements about packages that shall be used in conjunction with the clauses of this document.

ISO/IEC 15408-3 provides evaluation criteria, and specific requirements for STs, PPs and PP-Modules undergoing evaluation that may use packages and ISO/IEC 15408-5 provides some pre-defined assurance packages that may be used by PP, PP-Module, PP-Configuration and ST authors.

6.3.3.2 Protection Profiles (PPs)

PPs describe a TOE type and the security assurance requirements (SARs) and security functional requirements (SFRs) expected to be provided for that type of TOE.

PPs based on other PPs may be used to further refine a TOE type.

PPs may take either a standard or a direct rationale approach.

Core requirements for PPs can be found in Clause 10 and further information is found in Annex B that shall be used in conjunction with the clauses of this document.

ISO/IEC 15408-3 provides evaluation criteria for PPs.

6.3.3.3 PP-Modules and PP-Configurations

PP-Configurations build upon the concepts of PP and PP-Module.

A PP-Module may be used to refine the generic TOE type of a base PP, or to add security requirements for particular technologies which may be optionally associated with the TOE type defined in the base PPs. PP-Modules may also be based on other PP-Modules. Further, PP-Configurations consist of a TOE type and set of requirements specified in several PPs and possibly PP-Modules (these are the PP-Configuration components).

This concept is described in more detail in Clause 11 and Annex C.

EXAMPLE A PP-Module describes the SFRs for Bluetooth technology. Another PP-Module describes the SFRs for wireless LAN clients. Using a PP-Configuration, the SFRs for each of these technologies can be combined with PPs describing a TOE type, such as an operating system PP, or a mobile device PP. In this context the PP describing the TOE type is referred to as a base PP. A PP-Configuration describes which PPs and PP-Modules are combined to present a specification that includes all the requirements given in the appropriate PPs and PP-Modules.

In this example it would be possible to specify six PP-Configurations:

- a) operating system with Bluetooth,
- b) operating system with Wireless client,
- c) operating system with Bluetooth and Wireless client,
- d) mobile device with Bluetooth,
- e) mobile device with Wireless client,
- f) mobile device with Bluetooth and Wireless client.

6.3.3.4 Security Targets (STs)

6.3.3.4.1 General

The clause presents a simplified view of the ST construct. A more detailed and complete description of the ST concept and the content requirements can be found in 11.3.3 and Annex D which shall be used in conjunction with the clauses of this document.

ISO/IEC 15408-3 provides evaluation criteria and specific requirements for STs undergoing evaluation.

6.3.3.4.2 Purpose of a ST

The ST is a key document that begins with determining the security problem definition (SPD) for the TOE. This includes specifying the assets to be protected and the threats to those assets. The ST then considers any relevant assumptions and describes the security controls that need to be in place in order to demonstrate that these threats are countered. If the security controls do what they claim to do, the threats are countered.

The two groups of security controls are:

- a) the security objectives for the TOE: these describe the security control(s) for which correctness will be determined in the evaluation;

- b) the security objectives for the operational environment: these describe the security controls for which correctness will not be determined in the evaluation.

The reasons for this division are:

- the ISO/IEC 15408 series is suitable for assessing the correctness of IT development and production environments and product life cycle management. Security controls required from the operational environment are out of the scope of the evaluation according to the ISO/IEC 15408 series.
- assessing the correctness of security controls costs time and money, possibly making it infeasible to assess the correctness of all security controls.
- the correctness of some security controls can already have been assessed in another evaluation. It is therefore not cost-effective to assess this correctness again.

The ST further details the security objectives for the TOE by means of specifying SFRs. These SFRs shall be formulated in a standardized language, described in ISO/IEC 15408-2, to ensure precision and facilitate comparability.

In summary, the ST demonstrates that:

- the SFRs meet the security objectives for the TOE;
- the security objectives for the TOE and the security objectives for the operational environment address the SPD and, in particular, counter the threats;
- and therefore, the SFRs and the security objectives for the operational environment address the SPD and, in particular, counter the threats.

From this it follows that a correct TOE, i.e. a TOE that meets the SFRs in combination with a correct operational environment that meets the security objectives for the operational environment, will counter the threats. In 6.3.3.4.3 and 6.3.3.4.4 correctness of the TOE and correctness of the operational environment are discussed separately.

In some cases, defining a ST that omits security objectives for the TOE and directly maps the SFRs to the SPD is appropriate. This is a “Direct Rationale” ST, and is explained in detail in 11.3.3 and Annex D.

A ST may be defined as standalone document for a specific TOE or may conform with a pre-existent PP-Configuration or one or several pre-existent PP(s). These documents allow for generic definitions of a TOE type to be made allowing for comparability in evaluation results between TOEs as well as efficiencies to be made.

Packages, PPs, PP-Modules and PP-Configurations that may contribute to the specification of a ST are introduced in 6.3.3.1, 6.3.3.2 and 6.3.3.3.

6.3.3.4.3 Correctness of the TOE

A TOE can be incorrectly designed and implemented and therefore contain errors that lead to vulnerabilities. By exploiting these vulnerabilities, attackers can be able to damage and/or abuse the assets.

These vulnerabilities can arise from, e.g. poor design, accidental errors made during development, intentional addition of malicious code, poor configuration management.

To determine the correctness of the TOE, various activities may be performed such as:

- testing the TOE;
- examining various design representations of the TOE;
- examining the physical security of the development environment of the TOE.

The ST provides a structured description of these activities to determine correctness in the form of SARs. These SARs shall be formulated in a standardized language described in ISO/IEC 15408-3 to ensure precision and facilitate comparability.

If the SARs are met, there exists assurance in the correctness of the TOE and the TOE is therefore less likely to contain vulnerabilities that can be exploited by attackers. The amount of assurance that exists in the correctness of the TOE is determined by the SARs themselves.

6.3.3.4.4 Correctness of the operational environment

The operational environment can also be incorrectly specified or implemented and therefore contain errors that lead to vulnerabilities. By exploiting these vulnerabilities, attackers can damage and/or abuse the assets.

However, in the ISO/IEC 15408 series, no assurance is obtained regarding the correctness of the operational environment, i.e. the operational environment is not evaluated.

As far as the evaluation is concerned, the operational environment is assumed to be a correct instantiation of the security objectives for the operational environment.

This does not preclude a consumer of the TOE from using other methods to determine the correctness of this operational environment.

EXAMPLE 1 If, for an Operating System TOE, the security objectives for the operational environment state “The operational environment ensure that entities from an untrusted network can only access the TOE using the FTP protocol”, the consumer can select an evaluated firewall, and configure it to only allow FTP access to the TOE.

EXAMPLE 2 If the security objectives for the operational environment state: “The operational environment shall ensure that all administrative personnel do not behave maliciously”, the consumer can adapt their contracts with administrative personnel to include punitive sanctions for malicious behaviour, but this determination is not part of an evaluation using the ISO/IEC 15408 series as a basis.

NOTE The Internet is an example of an untrusted network.

6.3.4 Meeting the needs of consumers (risk owners)

6.3.4.1 General

Consumers (risk owners) can have different approaches for obtaining the assurance that the products they use to address the SPD. 6.3.4.2 and 6.3.4.3 introduce these approaches. Moreover, ISO/IEC 15408-4 provides methods to define specific evaluation activities for the assurance requirements.

6.3.4.2 Single assurance evaluation

Single assurance evaluation is the type of evaluation that has been specified in previous revisions of the ISO/IEC 15408 series. In single assurance evaluation a single set of SARs are applied to the entire TOE.

The single assurance evaluation paradigm:

- requires that the entire TOE has been subject to the same SARs;
- is used when a single set of SARs are commensurate with the security needs for the TOE.

A single assurance evaluation is based on an ST that may claim conformance with PP(s), or a PP-Configuration but is reliant on all claimed PPs or PP-Configuration components specifying identical sets or supersets of security assurance components. An evaluation based on an ST that does not make any conformance claim with PPs or a PP-Configuration is by its nature a single-assurance evaluation.

6.3.4.3 Multi-assurance evaluation

The multi-assurance evaluation paradigm consists in applying different assurance requirements to different parts of the TSF (sub-TSFs), while enforcing a global set of SARs for the entire TOE.

The multi-assurance evaluation paradigm:

- addresses heterogeneous IT products where different security needs require a different assurance within a single evaluation;
- ensures that the multiple assurance requirements are sound with regard to the security needs for the IT product.

Technically, a multi-assurance evaluation is driven by a ST that conforms with one (and only one) multi-assurance PP-Configuration. The multi-assurance PP-Configuration ensures that applying different assurance requirements to different parts of the TSF is consistent with their security needs. In this evaluation approach, each sub-TSF enforces some security functionality, e.g. an authentication protocol, a firewall policy, the boot process, encryption/decryption operations, and in some cases, the sub-TSF may be associated with a subset of TOE components, for instance a TPM, a cryptographic library or a card reader.

The multi-assurance paradigm is relevant, in particular, in the following situations:

- a product where some security functionality requires a higher assurance than the rest, e.g. a key storage and processing unit, a secure boot module;
- a product where some parts of the security functionality do not require the same high evaluation assurance as other more exposed parts, for instance an internet gateway with support for personal area network protocols;
- a family of products where some security functionality is shared across all the products with the same assurance, and some security functionality is implemented in different ways for different use cases, for instance in a tamper-resistant module or in a software module or through COTS, requiring a different assurance;

An example is a family of biometric authentication devices, with either match-on-device or match-on-SE, or both. This can give rise to a PP for the authentication device excluding the matching function, and two PP-Modules for the different types of matching functions, each with a dedicated set of assurance requirements. Three PP-Configurations can be defined for the device: PP with each of the PP-Modules, PP with both PP-Modules. A similar situation arises, for instance, for a family of mobile applications which uses either software crypto library secured by with-box techniques or a hardware-based crypto library, or for a family of payment terminals with either IC and/or magstripe readers;

Multi-assurance is also relevant for products claiming conformance to different PPs with different assurance packages: by defining and evaluating a PP-Configuration, the multi-assurance paradigm allows better control over possible inconsistencies between these PPs. The evaluation of electronic passports implementing both Basic Access Control and Extended Access Control constitutes a typical example, as these access control mechanisms are subject to different security problems and assurance requirements.

7 Specifying security requirements

7.1 Security problem definition (SPD)

7.1.1 General

The SPD defines the security problem that is to be addressed and may appear in PPs, PP-Modules and STs. The SPD is, as far as the ISO/IEC 15408 series is concerned, axiomatic, i.e. the process of deriving the SPD falls outside the scope of the ISO/IEC 15408 series.

SPD elements can be associated with configurations or requirements that are optional for the given TOE type, for example, in a case where the TOE is distributed, or where optional functional requirements (as outlined in 7.3.2.6) are specified. This is allowed as long as the optional nature of the SPD elements (and any associated objectives and functional requirements) are identified as specified in this document.

NOTE 1 The usefulness of the results of an evaluation strongly depends on the quality of the SPD. It is therefore often worthwhile to spend significant resources and use well-defined processes and analyses to derive a good SPD. ISO/IEC 15446 presents guidance in regard to deriving an SPD.

NOTE 2 According to ISO/IEC 15408-3, it is not mandatory to have statements in all sections. A PP with threats does not need to have OSPs and vice versa. Also, any PP can omit assumptions.

NOTE 3 Where the TOE is physically distributed, it is preferable to discuss the relevant threats, OSPs and assumptions separately for distinct domains of the TOE operational environment.

7.1.2 Threats

The SPD describes the threats that are to be countered by the TOE, its operational environment, or a combination of the two.

A threat consists of an adverse action performed by a threat agent on an asset.

Adverse actions influence one or more properties of an asset from which that asset derives its value.

Threat agents may be described as individual entities, but in some cases, it is preferable to describe them as, e.g. types of entities, groups of entities.

EXAMPLE 1

Examples of threat agents are:

- hackers;
- users;
- computer processes;
- accidents.

Threat agents can be further described by attributes such as expertise, resources, opportunity, and motivation.

EXAMPLE 2

Examples of threats are:

- a hacker (with substantial expertise, standard equipment, and being paid to do so) remotely copying confidential files from a company network;
- a worm seriously degrading the performance of a wide-area network;
- a system administrator violating user privacy;
- someone on the Internet listening in on confidential electronic communication.

7.1.3 Organizational security policies (OSPs)

The SPD describes the OSPs that are to be enforced by the TOE, its operational environment, or a combination of the two.

OSPs are security rules, procedures, or guidelines imposed in the operational environment. OSPs can be made by an organization controlling the operational environment of the TOE, or they can be made by legislative or regulatory bodies. OSPs can apply to the TOE and/or the operational environment of the TOE.

EXAMPLE Examples of OSPs are:

- “All products that are used by the government shall conform to the national standard for password generation and encryption”;
- “Only users with system administrator privilege and clearance of Department Secret shall be allowed to manage the Department Fileserver”.

7.1.4 Assumptions

The SPD describes the assumptions that are made on the operational environment in order to be able to provide security functionality. If the TOE is placed in an operational environment that does not meet these assumptions, there is a possibility that the TOE will be unable to provide all of its security functionality. Assumptions may be on physical, personnel and connectivity of the operational environment.

EXAMPLE Examples of assumptions are:

- assumptions on the non-TOE part of the product;
 - it is assumed that the TOE will be integrated into a device that provides a hardware-based root of trust.
- assumptions on physical aspects of the operational environment;
 - it is assumed that the TOE will be placed in a room that is designed to minimize electromagnetic emanations;
 - it is assumed that the administrator consoles of the TOE will be placed in a restricted access area.
- assumptions on personnel aspects of the operational environment;
 - it is assumed that users of the TOE will be trained sufficiently in order to operate the TOE;
 - it is assumed that users of the TOE are approved for information that is classified as National Secret;
 - it is assumed that users of the TOE will not write down their passwords.
- assumptions on connectivity aspects of the operational environment;
 - it is assumed that a PC workstation with at least 10GB of disk space is available to run the TOE on;
 - it is assumed that the TOE is the only non-OS application running on this workstation;
 - it is assumed that the TOE will not be connected to an untrusted network.

NOTE During an evaluation, these assumptions are considered to be true: they are not tested in any way. For these reasons, assumptions can only be made on the operational environment. Assumptions can never be made on the behaviour of the TOE because an evaluation consists of evaluating assertions made about the TOE and not by assuming that assertions on the TOE are true. Nevertheless, the ST, PP and PP-Configuration evaluations help detect unrealistic assumptions for the type of TOE and operational environment, which can become unacceptable.

7.2 Security objectives

7.2.1 General

The security objectives are a concise statement of the intended solution to the security problem. The role of the security objectives is threefold:

- a) provide a high-level, natural language solution of the problem. The security objectives consist of a set of statements without overly much detail that together form a high-level solution to the security problem. The level of abstraction of the security objectives aims at being clear and understandable to knowledgeable potential consumers of the TOE. The security objectives are in natural language;
- b) divide this solution into two part-wise solutions, that reflect the roles of the TOE and its operational environment to address each part of the problem. In a ST the high-level security solution, as described by the security objectives, is divided into two part-wise solutions. These part-wise solutions are called the security objectives for the TOE and the security objectives for the operational environment;
- c) demonstrate that these part-wise solutions form a complete solution to the problem.

7.2.2 Security objectives for the TOE

The TOE provides security functionality to solve a certain part of the problem defined by the SPD. This part-wise solution is called the security objectives for the TOE and consists of a set of objectives that the TOE shall achieve in order to solve its part of the problem.

EXAMPLE Examples of security objectives for the TOE are:

- “The TOE shall keep confidential the content of all files transmitted between it and a Server”;
- “The TOE shall identify and authenticate all users before allowing them access to the Transmission Service provided by the TOE”;
- “The TOE shall restrict user access to data according to the Data Access policy described in Annex 3 of the PP”.

If the TOE is physically distributed, it is preferable to subdivide the section containing the security objectives for the TOE into several subsections to reflect this.

NOTE In Direct Rationale STs security objectives for the TOE are not included: See D.4.

7.2.3 Security objectives for the operational environment

The operational environment of the TOE implements technical and procedural measures to assist the TOE in correctly providing its security functionality (which is defined by the security objectives for the TOE). This pair-wise solution is called the security objectives for the operational environment and consists of a set of statements describing the goals that the operational environment shall achieve.

EXAMPLE

Examples of security objectives for the operational environment are:

- “The operational environment shall provide a workstation with the OS Linux version 3.01b to execute the TOE on”;
- “The operational environment shall ensure that all human TOE users receive appropriate training before allowing them to work with the TOE”;
- “The operational environment of the TOE shall restrict physical access to the TOE to administrative personnel and maintenance personnel accompanied by administrative personnel”;
- “The operational environment shall ensure the confidentiality of the audit logs received from the TOE on the Audit Server”.

If the operational environment of the TOE consists of multiple physical sites, each with different properties, it is preferable to subdivide the section containing the security objectives for the operational environment into several sub-sections to reflect this.

Third party components that shall not be evaluated due to unavailability of evaluation evidence are included in the operational environment, and the security objectives for the operational environment shall include that the third-party component works as intended.

7.2.4 Relation between security objectives and the SPD

STs, PPs, PP-Modules and packages also contain a security objectives rationale containing two sections:

- a) a tracing that shows which security objectives address which SPD-elements;
- b) a set of justifications that shows that all SPD-elements are effectively addressed by the security objectives.

NOTE In Direct Rationale PPs a rationale for security objectives in the TOE is not included. See D.4.

EXAMPLE A threat "T17: Threat agent X reads the Confidential Information in transit between A and B", a security objective for the TOE: "OT12: The TOE shall ensure that all information transmitted between A and B is kept confidential", and a demonstration "T17 is directly countered by OT12".

7.2.5 Tracing between security objectives and the SPD

The tracing shows how the security objectives trace back to the SPD-elements and that:

- a) *there are no spurious objectives;*

Each security objective traces to at least one SPD-element.

- b) *the security problem definition is completely covered;*

Each SPD-element has at least one security objective tracing to it;

- c) *the tracing is correct.*

Since assumptions are always made by the TOE on the operational environment, security objectives for the TOE do not trace back to assumptions. The tracings allowed by ISO/IEC 15408-3 are depicted in Figure 3.

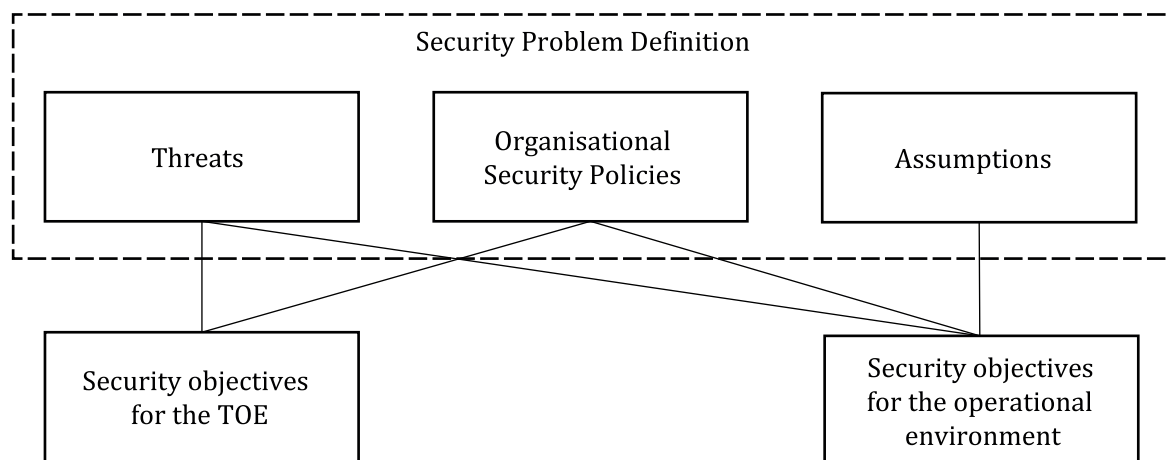


Figure 3 — Tracings between security objectives and the SPD

Multiple security objectives may trace to the same threat, indicating that the combination of those security objectives counters that threat. A similar argument holds for OSPs and assumptions.

7.2.6 Providing a justification for the tracing

The security objectives rationale also demonstrates that the tracing is effective: All the given threats, OSPs and assumption are addressed (i.e. countered, enforced, and upheld respectively) if all security objectives tracing to a particular threat, OSP or assumption are achieved.

This demonstration analyses the effect of achieving the relevant security objectives on countering the threats, enforcing the OSPs and upholding the assumptions and leads to the conclusion that this is indeed the case.

In some cases, where parts of the SPD very closely resemble some security objectives, the demonstration can be straightforward.

7.2.7 On countering threats

Countering a threat does not necessarily mean removing that threat, it can also mean sufficiently diminishing that threat or sufficiently mitigating the associated risk.

EXAMPLE Examples of removing a threat are:

- removing the ability to execute the adverse action from the threat agent;
- moving, changing, or protecting the asset in such a way that the adverse action is no longer applicable to it;
- removing the threat agent, e.g. removing machines from a network that frequently crash that network.

Examples of diminishing a threat are:

- restricting the ability of a threat agent to perform adverse actions;
- restricting the opportunity to execute an adverse action of a threat agent;
- reducing the likelihood of an executed adverse action being successful;
- reducing the motivation to execute an adverse action of a threat agent by deterrence;
- requiring greater expertise or greater resources from the threat agent.

Examples of mitigating the effects of a threat are:

- making frequent back-ups of the asset;
- obtaining spare copies of an asset;
- insuring an asset;
- ensuring that successful adverse actions are always timely detected, so that appropriate action can be taken.

7.2.8 Security objectives: conclusion

Based on the security objectives and the security objectives rationale, the following conclusion is drawn: If all security objectives are achieved then the security problem as defined in SPD is solved. All threats are countered, all OSPs are enforced, and all assumptions are upheld.

NOTE The ASE_SPD family in ISO/IEC 15408-3 supports this determination.

7.3 Security requirements

7.3.1 General

As mentioned in 6.3.3.4 and 6.3.3, packages, PPs, PP-Modules, PP-Configurations and STs specify the detailed security requirements applicable to a TOE that have been derived from the stated SPD. SFRs and SARs shall be drawn from security components defined in ISO/IEC 15408-2 and ISO/IEC 15408-3

respectively, which are a template for security requirements written in a standardized language. The process of deriving a security requirement from a security component involves digesting the components and is known as “completion”.

NOTE 1 In Clause 7, the term “author” includes authors of STs, PPs, PP-Modules, PP-Configurations and packages.

Security requirements are specified as a result of the description of the in a ST and possibly PP, PP-Module, and packages. Security requirements are specified by a choosing the components given in ISO/IEC 15408-2, ISO/IEC 15408-3 or that have been defined as extended components in accordance with 8.4. The tailoring process uses the operations in 8.2.

NOTE 2 Since a ST specifies the security requirements for a specific TOE it presents only fully completed components. PPs, PP-Modules and packages often present uncompleted security components allowing authors basing documents upon them appropriate flexibility.

The security requirements consist of two groups of requirements:

- a) **the security functional requirements** (SFRs): a description of how the TOE addresses the SPD in a standardized language;
- b) **the security assurance requirements** (SARs): a description of how assurance is to be gained that the TOE meets the SFRs.

NOTE 3 SARs concern the adherence of the TOE to the ST. SARs play no role in the coverage of the SPD, which is covered by security objectives and SFRs.

These two groups are discussed in 7.3.2 and 7.3.3.

7.3.2 Security Functional Requirements (SFRs)

7.3.2.1 General

The SFRs contribute to fulfil the TOE’s SPD and address the security objectives defined for the TOE. They are usually at a more detailed level of abstraction, but they have to be a complete translation (the security objectives for the TOE shall be completely addressed). The ISO/IEC 15408 series requires this translation into a standardized language for the following reasons:

- to provide a precise description of what is to be evaluated. As security objectives for the TOE are usually formulated in natural language, translation into a standardized language enforces a more precise description of the functionality of the TOE;
- to allow comparison between two STs. The standardized language enforces using the same terminology and concepts. This allows comparison of STs even when authors use different terminology in describing their SPD and security objectives (this situation does not arise when the STs conform to the same PPs or PP-Configuration).

In the context of PPs and PP-Modules, the SFRs shall be independent of any specific technical solution (implementation).

There is no translation required in this document for the security objectives for the operational environment, because the operational environment is not evaluated and does therefore not require a description aimed at its evaluation.

NOTE 1 See the Bibliography for items relevant to the security assessment of operational systems.

NOTE 2 It can be the case that parts of the operational environment are evaluated in another evaluation, but this is not within the scope of the ISO/IEC 15408 series.

EXAMPLE An operating system TOE can require a firewall to be present in its operational environment. Another evaluation can subsequently evaluate the firewall, but this evaluation has nothing to do with the evaluation of the OS TOE.

7.3.2.2 How this translation is supported

The ISO/IEC 15408 series supports this translation in three ways:

- a) By providing a pre-defined “language” designed to describe precisely what is to be evaluated. This language is defined as a set of components defined in ISO/IEC 15408-2. The use of this language as a well-defined translation of the security objectives for the TOE to SFRs is mandatory, though some exceptions exist and are given in 8.4;
- b) By providing operations: mechanisms that allow the author of the package, ST, PP or PP-Module to complete and modify the SFRs to provide a more accurate translation of the security objectives for the TOE or TOE type. This document defines the four allowed operations: assignment, selection, iteration, and refinement. These are described further in 8.2;
- c) By providing dependencies: a mechanism that supports a more complete translation to SFRs. In ISO/IEC 15408-2 language, an SFR may have a dependency on other SFRs. This signifies that if a ST uses that SFR, it generally needs to use those other SFRs as well. This makes it much harder for the ST author to overlook including necessary SFRs and thereby improves the completeness of the ST. Dependencies are described further in 8.3.

7.3.2.3 Relation between SFRs and security objectives

Packages, PPs, PP-Modules and STs contain a SFRs rationale, consisting of two sections:

- a) a tracing that shows which SFRs address which security objectives for the TOE;
- b) a set of justifications that shows that all security objectives for the TOE are effectively addressed by the SFRs.

NOTE In the Direct Rationale approach the tracing and rationale is provided between the SFRs and the SPD.

7.3.2.4 Tracing between SFRs and the security objectives for the TOE

The tracing shows how the SFRs trace back to the security objectives for the TOE as follows:

- a) *no spurious SFRs*: Each SFR traces back to at least one security objective;
- b) *complete with respect to the security objectives for the TOE*: Each security objective for the TOE has at least one SFR tracing to it.

Multiple SFRs may trace to the same security objective for the TOE, indicating that the combination of those security requirements meets that security objective for the TOE.

7.3.2.5 Providing a justification for the tracing

The SFRs rationale demonstrates that the tracing is effective: if all SFRs tracing to a particular security objective for the TOE are satisfied, that security objective for the TOE is achieved.

This demonstration analyses the effects of satisfying the relevant SFRs on achieving the security objective for the TOE and lead to the conclusion that this is indeed the case.

7.3.2.6 Special types of SFR

SFRs can be designated in packages, PPs and PP-Modules as optional requirements or selection-based requirements.

A. Optional requirements

Optional requirements are “optional” in the sense that they do not need to be included in a PP/ST in order for the PP/ST to claim conformance (of any type) to a PP or PP-Configuration.

Packages, PPs and PP-Modules may define optional requirements in one of two categories. Each category is specified explicitly by the author.

The first category of optional requirements is elective. Requirements in this category do not need to be included in a PP/ST in order for the PP/ST to claim conformance (of any type) to the PP or PP-Configuration where the requirement is defined. In this case, it is not obligatory that the PP/ST includes the requirement, even if the TOE implements the functionality described by the requirement.

The second category of optional requirements is conditional. If the TOE implements the described functionality then the optional requirement shall be included in the PP/ST. If the TOE does not implement the functionality covered by the optional requirement, then the requirement is not included in the PP/ST.

NOTE Optional requirements can be written in response to SPD-elements that exist in the package, PP or PP-Module, or SPD-elements that are specifically associated with the requirement. Such associations are identified in the package, PP or PP-Module. A Direct Rationale package, PP, PP-Module or ST do not define security objectives for optional requirements that have associated SPD elements, while a regular package, PP, PP-Module or ST includes security objectives for the associated SFRs and SPD elements.

B. Selection-based requirements

Packages, PPs and PP-Modules may identify a set of selection-based SFRs. In this case, the author additionally ensures that the package/PP/PP-Module clearly indicates the dependencies between a particular selection in a security functional component and/or SFR included in the package/PP/PP-Module and the associated selection-based SFR(s) that shall be included if that selection is chosen by another PP/ST author. This is explained in 8.2.4.2.

7.3.3 Security assurance requirements (SARs)

7.3.3.1 General

The SARs are a description of how the TOE is to be evaluated that may be defined in packages, PPs, PP-Modules, PP-Configurations and STs. This description uses a standardized language for two reasons:

- to provide a precise description of how the TOE is to be evaluated;
- to allow comparison between two STs. The standardized language enforces using the same terminology and concepts.

This standardized language is rendered by components defined in ISO/IEC 15408-3, and permitted operations are defined in Clause 8. The use of this language is mandatory, though some exceptions exist. The ISO/IEC 15408 series enhances this language in two ways:

- a) By providing operations: mechanisms that allow the package/PP/PP-Module/PP-Configuration/ST author to modify the SARs. The ISO/IEC 15408 series has four operations: assignment, selection, iteration, and refinement. These are described further in 8.2;
- b) By providing dependencies: a mechanism that supports consistent choice from other SARs to complete the depending SAR. In ISO/IEC 15408-3 language, a SAR can have a dependency on other SARs. This signifies that if a package/ PP/PP-Module/PP-Configuration/ST uses that SAR, it generally needs to use those other SARs as well. This makes it much harder for the author to overlook including necessary SARs and thereby improves the completeness of packages, STs, PPs, PP-Modules and PP-Configurations. Dependencies are described further in 8.3.

NOTE The SARs defined in ISO/IEC 15408-3 do not use assignments or selections. However, it is possible to define extended assurance components which allow those operations.

7.3.3.2 SARs and the security requirement rationale

Assurance packages, PPs, PP-Modules, PP-Configurations, and STs also contain a security requirements rationale that explains why the chosen set(s) of SARs are deemed appropriate.

NOTE In the case of exact conformance a PP-Module inherits the SARs from its PP-Module Base hence no rationale for the SARs is required.

SARs contribute to the confidence that a risk owner can place in an evaluation. Many SARs given in ISO/IEC 15408-3 relate to the design and development processes used in the implementation of a TOE by a developer and to developer testing. Some SARs relate to an operational TOE such as secure delivery process and flaw remediation. Some SARs relate specifically to evaluator vulnerability analysis and independent functional and penetration testing.

EXAMPLE An example of an inconsistency in the selection of SARs is if the SPD mentions threats where the threat agent is very capable, and a low (or no) vulnerability analysis (AVA_VAN) is included in the SARs.

7.3.4 Security requirements: conclusion

In the SPD section of a functional package/PP/PP-Module/ST, the security problem is defined as consisting of the SPD-elements: threats, OSPs and assumptions. In the security objectives section of the functional package/PP/PP-Module/ST, the solution is provided in the form of two sub-solutions:

- security objectives for the TOE;
- security objectives for the operational environment.

Additionally, the security objectives rationale is provided to justify that the security problem is solved if all security objectives are met.

In the security requirements section, the security objectives for the TOE are translated to SFRs and a security requirements rationale is provided showing that if all SFRs are satisfied, all security objectives for the TOE are achieved.

Additionally, a set of SARs is provided to show how the TOE is evaluated, together with an explanation for selecting these SARs. The set of SARs shall be in line with the security expectations derived from the SPD. The explanation for SAR selection shall be made in the SAR rationale.

The operational environment itself is not within the scope of the evaluation, although when the AGD assurance class is included in a ST then the TOE guidance shall fully reflect these security objectives for the operational environment and is assessed as part of the evaluation using the AGD class.

All of the above are combined into the statement: "If all SFRs and SARs are satisfied and all security objectives for the operational environment are achieved, then there exists assurance that the security problem as defined in ASE_SPD is solved: all threats are countered, all OSPs are enforced, and all assumptions are upheld." This is illustrated in Figure 4.

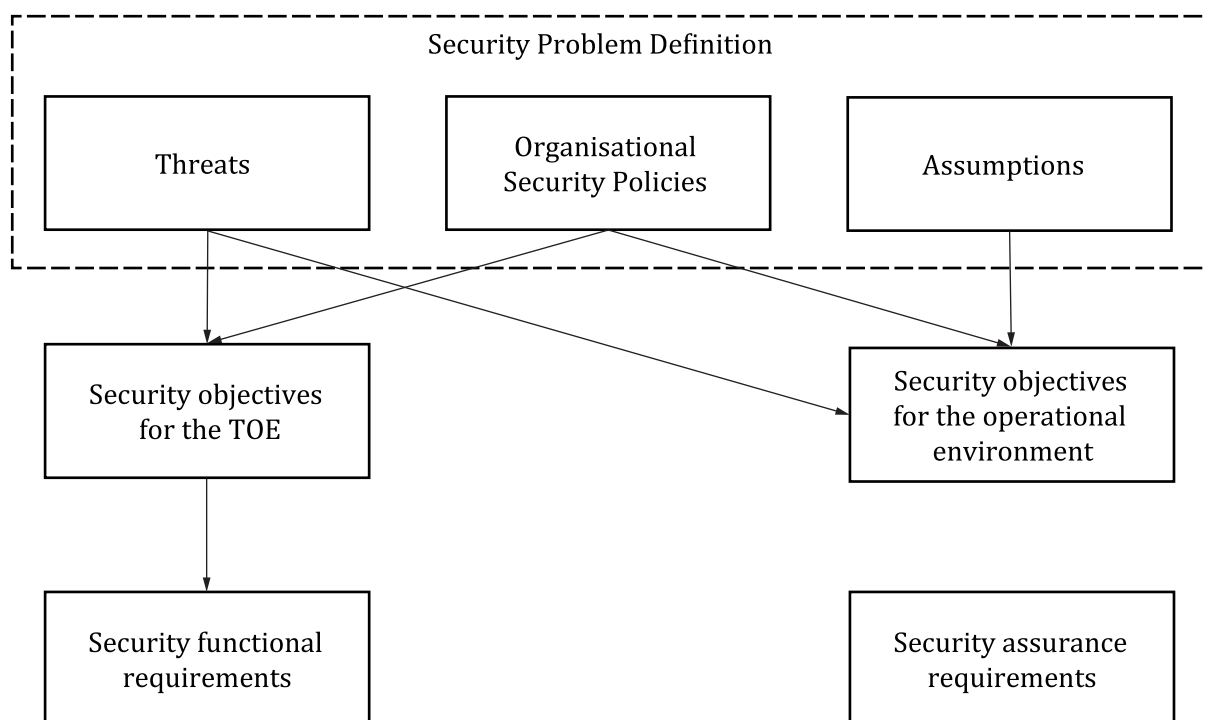


Figure 4 — Relations between the SPD, the security objectives, and the security requirements

The amount of assurance obtained through an evaluation is defined by the SARs, and whether this amount of assurance is sufficient to risk-owners using the ST is described in the explanation given for choosing these SARs.

8 Security components

8.1 Hierarchical structure of security components

8.1.1 General

ISO/IEC 15408-2 and ISO/IEC 15408-3 provide catalogues of security components that shall be used when specifying security requirements. The catalogues have organized the components into a hierarchical structure at four levels:

- classes, consisting of;
- families, consisting of;
- components, consisting of;
- elements, which cannot be decomposed.

8.1.2 Class

The requirements for functional classes are given in ISO/IEC 15408-2: 2022, 6.1.2. The requirements for assurance classes are given in ISO/IEC 15408-3: 2022, 6.2.

A class consists of a set of families.

EXAMPLE An example of a class is the “FIA: Identification and authentication” class that is focused at identification of users, authentication of users and binding of users and subjects.

8.1.3 Family

The requirements for functional families are provided in ISO/IEC 15408-2: 2022, 6.1.3. The requirements for assurance families are given in ISO/IEC 15408-3: 2022, 6.3.

A family consists of a set of components.

EXAMPLE An example of a family is the “User authentication (FIA_UAU)” family which is part of the “FIA: Identification and authentication class”. This family concentrates on the authentication of users.

8.1.4 Component

The requirements for functional component structure are provided in ISO/IEC 15408-2:2022, 6.1.4. The requirements for assurance components are given in ISO/IEC 15408-3:2022, 6.4.

A component consists of a set of elements.

EXAMPLE An example of a component is “FIA_UAU.3 Unforgeable authentication”, which concentrates on unforgeable authentication.

8.1.5 Element

The requirements for functional elements are provided in ISO/IEC 15408-2:2022, 6.1.4. The requirements for assurance elements are given in ISO/IEC 15408-3:2022, 6.5.

EXAMPLE An example of an element is “FIA_UAU.3.2”, which concentrates on the prevention of use of copied authentication data.

8.2 Operations

8.2.1 General

ISO/IEC 15408-2 and ISO/IEC 15408-3 provide catalogues of security components, and this document provides authors with the ability to extend the component catalogues in some circumstances. By applying operations to the security components, they may be tailored precisely to the author's needs when writing PPs, PP-Modules, packages and STs'.

Security components may be used precisely as defined in ISO/IEC 15408-2 and ISO/IEC 15408-3, or they may be tailored through the use of permitted operations.

When using operations, the author should be careful that the dependency needs of other requirements that depend on this requirement are satisfied. The permitted operations are selected from the following set:

- a) iteration: allows a component to be used more than once with varying operations;
- b) assignment: allows the specification of parameters;
- c) selection: allows the specification of one or more items from a list; and
- d) refinement: allows the addition of details.

The assignment and selection operations are permitted only where specifically indicated in a component. Iteration and refinement are permitted for all security requirements. The operations are described in more detail below.

The annexes of ISO/IEC 15408-2 provide the guidance on the valid completion of selections and assignments. This guidance provides instructions on how to complete operations, and those instructions shall be followed unless the author justifies the deviation:

- “None” is only available as a choice for the completion of a selection if explicitly provided;

The lists provided for the completion of selections shall be non-empty. If a “None” option is chosen, no additional selection options may be chosen. If “None” is not given as an option in a selection, it is permissible to combine the choices in a selection with “and”s and “or”s, unless the selection explicitly states “choose one of”.

Selection operations may be combined by iteration where needed. In this case, the applicability of the option chosen for each iteration should not overlap the subject of the other iterated selection, since they are intended to be exclusive.

- for the completion of assignments, the ISO/IEC 15408-2 annexes shall be consulted in order to determine when “None” would be a valid completion.

8.2.2 Iteration

The iteration operation may be performed on every component. The author performs an iteration operation by including multiple requirements based on the same component. Each iteration of a component shall be different from all other iterations of that component, which is realized by completing assignments and selections in a different way, or by applying refinements to it in a different way.

Different iterations shall be uniquely identified to allow clear rationales and tracings to and from these requirements. Iteration identifiers should be meaningful to readers.

EXAMPLE FCS_COP.1 Cryptographic operation being iterated twice in order to require the implementation of two different cryptographic algorithms. An example of each iteration being uniquely identified is:

- cryptographic operation (RSA signatures) (FCS_COP.1(RSA signatures));
- cryptographic operation (AES data encryption/decryption) (FCS_COP.1(AES data encryption/decryption)).

NOTE Sometimes an iteration operation can be used with components where it is also possible to perform an assignment operation with a range or list of values instead of iterating them. In that case, the author can select the most appropriate alternative, considering if there is a necessity of providing a whole rationale for the range of values or if it is necessary to have a separate one for each of them. The author considers if individual traces are required for those values.

8.2.3 Assignment

An assignment operation occurs where a given component contains an element with a parameter that may be set by the author. The parameter may be an unrestricted variable, or a rule that narrows the variable to a specific range of values.

Whenever an element in a PP, PP-Module or package within a PP/PP-Module contains an assignment, the author shall do one of four things:

- leave the assignment uncompleted;

EXAMPLE 1 The author can include FIA_AFL.1.2 in the PP, PP-Module or package.

“When the defined number of unsuccessful authentication attempts has been met or surpassed, the TSF **shall [assignment: list of actions]**.”

In this case, the ST author can complete FIA_AFL.1.2 thus:

“When the defined number of unsuccessful authentication attempts has been met or surpassed, the TSF shall prevent that external entity from binding to any subject in the future.”

- complete the assignment;

EXAMPLE 2 The author can include FIA_AFL.1.2 in the PP, PP-Module or package.

“When the defined number of unsuccessful authentication attempts has been met or surpassed, the TSF shall prevent that external entity from binding to any subject in the future.”

- c) narrow the assignment to further limit the range of values that is allowed;

EXAMPLE 3 The author can include FIA_AFL.1.1 in the PP, PP-Module or package.

“The TSF shall detect when [assignment: positive integer] unsuccessful authentication attempts occur ...”

In this case, the ST author can complete FIA_AFL.1.1 thus:

“The TSF shall detect when **3** unsuccessful authentication attempts occur ...”

- d) transform the assignment to a selection, thereby narrowing the assignment.

EXAMPLE 4 The author can include FIA_AFL.1.2 in the PP, PP-Module or package.

“When the defined number of unsuccessful authentication attempts has been met or surpassed, the TSF shall [selection: prevent that user from binding to any subject in the future, notify the administrator].”

In this case, the ST author can complete FIA_AFL.1.2 thus:

“When the defined number of unsuccessful authentication attempts has been met or surpassed, the TSF shall **prevent that user from binding to any subject in the future.**”

An ST author shall complete all the assignments.

The values chosen in options b), and c) shall conform to the indicated type required by the assignment.

When an assignment is to be completed with a set, an author should provide a description of the set from which the elements of the set may be derived as long as it is clear which subjects are meant.

EXAMPLE 5 Where the set is “subjects”:

- all subjects;
- all subjects of type X;
- all subjects except subject a.

8.2.4 Selection

8.2.4.1 General

The selection operation occurs where a given component contains an element where a choice from several items has to be made by the author.

Whenever an element in a PP, PP-Module or package contains a selection, the author may do one of three things:

- a) leave the selection uncompleted;
- b) complete the selection by choosing one or more items;
- c) restrict the selection by removing some of the choices but leaving two or more.

Whenever an element in a PP, PP-Module or package contains a selection, a ST author shall complete that selection, as indicated in b) above. Options a) and c) are not allowed for STs.

The item or items chosen in b) and c) shall be taken from the items provided in the selection.

EXAMPLE 1 An example of an element with a selection is:

FPT_TST.1.1 “The TSF shall run a suite of self-tests [selection: during initial start-up, periodically during normal operation, at the request of the authorized user, at the conditions [assignment: conditions under which self-test should occur]] to demonstrate the correct operation of...”

8.2.4.2 Selection-based security functional components and SFRs

A PP, PP-Module or package may define a set of security functional components and/or SFRs called selection-based SFRs. This set of components and/or SFRs is associated with a selection made in another component and/or SFRs in the PP, PP-Module or package. The related selection-based components and/or SFRs shall be included in a PP, PP-Module, package or ST if:

- a selection choice identified in the PP, PP-Module or package indicates that it has an associated selection-based SFR;
- that selection is made by the author.

The PP, PP-Module or package can be organized so that selection-based components and/or SFRs are grouped together.

For the case that an author needs to leave a selection operation uncompleted, the author shall leave the selection-based components and/or SFRs that are related to the uncompleted selection operation, unchanged.

For the case in which the author needs to complete the selection, authors should include the appropriate selection-based components and/or SFRs in the list of SFRs for the PP, PP-Module, package or ST.

For the case in which the selection operation is to be restricted, i.e. some but not all of the selections are removed, the author shall remove any selection-based components and/or SFRs from the list that corresponds to the choices removed from the selection.

The following is another example of such an SFR:

EXAMPLE 1 An example of a selection-based SFR, where FTP_ITC.1.1 is the SFR with the selection and FCS_IPSEC.1 is the selection-based SFR is:

FTP_ITC.1.1 The TSF shall be capable of using [selection: IPsec, SSH, TLS, HTTPS] to provide a trusted communication channel between...

Application Note:

In the selection for FTP_ITC.1.1, the ST author selects the mechanism or mechanisms supported by the TOE, and then ensures that the selection-based requirements in Appendix B of this PP that correspond to the selected mechanism or mechanisms are included in the ST.

And in Appendix B of the example PP:

The following SFRs are included in the ST if the ST author selects “IPsec” in FTP_ITC.1.1:

FCS_IPSEC.1 [...]

8.2.5 Refinement

The refinement operation may be performed on every requirement. The author performs a refinement by altering that requirement.

NOTE 1 A series of refined iteration operations can be used to cover all of the subjects, objects, operations, security attributes and/or external entities, but where each individual refinement does not.

The first rule for a refinement is that a TOE meeting the refined requirement also meets the unrefined requirement in the context of the PP, PP-Module, package or ST, i.e. a refined requirement shall be “stricter” than the original requirement. If a refinement does not meet this rule, the resulting refined requirement is considered to be an extended requirement and shall be treated as such in accordance with 7.3.

EXAMPLE 2 An example of a valid refinement is:

FIA_UAU.2.1 “The TSF shall require each user to be successfully authenticated before allowing any other TSF-mediated actions on behalf of that user.” being refined to “The TSF shall require each user to be successfully authenticated by username/password before allowing any other TSF-mediated actions on behalf of that user.”

The only exception to this rule is that an author can refine a SFR to apply to some but not all subjects, objects, operations, security attributes and/or external entities. However, this exception does not apply to refining SFRs that are taken from PPs, PP-Modules or package to which conformance is being claimed; these SFRs shall not be refined to apply to fewer subjects, objects, operations, security attributes and/or external entities than the SFR in the originating PP, PP-Module or package.

EXAMPLE 3 An example of a such an exception is:

FIA_UAU.2.1 “The TSF shall require each user to be successfully authenticated before allowing any other TSF-mediated actions on behalf of that user.” being refined to “The TSF shall require each user originating from the internet to be successfully authenticated before allowing any other TSF-mediated actions on behalf of that user.”

The second rule for a refinement is that the refinement shall be related to the original component.

EXAMPLE 4 Refining an audit component with an extra element on prevention of electromagnetic radiation is not allowed.

A special case of refinement is an editorial refinement, where a small change may be made in a requirement, i.e. rephrasing a sentence due to adherence to proper English grammar, or to make it more understandable to the reader. This change is not allowed to modify the meaning of the requirement in any way.

EXAMPLE 5 An example of an editorial refinement is:

The SFR FPT_FLS.1, “The TSF shall continue to preserve a secure state when the following failures occur: **breakdown of one CPU**”

that could be refined to

FPT_FLS.1, “The TSF shall continue to preserve a secure state when the following failure occurs: **break-down of one CPU**”

or even

FPT_FLS.1, “The TSF shall continue to preserve a secure state when **one CPU breaks down**”.

8.3 Dependencies between components

Dependencies may exist between components. Dependencies arise when a component is not self-sufficient and relies upon the presence of another component to provide security functionality or assurance.

The functional components in ISO/IEC 15408-2 typically have dependencies on other functional components. Some of the assurance components in ISO/IEC 15408-3 also have dependencies, which in turn, may have dependencies on other ISO/IEC 15408-3 components.

ISO/IEC 15408-2 dependencies on ISO/IEC 15408-3 components may also be defined. Extended functional/assurance components may define dependencies similarly.

Component dependency descriptions are determined by consulting the component definitions given in ISO/IEC 15408-2, ISO/IEC 15408-3, or the extended components definition. In order to ensure completeness of the TOE security requirements, dependencies should be satisfied when requirements based on components with dependencies are incorporated into PPs, PP-Modules, packages or STs. Dependencies should also be considered when constructing packages, i.e. if component A has a dependency on component B, this means that whenever a PP, PP-Module, package or ST contains a security requirement based on component A, the PP, PP-Module, package or ST shall also contain one of:

- a) a security requirement based on component B; or
- b) a security requirement based on a component that is hierarchically higher than B; or
- c) a justification why the PP, PP-Module, package or ST does not contain a security requirement based on component B.

In cases a) and b), when a security requirement is included because of a dependency, it can be necessary to complete operations (assignment, iteration, refinement, selection) on that security requirement in a particular manner to make sure that it actually satisfies the dependency.

In case c), the justification that a security requirement is not included should address either:

- why the dependency is not necessary or useful; or
- that the dependency has been addressed by the operational environment of the TOE, in which case the justification should describe how the security objectives for the operational environment address this dependency; or
- that the dependency has been addressed by the other SFRs in some other manner (e.g. extended SFRs, combinations of SFRs).

8.4 Extended components

8.4.1 General

Security requirements shall be based on components from ISO/IEC 15408-2 or ISO/IEC 15408-3 with two exceptions:

- a) there are security objectives for the TOE that cannot be translated to SFRs using components in ISO/IEC 15408-2;
- b) a security objective for the TOE that can be translated to SFRs, but only with great difficulty and/or complexity based on components in ISO/IEC 15408-2, there are third party requirements that cannot be translated to SARs using components in ISO/IEC 15408-3.

EXAMPLE Laws and/or regulation regarding the evaluation of cryptography.

In these cases, the author is required to define new components called extended components. A precisely defined extended component is needed to provide context and meaning to the extended SFRs and SARs based on that component.

After the new components have been defined correctly, the author can then base one or more SFRs or SARs on these newly defined extended components and use them in the same way as the other SFRs and SARs. From this point on, there is no further distinction between SFRs and SARs drawn from the ISO/IEC 15408 series and SFRs and SARs based on extended components.

Refer to ISO/IEC 15408-3, Extended components definition (APE_ECD) and Extended components definition (ASE_ECD) for further requirements on extended components. Further information on extended components is also given in D.3.6.

8.4.2 Defining extended components

Whenever an author of a package, PP, PP-Module or ST defines an extended component, this shall be done in a similar manner to the existing ISO/IEC 15408 series components: clear, unambiguous and evaluable (it is possible to systematically demonstrate whether a requirement based on that component holds for a TOE). Extended components shall use similar labelling, manner of expression, and level of detail as the existing ISO/IEC 15408 series components.

The author also shall make sure that all of the applicable dependencies of an extended component are included in the definition of that extended component.

EXAMPLE

Examples of possible dependencies are:

- a) an extended component that refers to auditing, can include dependencies to components of the FAU: Security audit class;
- b) an extended component that modifies or accesses data, can include dependencies to components of the Access control policy (FDP_ACC) family;
- c) an extended component that uses a particular design description can include a dependency to the appropriate ADV: Development family.

In the case of an extended functional component, the author also shall include any applicable audit and associated operations information in the definition of that component, similar to existing ISO/IEC 15408-2 components. In the case of an extended assurance component, the author may also provide a suitable evaluation methodology for the component, similar to the method provided in ISO/IEC 18045.

Extended components may be placed in existing families, in which case the author shall show how these families change. If they do not fit into an existing family, they shall be placed in a new family. New families shall be defined similarly to those given in ISO/IEC 15408-2 or ISO/IEC 15408-3.

New families may be placed in existing classes in which case the author shall show how these classes change. If they do not fit into an existing class, they shall be placed in a new class. New classes shall be defined similarly to those defined in ISO/IEC 15408-2 or ISO/IEC 15408-3.

9 Packages

9.1 General

A package is a named set of security components or security requirements.

A package can be defined by any party and is intended to be re-usable. To this goal, it contains requirements that are useful and effective in combination.

Where two or more packages are related to each other, they may be presented as part of a package family, see A.2.

Packages may be claimed by PPs, PP-Modules, PP-Configurations and STs, and used to construct larger packages. Authors shall not rename the claimed or used packages.

NOTE 1 Although no separate criteria are given in the ISO/IEC 15408 series for evaluating packages, once such packages are included in a PP, PP-Module or ST they will be evaluated using the APE, ACE, or ASE criteria.

NOTE 2 ISO/IEC 15408-5 provides commonly used packages, such as EALs that have been pre-defined and can be used by PP, PP-Modules, PP-Configurations or ST authors.

Functional packages cannot be claimed directly by a PP-Configuration; they shall be part of a PP-Configuration component.

Further information on packages is given in Annex A.

9.2 Package types

9.2.1 General

A package shall be either:

- a functional package, containing functional components or requirements, but no assurance components or requirements; or
- an assurance package, containing assurance components or requirements, but no functional components or requirements.

Mixed packages containing both functional and assurance components or requirements shall not be specified.

All packages shall include:

- a) the package identification giving a unique name, short name, version, date, sponsor, and the relevant parts of the ISO/IEC 15408 series;
- b) the type of the package, either an assurance package or a functional package;
- c) a package overview giving a narrative description of the purpose of the package;
- d) application notes, describing additional information in regard to the package;
- e) identification of evaluation methods(s) and/or activities, if such evaluation methods/activities derived from ISO/IEC 18045 have been specified;
- f) one or more security components or requirements;
- g) if extended components have been specified, then the package includes an extended components definition;
- h) a component rationale that provides the rationale for selecting the functional or assurance components/requirements included in the package.

9.2.2 Assurance packages

An assurance package contains a set of assurance components or requirements that may be drawn from ISO/IEC 15408-3, may be extended assurance components, or that may be some combination of both.

An assurance package shall not include an SPD or security objectives nor any security functional components or requirements.

Assurance packages may be used within PPs, PP-Modules, PP-Configurations and STs. A set of pre-defined hierarchic assurance packages is given in ISO/IEC 15408-5.

EXAMPLE The EALs that are defined in ISO/IEC 15408-5 are comprised of SARs drawn from ISO/IEC 15408-3. EALs are pre-defined security assurance packages.

9.2.3 Functional packages

A functional package contains a set of functional components or requirements that may be drawn from ISO/IEC 15408-2, or that may be extended functional components or requirements or some combination of both.

A functional package may include an SPD and security objectives derived from that SPD. If the package defines an SPD, then the functional package security objectives shall be given. The objectives include the security objectives for the TOE (these are omitted if the Direct Rationale approach is used), security objectives for the operational environment, and the security objectives rationale.

Functional packages may be used within PPs, PP-Modules and STs as a means to structure security functionality into building blocks.

Functional packages may have dependencies on other functional packages. Such dependencies shall be documented in the functional package and may also be documented in a PP, PP-Module or ST.

EXAMPLE A PP defines and includes functional package A; package A has no dependencies. Functional packages B, C, and D are defined elsewhere. Package D has no dependencies, but package C depends on package B. A ST can then claim conformance to the following combinations of PPs and packages:

- the ST claims conformance to the PP (which includes functional package A);
- the ST claims conformance to the PP and functional package B;
- the ST claims conformance to the PP and functional packages B and C;
- the ST claims conformance to the PP and functional package D;
- the ST claims conformance to the PP and functional packages B, C, and D.

The following would not be allowed:

- the ST claims conformance to the PP and functional package C (this is not allowed because package C depends on package B, so it cannot be claimed independently.)

9.3 Package dependencies

A package may not satisfy all of the dependencies of the components contained within it. However, the dependencies shall be met by a PP, PP-Module, PP-Configuration or ST that includes the package. This means that it is the responsibility of the author to ensure either that all the dependencies are met or to include a rationale that explains why the dependencies are not met. This is explained in 8.3.

9.4 Evaluation method(s) and activities

Packages may include evaluation methods/activities that have been derived from ISO/IEC 18045. If evaluation methods/ evaluation activities that have been derived from ISO/IEC 18045 are to be used to evaluate the package, then these shall be identified in the relevant security requirement section by including a statement in the following form:

“This package requires the use of evaluation methods/ evaluation activities defined in <reference(s)>.”

In this statement, <reference> is replaced by the identification of the location of the relevant evaluation methods and evaluation activities. This reference may be to the document containing the package, or to one or more separate documents.

NOTE ISO/IEC 15408-4 provides a framework to perform such derivations.

10 Protection Profiles (PPs)

10.1 General

A PP is intended to describe a general TOE type. Therefore, a PP may be used:

- as a ST template for any TOEs that meet the PP's TOE type;
- as a template for other PPs in order to further refine the TOE type;
- as a basis for a PP-Module, in which context it is known as a base PP.

A detailed description of PPs is given in Annex B.

NOTE A ST describes requirements for a specific TOE and is typically sponsored by the developer of that TOE.

10.2 PP introduction

The introduction to the PP shall include a reference identifier for the PP.

The introduction to the PP shall include an overview of the PP, including a description of the TOE type.

The reference identifier for a PP shall be unique within a catalogue.

EXAMPLE A TOE type can be "Firewall";

A refined TOE type can be "Stateful inspection firewalls";

A specific TOE related to that TOE type can be the "MinuteGap Firewall v18.5".

A PP describes the general requirements for a TOE type, and is therefore typically sponsored by:

- a technical user community seeking to come to a consensus on the requirements for a given TOE type;
- a developer of a TOE, or a group of developers of similar TOEs wishing to establish a minimum baseline for that type of TOE;
- an organization, such as a government or large corporation, specifying its security requirements as part of its acquisition process.

10.3 Conformance claims and conformance statements

In this subclause the use of italic text indicates literal text that shall appear in the text of the PP.

The conformance claims of PPs:

- a) shall state the edition of the relevant parts of the ISO/IEC 15408 series to which the PP claims conformance;

b) shall describe the conformance to ISO/IEC 15408-2 as either:

— *“ISO/IEC 15408-2 conformant”*;

A PP is ISO/IEC 15408-2 conformant if all SFRs in that PP are based only upon functional components in ISO/IEC 15408-2; or

— *“ISO/IEC 15408-2 extended”*.

A PP is ISO/IEC 15408-2 extended if at least one SFR in that PP is not based upon functional components in ISO/IEC 15408-2;

c) shall describe the conformance to ISO/IEC 15408-3 as either;

— *“ISO/IEC 15408-3 conformant”*;

A PP is ISO/IEC 15408-3 conformant if all SARs in that PP are based only upon assurance components in ISO/IEC 15408-3; or

— *“ISO/IEC 15408-3 extended”*.

A PP is ISO/IEC 15408-3 extended if at least one SAR in that PP is not based upon assurance components in ISO/IEC 15408-3;

d) may also include a conformance claim with respect to other PPs:

— *“PP Conformant”*;

A PP is “PP Conformant” when it meets other specific PP(s).

e) may include a package conformance claim;

More than one package may be claimed in a PP.

If a package claim is made, it shall consist of one of the following statements for each package claim:

— *“Package Conformant”*;

A PP is conformant to a package if:

- for functional packages, all constituent parts (SPD, security objectives, and SFRs) of the functional package are present in the corresponding parts of the PP without modification;
- for assurance packages, the SARs of that PP are identical to the SARs in the assurance package;
- a PP that restricts some selections of SFRs in a package may still claim it is package conformant.

— *“Package Augmented”*;

A PP claims an augmentation of a package if:

- for functional packages, all constituent parts (SPD, security objectives, and SFRs) of that PP contain all constituent parts given in the functional package but shall have at least one additional SFR or one SFR that is hierarchically higher than an SFR in the functional package;

- for assurance packages, the SARs of that PP contain all SARs in the assurance package, but have at least one additional SAR or one SAR that is hierarchically higher than an SAR in the assurance package.
- “*Package Tailored*”.

A PP claims tailoring of a package if:

- for functional packages, all constituent parts (SPD, Security Objectives, and SFRs) of that PP contain all constituent parts given in the functional package, but shall have additional selection items for an SFR with existing selections in the package, and optionally, at least one additional SFR and/or one SFR that is hierarchically higher than an SFR in the functional package;
- assurance packages and STs shall not claim (or perform) tailoring.

More than one package may be claimed in a PP.

Where PPs claim strict or demonstrable conformance to PP(s) they shall not also claim conformance to the packages claimed in the PPs they claim conformance to, unless the PP augments the package. The PP claims <package>-augmented only in the case where the PP augments the packages beyond that claimed by the PP to which it claims conformance to.

NOTE 1 PPs cannot claim exact conformance to PP(s).

- f) PPs shall contain a conformance claim rationale;

The conformance claim rationale describes the reasons and the logical basis for the authors choice of conformance claims and statement.

- g) PPs shall provide a conformance statement.

The conformance statement shall describe the manner in which other PPs or STs shall conform to this PP: The conformance statement shall be one of:

- “*Exact conformance*”;

If the PP states that exact conformance is required, a ST shall conform to the PP in an exact manner, i.e. a conformant ST shall contain SPD and objectives identical to the PP's, and the same set of PP's SFRs with all the assignments and selections resolved;

- “*Strict conformance*”;

If the PP states that strict conformance is required, a PP/ST shall conform to the PP in a strict manner, i.e. a conformant PP/ST shall contain a superset of PP's SPD, objectives and SFRs, where the new assumptions (if any) do not weaken the PP's SPD, and all the PP's SFRs have their assignments and selections unchanged or where appropriate, resolved;

Strict conformance allows the conformant PP/ST not to add any element to the PP's SPD, set of objectives and SFRs, i.e. the superset defined in the PP/ST may be identical to the PP's, with all the SFRs resolved;

- “*Demonstrable conformance*”.

If the PP states that demonstrable conformance is required, the PP/ST shall conform to the PP in a strict or demonstrable manner, i.e. a conformant PP/ST shall contain a SPD, set of objectives and set of SFRs that are equivalent to a superset of PP's SPD, objectives and SFRs, where the new assumptions (if any) do not weaken the PP's SPD, and where the set of the conformant PP/ST SFRs imply the PP's SFRs.

Demonstrable conformance allows the conformant PP/ST to use different but equivalent statements, and it allows as well to simply define a superset as in the strict conformance case, without changing the statements given in the PP.

NOTE 2 In other words, a PP/ST is only allowed to conform to a PP in a demonstrable manner if the PP explicitly allows this.

NOTE 3 PP-Modules and PP-Configurations cannot claim conformance to a PP. For more information, see 11.2 and 11.3.

The conformance statement may also include a reference to any evaluation methods/ activities that have been derived from ISO/IEC 18045. If evaluation methods/ evaluation activities that have been derived from ISO/IEC 18045 are to be used to evaluate the PP then these shall be identified with the relevant security requirement section by including a statement in the following form:

“This PP requires the use of evaluation methods/ evaluation activities defined in <reference(s)>.”

In this statement, <reference> is replaced by the identification of the location of the relevant evaluation methods and evaluation activities. This reference may be to the document containing the PP or to one or more separate documents.

NOTE 4 Either a PP/ST conforms to a PP or it does not. The ISO/IEC 15408 series does not recognize “partial” conformance. It is therefore the responsibility of the PP author to ensure the PP is not overly onerous, prohibiting PP/ST authors from claiming conformance to the PP. For more information on the conformance statements and claims for PPs, see Annex B.

10.4 Security assurance requirements (SARs)

A PP which is in accordance with ISO/IEC 15408-3 (possibly extended) shall define the set of SARs that applies to the entire TOE.

A PP may define a distinctive name for the set of SARs that are applicable. However, if the set of SARs is an (augmented) pre-defined EAL (EAL1 to EAL7) or an (augmented) assurance package defined in an applicable external reference, then the same name shall be used.

NOTE Pre-defined EAL's are given in ISO/IEC 15408-5.

10.5 Additional requirements common to strict and demonstrable conformance

10.5.1 Conformance claims and conformance statements

If a PP/ST claims either strict or demonstrable conformance to multiple PPs, it shall conform to each PP in the manner stated by that PP; that is, either strictly or demonstrably, i.e. the PP/ST may conform strictly to some PPs and demonstrably to other PPs.

A PP/ST conforms to a PP if the PP/ST is equivalent or more restrictive than this PP, that is, if:

- all TOEs that meet the PP/ST also meet the PP;
- all operational environments that meet the PP also meet the PP/ST.

In other words, the PP/ST shall levy the same or more requirements on the TOE and the same or less conditions on the operational environment of the TOE.

This general statement holds for the different constructs of the PP/ST, namely the SPD, the security objectives for the TOE, the security objectives for the environment, and the security functional and SARs.

10.5.2 Security problem definition (SPD)

The conformance rationale in the PP/ST shall demonstrate that the SPD in the PP/ST is equivalent or more restrictive than the SPD in the PP, i.e.:

- all TOEs that meet the SPD in the PP/ST also meet the SPD in the PP;

- all operational environments that meet the SPD in the PP also meet the SPD in the PP/ST.

10.5.3 Security objectives

The conformance rationale in the PP/ST shall demonstrate that the security objectives in the PP/ST are equivalent or more restrictive than the security objectives in the PP, i.e.:

- TOEs that meet the security objectives for the TOE in the PP/ST also meet the security objectives for the TOE in the PP;
- operational environments that meet the security objectives for the operational environment in the PP also meet the security objectives for the operational environment in the PP/ST.

10.6 Additional requirements specific to strict conformance

10.6.1 Requirements for the security problem definition (SPD)

The PP/ST shall contain the SPD of the PP and may specify additional threats and OSPs; it shall contain all assumptions as defined in the PP, with two possible exceptions as explained in the next two bullets:

- an assumption (or a part of an assumption) specified in the PP may be omitted from the PP/ST if all security objectives for the operational environment defined in the PP addressing this assumption (or this part of an assumption) are replaced by security objectives for the TOE in the PP/ST;
- a new assumption may be added in the PP/ST to the set of assumptions defined in the PP, if this new assumption does not mitigate a threat (or part of a threat) meant to be addressed by security objectives for the TOE in the PP and if this assumption doesn't fulfil an OSP (or a part of an OSP) meant to be addressed by security objectives for the TOE in the PP.

10.6.2 Requirements for the security objectives

The PP/ST:

- shall contain all security objectives for the TOE of the PP but may specify additional security objectives for the TOE;
- shall contain all security objectives for the operational environment as defined in the PP with two exceptions as explained in the next two bullet points;
- may specify that certain security objectives for the operational environment in the PP are security objectives for the TOE in the PP/ST. This is called re-assigning a security objective. If a security objective is re-assigned to the security objectives for the TOE, the security objectives justification has to make clear which assumption/OSP or part of the assumption/OSP is no longer necessary;
- may specify additional security objectives for the operational environment, if these new objectives do not mitigate a threat (or part of a threat) meant to be addressed by security objectives of the TOE in the PP and if these new objectives do not fulfil an OSP (or a part of an OSP) meant to be addressed by security objectives of the TOE in the PP.

10.6.3 Requirements for the security requirements

The PP/ST:

- shall contain all SFRs and SARs in the PP;
- may claim additional or hierarchically stronger SFRs and SARs. The completion of operations in the ST shall be internally consistent with that in the PP; either the same completion will be used in the PP/ST as that in the PP or one that makes the requirement more restrictive.

NOTE The rules of refinement apply.

10.7 Additional requirements specific to demonstrable conformance

Demonstrable conformance allows a PP author to describe a common security problem to be solved and provide generic guidelines to the requirements necessary for its resolution, in the knowledge that there is likely to be more than one way of specifying a resolution.

The PP/ST shall contain a rationale on why the PP/ST is considered to be “equivalent or more restrictive” than the PP.

10.8 Additional requirements specific to exact conformance

10.8.1 General

Exact conformance is used when a PP author needs to control what a ST may claim conformance to with respect to the PP that they have written. It is used in cases where the PP author requires that STs which claim conformance to the PP do not include additional SPD, security objectives or requirements that have not been considered by the PP author.

A PP that requires exact conformance in its conformance statement may define optional SFRs and any SPD-elements that are required to support these SFRs. A ST (or PP-Module) may then include these optional SFRs (and any required SPD elements) in its set of requirements while maintaining its exact conformance claim.

A PP with exact conformance type shall not claim conformance to any other PPs of any conformance type. A PP with exact conformance type shall not be included in a PP-Configuration which also includes PPs or PP-Modules with strict or demonstrable conformance type.

NOTE It is impossible to claim conformance to both a strict/demonstrable conformance PP and an exact conformance PP, since it would mean adding requirements or SPD-elements to the exact conformance PP, which explicitly prohibits this operation.

In the “simple” case where a ST claims exact conformance to a PP, there is no ambiguity whether the ST is exactly conformant or not because the correspondence between the SPD, security objectives, SFRs, and SARs is demonstrated during evaluation without the need to seek PP author input.

However, other cases are allowed where multiple sets of SPD-elements, security objectives, and SFRs may be combined, these cases require mechanisms that preserve the ability of the exact conformance PP authors to control a conformance claim against their PP. These mechanisms are described in the following subclauses.

EXAMPLE A complex case can be if a PP-Module aims to use a PP as its base PP, or if a ST claims conformance to two PPs.

If a PP requires exact conformance, then only those SFRs and SARs specified by that PP are allowed in the conformant ST. These security requirements are related to the SPD and security objectives specified in the PP, which are also included in the conformant ST. SFRs in an exact conformance PP can be iterated and refined (as stated in ISO/IEC 18045 for ASE_CCL.1-12).

10.8.2 Conformance claims and statements

If a PP requires exact conformance in its conformance statement, then

- a) the PP shall include an allowed-with statement that states which other PPs and PP-Modules are allowed to be included in a conformance claim along with the PP;
- b) all the additional PPs to which a ST may claim exact conformance shall also have an exact conformance requirement;
- c) all of the additional PPs an ST is claiming conformance to shall identify the PP in their respective allowed-with statements;

- d) all of the additional PP-Modules claimed through a PP-Configuration shall identify the PP in their respective allowed-with statements.

A PP-Module does not have to identify its own base PPs/PP-Module(s) in its conformance statement, however, the PP-Module Base shall be identified in its PP-Module introduction.

10.9 Using PPs

If a PP/ST claims to be conformant to one or more PPs and possibly one or more packages, the evaluation of that PP/ST will include a demonstration that the PP/ST actually conforms to the claimed PPs and/or packages. Details of this determination of conformance are found in Annex A and Annex B.

This allows the following process:

- an organization seeking to acquire a particular type of IT security product develops their security needs into a PP, then has this PP evaluated and publishes it;
- a developer takes this PP, writes a ST that claims conformance to the PP and has this ST evaluated;
- the developer then builds a TOE (or uses an existing one) and has this evaluated against the ST.

The result is that the evaluated TOE meets the requirements of the organization as defined in the PP and that the organization can therefore have confidence that the TOE meets their security needs. A similar line of reasoning applies to packages.

10.10 Conformance statements and claims in the case of multiple PPs

10.10.1 General

The ISO/IEC 15408 series allows both STs and PPs to claim conformance to multiple PPs. The case for a ST claiming conformance to multiple PPs is covered in 11.3.3. 10.10 covers the case where a PP claims conformance to multiple PPs.

10.10.2 Where strict or demonstrable conformance is specified

Allowing a PP to claim conformance to multiple PPs permits chains of PPs to be constructed, each PP in the chain is based on the previous PP(s).

EXAMPLE PPs for an Integrated Circuit and for a Smart Card OS, can be used to construct a Smart Card PP (IC and OS) that claims conformance to both. In turn, this Smart Card PP can be used to develop specific PPs for different use cases, e.g. tachograph card, payment card, electronic passport, etc. A developer can then construct a ST conformant to any of those PPs.

10.10.3 Where exact conformance is specified

A PP shall not claim exact conformance to another PP or combination of PPs.

NOTE In cases where such a combination of functionality is needed, this can be achieved by creating a PP-Configuration that consists of the PPs to which conformance is desired to be claimed.

11 Modular requirements construction

11.1 General

In order to allow a modular description of the TOE's security features, STs can claim conformance to a PP-Configuration instead of PPs. Such PP-Configurations are composed of a set of PPs and PP-Modules which contains the PP-Module Base(s).

PP-Configurations can be constructed to accommodate either single-assurance or multi-assurance evaluations. In a single-assurance evaluation, a single set of assurance requirements applies to all the components of the PP-Configuration. In a multi-assurance evaluation, there is a single global set of assurance requirements that applies to all the components of the PP-Configuration, but additionally each component (PP or PP-Module) has its own set of assurance requirements to which it is subject. The following subclauses present the content-related details for these two evaluation approaches; the actual evaluation particulars using these approaches is discussed in Clause 13.

11.2 PP-Modules

11.2.1 General

A PP-Module is an internally consistent set of SPD-elements, security objectives for the TOE and the operational environment, and SFRs, defined in the context of one or more PPs and possibly other PP-Modules.

Unlike PPs, PP-Modules address those security features of a given TOE type that cannot be required uniformly for all products of this TOE type.

Unlike PPs, PP-Modules shall be used only in PP-Configurations. A PP/ST cannot claim conformance with a PP-Module directly.

EXAMPLE Examples of features that cannot be required uniformly for all products within a TOE type are authentication using biometrics, Bluetooth security functions, and Wireless Local Area Network clients.

11.2.2 PP-Module Base

A given PP-Module specifies one or several PP-Module Base(s) consisting of a set of PPs and possibly other PP-Modules. Anytime the given PP-Module is used in a PP-Configuration, one of its PP-Module Base(s) is required. See Clause 10 and Annex B.

11.2.3 Requirements for PP-Modules

11.2.3.1 General

A PP-Module shall be identified with a reference identifier.

The reference identifier for a PP-Module shall be unique within a catalogue.

A PP-Module shall define one or several PP-Module Base(s) which may be required to be used with the PP-Module in a PP-Configuration.

A PP-Module shall specify the TOE types relative to each of its PP-Module Bases.

A PP-Module may introduce new SPD-elements and objectives and may also refine some of the SPD-elements or objectives of its PP-Module Bases.

A PP-Module shall define a non-empty set of SFRs that are refinement of the SFRs of the PP-Module Bases or new.

A ST that claims conformance to a PP-Configuration including a given PP-Module shall then include the PP-Module SPD-elements, security objectives and SFRs, combined with those of the PP-Module Base that belong to the PP-Configuration.

NOTE 1 The TOE type defined in the PP-Module can supplement the TOE type defined in each of its PP-Module Bases.

A PP-Module shall provide a consistency rationale ensuring that the union of the elements defined in the PP-Module and in each of its PP-Module Bases do not lead to contradiction.

NOTE 2 In a Direct Rationale PP-Module, security objectives for the TOE are not included.

The evaluation of a PP-Module alone is meaningless. A PP-Module shall be evaluated as part of a PP-Configuration, at least with one PP-Module Base.

Further information on PP-Modules is given in C.1.

11.2.3.2 Direct Rationale

A PP-Module may use the Direct Rationale approach, provided that its PP-Module Base(s) also use the Direct Rationale approach.

11.2.3.3 Conformance claims and conformance statements

In this subclause the use of italic text indicates literal text that shall appear in the text of the PP-Module.

The conformance claims of a PP-Module:

- a) shall state the edition of relevant parts of the ISO/IEC 15408 series to which the PP-Module claims conformance;
- b) shall describe the conformance to ISO/IEC 15408-2 as either:

— “*ISO/IEC 15408-2 conformant*”;

NOTE 1 A PP-Module is ISO/IEC 15408-2 conformant if all SFRs in that PP-Module are based only upon functional components in ISO/IEC 15408-2.

or

— “*ISO/IEC 15408-2 extended*”.

NOTE 2 A PP-Module is ISO/IEC 15408-2 extended if at least one SFR in that PP-Module is not based upon functional components in ISO/IEC 15408-2.

- c) may include a conformance claim made with respect to functional packages. More than one functional package may be claimed by a PP-Module;

NOTE 3 A PP-Module does not claim conformance to a functional package that is already claimed by one of the PPs or PP-Modules in the PP-Module Bases. The exception to this rule is when the PP-Module augments or tailors the functional package as it is instantiated in its PP-Module Base; in this case the PP-Module would claim the functional package as “Package Augmented” or “Package Tailored” (as appropriate) in its package conformance claim statement.

If a functional package claim is made, it shall consist of one of the following claims for each package:

— “*Package Conformant*”;

A PP-Module is conformant to a package if all constituent parts of the functional package, including the SPD, security objectives, and SFRs, of that functional package are present in the corresponding parts of the PP-Module without modification;

— “*Package Augmented*”;

A PP-Module claims an augmentation of a package if all constituent parts of the functional package, including the SPD, security objectives, and SFRs, contained in the PP-Module are identical to those given in the functional package, but shall also contain at least one SFR that is either additional or hierarchically higher than an SFR in the functional package;

— *“Package Tailored”.*

A PP-Module claims tailoring of a package if all constituent parts of the functional package, including the SPD, Security Objectives, and SFRs, contained in the PP-Module are identical to those given in the functional package, but shall have additional selection items for an SFR with existing selections in the package, and optionally, at least one additional SFR and/or one SFR that is hierarchically higher than an SFR in the functional package;

- d) shall include a conformance claim in respect to ISO/IEC 15408-3. The conformance claim to ISO/IEC 15408-3 shall be either:

— *“ISO/IEC 15408-3 conformant”;*

A PP-Module is ISO/IEC 15408-3 conformant if all SARs in that PP-Module are based only upon assurance components in ISO/IEC 15408-3.

or

— *“ISO/IEC 15408-3 extended”.*

A PP-Module is ISO/IEC 15408-3 extended if at least one SAR in that PP-Module is not based upon assurance components in ISO/IEC 15408-3;

- may include a conformance claim made with respect to assurance packages. More than one assurance package may be claimed by a PP-Module. Overlap between the claimed assurance packages is allowed; by construction the hierarchically higher SAR takes precedence over the other and is applied in the PP-Configuration.

In the strict and demonstrable cases, a PP-Module may claim conformance to more than one assurance package, for instance an ALC-based package and an ADV-based package.

If a package claim is made, it shall consist of one of the following claims for each package:

— *“Package Conformant”;*

A PP-Module is conformant to an assurance package if all constituent parts of the assurance package are present in the PP-Module without modification;

— *“Package Augmented”.*

A PP-Module claims an augmentation of an assurance package if all constituent parts of the assurance package contained in the PP-Module are identical to those given in the assurance package, but shall also contain at least one SAR that is either additional or hierarchically higher than those SARs contained in the package;

The conformance statement of a PP-Module:

- e) shall provide a conformance statement which describes the manner in which STs shall conform to this PP-Module as part of a PP-Configuration. The conformance statement shall be one of:

— *“Exact conformance”;*

The PP-Module shall require exact conformance if and only if all its PP-Module Base(s) are of exact conformance. A ST shall conform to the PP-Module, as part of a PP-Configuration, in an exact manner. Additionally:

- the allowed-with Statement shall state which other PPs and PP-Modules (which are not in the set of PP-Module Bases) are allowed to be used in a PP-Configuration with that PP-Module;
- each PP and PP-Module in the PP-Module Base for the PP-Module being defined, and all of the additional PPs and PP-Modules (that are not in the PP-Module Base) that are allowed to

be specified with the PP-Module in a PP-Configuration, shall identify the PP-Module being defined in their respective allowed-with statements.

— all of the referenced PP-Module Bases shall also require exact conformance.

— “*Strict conformance*”;

If the PP-Module states that strict conformance is required, a ST shall conform to the PP-Module, as part of a PP-Configuration, in a strict manner;

— “*Demonstrable conformance*”.

If the PP-Module states that demonstrable conformance is required, the ST shall conform to the PP-Module, as part of a PP-Configuration, in a strict or demonstrable manner. A ST is only allowed to conform to a PP-Module, as part of a PP-Configuration, in a demonstrable manner if the PP-Module explicitly allows this;

NOTE 1 A PP-Module can require strict or demonstrable conformance although its PP-Module Base(s) do not all require strict or demonstrable conformance. The combination of demonstrable and strict conformance will be validated in the PP-Configuration evaluation.

NOTE 2 The explicit declaration of strict or demonstrable conformance allows sponsors to make the most appropriate statement in each PP-Module, independently of its PP-Module Base(s).

NOTE 3 PP-Module Base(s) do not need to be specified in the PP-Modules’ conformance statement.

f) may also include a reference to any evaluation methods/ activities that have been derived from ISO/IEC 18045.

If evaluation methods/ evaluation activities that have been derived from ISO/IEC 18045 are to be used to evaluate the PP-Module, then these shall be identified with the relevant security requirement section by including a statement in the following form:

“This PP-Module requires the use of evaluation methods/ evaluation activities defined in <reference(s)>.”

In this statement, <reference> is replaced by the identification of the location of the relevant evaluation methods and evaluation activities. This reference may be to the document containing the PP-Module, or to one or more separate documents.

For more information and requirements on the conformance types, claims and statements for PP-Modules, Annex C shall be used in conjunction with the clauses of this document.

11.2.3.4 Assurance requirements

A PP-Module shall define the set of SARs that applies to the TSF defined in the PP-Module, which can be either inherited from the PP-Module Base(s) or explicitly declared by the PP-Module author.

A PP-Module may define a distinctive name for its set of SARs. However, if the PP-Module declares an (augmented) pre-defined EAL (EAL1 to EAL7) or an (augmented) assurance package defined in an applicable external reference or inherits the set of SARs from its PP-Module Base(s), then the same name shall be used.

A PP-Module shall provide an assurance rationale that justifies the internal consistency of its set of SARs, i.e.:

- the consistency of the set of SARs with regard to the threat model as defined in the SPD of the PP-Module;
- if the PP-Module does not inherit its set of SARs from its PP-Module Base(s), the consistency of the set of SARs with all the sets of SARs defined in the PP-Module Base(s) of the PP-Module.

NOTE 1 Consistency refers to the absence of contradiction. An example of an inconsistency between SARs and SPD would be to consider highly skilled threat agents together with a low AVA_VAN level that cannot consider these threat agents by definition.

NOTE 2 The PP-Module assurance rationale ensures that the set of SARs defined in the PP-Module does not undermine the security that is expected for the assets that are shared between the PP-Module and its PP-Module Base(s) (if shared assets exist).

NOTE 3 The assurance rationale at PP-Module level contributes but is not sufficient to ensure the consistency of the assurance requirements at PP-Configuration level. See 11.3.2.4.

NOTE 4 The assurance rationale can rely on the relationship of the set of SARs in the PP-Module with the pre-defined EALs to demonstrate the internal consistency.

11.3 PP-Configurations

11.3.1 General

A PP-Configuration is a specification for the construction of a set of requirements to which conformance can be claimed.

A PP-Configuration is intended to describe a general TOE type. A PP-Configuration:

- may be used as a ST template for any TOEs that meet the PP-Configuration's TOE type;
- cannot be used as a template for other PP-Configurations, PPs or PP-Modules.

A PP-Configuration contains a set of PPs and PP-Modules (the PP-Configuration components) and cannot claim conformance to any functional packages, except indirectly through its PPs/PP-Modules. PP-Configurations may contain SARs and claim conformance to assurance packages.

Two types of PP-Configurations are identified, each has different requirements for their construction and are applicable depending on the needs of the consumer (risk owner). These are:

- Single Assurance PP-Configuration: This describes a configuration type in which the set of SARs that apply to the PP-Configuration's components are identical.
- Multi Assurance PP-Configuration: This describes a configuration type in which the SARs in the PP-Configuration components are not identical.

11.3.2 Requirements for PP-Configurations

11.3.2.1 General

A PP-Configuration shall be identified with a reference.

The reference identifier for a PP-Configuration shall be unique within a catalogue.

A PP-Configuration shall define the PP-Configuration components statement, a list that uniquely identifies all the PPs and PP-Modules that compose, by reference, the PP-Configuration. A PP-Configuration shall contain one PP and at least another PP-Configuration component. It may contain a PP-Module provided one of the PP-Module Bases are also included in the PP-Configuration. It may contain PPs that have no associated PP-Module.

A PP-Configuration shall define the TOE type to which it applies.

A PP-Configuration contains exactly, by reference, the SPD, security objectives, SFRs, and functional packages defined in its components; the specification of any additional element shall be done in one of its components.

A PP-Configuration shall provide a consistency rationale ensuring that the union of the elements defined in its components do not lead to contradiction.

A multi-assurance PP-Configuration shall describe the organization of the TSF in terms of the sub-TSFs that are defined in its components and shall define for each sub-TSF a set of SARs that is consistent with the corresponding component.

NOTE In the case of a multi-assurance PP-Configuration containing one PP and one PP-Module with different sets of SARs, the TSF organization is the following: the TSF is the union of the SFRs defined in the PP and in the PP-Module, and there are two sub-TSFs, which consist of the PP's TSF and the PP-Module's TSF. The same organization holds for a PP-Configuration composed of two PPs, which define the two sub-TSFs.

The sub-TSFs contained in a multi-assurance PP-Configuration may have some overlap. This does not impact on the applicable assurance requirements: Each sub-TSF shall be evaluated against its own set of SARs. This means that the overlapping parts may be evaluated against multiple sets of assurance requirements.

A PP-Configuration:

- may be used in context with the Direct Rationale approach described in B.5 and C.2.3. In this case, all of the components of the PP-Configuration shall also use the Direct Rationale approach;
- shall not contain any additional content beyond that described in this document.

11.3.2.2 Components statement

A PP-Configuration:

- shall identify all the components of the PP-Configuration in a components statement. The components statement shall contain one PP and at least another component;

NOTE 1 The components statement is further described in C.3.3.

- shall not claim conformance to another PP-Configuration;

NOTE 2 If this is desired, the effect can be achieved by directly including all components from both PP-Configurations in one new defined PP-Configuration, where exact conformance can be checked and maintained.

- shall include the PP-Module Bases of all the PP-Modules included in the PP-Configuration. If a PP-Module defines alternative sets of PP-Module Bases, then only one of these sets shall be used in a PP-Configuration;
- may select more PPs than the PP-Module Base of the PP-Modules;
- for single-assurance PP-Configurations, may identify the sub-TSF that corresponds to each component defined by the PP-Configuration;
- for multi-assurance PP-Configurations, shall identify the sub-TSF that corresponds to each component defined by the PP-Configuration.

For a PP-Configuration that requires exact conformance, all PP-Configuration components shall specify each other in their respective allowed-with statements.

An exception to listing in the allowed-with statement is that a PP-Module shall not list any PPs or PP-Modules contained in its PP-Module Base in its allowed-with statement (because they are explicitly allowed by virtue of the fact that they are a base for the PP-Module).

11.3.2.3 Conformance claims and conformance statement

In this subclause the use of italic text indicates literal text that shall appear in the text of the PP-Configuration.

i

The conformance claims of a PP-Configuration:

- a) shall state the edition of the relevant parts of the ISO/IEC 15408 series to which the PP-Configuration components claim conformance.
- b) shall describe the conformance to ISO/IEC 15408-2 (SFRs) as either:
 - *“ISO/IEC 15408-2 conformant”*;
 A PP-Configuration is ISO/IEC 15408-2 conformant if all the PPs and PP-Modules in the PP-Configuration are ISO/IEC 15408-2 conformant.
 or
 - *“ISO/IEC 15408-2 extended”*.
 A PP-Configuration is ISO/IEC 15408-2 extended if at least one PP or PP-Module is not based upon functional components in ISO/IEC 15408-2.
- c) shall describe the conformance to ISO/IEC 15408-3 (security assurance requirements) as either:
 - *“ISO/IEC 15408-3 conformant”*;
 A PP-Configuration is ISO/IEC 15408-3 conformant if all SARs in that PP-Configuration, which may be simply inherited from its components, are based only upon assurance components in ISO/IEC 15408-3; or
 - *“ISO/IEC 15408-3 extended”*.
 A PP-Configuration is ISO/IEC 15408-3 extended if at least one SAR in that PP-Configuration, which may be simply inherited from its components, is not based upon assurance components in ISO/IEC 15408-3.
- d) may include an assurance package conformance claim;

More than one package may be claimed in a PP-Configuration. If an assurance package claim is made, it shall consist of one of the following statements for each package claim:

 - *“Package Conformant”*;
 A PP-Configuration is conformant to an assurance package if the SARs of that PP-Configuration, which may be inherited from its components, are identical to the SARs in the assurance package.
 - *“Package Augmented”*.
 A PP-Configuration claims an augmentation of an assurance package if: the SARs of that PP-Configuration, which may be inherited from its components, contain all SARs in the assurance package, but have at least one additional SAR or one SAR that is hierarchically higher than an SAR in the assurance package.
- e) shall not include a functional package conformance claim. Functional packages may be claimed by the components of the PP-Configuration;
- f) shall not include a conformance claim with respect to other PP-Configurations, PPs or PP-Modules;

The PP-Configuration shall provide a conformance statement which describes the manner in which STs shall conform to this PP-Configuration:

- g) for a PP-Configuration where all its PPs and PP-Modules are of the same conformance type, the conformance statement shall provide a single conformance type, that is one of:

— “Exact conformance”;

If the PP-Configuration states that exact conformance is required, a ST shall conform to the PP-Configuration in an exact manner.

— “Strict conformance”;

If the PP-Configuration states that strict conformance is required, a ST shall conform to the PP-Configuration in a strict manner.

— “Demonstrable conformance”.

If the PP-Configuration states that demonstrable conformance is required, a ST shall conform to the PP-Configuration in a strict or demonstrable manner.

- h) for a PP-Configuration where the PPs and PP-Modules do not require all the same conformance type, the conformance statement shall provide the list of the conformance types that are required by each of the PPs and PP-Modules composing the PP-Configuration. A ST shall conform to the PP-Configuration by conforming to each of the PPs and PP-Modules in the manner they require.

NOTE This applies only to strict and demonstrable conformance, since the combination of exact conformance with other types of conformance is not allowed in a PP-Configuration.

The compatibility of the multiple conformance shall be validated in the ST evaluation, in the same manner as when a ST claims conformance to several PPs that require different conformance.

- i) may also include a reference to any evaluation methods/ activities that have been derived from ISO/IEC 18045. If evaluation methods/ activities that have been derived from ISO/IEC 18045 are associated with the PP-Configuration, then the conformance statement shall also include a statement in the following form:

“This PP-Configuration requires the use of evaluation methods/ evaluation activities defined in <reference>.”

In this statement, <reference> is replaced by the identification of the location of the relevant evaluation methods and evaluation activities. This reference may be to the PP-Configuration itself, or to one or more separate documents.

NOTE 1 Specification of additional EMs/EAs that apply to one or more PP-Configuration components is only allowed for PP-Configurations of strict or demonstrable conformance type.

NOTE 2 There are implications for conformance statements in PP-Modules in the exact conformance case that are covered in C.2.2.5.

11.3.2.4 Assurance requirements

A PP-Configuration shall provide a SAR statement where the applicable assurance requirements and associated rationale are defined.

A single-assurance PP-Configuration shall define a single set of SARs for all the PP-Configuration components. In the exact conformance case, this set of SARs shall be identical to those declared in the individual PP-Configuration components. In the strict and demonstrable conformance case, this set of SARs shall be identical to or augment those declared in the individual PP-Configuration components.

A multi-assurance PP-Configuration shall define:

- The global set of SARs that applies to the entire TOE. In the exact conformance case, this set of SARs shall be identical to the common subset of SARs in the individual PP-Configuration components. In the strict and demonstrable conformance case, this set of SARs shall be identical to or augment the common subset of SARs in the individual PP-Configuration components;
- For each sub-TSF, the set of SARs that applies. In the exact conformance case, this set of SARs shall be identical to the set of SARs declared in the PP-Configuration component for the sub-TSF. In the strict and demonstrable conformance case, this shall be identical to or augment the set of SARs declared in the PP-Configuration component for the sub-TSF.

A PP-Configuration may use the pre-defined EALs (EAL1 to EAL7) given in ISO/IEC 15408-5, assurance packages defined in external references and/or SARs defined within the PP-Configuration itself to define its SAR statement.

NOTE 1 The multi-assurance evaluation allows applying multiple pre-defined EALs. However, for the same reasons as for PPs in the general model, PP-Configurations can claim sets of SARs that are different from pre-defined EALs and/or that contain extended SARs.

A PP-Configuration may define distinctive names for the sets of SARs that apply to the entire TOE and to each sub-TSF. However, the use of an (augmented) pre-defined EAL or an (augmented) assurance package defined in one of the PP-Configuration's components or in another external reference requires the usage of the same name.

A multi-assurance PP-Configuration shall provide an assurance rationale for:

- the consistency of the global set of SARs with regard to the threat models as defined in the SPDs of the PPs and PP-Modules in the PP-Configuration;
- the consistency of the global set of SARs and all the sets of SARs for the sub-TSF with each other.

In constructing the global set of SARs for the exact conformance case, the multi-assurance PP-Configuration author chooses the hierarchically lowest SAR if sub-TSFs specify hierarchically different SARs. For example, if there are three sub-TSFs with ADV_FSP.1, ADV_FSP.2 and ADV_FSP.3, respectively, then the global set of SARs would contain ADV_FSP.1. However, if one of the sub-TSFs did not contain an ADV_FSP component, then ADV_FSP would not be in the global set of SARs. For a strict/demonstrable case, the multi-assurance PP-Configuration author may choose ADV_FSP.1 or a higher component thus augmenting the assurance requirements for some of its sub-TSFs (even in the case when a sub-TSF does not define any ADV_FSP component) provided the assurance rationale is consistent.

NOTE 2 In most cases (and always in the exact conformance case), the global set of SARs can be built as the common set of SARs that apply to all of the sub-TSFs. However, as it is the case with STs in the general model, the PP-Configuration (of strict or demonstrable conformance type) can require additional or higher SARs. The evaluation of the PP-Configuration ensures the consistency of the claim, similar to the general model for the conformance with two or more PPs defining different sets of SARs, and similar to the approach for a multi-assurance ST which can extend the sets of SARs defined in the PP-Configuration the ST claims conformance to.

NOTE 3 A PP-Configuration cannot claim less assurance requirements as the global set of SARs/assurance package than those contained in the common set of SARs that apply to all of the sub-TSFs.

NOTE 4 The PP-Configuration assurance rationale contributes to ensuring that the multiple sets of SARs do not undermine the security expected for the assets that are shared between the PPs and PP-Modules in the PP-Configuration. The PP-Configuration assurance rationale relies on and/or reuses the assurance rationales given in the PPs and PP-Modules.

For exact conformance type PP-Configurations, augmentation of the SARs for each sub-TSF (by the PP-Configuration) is not allowed.

If additional SARs are specified, or SARs are replaced with hierarchically higher SARs then any derived evaluation methods / evaluation activities required by the components of the PP-Configuration shall be

addressed in the assurance rationale to demonstrate that the evaluation methods / evaluation activities required by the PP-Configuration:

- are still adequate, i.e. the new SAR has no effect on the EMs/EAs in the components and the assurance that they provide; or
- have been addressed by defined refinements to the original EMs/EAs in the components so that the resulting EMs/EAs required for the PP-Configuration generate assurance that is the same or higher than the original EMs/EAs applied to the components; or
- have been supplemented by additional EMs/EAs to so that the resulting EMs/EAs generate assurance that is the same or higher than the original EMs/EAs applied to the components.

EXAMPLE 1 An activity that was an examination of documentation for a lower SAR but where additional testing might be needed for a hierarchically higher SAR can supplement the original documentation evaluation activities with additional evaluation activities that require testing.

EXAMPLE 2 Figure 5 shows an example of multi-assurance PP-Configuration with one PP, A, and two PP-Modules, X and Y. It illustrates the default construction of the global set of SARs for the entire TOE, which consists of SAR_C, i.e. the common set of SARs of each of the PP-Configuration components A, X and Y. In the example, the sets of SARs that apply to the sub-TSFs defined in A, X and Y are unchanged as well.

NOTE 5 The rules allow the augmentation of the sets of SARs.

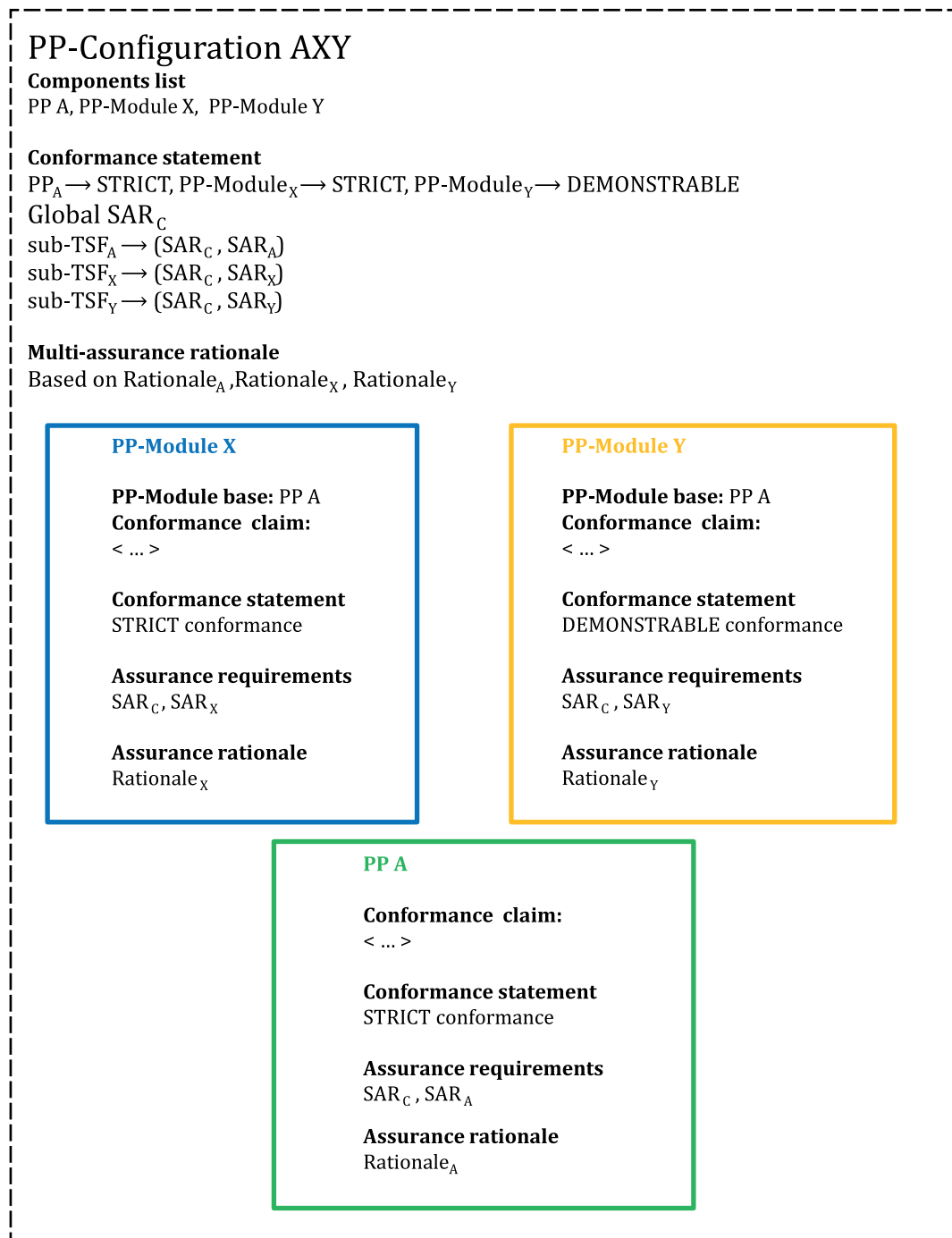


Figure 5 — Example of PP-Configuration

11.3.3 Usage of PP-Configurations

Figure 6 shows the usage of single and multi-assurance PP-Configurations. Figure 7 gives the detail of PP-Configuration components. Figure 8 shows the assurance classes that are used for evaluating PPs, PP-Configurations and STs.

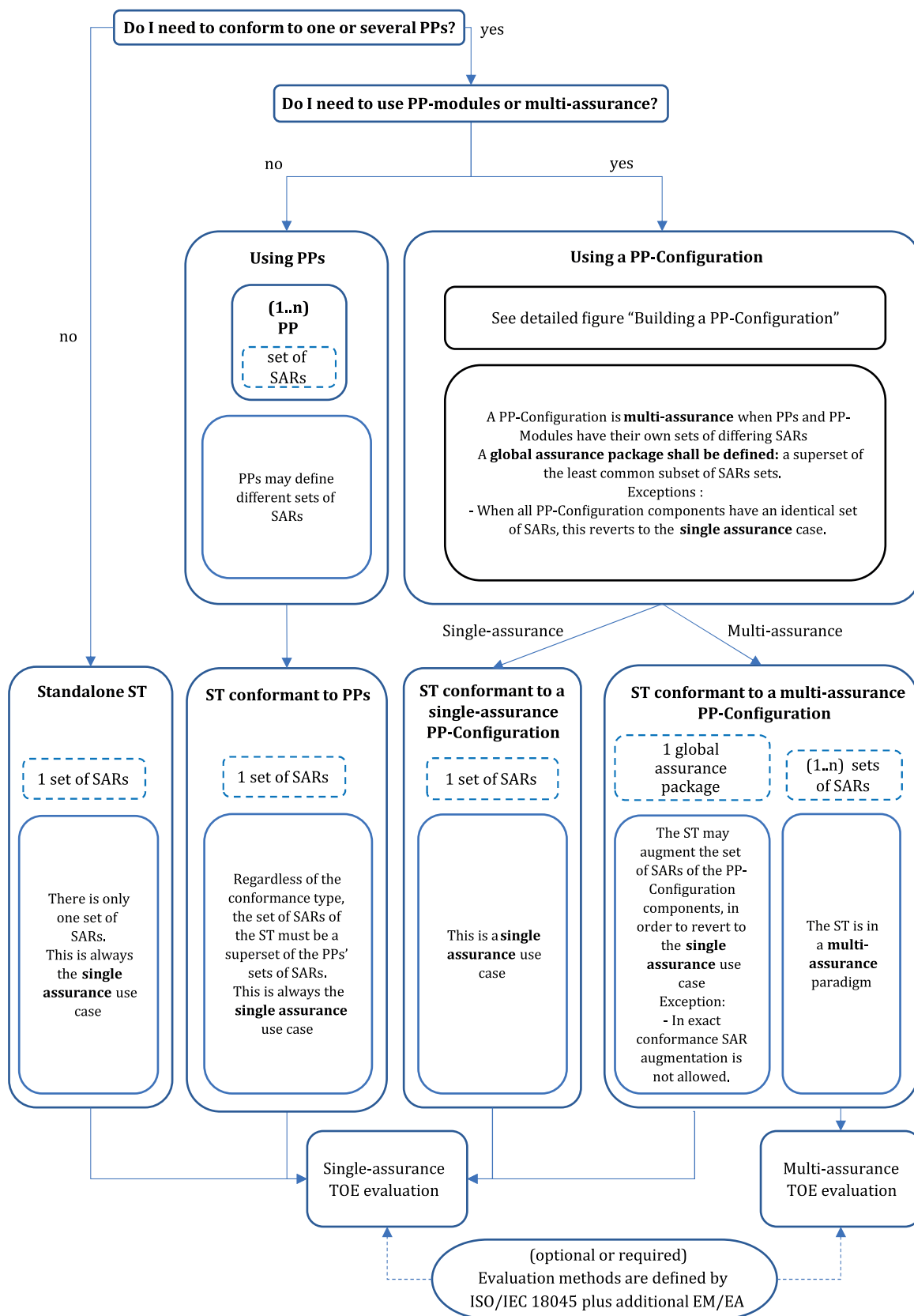


Figure 6 — Usage of single and multi-assurance PP-Configurations

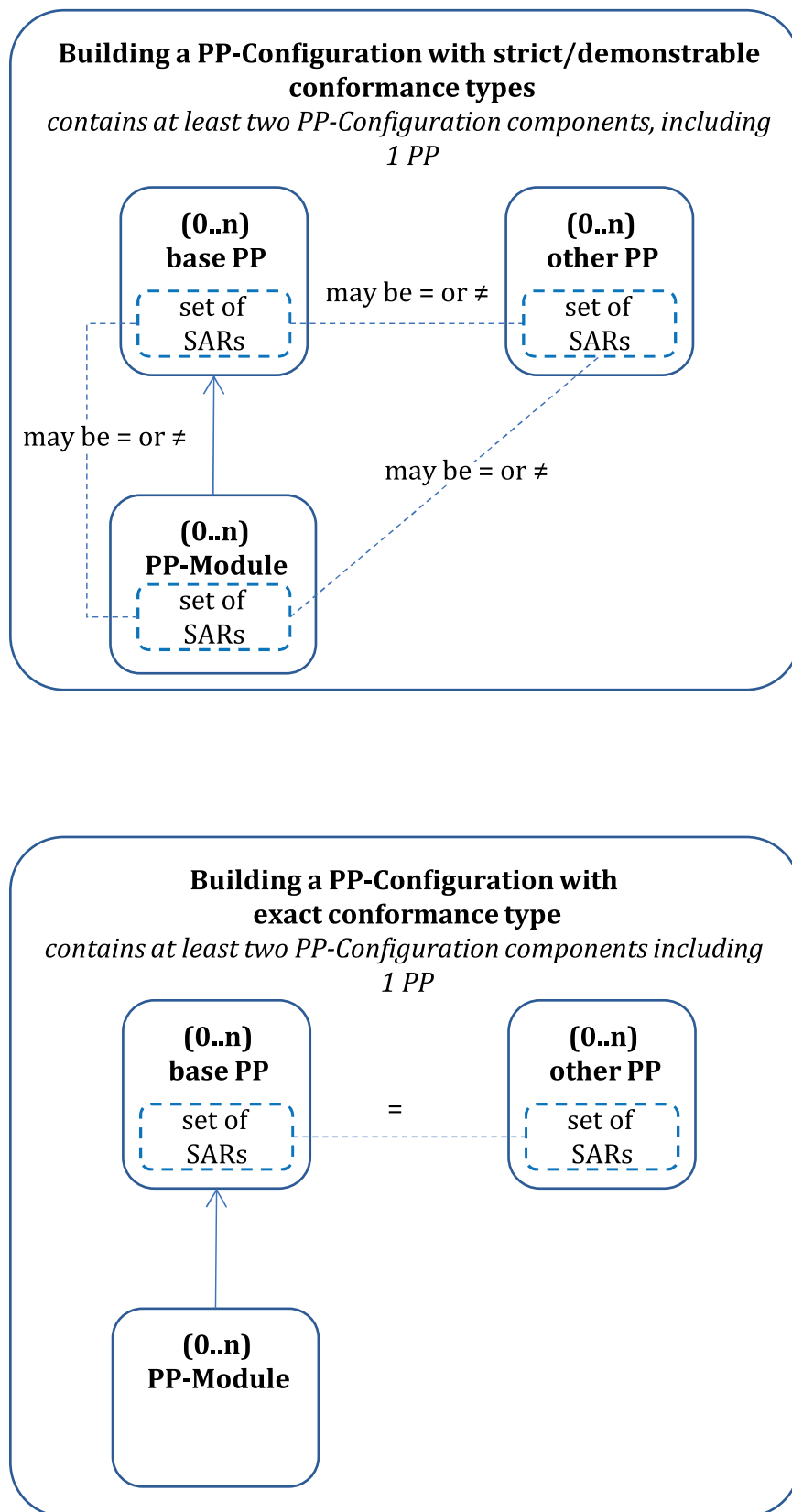
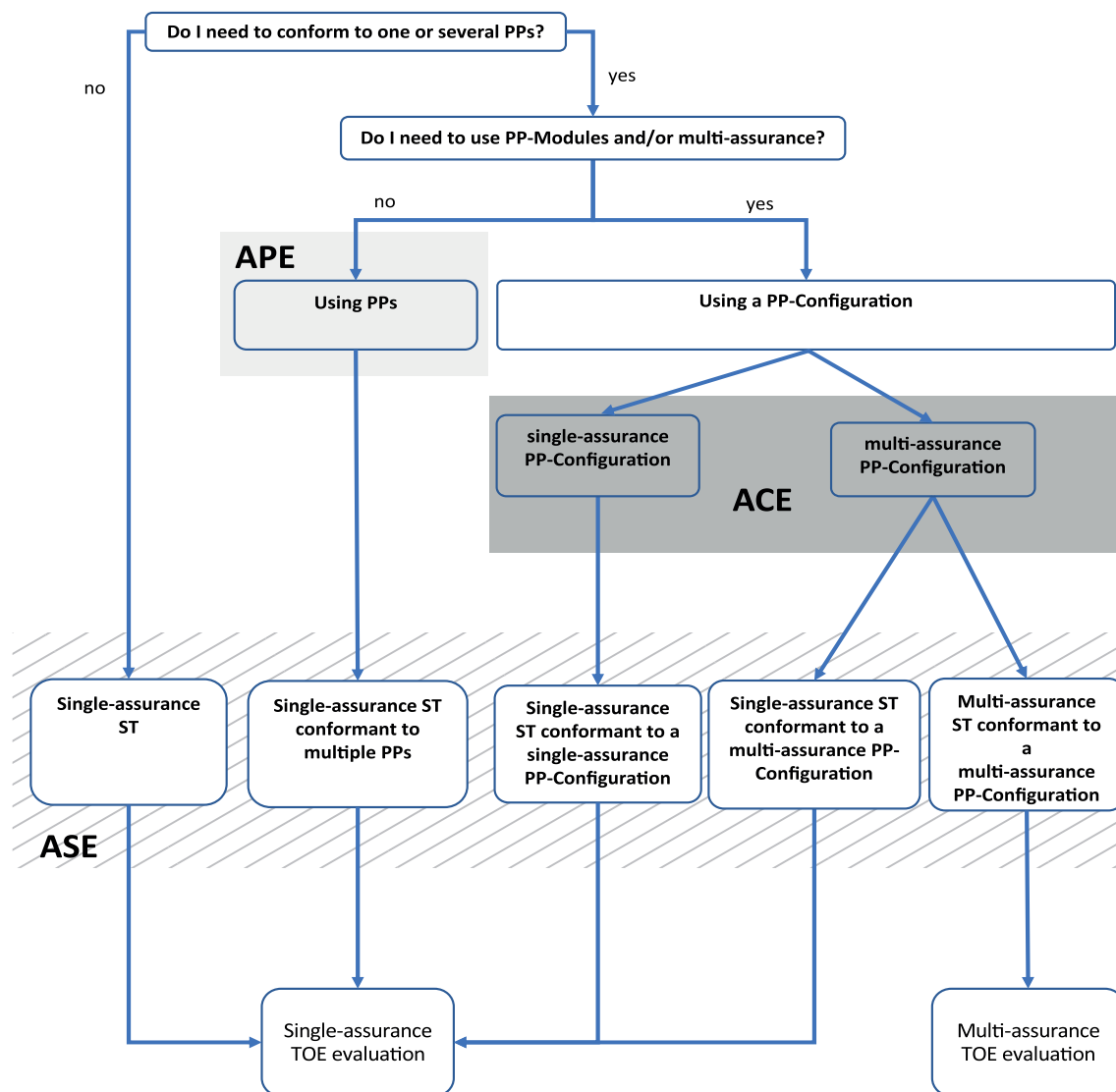


Figure 7 — Composition of PP Components

**Figure 8 — Assurance classes used to evaluate PPs, PP-Configurations and STs**

12 Security Targets (STs)

12.1 General

A ST is a document that describes a specific TOE, the conformance claims applicable to the evaluation of the TOE, the security problem to be addressed, the security objectives for the TOE and its operational environment, the security requirements applicable to solving the stated security problem, and additional material necessary to describe the TOE sufficiently for evaluation. STs are generally based upon PPs or PP-Configurations that describe a security problem and security requirements for a TOE type that is relevant to the specific TOE.

A ST is typically produced by a developer and the audience for the ST includes evaluators, certifying bodies and end users of the evaluated TOE.

Further information about STs, Annex D shall be used in conjunction with the clauses of this document.

12.2 Conformance claims and statements

In this subclause the use of *italic text* indicates literal text that shall appear in the text of the ST.

The conformance claims of a ST:

- a) shall state the edition of relevant parts of the ISO/IEC 15408 series to which the ST claims conformance;
- b) shall describe the conformance to ISO/IEC 15408-2 (SFRs) as either:

- *“ISO/IEC 15408-2 conformant”*

A ST is ISO/IEC 15408-2 conformant if all SFRs in that ST are based only upon functional components in ISO/IEC 15408-2, or

- *“ISO/IEC 15408-2 extended”*.

A ST is ISO/IEC 15408-2 extended if at least one SFR in that ST is not based upon functional components in ISO/IEC 15408-2.

NOTE 1 When a TOE is successfully evaluated to a ST, any conformance claims of the ST also hold for the TOE. A TOE can therefore also claim to be ISO/IEC 15408-2 conformant.

- c) shall describe the conformance to ISO/IEC 15408-3 (security assurance requirements) as either:

- *“ISO/IEC 15408-3 conformant”*;

A ST is ISO/IEC 15408-3 conformant if all SARs in that ST are based only upon assurance components in ISO/IEC 15408-3, or

- *“ISO/IEC 15408-3 extended”*.

A ST is ISO/IEC 15408-3 extended if at least one SAR in that ST is not based upon assurance components in ISO/IEC 15408-3.

- d) may include a conformance claim made with respect to packages.

If a package conformance claim is made, it shall consist of one of the following claims for each package:

- *“Package Conformant”*;

A ST is conformant to a package if:

- for functional packages, all constituent parts (SPD, security objectives, and SFRs) of the functional package are present in the corresponding parts of the ST without modification;
- for assurance packages, the SARs of that ST are identical to the SARs in the assurance package.

- *“Package Augmented”*

A ST claims augmentation of a package if:

- for functional packages, all constituent parts (SPD, security objectives, and SFRs) of the functional package are present in the corresponding parts of the ST but the ST contains at least one additional SFR or one SFR that is hierarchically higher than an SFR in the package;
- for assurance packages, the ST contains all SARs in the assurance package but contains at least one additional SAR or one SAR that is hierarchically higher than an SAR in the assurance package.

- *“Package Tailored”*

STs shall not claim or perform tailoring.

More than one package may be claimed in a ST.

Where STs claim exact conformance to PP(s) they shall not claim conformance to any packages, including any packages claimed by the PP.

Where STs claim strict or demonstrable conformance to PPs they shall not also claim conformance to the packages claimed in the PPs unless the ST augments the package as claimed in the PP, i.e. the PP may claim a package as <package>-conformant, <package>-augmented or <package>-tailored, but if the ST does not itself augment the conformant/augmented/tailored version of the package in the PP, then it will not claim conformance to the package. The ST claims <package>-augmented only in the case where the ST augments the packages beyond that claimed by the PP.

Where STs claim conformance to a PP-Configuration they shall not also claim conformance to any functional packages, including any functional packages claimed by the PP-Configuration's components.

Where STs claim strict or demonstrable conformance to a PP-Configuration they shall not also claim conformance to the assurance packages claimed in the PP-Configuration unless the ST augments the assurance package as claimed in the PP-Configuration, i.e. the PP-Configuration may claim an assurance package as <package>-conformant or <package>-augmented, but if the ST does not itself augment the conformant/augmented version of the package in the PP-Configuration, then it will not claim conformance to the assurance package. The ST claims <package>-augmented only in the case where the ST augments the assurance package beyond that claimed by the PP-Configuration.

NOTE 2 For exact conformance, it is allowed to claim conformance to a PP that claims conformance to a package, or a PP-Configuration that has components that claim conformance to a package, but those are not reflected in the ST's conformance claim.

- e) may also include a conformance claim with respect to PPs:

— “PP Conformant”;

A PP or TOE meets specific PP(s).

A Direct Rationale ST may only claim conformance to one or more other Direct Rationale PPs. (See Annex B)

- f) may also include a conformance claim with respect to PP-Configurations:

— a ST may claim conformance to exactly one PP-Configuration;

— a Direct Rationale ST shall only claim conformance to a PP-Configuration if that PP-Configuration uses the Direct Rationale approach.

NOTE 3 The evaluation of a PP-Configuration can be performed upfront, independently of any product evaluation. Alternatively, the evaluation of a PP-Configuration can be performed during the evaluation of a conformant ST, prior to evaluating the ST conformance claim. See 13.3 for a discussion of the evaluation of PP-Configurations.

PP-Modules are used to build specific PP-Configurations on top of one or more PP-Module Base(s). Hence, PP-Modules shall only be used by STs through claimed PP-Configurations.

- g) if evaluation methods/ evaluation activities that have been derived from ISO/IEC 18045 are identified in the conformance statement of any package, PP, PP-Module, or PP-Configuration to which the ST claims conformance, then the conformance claim shall also include a claim in the following form:

“The TOE is evaluated using evaluation methods/ evaluation activities defined in <reference>.”

In this statement, <reference> is replaced by the identification of the location of the relevant evaluation methods and evaluation activities.

STs that reference evaluation methods/ activities are not required to reproduce the text of the evaluation methods/ activities within the ST.

A ST shall only make a conformance claim for evaluation methods/ evaluation activities that are included in a package, PP, PP-Module, or PP-Configuration claimed by the ST.

NOTE 4 The reader is reminded that it can be the case that a ST claims no PP or PP-Configuration but can still directly specify a package.

A ST can claim conformance to several PPs. If one such PP has exact conformance type, then all PPs shall be of the exact conformance type. Otherwise, the PPs can have a mix of strict and demonstrable types, and the consistency of the combination of demonstrable and strict conformance shall be validated as part of the ST evaluation.

For more information and requirements on the conformance claims for STs see Annex D.

For more information and requirements on conformance types see Annex E.

12.3 Assurance requirements

A ST that claims conformance with ISO/IEC 15408-3 (possibly extended) shall define the global set of SARs that applies to the TOE.

A ST may define a distinctive name for the set of SARs that are applicable. However, the use of an (augmented) pre-defined EAL or an (augmented) assurance package defined in an applicable external reference shall require the usage of the same name.

If additional SARs are specified, or SARs are replaced with hierarchically higher SARs in an ST then any derived evaluation methods / evaluation activities shall be addressed in the assurance rationale to demonstrate that the evaluation methods / evaluation activities used by the ST:

- are still adequate, i.e. the new SAR has no effect on the EMs/EAs specified for use in the ST and the assurance that they provide; or
- have been addressed by defined refinements to the original EMs/EAs specified by the ST so that the resulting EMs/EAs required for the ST generate assurance that is the same or higher than the original EMs/EAs applied to the ST; or
- have been supplemented by additional EMs/EAs to so that the resulting EMs/EAs generate assurance that is the same or higher than the original EMs/EAs applied to the ST.

EXAMPLE An activity that was an examination of documentation for a lower SAR but where additional testing might be needed for a hierarchically higher SAR can supplement the original documentation evaluation activities with additional evaluation activities that require testing.

12.4 Additional requirements in the exact conformance case

12.4.1 Additional requirements for the conformance claim

A ST shall not claim conformance to an exact conformance PP/PP-Configuration and, at the same time, to other PPs which are not of exact conformance type, i.e. a PP/PP-Configuration of exact conformance shall not be combined with strict or demonstrable conformance.

12.4.2 Additional requirements for the SPD

A ST claiming exact conformance:

- shall contain the SPD of all the packages and the PPs or PP-Configuration to which it is claiming exact conformance, including all SPD elements;
- shall not include any SPD-elements that are not present in the packages or PPs/PP-Configuration to which it is claiming exact conformance.

NOTE The SPD that is instantiated in the ST from a PP-Configuration contains exactly the SPD-elements present in the PP-Configuration's components (PPs and PP-Modules). Note that PP-Configuration components can combine to change or eliminate SPD-elements (e.g. an assumption in a base PP can become a threat that is countered by a PP-Module on top of that base PP), so the result that appears in the ST considers these kinds of modifications. See 11.3.

12.4.3 Additional requirements for the security objectives

A ST claiming exact conformance:

- shall contain all the security objectives for the TOE specified in all of the PPs to which it claims conformance;
- shall not specify additional security objectives for the TOE that are not specified in the combination of the PPs to which it claims conformance;
- shall contain all of the security objectives for the operational environment that are specified in the combination of PPs to which it claims conformance; and
- shall not specify additional security objectives for the operational environment that are not present in the combination of PPs to which it claims conformance.

The same is true for PP-Configurations. The security objectives that are instantiated in the ST from a PP-Configuration contain exactly the security objectives present in the PP-Configuration's components. It should be noted that PP-Configuration components can combine to change or eliminate security objectives (e.g. a security objective for the environment in a base PP may become a TOE security objective in a PP-Module using that base PP), so the resulting ST reflects these kinds of modifications.

12.4.4 Additional requirements for the security requirements

A ST shall contain all the SARs present in the PPs, and all the SFRs present in the PP-Configuration components, with the following exceptions:

- ST authors shall not include additional or hierarchically higher security requirements;
- SFRs designated as selection-based SFRs in the PPs or PP-Modules shall be excluded if the selection that requires their inclusion is not chosen by the ST author;
- SFRs designated as optional SFRs in the PPs or PP-Modules may be included or excluded while maintaining its exact conformance claim.

NOTE 1 SFRs in an exact conformance PP can be iterated and refined (as stated in ISO/IEC 18045 for ASE_CCL.1-12).

NOTE 2 See 7.3.2.6 for further information in regard to optional and selection-based SFRs.

NOTE 3 See Annex E for further information on PP conformance.

12.5 Additional requirements in the multi-assurance case

A multi-assurance ST shall claim conformance to exactly one multi-assurance PP-Configuration and no other PP or PP-Configuration.

A multi-assurance ST shall organize the TSF in sub-TSFs and claim a specific set of SARs for each of the sub-TSFs and a global set of SARs for the entire TOE: this can be achieved exclusively through the conformance to a multi-assurance PP-Configuration. The TSF structure defined in the ST is inherited from the PP-Configuration, and the sets of SARs that apply to them in the ST are either identical to the ones defined in the PP-Configuration or augmented.

A multi-assurance ST may extend the multi-assurance PP-Configuration (of strict or demonstrable conformance type) with additional SFRs (and related SPD and security objectives as necessary) so that

each new element completes at a minimum one PP or PP-Module of the PP-Configuration provided the required conformity rules are satisfied, i.e. the new SFRs are aimed at extending the sub-TSFs defined by the components of the PP-Configuration. As a consequence, the extended sub-TSFs are subject to the set of SARs as defined in the original PPs/PP-Modules.

A multi-assurance ST may claim the sets of SARs defined in the multi-assurance PP-Configuration, or, in the case of strict or demonstrable conformance type, may provide a rationale to claim “augmented” sets of SARs, similar to STs in the general model.

In order to conform with two or more PPs according to their respective sets of SARs, a multi-assurance PP-Configuration composed of the PPs shall be defined and claimed by the ST.

A ST that claims conformance with a multi-assurance PP-Configuration and augments all the applicable sets of SARs to reach the same set of SARs for the entire TOE and all of the sub-TSFs becomes a single-assurance ST. In this case, the evaluation of the TOE shall follow the single-assurance evaluation approach. This is only allowed for PP-Configurations of strict or demonstrable conformance type.

A ST that claims conformance with several PPs can only define a global set of SARs that applies to the entire TOE, thus giving rise to a single-assurance ST. The ASE rules for ensuring the consistency of the assurance requirements of the single-assurance ST with regard to the PPs apply.

A ST that claims conformance with one single-assurance PP-Configuration, i.e. which defines only one set of SARs for the entire TOE and its parts, cannot become a multi-assurance ST. The reason is that the multi-assurance consistency rules are defined at PP-Configuration level. In order to achieve this, a multi-assurance PP-Configuration derived from the PP-Configuration shall be defined and evaluated.

For more information on multi-assurance PP-Configurations and STs see 12.4.2. A ST that claims conformance with a multi-assurance PP-Configuration may become a multi-assurance ST by defining, for each sub-TSF, the applicable set of SARs. This will be either the same set of SARs inherited from the PP-Configuration, or a larger set (augmentation, valid only in the strict and demonstrable conformance type cases) which requires the update of the assurance rationale provided in the PP-Configuration.

A multi-assurance ST may define distinctive names for the sets of SARs that apply to the entire TOE and to each sub-TSF. The names shall be consistent with the names given in the PP-Configuration. The use of an (augmented) pre-defined EAL or an (augmented) assurance package defined in an applicable external reference requires the usage of the same name.

A multi-assurance ST that claims strict or demonstrable conformance to a PP-Configuration and extends the sets of SARs of the PP-Configuration it claims conformance to shall provide an assurance rationale that justifies the consistency of the extension.

A multi-assurance ST shall conform to each and all of the individual conformance types that are identified in the conformance statement of the multi-assurance PP-Configuration.

NOTE A ST that claims conformance with more than one PP can only define a global set of SARs, which applies to the entire TOE. In such a case, the ASE rules for ensuring the consistency of the assurance requirements of the ST with regard to the PPs apply.

Figure 9 shows an example of a multi-assurance ST that claims conformance to PP-Configuration “AXY” composed of PP A and two PP-Modules X and Y. The TSF structure consists of the sub-TSF defined in A, X and Y. The global set of SARs (SAR_C) and the multiple sets of SARs applicable to the sub-TSFs come from the PP-Configuration without any augmentation.

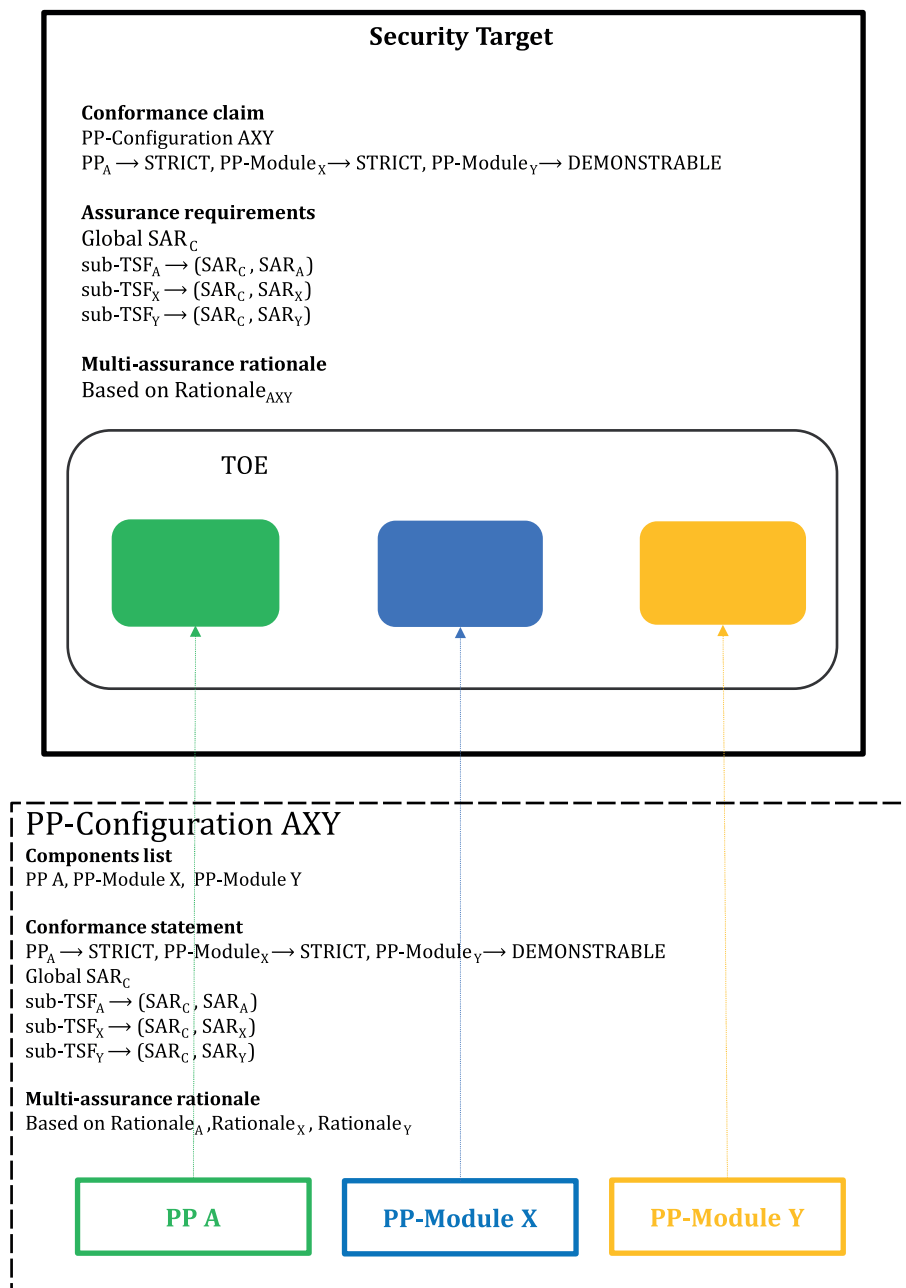


Figure 9 — Example of multi-assurance ST

13 Evaluation and evaluation results

13.1 General

This clause presents the expected results from PP, PP-Configuration and ST/TOE evaluations performed according to either ISO/IEC 18045, and/or additional evaluation methods and activities.

The goal of evaluation is to provide objective and repeatable results that can be cited as evidence, even if there is no absolute objective scale for representing the results of a security evaluation.

NOTE 1 A trade-off between following the relevant state of the art versus a sufficient level of repeatability is often necessary. Therefore, properties such as objectivity and repeatability are not seen as absolute by the standard, but rather as goals that can be approached in different ways. For example, ISO/IEC 15408-4 provides one such framework for preserving objectivity and repeatability when deriving evaluation activities from ISO/IEC 18045.

An evaluation result represents the findings of a specific type of investigation of the security properties of a TOE. Such a result does not automatically guarantee fitness for use in any particular application environment. The decision to accept a TOE for use in a specific application environment is based on consideration of many security issues including the evaluation findings.

Figure 10 describes the various evaluations that are needed to provide confidence in the evaluation results for a TOE.

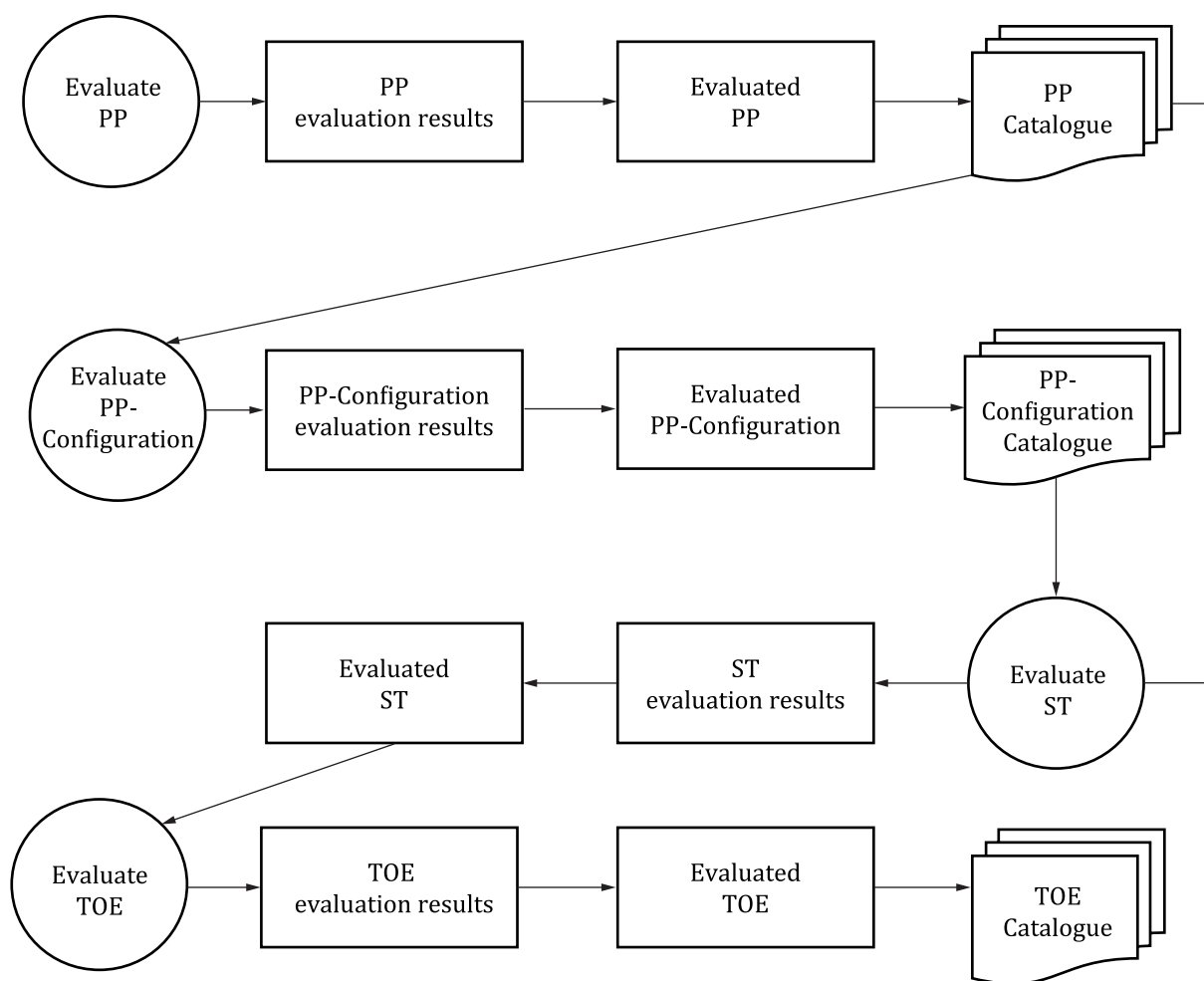


Figure 10 — Evaluation flow

The ISO/IEC 15408 series gives criteria for four types of evaluation:

- a PP evaluation which is based on the APE class given in ISO/IEC 15408-3, described in 13.3;
- a PP-Configuration evaluation which is based on the ACE class given in ISO/IEC 15408-3, described in 13.3;
- a ST evaluation which is based on the ASE class given in ISO/IEC 15408-3, described in 13.4;

- d) a TOE evaluation, which is based on an evaluated ST and the criteria for evaluating the security requirements claimed by the ST, described in 13.5.

PP and PP-Configuration evaluations provide confidence that the PP and/or PP-Configuration meets the requirements of the ISO/IEC 15408 series. Catalogues of PPs and PP-Configurations can be maintained by authorities or others which define the criteria for inclusion in the catalogue.

NOTE 2 The criteria for inclusion in a catalogue are out of scope for the ISO/IEC 15408 series.

PP-Modules are only evaluated as part of an evaluation based on a PP-Configuration.

Packages are only evaluated as part of a PP-Configuration, PP, or ST evaluation.

NOTE 3 In practice, a ST that claims conformance with some non-evaluated PP-Configurations can still be evaluated by performing the PP-Configuration evaluation first.

A ST evaluation leads to an intermediate result that is used in the frame of a TOE evaluation. Optionally, STs may be developed with conformance claims to packages, PPs and PP-Configurations.

ST/TOE evaluations can lead to catalogues of evaluated TOEs. In many cases these catalogues refer to the IT products that the TOEs are derived from rather than the specific TOE. Therefore, the existence of an IT product in a catalogue cannot be construed as meaning that the whole IT product has been evaluated; instead the actual ST defines the actual extent of the TOE evaluation.

Refer to the Bibliography for examples of such catalogues.

13.2 Evaluation context

In order to achieve greater comparability between evaluation results, evaluations should be performed within the framework of an evaluation scheme.

NOTE 1 The ISO/IEC 15408 series does not state requirements for such evaluation schemes.

Supporting greater comparability between evaluation results is also achieved through the use of common evaluation methods producing these evaluation results. Use of a common evaluation methodology contributes to the repeatability and objectivity of the results but is not by itself sufficient. Many of the evaluation criteria require the application of expert judgement and background knowledge for which consistency is more difficult to achieve. In order to enhance the consistency of the evaluation findings, the final evaluation results can be submitted to a certification process.

NOTE 2 The ISO/IEC 15408 series does not provide requirements to assess the competences of developers or evaluators. ISO/IEC 19896-3 provides competency requirements for the ISO/IEC 15408 series evaluators that can be used as a support in the evaluation process. However, it only addresses basic methodology competences and does not address the way to assess:

- technology-specific knowledge and skills such as those required to perform ADV, ATE or AVA_VAN evaluation on a given product type;
- sector-specific knowledge that is typically required to perform ASE, APE or ACE evaluation.

Additionally, specific skills required by evaluations made in accordance with ISO/IEC 15408 can require additional competence assessment methods. For example, to assess skills related to formal methods.

For the ISO/IEC 15408 series, the generic methodology for IT security evaluations is given in ISO/IEC 18045. More specific evaluation methods and activities may be derived from ISO/IEC 18045 by using the framework given in ISO/IEC 15408-4, by refining standard assurance components or by defining extended assurance components.

It can be necessary for PP authors to augment the generic methodology for IT security evaluations given in ISO/IEC 18045 with a method that includes technology-specific evaluation activities.

A certification process, which is outside the scope of the ISO/IEC 15408 series, can include an independent inspection of the results of the evaluation leading to the production of a final certificate or

approval, which can be made publicly available. The certification process is a means of gaining greater consistency in the application of IT security criteria.

13.3 Evaluation of PPs and PP-Configurations

Basing a PP or a ST on an evaluated PP/PP-Configuration has two advantages:

- there is much less risk that there are errors, ambiguities, or gaps in the PP/PP-Configuration. If any problems with that would have been found during the evaluation of that PP/PP-Configuration, are found during the writing or evaluation of the new ST, significant time can elapse before the PP/PP-Configuration is corrected;
- evaluation of the new PP/PP-Configuration can re-use the previous evaluation results, resulting in less effort being employed in the evaluation of the new PP/PP-Configuration.

If the evaluation of a PP is required then the APE criteria, given in ISO/IEC 15408-3 shall be used.

If the evaluation of a PP-Configuration is required, then the ACE criteria given in ISO/IEC 15408-3 shall be used.

The goal of such evaluations is to demonstrate that the PP, or PP-Configuration is complete, internally consistent, and technically sound and suitable for use as a template on which to build a ST or another PP.

The method of stating evaluation results for PPs and PP-Configurations is described in 13.7.

NOTE PP-Modules are not evaluated separately; they are evaluated in the course of evaluating the PP-Configuration that uses them.

13.4 Evaluation of STs

A ST evaluation determines the sufficiency of the TOE, the operational environment and the internal consistency of the descriptions and requirements it contains.

The ST evaluation shall be carried out by applying the ASE evaluation criteria, defined in ISO/IEC 15408-3. The methods and activities used to apply the ASE criteria are determined by the evaluation methodology that is associated with the ST, which is specified in ISO/IEC 18045 or by evaluation methods/ activities that are derived from ISO/IEC 18045. Derived evaluation methods/ evaluation activities are validated outside of the ISO/IEC 15408 series and ISO/IEC 18045 framework.

Users of this document/series should be aware that evaluation schemes do not always approve the use of particular evaluation methods/evaluation activities. A ST can require evaluation methods/evaluation activities, and an evaluation scheme can decide not to carry out evaluations following this ST.

The method of stating ST evaluation results is described in 13.7. These results also identify any PP(s) and package(s) to which the ST claims conformance.

13.5 Evaluation of TOEs

A TOE evaluation determines that the correctness of the TOE against the criteria defined in the ST. As said earlier, the TOE evaluation does not assess the correctness of the operational environment.

The TOE evaluation is more complex. The principal inputs to a TOE evaluation are the evaluation evidence, which includes the TOE and the ST, but will usually also include input from the development environment, such as design documents or developer test results.

The TOE evaluation consists of applying the SARs (from the ST) to the evaluation evidence. The method to apply a specific SAR to a TOE is determined by ISO/IEC 18045 and by evaluation methods/ activities that are derived from ISO/IEC 18045. Derived evaluation methods/evaluation activities are validated outside of the ISO/IEC 15408 series and ISO/IEC 18045 framework. Users of this document/ series should be aware that evaluation schemes do not always approve the use of particular evaluation

methods/evaluation activities. A ST may require evaluation methods/evaluation activities, and an evaluation scheme can decide not to carry out evaluations following this ST.

How the results of applying the SARs are documented, and what reports need to be generated and in what detail, is determined by both the evaluation methodology that is used and the evaluation scheme under which the evaluation is carried out.

The TOE evaluation may be carried out after TOE development has finished, or in parallel with TOE development, provided that the appropriate assurance components are chosen for this evaluation.

The method of stating ST/TOE evaluation results is described in 13.7.

13.6 Evaluation methods and evaluation activities

Generic IT evaluation methods and activities for each of the security assurance classes given in ISO/IEC 15408-3 are provided in ISO/IEC 18045. The evaluation methods and activities given in ISO/IEC 18045 are high level and depending on the technology type, the assurance level, or the security problem described, the provision of more specific evaluation methods and activities can be needed.

Such evaluation methods/ evaluation activities that have been derived from ISO/IEC 18045 may be published either as an inclusion in PPs, PP-Modules and packages or as separate supporting documents.

13.7 Evaluation results

13.7.1 Results of a PP evaluation

The results of the PP evaluation shall include a “conformance claim” in accordance with 10.3.

NOTE ISO/IEC 15408-3 provides evaluation criteria for PPs in the APE class.

13.7.2 Results of a PP-Configuration evaluation

The results of a PP-Configuration evaluation shall include a “conformance claim” in accordance with 11.3.

Once a PP-Configuration has been evaluated, a ST evaluation may rely on the results of the PP-Configuration evaluation.

NOTE 1 ISO/IEC 15408-3 provides evaluation criteria for PP-Configurations in the ACE class.

NOTE 2 The evaluation of a PP-Configuration can arise in two situations, with no impact on the evaluation methodology:

- independently of any product evaluation, or
- as the first step of the evaluation of a ST that claims conformity with the PP-Configuration. Otherwise the conformance claim is meaningless, and the ST evaluation would fail in this aspect.

13.7.3 Results of a ST/TOE evaluation

13.7.3.1 General

The results of a ST evaluation shall include a “conformance claim” as defined in 12.2.

A successful TOE evaluation requires a successful ST evaluation. The result of the TOE evaluation process is either:

- a statement that all SARs have been met, and that therefore there is the specified level of assurance that the TOE meets the SFRs as stated in the ST;

- a statement that not all SARs have been met and that therefore there is not the specified level of assurance that the TOE meets the SFRs as stated in the ST.

NOTE In some cases the evaluation results are subsequently used in a certification process, but this certification process is outside the scope of the ISO/IEC 15408 series.

If the TOE evaluation has resulted in a pass statement, the underlying product can be eligible for inclusion in a catalogue of successfully evaluated products.

13.7.3.2 Use of ST/TOE evaluation results

Once a ST and a TOE have been evaluated, asset owners can have the assurance, as defined in the ST, that the TOE, together with the operational environment, counters the stated threats. The evaluation results may be used by the asset owner as part of a risk-acceptance decision related to exposing the assets to the threats.

However, risk owners should carefully check whether:

- a) the SPD in the ST matches their own security problem;
- b) their operational environments conform (or can be made to conform) to the security objectives for the operational environment described in the ST;
- c) any guidance documents provided by the developer in the context of the TOE evaluation are followed during the installation, configuration, and operation of the TOE.

If any of these conditions do not hold true, the associated assurance cannot be relied on and the evaluation results should be treated accordingly in a risk-acceptance decision.

Additionally, once an evaluated TOE is in operation, it is probable that previously unknown errors or vulnerabilities in the TOE will be identified. In that case, the developer can correct the TOE (to address the vulnerabilities) or change the ST in a way that excludes the newly identified vulnerabilities from the scope of the evaluation. In either case, the old evaluation results can no longer be valid.

NOTE If assurance is to be maintained, re-evaluation is needed. The ISO/IEC 15408 series can be used for this re-evaluation, but detailed procedures for re-evaluation are outside of the scope of this document.

13.8 Multi-assurance evaluation

For a multi-assurance PP-Configuration, the ACE requirements, given in ISO/IEC 15408-3, ensure that the combination of different sets of SARs does not undermine the expected security of the underlying assets, as defined in the SPDs of the PPs and PP-Modules that compose the PP-Configuration.

For a multi-assurance ST, the ASE requirements, given in ISO/IEC 15408-3, ensure that the ST is conformant to a multi-assurance PP-Configuration which satisfies ACE assurance requirements. This means that the organization of the TSF in sub-TSFs and the sets of SARs that apply to them are consistent with the PP-Configuration. For each sub-TSF this means that the multi-assurance ST claims a set of SARs that is identical or an augmentation of the set of SARs defined in the PP-Configuration for the corresponding component (PP or PP-Module).

The general model of the standard, which holds in a multi-assurance evaluation, requires that the evaluator evaluates the TSF in order to ensure the security of the TOE. In the context of multi-assurance, the evaluator still considers the impact on the entire TOE, when evaluating each of the sub-TSFs.

In practice, a multi-assurance evaluation can be seen as several evaluations of the same TOE, according to different PPs. The multi-assurance evaluation adds the consistency checks that are required to ensure that these evaluations can be performed together. This means in particular that the set of SARs associated with a sub-TSF does not impact on the other sub-TSFs. Therefore, the evidence required by

the SARs of one sub-TSF cannot be negatively impacted by the SARs that have been chosen for the other sub-TSFs.

EXAMPLE Let us imagine that a PP-Configuration selects AVA_VAN.3 for one sub-TSF. ADV_TDS.3 will then be required by dependency. The evaluation of ADV_TDS.3 for this sub-TSF will, by definition, consider all the subsystems of the TOE, regardless of the ADV_TDS levels of the other sub-TSFs defined in the TOE.

The multi-assurance evaluation of a TOE which conforms with a multi-assurance ST consists in evaluating the entire TOE against the global set of SARs and evaluating each of the sub-TSFs against the corresponding sets of SARs, as defined in the ST. The order of the evaluation activities is left to the evaluator. The most suitable order depends on factors such as the actual structure of the TSF in terms of the sub-TSFs and the difference between the global set of SARs and the sets of SARs that apply to the sub-TSFs.

The limitation of multi-assurance evaluation to TOEs (and ST s) that conform with one multi-assurance PP-Configuration and the definition of the multi-assurance consistency rules in ACE allow to limit the impact on the other assurance classes. Performing a multi-assurance evaluation consists in applying a uniform interpretation of all the assurance classes, as defined in ISO/IEC 18405: in the context of a multi-assurance evaluation, whenever a SAR mentions the “TOE” it refers to the entire TOE. Whenever a SAR mentions the “TSF”, it refers to the sub-TSF to which the SAR applies.

A multi-assurance ST reflects the TSF organization in sub-TSFs defined in the PP-Configuration to which the ST claims conformance. This TSF organization does not describe the organization of the TOE's implementation in subsystems and modules, but rather associates a given set of security functionalities (sub-TSF) with specific assurance requirements. It can happen that sub-TSFs are implemented by different sets of subsystems/modules, but there can also be some degree of overlap: a subsystem or module can implement functionalities belonging to two different sub-TSFs. This means that the two sets of SARs apply to the common subsystem or module (i.e. the union of the sets of SARs applies). In both cases, for each sub-TSF, all of the other sub-TSFs belong to the TOE and the corresponding subsystems/modules shall be evaluated through the prism of the requirements of the sub-TSF.

14 Composition of assurance

14.1 General

IT products are almost always composed from several components, whereby some of them are evaluated and some are not. Independent product components are often evaluated separately, and the question of composing the security assurance of the single components to determine the security assurance of the entire product arises.

EXAMPLE Software is composed with evaluated hardware to create an IT product.

Composition of assurance is dependent upon:

- the type of composition;
- the security function policies, and OSPs that the component evaluation was based on;
- the claimed security assurance, for example the assurance level;
- the overall security policies for the entire product.

Concepts of composition models are described in 14.2. Evaluation methods by which security assurance in such composition models can be provided are given in 14.3. Considerations about the re-use of evaluation results related to individual product components in the composition approach are addressed in 14.4. 14.5 addresses the relationship between composite and multi-assurance evaluation approaches.

14.2 Composition models

14.2.1 Layered composition model

In this type of composition, one component is built on top of another component, as pictured in Figure 11.

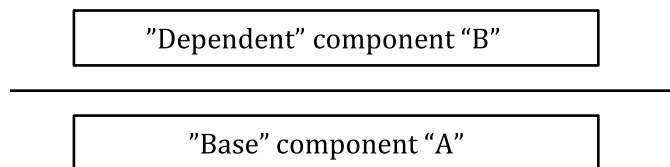


Figure 11 — Layered composition model

The following assumptions are made in regard to the layered composition model:

- the base component is independent from the dependent component;
- the base component is not modified by the dependent component;
- the dependent component uses the functionality of the base component and not vice versa.

Those performing such a composition should consider that:

- the dependent component can depend on other functionality than the security functionality in the scope of the evaluation of the base component;

Two examples are given to clarify the layered composition model described in Figure 11.

EXAMPLE 1 The first and main example comes from the smartcard domain, where an evaluation technique has been defined for the layered composition model. In this context, a smartcard is built up with a combination of two parts:

- a hardware integrated circuit (IC) part (as a base component);
- a software part on top of it (as a dependent component).

The software part can depend on functionality that does not belong to the evaluated security functionality of the underlying hardware. However, in general almost all instructions of the hardware are part of the hardware's security functionality and are used to implement the security functionality of the software part.

The software part of the smartcard is potentially layered itself, consisting of an

- 'Operating System' layer with possibly integrated applicative functionality (as a base component);
- 'Application' layer on top of it that contains different applications (as a dependent component).

All these parts can be developed by different actors with specific objectives.

EXAMPLE 2 Applications running on a personal computer follow the same principle, with an operating system (OS) acting as a base component and the application layer as a dependent component: the application uses Identification and Authentication provided by the OS, builds its own objects on top of the OS file system, builds its own application structure on top of the OS address space management and separation, and needs to enforce specific properties (e.g. fault tolerance, information flow control). If the OS has already been evaluated, then the security functionality of the application layer can be broken down to the evaluated security functionality of the base component. Where this is not possible, the dependent component implements the security functionality by itself. Furthermore, the dependent component can depend on functionality that does not belong to the evaluated security functionality of the underlying base component.

14.2.2 Network or bi-directional composition model

In this type of composition, a component uses the specific functionality of another component communicating via some communication channel, as pictured in Figure 12.



Figure 12 — Network or bi-directional composition model

The following assumptions are made in regard to the network or bi-directional composition model:

- the security interdependencies are clearly described;
- both products are separated such that there is no other channel or influence than the defined one;
- both products implement the functionality required to protect the communication channel.

EXAMPLE 1 An application (component "A") using the functionality of an external LDAP server (component "B").

Those performing such a composition consider that:

- security functionality might not fit together.

EXAMPLE 2 Access control can be based on different objects:

- assumptions made on a component might not be valid.

EXAMPLE 3 Assumption on the protection of critical data transferred to another component:

- security functionality can have unwanted side effects.

EXAMPLE 4 A covert channel leaking cryptographic keys.

If these kinds of issues are identified, then they should be clearly documented along with the determination of appropriate mitigating controls.

14.2.3 Embedded composition model

In this type of composition, a component is used as part of a larger component or product, as pictured in Figure 13.

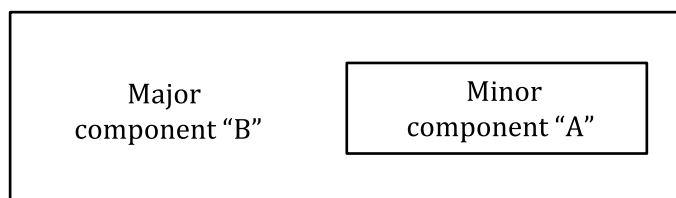


Figure 13 — Embedded composition model

The following assumptions are made in regard to the embedded composition model:

- there is usually no separation between the components;
- each part can influence the other via channels and interfaces other than the intended ones.

EXAMPLE A library or subsystem providing specific security functions as part of a larger product.

Those performing such a composition should consider that due to the lack of separation, components potentially:

- bypass the security functionality of the other components;
- modify the security functionality and security policy of other components and of the whole product;
- introduce a number of critical side effects.

NOTE If separation is specified, ADV_ARC given in ISO/IEC 15408-3 describes the criteria for evaluation.

14.3 Evaluation techniques for providing assurance in composition models

14.3.1 General

To achieve reliable and repeatable evaluation results for the evaluation of IT products (TOEs) that make use of the composition models described in 14.2, a corresponding suitably defined evaluation method is needed.

14.3.2 and 14.3.3 address evaluation techniques for the layered composition model. 14.3.2 describes how the ACO class defined in ISO/IEC 15408-3 may be used for composed TOEs, and in 14.3.3 an evaluation technique for composite products is provided which is already widely applied in the industry and shows multiple advantages (see 14.3.3.1).

The other two composition models (i.e. bi-directional and embedded) are not explicitly addressed by constructs defined in the ISO/IEC 15408 series.

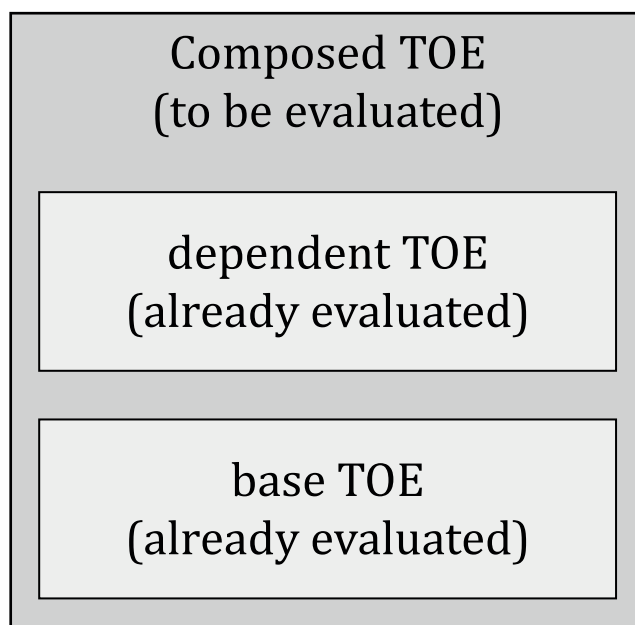
14.3.2 ACO class for composed TOEs

The ACO class specified in ISO/IEC 15408-3 addresses a TOE composed of two TOEs using a layered composition model as described in 14.2, both of which have been separately evaluated. These component TOEs can be described as a base TOE and a dependent TOE, as shown in Figure 14. In such a case, the ACO class is used for evaluating the composed TOE.

An evaluation of such a composed TOE consists of evaluating the interaction between both TOEs, whereby reuse of the evaluation results from both the base TOE and the dependent TOE takes place.

ISO/IEC 15408-5 provides pre-defined CAPs that may be used for determining the composed TOE's assurance level.

The ACO class is applicable up to 'Enhanced-basic' assurance level.

**Figure 14 — Composed TOE evaluated using the ACO class**

14.3.3 Composite evaluation for composite products

14.3.3.1 General

The composite evaluation technique addresses the layered composition model for composite products as described in 14.2 and is devised to meet the following objectives:

- independently perform the evaluation of a base component to address several dependent components and customers;
- create one or several dependent component(s) to use with an evaluated base component;
- install one dependent component onto an evaluated base component to reduce the evaluation effort keeping a high level of confidence.

The composite evaluation technique describes a way to perform transfer of knowledge and reuse of evidence, in order to meet these objectives.

The COMP related assurance families specified in ISO/IEC 15408-3 for the ADV, ALC, ASE, ATE and AVA classes provide evaluation criteria pertinent to composite products using this layered model.

14.3.3.2 Objectives

This method for composition of assurance applies to layered products that comprise one independently evaluated base component and one dependent component.

NOTE A dependent component potentially consists of one or more dependent sub-components. For simplification, they are considered as 'one dependent component' in the following.

The composite product is made of the integration of the already evaluated base component (including its base TOE) and the dependent component. Hereby, the base TOE is part of the composite TOE. In the composite evaluation approach, the evaluation results already obtained for the base TOE are reused, and the evaluation of the dependent component is performed within the evaluation of the composite product, whereby in particular focus is laid on the evaluation of the relationship between the base TOE and the dependent component. Therefore, an assurance level is claimed for and applies to the composite product as a whole and not to the dependent component only.

The composite product, with its base component (including the base TOE) and dependent component, is intended to be efficiently evaluated. The specific composite evaluation technique is set up with the objective to optimize the evaluation of such a composite product.

Unlike ACO-based evaluation, this allows a direct comparison with similar products that are evaluated at once without using composition techniques. Moreover, there is no limitation in the assurance level, i.e. the composite product can claim any pre-defined EAL or well-defined assurance package, including resistance up to 'High attack potential' as defined in ISO/IEC 15408-3 AVA_VAN.5, whereas ACO is limited by CAP requirements up to 'Enhanced-basic' attack potential. The aim is not to define an additional assurance class, but to define additional assurance requirements for a composite evaluation.

EXAMPLE Examples of smartcard devices requiring high-level assurance include payment and digital signature applications.

14.3.3.3 Design of composite product and composite TOE

The composite product is composed of one base component (including its base TOE) and one dependent component whereby in view of evaluation aspects the following rules and constraints apply for the composite product and its composite TOE part:

- the base component builds the underlying independent layer of the composite product and contains the base TOE. The base component with its base TOE shall already have been evaluated;
- the dependent component builds a supplementary layer of the composite product that is dependent on the base component and that shall be evaluated in the framework of the composite evaluation;
- the composite TOE is part of the composite product and covers the entire dependent component, and the base TOE, more detailed a superset of the base TOE functionalities is required for the correct and secure execution of the composite product;

NOTE 1 A composite TOE can contain parts that are independent from the base component / base TOE. For simplification, such parts are considered as belonging to the dependent component.

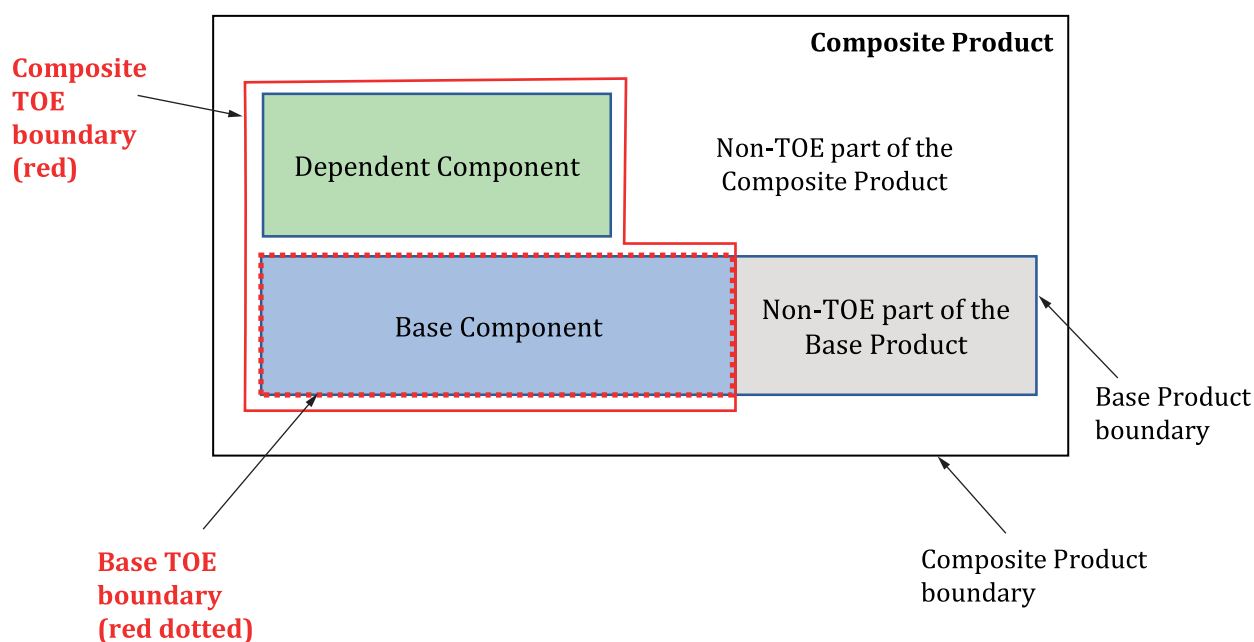
- the dependent component cannot rely on base component functionalities that are in the base component, but lie outside the base TOE (that is, functionalities in the non-TOE part of the base component);
- the non-TOE part of the composite product can use base component functionalities, in particular base TOE functionalities. As usual, the composite evaluation needs to determine that this non-TOE part of the composite product is non-interfering with the dependent component – neither directly nor through the usage of the base component functionalities;
- non-TOE parts of the composite product, in particular non-TOE parts of the evaluated base component (that is, parts in the base component lying outside the base TOE), are considered part of the operational environment of the composite TOE.

NOTE 2 Composite evaluation is applicable independently of the EAL for the composite product aimed. Where some evaluation activities are not applicable due to the EAL chosen, they are also not expected to be applied.

NOTE 3 This document only addresses cases where the level of assurance of the base component is equivalent or higher compared to the composite evaluation level.

NOTE 4 In the case where both base component and dependent component have already been evaluated using the ISO/IEC 15408 series, the composite evaluation work potentially relies on the results already obtained both from the previous base component evaluation and the previous dependent component evaluation. Nevertheless, the composite evaluation objective as defined in this document has still to be achieved.

Figure 15 illustrates the general design and layering of a composite product and composite TOE in the framework of the composite evaluation approach.

**Figure 15 — Composite evaluation**

Several composition steps can follow each other. In other terms, the base component can itself be a composite product consisting of an own already evaluated base component and a dependent component.

14.3.3.4 Roles

The base component and the composite product, more precisely the base TOE and the composite TOE, are both undergoing an evaluation. Therefore, both of them have a sponsor, a developer, an evaluator, and an evaluation authority.

For the composite evaluation model addressing the evaluation of the composite product, a preceding finalized evaluation of the base component with its base TOE is expected. The composite evaluation performs the evaluation of the composite product by re-using the evaluation results of the already evaluated base component. Hence, the evaluation of the composite product focuses on the evaluation of the dependent component including its relationship to the base component and hereby takes the base TOE with its related evaluation results into account.

In practice, there is no composite product developer since the composite product results from the integration of the dependent component and the base component. Instead, the relevant developer-related roles here are:

- the dependent component developer responsible for implementing the dependent component (and further non-TOE parts of the composite product, if applicable);
- the base component developer responsible for implementing the base component;
- the composite product integrator responsible for the integration of the base component and the dependent component.

In order to address this role model, the composite evaluation approach and technique defines additional evaluation activities for the above-mentioned dependent component developer, the base component developer, and the composite product integrator.

NOTE 1 As already mentioned, the dependent component can have undergone a separate evaluation, but the evaluator and evaluation authority of this previous evaluation are not considered here. If the base component and the dependent component were evaluated separately, each of them would have a sponsor, a developer, an evaluator, and an evaluation authority.

NOTE 2 As in the general cases, some actors involved can be the same. The composite evaluation context also leads to specific cases of actors having several roles. Each evaluation will associate particular organizations or persons to these generic roles.

EXAMPLE 1

- the base component developer can also be the base component sponsor;
- the base component evaluation authority can also be the composite product evaluation authority.

NOTE 3 The composite product integrator is a different role than the developer. While this integrator can, in some cases, also be one of the developers defined previously, this is not always the case.

The following example illustrates the role of the composite product integrator:

EXAMPLE 2

- native smartcards: The underlying base component is an integrated circuit and the base component developer is the integrated circuit (chip) manufacturer; the dependent component is a card operating system and its application(s) and the dependent component developer is the developer of the smartcard operating system and the application(s). In this case, the role of the composite product integrator is played by:
 - the chip manufacturer embedding the core of the operating system into the ROM of the chip, then by;
 - the card manufacturer usually loading some parts of the operating system and the applications into NV-Memories (EEPROM and/or Flash) of the chip.
- Java Card technology-enabled devices: The underlying base component is the Java Card System (Java Card Runtime Environment, Virtual Machine and APIs) on chip and the base component developer is the card manufacturer/issuer; the dependent component is a Java Card applet, which can be developed by an applet developer playing the role of the dependent component developer. In this case, the composite product integrator role can be played by the domain/application service provider or by a trust centre loading the applet and often personalizing the card electronically.

14.3.3.5 Action elements and required information

To allow the evaluation of a composite product, the composite evaluation technique identifies two main sets of issues, leading to the following rules:

- the composite product can be insecure due to gaps in the definition, integration or test of the base component and dependent component security mechanisms. In particular, the following properties are to be enforced:
 - the assets to be protected are the final composite product assets defined in a dedicated composite product ST;
 - the security mechanisms involved in the protection of these assets are those provided by the base component and by the dependent component;
 - some of the security mechanisms and security services provided by the base component may require configuration, programming, or activation as allowed for the base TOE by the dependent component;
 - evaluation is performed and validated on the final composite product.

To this effect, the composite evaluation technique defines specific action elements to be performed by the actors involved in the evaluation of the base component, as well as in the development of the dependent component and in the evaluation of the composite product.

- the aforementioned action elements are potentially impossible to perform due to a lack of information sharing between actors. To avoid this, the composite evaluation technique explicitly defines which information is required for each action element.

Table 2 and Table 3 define which SARs shall be selected in the composite product ST, and the information that is required to be available for the dependent component developer, the composite product evaluator and the composite product evaluation authority to allow and support a composite evaluation.

Table 2 — Information to be provided to the dependent component developer

SAR defining the action elements	Information required	Originator of the information
Consistency of composite product Security Target (ASE_COMP)	ST of the base component. Information to build the composite product ST and to ensure consistency of the security definition between the base component and dependent component. Information related to the base component's security mechanisms and security services that the dependent component has to manage or use.	Base component developer
Composite design compliance (ADV_COMP)	Information (usually in the form of a guidance or user's manual) related to the base component's security mechanisms and security services that the dependent component has to manage or use.	Base component developer

Potentially, the composite product evaluator does not need all the detailed results of the base component evaluation for performing a composite evaluation of a composite product that integrates such evaluated base component. However, for reusing the base component evaluation results the composite product evaluator needs complementary information on the assurance measures where the base component and the dependent component interfere. In particular, for the examination that the dependent component meets the security requirements imposed by the base component and for the vulnerability analysis of the composite product, the composite product evaluator makes use of the evaluated base component's user guidance, the related report of the base component evaluation authority (i.e. the report for an evaluated product that confirms the acceptance of the evaluation results provided by the evaluator) and the so-called *ETR for composite evaluation* (ETR_COMP) described in 14.3.3.6.

All in all, for making use of the composite evaluation technique, in addition to the standard amount of information required by the assurance package chosen for the composite evaluation (e.g. an EAL), the following is needed as outlined in Table 3.

Table 3 — Information to be provided to the composite product evaluator and composite product evaluation authority

SAR defining the action elements	Information required	Originator of the information
Consistency of composite product Security Target (ASE_COMP)	ST of the base component. Information related to the composite product ST for ensuring consistency of the security definition between the base component and dependent component. Information related to the base component's security mechanisms and security services that the dependent component has to manage or use.	Base component developer
	ST of the composite product (including information on the compatibility of the ST of the composite product with the ST of the base component).	Dependent component developer

Table 3 (continued)

SAR defining the action elements	Information required	Originator of the information
Integration of composition parts and consistency check of delivery procedures (ALC_COMP)	Composite configuration evidence. Organizational evidence of version correctness, on the basis of configuration lists containing unambiguous version information of the evaluated base component and the dependent component having been integrated into the final composite product. Evidence elements that security measures prescribed by the base component developer and the dependent component developer are actually being applied by the composite product integrator.	Composite product integrator
	Delivery and acceptance procedures evidence. Information on the compliance of the delivery procedures of the base component developer and the dependent component developer with the acceptance procedure of the composite product integrator. Organizational evidence that components (dependent component and base component) transmitted from an actor to another are securely received, accepted and parameterized.	Composite product integrator Base component developer Dependent component developer
Composite design compliance (ADV_COMP)	Base component-related integration requirements and recommendations, typically including the user guidance.	Base component developer
	<i>ETR for composite evaluation.</i> Base component-related integration requirements and recommendations.	Base component evaluator
	Design compliance evidence. Evidence that the composite product meets the base component-related integration requirements and recommendations. It enfolds evidence elements on how the requirements on the dependent component design, imposed by the base component's user guidance and report of the base component evaluation authority are fulfilled in the composite product. If such a requirement was not followed, a rationale that the chosen composite product implementation is still secure shall be given here.	Composite product integrator Dependent component developer
	Report for the base component evaluation generated by the base component evaluation authority. (Additional) Base component-related integration requirements and recommendations.	Base component evaluation authority
Composite functional testing (ATE_COMP)	Composite product samples suitable for testing.	Composite product integrator

Table 3 (continued)

SAR defining the action elements	Information required	Originator of the information
Composite vulnerability assessment (AVA_COMP)	<i>ETR for composite evaluation.</i>	Base component evaluator
	Evidence allowing the composite product evaluator and the respective evaluation authority to understand the attack paths and the tests that have been considered and performed for the base component and the effectiveness of the countermeasures implemented by the base component, and explanations related to residual vulnerabilities of the base component linked to integration recommendations included in the base component user guidance.	
	Report for the base component evaluation generated by the base component evaluation authority.	Base component evaluation authority
	(Additional) Base component-related integration requirements and recommendations, obligations, information on vulnerabilities.	
	The base component-related user guidance.	Base component developer

NOTE The report for the base component evaluation generated by the base component evaluation authority can also be relevant for the SARs ASE_COMP, ALC_COMP and ATE_COMP even if not directly addressed in Table 3.

In the case of composition, the term ‘developer’ needs further clarification in order to distinguish the actors. Here, the base component developer, the dependent component developer and the composite product integrator can be different entities. Similarly, for the terms ‘evaluator’ and ‘evaluation authority (evaluation scheme)’ further distinguishing of the different entities involved needs to be made.

In the case where both base component and dependent component have already been evaluated, a reduced amount of evaluation activities is possibly sufficient to be performed considering the evaluation results already obtained from the previous dependent component evaluation. Nevertheless, the composite evaluation tasks as defined in this document are still required.

EXAMPLE Smartcard.

The smartcard architecture is composed of a hardware platform and a software application on top of the platform. In this case, the platform is the base component, and the application is the dependent component. In a composite evaluation, the platform is already evaluated, the application is evaluated as part of the composite evaluation and the results of the platform evaluation are re-used.

The hardware platform provides functionality supporting the protection of the composite product’s assets, but the composite product behaviour depends on the software application having to use, configure, and activate the security functionality.

Therefore, the hardware platform evaluation results usually provide specific security recommendations and conditions for the software application implementation. The composite evaluation includes examination that the combination of both components does not lead to any exploitable vulnerability.

A composite evaluation method and associated evaluation activities are provided that include precise work units with clear statements on the information required from the platform developer and provide an agreed ‘framework’ for information transfer from the platform evaluator to the composite product evaluator.

The information required is already available from the platform evaluation tasks and no additional work is required from the platform developer.

There are no further requirements for the development class ADV.

The user guidance (AGD) of the platform is considered early in the development of the composite product and provides all of the interfaces on which information is needed.

The development and the evaluation of the composite product rely on the proper implementation of the evaluated interfaces of the platform.

The proper use of all relevant interfaces between the platform and the application is in the scope of the composite evaluation.

Test (ATE) and vulnerability assessment (AVA) are performed on the composite product taking advantage of the available platform evaluation results.

14.3.3.6 ETR for composite evaluation (ETR_COMP)

14.3.3.6.1 Objective of the document

The *ETR for composite evaluation* (ETR_COMP) document is compiled from the Evaluation Technical Report (ETR) related to a base component and its evaluation in order to provide sufficient information for a composite evaluation with such an already evaluated base component.

NOTE 1 A standard ETR usually contains proprietary information on the base component and its evaluation that cannot be made public. Such full ETR is therefore possibly not suitable for external delivery. The information that is presented in the ETR_COMP document contains a meaningful subset of the information provided in the full ETR of the base component for support of a composite evaluation.

The goal of the ETR_COMP document is to enable the composite product evaluator and the composite product evaluation authority to understand the attack paths and the tests that have been considered and performed for the base component and the effectiveness of the countermeasures implemented by the base component.

NOTE 2 The content of the ETR_COMP document strikes the right balance between protecting the proprietary information of the base component developer and/or the base component evaluator on the one hand and providing sufficient information for the composite product evaluator and the composite product evaluation authority on the other hand.

14.3.3.6.2 Procedure

The ETR_COMP is produced by the base component evaluator on the basis of the base component evaluation results and is derived from the full ETR related to the base component evaluation.

The ETR_COMP is part of the base component evaluation. The ETR_COMP is provided and validated on request of the sponsor of the base component evaluation. The report of the base component evaluation authority for the base component in particular declares the acceptance of the ETR_COMP by all parties involved in the base component evaluation (i.e. the base component evaluator, the base component evaluation authority, the base component developer and the sponsor of the base component evaluation). Such validation statement for the ETR_COMP especially covers the consistency of the ETR_COMP with the original ETR. The ETR_COMP is referenced in the report of the base component evaluation authority for the base component for further re-use.

For re-use of the ETR_COMP in a composite evaluation, the previous acceptance of the ETR_COMP by the base component evaluation authority in the framework of the base component evaluation is required. The ETR_COMP is supplied to the composite product evaluator and the composite product evaluation authority for use in the composite evaluation.

For the ETR_COMP, as being part of the base component evaluation, it is ensured by the base component evaluator and the base component evaluation authority that sufficient information is provided in the ETR_COMP considering the composite evaluation approach and the intended secure use of the base component in composite products.

In the case that security issues for the base component are found after acceptance of the ETR_COMP that are not sufficiently addressed in the ETR_COMP, then the base component evaluation authority decides about the actions to take. This may include an appropriate update of the ETR_COMP and a subsequent validation of this updated ETR_COMP.

Furthermore, as part of the base component evaluation the base component evaluator ensures that the recommendations for the base component in the related ETR_COMP are consistent and complete regarding the requirements provided in the base component's user guidance. If any inconsistencies

(including missing requirements) are found which are not solved before issuance of the evaluation authority's report for the base component, then the base component evaluation authority can add supplementary information for the dependent component developer in the evaluation authority's report for the base component.

In a composite evaluation, if the current base component itself relies on a previous composite evaluation, and if there is a direct interface between the dependent component of the current evaluation and the previous base component, then the ETR_COMP of the previous composite evaluation is also supplied to the current composite product evaluator and composite product evaluation authority.

14.3.3.6.3 Exchange of the ETR for composite evaluation

The ETR_COMP document is created and maintained by the base component evaluator. However, for a composite evaluation the base component developer is the point of contact for the dependent component developer.

The dependent component developer contacts the base component developer for delivery of the ETR_COMP to the point of contact at the composite product evaluator. The base component developer checks its confidentiality management rules to determine whether delivery is possible. If necessary, the base component developer contacts the base component evaluation authority about the intent of the delivery of the ETR_COMP.

The base component developer contacts the base component evaluator to request the delivery (using a secure method and distributing only marked versions) of the ETR_COMP to the given contact point of the composite product evaluator. If the delivery is granted, either the base component evaluator or the base component developer sends the ETR_COMP to the composite product evaluator depending on the agreements between these two parties. The ETR_COMP delivery process depends on the (usually contractual) agreement between the base component developer and the base component evaluator, which may lead to deviations from the described procedure. The ETR_COMP document is delivered also to the composite product evaluation authority using the similar exchange procedure as for its provisioning to the composite product evaluator.

If necessary, the base component evaluator and the composite product evaluator exchange additional or more detailed information. This is always under the control of the base component developer. In case of clarification the base component evaluator and the composite product evaluator are the main parties. If an additional assurance statement is required, then the base component evaluation authority is also involved in the exchange.

It is important that multi-party exchange of information considers all the identified controls for information exchange and protection.

14.3.3.6.4 Content of the ETR for composite evaluation

The information required to be provided in the ETR_COMP document includes:

- a) information about the evaluated base component;

This section of the ETR_COMP shall provide formal information on the base component evaluation including:

- version information of the ETR_COMP;
- base component unambiguous identification;
- base component developer and sponsor identities;
- identities of the base component evaluator and the base component evaluation authority;
- assurance level of the base component evaluation;
- formal evaluation results such as pass/fail;

— reference to the ETR related to the base component and its evaluation.

b) information about the base component design:

This section of the ETR_COMP shall provide a high-level description of the base component and its major components based on the deliverables required by the assurance class ADV.

The intent of this section is to characterize the degree of architectural separation of the major components of the base component, to show possible technical dependencies between the base component and a dependent component using this base component, and to outline the security mechanisms of the base component covered by the base component evaluation.

c) information about the evaluated configuration of the base component:

This section of the ETR_COMP shall provide information about the evaluated configuration of the base component established on the developer's configuration list or relevant parts as needed or on a case by case basis. The base component shall unambiguously be identifiable, and this identification shall be linked to the evaluated configuration as stated in the report of the base component evaluation authority for the base component.

If applicable, generation and installation parameter settings which are security relevant for the base component shall be explained and their effect on the defence against attacks shall be outlined (for example key length, counter limits). This shall include methods for the dependent component developer and the dependent component evaluator to verify the values of these settings, in order to ensure that the expected evaluated configuration is used.

This evidence can include installation, generation and start-up procedures of the base component as outlined in the related user guidance to ensure that the base component is configured in a secure manner.

d) information on delivery procedures, the development and production sites involved and data exchange:

For supporting composite evaluation, both evaluation evidence for delivery procedures of the base component and for acceptance procedures of the dependent component, and related data to be integrated during development and production are necessary.

The ETR_COMP shall provide an overview of the sites involved in the development and production of the base component, including the role of each site and the date of the latest audit.

e) information about the penetration testing of the base component including the considered attack paths and summary of test results; information about the penetration testing of the supporting functions in the base component:

This section of the ETR_COMP shall provide information about the independent vulnerability analysis performed for the base component by the base component evaluator with the considered attack scenarios, the performed penetration testing and the reference to the corresponding rating (quotation) of the attack potential.

The information about the penetration testing shall include:

- a summary showing all of the attack methods that have been addressed during the vulnerability analysis,
- the details necessary for understanding the attack scenarios/paths that were considered,
- the assessments of the penetration tests performed and their results.

The attack scenario descriptions shall provide sufficient details to support the composite product evaluator in reproducing attacks, which require additional countermeasures in the composite product.

If a potential vulnerability of the base component has to be resolved by adhering to the base component guidance this shall be clearly outlined in the summary including a reference to a specific section in the guidance or if possible, a guidance element.

f) Observations and recommendations:

The evaluated base component user guidance shall contain all information required to use the base component in a secure way as defined in the base component ST, in particular including information on how to avoid residual vulnerabilities and unexpected behaviour. The base component evaluator shall ensure that the ETR_COMP only contains recommendations on the secure use of the base component that are also addressed as requirements in the base component user guidance. The base component evaluator shall ensure that the base component user guidance and the recommendations in the ETR_COMP are consistent and that the user guidance requirements are sufficiently specific to enable the dependent component developer to perform design compliance analysis.

However, in some cases additional detailed information beyond the base component guidance can be necessary for allowing the composite product evaluator to perform the composite evaluation such as:

- observations on the base component evaluation results (e.g. specific base component configuration for the base component evaluation);
- recommendations/stipulations for the composite product evaluator: specific information on the use of the base component evaluation results (e.g. about specific testing necessary during a composite evaluation).

Any such observation or recommendation/stipulation comes from the base component evaluator and/or the base component evaluation authority.

The ETR_COMP document is not intended to reproduce information (e.g. text copies) from other available base component evidence such as the ST and guidance. However, the composite evaluation is supported by references to the relevant sections of such base component evidence.

14.3.3.7 Reports and their validity

The results of a composite evaluation are provided to the composite product evaluation authority in the form of an ETR for the composite product. This composite product ETR shall contain, amongst other information, the final overall verdict for the composite evaluation based on the partial verdicts for each assurance component being in scope of the current composite evaluation. The usage of the composite evaluation approach shall be addressed in the composite product ETR and if applicable, in the composite product's report of the composite product evaluation authority.

As the composite product and its composite evaluation cover the base component and its related evaluation, the composite evaluation is linked to the validity and topicality of the report of the base component evaluation authority for the base component. The composite product evaluator and the composite product evaluation authority need a valid and up-to-date report of the base component evaluation authority for the base component or at a minimum the assessment of the base component evaluation authority on the status of the evaluation authority's report in question.

NOTE 1 The composite product evaluation authority generally asks for a re-assessment of the base component if the base component's ETR_COMP is not valid or not up-to-date, and therefore not suitable for re-use in the composite evaluation, in particular because of its (obsolete or insufficient) vulnerability analysis and penetration testing. This re-assessment consists of a re-evaluation of the base component focusing on a renewal of the vulnerability analysis and penetration testing (surveillance process) or as an alternative, of a confirmation statement of the base component evaluation authority.

NOTE 2 If the base component's ETR_COMP was issued before the submission of the related composite evaluation tasks and in the meantime a major change in performing state-of-the-art relevant attacks on the base component arose (e.g. a major change in the attack methods or attack ratings) then the composite product evaluation authority potentially requires a re-assessment or re-evaluation of the base component focusing in particular on the new attack issues.

NOTE 3 Rules determining the validity and topicality of reports (here in particular the base component-related report of the base component evaluation authority and the ETR_COMP) are defined by the respective evaluation scheme and can be linked to a specifically defined validity period.

NOTE 4 If the composite product evaluator detects any failures resulting from the testing of the base component (e.g. vulnerabilities due to improved attack methods or techniques), these results are communicated to the composite product evaluation authority. The composite product evaluation authority then takes appropriate steps together with the base component evaluation authority, e.g. to invoke a re-assessment or re-evaluation of the base component.

In the case that the entire composite product is set up as a chain of composite products constructed on top of each other (e.g. the base component itself is already a composite product) the validity and up-to-date aspect of each ETR_COMP and evaluation authority report used in this chain of composite products is necessary. In addition, all dependencies from a lower level ETR_COMP to a higher level ETR_COMP are in consideration when re-using the results in the composite evaluation of the entire composite product.

NOTE 5 The evaluation authority report for a product declares the acceptance of the product's evaluation and its results by the respective evaluation authority (i.e. acceptance of the related ETR by the evaluation authority is given). In particular, such report declares that the evaluation of the product was carried out according to ISO/IEC 15408.

The validity, topicality and relevance of the base component's report of the base component evaluation authority and of the ETR_COMP for the current composite product and its composite evaluation are acknowledged by the report of the composite product evaluation authority for the composite product. This includes the determination and acceptance of equivalence of single assurance components (and, hence, of assurance levels) belonging to different ISO/IEC 15408 and ISO/IEC 18405 versions, if the base component evaluation was performed in conformance to another version of ISO/IEC 15408 and ISO/IEC 18405 than the current composite evaluation.

The composite product evaluation authority issues a report for the composite product, if:

- the final overall verdict for the composite evaluation in the composite product ETR is "PASS", and
- the validity, topicality and relevance of the base component's report of the base component evaluation authority and the ETR_COMP are acknowledged for the present composite product and its composite evaluation by the composite product evaluation authority.

14.4 Requirements for evaluations using composition techniques

14.4.1 Re-use of evaluation results

When composing components into an IT product, it is possible that single components of the product have already been evaluated and that therefore already existing evaluation results for such components can be re-used. However, additional evaluation activities are usually required and performed to confirm the security assurance of the entire IT product.

The re-use of evaluation results and evidence related to such components of the IT product (TOE) require their availability for the evaluation of the entire IT product (TOE).

14.3.2 and 14.3.3 address evaluation techniques for the layered composition model. 14.3.2 describes the usage of the ACO class defined in ISO/IEC 15408-3 for composed TOEs, and in 14.3.3 an evaluation technique for composite products is provided.

The re-use of evaluation results and evidence of components of the IT product (TOE) is dependent upon:

- the composition model used for the IT product (TOE);
- the security assurance to be claimed for the entire IT product (TOE), in particular in relationship to its components and their security assurance;
- the security properties claimed for the IT product (TOE) and its components.

EXAMPLE Separation, Information Flow Control and Fault tolerance are examples of security properties.

14.4.2 Composition evaluation issues

14.4.2.1 Composition rationale

When composing an IT product (TOE) from components using a composition model as described in 14.2 and using composition techniques for its evaluation, a composition rationale shall be provided for the evaluation of the IT product (e.g. in the ST of the composite/composed product). This includes analysis of at least:

- the composition model used for the IT product (TOE);
- the security assurance to be claimed for the entire TOE, in particular in relationship to its components and their security assurance;
- the interfaces and dependencies of the components and their functionality;
- the composability of the security function policies and OSPs of the components;
- the preservation of security properties of the components;
- for the embedded composition model, aspects of correctness.

14.4.2.2 Vulnerability analysis

The IT product composed from components using a composition model as described in 14.2 and using composition techniques for its evaluation shall undergo a vulnerability analysis, in accordance with the AVA class given in ISO/IEC 15408-3 taking the proposed EAL for the IT product into account. Although it is possible to re-use the vulnerability analysis results from the components additional vulnerability analysis activities for the entire IT product (TOE) shall be designed and performed.

The vulnerability analysis shall be designed in consideration of the analysis of the IT product with its components.

14.4.2.3 Testing

The IT product composed from components using a composition model as described in 14.2 and using composition techniques for its evaluation shall undergo additional testing, using the ATE class given in ISO/IEC 15408-3. Although it is possible to re-use the testing evaluation results from the components additional tests for the entire IT product (TOE) shall be designed and performed.

The testing shall be designed in consideration of the analysis of the IT product and its components.

14.4.2.4 Use of the ACO class for composed TOEs

ISO/IEC 15408-3 describes the ACO class which provides security assurance components that are intended to be used in support of the evaluation of composed TOEs.

ISO/IEC 15408-5 provides a family of pre-defined assurance packages for composed TOEs [composed assurance packages (CAP)] which balance the level of assurance obtained with the cost and feasibility of acquiring such assurance for composed TOEs.

The CAPs are designed to provide assurance that the composition was performed correctly, to a specified rigour, and in consideration of the proposed EAL for the composed IT product.

14.4.2.5 Use of the composite evaluation technique for composite products

ISO/IEC 15408-3 describes the COMP families in different assurance classes, which provide security assurance components that are intended to be used in support of the evaluation of composite products.

These COMP families are set up as assurance families that appropriately supplement other already existing assurance families defined in ISO/IEC 15408-3 in order to address the composite-specific evaluation aspects and issues.

The COMP families are designed to provide assurance that the composition was performed correctly, to a specified rigour, and in consideration of the proposed EAL for the composite product.

Use of the composite evaluation technique for the evaluation of a composite product requires an already evaluated base component accompanied by a corresponding ETR_COMP and a valid report of the base component evaluation authority.

14.5 Evaluation by composition and multi-assurance

The notions of composition and multi-assurance are aimed at solving different problems. In summary, composed and composite evaluations refer to evaluation processes which are particularly suitable for multi-actor TOEs and allows the reuse of previous evaluation results, while multi-assurance refers to a property of some TOEs in the context of a particular security problem and operational environment.

Evaluation by composition addresses TOEs with a supply and/or integration chain that potentially involves multiple parties, where each party takes care of the evaluation of the security functionality they develop. The ISO/IEC 15408 series standardizes two approaches for the reuse of evaluation results in an evaluation process:

- a) composed evaluation allows to obtain a composed assurance level for a TOE from the individual assurance levels of its interacting sub-TOEs;
- b) composite evaluation allows to obtain an EAL for a layered TOE, in an incremental way where the base layer is evaluated first, then the integrated dependent and base layers are evaluated by reusing the evaluation results of the base layer.

Multi-assurance evaluation focuses on TOEs where different assurance needs apply to different parts of the security functionality (the sub-TSFs) while ensuring a global assurance level for the entire TOE. Before the introduction of multi-assurance, such needs would have forced a sponsor to undergo several evaluations of the same TOE for different STs. Using this concept, the ISO/IEC 15408 series standardizes and optimizes this process.

From the point of view of the TOE/TSF, multi-assurance evaluation applies to any architecture, while evaluation by composition applies to specific architectures: composed evaluation applies to a TOE that consists of several interacting sub-TOEs, while composite evaluation applies to a TOE where a dependent layer relies on a base layer.

In practice, multi-assurance and evaluation by composition can be used together in an evaluation.

Annex A

(normative)

Specification of packages

A.1 Goal and structure of this annex

The goal of this annex is to give further information about the specification of packages.

NOTE ISO/IEC 15408-3 does not define evaluation criteria for packages since packages are not separately evaluated. Evaluation of packages is implicit once a package is incorporated into a PP, PP-Module or ST.

A.2 Package families

A.2.1 General

Figure A.1 shows the structure of a package family. Each part is discussed below.

A.2.2 Package family name

Packages with related objectives are presented as a family of packages. In this case, the package family name is mandatory and the package family sponsor endeavours to allocate a unique name.

A.2.3 Package family overview

Packages presented as a family of packages contain a section giving an overview of the family, describing the family at a high-level.

A.2.4 Package family objectives

The objectives section of the package family presents the intent of the family.

A.2.5 Packages

One or more packages, as described below are included in the package family. Packages of SARs and packages of SFRs are not mixed in the same package family.

A.3 Packages

A.3.1 Mandatory contents of a package

A.3.1.1 Package identification

The package identification includes:

- a) the name of the package. The name provides a unique descriptive information about the intent of the package;
- b) package version information;
- c) last updated date;
- d) sponsor;

e) reference to the edition of the ISO/IEC 15408 series that is used.

The package may also be given a short name.

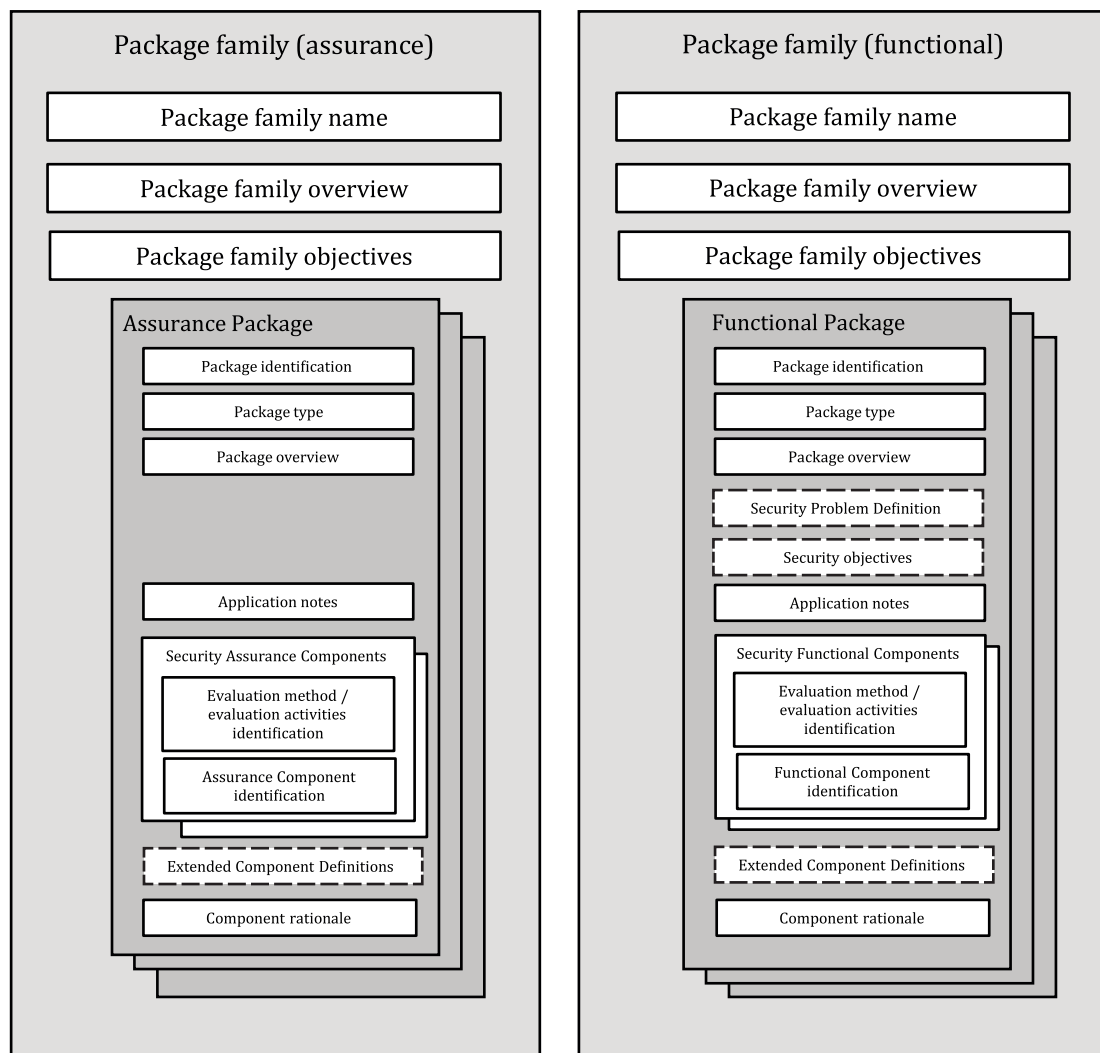


Figure A.1 — Structure of a package family with assurance or functional packages

EXAMPLE Evaluation Assurance Level 1 is also known as “EAL 1”.

NOTE For those packages defined in ISO/IEC 15408-5, items b) to e) are implicit in the edition information of ISO/IEC 15408-5.

A.3.1.2 Package type

A package is identified as one of the following types:

- a) Functional package; or
- b) Assurance package.

A.3.1.3 Package overview

Packages contain a section giving a high-level overview and the intent of the package.

A.3.1.4 Application notes

Application notes are optional with the following exceptions:

- for functional packages, any additional audit and management requirements relating to the SFRs included in the package shall be specified in the Application notes section;
- functional packages may have dependencies on other functional packages. Such dependencies shall be documented in the functional package and may also be documented in a PP, PP-Module or ST.

Functional packages may also specify components that have dependencies that are not satisfied by the package, but are expected to be satisfied by another package, PP, PP-Module, or ST that uses the package.

EXAMPLE A package that contains the specification for a cryptographic protocol (e.g. TLS), where the higher-level SFR components are specified in the package, but the cryptographic primitives are not.

In this case an optional list of the dependent components may be provided in the application notes section of the functional package and may include further information such as any required selections/assignments for those SFRs.

NOTE Users of packages include authors of PPs, PP-Modules, other packages and STs, integrators, and evaluators.

A.3.1.5 Components (either SFRs or SARs)

The security requirements included in the package are given. This section also provides the rationale for the selection of the requirements.

The security requirements may be selection-based. See 8.2.4.2. Optional SFRs (and supporting SPD-elements and objectives, as required) are also allowed to be specified in functional packages.

A.3.2 Optional contents of a package

A.3.2.1 Security problem definition (SPD) (Functional Packages)

Assurance packages do not contain this section.

Functional packages may include this section.

This section includes any SPD-elements which describe the security problem addressed by the functional package. SPD-elements associated with optional SFRs may be defined in this section. Application notes shall be used to identify the security objectives (if applicable) and SFRs to which the optional SPD-elements are associated.

A.3.2.2 Security objectives (Functional Packages)

Assurance packages shall not contain this section.

Functional packages may include this section.

In the case of a functional package used for Direct Rationale PPs/PP-Modules/STs TOE security objectives shall not be included.

The security objectives section of a functional package presents any additional TOE security objectives or security objectives for the operational environment derived from the SPD. Security objectives for the TOE associated with optional SFRs may be defined in this section, if applicable. Application notes shall be used to identify the SPD-elements and SFRs to which the optional security objectives are associated.

A.3.2.3 Application notes

The inclusion of application notes in a package is optional. See A.3.1.4.

The application notes section may also contain information of particular interest to users of the package. The presentation is informal and covers, for example, warnings about limitations of use and areas where specific attention is needed.

A.3.2.4 Extended components definition(s)

A package may contain extended components. In this case, packages contain a section giving the extended component definitions.

A.3.2.5 Evaluation methods/activities

Packages may include evaluation methods/ activities that have been derived from ISO/IEC 18045. Where evaluation methods / activities are included, a conformance statement or statements shall be included in the security requirements section of the package, see 9.4. Evaluation methods/ activities may be provided either in the package document or may reference external documents.

Annex B **(normative)**

Specification of Protection Profiles (PPs)

B.1 Goal and structure of this annex

The goal of this annex is to summarize the structure and expected content of a PP.

NOTE 1 This annex does not define the requirements for evaluation of PPs. The PP evaluation criteria are found in the APE class given in ISO/IEC 15408-3.

NOTE 2 This annex does not give the requirements for the specification of PP-Configurations and PP-Modules. These are found in Annex C.

This annex consists of the following major parts:

a) *the specification of a PP*

This is summarized in B.2. and includes:

- *how to use a PP;*
- *how not to use a PP.*

b) *what a PP shall contain*

This is summarized in B.3 and is described in more detail in B.3.2 to B.3.7 that describe the mandatory contents of the PP, the interrelationships between these contents, and provide examples.

c) *claiming conformance with standards*

B.4 describes how a PP author can claim that the TOE is to meet a particular standard.

d) *Direct Rationale PPs*

Direct Rationale PPs are PPs in which the threats and OSPs in the SPD are mapped directly to the SFRs and possibly to security objectives for the operational environment. They are described in detail in B.5.

B.2 Specification of a PP

B.2.1 How to use a PP

A PP is typically a statement of need where a user community, a regulatory entity, or a group of developers define a common set of security needs. A PP gives consumers a means of referring to this set and facilitates future evaluation against these needs.

Although this does not preclude other uses, a PP is typically used as:

- part of a requirement specification for a specific consumer or group of consumers, who will only consider buying a specific type of IT product if it meets the PP;
- part of a regulation from a specific regulatory entity, who will only allow a specific type of IT product to be used if it meets the PP;

- to address a common security problem presented by a variety of consumers, and often defined by a group including several IT product developers, who then produce IT products of this type in order to meet the needs of their common market.

B.2.2 How not to use a PP

Two roles, among many, that a PP does not fulfil are:

- a complete specification;

A PP is designed to be a security specification and not a general specification. Unless security-relevant, properties such as interoperability, physical size, and weight, required voltage etc. should not be part of a PP. This means that in general a PP is a part of a complete specification, but not a complete specification itself.

- A specification of a single product.

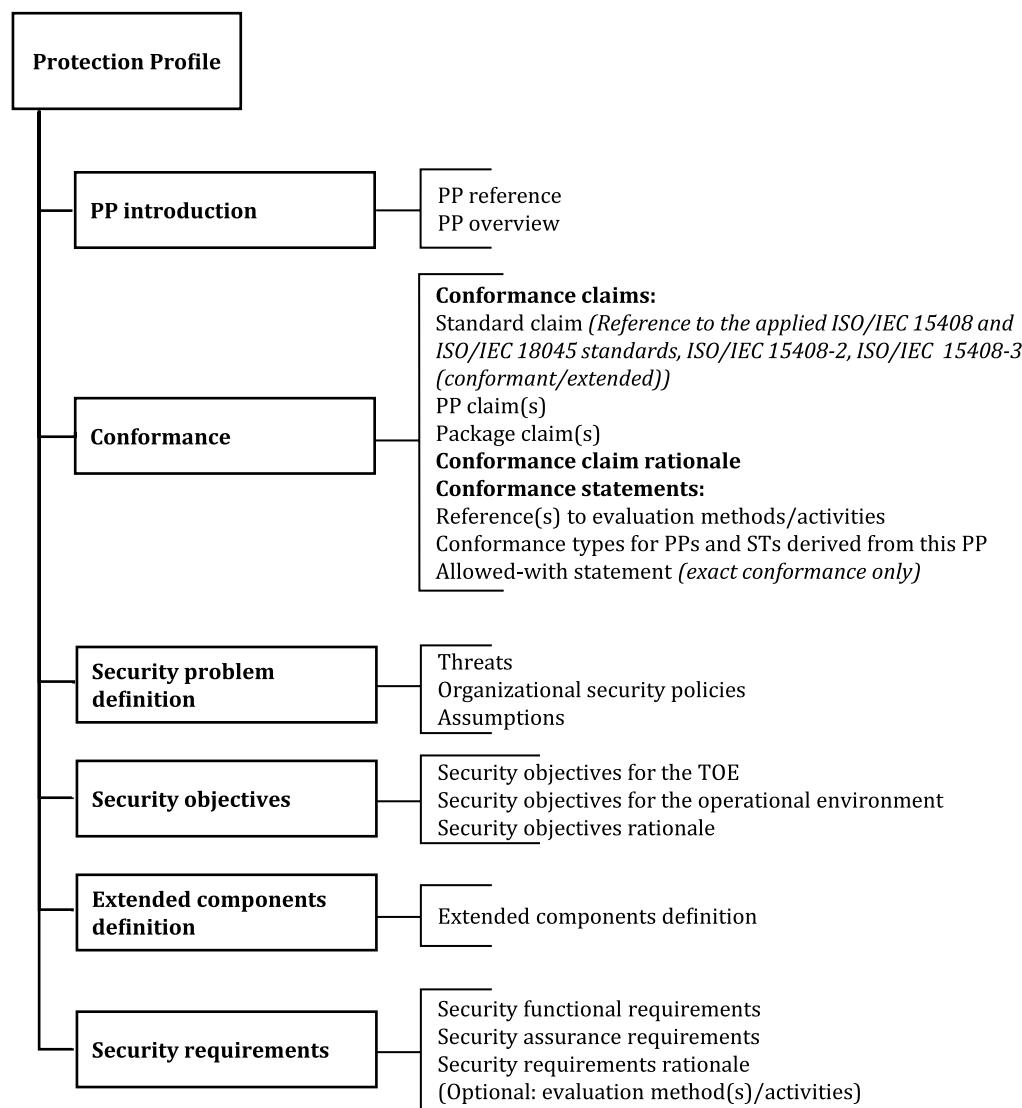
Unlike a ST, a PP is designed to describe a certain type of IT product, and not a single product. When only a single product is described, it is better to use a ST for this purpose.

B.3 Mandatory contents of a PP

B.3.1 General

There are two types of PP. Firstly, the “regular” PP which is a PP that contains the full contents as described in B.3.2 to B.3.7. Secondly, in some cases a PP author can write a Direct Rationale PP which has different contents compared to PPs that contain security objectives for the TOE. Direct Rationale PPs, and the reasons and circumstances in which they are used are described in detail in B.5. All other parts of this annex assume a PP with full contents.

Figure B.1 shows the content for a PP that is given in ISO/IEC 15408-3. Figure B.1 may also be used as a structural outline of the PP, though alternative structures are allowed. For instance, if the security requirements rationale is particularly bulky, it can be included in an appendix of the PP instead of in the security requirements section. The separate sections of a PP and the contents of those sections are briefly summarized below and explained in much more detail in B.3.2 to B.3.7.

**Figure B.1 — Contents of a Protection Profile**

A PP contains:

- a) a *PP introduction* containing the PP reference and a narrative description of the TOE type;
- b) *conformance claims*, showing:
 - which edition of relevant parts of the ISO/IEC 15408 series is applicable;
 - conformance to ISO/IEC 15408-2 and ISO/IEC 15408-3 (conformant or extended);
 - whether the PP claims conformance to any other PPs and/or packages, and if so, to which ones and the type of conformance claimed.
- c) *A conformance statement, containing:*
 - reference to any evaluation method(s) and/or activities that have been derived from ISO/IEC 18045;

NOTE Detail of any evaluation methods/activities can optionally be included in the PP, or in an associated supporting document.

- in the case of exact conformance, the allowed-with statement, indicating the PPs and PP-Modules that can be used in conjunction with the PP, appears in this section of the PP.
 - the type of conformance demanded of STs and other PPs derived from it.
- d) a *security problem definition*, showing threats, OSPs and assumptions;
- e) *security objectives*, showing how the solution to the security problem is divided between security objectives for the operational environment and optionally security objectives for the TOE;
- f) *extended components definition(s)*, where new components (i.e. those not included in ISO/IEC 15408-2 or ISO/IEC 15408-3) may be defined. These new components are needed to define extended functional and extended assurance requirements;
- g) *security requirements*, where a translation of the security objectives for the TOE into a standardized language is provided. This standardized language is in the form of SFRs. Additionally, this section of a PP defines the SARs.

B.3.2 PP introduction (APE_INT)

B.3.2.1 General

The PP introduction describes the TOE in a narrative way on two levels of abstraction:

- a) the PP reference, which provides identification material for the PP;
- b) the TOE overview, which briefly describes the TOE.

B.3.2.2 PP reference

A PP contains a clear PP reference that identifies that particular PP. A typical PP reference consists of title, version, sponsors, and publication date.

NOTE Here a distinction is made between the sponsor of a PP, i.e. the entity responsible for its development, and the author of a PP which is the entity responsible for its production.

EXAMPLE An example of a PP reference is "Atlantean Navy CablePhone Encryptor PP, version 2b, Atlantean Navy Procurement Office, April 1, 2020".

The reference should be unique so that it is possible to tell different PPs and different versions of the same PP apart. The PP reference facilitates indexing and referencing the PP and its inclusion in PP catalogues.

B.3.2.3 PP overview

B.3.2.3.1 General

The PP overview is aimed at potential consumers of a TOE type who are looking through catalogues of PPs that can support the specification of their security needs.

The PP overview is also aimed at developers who can use the PP in designing TOEs or in adapting existing products.

The typical length of a PP overview is several paragraphs.

To this end, the PP overview briefly describes the usage of the TOE and its major security features, identifies the TOE type, and identifies any major non-TOE hardware/software/firmware available to the TOE.

B.3.2.3.2 Usage and major security features of a TOE type

The description of the usage and major security features of the TOE type is intended to give a very general idea of what the TOE is capable of, and what it can be used for. This section is written for PP authors, TOE developers, or potential TOE consumers, describing TOE type usage and major security features in terms of business operations, using language that TOE consumers can understand.

EXAMPLE An example of this is “The Atlantean Navy CablePhone Encryptor is an encryption device that allows confidential communication between ships across the Atlantean Navy CablePhone system. To this end it allows at least 1024 different users and support at least 500 Mb/s encryption speed. It allows both bilateral communication between ships and broadcast across the entire network.”

B.3.2.3.3 TOE type

The TOE overview identifies the general type of a TOE addressed by the PP, such as: firewall, VPN-firewall, smart card, crypto-modem, intranet, web server, database, web server, mobile device, and database, etc. The TOE type definition often includes a characterization of the TOE software and hardware boundaries.

EXAMPLE This example of TOE type description is drawn from the Security IC Protection Profile: “The Target of Evaluation (TOE) is a security integrated circuit (security IC) which is composed of a processing unit, security components, I/O ports (contact, contactless, or similar interfaces like USB, MMC) and volatile and non-volatile memories (hardware). The TOE can also include IC Developer/Manufacturer proprietary IC Dedicated Software as long as it is delivered by the IC Manufacturer. (...) All other software running on the Security IC is called Security IC Embedded Software and is not part of the TOE.”

B.3.2.3.4 Available non-TOE hardware/software/firmware

While some TOEs do not rely upon other IT, many TOEs, notably software TOEs, rely on additional, non-TOE, hardware, software and/or firmware. In the latter case, the PP overview is required to identify the non-TOE hardware/software/firmware.

As a PP is not written for a specific product, in many cases only a general idea can be given of the available hardware/software/firmware. In some other cases, more specific information can be provided.

EXAMPLE 1 An example where more specific information is provided would be a requirements specification for a specific consumer where the platform is already known.

EXAMPLE 2 Examples of hardware/software/firmware identifications include:

- none (for a completely stand-alone TOE);
- a standard PC with a dual core 2.10 GHz or faster processor and 4GB or more RAM, running the Yaiza operating system for professionals, version 53.0 Update 6b, c, or 7, or version 54.0;
- a standard 64-bit server with a 2xQuad-Core core processor and 16GB or more RAM, running the Yaiza operating system, server edition version 7.0 Update 6d, and the WonderMagic 12.0 Graphics card with the 1.01 WM Driver Set;
- a CleverCard SB17067 integrated circuit;
- a CleverCard SB17067 integrated circuit running v12.0 of the QuickOS smart card operating system;
- the Yaiza mobile-OS 3.1.6 on smartphone and tablet devices using the FP9 processor.

B.3.3 Conformance claims and conformance statement (APE_CCL)**B.3.3.1 General**

The conformance claims section of a PP describes how the PP:

- states the applicable edition of the relevant parts of ISO/IEC 15408 series;

- conforms with ISO/IEC 15408-2 and ISO/IEC 15408-3 (i.e. conformant or extended);
- claims other PPs (if any);
- claims packages (if any);

The description of how the PP conforms to the ISO/IEC 15408 series consists of two items: the edition of the relevant part of ISO/IEC 15408 series that is used and whether the PP contains extended security requirements or not (see 10.3 and D.3.6).

The description of conformance claimed by the PP to other PPs means that the PP lists any other PPs to which conformance is being claimed to. The type of conformance being claimed is also identified. For an explanation of this, see 10.3.

The description of conformance of the PP to packages means that the PP lists the packages to which conformance is being claimed. For an explanation of this, see 10.3.

NOTE 1 See C.2.2.5 for the use of conformance claims in PP-Modules.

NOTE 2 See B.5.2 for the use of conformance claims in Direct Rationale PPs.

The conformance statement section of a PP describes how the PP:

- references any evaluation method(s) and/or activities derived from ISO/IEC 18405;
- may be used in conjunction with other PPs and PP-Modules in PP-Configuration. In the case of exact conformance, the conformance statement is required.

In the conformance statement, the references to the evaluation methods/ activities means that the PP provides references to the evaluation method(s) and/or activities to be used during an evaluation based on a ST claiming conformance to the PP. These evaluation methods and activities may be included directly in the PP or may be found in a referenced supporting document. It is not necessary to reproduce the text of these evaluation methods and activities in the PP. See 10.3.

If evaluation methods/ evaluation activities that have been derived from ISO/IEC 18045 are to be used to evaluate the PP then these shall be identified with the relevant security requirement section by including a statement in the following form:

“This PP requires the use of evaluation methods/ evaluation activities defined in <reference(s)>.”

In this statement, <reference> is replaced by the identification of the location of the relevant evaluation methods and evaluation activities. This reference may be to the document containing the PP or to one or more separate documents.

NOTE 3 As outlined in 13.5, in some cases, evaluation schemes do not always approve the use of particular EMs/EAs.

The conformance type in the PP states how STs and/or other PPs shall conform to that PP. The PP author selects whether “exact”, “strict” or “demonstrable” conformance is required.

B.3.3.2 Exact conformance

If exact conformance is selected, the PP author shall, where applicable, specify the following information in the allowed-with statement in the conformance claims section of the PP:

- other PPs that may be used, either by a ST based on this PP, or used in a PP-Configuration, with this PP;
- PP-Modules that may specify this PP in that PP-Module’s PP-Module Base, or that may be present in a PP-Configuration that also includes the PP.

NOTE 1 If neither of the above options is exercised, then a ST can claim exact conformance to only the PP by itself.

NOTE 2 A PP cannot claim exact conformance to another PP.

B.3.4 Security problem definition (SPD) (APE_SPD)

See 7.1 for information and requirements for the SPD, including threats, assumptions and organizational security policies (OSPs).

B.3.5 Security objectives (APE_OBJ)

See 7.2 for information and requirements for the security objectives including security objectives for the TOE and security objectives for the operational environment.

NOTE In the case of Direct Rationale, security objectives for the TOE are not included.

B.3.6 Extended components definition (APE_ECD)

In many cases the security requirements in a PP are based on components given in ISO/IEC 15408-2 or ISO/IEC 15408-3, see B.3.7. However, in some cases, there can be requirements in a PP that are not based on components in ISO/IEC 15408-2 or ISO/IEC 15408-3. In these cases, new components, i.e. extended components, shall be defined, and the definition provided in the Extended Components Definition section. For more information on this, see 8.4.

NOTE This subclause is intended to contain only the extended components and not the extended requirements which are based on the extended components. The extended requirements are included in the security requirements section as described in B.3.7 and are then for all purposes treated identically to the requirements that are based on components given in ISO/IEC 15408-2 or ISO/IEC 15408-3.

B.3.7 Security requirements (APE_REQ)

B.3.7.1 General

The security requirements consist of two groups of requirements:

- a) *the security functional requirements* (SFRs): a translation of the security objectives for the TOE into a standardized language;
- b) *the security assurance requirements* (SARs): a description of how assurance is to be gained that the TOE meets the SFRs.

These two groups are discussed in 7.3.

B.3.7.2 Including requirements in a PP

For a PP with strict conformance to another PP, all the requirements in this PP shall be included, and additional requirements may be included in the conformant PP.

For a PP with demonstrable conformance to another PP, all requirements in this PP shall be included, or a rationale explaining how they are otherwise met shall be provided in the conformant PP.

The following types of discretionary requirement may be included in PPs in all (exact, strict and demonstrable) conformance types:

If a PP contains optional requirements, a conformant PP may instantiate these requirements, being sure to include any required SPD-elements associated with those requirements. This may be done regardless of the conformance required by the PP. Omitting optional SFRs does not constitute “partial conformance” to a PP, and thus is allowed.

B.4 Referring to other standards in a PP

In some cases, a PP author needs to refer to an external standard, such as a particular cryptographic standard or protocol. The ISO/IEC 15408 series allows two ways of doing this:

- a) as an OSP (or part of it);

EXAMPLE 1 There exists a government standard defining how passwords shall be chosen, this can be stated as an OSP in a PP. This can lead to an objective for the environment (e.g. if users of the TOE need to choose passwords accordingly), or it can lead to security objectives for the TOE and then to appropriate SFRs (likely of the FIA class), if the TOE generates passwords. In both cases the rationale of the PP author needs to make plausible that the security objectives for the TOE and the SFRs are suitable to fulfil the OSP. The evaluator will examine if this is in fact plausible (and can decide to look into the standard for this), if the OSP is implemented by SFRs, as explained below.

- b) as a technical standard used in a refinement of a component or security requirement.

EXAMPLE 2

FCS_CKM.1.1 Refinement: “The [selection: TSF, TOE platform] shall generate asymmetric cryptographic keys in accordance with a specified cryptographic key generation algorithm

[selection:

RSA schemes using cryptographic key sizes of 2048-bit or greater that meet the following: [selection:

FIPS PUB 186-4, “Digital Signature Standard (DSS)”, Appendix B.3;

ANSI X9.31-1998, Section 4.1];

ECC schemes using “NIST curves” P-256, P-384 and [selection: P-521, no other curves] that meet the following: FIPS PUB 186-4, “Digital Signature Standard (DSS)”, Appendix B.4;

FFC schemes using cryptographic key sizes of 2048-bit or greater that meet the following: FIPS PUB 186-4, “Digital Signature Standard (DSS)”, Appendix B.1

]”.

If reference to only a certain part of a standard is intended, that part shall be unambiguously stated in the SFR refinement.

NOTE The PP author is reminded that referring to a standard in SFRs can impose a significant burden on a developer developing a TOE that meets the PP (depending on the size and complexity of the standard and the assurance required), and that it can be more suitable to require alternative (non-CC related) ways to assess conformance to that standard.

B.5 Direct Rationale PPs

B.5.1 General

Writing a PP includes consideration of the STs that will be written with the PP as a basis. As noted in D.4, in some cases it is desired to write a PP that supports the specification of Direct Rationale STs.

The intention of the Direct Rationale PP is to minimize the level of indirection between the SPD, any security objectives for the operational environment, and the SFRs.

In some situations, it is appropriate to omit the definition of the TOE security objectives. In this case the SFRs enhanced with natural language descriptions and the objectives for the environment directly map the SPD.

A Direct Rationale PP consists of:

- a PP introduction, consisting of a PP reference and a TOE overview;
- the conformance claim;
- security objectives for the operational environment;
- the SFRs and the SARs (including the extended components definition) and the security requirements rationale (only if the dependencies are not satisfied).

The content of a Direct Rationale PP is shown in Figure B.2.

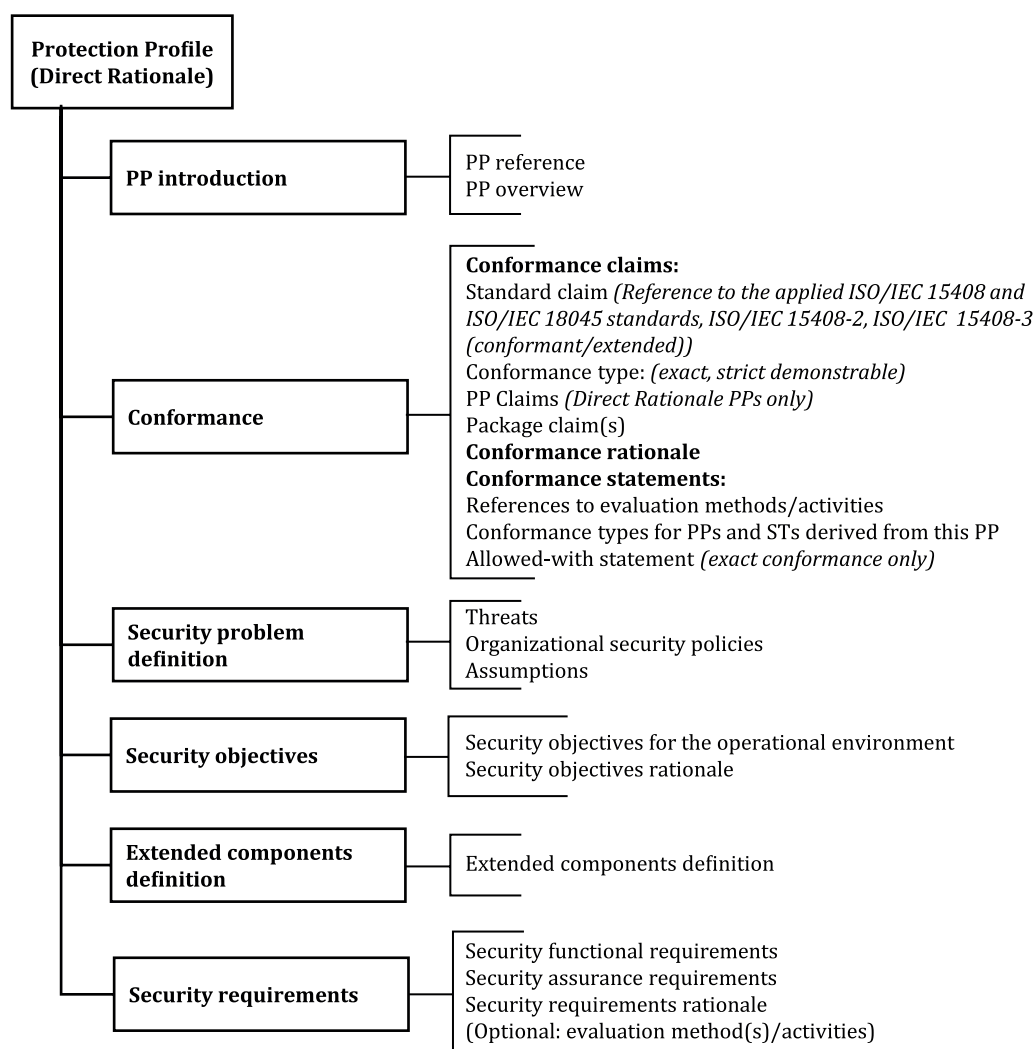


Figure B.2 — Contents of a Direct Rationale PP

B.5.2 Conformance claims (APE_CCL) for Direct Rationale PPs

A Direct Rationale PP shall only claim conformance to another Direct Rationale PP.

A regular PP may claim conformance with a Direct Rationale PP.

B.5.3 Security Objectives (APE_OBJ) for Direct Rationale PPs

A Direct Rationale PP has the following differences with respect to security objectives when compared to a PP that contains security objectives for the TOE:

- security objectives for the TOE are not included. The security objectives for the operational environment shall still be described;
- a security objectives rationale is included only for the security objectives for the operational environment since there are no TOE security objectives in the PP;
- Security Requirements (APE_REQ) for Direct Rationale PPs.

A security requirements rationale that directly maps the SFRs and any security objectives for the operational environment to the SPD-elements is included. It is recommended that this part of the security requirements rationale is located directly under each of the threats, OSPs and assumptions in the SPD section. As in regular PPs, the security requirements rationale also needs to justify any SFR dependencies that are not satisfied; this part of the rationale is typically located after the definition of the SFRs.

B.6 Optional contents of a PP

PPs may include evaluation methods/ activities that are derived from ISO/IEC 18405. Evaluation methods/ activities that are associated with the PP are referenced in the conformance statement section of the PP. See 10.3.

If the PP author decides to include any evaluation method(s) and/or activities in the PP then they may be described either in a (separate) supporting document, or in the security requirements section of the PP along with the relevant security requirement.

Annex C (normative)

Specification of PP-Modules and PP-Configurations

C.1 Goal and structure of this annex

The goal of this annex is to summarize the structure and expected content of PP-Modules and PP-Configurations.

NOTE This annex does not define the requirements for evaluation of PP-Configurations. The PP-Configuration evaluation criteria are found in the ACE class given in ISO/IEC 15408-3.

C.2 Specification of PP-Modules

C.2.1 Using a PP-Module

A PP-Module is a security statement of a group of users or developers, regulators, administration, or any other entity that meets specific consumer needs. A PP-Module complements one or more PPs and optionally other PP-Modules, which are referred to as that PP-Module's "PP-Module Base", and allows consumers to refer to this statement, facilitates the evaluation against it and the comparison of conformant evaluated TOEs. A PP-Module can only be used within a PP-Configuration that includes this PP-Module Base.

NOTE A base PP is a PP that is required by a PP-Module. A base PP-Module is a PP-Module that along with its PP-Module Base is required by another PP-Module.

C.2.2 Mandatory contents of a PP-Module

C.2.2.1 General

Figure C.1 shows the content of a PP-Module.

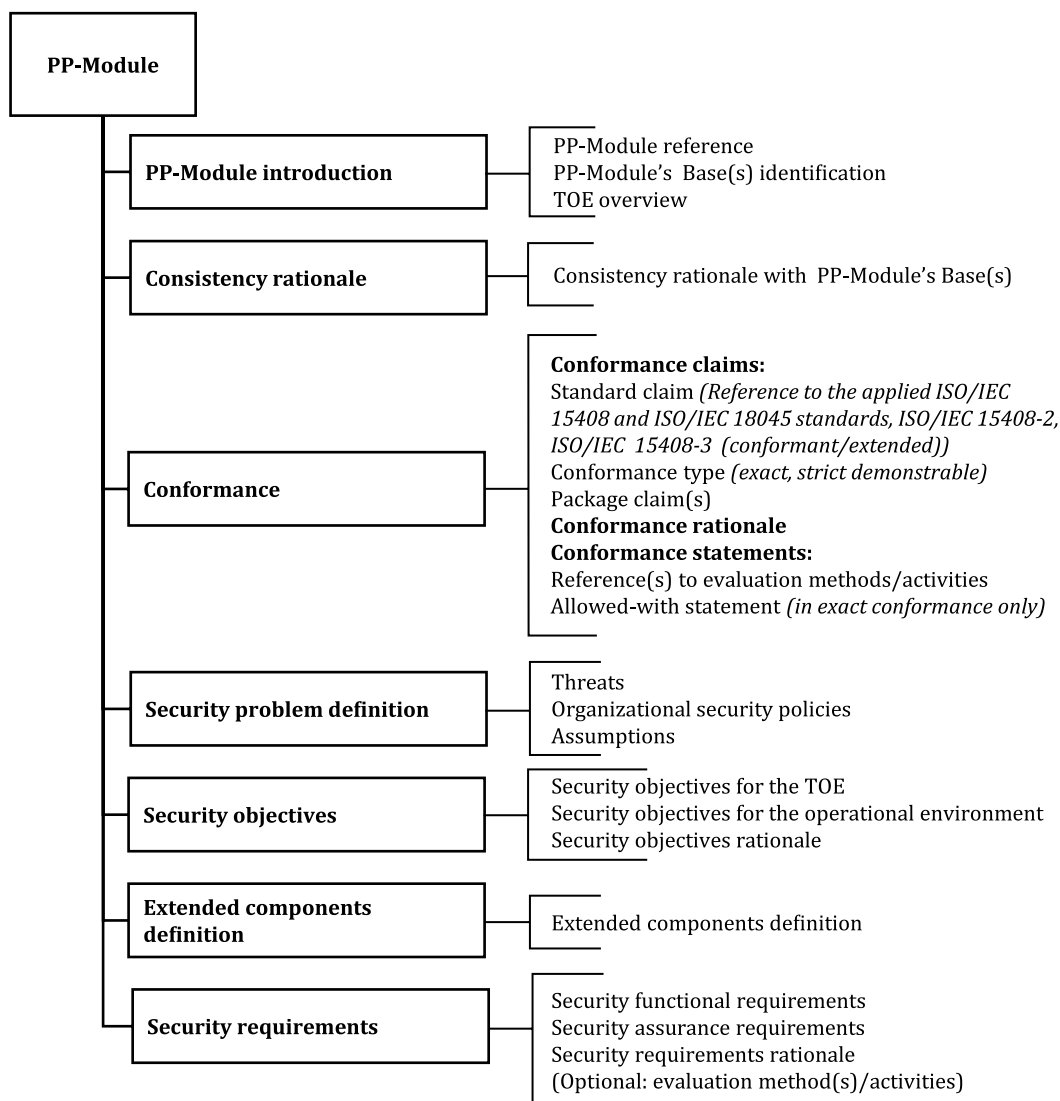


Figure C.1 — Contents of a PP-Module

The content of a PP-Module is summarized below and explained in detail in C.2.2.2 to C.2.3. A PP-Module contains:

- an *Introduction* which identifies the PP-Module, identifies the PP-Module Base which it is based on and provides a description of the TOE within its environment that meets the descriptions underlying the PP-Module Base;
- a *consistency rationale* that states the correspondence between the PP-Module and its PP-Module Base;
- a *conformance claim* regarding the edition of the ISO/IEC 15408 series, the conformance statement and for the case of exact conformance the allowed-with statements;
- a *security problem definition* with threats, assumptions, and OSPs;
- a *security objectives section* presenting the solution to the security problem in terms of objectives for the TOE and its operational environment;
- an optional *extended functional components* definition where new functional components not included in ISO/IEC 15408-2 are introduced;

- a *security functional requirements* section with a standardized statement of the TOE security objectives;
- a *security assurance requirements* section, except in the exact conformance where the SARs are inherited from the base PPs.

C.2.2.2 PP-Module introduction

C.2.2.2.1 PP-Module reference

The PP-Module introduction provides a clear and unambiguous reference that allows identifying the PP-Module. A typical reference is made of the title of the PP-Module and the version of the document, the sponsors, and the publication date.

The PP-Module reference can be used to index the document in PP catalogues.

C.2.2.2.2 Identification of PP-Module Base

The PP-Module introduction identifies its PP-Module Base. The identification consists of a list of references.

A PP-Module that requires to be used with a PP-Module Base, say $\{B_1 \dots, B_n\}$, will provide an identification list of the following shape:

$$B_1 \dots AND \dots B_n \text{ with } n \geq 1$$

This set of PPs/PP-Modules shall be closed, that is, for any PP-Module B_i , its own PP-Module Base shall belong to the set $\{B_1 \dots B_n\}$.

NOTE 1 This means that the set $\{B_1 \dots, B_n\}$ either does not contain any PP-Module or that it contains at least one PP-Module which requires base PPs only but no other base PP-Module.

A PP-Module may also allow alternative sets of PP-Module Base, say $\{S_1 \dots S_k\}$; in this case, the identification list states:

$$S_1 \dots OR \dots S_k \text{ with } k \geq 1$$

The unfolded form of the identification of alternative sets of PP-Module Base is then:

$$(B_1 \dots AND \dots B_{n_i}) \dots OR \dots (B_1 \dots AND \dots B_{n_k}) \text{ with } k \geq 1 \text{ and } n_i \geq 1$$

NOTE 2 A PP-Module that states an OR-ed list is equivalent to as many PP-Modules as elements S_i in the list, i.e. an OR-ed list is a shortcut to avoid defining and maintaining similar PP-Modules for different usages.

C.2.2.2.3 TOE overview

The TOE overview of a PP-Module may complete the TOE overviews of the PP-Module Base, provided consistency between the PP-Module and its PP-Module Base is ensured;

- the TOE type of the PP-Module may either be the same as that of the PP-Module Base or may introduce specificities required to meet the purpose of the PP-Module;
- the PP-Module may introduce further usage and major security features in addition to those stated in the PP-Module Base;
- the PP-Module can specify particular non-TOE hardware, software and/or firmware compliant with the statement in the PP-Module Base.

In a PP-Module, the possibility of supplementing the TOE overview of the PP-Module Base has the same meaning as in a PP or ST that supplements the TOE overview of another PP to which they claim conformance.

The statement of the TOE overview in a PP-Module may be given by reference when it is the same as in its PP-Module Base, i.e. when there is no addition. The PP-Module may provide as many specific TOE overviews as alternative PP-Module Bases.

C.2.2.3 Consistency rationale

The PP-Module shall provide a consistency rationale with respect to its PP-Module Base.

If the PP-Module specifies alternative PP-Module Bases, the PP-Module shall provide as many consistency rationales as the number of alternative PP-Module Bases.

The consistency analysis for each PP-Module Base shall be performed on the TOE type, the SPD, the objectives, and the SFRs. At the end, the goal is to demonstrate that a TOE can meet the TOE type descriptions provided in the PP-Module Base and in the PP-Module and satisfy all the SFRs specified in the PP-Module and its PP-Module Base. The consistency rationale shall demonstrate that the unions of SPDs, objectives, and SFRs defined in the PP-Module and in its PP-Module Base do not lead to a contradiction.

The consistency rationale may use correspondence tables between SPD/objectives/SFRs together with textual justifications.

C.2.2.4 Assurance rationale

The assurance rationale shall demonstrate the consistency of the applicable set of SARs, which may be inherited from its base PPs, with the SPD defined in the PP-Module, i.e. the assurance requirements and the threat model are not contradictory.

If the PP-Module does not inherit its set of SARs from its base PPs, then the assurance rationale shall demonstrate that the assurance requirements in the PP-Module and in its PP-Module Base are not contradictory with regard to the assets that are common to the PP-Module and its PP-Module Base.

C.2.2.5 Conformance claims and conformance statement

C.2.2.5.1 General

This section of a PP-Module shall be included for all PP-Modules and describes how the PP-Module conforms to:

- ISO/IEC 15408-2, ISO/IEC 15408-3, their editions, and any use of extended security requirements;
- functional and assurance packages.

A PP-Module shall not claim conformance to any PP, other PP-Module, or PP-Configuration.

The PP-Module conformance statement identifies the required conformance type. Exact conformance is inherited from the base PPs and require that all the PP-Module Bases are of exact conformance as well. The PP-Module conformance statement may also identify any evaluation methods/ activities that are required to be used with it.

If evaluation methods/ evaluation activities that have been derived from ISO/IEC 18045 are to be used to evaluate the PP-Module, then these shall be identified with the relevant security requirement section by including a statement in the following form:

“This PP-Module requires the use of evaluation methods/ evaluation activities defined in <reference>.”

Where <reference> is replaced by identification of the location of the evaluation methods and evaluation activities applicable to the PP-Module. This reference may be to the document containing the package, or to one or more separate documents.

NOTE Evaluation methods/ evaluation activities can either be included in the PP-Module itself or included by reference to one or more separate documents describing them.

C.2.2.5.2 Exact conformance

In the case of exact conformance, the allowed-with statement also includes an identification of PPs and PP-Modules other than the PP-Module's set of PP-Module Base, that are allowed to be used in PP-Configurations with that PP-Module.

All components in a PP-Configuration that require exact conformance shall require exact conformance in their conformance statements as well.

NOTE 1 This maintains the exact conformance concept that the PP-Module authors have control over which other requirements can be specified in combination with the requirements specified in their PP-Module.

Figure C.2 shows how conformance claims and statements are inherited in the single-assurance case of exact conformance.

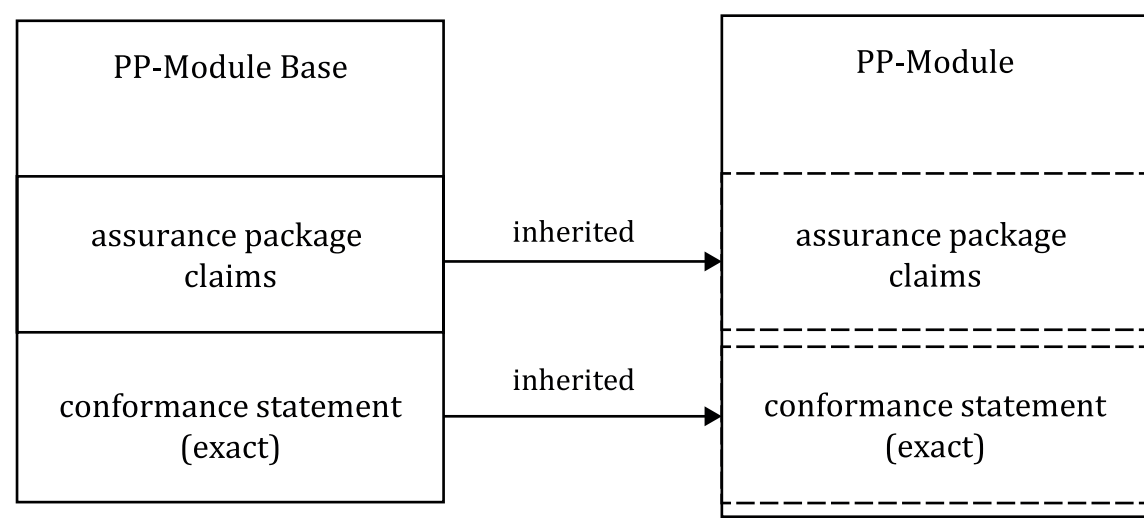


Figure C.2 — Inherited conformance claims and statement for the exact conformance case

NOTE 2 Where exact conformance is used, EMs/EAs are not allowed to be defined in a PP-Configuration (i.e. the EMs/EAs to be used are identified only in the PPs and PP-Modules used in the PP-Configuration).

C.2.2.6 Security problem definition (SPD)

This section defines the security problem addressed by the PP-Module. It can contain all types of SPD-elements, i.e. assumptions, threats, and OSPs.

A PP-Module defines the security problem in relationship with the security problem of the PP-Module Base and the definition of the TOE and its environment provided in the PP-Module's *Introduction*.

Each SPD-element can either come from a PP-Module Base or be entirely new. Let "E" be an SPD-element of the PP-Module, one of the following cases holds:

- "E" belongs to an identified PP-Module Base; a reference to the SPD-element is sufficient;
- "E" is a refinement of an SPD-element of a PP-Module Base;
- "E" is a new SPD-element, related to additional features of the TOE or its environment.

NOTE 1 The refined SPD-elements can be dealt with as new SPD-elements without any impact on the meaning of the SPD.

NOTE 2 In the same way that STs can, a PP-Module can introduce assumptions provided they cover aspects that are outside the scope of the PP-Module Base.

C.2.2.7 Security objectives

This section defines the security objectives for the TOE and for the TOE's operational environment.

A PP-Module defines new security objectives in context with the security objectives of the PP-Module Base.

Each security objective may either come from a PP-Module Base or be entirely new. Let “O” be an objective of the PP-Module, one of the following cases holds:

- “O” belongs to the PP-Module Base; a reference to the security objective is sufficient;
- “O” is a refinement of a security objective of the PP-Module Base;
- “O” is a new objective introduced by the PP-Module.

NOTE The refined objectives can be dealt with as new objectives without any impact on the meaning of the whole set of objectives.

A PP-Module may introduce new objectives for the TOE operational environment only when they address aspects that are outside the scope of the PP-Module Base.

In the case where a PP-Module refines the TOE type, some security objectives for the environment of the PP-Module Base can become security objectives for the TOE in the PP-Module.

This section also defines the rationale between the SPD and the security objectives of the PP-Module, which consists of a mapping that traces the SPD of the PP-Module to their security objectives as well as a justification demonstrating that the tracing is effective, as specified in 7.2.5. Moreover, the mapping has to show not only that all the SPD-elements are covered but also that there is no useless security objective.

It can happen that some security objectives of the PP-Module cover also SPD-elements of the PP-Module Base that do not belong to the SPD of the PP-Module itself. This information is not required but may be provided in application notes.

C.2.2.8 Extended functional components definition

This section is identical to the PP and ST extended components section specified in B.3.6.

C.2.2.9 Security requirements

The security requirements consist of two groups of requirements:

a) *security functional requirements* (SFRs);

A translation of the security objectives for the TOE into a standardized language;

b) *security assurance requirements* (SARs).

A description of how assurance is to be gained that the TOE meets the SFRs.

These two groups are discussed in 7.3.

C.2.2.9.1 Security functional requirements (SFRs)

This section defines the SFRs for the TOE in relationship with the set of TOE security objectives in the PP-Module and with the SFRs of the PP-Module Base.

Each security functional requirement may either come from the PP-Module Base or be entirely new. Let “R” be a security functional requirement of the PP-Module, one of the following cases holds:

- “R” belongs to the PP-Module Base; a reference to the requirement is sufficient;

- “R” is a refinement of an SFR in the PP-Module Base;
- “R” is a new requirement introduced by the PP-Module.

NOTE The refined requirements can be dealt with as new ones without any impact on the meaning of the whole set of requirements.

This section also defines the rationale between the SFRs and the TOE security objectives of the PP-Module, which consists of a mapping that traces the SFRs to the TOE objectives of the PP-Module and a justification demonstrating that the tracing is effective, as specified in 7.2.5. Moreover, the mapping shall show not only that all the objectives for the TOE are covered but also that there is no useless security functional requirement.

It can happen that some SFRs of the PP-Module cover also TOE security objectives of the PP-Module Base that do not belong to the PP-Module itself. This information is not required but may be provided in application notes.

PP-Modules may define and include optional SFRs (and any required SPD elements) as previously specified for PPs in B.3.7.

C.2.2.9.2 Security assurance requirements (SARs)

A PP-Module defines the set of SARs to be used in PP-Configurations that include this PP-Module. The assurance rationale described in C.2.2.4. ensures the consistency of this set of SARs with regard to the PP-Module Base.

A PP-Module using single-assurance inherits the set of SARs, including any assurance packages such as the pre-defined EALs, from its PP-Module Base. The issue of ANDed elements of PP-Module Base with different SARs shall be resolved and is dealt with in the same way that a PP conformant to all those PPs deals with the issue.

C.2.3 Direct Rationale PP-Modules

PP-Modules can be written with the intention that they be used with components in their PP-Module Base that also use the Direct Rationale approach. In this case security objectives for the TOE are not included in the PP-Module and security objectives for the TOE's operational environment may be included.

The contents of a Direct Rationale PP-Module are shown in Figure C.3.

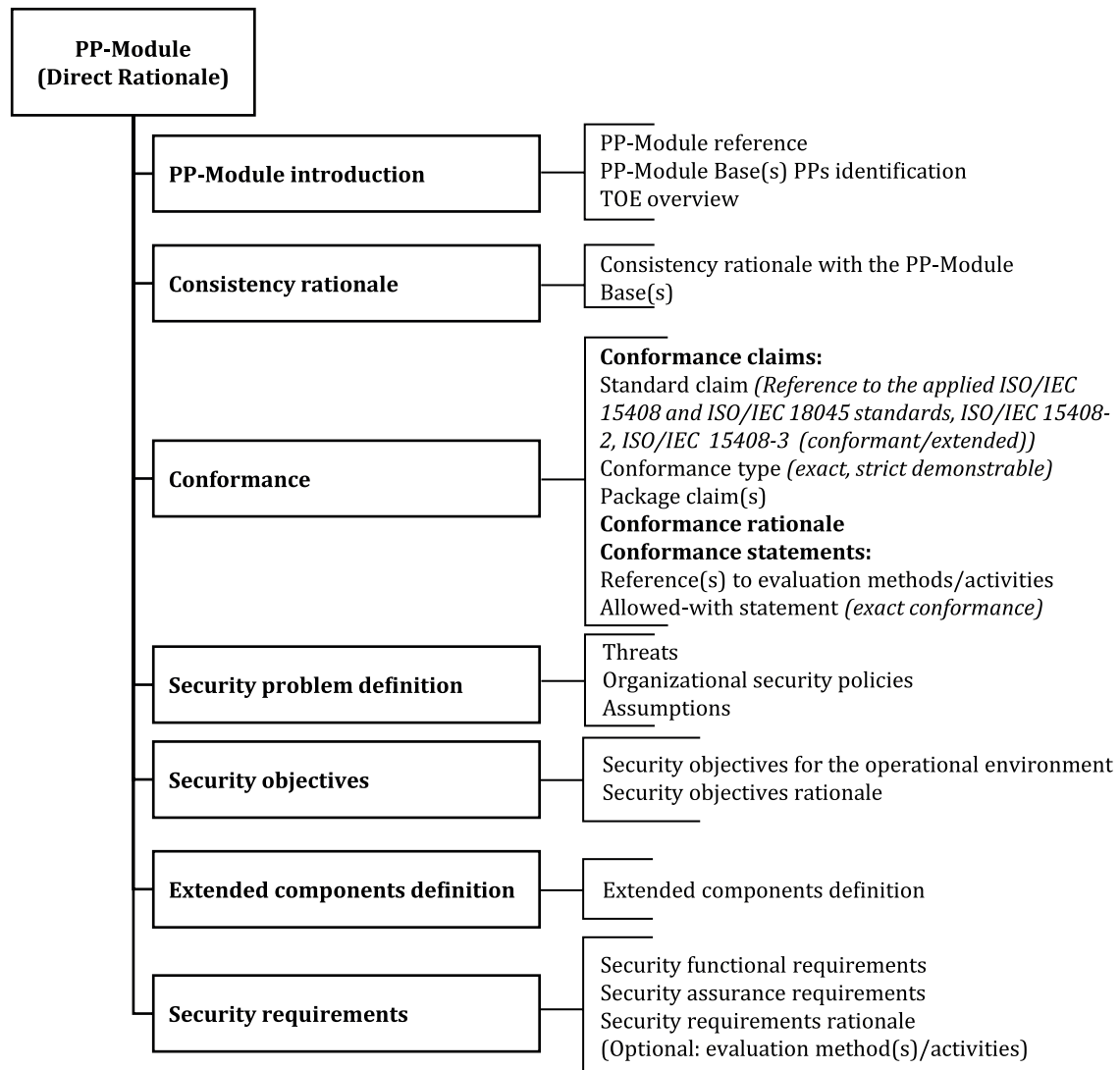


Figure C.3 — Contents of a direct rationale PP-Module

C.2.4 Guidance for inclusion of SPD-elements from a PP-Module Base

In order to limit the amount of information contained in the PP-Module, the PP-Module author applies the following rules:

Let E, O and R belong to the SPD, the security objectives, and the SFRs of a PP/PP-Module Q, respectively, with R mapped to O and O mapped to E.

Let M be a PP-Module and let Q belong to M's PP-Module Base.

M shall satisfy the following condition: E, O, R, and the mappings between them should belong to M only if at least one of these elements is linked to a new element in M, i.e.:

- either there is a new SPD-element E' in M such that O is mapped to E'; or
- there is a new objective O' in M such that O' is mapped to E' or R is mapped to O'; or
- there is a new requirement R' in M such that R' is mapped to O.

A PP-Module would not contain portions of the PP-Module Base unless they are required to fulfil new needs. Here, refined elements are considered new.

C.2.5 Optional Contents of a PP-Module

PP-Modules may optionally include evaluation methods/ activities that have been derived from ISO/IEC 18045. Evaluation methods/ activities that are associated with the PP-Module are identified in the conformance statement section. See 11.2.3.3.

If the PP-Module author decides to include any evaluation method(s) and/or activities in the PP-Module then they may either be provided in the security requirement section with the relevant security requirement or in any other suitable section or external document. Application notes, when appropriate, should be associated with the specific requirements in the PP-Module.

C.3 Specification of PP-Configurations

C.3.1 General

The content of a PP-Configuration is summarized below in Figure C.4 and explained in detail in Annexes C.3.2 through C.3.7.

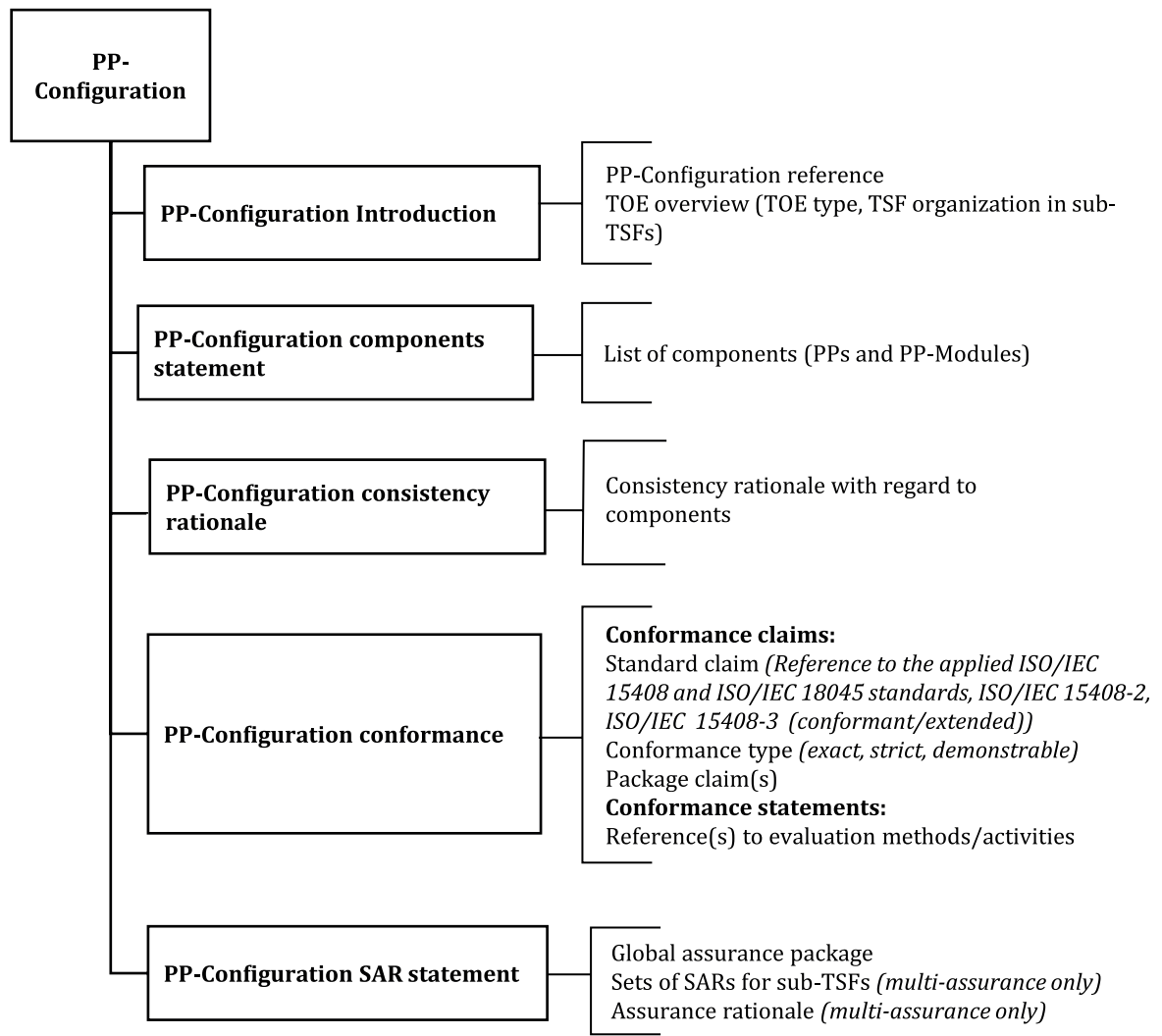


Figure C.4 — Contents of a PP-Configuration

A PP-Configuration contains:

- a reference that uniquely identifies the PP-Configuration;

- a components statement that identifies the PPs and the PP-Modules composing the PP-Configuration, including all the PP-Module Base required to define a closed set of components;
- a conformance claim, that specifies the edition of relevant parts of ISO/IEC 15408 series, the claims to ISO/IEC 15408-2 and ISO/IEC 15408-3, the claims to assurance packages, and the conformance statement that defines whether the conformance of STs to this PP-Configuration has to be exact, strict, demonstrable, or a combination of strict and demonstrable inherited from its set of components, and any applicable evaluation methods/ activities;
- a description of the TOE type;
- a description of the TSF organization in terms of the sub-TSFs defined by the PP-Configuration components;
- a SAR statement, specifying the set of the SAR that are applicable to the entire TOE. In a multi-assurance case, the SAR statement includes the sets of SARs that apply to the sub-TSFs defined in the PP-Configuration components. The SAR statement also includes the assurance rationale to ensure consistency between the PP-Configuration and its components.

NOTE An assurance package can be an EAL drawn from ISO/IEC 15408-5.

C.3.2 PP-Configuration reference

The PP-Configuration reference provides a clear and unambiguous identification, usually made of a title, version number, author, and the publication date.

The PP-Configuration reference can be used to index the document in catalogues.

C.3.3 Components statement

The PP-Configuration components statement identifies the PPs and the PP-Modules that compose the PP-Configuration.

The PP-Configuration components statement shall include the PP-Module Base required by the specified PP-Modules. If a PP-Module specifies alternative PP-Module Bases, only one of these sets shall be referred to in the PP-Configuration.

NOTE PP-Configurations do not directly claim conformance to functional packages, regardless of whether they are claimed by one of their components or not.

In the multi-assurance case, the PP-Configuration components statement shall provide the TSF organization in terms of the sub-TSFs defined by the components of the PP-Configuration.

C.3.4 TOE overview

The TOE overview of a PP-Configuration shall provide:

- the TOE type of the PP-Configuration, to be used by STs claiming conformance with the PP-Configuration;
- the expected usage and major security features of the TOE;
- the available non-TOE hardware, software and/or firmware (if applicable).

C.3.5 Consistency rationale

A PP-Configuration shall provide a consistency rationale to ensure the compatibility of the combination of components.

The consistency rationale shall demonstrate that the TOE overview is consistent with the TOE overview of the PP-Configuration components and that the unions of SPDs, objectives, and SFRs defined in these components do not lead to a contradiction.

The consistency rationale may use correspondence tables between SPD/objectives/SFRs together with textual justifications.

C.3.6 Conformance claim and conformance statement

C.3.6.1 ISO/IEC 15408 series conformance claim

The edition of relevant parts of the ISO/IEC 15408 series applicable to the PP-Configuration.

C.3.6.2 Conformance type

The conformance to this PP-Configuration by a ST shall be one of exact, strict, or demonstrable; or a combination of strict and demonstrable if the PP-Configuration contains components of both conformance types.

Any ST that claims conformance to a PP-Configuration shall conform to the conformance type required in the conformance statement of the PP-Configuration.

C.3.6.3 Assurance package conformance claim

The conformance claim may include an assurance package conformance claim describing any conformance of the PP-Configuration to an assurance package. More than one package may be claimed in a PP-Configuration.

C.3.6.4 Evaluation methods/activities references statement(s)

The PP-Configuration EM/EA conformance statement may also identify any evaluation methods/activities that are required to be used with it.

A PP-Configuration that is of strict or demonstrable conformance type (but not of exact conformance type) may specify evaluation methods/ activities in addition to those referenced in the PP-Configuration components.

C.3.6.5 Additional requirements for exact conformance

If a PP-Configuration specifies exact conformance as its conformance type in its conformance statement, then:

- if any one component in the PP-Configuration requires exact conformance, then all other components in the PP-Configuration shall also require exact conformance, and the conformance statement of the PP-Configuration shall specify exact conformance;
- all components in the PP-Configuration shall allow all the other components in the PP-Configuration to be used together in the PP-Configuration in their respective allowed-with statement in the conformance claims section;

NOTE A PP-Module does not need to include its own PP-Module Base in its allowed-with statement because they are implicitly allowed. An example is provided in Figure C.5.

- the EM/EA that are applied to a PP-Configuration shall be only those that are contained in the PP-Configuration's components; no additional evaluation methods/activities or modifications to the PP-Configuration components' evaluation methods/activities are allowed.

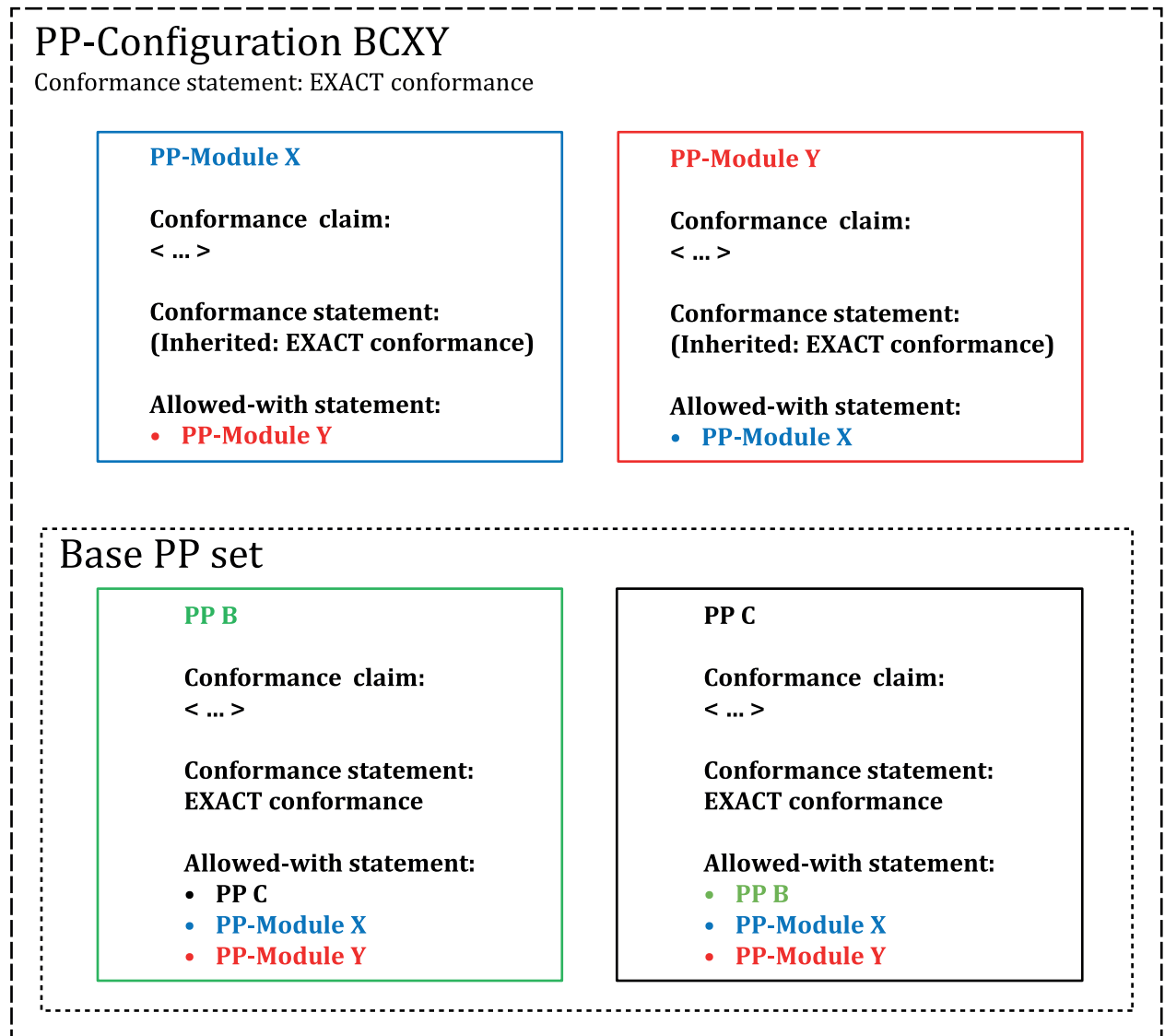


Figure C.5 — PP-Configuration and exact conformance

EXAMPLE A PP-Configuration requires exact conformance in its conformance statement because exact conformance is required in both base PPs and is therefore inherited by the PP-Modules. PP-Modules X and Y both have an identical base PP set: PP B and PP C both of which require exact conformance. The following statements (shown in the diagram) shall be true for this to be an evaluable PP-Configuration with a conformance statement of “exact conformance”:

- the PP-Modules inherit the conformance statement from their base PPs, so their conformance statement is exact conformance;
- the PP-Configuration shall require exact conformance since the PP-Modules require exact conformance;
- PP B shall specify in its conformance statement that it is allowed to be used with PP C, PP-Module X, and PP-Module Y;
- PP C shall specify in its conformance statement that it is allowed to be used with PP B, PP-Module X, and PP-Module Y;
- PP-Module X shall specify in its conformance statement that it is allowed to be used with PP-Module Y;
- PP-Module Y shall specify in its conformance statement that it is allowed to be used with PP-Module X.

C.3.7 SAR statement

The PP-Configuration SAR statement specifies the set of SARs applicable to the evaluation of a TOE specified by a ST that claims conformance to this PP-Configuration. In a multi-assurance case, when the PP-Configuration components carry different sets of SARs, the PP-Configuration shall define the set of SARs that applies to each of the sub-TSF defined by these components.

The set of SARs that apply to the entire TOE is called global assurance package.

In the case of demonstrable or strict type, the global assurance package is a superset of the common subset of SARs that apply to each of the PP-Configurations components.

In the case of an exact conformance type, the global assurance package is the minimum common set of SARs for the PP-Configuration's components; no augmentation is allowed.

In the PP-Configuration, the set of SARs that applies to each of the sub-TSF is either identical to the set of SARs defined in the corresponding PP-Configuration component or an augmentation of this set.

EXAMPLE An example of a set of SARs is an EAL assurance package pre-defined in ISO/IEC 15408-5.

A PP-Configuration shall provide an assurance rationale to demonstrate the consistency of the applicable set of SARs with those defined in its components, in particular with regard to the common assets. Additionally, the assurance rationale discusses disposition of EMs/EAs in the PP-Configuration components in the case where the SARs have been augmented at the PP-Configuration level, or additional EMs/EAs have been specified at the PP-Configuration level.

NOTE The assurance rationale of the PP-Configuration has to extend the analysis given in the PP-Modules to all the components of the PP-Configuration together. Usually this is done by unfolding the SPD-elements of the PP-Configuration components and analysing the sets of SARs applicable to each asset.

Annex D (normative)

Specification of Security Targets (STs) and Direct Rationale STs

D.1 Goal and structure of this annex

The goal of this annex is to summarize the structure and expected content of a ST.

As PPs and STs have a significant overlap, this annex focuses on the differences between PPs and STs. The material that is identical between STs and PPs is described in Annex B.

NOTE This annex does not define the requirements for the evaluation of STs. The ST evaluation criteria are found in the ASE class in ISO/IEC 15408-3.

This annex consists of four major parts:

a) *how to use a ST;*

This is summarized in D.2. This describes how a ST should be used, and some of the questions that can be answered with a ST.

b) *what a ST shall contain;*

This is detailed in D.3. This describes the mandatory contents of the ST, the interrelationships between these contents, and provide examples.

c) *claiming conformance with standards;*

D.5 describes how a ST author can claim that the TOE meets a particular standard.

d) *Direct Rationale STs.*

Direct Rationale STs are STs in which the SFRs and possibly to security objectives for the operational environment are mapped directly to the SPD-elements. D.4 is applicable to Direct Rationale STs.

D.2 Using a ST

D.2.1 How to use a ST

A typical ST fulfils two roles:

- a) Before and during the evaluation, the ST specifies “what is to be evaluated”. In this role, the ST serves as a basis for agreement between the developer and the evaluator on the exact security properties of the TOE and the exact scope of the evaluation. Technical correctness and completeness are major issues for this role. D.3.2 and D.3.5 describe how the ST is used in this role;
- b) After the evaluation, the ST specifies “what was evaluated”. In this role, the ST serves as a basis for agreement between the developer or re-seller of the TOE and the potential consumer of the TOE. The ST describes the exact security properties of the TOE in an abstract manner, and the potential consumer can rely on this description because the TOE has been evaluated to meet the ST. Ease of use and understandability are major issues for this role. D.2.3 describes how the ST is used in this role.

D.2.2 How not to use a ST

One role, among many, that a ST should not fulfil is:

- *A complete specification:*

A ST is designed to be a security specification and not a complete specification. Unless security-relevant, properties such as interoperability, physical size, and weight, required voltage etc. should not be part of a ST. This means that in general a ST can be a part of a complete specification, but not a complete specification itself.

D.2.3 Questions that can be answered with a ST

After the evaluation, the ST specifies “what was evaluated”. In this role, the ST serves as a basis for agreement between the developer or re-seller of the TOE and the potential consumer of the TOE. The ST can therefore answer the following questions (and more):

- a) *How can I find the ST/TOE that I need given the multitude of existing STs/TOEs?;*

This question is addressed by the TOE overview, which gives a brief (several paragraphs) summary of the TOE;

- b) *Does this TOE fit in with my existing IT-infrastructure?;*

This question is addressed by the TOE overview, which identifies the major hardware/firmware/software elements needed to run the TOE;

- c) *Does this TOE fit in with my existing operational environment?;*

This question is addressed by the security objectives for the operational environment, which identifies all constraints the TOE places on the operational environment in order to function;

- d) *What does the TOE do (interested reader)? ;*

This question is addressed by the TOE overview, which gives a brief (several paragraphs) summary of the TOE;

- e) *What does the TOE do (potential consumer)? ;*

This question is addressed by the TOE description, which gives a less brief (several pages) summary of the TOE;

- f) *What does the TOE do (technical)?;*

This question is addressed by the TOE summary specification which provides a high-level description of the mechanisms the TOE uses;

- g) *What does the TOE do (expert)?;*

This question is addressed by the SFRs which provide an abstract highly technical description, and the TOE summary specification which provide additional detail;

- h) *Does the TOE address the problem as defined by my government/organization?;*

If your government/organization has defined packages and/or PPs and/or PP-Configurations to define this solution, then the answer can be found in the Conformance Claims section of the ST, which lists all packages, PPs and PP-Configurations that the ST conforms to;

- i) *Does the TOE address my security problem (expert)?;*

What are the threats countered by the TOE? What OSPs does it enforce? What assumptions does it make about the operational environment? These questions are addressed by the SPD;

j) *How much trust can I place in the TOE?*

This can be found in the SARs in the security requirements section, which provide the assurance requirements that were used to evaluate the TOE, and hence the trust that the evaluation provides in the correctness of the TOE.

D.3 Mandatory contents of a ST

D.3.1 General

There are two types of ST. Firstly the “regular” ST which is a ST that contains the full contents as described in D.3.3 through D.3.7.2. Secondly, in some cases a ST author may use a Direct Rationale ST which does not state the security objectives for the TOE. Direct Rationale STs, and the reasons and circumstances in which they are used are described in detail in D.4 All other parts of this annex assume a ST with full contents.

Figure D.1 shows the contents of a ST that are given in ISO/IEC 15408-3.

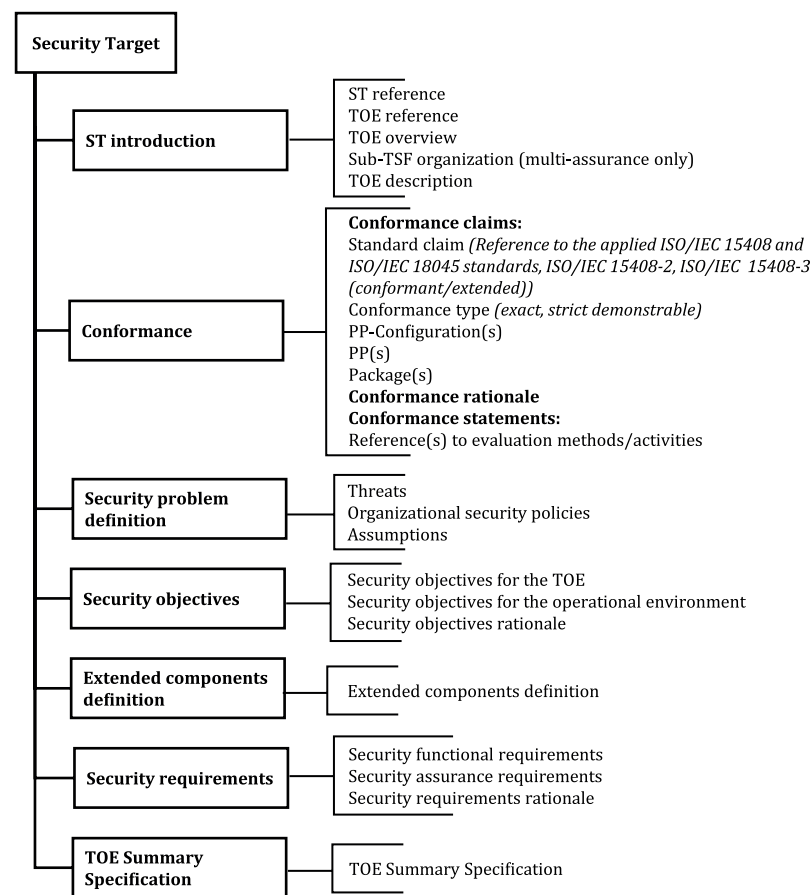


Figure D.1 — Contents of a ST

Figure D.1 may also be used as a structural outline of the ST, though alternative structures are allowed. For instance, if the security requirements rationale is particularly bulky, it can be included in an appendix of the ST instead of in the security requirements section. The separate sections of a ST and the contents of those sections are briefly summarized below and explained in much more detail in D.3.3 through D.3.7.2. A ST contains:

- a) *a ST introduction* containing three narrative descriptions of the TOE on different levels of abstraction;

- b) *a conformance claim*, stating the ST's conformance to the relevant edition of ISO/IEC 15408-2 and ISO/IEC 15408-3; showing whether the ST claims conformance to any PPs, PP-Configurations, and/or packages; and if so identifying the specific PPs, PP-Configurations, and/or packages, evaluation methods/activities, and the type of conformance claimed;
- c) *a security problem definition*, showing threats, OSPs and assumptions;
- d) *security objectives*, showing how the solution to the security problem is divided between security objectives for the TOE and security objectives for the operational environment of the TOE;
- e) *extended components definitions* (optional), where new components (i.e. those not included in ISO/IEC 15408-2 or ISO/IEC 15408-3) may be defined. These new components are needed to define extended functional and extended assurance requirements;
- f) *security requirements*, where a translation of the security objectives for the TOE into a standardized language is provided. This standardized language is in the form of SFRs. Additionally, this section defines the SARs;
- g) *a TOE summary specification*, showing how the SFRs are implemented in the TOE.

D.3.2 ST introduction (ASE_INT)

D.3.2.1 General

The ST introduction describes the TOE in a narrative way on three levels of abstraction:

- a) the ST reference and the TOE reference, which provide identification material for the ST and the TOE that the ST refers to;
- b) the TOE overview, which briefly describes the TOE;
- c) the TOE description, which describes the TOE in more detail.

D.3.2.2 ST reference and TOE reference

The ST reference and the TOE reference facilitate indexing and referencing the ST and TOE and their inclusion in catalogues.

A ST contains a clear ST reference that identifies that particular ST. A typical ST reference consists of title, version, sponsors, and publication date.

EXAMPLE 1 An example of a ST reference is "MauveRAM Database ST, version 1.3, MauveCorp Specification Team, 11 October 2017".

A ST also contains a TOE reference that identifies the TOE that claims conformance to the ST. A typical TOE reference consists of developer name, TOE name and TOE version number. A single TOE may be evaluated multiple times, for instance by different consumers of that TOE, and therefore have multiple STs associated with this this reference.

EXAMPLE 2 An example of a TOE reference is "MauveCorp MauveRAM Database v5.12".

If the TOE is constructed from one or more well-known products, it is allowed to reflect this in the TOE reference, by referring to the product name(s). However, this should not be used to mislead consumers: situations where major parts or security functionalities were not considered in the evaluation, yet the TOE reference does not reflect this are not allowed.

D.3.2.3 TOE overview

D.3.2.3.1 General

The TOE overview is aimed at potential consumers of a TOE who are looking through catalogues of evaluated TOEs/Products to find TOEs that meet their security needs, and are supported by their hardware, software, and firmware. The typical length of a TOE overview is several paragraphs.

To this end, the TOE overview briefly describes the usage of the TOE and its major security features, identifies the TOE type, and identifies any major non-TOE hardware/software/firmware required by the TOE.

In the case of a multi-assurance ST, the TOE overview also provides the TSF organization in terms of the sub-TSFs defined in the PP-Configuration the ST claims conformance to.

D.3.2.3.2 Usage and major security features of a TOE

The description of the usage and major security features of the TOE is intended to give a very general idea of what the TOE is capable of in terms of security, and what it can be used for in a security context. This section of the ST is written for (potential) TOE consumers, describing TOE usage and major security features in terms of business operations, using language that TOE consumers understand.

EXAMPLE “The MauveCorp MauveRAM Database v5.12 is a multi-user database intended to be used in a networked environment. It allows 1024 users to be active simultaneously. It allows password/token and biometric authentication, protects against accidental data corruption, and can roll-back ten thousand transactions. Its audit features are highly configurable, so as to allow detailed audit to be performed for some users and transactions, while protecting the privacy of other users and transactions.”

D.3.2.3.3 TOE type

The TOE overview identifies the type of TOE, e.g. firewall, VPN-firewall, smart card, crypto-modem, intranet, web server, database, web server and database, LAN, LAN with web server and database.

In the case that the TOE is not of a readily available type, in which case a TOE type of “none” can be used.

The identification of the TOE type shall not be misleading for consumers.

EXAMPLE Examples of misleading TOE types include:

- certain functionality can be expected of the TOE because of its TOE type, but the TOE does not have this functionality;

Examples include:

- an ATM-card type of TOE, which does not support any identification/authentication functionality;
- a firewall type of TOE, which does not support protocols that are almost universally used;
- a PKI-type of TOE, which has no certificate revocation functionality;
- the TOE can be expected to operate in certain operational environments because of its TOE type, but it cannot do so;
- a PC-operating system type of TOE, which is unable to function securely unless the PC has no network connection, floppy drive, and CD/DVD-player;
- a firewall, which is unable to function securely unless all users that can connect through that firewall are benign.

D.3.2.3.4 Required non-TOE hardware/software/firmware

While some TOEs do not rely upon other IT, many TOEs (notably software TOEs) rely on additional, non-TOE, hardware, software and/or firmware. In the latter case, the TOE overview is required to identify such non-TOE hardware, software and/or firmware. A complete and fully detailed identification of the additional hardware, software and/or firmware is not necessary, but the identification shall be complete and detailed enough for potential consumers to determine the major hardware, software and/or firmware needed to use the TOE.

EXAMPLE Examples of hardware/software/firmware identifications are:

- a standard PC with a dual core 2.10 GHz or faster processor and 4GB or more RAM, running the Yaiza operating system for professionals, version 53.0 Update 6b, c, or 7, or version 54.0;
- a standard 64-bit server with a 2xQuad-Core core processor and 16GB or more RAM, running the Yaiza operating system, server edition version 7.0 Update 6d, and the WonderMagic 12.0 Graphics card with the 1.0 WM Driver Set;
- a CleverCard SB17067 integrated circuit;
- a CleverCard SB17067 integrated circuit running v12.0 of the QuickOS smart card operating system;
- the December 2020 installation of the LAN of the Director-General's Office of the Department of Traffic.

D.3.2.3.5 TSF organization in sub-TSFs in the multi-assurance case

A multi-assurance ST, i.e. a ST that claims conformance to a multi-assurance PP-Configuration and which defines multiple sets of SARs for the different sub-TSFs, shall inherit the organization of the TSF in sub-TSFs from the PP-Configuration.

The TOE overview describes such organization, possibly completed with details of the actual TOE.

D.3.2.4 TOE description

A TOE description is a narrative description of the TOE, likely to run to several pages. The TOE description provides evaluators and potential consumers with a general understanding of the security capabilities of the TOE, in more detail than was provided in the TOE overview. The TOE description may also be used to describe the wider application context into which the TOE will fit.

The TOE description discusses the physical scope of the TOE: a list of all hardware, firmware, software, and guidance parts that constitute the TOE. This list shall be described at a level of detail that is sufficient to give the reader a general understanding of those parts.

The TOE description shall also discuss the logical scope of the TOE, including the major TOE functions and provide a brief description of the security features (the TSF). The description provided shall be at a level of detail that is sufficient to give the reader a general understanding of those features. This description is expected to be in more detail than the major security features described in the TOE overview.

An important property of the physical and logical scopes is that they describe the TOE in such a way that there remains no doubt on whether a certain part or feature is in the TOE or whether this part or feature is outside the TOE. This is especially important when the TOE is integrated with and cannot be easily separated from non-TOE entities.

EXAMPLE 1 Examples where the TOE is integrated with non-TOE entities are:

- the TOE is a cryptographic co-processor of a smartcard IC, instead of the entire IC;
- the TOE is a smartcard IC, except for the cryptographic processor;
- the TOE is the Network Address Translation part of the MinuteGap Firewall v28.2.

In some cases, third-party components can present practical difficulties in obtaining evidence.

EXAMPLE 2 An example of where sufficient evidence for evaluation is not available from third-parties includes when source code, design documentation or test evidence cannot be made available to the developer of the TOE.

D.3.3 Conformance claims (ASE_CCL)

The conformance claims section of a ST describes how the ST conforms with the ISO/IEC 15408 series, packages, PPs, and PP-Configurations. It is similar to the conformance claims section for a PP described in B.3.3 with one exception, a ST does not have a conformance statement since the ST is not allowed to claim conformance to another ST.

An additional distinction between an ST that claims conformance with a PP vs. an ST that claims conformance with a PP-Configuration is that while an ST can claim conformance to multiple PPs, and can augment functional packages in the PPs and even claim conformance to both a PP and a functional package, an ST can only claim conformance to exactly one PP-Configuration, and no additional PP-Configurations, PPs, or functional packages.

D.3.4 Security problem definition (SPD) (ASE_SPD)

The SPD section of a ST describes how the ST states the security problem that is to be addressed. It is identical to the SPD section for a PP described in B.3.4.

For a ST that conforms to PPs and/or PP-Configuration, the ST includes all the SPD elements defined in these PPs and PP-Configurations components. It may be the case that an assumption in a PP or PP-Configuration component may become an objective for the TOE in the ST.

D.3.5 Security objectives (ASE_OBJ)

This section of a ST is identical to the security objectives section of a PP as explained in B.3.5 and B.5.

For a ST that conforms to PPs and/or PP-Configuration, the ST includes all the objectives defined in these PPs and PP-Configurations components. It may be the case that objectives for the TOE operational environment in a PP or PP-Configuration component may become an objective for the TOE in the ST.

D.3.6 Extended Components Definition (ASE_ECD)

This section of a ST is identical to the extended components section of a PP as explained in B.3.6.

D.3.7 Security requirements (ASE_REQ)

D.3.7.1 Security Functional Requirements (SFRs)

D.3.7.1.1 General

This section of a ST is identical to the security requirements section of a PP as explained in B.3.7 with the exception that the specification of selection-based SFRs and optional requirements is not applicable in STs because all the SFRs shall be fully instantiated.

For a ST that conforms to PPs and/or PP-Configuration, the ST includes all the SFRs defined in these PPs and PP-Configurations components.

D.3.7.1.2 Including requirements in STs

For STs with exact conformance to a PP all requirements in the PP shall be included. Requirements that are not found in the PP shall not be included in the ST.

For STs with strict conformance to a PP all requirements in a PP shall be included.

For STs with demonstrable conformance to a PP all requirements in a PP shall be included, or a rationale explaining how they are otherwise met shall be provided in the ST.

For STs with strict or demonstrable conformance to a PP, additional requirements not found in the PP may be included provided they support additional security objectives/cover additional threats.

For a STs claiming conformance to a PP-Configuration, the same rules as for conformance to a PP applies. In that case, the requirements are taken from the components of the PP-Configuration, i.e. its PPs and PP-Modules. If the PP-Configuration contains components that require different conformance type (strict and demonstrable only, because exact conformance cannot be combined with other types), the ST conforms to each of the components (PPs and PP-Modules) in the manner they require, either strict or demonstrable.

If the ST claims conformance to a PP or PP-Configuration, and the PP or the components of the PP-Configuration contain optional requirements, the ST may instantiate these requirements, being sure to include any required SPD-elements associated with those requirements. This may be done regardless of the conformance required by the PP or PP-Configuration. Omitting optional SFRs in a ST does not constitute “partial conformance” to a PP or PP-Configuration, and thus is allowed.

EXAMPLE Example of the specification of external standards in SFRs and their evaluation:

FCS_CKM.1.1 Refinement: “The TSF¹⁾ shall generate asymmetric cryptographic keys in accordance with a specified cryptographic key generation algorithm: RSA schemes using cryptographic key sizes of 2048-bit or greater that meet the following: FIPS PUB 186-4, “Digital Signature Standard (DSS)”, Appendix B.3²⁾.”

Conformance to the standard as part of the fulfilment of the SFR by the TOE is then assessed in one of the following ways:

- if an explicit Evaluation Activity has been defined for the SFR, then the evaluator actions in that Evaluation Activity are carried out;
- if no explicit Evaluation Activity has been defined for the SFR then conformance is subsequently determined as if the full text of the standard is included as part of the SFR, applying the SARs that have been selected for the ST.

D.3.7.2 Security Assurance Requirements (SARs)

The ST specifies the set of SARs applicable to the evaluation of a TOE.

If the ST conforms to a PP or PP-Configuration, then the set of SARs shall be consistent with the PP or PP-Configuration.

If the ST conforms to a multi-assurance PP-Configuration, then either:

- the ST applies one set of SARs to the entire TOE and TSF (consistent with the global assurance package defined in the PP-Configuration). In this case, the TOE shall be evaluated following the single-assurance approach; or
- the ST defines the global set of SARs that applies to the entire TOE and the sets of SARs that apply to each of the sub-TSF defined in the PP-Configuration (consistent with the sets of SARs defined in the PP-Configuration). In this case, the TOE shall be evaluated following the multi-assurance approach.

1) [selection: **TSF, TOE platform**]

2) [selection:

— RSA schemes using cryptographic key sizes of 2048-bit or greater that meet the following: [selection:

— **FIPS PUB 186-4, “Digital Signature Standard (DSS)”, Appendix B.3;**

— **ANSI X9.31-1998, Section 4.1];**

— ECC schemes using “NIST curves” P-256, P-384 and [selection: P-521, no other curves] that meet the following: FIPS PUB 186-4, “Digital Signature Standard (DSS)”, Appendix B.4;

— FFC schemes using cryptographic key sizes of 2048-bit or greater that meet the following: FIPS PUB 186-4, “Digital Signature Standard (DSS)”, Appendix B.1]

A multi-assurance ST, and STs that augment the SARs of the PPs/PP-Configurations they conform to, shall provide an assurance rationale to demonstrate the consistency of the sets of SARs.

D.3.8 TOE summary specification (ASE_TSS)

The objective for the TOE summary specification (TSS) is to provide potential consumers of the TOE with a description of how the TOE satisfies all the SFRs. The TOE summary specification provides the general technical mechanisms that the TOE uses for this purpose. The level of detail of this description shall be sufficient to enable potential consumers to understand the general form and implementation of the TOE.

The TSS includes a natural language description describing the implementation of the SFRs, part of which describes how the SFRs combine together to provide security functionality in terms of the architecture that is visible (observable) to Administrators and other users, or in terms of internal features or properties.

EXAMPLE 1 The following are examples of internal features:

- unavailability of residual data upon reallocation of a resource;
- hidden failure conditions of login/password-authentication;
- hidden biometric comparison score.

EXAMPLE 2 If the TOE is an Internet PC and the SFRs contain FIA_UAU.1 to specify authentication, the TOE summary specification indicates how this authentication is done: password, token, iris scanning etc. More information, like applicable standards that the TOE uses to meet SFRs, or more detailed descriptions can also be provided.

EXAMPLE 3 The TOE summary specification can reference Technical standards, for instance: “The TOE provides cryptographic functionality to perform an AES encryption and decryption with 128, 192- or 256-bits keys to the embedded software. The AES algorithm conforms with ISO/IEC 18033-3:2010, 5.2.”

NOTE The ST is an input to ADV, which means that ADV allows to point out inconsistencies between TSS and other specifications. However, there is no dedicated evaluation activity specified, which reflects the fact that the TSS provides an overview of the realization of the SFRs by the TOE but does not constitute an implementation specification.

D.4 Direct Rationale STs

D.4.1 General

In some situations, it is appropriate to omit the definition of the TOE security objectives. In this case the Security Requirements rationale directly maps the SFRs and, where appropriate, security objectives for the operational environment, to the SPD.

The intention of the Direct Rationale ST is to minimize the level of indirection between the SPD, any security objectives for the operational environment, and the SFRs, based on an enhanced description of the SFRs.

The differences found in a Direct Rationale ST are in the conformance claims, security objectives and in the SPD sections. These are described in D.4.2 and D.4.3, below.

The content of a Direct Rationale ST is shown in Figure D.2.

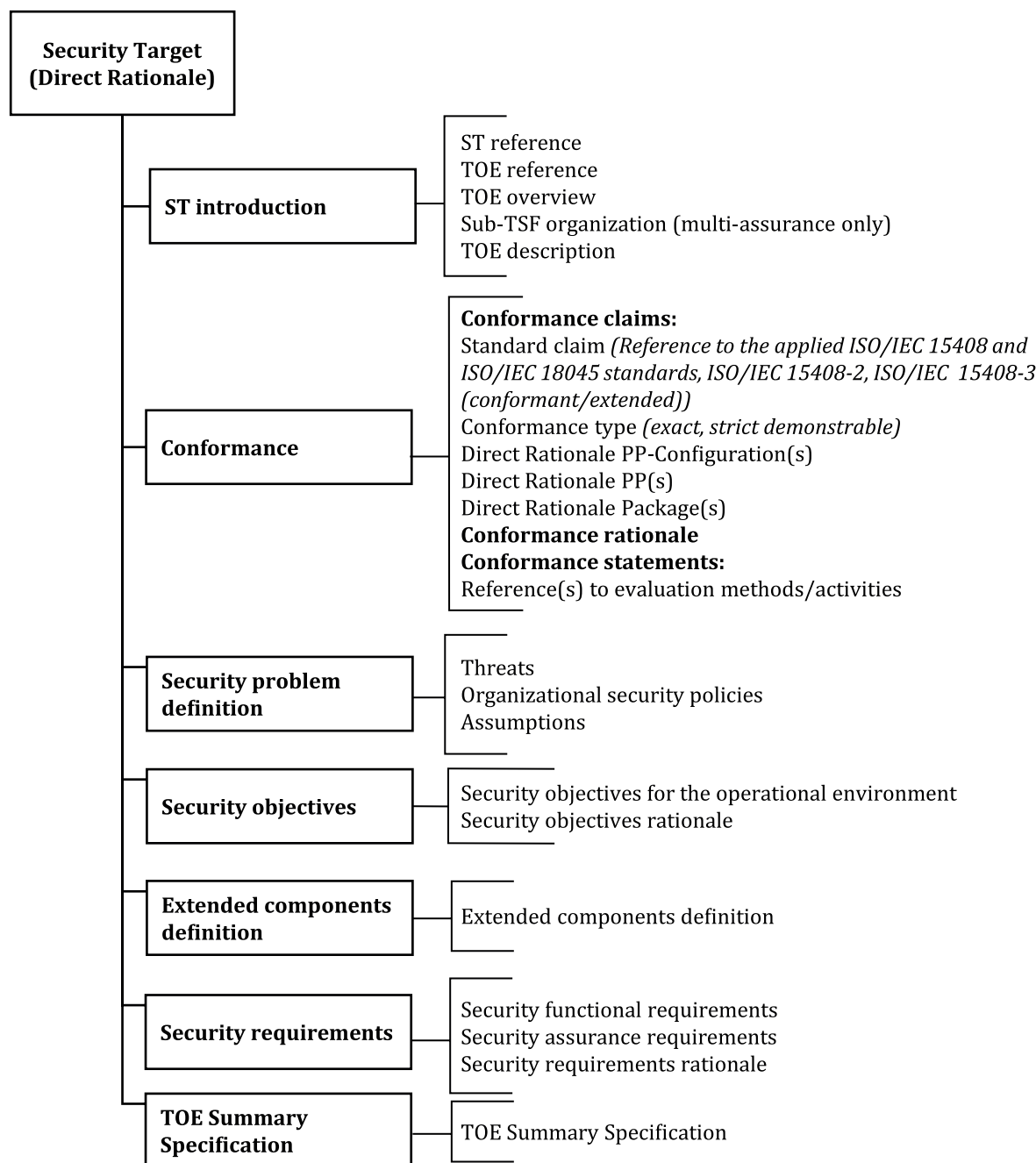


Figure D.2 — Contents of a Direct Rationale ST

D.4.2 Conformance claims (ASE_CCL) for Direct Rationale STs

A Direct Rationale ST shall only claim conformance to other Direct Rationale PPs, see 12.2 and Annex B.

A Direct Rationale ST shall only claim conformance to a PP-Configuration that uses the Direct Rationale approach, see 12.2.

D.4.3 Security Problem Definition (SPD) (ASE_SPD) for Direct Rationale STs

A Direct Rationale ST has the following differences with respect to security objectives when compared to a ST that contains security objectives for the TOE:

- security objectives for the TOE are not included. The security objectives for the environment shall still be described;

- a security objectives rationale included only for the security objectives for the operational environment since there are no TOE security objectives in the ST.

D.4.4 Security Problem Requirements (ASE_REQ) for Direct Rationale STs

A security requirements rationale that directly maps the SFRs and any security objectives for the operational environment to the SPD-elements is included. It is recommended that this part of the security requirements rationale is located directly under each of the threats, OSPs and assumptions in the SPD section. As in STs that contain security objectives for the TOE, the security requirements rationale also needs to justify the absence of superfluous SFRs and any SFR dependencies that are not satisfied; this part of the rationale is typically located after the definition of the SFRs.

D.5 Referring to other standards in a ST

Referring to standards in a ST is similar to the section on standards for PPs as described in B.4. Examples are given in D.3.7.1.2 and D.3.7.2.

Annex E **(normative)**

PP/PP-Configuration conformance

E.1 General

A PP is intended to be used as a “template” for a ST. i.e. the PP/PP-Configuration describes a set of user needs, while a ST that conforms to that PP/PP-Configuration describes a TOE that satisfies those needs.

The ISO/IEC 15408 series does not allow any form of partial conformance, so if PP/PP-Configuration conformance is claimed, the ST shall conform to the referenced PP(s) or PP-Configuration.

NOTE 1 In the case of selection-based or optional SFRs, the inclusion or exclusion of these types of SFRs as outlined in 7.3.2.6 is not considered partial conformance and so is allowed.

The ISO/IEC 15408 series defines three types of conformance: “demonstrable”, “strict” and “exact” where the type of conformance allowed is determined by the PP/ PP-Configuration (and indirectly its PPs and PP-Modules), i.e. the PP/PP-Configuration states, in its conformance statement what the allowed types of conformance for the derivative STs are.

As indicated in 10.5, if a PP/PP-Configuration specifies exact conformance, then a ST shall only claim exact conformance to that PP/PP-Configuration, and any other PP to which the ST claims conformance shall also require exact conformance. If the PP is included in a PP-Configuration (either by itself, or as a base PP to a PP-Module in that PP-Configuration), then the PP-Configuration itself and all other components of the PP-Configuration also require exact conformance.

The distinction between demonstrable and strict conformance when such conformance statements are contained in multiple PPs to which a ST is claiming conformance is applicable to each PP to which a ST may claim conformance on an individual basis. This can mean that the ST conforms strictly to some other PPs and demonstrably to other PPs.

A ST with exact conformance type shall claim conformance to a PP/PP-Configuration only if the PP/PP-Configuration is of exact conformance type and explicitly allows this.

A ST shall only claim demonstrable conformance to a PP/PP-Configuration if the PP/PP-Configuration explicitly allows this.

NOTE 2 Demonstrable conformance means that STs claiming conformance with the PP or PP-Configuration has to offer a solution to the generic security problem described in the PP/PP-Configuration, but can do so in any way that is equivalent or more restrictive to that described in the PP/PP-Configuration. In principle that means that the ST can contain statements that vary from the PP/PP-Configuration, provided that overall the ST levies the same or more restrictions on the TOE, and the same or less restrictions on the operational environment of the TOE.

It is also possible for a PP to be used as a template for another PP that specifies either strict or demonstrable conformance type, i.e. PPs specifying either strict or demonstrable conformance can claim conformance to other PPs. This case is completely similar to that of a ST vs. a PP.

When the ST conforms with a PP-Configuration and this PP-Configuration is not of exact conformance, then the ST may be required to conform in a strict and in a demonstrable manner depending on the conformance types of the PP-Configuration components.

The conformance of a PP to a PP-Configuration is not allowed regardless of the conformance types.

E.2 Demonstrable conformance

Demonstrable conformance is orientated to the PP/PP-Configuration sponsor who requires evidence that the ST is a suitable solution to the generic security problem described in the PP/PP-Configuration.

Where there is a clear subset-superset type relation between PP/PP-Configuration and ST in the case of strict conformance, the relation is less clear-cut in the case of demonstrable conformance. STs claiming conformance to the PP/PP-Configuration shall offer a solution to the generic security problem described in the PP/PP-Configuration.

However, claiming conformance is allowed only in the case that the ST imposes the same, or more, restrictions on the TOE and the same, or less, restrictions on the operational environment of the TOE.

E.3 Strict conformance

Strict conformance is oriented to the PP/PP-Configuration sponsor who requires evidence that the requirements in the PP/PP-Configuration are met, that the ST is an instantiation of the PP/PP-Configuration, though the ST can be broader than the PP/PP-Configuration. In essence, the ST specifies that the TOE does at least the same as in the PP/PP-Configuration, while the operational environment does at most the same as in the PP/PP-Configuration.

EXAMPLE A typical example of the use of strict conformance is in selection-based purchasing where an IT product's security requirements are expected to match those specified in the PP/PP-Configuration.

A ST instantiating strict conformance to a PP/PP-Configuration may still introduce additional restrictions to those given in the PP/PP-Configuration.

E.4 Exact conformance

E.4.1 General

Exact conformance is oriented to the PP/PP-Module sponsor who requires evidence that the requirements in the PP/PP-Module are met, and that the ST is an instantiation of exactly those security requirements (SFRs) without including additional functionality. In essence, the ST specifies that the TOE does what is required by the PP or a PP-Configuration containing a PP-Module, without making additional claims.

If “exact” conformance is selected, the PP/PP-Module author also has the option of specifying the following information:

- a) other PPs to which a ST may claim conformance in combination with the subject PP/PP-Module and still maintain exact conformance;
- b) PP-Modules that may be specified with the PP/PP-Module and still maintain exact conformance.

The ISO/IEC 15408 series allows STs to claim exact conformance to multiple PPs as long as all PPs require exact conformance in their allowed-with statement and allow the claim with the other PPs specified. The ISO/IEC 15408 series allows STs to claim exact conformance to a PP-Configuration as long as the PP-Configuration requires exact conformance and the STs do not claim conformance to any other PP or PP-Configuration.

The ISO/IEC 15408 series also allows PPs to claim conformance to one or more PPs. However, in the case where the PP being claimed requires exact conformance the potential to circumvent the intent of exact conformance becomes apparent. This is because requirements can be added that the exact conformance PP's authors would not find appropriate for use with the claimed PP. Therefore, if a PP requires exact conformance, another PP shall not claim any type of conformance to that PP. This

restriction gives the exact conformance PP author more control over the functionality and assurance provided for conformant STs than either strict or demonstrable conformance does.

EXAMPLE 1 If a ST can claim conformance to PP A (which requires exact conformance) and to PP B (which requires demonstrable conformance) at the same time, this would pull in SFRs which PP A's author did not explicitly approve to be used in combination with PP A's functionality when a ST claims conformance to PP A.

As indicated above, it is allowed for a ST to claim exact conformance with multiple exact conformance PPs. Also, a PP-Configuration is allowed to include multiple components (PPs, base PPs, PP-Modules and base PP-Modules) that require exact conformance. In order to allow PP authors to maintain control of which PP-Configuration components may be claimed along with their PP, the allowed-with statement in the PP, described in B.2.3, may be included that specifies which PPs a ST author may simultaneously claim conformance to with the subject PP. All identified PPs shall require exact conformance in their allowed-with statement and shall also list the subject PPs, and all other PPs being claimed, in their allowed-with statement. The same construct is used for PP-Modules and base PPs, as well as any base PP-Modules that may be specified. Example 2 is provided to clarify the concept of a ST claiming conformance to multiple PPs.

EXAMPLE 2 For the ST example, suppose PP B's authors wanted to allow STs to claim conformance to PP "B" and also to allow conformance claims to it in combination with PP "C". This situation is pictured in Figure E.1.

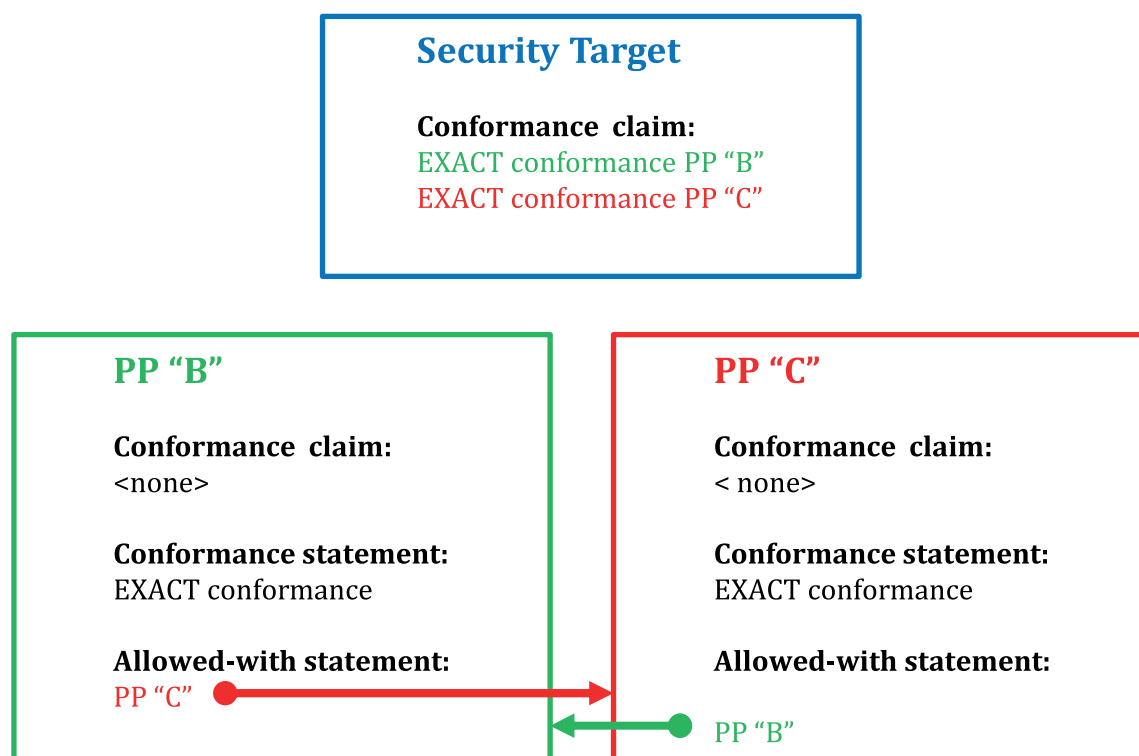


Figure E.1 — Exact conformance of a ST to multiple PPs

Then the following would have to be true:

- both PP B and PP C would have to specify exact conformance in their conformance statement;
- PP B would list PP C as allowed-with PP B in its allowed-with statement;
- PP C would list PP B as allowed-with PP C in its allowed-with statement.

If any of these statements did not hold, then the ST cannot claim exact conformance to PPs B and C.

This concept also extends to PP-Modules and PP-Configurations. A PP-Module shall identify a set of PP-Module Base; if one of the identified PP-Module Base has a conformance statement of exact conformance, then all of the PP-Module Base specified by the PP-Module shall also have conformance statements

specifying exact conformance. Further, in order to ensure that the PP-Modules are allowed for use with the PP-Module Base, each PP-Module Base specifies in its allowed-with statement the PP-Modules that are allowed to specify it as a PP-Module Base for use in a PP-Configuration.

NOTE The reverse is not true; a PP-Module does not need to specify any of its PP-Module Base in the Allowed-with statement because it has implicitly done so by defining the PP/PP-Module as a PP-Module Base.

A PP-Module also specifies which other PP-Modules or PPs that are not already included as one of the PP-Module's PP-Module Base, can be used in combination with it in a PP-Configuration.

EXAMPLE 3 Figure E.2 describes a case for exact conformance involving both PPs and PP-Modules.

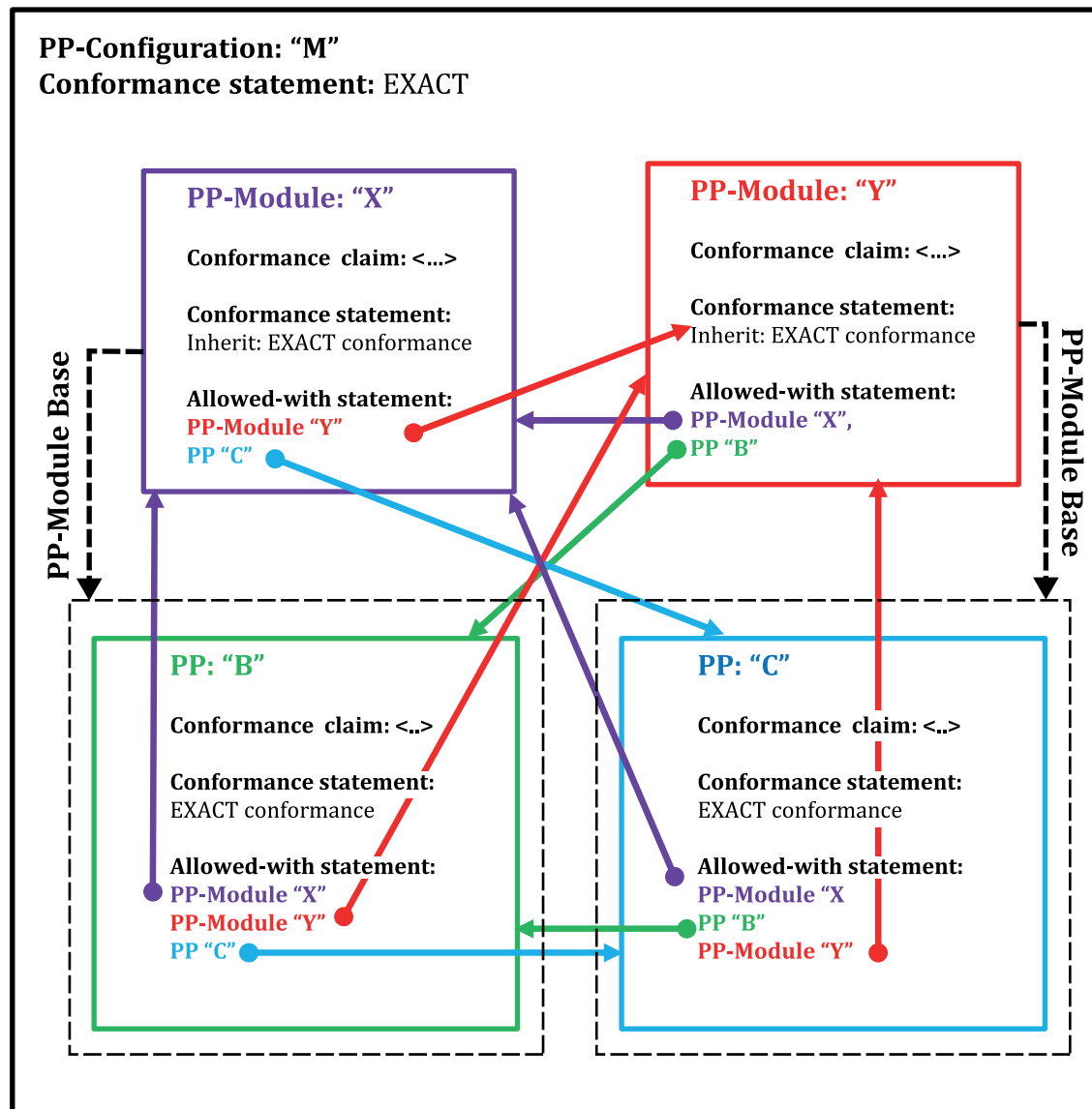


Figure E.2 — Exact conformance with a PP-Configuration including multiple PPs and PP-Modules

E.4.2 Exact conformance FAQs/cheat-sheet

Table E.1 gives a summary of frequently asked questions about the exact conformance case.

Table E.1 — Exact conformance summary

PP-Configurations	Reference	Allowed/Required?
Can be used in multi-assurance – modular PP-Configuration?	Figure 5	Yes
Can be used in single assurance – modular PP-Configuration?	Figure 5	Yes
Can mix EC with strict/demonstrable conformance types	10.8.1	No
Other EC PPs allowed in EC PP-Configuration		Yes
EC PP		
Optional/Selection-based SFRs in EC PP	12.4.1	Yes
Additional SPD elements associated with optional SFRs		Yes
EC PP claim conformance to another EC PP? (Chained)	10.8.1 10.10.3 B.3.2.2	No
Other EC PPs allowed in EC PP-Configuration		Yes
PP build upon strict or demonstrable PP?		No
Can be used in strict or demonstrable PP-Configuration?		No
States which other EC PPs are “Allowed-with”		Yes
States which other EC PP-Modules are “Allowed-with”	11.2.3.3 d)	Yes
EC PP-Modules		
Optional/Selection-based SFRs in EC PP-Module	11.2.3.3	Yes
EC PP-Module doesn’t include components in its PP-Module Base in its allowed-with statement.	11.2.3.3 d)	Yes
States other EC PPs and PP-Modules are allowed-with	11.2.3.3 d)	Yes
All Allowed-with items also EC	11.2.3.3 d)	Yes
EC functional Packages		
Optional/Selection-based SFRs allowed in EC functional Package		Yes
Functional packages can be augmented in the ST		No
Are claimed in a ST conformance claim	12.2 d)	No
EC STs		
Contains the SPD of all EC PPs, and/or PP-Configuration components	12.4.3	Yes
Additional or hierarchically higher security requirements?	12.4.4	No
Includes only those selection-based requirements that have been selected	12.4.4	Yes
Can be used with Direct Rationale approach		Yes

Bibliography

ISO/IEC standards and guidance

- [1] ISO/IEC 8367, *Information technology — Security techniques — Cryptographic algorithms and security mechanisms conformance testing*
- [2] ISO/IEC 15408-4:2022, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 4: Framework for the specification of evaluation methods and activities*
- [3] ISO/IEC 15408-5:2022, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 5: Pre-defined packages of security requirements*
- [4] ISO/IEC 15446, *Information technology — Security techniques — Guidance for the production of Protection Profiles and STs*
- [5] ISO/IEC/TR 18018:2010, *Information technology — Systems and software engineering — Guide for configuration management tool capabilities*
- [6] ISO/IEC/TR 18031:2011, *Information technology — Security techniques — Random bit generation*
- [7] ISO/IEC 18033-3:2010, *Information technology — Security techniques — Encryption algorithms — Part 3: Block ciphers*
- [8] ISO/IEC 19608, *Information technology — Security techniques — Guidance for developing security and privacy functional requirements based on ISO/IEC 15408*
- [9] ISO/IEC 19249, *Information technology — Security techniques — Catalogue of architectural and design principles for secure products, systems, and applications*
- [10] ISO/IEC 19790, *Information technology — Security techniques — Security requirements for cryptographic modules*
- [11] ISO/IEC 19791, *Information technology — Security techniques — Security assessment of operational systems*
- [12] ISO/IEC 19896-1, *IT security techniques — Competence requirements for information security testers and evaluators — Part 1: Introduction, concepts and general requirements*
- [13] ISO/IEC 19896-3, *IT security techniques — Competence requirements for information security testers and evaluators — Part 3: Knowledge, skills and effectiveness requirements for ISO/IEC 15408 evaluators*
- [14] ISO/IEC 20004, *Information technology — Security techniques — Refining software vulnerability analysis under ISO/IEC 15408 and ISO/IEC 18045*
- [15] ISO/IEC TR 22216, *Information security, cybersecurity and privacy protection — New concepts and changes in ISO/IEC 15408:2022 and ISO/IEC 18045:2022*
- [16] ISO/IEC 27001, *Information technology — Security techniques — Information security management systems — Requirements*
- [17] ISO/IEC 27002, *Information security, cybersecurity and privacy protection — Information security controls*
- [18] ISO/IEC 27034 (all parts), *Information technology — Application security*

Catalogues of PPs and evaluated products

- [19] Common Criteria portal: Certified Products, available at <http://www.commoncriteriaportal.org/products/>
- [20] Common Criteria portal: Protection Profiles, available at <http://www.commoncriteriaportal.org/pps/>
- [21] Common Criteria portal: Collaborative Protection Profiles, available at <http://www.commoncriteriaportal.org/pps/?cpp=1>